CYBERSNOVA CYBER SECURITY INTERNSHIP REPORT

Name: Shaurya Gupta
Email: shauryagupta0106@gmail.com
Reference No.: CSN-OC-OL-26194
Registration No.: CSN-OC-2026-194
Domain: Cyber Security
Project Level: Beginner And Intermediate
Internship Month/Year: October 2026

Project Description Table

S. No.	Project Description	Page No.
1	Network Reconnaissance and Service Enumeration using Nmap and related tools	02
2	Hidden Directory and File Enumeration using Gobuster, Dirsearch and Dirb	32
3	Login Traffic Analysis using Wireshark/TShark and HTTP request inspection	86
4	Basic Web Vulnerability Assessment using Nikto and HTTP response analysis	121
5	OWASP Juice Shop Security Assessment	164
6	PortSwigger Web Security Academy: Five Apprentice-Level Labs	237

CYBERSNOVA INTERNSHIP PROJECT REPORT

Intern Details

Field	Details
Name	SHAURYA GUPTA
Email	shauryagupta0106@gmail.com
Reference No.	CSN-OC-OL-26194
Registration No.	CSN-OC-2026-194
Domain	Cyber Security
Project Level	Beginner
Internship Month/Year	October 2026

Project Title: Network Reconnaissance and Service Enumeration Using Nmap, WhatWeb, Netcat, and curl

Target: testphp.vulnweb.com

Assessment Type: Basic external reconnaissance and conservative TCP service enumeration.

Assessment Environment: Kali GNU/Linux Rolling, Version 2026.3, running in a virtualized environment.

Report Status: Completed with documented connectivity limitations.

---

1. Introduction

Network reconnaissance is the process of collecting information about a target system, its network presence, accessible services, and externally observable characteristics. It is commonly performed during the initial stages of an authorized cybersecurity assessment.

Service enumeration builds upon reconnaissance by examining network ports and attempting to identify the services associated with them. Tools such as Nmap help determine whether TCP ports appear open, closed, or filtered. Web fingerprinting tools such as WhatWeb attempt to identify technologies from HTTP responses, while curl and Netcat can be used to inspect HTTP connectivity and server responses.

This project demonstrates a basic external reconnaissance workflow against the designated training target, testphp.vulnweb.com. The assessment included DNS resolution, HTTP and HTTPS connectivity checks, TCP port scanning, web technology fingerprinting, and attempts to establish direct TCP and TLS connections.

The primary objective was to collect reproducible evidence, interpret the results accurately, and understand the limitations of network scanning when the target does not respond to connection attempts.

The assessment also demonstrates an important principle of cybersecurity: a tool failure is not proof of a vulnerability, and an unresponsive service must not be reported as a confirmed security weakness without supporting evidence.

2. Problem Statement

The objective of this project was to perform basic network reconnaissance and service enumeration against the designated practice website.

The assessment aimed to:

1. Resolve the target hostname to its associated IP address.
2. Check basic HTTP and HTTPS connectivity.
3. Scan the top 100 TCP ports to identify their observable states.
4. Examine ports 80 and 443 for web service availability.
5. Attempt to identify web technologies using WhatWeb.
6. Attempt to retrieve HTTP response information using curl and Netcat.
7. Preserve the results and explain any limitations encountered.

The assessment encountered repeated connection timeouts and other connection failures. Consequently, the project documents the information successfully collected and distinguishes it from information that could not be verified.

3. Scope and Target

Field	Details
Target hostname	testphp.vulnweb.com
Target URL	http://testphp.vulnweb.com/
Resolved IPv4 address	44.228.249.3
Reverse DNS	ec2-44-228-249-3.us-west-2.compute.amazonaws.com
Assessment type	Basic external reconnaissance
Port scope	Top 100 TCP ports
Additional port checks	TCP ports 80 and 443
DNS checks	A, AAAA, CNAME records and system resolver lookup

Field	Details
Assessment date	23 October 2026, as recorded in terminal evidence
Nmap scan start	23 October 2026, 12:08:23 -0400, for the completed top-100 scan
Nmap scan duration	202.87 seconds
Operating system	Kali GNU/Linux Rolling 2026.3
Authorization basis	Training target identified in the supplied CyberSNova task information

Only the hostname, ports, and checks documented in the supplied terminal evidence are included in the reported scope. No successful exploitation, authentication testing, or vulnerability confirmation was performed.

4. Tools Used

4.1 Nmap

Nmap is a network exploration and security auditing tool. It sends network probes to identify hosts and determine the observable state of ports.

In this project, Nmap was used to scan the top 100 TCP ports with a conservative timing profile. A separate scan examined ports 80 and 443 with lightweight service detection.

The completed scan reported all 100 TCP ports as filtered, with no responses received. The separate web-port scan also reported ports 80 and 443 as filtered.

These findings indicate that Nmap could not establish the port states through the expected responses. They do not establish that the services are permanently unavailable or that the target has no running services.

4.2 WhatWeb

WhatWeb is a web technology fingerprinting tool. It attempts to identify web servers, content management systems, frameworks, libraries, and other technologies by examining responses and recognizable characteristics.

Multiple WhatWeb attempts were made against the target. The observed output included:

ERROR Opening: http://testphp.vulnweb.com/ - execution expired

A subsequent attempt reported:

ERROR Opening: http://testphp.vulnweb.com/ - Connection refused - connect(2) for “44.228.249.3” port 80

Other attempts again ended with an execution timeout.

No successful WhatWeb fingerprint was obtained in the supplied evidence. Therefore, no specific web server, framework, programming language, or content management system is claimed as detected by this assessment.

4.3 Netcat

Netcat is a network utility that can establish TCP connections and exchange data with a remote endpoint.

The project attempted to send a basic HTTP HEAD request to the target on TCP port 80.

The observed output was:

nc: getaddrinfo for host “testphp.vulnweb.com” port 80: Name or service not known

This particular Netcat attempt failed during hostname resolution. It did not return an HTTP response, and it cannot be used as evidence of a successful TCP connection.

The failure also contrasts with the successful DNS lookups performed using dig and getent at other points in the assessment. This may indicate a transient or resolver-specific problem, but the available evidence does not establish its exact cause.

4.4 curl

curl is a command-line utility for transferring data using protocols including HTTP and HTTPS. It can retrieve response headers, report HTTP status codes, and display connection diagnostics.

In this project, curl was used to test HTTP connectivity, save response headers, summarize the HTTP status, and attempt an HTTPS header request.

The HTTP connectivity test reported:

curl: (28) Connection timed out after 10009 milliseconds

The HTTP status summary reported:

HTTP status: 000 Remote IP: HTTP version: 0

The HTTPS request also timed out.

HTTP status 000 is curl’s indication that no HTTP response status was received. It is not an HTTP status code returned by the target.

The response-header file was empty when inspected. Therefore, no server response headers were confirmed.

4.5 dig and getent

dig was used to query DNS A, AAAA, and CNAME records. getent was used to check hostname resolution through the system's configured name-service mechanisms.

These tools successfully resolved the target to the IPv4 address 44.228.249.3 during the recorded checks.

The AAAA and CNAME queries returned no answer records in the captured output. This means that no matching records were displayed in those particular responses. It should not be interpreted as proof that such records can never exist.

4.6 OpenSSL

OpenSSL's s_client utility was used to attempt a TLS connection to the target on TCP port 443.

The attempt ended with a timeout:

timeout 12 openssl s_client -connect testphp.vulnweb.com:443 -servername testphp.vulnweb.com -brief </dev/null

Observed terminal result:

zsh: exit 124

The command timed out before a successful TLS session was confirmed. No TLS certificate details or negotiated protocol were verified.

5. Methodology

The following workflow was followed using the supplied terminal evidence.

Step 1: Prepare the project directory

The project structure was created with directories for reports, screenshots, results, and logs.

The working directory was confirmed as:

/home/kali/SHAURYA_GUPTA/Project_1_Network_Reconnaissance

Step 2: Record the environment

The operating system and installed tool versions were checked. The recorded environment was Kali GNU/Linux Rolling, Version 2026.3.

Nmap, WhatWeb, Netcat, curl, DNS utilities, and OpenSSL were confirmed as installed.

Step 3: Resolve the target hostname

DNS queries were made for A, AAAA, and CNAME records. The system resolver was also tested using getent.

The A-record query returned 44.228.249.3.

Step 4: Check HTTP and HTTPS connectivity

curl was used to request HTTP response headers and summarize the response status. A separate HTTPS request was attempted.

Both checks timed out in the supplied evidence. The HTTP status summary recorded status 000, with no remote IP or HTTP version reported.

Step 5: Scan the top 100 TCP ports

The following Nmap command was used:

nmap -sT -Pn -T2 –top-ports 100 –version-light –reason -oA results/nmap_top100 testphp.vulnweb.com

The completed scan identified the target IP address and reported all 100 scanned ports as filtered with no response.

Step 6: Examine web ports

A separate Nmap scan examined TCP ports 80 and 443:

nmap -sT -Pn -T2 -sV –version-light –reason -p 80,443 -oA results/nmap_web_services testphp.vulnweb.com

Both ports were reported as filtered, with the reason recorded as no-response.

Step 7: Perform web fingerprinting

WhatWeb was executed multiple times. The observed attempts ended with execution timeouts or a connection-refused error. No successful technology fingerprint was obtained.

Step 8: Attempt direct HTTP and TLS connections

Netcat was used to send an HTTP HEAD request, while OpenSSL was used to attempt a TLS handshake.

The Netcat attempt failed during hostname resolution. The OpenSSL attempt timed out.

Step 9: Preserve and interpret the evidence

Command output was saved in the results directory using tee and Nmap's output options. The available evidence was reviewed to separate confirmed observations from unverified assumptions.

The assessment did not treat missing responses as proof of a vulnerability or as proof that no services exist.

6. Findings

6.1 DNS and Connectivity

DNS resolution

The following A-record result was captured:

testphp.vulnweb.com. 4319 IN A 44.228.249.3

The getent lookup also returned:

44.228.249.3 testphp.vulnweb.com

The reverse DNS name reported by Nmap was:

ec2-44-228-249-3.us-west-2.compute.amazonaws.com

DNS findings

Check	Observed result	Interpretation
DNS A record	44.228.249.3	IPv4 address resolved
DNS AAAA record	No answer record shown	No IPv6 address confirmed by this quer
DNS CNAME record	No answer record shown	No CNAME confirmed by this query
getent lookup	44.228.249.3	System hostname resolution succeeded
HTTP connectivity	Connection timeout	No HTTP response obtained
HTTPS connectivity	Connection timeout	No successful HTTPS response obtained

The target hostname resolved successfully, so DNS resolution was possible during the successful queries. However, successful hostname resolution did not lead to a successful HTTP or HTTPS connection.

HTTP response status

The recorded summary was:

HTTP status: 000 Remote IP: HTTP version: 0

This confirms that curl did not obtain an HTTP response in that attempt. It does not establish that the target returned an HTTP error page.

Connectivity conclusion

The available evidence establishes a difference between DNS reachability and TCP application connectivity. DNS returned an address, but the attempted web connections did not produce HTTP responses.

Possible explanations include network filtering, an unavailable destination service, an intermediate firewall, routing issues, or transient network conditions. The supplied evidence does not establish which explanation is correct.

Evidence files: - results/dns.txt - results/dns_ipv6.txt - results/dns_cname.txt - results/resolved_addresses.txt - results/http_headers.txt - results/http_status.txt - results/https_check.txt

6.2 Nmap Port and Service Enumeration

Top 100 TCP ports

The completed Nmap scan reported:

Nmap scan report for testphp.vulnweb.com (44.228.249.3) Host is up, received user-set. rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com All 100 scanned ports on testphp.vulnweb.com (44.228.249.3) are in ignored states. Not shown: 100 filtered tcp ports (no-response)

Nmap completed the scan in 202.87 seconds.

Results table

Field	Result
Scan type	TCP connect scan
Target IP	44.228.249.3
Port scope	Top 100 TCP ports
Open ports confirmed	None
Closed ports confirmed	None
Filtered ports	100
Reported reason	No response
Scan duration	202.87 seconds

No open TCP ports were confirmed in the completed top-100 scan. The scan also did not confirm any closed ports. All scanned ports were reported as filtered.

A filtered result generally means that Nmap could not determine whether the port was open or closed because expected network responses were not received or were blocked. This can occur when firewalls, packet filters, or network conditions prevent probes from reaching the destination or their responses from returning.

The output does not prove that every service on the destination is disabled.

Web-port scan

The separate Nmap scan reported:

PORT STATE SERVICE REASON VERSION 80/tcp filtered http no-response 443/tcp filtered https no-response

The service labels indicate the conventional services associated with those port numbers. They do not confirm that an HTTP or HTTPS service was successfully identified on the target.

No service versions were identified.

Evidence files: - results/nmap_top100.nmap - results/nmap_top100.xml - results/nmap_top100.gnmap - results/nmap_web_services.nmap - results/nmap_web_services.xml - results/nmap_web_services.gnmap

6.3 Web Technology Fingerprinting

Tool: WhatWeb 0.6.4

WhatWeb was run repeatedly against the target URL.

The recorded output included execution-expired errors and one connection-refused error involving port 80.

The extended-timeout attempt also failed, despite the use of increased connection and read timeouts.

Item	Finding
WhatWeb version	0.6.4
Successful page retrieval	Not confirmed
Web server identification	Not confirmed
Framework identification	Not confirmed
CMS identification	Not confirmed
Technology fingerprint	Not obtained
Main limitation	Connection failures and timeouts

Since WhatWeb did not successfully retrieve a usable response, the assessment cannot reliably identify the target's web technologies from the supplied output.

The absence of a fingerprint must not be interpreted as evidence that the website does not use a web server, programming language, or framework.

Evidence file: results/whatweb.txt

6.4 HTTP and Netcat Checks

curl observations

curl timed out while attempting to contact the target over HTTP and HTTPS.

The HTTP status summary recorded status 000, no remote IP, and HTTP version 0. The saved HTTP header file was empty when inspected.

Netcat observation

The Netcat command failed with:

nc: getaddrinfo for host "testphp.vulnweb.com" port 80: Name or service not known

This attempt failed before establishing the intended TCP connection. No HTTP status line, response headers, or response body were obtained.

TLS observation

The OpenSSL connection attempt did not complete within the 12-second timeout. No TLS handshake or certificate was confirmed.

Comparison

The curl and Netcat attempts both failed to retrieve HTTP response information. However, the specific errors differed: curl timed out while Netcat reported a hostname-resolution failure. These are separate observations and should not be treated as identical failures.

Because no HTTP response or TLS session was obtained, the project cannot confirm the target's response headers, HTTP server banner, certificate details, or negotiated TLS version.

Evidence files: - results/http_headers.txt - results/http_status.txt - results/https_check.txt - results/netcat_http.txt - results/tls_check.txt

7. Security Observations

7.1 External visibility

The target's IPv4 address and reverse DNS name were visible through the recorded DNS and Nmap results. This demonstrates that hostname resolution and some basic external information gathering were possible.

The availability of DNS information alone does not indicate a security vulnerability.

7.2 Filtered TCP ports

Nmap reported all 100 scanned TCP ports as filtered. Ports 80 and 443 were also filtered in the separate web-port scan.

From a defensive perspective, filtering can be consistent with a firewall or network policy that restricts unsolicited connections. However, the scan results do not identify the specific filtering mechanism or prove that the filtering was intentional.

7.3 Web service identification

WhatWeb could not obtain a usable response. Therefore, no web technology, software version, or application component was confirmed by this assessment.

The inability to fingerprint the website is an assessment limitation, not a confirmed vulnerability.

7.4 HTTP and TLS availability

The attempted HTTP and HTTPS connections did not complete successfully in the recorded tests. It is therefore not possible to determine from these results whether the target's web services were temporarily unavailable, blocked from the testing environment, or affected by another connectivity issue.

No conclusion about insecure TLS configuration, missing HTTPS support, or insecure HTTP behavior should be drawn solely from these failed connections.

7.5 Evidence-based reporting

This assessment highlights the importance of separating observed facts from assumptions. A filtered port is not necessarily closed, a timeout is not proof of a vulnerability, and a missing fingerprint is not proof that a technology is absent.

Further verification from an authorized and functioning assessment path would be required before making stronger claims.

8. Limitations

The following limitations affected the assessment:

1. **Limited port scope:** The completed general Nmap scan examined the top 100 TCP ports rather than every possible TCP port or any UDP ports.
2. **Filtered ports:** All 100 scanned TCP ports were reported as filtered, so the scan could not confirm open or closed states for those ports.
3. **Web connectivity failures:** HTTP and HTTPS requests timed out, preventing retrieval of web response data.
4. **Unsuccessful fingerprinting:** WhatWeb did not produce a successful technology fingerprint.
5. **Netcat resolution error:** The recorded Netcat attempt failed during hostname resolution and did not establish an HTTP connection.
6. **Unsuccessful TLS check:** The OpenSSL attempt timed out before a TLS session could be verified.
7. **Incomplete response evidence:** The saved HTTP header file was empty, and no HTTP response status line or TLS certificate was confirmed.
8. **Potential environmental restrictions:** Firewall rules, network routing, DNS behavior, transient outages, or restrictions between the virtual machine and the target may have influenced the results. The available evidence does not identify the precise cause.
9. **Time-specific results:** The observations describe the target's apparent behavior during the recorded assessment attempts. Network and service states can change over time.
10. **No vulnerability confirmation:** No successful exploitation, authenticated testing, or independent verification of a vulnerability was performed.

These limitations mean that the project can document DNS resolution and observed network filtering, but it cannot provide a complete inventory of the target's active web technologies or services.

9. Recommendations

The following recommendations are intended for the authorized owner or administrator of the assessed environment. They are defensive recommendations, not claims that a particular vulnerability was discovered.

9.1 Verify firewall and network policies

Review firewall, security group, and network access-control rules to ensure that only intended services are reachable from the public internet.

If the observed filtering is intentional, confirm that it aligns with the documented security policy.

9.2 Maintain an accurate external service inventory

Maintain an inventory of public-facing services and their business purposes. Disable unnecessary services and restrict administrative interfaces to trusted networks.

The current scan did not identify any open ports, so no specific exposed service can be recommended for removal based on these results alone.

9.3 Maintain supported and patched software

Keep operating systems, web servers, application frameworks, and dependencies updated with supported security fixes.

The assessment did not identify a specific software version, so it cannot establish whether the target is running vulnerable or outdated software.

9.4 Configure HTTP and HTTPS appropriately

Where web services are intended to be publicly accessible, verify HTTP and HTTPS availability from an authorized monitoring location. Configure HTTPS and TLS securely, and redirect HTTP traffic to HTTPS where appropriate.

The failed connection attempts do not prove that HTTPS is missing or incorrectly configured.

9.5 Minimize unnecessary information disclosure

Review server banners and response headers to avoid disclosing unnecessary implementation details. Such information should be evaluated only after a successful response has been obtained.

9.6 Investigate connectivity from an authorized environment

If the target is expected to be reachable, verify the service status, routing, firewall rules, and access restrictions from an approved network. Compare results with server-side logs where available.

Repeat the assessment only within the permitted scope and use genuine outputs to establish whether the earlier timeouts were transient.

9.7 Preserve and compare evidence

Retain dated scan outputs and repeat authorized checks periodically. Comparing verified results helps distinguish genuine changes in exposure from temporary connectivity problems.

10. Summary

This project performed basic external reconnaissance and TCP service enumeration against testphp.vulnweb.com using Kali Linux.

DNS resolution succeeded during the recorded checks, identifying the IPv4 address 44.228.249.3. The reverse DNS name was also recorded.

The completed Nmap scan examined the top 100 TCP ports and reported all 100 as filtered with no response. A separate scan found ports 80 and 443 filtered as well.

HTTP and HTTPS connection attempts using curl timed out. WhatWeb failed to retrieve the target, Netcat reported a hostname-resolution error during its HTTP request attempt, and the OpenSSL TLS connection attempt timed out.

As a result, the assessment did not confirm any open TCP ports, web technology fingerprints, HTTP response headers, server versions, or TLS certificate details.

The main outcome was a documented set of DNS, port-state, and connectivity observations. The project also demonstrated why scan results must be interpreted cautiously: filtering and connection failures limit what can be concluded about the target's services.

11. Screenshots and Evidence

Inserted genuine screenshots captured from the actual Kali terminal.

12. Conclusion

The project provided practical experience with the initial stages of an external cybersecurity assessment. It covered DNS resolution, TCP port scanning, web technology fingerprinting, HTTP connectivity checks, direct TCP connection attempts, and TLS connection testing.

The most important confirmed result was that the target hostname resolved to an IPv4 address, while the completed Nmap scans reported the tested TCP ports as filtered. Attempts to retrieve HTTP responses, identify web technologies, and establish a TLS session were unsuccessful in the supplied evidence.

The project demonstrated the importance of using multiple tools, saving outputs, interpreting errors accurately, and distinguishing confirmed observations from assumptions. It also showed that the absence of a response can restrict the conclusions an assessor can draw.

Further authorized testing from a verified network path would be necessary to establish the target's actual service availability and obtain reliable application-level information.

The findings in this report are limited to the commands and outputs provided. No vulnerability is claimed without supporting evidence.

Appendix A: Commands Used

The following commands are based on the supplied terminal history. Commands that were attempted are documented even when they did not produce successful results.

A.1 Project setup and environment

```
mkdir -p
~/SHAURYA_GUPTA/Project_1_Network_Reconnaissance/{report,screenshots,results,
logs}
cd ~/SHAURYA_GUPTA/Project_1_Network_Reconnaissance
pwd
date
cat /etc/os-release
whoami
```

A.2 Tool installation and verification

```
sudo apt update
sudo apt install -y nmap whatweb netcat-openbsd curl dnsutils openssl

nmap --version
whatweb --version
nc -h
curl --version
dig -v
```

A.3 DNS resolution

```
dig testphp.vulnweb.com A +noall +answer
dig testphp.vulnweb.com AAAA +noall +answer
dig testphp.vulnweb.com CNAME +noall +answer
getent ahosts testphp.vulnweb.com
getent hosts testphp.vulnweb.com
```

A.4 HTTP and HTTPS connectivity

```
curl --connect-timeout 10 --max-time 20 -sS \
  -D results/http_headers.txt -o /dev/null \
  http://testphp.vulnweb.com/

curl --connect-timeout 10 --max-time 20 -sS \
  -o /dev/null \
  -w 'HTTP status: %{http_code}\nRemote IP: %{remote_ip}\nHTTP version:
%{http_version}\n' \
  http://testphp.vulnweb.com/
```

```
curl --connect-timeout 10 --max-time 20 -sS -I \
  https://testphp.vulnweb.com/
```

A.5 Nmap enumeration

```
nmap -sT -Pn -T2 --top-ports 100 --version-light --reason \
  -oA results/nmap_top100 testphp.vulnweb.com

nmap -sT -Pn -T2 -sV --version-light --reason -p 80,443 \
  -oA results/nmap_web_services testphp.vulnweb.com
```

A.6 WhatWeb fingerprinting

```
whatweb --color=never http://testphp.vulnweb.com/

whatweb --color=never --open-timeout=20 --read-timeout=30 \
  --max-threads=1 http://testphp.vulnweb.com/
```

A.7 Netcat HTTP request

```
printf 'HEAD / HTTP/1.1\r\nHost: testphp.vulnweb.com\r\nConnection:
close\r\n\r\n' |
  nc -nv -w 8 testphp.vulnweb.com 80
```

A.8 TLS connection attempt

```
timeout 12 openssl s_client \
  -connect testphp.vulnweb.com:443 \
  -servername testphp.vulnweb.com \
  -brief </dev/null
```

A.9 Save command history

The original command log was saved as:

logs/commands.txt

The log contains the commands recorded in the terminal history. Additional troubleshooting commands should be appended if executed later.

Appendix B: Evidence Files

The following files were referenced or created by the commands shown in the supplied terminal history.

B.1 DNS and environment

- results/target.txt
- results/environment.txt
- results/dns.txt
- results/dns_ipv6.txt
- results/dns_cname.txt

- results/resolved_addresses.txt

B.2 HTTP, HTTPS, and connection checks

- results/http_headers.txt
- results/http_status.txt
- results/https_check.txt
- results/whatweb.txt
- results/netcat_http.txt
- results/tls_check.txt

B.3 Nmap outputs

- results/nmap_top100.nmap
- results/nmap_top100.xml
- results/nmap_top100.gnmap
- results/nmap_web_services.nmap
- results/nmap_web_services.xml
- results/nmap_web_services.gnmap

Nmap's -oA option requests output in normal, XML, and grepable formats. Confirm that each file exists before including it in the final submission.

B.4 Command log

- logs/commands.txt

B.5 Screenshots

The screenshots directory was created.

B.6 Final verification

Before submission, verify the actual directory contents using:

```
find results logs screenshots -maxdepth 2 -type f -printf '%p\n' | sort
```

End of Report

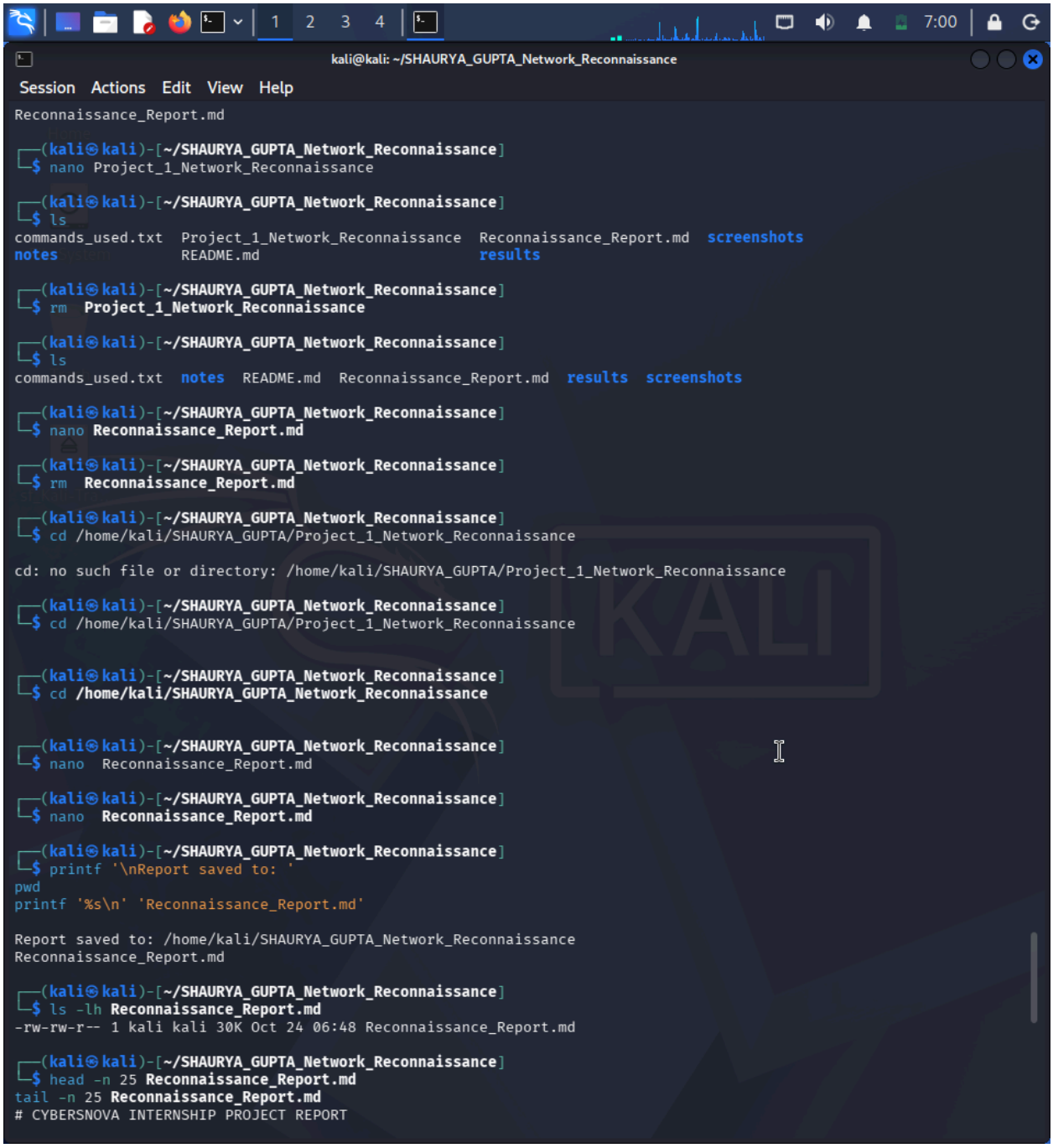
Prepared by: SHAURYA GUPTA
Domain: Cyber Security
Project: Network Reconnaissance and Service Enumeration
Organization: CyberSNova

kali@kali: ~/SHAURYA_GUPTA_Network_Reconnaissance
Session Actions Edit View Help
Project Title: Network Reconnaissance and Service Enumeration Using Nmap, WhatWeb, Netcat, and curl
Target: testphp.vulnweb.com
Assessment Type: Basic external reconnaissance and conservative TCP service enumeration.
Assessment Environment: Kali GNU/Linux Rolling, Version 2026.3, running in a virtualized environment.
Report Status: Completed with documented connectivity limitations.
B.4 Command log
- logs/commands.txt
B.5 Screenshots
The screenshots directory was created.
B.6 Final verification
Before submission, verify the actual directory contents using:
```bash
find results logs screenshots -maxdepth 2 -type f -printf '%p\n' | sort
```

End of Report
Prepared by: SHAURYA GUPTA
Domain: Cyber Security
Project: Network Reconnaissance and Service Enumeration
Organization: CyberSNova
(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
$ find results logs screenshots -maxdepth 2 -type f -printf '%p\n' | sort
find: 'logs': No such file or directory
results/dns_lookup.txt
results/http_get_summary.txt
results/http_response_headers.txt
results/http_summary.txt
results/netcat_connection.txt
results/netcat_http_head.txt
results/network_route.txt
results/nmap_console.txt
results/nmap_top100.txt
results/nmap_top100.xml
results/nmap_web_ports.txt
results/ping_test.txt
results/scan_timestamp.txt
results/whatweb_retry.txt
results/whatweb.txt
(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
$

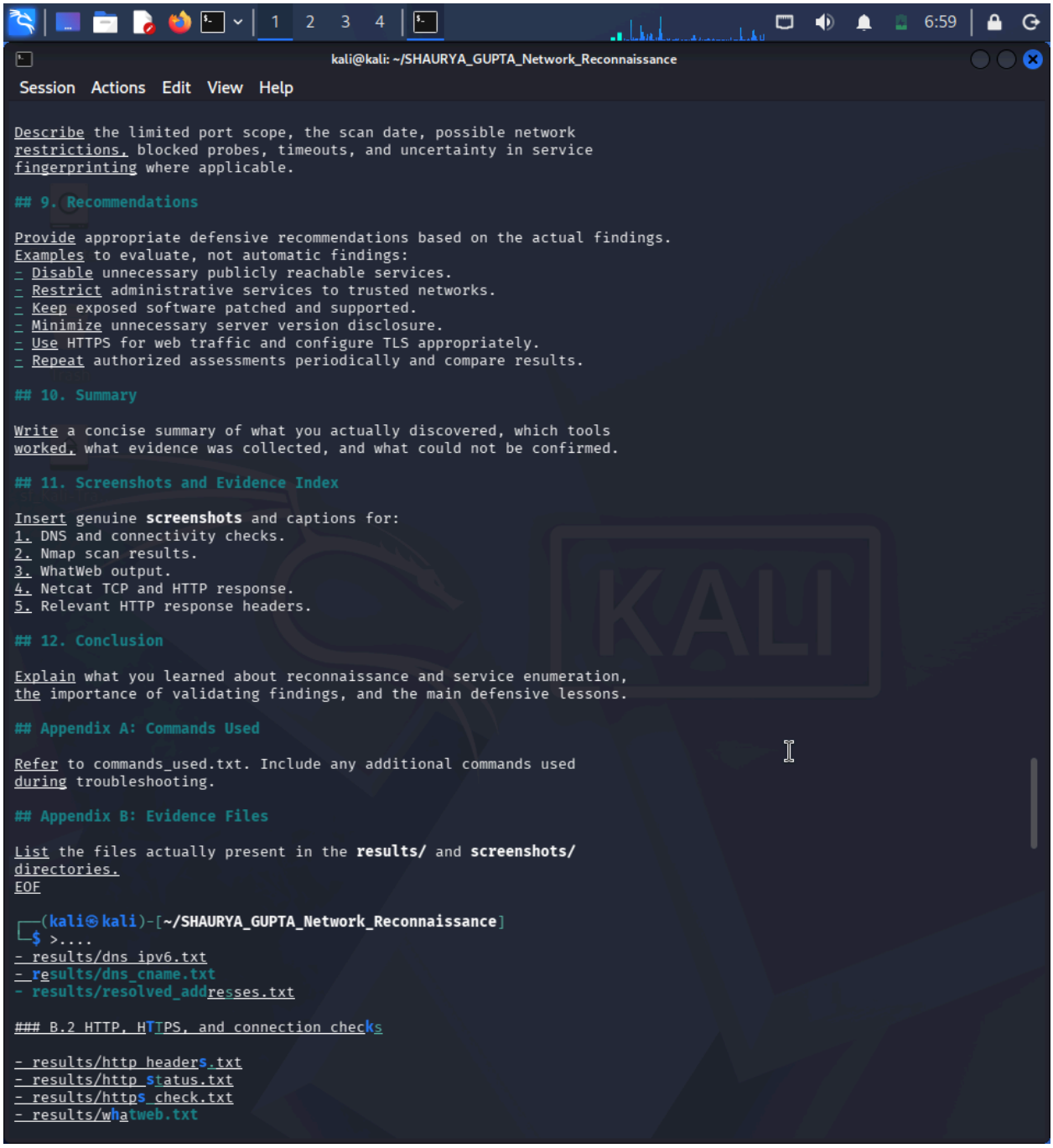
kali@kali: ~/SHAURYA_GUPTA_Network_Reconnaissance
Session Actions Edit View Help
└─$ ls -lh Reconnaissance_Report.md
-rw-rw-r-- 1 kali kali 30K Oct 24 06:48 Reconnaissance_Report.md
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ head -n 25 Reconnaissance_Report.md
tail -n 25 Reconnaissance_Report.md
CYBERSNOVA INTERNSHIP PROJECT REPORT
Intern Details
Field	Details
Name	SHAURYA GUPTA
Email	shauryagupta0106@gmail.com
Reference No.	CSN-OC-OL-26194
Registration No.	CSN-OC-2026-194
Domain	Cyber Security
Project Level	Beginner
Internship Month/Year	October 2026
Project Title: Network Reconnaissance and Service Enumeration Using Nmap, WhatWeb, Netcat, and curl
Target: testphp.vulnweb.com
Assessment Type: Basic external reconnaissance and conservative TCP service enumeration.
Assessment Environment: Kali GNU/Linux Rolling, Version 2026.3, running in a virtualized environment.
Report Status: Completed with documented connectivity limitations.
B.4 Command log
- logs/commands.txt
B.5 Screenshots
The screenshots directory was created.
B.6 Final verification
Before submission, verify the actual directory contents using:
```bash
find results logs screenshots -maxdepth 2 -type f -printf '%p\n' | sort
```

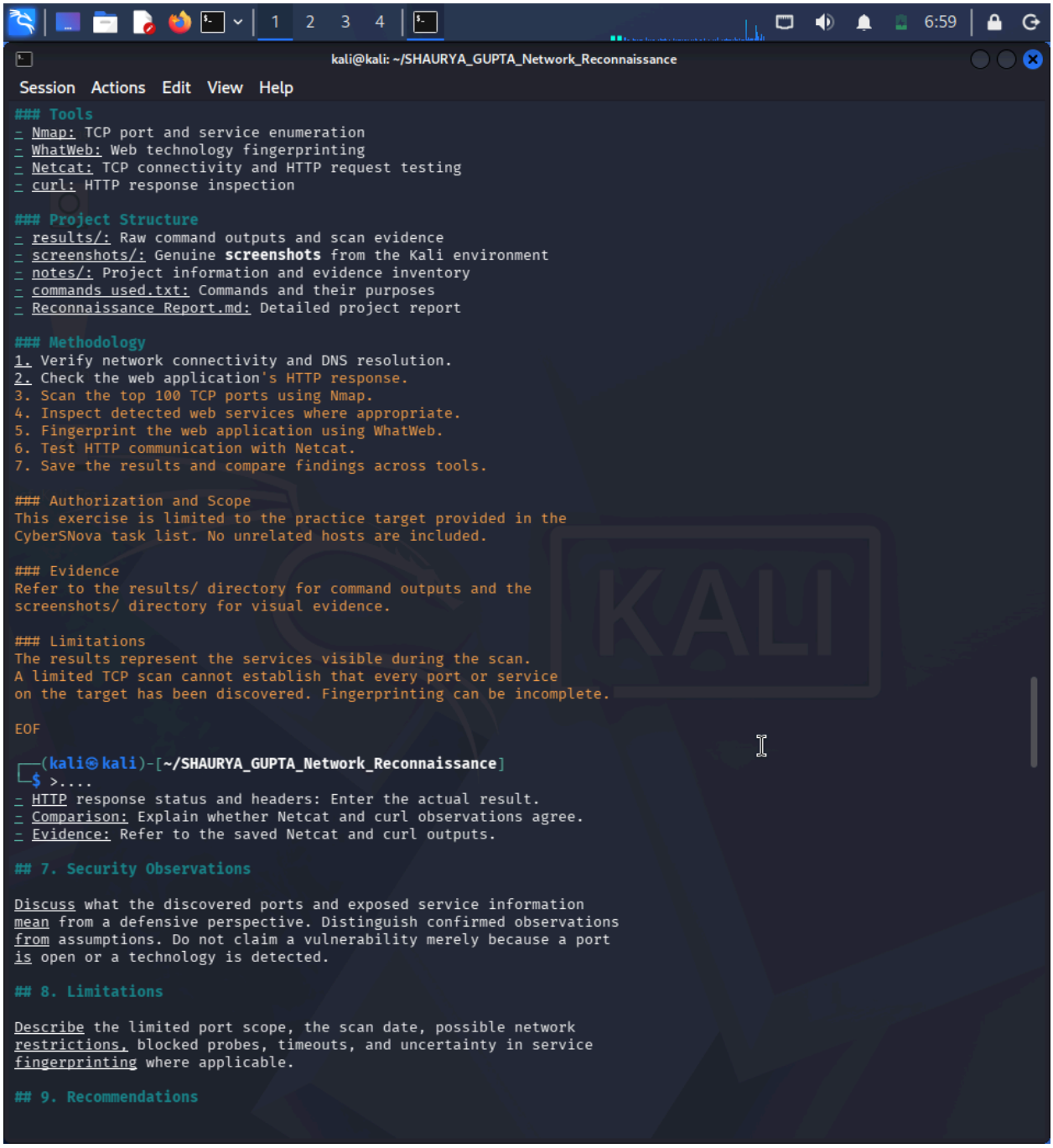
End of Report
Prepared by: SHAURYA GUPTA
Domain: Cyber Security
Project: Network Reconnaissance and Service Enumeration
Organization: CyberSNova
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]

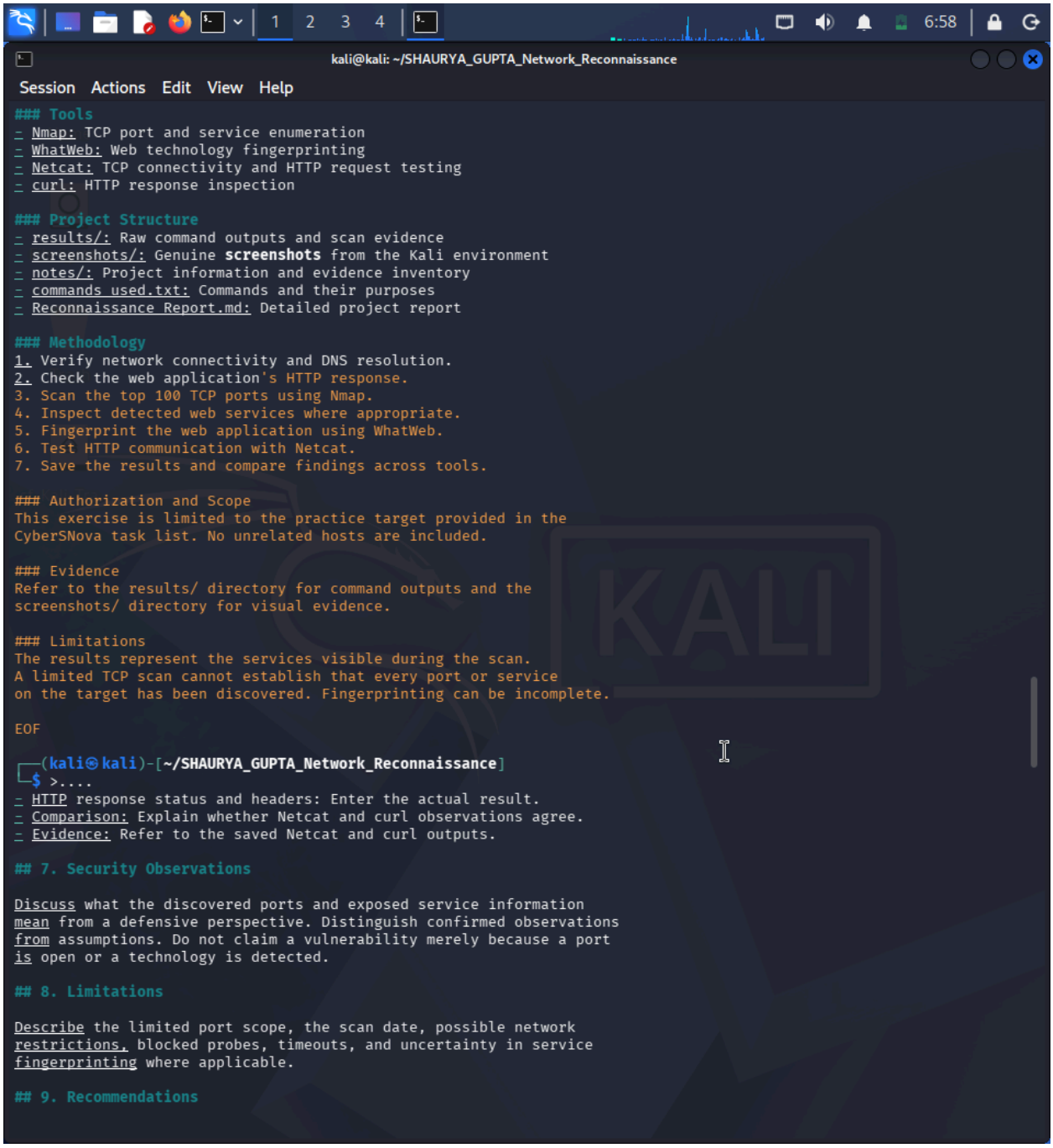

kali@kali: ~/SHAURYA_GUPTA_Network_Reconnaissance
Session Actions Edit View Help
Reconnaissance_Report.md
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ nano Project_1_Network_Reconnaissance
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ ls
commands_used.txt Project_1_Network_Reconnaissance Reconnaissance_Report.md screenshots
notes README.md results
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ rm Project_1_Network_Reconnaissance
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ ls
commands_used.txt notes README.md Reconnaissance_Report.md results screenshots
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ nano Reconnaissance_Report.md
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ rm Reconnaissance_Report.md
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ cd /home/kali/SHAURYA_GUPTA/Project_1_Network_Reconnaissance
cd: no such file or directory: /home/kali/SHAURYA_GUPTA/Project_1_Network_Reconnaissance
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ cd /home/kali/SHAURYA_GUPTA/Project_1_Network_Reconnaissance
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ cd /home/kali/SHAURYA_GUPTA_Network_Reconnaissance
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ nano Reconnaissance_Report.md
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ nano Reconnaissance_Report.md
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ printf '\nReport saved to: '
pwd
printf '%s\n' 'Reconnaissance_Report.md'
Report saved to: /home/kali/SHAURYA_GUPTA_Network_Reconnaissance
Reconnaissance_Report.md
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ ls -lh Reconnaissance_Report.md
-rw-rw-r-- 1 kali kali 30K Oct 24 06:48 Reconnaissance_Report.md
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ head -n 25 Reconnaissance_Report.md
tail -n 25 Reconnaissance_Report.md
CYBERSNOVA INTERNSHIP PROJECT REPORT

kali@kali: ~/SHAURYA_GUPTA_Network_Reconnaissance
Session Actions Edit View Help
- results/http_headers.txt
- results/http_status.txt
- results/https_check.txt
- results/whatweb.txt
- results/netcat_http.txt
- results/tls_check.txt
B.3 Nmap outputs
- results/nmap_top100.nmap
- results/nmap_top100.xml
- results/nmap_top100.gnmap
- results/nmap_web_services.nmap
- results/nmap_web_services.xml
- results/nmap_web_services.gnmap
Nmap's -oA option requests output in normal, XML, and grepable formats.
B.4 Command log
- logs/commands.txt
B.5 Screenshots
The screenshots directory was created.
B.6 Final verification
Before submission, verify the actual directory contents using:
```bash
find results logs screenshots -maxdepth 2 -type f -printf '%p\n' | sort
```
Review the report against the genuine output files and update any details if subsequent authorized tests produce new results.

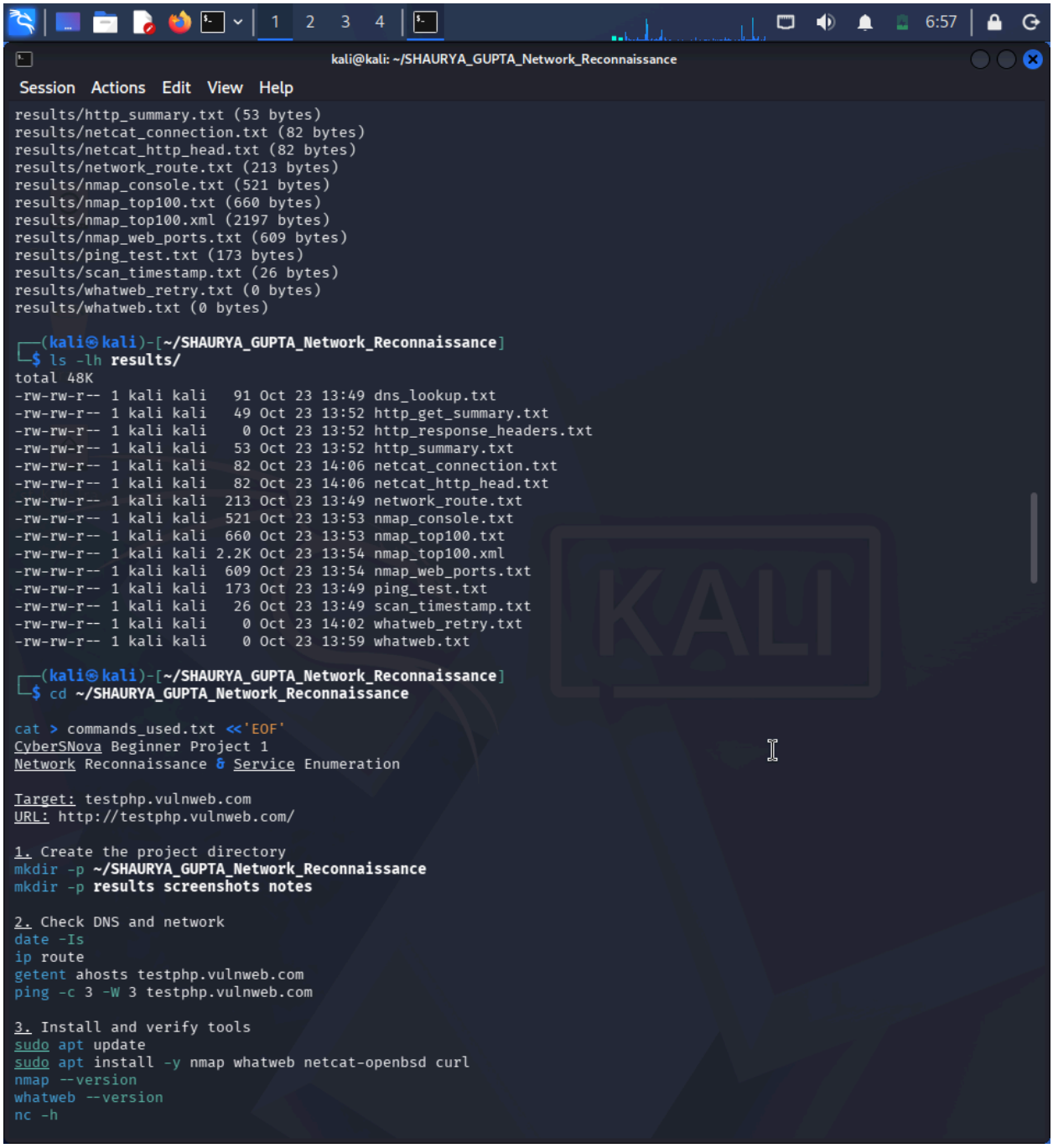
End of Report
Prepared by: SHAURYA GUPTA
Domain: Cyber Security
Project: Network Reconnaissance and Service Enumeration
Organization: CyberSNova
EOF
printf '\nReport saved to: '
pwd
printf '%s\n' 'Reconnaissance_Report.md'
cd: no such file or directory: /home/kali/SHAURYA_GUPTA/Project_1_Network_Reconnaissance
Report saved to: /home/kali/SHAURYA_GUPTA_Network_Reconnaissance
Reconnaissance_Report.md
(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
$ nano Project_1_Network_Reconnaissance

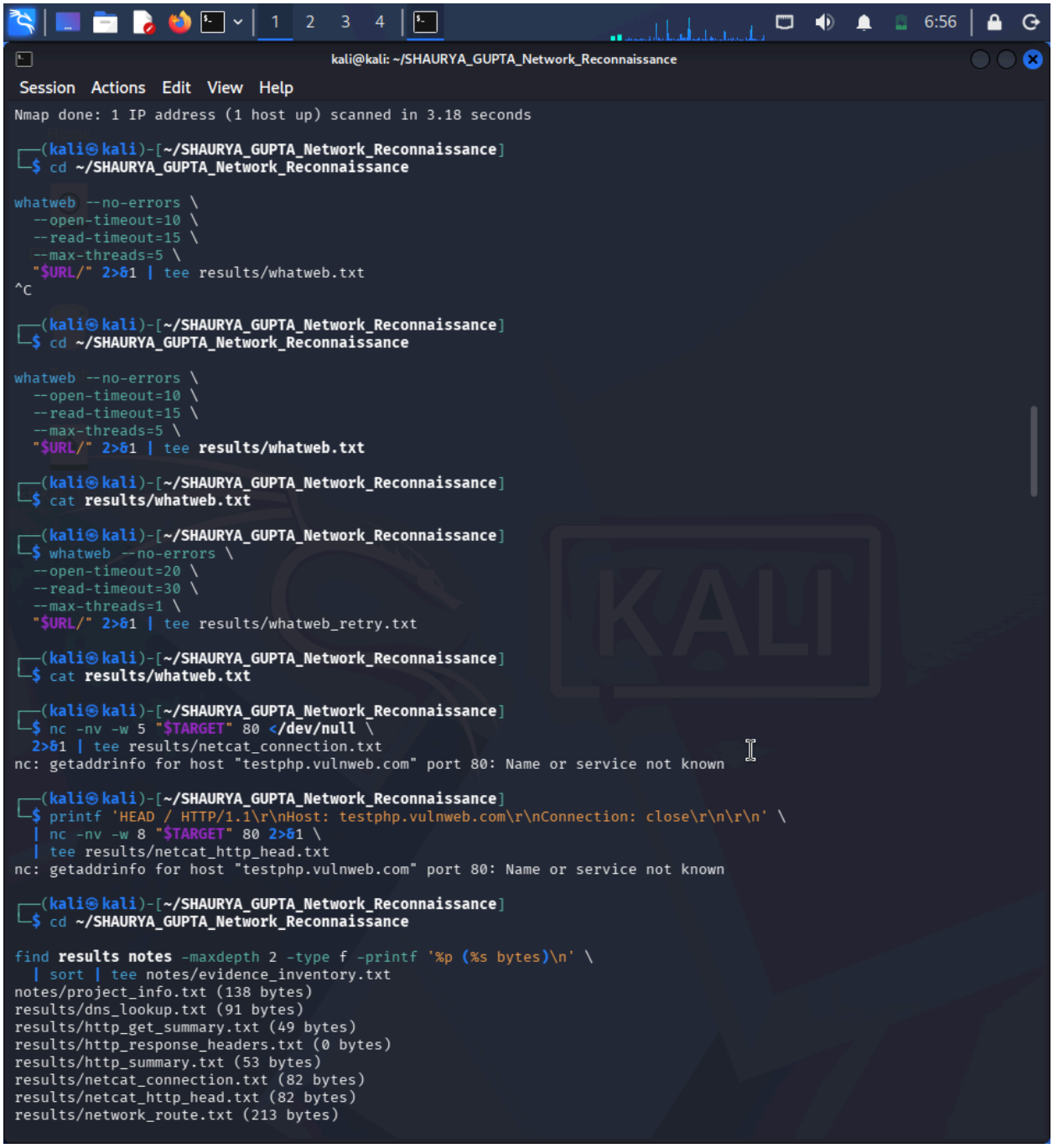

kali@kali: ~/SHAURYA_GUPTA_Network_Reconnaissance
Session Actions Edit View Help
Describe the limited port scope, the scan date, possible network
restrictions, blocked probes, timeouts, and uncertainty in service
fingerprinting where applicable.
9. Recommendations
Provide appropriate defensive recommendations based on the actual findings.
Examples to evaluate, not automatic findings:
- Disable unnecessary publicly reachable services.
- Restrict administrative services to trusted networks.
- Keep exposed software patched and supported.
- Minimize unnecessary server version disclosure.
- Use HTTPS for web traffic and configure TLS appropriately.
- Repeat authorized assessments periodically and compare results.
10. Summary
Write a concise summary of what you actually discovered, which tools
worked, what evidence was collected, and what could not be confirmed.
11. Screenshots and Evidence Index
Insert genuine screenshots and captions for:
1. DNS and connectivity checks.
2. Nmap scan results.
3. WhatWeb output.
4. Netcat TCP and HTTP response.
5. Relevant HTTP response headers.
12. Conclusion
Explain what you learned about reconnaissance and service enumeration,
the importance of validating findings, and the main defensive lessons.
Appendix A: Commands Used
Refer to commands_used.txt. Include any additional commands used
during troubleshooting.
Appendix B: Evidence Files
List the files actually present in the results/ and screenshots/
directories.
EOF
(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
$ >....
- results/dns_ipv6.txt
- results/dns_cname.txt
- results/resolved_addresses.txt
B.2 HTTP, HTTPS, and connection checks
- results/http_headers.txt
- results/http_status.txt
- results/https_check.txt
- results/whatweb.txt

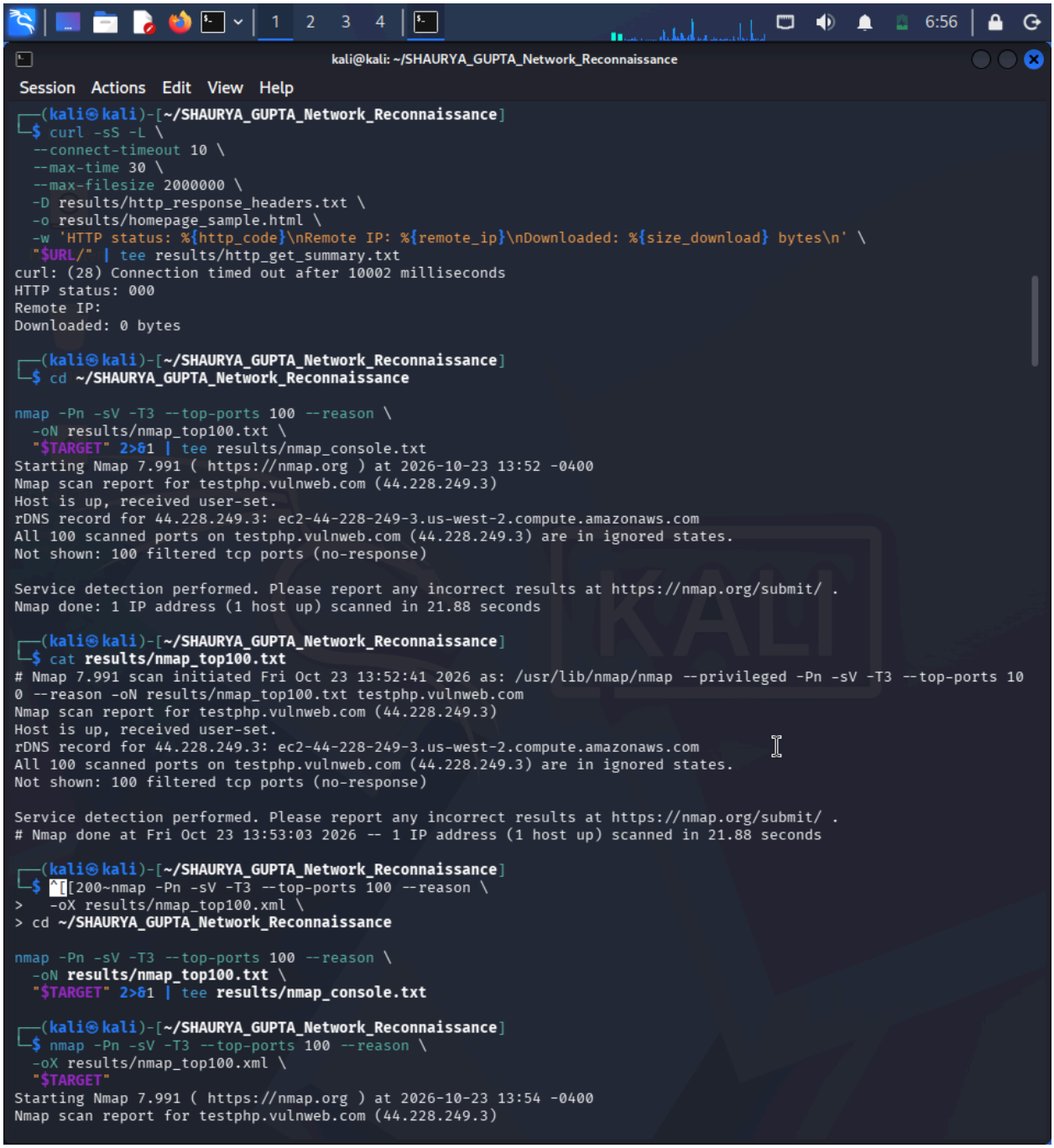

1 2 3 4
6:59
kali@kali: ~/SHAURYA_GUPTA_Network_Reconnaissance
Session Actions Edit View Help
Tools
- Nmap: TCP port and service enumeration
- WhatWeb: Web technology fingerprinting
- Netcat: TCP connectivity and HTTP request testing
- curl: HTTP response inspection
Project Structure
- results/: Raw command outputs and scan evidence
- screenshots/: Genuine **screenshots** from the Kali environment
- notes/: Project information and evidence inventory
- commands used.txt: Commands and their purposes
- Reconnaissance Report.md: Detailed project report
Methodology
1. Verify network connectivity and DNS resolution.
2. Check the web application's HTTP response.
3. Scan the top 100 TCP ports using Nmap.
4. Inspect detected web services where appropriate.
5. Fingerprint the web application using WhatWeb.
6. Test HTTP communication with Netcat.
7. Save the results and compare findings across tools.
Authorization and Scope
This exercise is limited to the practice target provided in the
CyberSNova task list. No unrelated hosts are included.
Evidence
Refer to the results/ directory for command outputs and the
screenshots/ directory for visual evidence.
Limitations
The results represent the services visible during the scan.
A limited TCP scan cannot establish that every port or service
on the target has been discovered. Fingerprinting can be incomplete.
EOF
(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
$ >....
- HTTP response status and headers: Enter the actual result.
- Comparison: Explain whether Netcat and curl observations agree.
- Evidence: Refer to the saved Netcat and curl outputs.
7. Security Observations
Discuss what the discovered ports and exposed service information
mean from a defensive perspective. Distinguish confirmed observations
from assumptions. Do not claim a vulnerability merely because a port
is open or a technology is detected.
8. Limitations
Describe the limited port scope, the scan date, possible network
restrictions, blocked probes, timeouts, and uncertainty in service
fingerprinting where applicable.
9. Recommendations


kali@kali: ~/SHAURYA_GUPTA_Network_Reconnaissance
Session Actions Edit View Help
Tools
- Nmap: TCP port and service enumeration
- WhatWeb: Web technology fingerprinting
- Netcat: TCP connectivity and HTTP request testing
- curl: HTTP response inspection
Project Structure
- results/: Raw command outputs and scan evidence
- screenshots/: Genuine **screenshots** from the Kali environment
- notes/: Project information and evidence inventory
- commands_used.txt: Commands and their purposes
- Reconnaissance_Report.md: Detailed project report
Methodology
1. Verify network connectivity and DNS resolution.
2. Check the web application's HTTP response.
3. Scan the top 100 TCP ports using Nmap.
4. Inspect detected web services where appropriate.
5. Fingerprint the web application using WhatWeb.
6. Test HTTP communication with Netcat.
7. Save the results and compare findings across tools.
Authorization and Scope
This exercise is limited to the practice target provided in the
CyberSNova task list. No unrelated hosts are included.
Evidence
Refer to the results/ directory for command outputs and the
screenshots/ directory for visual evidence.
Limitations
The results represent the services visible during the scan.
A limited TCP scan cannot establish that every port or service
on the target has been discovered. Fingerprinting can be incomplete.
EOF
(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
$ >....
- HTTP response status and headers: Enter the actual result.
- Comparison: Explain whether Netcat and curl observations agree.
- Evidence: Refer to the saved Netcat and curl outputs.
7. Security Observations
Discuss what the discovered ports and exposed service information
mean from a defensive perspective. Distinguish confirmed observations
from assumptions. Do not claim a vulnerability merely because a port
is open or a technology is detected.
8. Limitations
Describe the limited port scope, the scan date, possible network
restrictions, blocked probes, timeouts, and uncertainty in service
fingerprinting where applicable.
9. Recommendations

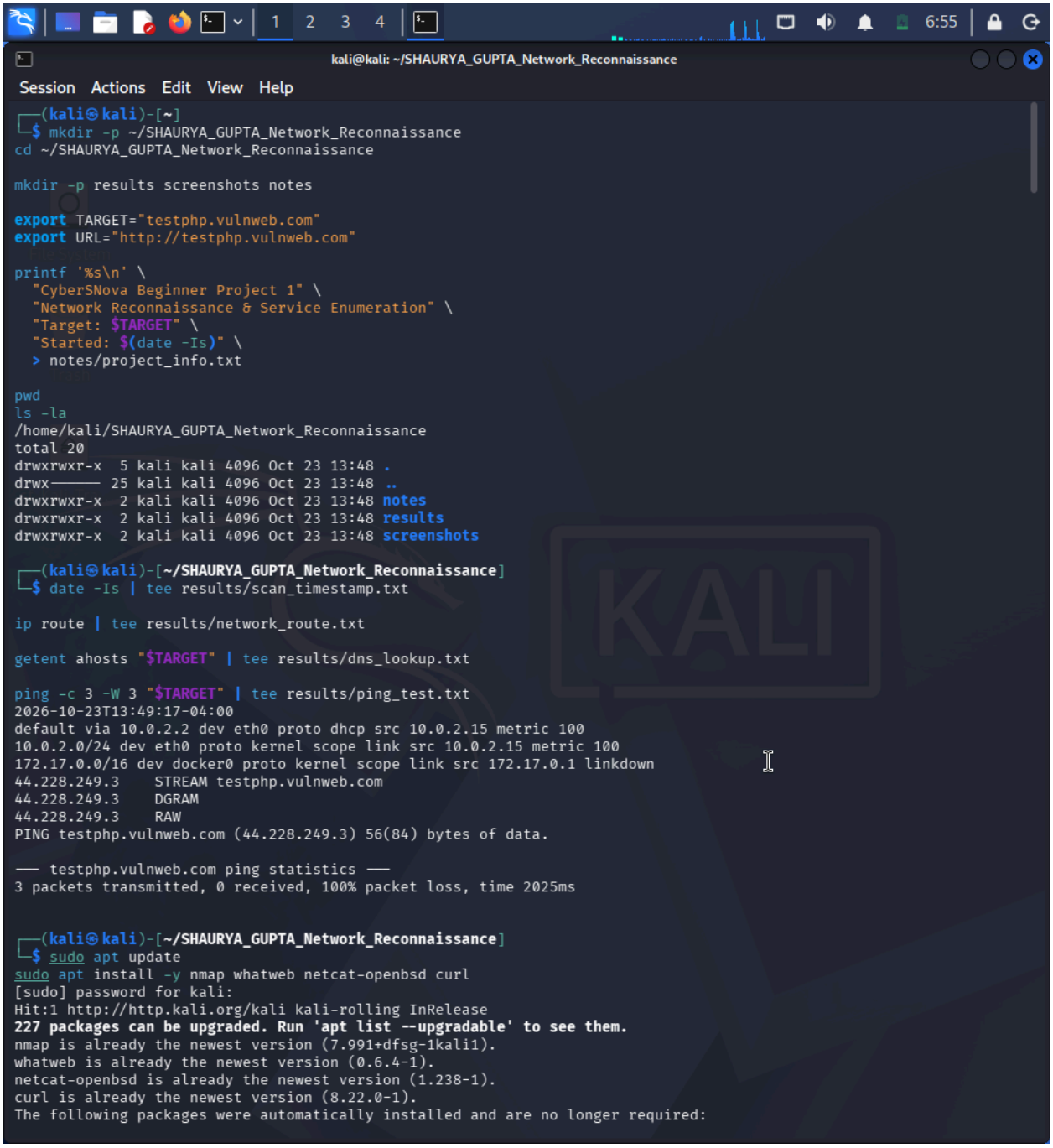
kali@kali: ~/SHAURYA_GUPTA_Network_Reconnaissance
Session Actions Edit View Help
5. Nmap service enumeration
nmap -Pn -sV -T3 --top-ports 100 --reason testphp.vulnweb.com
6. Nmap XML output
nmap -Pn -sV -T3 --top-ports 100 --reason -oX results/nmap_top100.xml testphp.vulnweb.com
7. Optional web port inspection
nmap -Pn -sV -T3 -p 80,443 --script http-title,http-headers testphp.vulnweb.com
8. WhatWeb fingerprinting
whatweb --no-errors --open-timeout=10 --read-timeout=15 --max-threads=5 http://testphp.vulnweb.com/
9. Netcat TCP test
nc -nv -w 5 testphp.vulnweb.com 80 </dev/null
10. Netcat HTTP HEAD request
printf 'HEAD / HTTP/1.1\r\nHost: testphp.vulnweb.com\r\nConnection: close\r\n\r\n' | nc -nv -w 8 testphp.vulnweb.com 80
11. Review evidence
find results notes -maxdepth 2 -type f -printf '%p (%s bytes)\n'
ls -lh results/
Note:
Commands may be retried when a tool or connection fails. Only claim
results that are supported by the actual output files and screenshots.
EOF
(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
$ >....
# CyberSNova Beginner Project 1
Network Reconnaissance & Service Enumeration
Intern Details
- Name: SHAURYA GUPTA
- Email: shauryagupta0106@gmail.com
- Reference Number: CSN-OC-OL-26194
- Registration Number: CSN-OC-2026-194
- Domain: Cyber Security
- Project Level: Beginner
- Internship Month/Year: October 2026
Objective
Perform basic network reconnaissance and service enumeration on
the training website specified in the CyberSNova task list.
Target
- Hostname: testphp.vulnweb.com
- URL: http://testphp.vulnweb.com/
Tools
- Nmap: TCP port and service enumeration
- WhatWeb: Web technology fingerprinting
- Netcat: TCP connectivity and HTTP request testing
- curl: HTTP response inspection
Project Structure


kali@kali: ~/SHAURYA_GUPTA_Network_Reconnaissance
Session Actions Edit View Help
results/http_summary.txt (53 bytes)
results/netcat_connection.txt (82 bytes)
results/netcat_http_head.txt (82 bytes)
results/network_route.txt (213 bytes)
results/nmap_console.txt (521 bytes)
results/nmap_top100.txt (660 bytes)
results/nmap_top100.xml (2197 bytes)
results/nmap_web_ports.txt (609 bytes)
results/ping_test.txt (173 bytes)
results/scan_timestamp.txt (26 bytes)
results/whatweb_retry.txt (0 bytes)
results/whatweb.txt (0 bytes)
(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
$ ls -lh results/
total 48K
-rw-rw-r-- 1 kali kali 91 Oct 23 13:49 dns_lookup.txt
-rw-rw-r-- 1 kali kali 49 Oct 23 13:52 http_get_summary.txt
-rw-rw-r-- 1 kali kali 0 Oct 23 13:52 http_response_headers.txt
-rw-rw-r-- 1 kali kali 53 Oct 23 13:52 http_summary.txt
-rw-rw-r-- 1 kali kali 82 Oct 23 14:06 netcat_connection.txt
-rw-rw-r-- 1 kali kali 82 Oct 23 14:06 netcat_http_head.txt
-rw-rw-r-- 1 kali kali 213 Oct 23 13:49 network_route.txt
-rw-rw-r-- 1 kali kali 521 Oct 23 13:53 nmap_console.txt
-rw-rw-r-- 1 kali kali 660 Oct 23 13:53 nmap_top100.txt
-rw-rw-r-- 1 kali kali 2.2K Oct 23 13:54 nmap_top100.xml
-rw-rw-r-- 1 kali kali 609 Oct 23 13:54 nmap_web_ports.txt
-rw-rw-r-- 1 kali kali 173 Oct 23 13:49 ping_test.txt
-rw-rw-r-- 1 kali kali 26 Oct 23 13:49 scan_timestamp.txt
-rw-rw-r-- 1 kali kali 0 Oct 23 14:02 whatweb_retry.txt
-rw-rw-r-- 1 kali kali 0 Oct 23 13:59 whatweb.txt
(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
$ cd ~/SHAURYA_GUPTA_Network_Reconnaissance
cat > commands_used.txt <<'EOF'
CyberSNova Beginner Project 1
Network Reconnaissance & Service Enumeration
Target: testphp.vulnweb.com
URL: http://testphp.vulnweb.com/
1. Create the project directory
mkdir -p ~/SHAURYA_GUPTA_Network_Reconnaissance
mkdir -p results screenshots notes
2. Check DNS and network
date -Is
ip route
getent ahosts testphp.vulnweb.com
ping -c 3 -W 3 testphp.vulnweb.com
3. Install and verify tools
sudo apt update
sudo apt install -y nmap whatweb netcat-openbsd curl
nmap --version
whatweb --version
nc -h


kali@kali: ~/SHAURYA_GUPTA_Network_Reconnaissance
Session Actions Edit View Help
Nmap done: 1 IP address (1 host up) scanned in 3.18 seconds
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ cd ~/SHAURYA_GUPTA_Network_Reconnaissance
whatweb --no-errors \
--open-timeout=10 \
--read-timeout=15 \
--max-threads=5 \
"$URL/" 2>&1 | tee results/whatweb.txt
^C
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ cd ~/SHAURYA_GUPTA_Network_Reconnaissance
whatweb --no-errors \
--open-timeout=10 \
--read-timeout=15 \
--max-threads=5 \
"$URL/" 2>&1 | tee results/whatweb.txt
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ cat results/whatweb.txt
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ whatweb --no-errors \
--open-timeout=20 \
--read-timeout=30 \
--max-threads=1 \
"$URL/" 2>&1 | tee results/whatweb_retry.txt
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ cat results/whatweb.txt
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ nc -nv -w 5 "$TARGET" 80 </dev/null \
2>&1 | tee results/netcat_connection.txt
nc: getaddrinfo for host "testphp.vulnweb.com" port 80: Name or service not known
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ printf 'HEAD / HTTP/1.1\r\nHost: testphp.vulnweb.com\r\nConnection: close\r\n\r\n' \
| nc -nv -w 8 "$TARGET" 80 2>&1 \
| tee results/netcat_http_head.txt
nc: getaddrinfo for host "testphp.vulnweb.com" port 80: Name or service not known
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ cd ~/SHAURYA_GUPTA_Network_Reconnaissance
find results notes -maxdepth 2 -type f -printf '%p (%s bytes)\n' \
| sort | tee notes/evidence_inventory.txt
notes/project_info.txt (138 bytes)
results/dns_lookup.txt (91 bytes)
results/http_get_summary.txt (49 bytes)
results/http_response_headers.txt (0 bytes)
results/http_summary.txt (53 bytes)
results/netcat_connection.txt (82 bytes)
results/netcat_http_head.txt (82 bytes)
results/network_route.txt (213 bytes)


kali@kali: ~/SHAURYA_GUPTA_Network_Reconnaissance
Session Actions Edit View Help
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ curl -sS -L \
--connect-timeout 10 \
--max-time 30 \
--max-filesize 2000000 \
-D results/http_response_headers.txt \
-o results/homepage_sample.html \
-w 'HTTP status: %{http_code}\nRemote IP: %{remote_ip}\nDownloaded: %{size_download} bytes\n' \
"$URL/" | tee results/http_get_summary.txt
curl: (28) Connection timed out after 10002 milliseconds
HTTP status: 000
Remote IP:
Downloaded: 0 bytes
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ cd ~/SHAURYA_GUPTA_Network_Reconnaissance
nmap -Pn -sV -T3 --top-ports 100 --reason \
-oN results/nmap_top100.txt \
"$TARGET" 2>&1 | tee results/nmap_console.txt
Starting Nmap 7.991 (https://nmap.org) at 2026-10-23 13:52 -0400
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up, received user-set.
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
All 100 scanned ports on testphp.vulnweb.com (44.228.249.3) are in ignored states.
Not shown: 100 filtered tcp ports (no-response)
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.88 seconds
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ cat results/nmap_top100.txt
Nmap 7.991 scan initiated Fri Oct 23 13:52:41 2026 as: /usr/lib/nmap/nmap --privileged -Pn -sV -T3 --top-ports 10
0 --reason -oN results/nmap_top100.txt testphp.vulnweb.com
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up, received user-set.
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
All 100 scanned ports on testphp.vulnweb.com (44.228.249.3) are in ignored states.
Not shown: 100 filtered tcp ports (no-response)
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done at Fri Oct 23 13:53:03 2026 -- 1 IP address (1 host up) scanned in 21.88 seconds
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ ^[[200~nmap -Pn -sV -T3 --top-ports 100 --reason \
> -oX results/nmap_top100.xml \
> cd ~/SHAURYA_GUPTA_Network_Reconnaissance
nmap -Pn -sV -T3 --top-ports 100 --reason \
-oN results/nmap_top100.txt \
"$TARGET" 2>&1 | tee results/nmap_console.txt
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ nmap -Pn -sV -T3 --top-ports 100 --reason \
-oX results/nmap_top100.xml \
"$TARGET"
Starting Nmap 7.991 (https://nmap.org) at 2026-10-23 13:54 -0400
Nmap scan report for testphp.vulnweb.com (44.228.249.3)

kali@kali: ~/SHAURYA_GUPTA_Network_Reconnaissance
Session Actions Edit View Help
whatweb is already the newest version (0.6.4-1).
netcat-openbsd is already the newest version (1.238-1).
curl is already the newest version (8.22.0-1).
The following packages were automatically installed and are no longer required:
bluez-hcidump libimath-3-1-29t64 libpoppler156 python3-mitmproxy-wireguard
firmware-marvell-prestera libjim0.83 libpython3.13 python3.13
libabsl20260107 libkmlbase1t64 libpython3.13-dev python3.13-dev
libavfilter11 libkmldom1t64 libpython3.13-minimal python3.13-minimal
libbluray3 libkmlengine1t64 libpython3.13-stdlib python3.13-tk
libconfig++11 libmupdf27.0 libsimdutf33 python3.13-venv
libconfig11 libntfs-3g89t64 libvidstab1.1 rpcsvc-proto
libgeos3.14.1 libobjc-15-dev libx265-215
libhdf5-310 libopenjph0.27 openssh-client-gssapi
libhdf5-hl-310 libperl5.40 perl-modules-5.40
Use 'sudo apt autoremove' to remove them.
Summary:
Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 227
(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
$ nmap --version | head -n 2
whatweb --version
nc -h 2>&1 | head -n 5
curl --version | head -n 1
Nmap version 7.991 (https://nmap.org)
Platform: x86_64-pc-linux-gnu
WhatWeb version 0.6.4 (https://morningstarsecurity.com/research/whatweb/)
OpenBSD netcat (Debian patchlevel 1.238-1)
usage: nc [-46CDdFhklNnrStUuvZz] [-I length] [-i interval] [-M ttl]
[-m minttl] [-O length] [-P proxy_username] [-p source_port]
[-q seconds] [-s sourceaddr] [-T keyword] [-V rtable] [-W recvlimit]
[-w timeout] [-X proxy_protocol] [-x proxy_address[:port]]
curl 8.22.0 (x86_64-pc-linux-gnu) libcurl/8.22.0 OpenSSL/3.6.4 zlib/1.3.2 brotli/1.2.0 zstd/1.5.7 libidn2/2.3.8 lib
psl/0.23.3 libssh2/1.11.1 nghttp2/1.70.0 ngtcp2/1.24.0 nghttp3/1.17.0 mit-krb5/1.22.1 OpenLDAP/2.6.14
(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
$ curl -sS -I \
--connect-timeout 10 \
--max-time 20 \
"$URL/" \
-o results/http_headers.txt \
-w 'HTTP status: %{http_code}\nRemote IP: %{remote_ip}\nTime: %{time_total} seconds\n' \
| tee results/http_summary.txt
cat results/http_headers.txt
curl: (28) Connection timed out after 10003 milliseconds
HTTP status: 000
Remote IP:
Time: 10.003418 seconds
cat: results/http_headers.txt: No such file or directory
(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
$ curl -sS -L \
--connect-timeout 10 \
--max-time 30 \


kali@kali: ~/SHAURYA_GUPTA_Network_Reconnaissance
Session Actions Edit View Help
┌──(kali㉿kali)-[~]
└─$ mkdir -p ~/SHAURYA_GUPTA_Network_Reconnaissance
cd ~/SHAURYA_GUPTA_Network_Reconnaissance
mkdir -p results screenshots notes
export TARGET="testphp.vulnweb.com"
export URL="http://testphp.vulnweb.com"
printf '%s\n' \
"CyberSNova Beginner Project 1" \
"Network Reconnaissance & Service Enumeration" \
"Target: $TARGET" \
"Started: $(date -Is)" \
> notes/project_info.txt
pwd
ls -la
/home/kali/SHAURYA_GUPTA_Network_Reconnaissance
total 20
drwxrwxr-x 5 kali kali 4096 Oct 23 13:48 .
drwx------ 25 kali kali 4096 Oct 23 13:48 ..
drwxrwxr-x 2 kali kali 4096 Oct 23 13:48 notes
drwxrwxr-x 2 kali kali 4096 Oct 23 13:48 results
drwxrwxr-x 2 kali kali 4096 Oct 23 13:48 screenshots
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ date -Is | tee results/scan_timestamp.txt
ip route | tee results/network_route.txt
getent ahosts "$TARGET" | tee results/dns_lookup.txt
ping -c 3 -W 3 "$TARGET" | tee results/ping_test.txt
2026-10-23T13:49:17-04:00
default via 10.0.2.2 dev eth0 proto dhcp src 10.0.2.15 metric 100
10.0.2.0/24 dev eth0 proto kernel scope link src 10.0.2.15 metric 100
172.17.0.0/16 dev docker0 proto kernel scope link src 172.17.0.1 linkdown
44.228.249.3 STREAM testphp.vulnweb.com
44.228.249.3 DGRAM
44.228.249.3 RAW
PING testphp.vulnweb.com (44.228.249.3) 56(84) bytes of data.
— testphp.vulnweb.com ping statistics —
3 packets transmitted, 0 received, 100% packet loss, time 2025ms
┌──(kali㉿kali)-[~/SHAURYA_GUPTA_Network_Reconnaissance]
└─$ sudo apt update
sudo apt install -y nmap whatweb netcat-openbsd curl
[sudo] password for kali:
Hit:1 http://http.kali.org/kali kali-rolling InRelease
227 packages can be upgraded. Run 'apt list --upgradable' to see them.
nmap is already the newest version (7.991+dfsg-1kali1).
whatweb is already the newest version (0.6.4-1).
netcat-openbsd is already the newest version (1.238-1).
curl is already the newest version (8.22.0-1).
The following packages were automatically installed and are no longer required:

HIDDEN DIRECTORY & FILE ENUMERATION REPORT

CyberSNova Cybersecurity Internship

Name: SHAURYA GUPTA

Email: shauryagupta0106@gmail.com

Reference Number: CSN-OC-OL-26194

Registration Number: CSN-OC-2026-194

Domain: Cyber Security

Project Level: Beginner

Project Number: 2

Project Title: Hidden Directory & File Enumeration

Internship Month/Year: October 2026

Assessment Target: http://testasp.vulnweb.com/

Assessment Period: October 20-22, 2026

Description Table

S. No.	Project Description	Page No.
1	Introduction and objectives	2
2	Environment and tool setup	2
3	Enumeration methodology	3
4	Gobuster results	3
5	Dirsearch results	4

S. No.	Project Description	Page No.
6	Dirb results	4
7	Findings and verification	5
8	Risk assessment and recommendations	6
9	Summary and conclusion	7
10	Screenshots and evidence	8

Note: These are proposed page numbers for document organization. Adjust them after exporting the final report to PDF.

---

1. Introduction

Web applications may expose directories and files that are not linked directly from their homepages. These resources may include application pages, static assets, server-generated content, administrative interfaces, or configuration-related resources.

Hidden directory and file enumeration is a reconnaissance technique used to identify candidate web paths by sending HTTP requests with words from a predefined wordlist. The server's responses help determine which paths may exist and which resources deserve further investigation.

This project was conducted against the assigned training target, `http://testasp.vulnweb.com/`, using Gobuster, Dirsearch, Dirb, and curl in Kali Linux.

The assessment identified multiple directory paths, ASP application endpoints, and a robots.txt file. Selected findings were subsequently checked using read-only HTTP requests to compare enumeration results with observed server responses.

The report documents the actual findings, limitations, and evidence available from the assessment.

2. Objectives

1. Understand how web directory and file enumeration works.
2. Use Gobuster, Dirsearch, and Dirb in Kali Linux.
3. Record and compare the results generated by the three tools.

4. Identify candidate directories and application endpoints.
5. Verify selected paths using curl and record their HTTP status codes.
6. Assess potential security significance without assuming that every discovered path is vulnerable.
7. Maintain reproducible result files, environment information, and screenshot evidence.
8. Recommend appropriate defensive measures based on the findings.

3. Scope and Authorization

Target URL: http://testasp.vulnweb.com/

Assessment type: Web directory and file enumeration.

Assessment tools: Gobuster, Dirsearch, Dirb, curl.

Operating environment: Kali GNU/Linux Rolling 2026.3.

Assessment period: October 20-22, 2026, according to the supplied terminal output.

Scope limitations

The assessment was restricted to the specified training target and ordinary web-path discovery and verification requests.

The recorded activities included wordlist-based enumeration and read-only HTTP requests. No successful authentication bypass, exploitation, or destructive activity was demonstrated in the supplied evidence.

The assessment did not establish that every discovered resource was sensitive, that directory listings were enabled, or that the application contained an exploitable vulnerability.

4. Environment and Tool Setup

4.1 Operating system

The following information was collected from `/etc/os-release`:

Property	Observed value
Operating system	Kali GNU/Linux Rolling
Version ID	2026.3
Version codename	kali-rolling

Property	Observed value
Distribution ID	kali
Architecture	Not recorded in the supplied output
Working directory	`/home/kali/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration`

4.2 Tool versions and availability

Tool	Recorded version or result
Gobuster	3.8.2
Dirsearch	0.5.0
Dirb	2.22
curl	Installed and successfully used for HTTP requests. Exact version not recorded in the supplied output.

4.3 Wordlists

The following wordlists were confirmed to exist on the system.

Wordlist	Actual path	Observed file size
SecLists raft small directories	`/usr/share/seclists/Discovery/Web-Content/raft-small-directories.txt`	163,210 bytes
Dirb common wordlist	`/usr/share/dirb/wordlists/common.txt`	35,849 bytes

The Gobuster command history also contains references to `directory-list-2.3-small.txt`, but the later confirmed wordlist checks establish the availability of `raft-small-directories.txt` and `common.txt`. The report therefore identifies the wordlists associated with the recorded enumeration output rather than assuming that every earlier command completed successfully.

4.4 Project directory structure

The project was stored at:

`/home/kali/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration`

The following project files and directories were observed:

Path	Purpose
`README.md`	Project overview and instructions
`evidence/environment.txt`	Recorded environment information
`results/gobuster.txt`	Gobuster output
`results/dirsearch.txt`	Dirsearch output
`results/dirb.txt`	Dirb output
`results/candidate_findings.txt`	Candidate findings
`results/discovered_directories.txt`	Consolidated findings
`results/verification.txt`	Verification record
`results/homepage.html`	Saved homepage response
`results/response_headers.txt`	HTTP header evidence
`results/robots_headers.txt`	robots.txt response headers
`results/robots.txt`	Retrieved robots.txt content
`results/target.txt`	Target-related record
`screenshots/01.png` through `screenshots/27.png`	Available screenshot files
`report/`	Report directory

The supplied file listing also showed a temporary swap file named `.Enumeration_Report.md.swp`. Temporary editor files should be excluded from the final submission unless they are specifically required.

5. Enumeration Methodology

5.1 Initial connectivity checks

The assessment began with a connectivity check and retrieval of the target homepage and robots.txt.

The supplied terminal history shows the following commands were used during the project:

```
curl -sS -L --max-time 15 \
  -o /dev/null \
  -w 'HTTP status: %{http_code}\nFinal URL: %{url_effective}\n' \
  http://testasp.vulnweb.com/
curl -sS -L --max-time 15 \
  http://testasp.vulnweb.com/ \
  -o results/homepage.html
curl -sS -L --max-time 15 \
  -D results/robots_headers.txt \
  http://testasp.vulnweb.com/robots.txt \
  -o results/robots.txt
```

The later verification output recorded HTTP 200 for the homepage and robots.txt. The retrieved robots.txt content was:

```
User-agent: *
```

This indicates that the supplied robots.txt response contained a general user-agent directive. No additional paths or restrictions were shown in the provided content.

5.2 Gobuster

Tool: Gobuster

Result file: `results/gobuster.txt`

Wordlist associated with the recorded scan:
`/usr/share/seclists/Discovery/Web-Content/raft-small-directories.txt`

A representative command from the recorded command history was:

```
gobuster dir \
  -u http://testasp.vulnweb.com/ \
  -w /usr/share/seclists/Discovery/Web-Content/raft-small-directories.txt \
  -t 5 \
  --timeout 10s \
  -x asp,aspx,html,txt,bak \
  -o results/gobuster.txt
```

Outcome: Multiple directory paths and ASP application endpoints were identified.

The recorded output included:

- Directory candidates returning HTTP 301.
- Application endpoints returning HTTP 200.
- The logout endpoint returning HTTP 302.
- `db.asp` returning HTTP 200 with a zero-byte response.
- `robots.txt` returning HTTP 200.

The results also contained variations in capitalization, such as `images` and `Images`. These are recorded as discovered path variants, but the output does not establish whether they resolve to distinct underlying resources.

The attempted version check did not establish the installed Gobuster version. The report therefore does not assign an unverified version number.

5.3 Dirsearch

Tool: Dirsearch 0.5.0

Result file: `results/dirsearch.txt`

Recorded command:

```
./dirsearch-venv/bin/dirsearch \
  -u http://testasp.vulnweb.com/ \
  -w /usr/share/seclists/Discovery/Web-Content/raft-small-directories.txt \
  --threads=10 \
  --timeout=10 \
  -o results/dirsearch.txt
```

Recorded start time: October 20, 2026, at 10:33:28, as displayed in the scan output.

Outcome: Dirsearch reported nine paths in the supplied output, each returning HTTP 301.

The discovered paths were:

- `/cgi-bin`
- `/templates`
- `/images`
- `/aspnet_client`
- `/Templates`
- `/_vti_cnf`
- `/html`
- `/t`
- `/T`

The output showed redirects from paths without trailing slashes to corresponding URLs ending in `/`.

Recursive enumeration also identified:

`/aspnet_client/system_web/`

The supplied recursive output did not show an HTTP status for that nested path. It is therefore recorded as a directory candidate rather than as a separately status-verified resource.

5.4 Dirb

Tool: Dirb 2.22

Result file: `results/dirb.txt`

Two scan configurations appear in the supplied terminal output.

The first scan used:

```
dirb http://testasp.vulnweb.com/ \
  /usr/share/seclists/Discovery/Web-Content/raft-small-directories.txt \
  -o results/dirb.txt
```

A later scan used:

```
dirb http://testasp.vulnweb.com/ \
  /usr/share/dirb/wordlists/common.txt \
  -o results/dirb.txt
```

Outcome: Dirb identified multiple directory candidates, including `/cgi-bin/`, `/images/`, `/templates/`, `/aspnet_client/`, `/_vti_cnf/`, `/avatars/`, and several capitalization variants.

The first supplied output also showed recursive scanning of selected directories and discovery of:

`/aspnet_client/system_web/`

The later scan encountered a connection error:

FATAL: Too many errors connecting to host

(Possible cause: COULDNT RESOLVE HOST)

That scan ended with `DOWNLOADED: 1443 - FOUND: 1`, and the output explicitly reported `/cgi-bin/` with HTTP 403.

This indicates that the later Dirb run was incomplete. Its results should not be interpreted as an exhaustive enumeration of the target.

5.5 Verification using curl

The supplied verification loop requested the following paths:

/

/cgi-bin/

/images/

/templates/

/aspnet_client/

/_vti_cnf/

/search.asp

/login.asp

/register.asp

/logout.asp

/default.asp

/db.asp

/robots.txt

The requests used curl with a connection timeout, an overall timeout, and no permitted redirects for the individual path checks.

The recorded responses are summarized in Section 7.

6. Consolidated Findings

The table below combines the supplied tool results and verification responses. Duplicate path observations are consolidated, while case variants are retained where they appeared in the raw outputs.

Path	Tool(s)	HTTP status	Classification	Verification	Security significance
/	curl	200	Homepage	Verified	Homepage was accessible.

Path	Tool(s)	HTTP status	Classification	Verification	Security significance
					No vulnerability established.
`/cgi-bin/`	Gobuster, Dirsearch, Dirb, curl	301 during enumeration; 403 during verification	Directory	Verified	The direct verification request returned 403, indicating restricted access to that request. No directory contents were exposed in the supplied evidence.
`/images/`	Gobuster, Dirsearch, Dirb, curl	301 during enumeration; 403 during verification	Directory	Verified	The directory returned 403 during verification. No exposed files or directory listing were demonstrated.
`/templates/`	Gobuster, Dirsearch, Dirb, curl	301 during enumeration; 403 during verification	Directory	Verified	The directory returned 403 during verification. No sensitive template files were verified.
`/Templates/`	Gobuster, Dirsearch, Dirb	301	Directory	Enumeration confirmed	Case-variant path returned a redirect.

Path	Tool(s)	HTTP status	Classification	Verification	Security significance
					Distinct contents or case-sensitive behavior were not established.
`/aspnet_client/`	Gobuster, Dirsearch, Dirb, curl	301 during enumeration; 403 during verification	Directory	Verified	The directory returned 403 during verification. No exposed ASP.NET resources were demonstrated.
`/aspnet_client/system_web/`	Dirb, Dirsearch	Not provided	Directory candidate	Partially verified	Recursive enumeration identified the path, but the supplied output did not provide its HTTP status.
`/_vti_cnf/`	Gobuster, Dirsearch, Dirb, curl	301 during enumeration; 200 during verification	Directory	HTTP response verified; contents require review	A successful HTTP response with a 926-byte body was recorded. Inspect the actual body before determining whether sensitive

Path	Tool(s)	HTTP status	Classification	Verification	Security significance
					metadata is exposed.
`/html/`	Gobuster, Dirsearch, Dirb	301	Directory	Enumeration confirmed	Redirect observed. No sensitive content or directory listing demonstrated.
`/HTML/`	Gobuster, Dirb	301	Directory	Enumeration confirmed	Case-variant path returned a redirect. Distinct underlying content not established.
`/Html/`	Gobuster, Dirb	301	Directory	Enumeration confirmed	Case-variant path returned a redirect. Distinct underlying content not established.
`/t/`	Gobuster, Dirsearch, Dirb	301	Directory	Enumeration confirmed	Redirect observed. Contents not independently verified.
`/T/`	Gobuster, Dirsearch, Dirb	301	Directory	Enumeration confirmed	Case-variant path returned a redirect. Distinct underlying content not established.

Path	Tool(s)	HTTP status	Classification	Verification	Security significance
`/avatars/`	Gobuster, Dirb, curl output not provided for this path	301 during enumeration	Directory	Enumeration confirmed	Redirect observed. No sensitive files verified.
`/jscripts/`	Gobuster, Dirb	301	Directory	Enumeration confirmed	Redirect observed. No exposed scripts or sensitive data verified.
`/JScripts/`	Gobuster, Dirb	301	Directory	Enumeration confirmed	Case-variant path returned a redirect. Distinct underlying content not established.
`/IMAGES/`	Gobuster, Dirb	301	Directory	Enumeration confirmed	Case-variant path returned a redirect. Distinct underlying content not established.
`/CGI-BIN/`	Gobuster, Dirb	301 during enumeration	Directory	Enumeration confirmed	Case-variant path returned a redirect. No additional security conclusion established.
`/Cgi-bin/`	Gobuster, Dirb	301	Directory	Enumeration confirmed	Case-variant path returned a redirect. Distinct underlying

Path	Tool(s)	HTTP status	Classification	Verification	Security significance
					content not established.
`/Aspnet_client/`	Gobuster, Dirb	301	Directory	Enumeration confirmed	Case-variant path returned a redirect. Distinct underlying content not established.
`/aspnet_Client/`	Gobuster, Dirb	301	Directory	Enumeration confirmed	Case-variant path returned a redirect. Distinct underlying content not established.
`/TEMPLATES/`	Gobuster, Dirb	301	Directory	Enumeration confirmed	Case-variant path returned a redirect. Distinct underlying content not established.
`/search.asp`	Gobuster, curl	200	ASP application endpoint	Verified	Endpoint was accessible. Response size was 2,809 bytes. No application vulnerability was demonstrated.
`/login.asp`	Gobuster, curl	200	ASP application endpoint	Verified	Endpoint was accessible. Response

Path	Tool(s)	HTTP status	Classification	Verification	Security significance
					size was 3,194 bytes. Authentication controls were not tested.
`/Login.asp`	Gobuster	200	ASP application endpoint	Enumeration confirmed	Case-variant request returned HTTP 200. The output showed the same response size as `/login.asp`, but equivalent content was not independently confirmed.
`/LOGIN.asp`	Gobuster	200	ASP application endpoint	Enumeration confirmed	Case-variant request returned HTTP 200. Distinct content was not established.
`/register.asp`	Gobuster, curl	200	ASP application endpoint	Verified	Endpoint was accessible. Response size was 3,617 bytes. Registration security was not tested.

Path	Tool(s)	HTTP status	Classification	Verification	Security significance
`/Register.asp`	Gobuster	200	ASP application endpoint	Enumeration confirmed	Case-variant request returned HTTP 200. Distinct content was not established.
`/logout.asp`	Gobuster, curl	302	ASP application endpoint	Redirect verified	Redirected to `/Default.asp`. Authentication and session invalidation behavior were not tested.
`/default.asp`	Gobuster, curl	200	ASP application endpoint	Verified	Accessible. Verification recorded 3,562 bytes; another enumeration result recorded 3,542 bytes.
`/Default.asp`	Gobuster	200	ASP application endpoint	Enumeration confirmed	Accessible in enumeration output. Another result recorded 3,540 bytes. The response size varied across observations.

Path	Tool(s)	HTTP status	Classification	Verification	Security significance
`/db.asp`	Gobuster, curl	200	ASP application endpoint	Verified	HTTP 200 with a zero-byte response. No database contents or secrets were demonstrated.
`/DB.asp`	Gobuster	200	ASP application endpoint	Enumeration confirmed	Case-variant request returned HTTP 200 with a zero-byte response. Distinct behavior was not established.
`/robots.txt`	Gobuster, curl	200	Text file	Verified	Response size was 13 bytes. Retrieved content was `User-agent: *`. No additional paths were shown.
`/Robots.txt`	Gobuster	200	Text file	Enumeration confirmed	Case-variant request returned HTTP 200 with a reported response size of 13

Path	Tool(s)	HTTP status	Classification	Verification	Security significance
					bytes. Distinct content was not established.

6.1 Verification details

The recorded verification loop produced these results:

Path	HTTP status	Response size	Additional observation
`/`	200	3,562 bytes	Homepage accessible
`/cgi-bin/`	403	1,233 bytes	Access denied
`/images/`	403	1,233 bytes	Access denied
`/templates/`	403	1,233 bytes	Access denied
`/aspnet_client/`	403	1,233 bytes	Access denied
`/_vti_cnf/`	200	926 bytes	Response body should be reviewed
`/search.asp`	200	2,809 bytes	Application endpoint accessible
`/login.asp`	200	3,194 bytes	Application endpoint accessible
`/register.asp`	200	3,617 bytes	Application endpoint accessible
`/logout.asp`	302	132 bytes	Redirect to `http://testasp.vulnweb.com/Default.asp`

Path	HTTP status	Response size	Additional observation
`/default.asp`	200	3,562 bytes	Application endpoint accessible
`/db.asp`	200	0 bytes	Empty response body
`/robots.txt`	200	13 bytes	Contains `User-agent: *`

The logout request also generated a curl warning because the command prohibited following redirects. The observed HTTP 302 response is still valid evidence of the redirect.

The verification output did not include a separate HTTP status for every capitalization variant or the nested `system_web` directory.

7. Findings and Verification Analysis

7.1 Directory redirects

Several discovered paths returned HTTP 301 during enumeration. The redirect destinations generally added a trailing slash, for example:

`/cgi-bin` to `/cgi-bin/`

This behavior is consistent with URL normalization. It does not independently indicate a security weakness.

7.2 Access-restricted directories

The verification requests returned HTTP 403 for:

- `/cgi-bin/`
- `/images/`
- `/templates/`
- `/aspnet_client/`

These responses indicate that the server denied the tested requests. The evidence does not establish whether access would differ under other legitimate application contexts, but no directory listing or sensitive file was demonstrated.

7.3 The `/_vti_cnf/` directory

The path was discovered by the enumeration tools and returned HTTP 200 during verification, with a response size of 926 bytes.

This is a candidate for additional review because the path name is associated with FrontPage-related metadata in some web-server environments. However, the path name and HTTP status alone do not prove that this particular resource contains sensitive information.

Evidence-supported conclusion: The resource returned an HTTP 200 response. Its actual body must be examined before assigning a vulnerability or severity rating.

7.4 Application endpoints

The following endpoints returned HTTP 200 during verification:

- `/search.asp`
- `/login.asp`
- `/register.asp`
- `/default.asp`

These are application endpoints rather than automatically confirmed vulnerabilities. Their presence is expected for many web applications.

The assessment did not include detailed application testing of input validation, authentication, authorization, session management, or business logic.

7.5 The `db.asp` endpoint

The endpoint returned HTTP 200 but delivered a zero-byte response.

An empty response does not demonstrate that database credentials, database contents, or internal configuration are exposed. Further conclusions would require additional evidence.

7.6 Incomplete Dirb scan

The later Dirb scan encountered connection errors and a possible DNS resolution problem. As a result, its findings cannot be treated as a complete enumeration.

The results remain useful as partial observations, but the report does not claim that every directory or file on the target was identified.

8. Risk Assessment

The assessment uses evidence-based classifications rather than assigning a severity rating simply because a path exists.

Finding	Evidence	Potential impact	Severity
`/_vti_cnf/` returns HTTP 200	Verified response size of 926 bytes	Sensitive metadata exposure is possible only if the response contains sensitive information	Not determined
`/cgi-bin/` returns HTTP 403	Verified response size of 1,233 bytes	No unauthorized directory access demonstrated	No vulnerability established
`/images/`, `/templates/`, `/aspnet_client/` return HTTP 403	Verified HTTP responses	No directory listing or sensitive file exposure demonstrated	No vulnerability established
`/login.asp` and `/register.asp` are accessible	HTTP 200 responses	Authentication or registration weaknesses are possible in principle, but none was tested or established	Not determined
`/db.asp` returns an empty HTTP 200 response	Verified zero-byte body	No database disclosure demonstrated	No vulnerability established
`/logout.asp` returns HTTP 302	Redirect to `/Default.asp`	Session termination behavior was not assessed	Not determined
Other enumerated directories return HTTP 301	Redirects to trailing-slash URLs	No security impact established by the redirect alone	No vulnerability established

8.1 Detailed candidate assessment: `/_vti_cnf/`

Finding: An enumerated directory path returned HTTP 200.

Evidence: Enumeration outputs and the recorded curl verification loop.

Potential impact: If the response contains publicly accessible internal metadata, it could disclose implementation details or other information useful to an attacker. The actual content has not been established as sensitive.

Severity: Not determined.

Recommendation: Inspect the saved or freshly retrieved response body, determine whether it contains sensitive information, and restrict or remove unnecessary public access if exposure is confirmed.

8.2 Detailed candidate assessment: application endpoints

Finding: Login, registration, search, and default application endpoints were accessible.

Evidence: HTTP 200 responses and recorded response sizes.

Potential impact: These endpoints may warrant further security review, but accessibility alone does not establish a vulnerability.

Severity: Not determined.

Recommendation: Review authentication, authorization, input validation, error handling, and session management using authorized testing procedures.

9. Recommendations

The following recommendations are defensive measures relevant to the types of resources identified during this assessment.

1. **Review `/_vti_cnf/`.** Examine its response body and determine whether it contains internal metadata or other information that should not be public.
2. **Restrict unnecessary resources.** Remove or restrict obsolete directories, unused application endpoints, and unnecessary server components.
3. **Prevent unintended directory listings.** Verify that directory indexing is disabled where it is not required.
4. **Protect sensitive files.** Keep configuration files, backups, database credentials, and temporary files outside publicly served directories.
5. **Review authentication and authorization.** Ensure that login, registration, and other application functions enforce the intended access controls.
6. **Validate session handling.** Confirm that logout operations invalidate the appropriate session state rather than relying only on a redirect.
7. **Monitor web-server responses.** Review logs for suspicious requests and repeated enumeration attempts where appropriate.
8. **Repeat verification when necessary.** Confirm important findings with direct requests and retain timestamps and response evidence.

9. **Document limitations.** Record incomplete scans, timeouts, and connection failures rather than interpreting missing results as proof that resources do not exist.

These recommendations do not imply that every listed weakness was present on the target.

10. Limitations

The findings are limited to the paths tested, the wordlists used, the tool configurations, the responses received, and the assessment period.

The following limitations apply:

- Enumeration may miss paths that are absent from the selected wordlists.
- HTTP responses may vary over time or with server configuration.
- HTTP 200 indicates a successful HTTP response, not that a resource is safe or vulnerable.
- HTTP 301 indicates a redirect, not necessarily a security issue.
- HTTP 302 indicates a temporary redirect, not proof of successful logout or session invalidation.
- HTTP 403 indicates denial of the tested request, not proof that every access route is blocked.
- Case variations may resolve to equivalent content or distinct resources. The supplied results do not establish which applies to every variant.
- The nested `/aspnet_client/system_web/` path was discovered, but its HTTP status was not supplied.
- The later Dirb scan was incomplete because of connection errors.
- The actual response body for `/_vti_cnf/` was not included in the supplied verification output.
- No successful exploitation or confirmed disclosure of sensitive information was demonstrated.

Accordingly, this report documents enumeration and selected response verification, not a comprehensive penetration test.

11. Summary and Conclusion

This project used Gobuster, Dirsearch, and Dirb to identify candidate directories and application endpoints on `http://testasp.vulnweb.com/`.

The recorded outputs identified directory paths such as `/cgi-bin/`, `/images/`, `/templates/`, `/aspnet_client/`, `/_vti_cnf/`, `/html/`, `/t/`, `/avatars/`, and `/jscripts/`, together with multiple capitalization variants. ASP endpoints included

`/search.asp`, `/login.asp`, `/register.asp`, `/logout.asp`, `/default.asp`, and `/db.asp`. The assessment also identified `robots.txt`.

The subsequent curl verification confirmed several HTTP responses. Four tested directories returned HTTP 403, while `/_vti_cnf/` returned HTTP 200 with a 926-byte response. The login, registration, search, and default application endpoints returned HTTP 200. The logout endpoint returned HTTP 302 and redirected to `/Default.asp`. The `db.asp` endpoint returned an empty response body.

The most important follow-up candidate is `/_vti_cnf/`, because its contents have not yet been reviewed. The evidence does not establish that this resource contains sensitive data, so it would be inappropriate to label it a confirmed vulnerability.

The project demonstrates the use of wordlists, enumeration tools, HTTP status codes, response verification, and evidence-based reporting. It also illustrates why raw tool output must be interpreted carefully and why incomplete scans should be documented honestly.

Final conclusion: Multiple candidate web paths were identified and selected responses were verified. No confirmed security vulnerability was established from the supplied evidence alone. Further content inspection and authorized application testing would be required to establish any actual security impact.

12. Evidence Index

The project directory contains 27 screenshot files, named `01.png` through `27.png`. The supplied terminal listing confirms that the files exist, but does not establish the exact subject of each screenshot.

Evidence ID	Filename	Description
E01	`screenshots/01.png`	Screenshot available
E02	`screenshots/02.png`	Screenshot available
E03	`screenshots/03.png`	Screenshot available
E04	`screenshots/04.png`	Screenshot available
E05	`screenshots/05.png`	Screenshot available
E06	`screenshots/06.png`	Screenshot available
E07	`screenshots/07.png`	Screenshot available

Evidence ID	Filename	Description
E08	`screenshots/08.png`	Screenshot available
E09	`screenshots/09.png`	Screenshot available
E10	`screenshots/10.png`	Screenshot available
E11	`screenshots/11.png`	Screenshot available
E12	`screenshots/12.png`	Screenshot available
E13	`screenshots/13.png`	Screenshot available
E14	`screenshots/14.png`	Screenshot available
E15	`screenshots/15.png`	Screenshot available
E16	`screenshots/16.png`	Screenshot available
E17	`screenshots/17.png`	Screenshot available
E18	`screenshots/18.png`	Screenshot available
E19	`screenshots/19.png`	Screenshot available
E20	`screenshots/20.png`	Screenshot available
E21	`screenshots/21.png`	Screenshot available
E22	`screenshots/22.png`	Screenshot available
E23	`screenshots/23.png`	Screenshot available
E24	`screenshots/24.png`	Screenshot available
E25	`screenshots/25.png`	Screenshot available
E26	`screenshots/26.png`	Screenshot available
E27	`screenshots/27.png`	Screenshot available

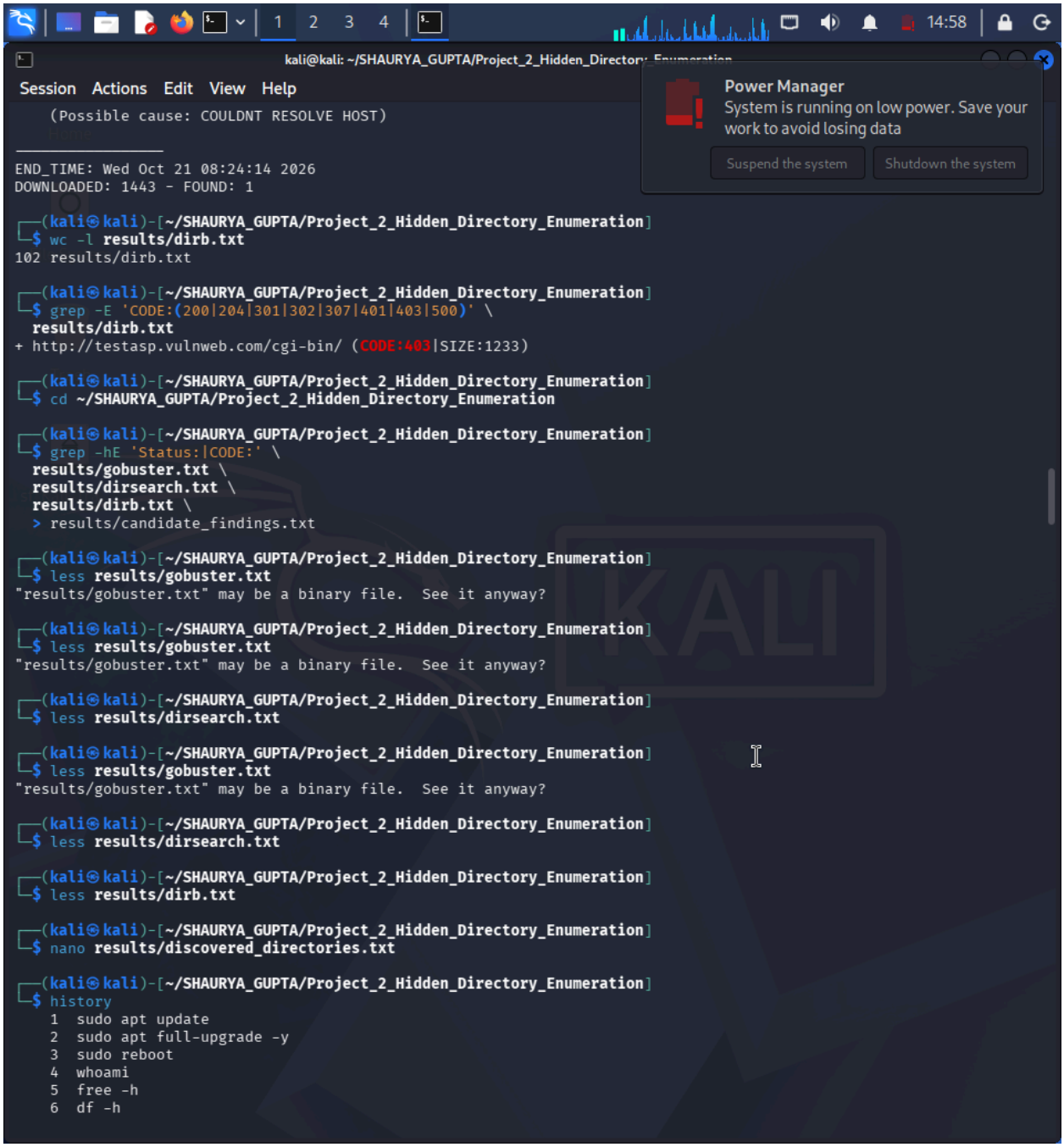
13. References

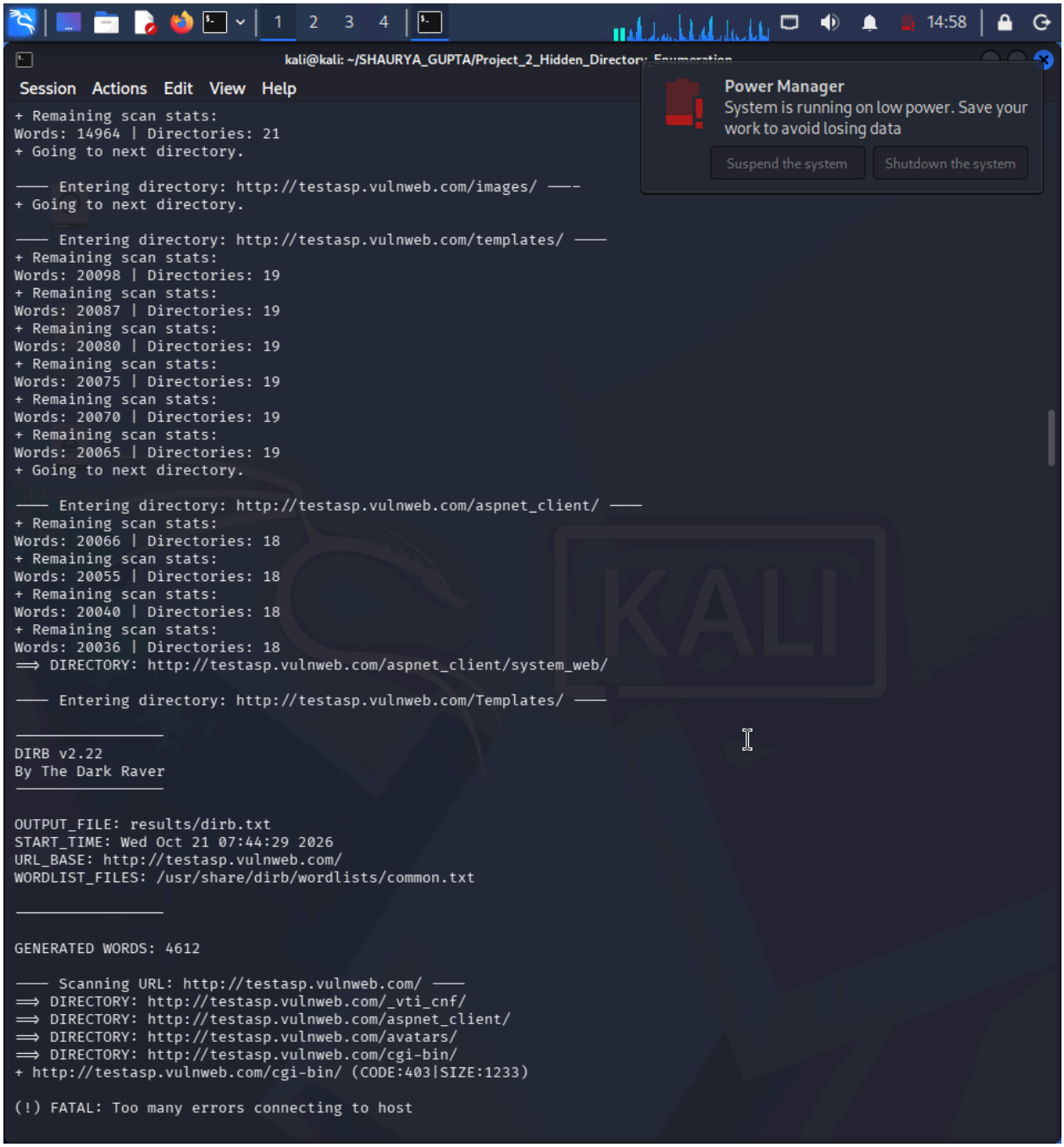
1. CyberSNova Cyber Security Internship Task List and Guidelines.

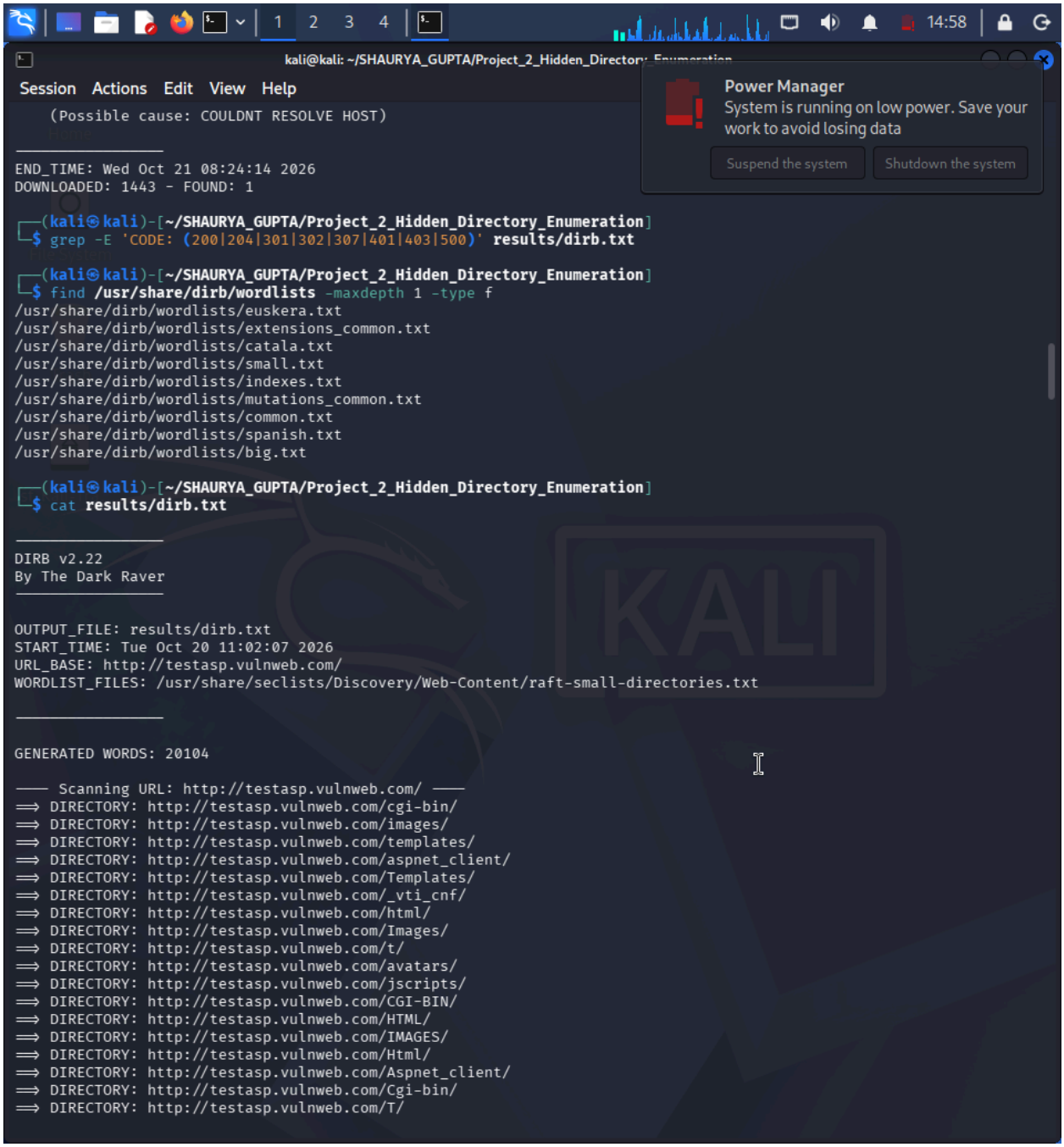
2. Gobuster project documentation: https://github.com/OJ/gobuster
3. Dirsearch project documentation: https://github.com/maurosoria/dirsearch
4. Dirb documentation: https://dirb.sourceforge.net/
5. SecLists wordlists: https://github.com/danielmiessler/SecLists

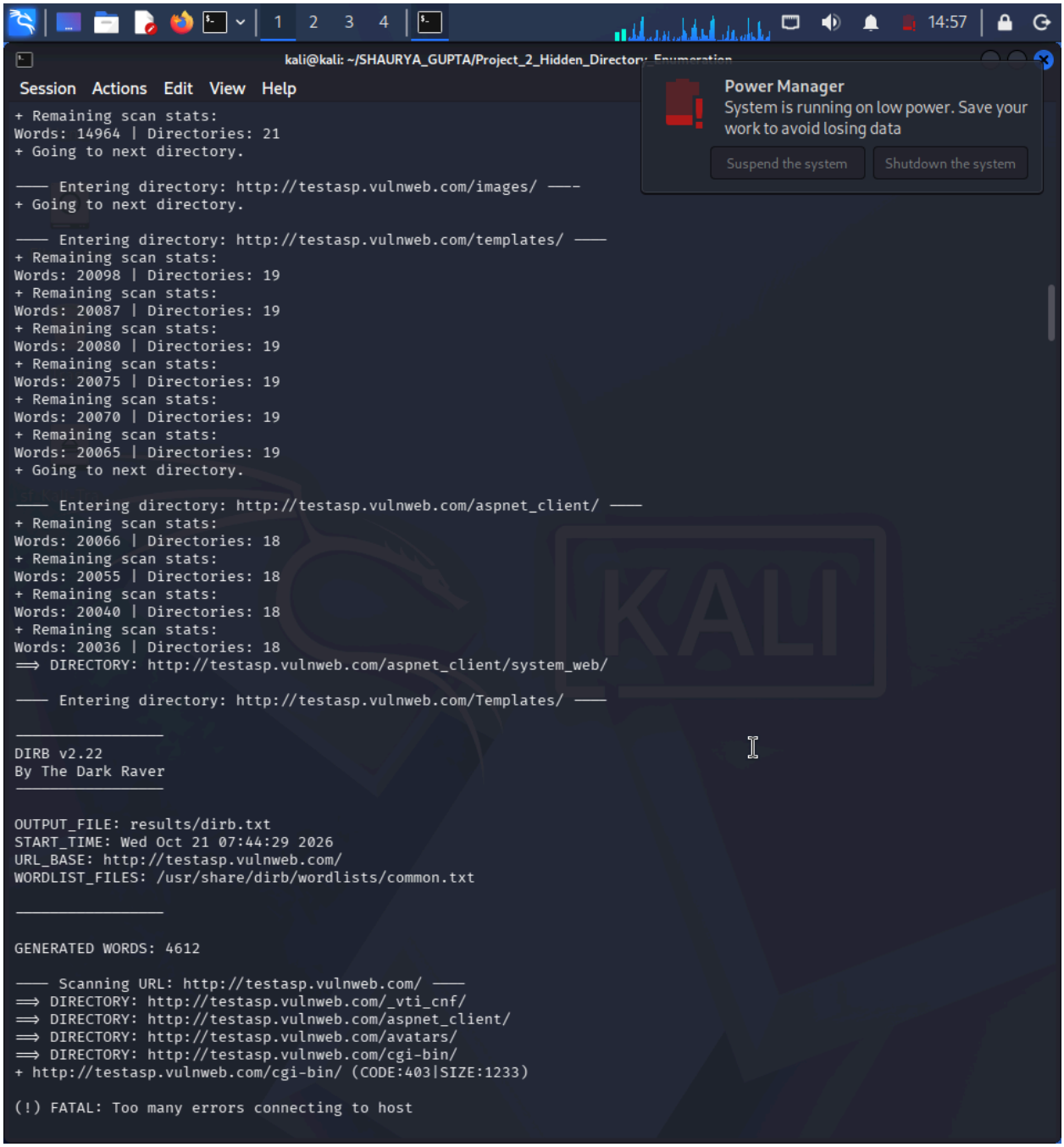
End of Report

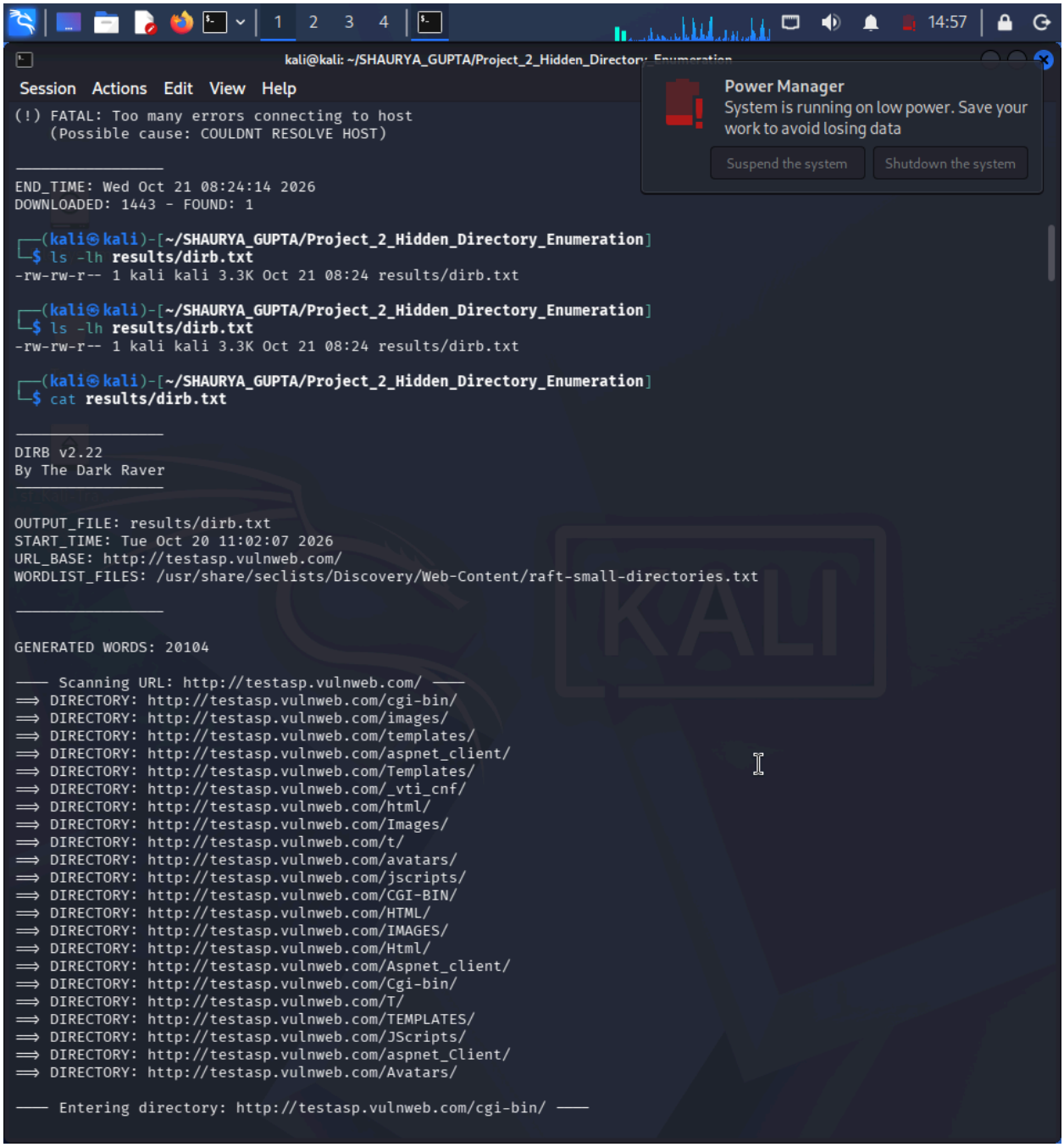
kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
Power Manager
System is running on low power. Save your work to avoid losing data
Suspend the system
Shutdown the system
/aspnet_client/system_web/ | Dirsearch | Not provided |
enumeration. The supplied output does not include its HTTP status.
/_vti_cnf/ | Gobuster, Dirsearch, Dirb | 301 |
lash URL. Potentially worth checking for exposed metadata, but no sensi
/html/ | Gobuster, Dirsearc | 301 |
lash URL. Contents were not independently verified.
/t/ | Gobuster, Dirsearc | 301 | Directory | Redirects to the trailing-s
lash URL. Contents were not independently verified.
/T/ | Gobuster, Dirsearch | 301 | Directory | Case-variant path returned
a redirect. Case sensitivity and distinct contents were not verified.
/avatars/ | Gobuster, Dirb | 301 | Directory | Redirects to the trailing-s
lash URL. No sensitive contents verified.
/jscripts/ | Gobuster | 301 | Directory | Redirects to the trailing-s
lash URL. No sensitive contents verified.
/search.asp | Gobuster | 200 | File | ASP endpoint returned HTTP
200. Response size was 2809 bytes. Application behavior and security were not tested.
/login.asp | Gobuster | 200 | File | ASP endpoint returned HTTP
200. Response size was 3194 bytes. Authentication behavior was not tested.
/register.asp | Gobuster | 200 | File | ASP endpoint returned HTTP
200. Response size was 3617 bytes. Registration behavior was not tested.
/logout.asp | Gobuster | 302 | File | Redirected to Default.asp.
Authentication and session behavior were not tested.
/default.asp | Gobuster | 200 | File | ASP endpoint returned HTTP
200. Response size was 3542 bytes in one result and 3540 bytes in another. The difference may reflect response vari
ation or request conditions.
/db.asp | Gobuster | 200 | File | Returned HTTP 200 with a re
sponse size of 0 bytes. No database contents or sensitive information were verified.
/robots.txt | Gobuster | 200 | File | Returned HTTP 200 with a re
sponse size of 13 bytes. Contents should be reviewed before drawing conclusions.
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ export CANDIDATE_PATH="/replace-with-an-actual-discovered-path"
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ curl -sS -I --max-time 15 \
"$TARGET$CANDIDATE_PATH" \
2>&1 | tee -a results/verification.txt
HTTP/1.1 404 Not Found
Content-Length: 1245
Content-Type: text/html
Server: Microsoft-IIS/8.5
X-Powered-By: ASP.NET
Date: Wed, 21 Oct 2026 19:02:03 GMT
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ curl -sS -L --max-time 15 \
-o /dev/null \
-w 'HTTP status: %{http_code}\nContent type: %{content_type}\nFinal URL: %{url_effective}\n' \
"$TARGET$CANDIDATE_PATH" \
2>&1 | tee -a results/verification.txt
HTTP status: 404
Content type: text/html
Final URL: http://testasp.vulnweb.com/replace-with-an-actual-discovered-path
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$


1 2 3 4
14:58
kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
(Possible cause: COULDNT RESOLVE HOST)
END_TIME: Wed Oct 21 08:24:14 2026
DOWNLOADED: 1443 - FOUND: 1
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ wc -l results/dirb.txt
102 results/dirb.txt
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ grep -E 'CODE:(200|204|301|302|307|401|403|500)' \
results/dirb.txt
+ http://testasp.vulnweb.com/cgi-bin/ (CODE:403|SIZE:1233)
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ cd ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ grep -hE 'Status:|CODE:' \
results/gobuster.txt \
results/dirsearch.txt \
results/dirb.txt \
> results/candidate_findings.txt
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ less results/gobuster.txt
"results/gobuster.txt" may be a binary file. See it anyway?
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ less results/gobuster.txt
"results/gobuster.txt" may be a binary file. See it anyway?
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ less results/dirsearch.txt
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ less results/gobuster.txt
"results/gobuster.txt" may be a binary file. See it anyway?
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ less results/dirsearch.txt
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ less results/dirb.txt
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ nano results/discovered_directories.txt
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ history
1 sudo apt update
2 sudo apt full-upgrade -y
3 sudo reboot
4 whoami
5 free -h
6 df -h
Power Manager
System is running on low power. Save your work to avoid losing data
Suspend the system
Shutdown the system


1 2 3 4
14:58
kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
Power Manager
System is running on low power. Save your work to avoid losing data
Suspend the system
Shutdown the system
+ Remaining scan stats:
Words: 14964 | Directories: 21
+ Going to next directory.
---- Entering directory: http://testasp.vulnweb.com/images/ ----
+ Going to next directory.
---- Entering directory: http://testasp.vulnweb.com/templates/ ----
+ Remaining scan stats:
Words: 20098 | Directories: 19
+ Remaining scan stats:
Words: 20087 | Directories: 19
+ Remaining scan stats:
Words: 20080 | Directories: 19
+ Remaining scan stats:
Words: 20075 | Directories: 19
+ Remaining scan stats:
Words: 20070 | Directories: 19
+ Remaining scan stats:
Words: 20065 | Directories: 19
+ Going to next directory.
---- Entering directory: http://testasp.vulnweb.com/aspnet_client/ ----
+ Remaining scan stats:
Words: 20066 | Directories: 18
+ Remaining scan stats:
Words: 20055 | Directories: 18
+ Remaining scan stats:
Words: 20040 | Directories: 18
+ Remaining scan stats:
Words: 20036 | Directories: 18
==> DIRECTORY: http://testasp.vulnweb.com/aspnet_client/system_web/
---- Entering directory: http://testasp.vulnweb.com/Templates/ ----
DIRB v2.22
By The Dark Raver
OUTPUT_FILE: results/dirb.txt
START_TIME: Wed Oct 21 07:44:29 2026
URL_BASE: http://testasp.vulnweb.com/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
GENERATED WORDS: 4612
---- Scanning URL: http://testasp.vulnweb.com/ ----
==> DIRECTORY: http://testasp.vulnweb.com/_vti_cnf/
==> DIRECTORY: http://testasp.vulnweb.com/aspnet_client/
==> DIRECTORY: http://testasp.vulnweb.com/avatars/
==> DIRECTORY: http://testasp.vulnweb.com/cgi-bin/
+ http://testasp.vulnweb.com/cgi-bin/ (CODE:403|SIZE:1233)
(!) FATAL: Too many errors connecting to host


1 2 3 4
14:58
kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
(Possible cause: COULDNT RESOLVE HOST)
END_TIME: Wed Oct 21 08:24:14 2026
DOWNLOADED: 1443 - FOUND: 1
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ grep -E 'CODE: (200|204|301|302|307|401|403|500)' results/dirb.txt
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ find /usr/share/dirb/wordlists -maxdepth 1 -type f
/usr/share/dirb/wordlists/euskera.txt
/usr/share/dirb/wordlists/extensions_common.txt
/usr/share/dirb/wordlists/catala.txt
/usr/share/dirb/wordlists/small.txt
/usr/share/dirb/wordlists/indexes.txt
/usr/share/dirb/wordlists/mutations_common.txt
/usr/share/dirb/wordlists/common.txt
/usr/share/dirb/wordlists/spanish.txt
/usr/share/dirb/wordlists/big.txt
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ cat results/dirb.txt
DIRB v2.22
By The Dark Raver
OUTPUT_FILE: results/dirb.txt
START_TIME: Tue Oct 20 11:02:07 2026
URL_BASE: http://testasp.vulnweb.com/
WORDLIST_FILES: /usr/share/seclists/Discovery/Web-Content/raft-small-directories.txt
GENERATED WORDS: 20104
---- Scanning URL: http://testasp.vulnweb.com/ ----
==> DIRECTORY: http://testasp.vulnweb.com/cgi-bin/
==> DIRECTORY: http://testasp.vulnweb.com/images/
==> DIRECTORY: http://testasp.vulnweb.com/templates/
==> DIRECTORY: http://testasp.vulnweb.com/aspnet_client/
==> DIRECTORY: http://testasp.vulnweb.com/Templates/
==> DIRECTORY: http://testasp.vulnweb.com/_vti_cnf/
==> DIRECTORY: http://testasp.vulnweb.com/html/
==> DIRECTORY: http://testasp.vulnweb.com/Images/
==> DIRECTORY: http://testasp.vulnweb.com/t/
==> DIRECTORY: http://testasp.vulnweb.com/avatars/
==> DIRECTORY: http://testasp.vulnweb.com/jscripts/
==> DIRECTORY: http://testasp.vulnweb.com/CGI-BIN/
==> DIRECTORY: http://testasp.vulnweb.com/HTML/
==> DIRECTORY: http://testasp.vulnweb.com/IMAGES/
==> DIRECTORY: http://testasp.vulnweb.com/Html/
==> DIRECTORY: http://testasp.vulnweb.com/Aspnet_client/
==> DIRECTORY: http://testasp.vulnweb.com/Cgi-bin/
==> DIRECTORY: http://testasp.vulnweb.com/T/
Power Manager
System is running on low power. Save your work to avoid losing data
Suspend the system
Shutdown the system

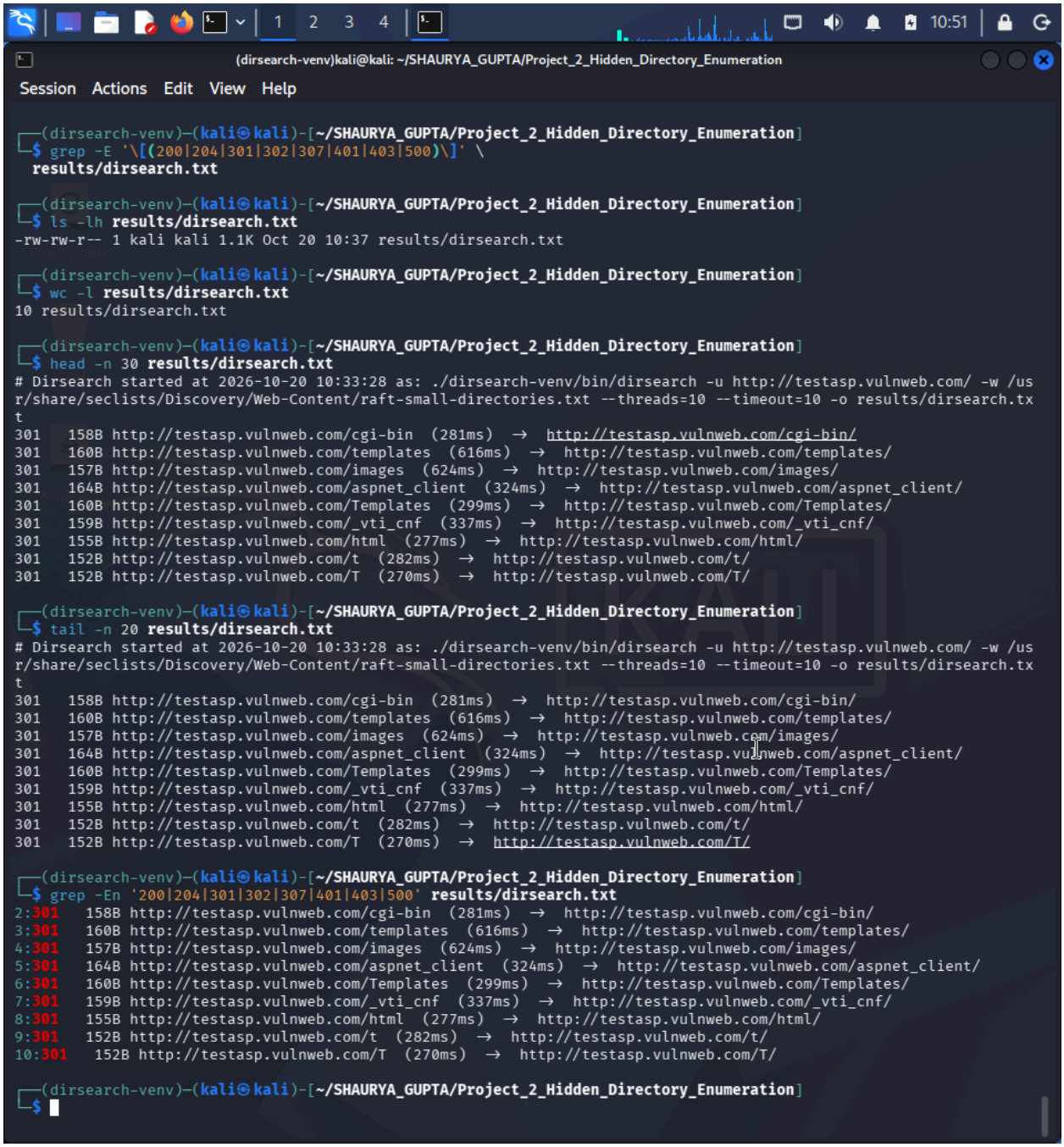

1 2 3 4
14:57
kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
Power Manager
System is running on low power. Save your work to avoid losing data
Suspend the system
Shutdown the system
+ Remaining scan stats:
Words: 14964 | Directories: 21
+ Going to next directory.
—— Entering directory: http://testasp.vulnweb.com/images/ ——-
+ Going to next directory.
—— Entering directory: http://testasp.vulnweb.com/templates/ ——
+ Remaining scan stats:
Words: 20098 | Directories: 19
+ Remaining scan stats:
Words: 20087 | Directories: 19
+ Remaining scan stats:
Words: 20080 | Directories: 19
+ Remaining scan stats:
Words: 20075 | Directories: 19
+ Remaining scan stats:
Words: 20070 | Directories: 19
+ Remaining scan stats:
Words: 20065 | Directories: 19
+ Going to next directory.
—— Entering directory: http://testasp.vulnweb.com/aspnet_client/ ——
+ Remaining scan stats:
Words: 20066 | Directories: 18
+ Remaining scan stats:
Words: 20055 | Directories: 18
+ Remaining scan stats:
Words: 20040 | Directories: 18
+ Remaining scan stats:
Words: 20036 | Directories: 18
==> DIRECTORY: http://testasp.vulnweb.com/aspnet_client/system_web/
—— Entering directory: http://testasp.vulnweb.com/Templates/ ——
DIRB v2.22
By The Dark Raver
OUTPUT_FILE: results/dirb.txt
START_TIME: Wed Oct 21 07:44:29 2026
URL_BASE: http://testasp.vulnweb.com/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
GENERATED WORDS: 4612
—— Scanning URL: http://testasp.vulnweb.com/ ——
==> DIRECTORY: http://testasp.vulnweb.com/_vti_cnf/
==> DIRECTORY: http://testasp.vulnweb.com/aspnet_client/
==> DIRECTORY: http://testasp.vulnweb.com/avatars/
==> DIRECTORY: http://testasp.vulnweb.com/cgi-bin/
+ http://testasp.vulnweb.com/cgi-bin/ (CODE:403|SIZE:1233)
(!) FATAL: Too many errors connecting to host

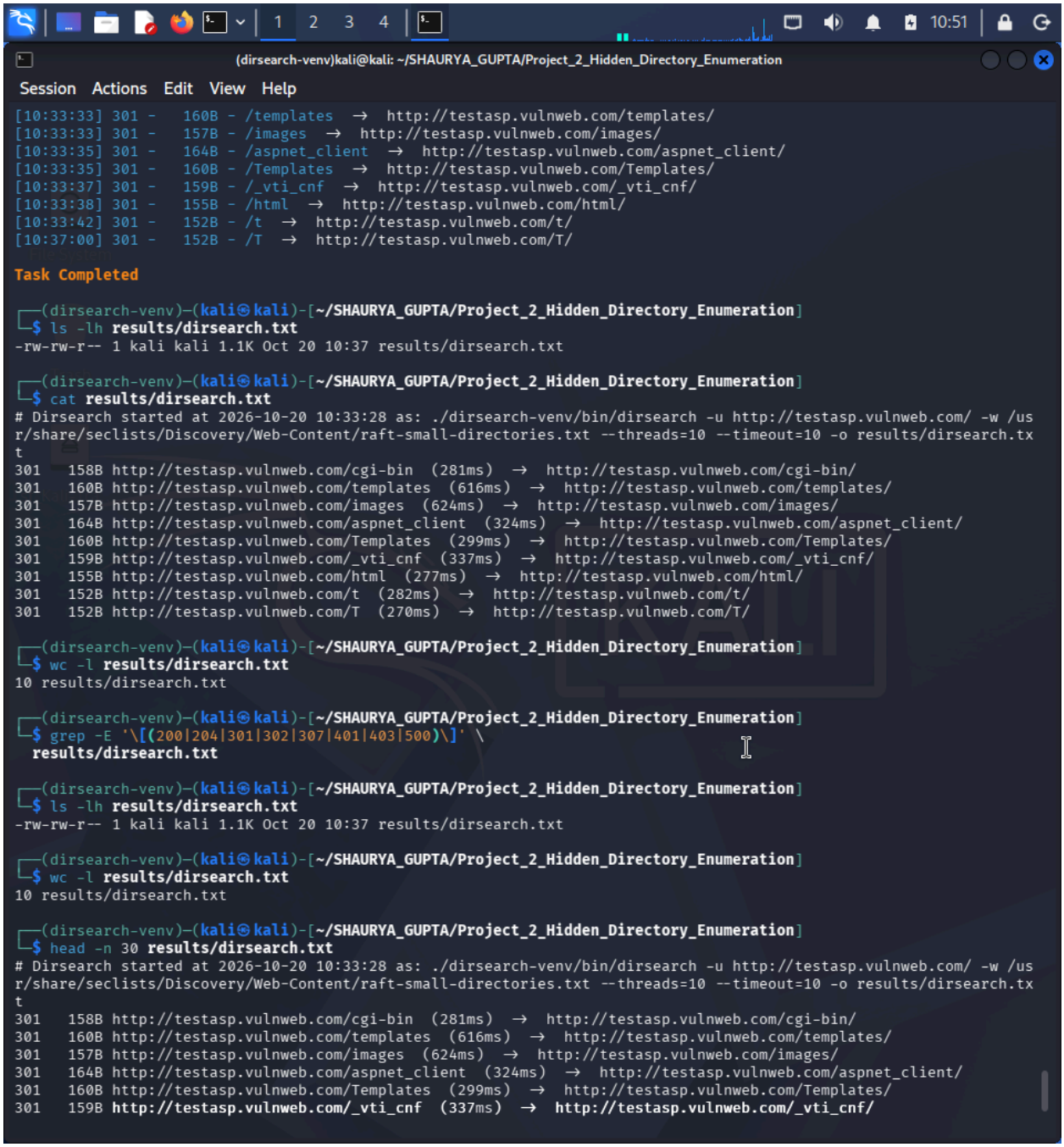

kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
Power Manager
System is running on low power. Save your work to avoid losing data
Suspend the system
Shutdown the system
(!) FATAL: Too many errors connecting to host
(Possible cause: COULDNT RESOLVE HOST)
END_TIME: Wed Oct 21 08:24:14 2026
DOWNLOADED: 1443 - FOUND: 1
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ ls -lh results/dirb.txt
-rw-rw-r-- 1 kali kali 3.3K Oct 21 08:24 results/dirb.txt
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ ls -lh results/dirb.txt
-rw-rw-r-- 1 kali kali 3.3K Oct 21 08:24 results/dirb.txt
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ cat results/dirb.txt
DIRB v2.22
By The Dark Raver
OUTPUT_FILE: results/dirb.txt
START_TIME: Tue Oct 20 11:02:07 2026
URL_BASE: http://testasp.vulnweb.com/
WORDLIST_FILES: /usr/share/seclists/Discovery/Web-Content/raft-small-directories.txt
GENERATED WORDS: 20104
---- Scanning URL: http://testasp.vulnweb.com/ ----
==> DIRECTORY: http://testasp.vulnweb.com/cgi-bin/
==> DIRECTORY: http://testasp.vulnweb.com/images/
==> DIRECTORY: http://testasp.vulnweb.com/templates/
==> DIRECTORY: http://testasp.vulnweb.com/aspnet_client/
==> DIRECTORY: http://testasp.vulnweb.com/Templates/
==> DIRECTORY: http://testasp.vulnweb.com/_vti_cnf/
==> DIRECTORY: http://testasp.vulnweb.com/html/
==> DIRECTORY: http://testasp.vulnweb.com/Images/
==> DIRECTORY: http://testasp.vulnweb.com/t/
==> DIRECTORY: http://testasp.vulnweb.com/avatars/
==> DIRECTORY: http://testasp.vulnweb.com/jscripts/
==> DIRECTORY: http://testasp.vulnweb.com/CGI-BIN/
==> DIRECTORY: http://testasp.vulnweb.com/HTML/
==> DIRECTORY: http://testasp.vulnweb.com/IMAGES/
==> DIRECTORY: http://testasp.vulnweb.com/Html/
==> DIRECTORY: http://testasp.vulnweb.com/Aspnet_client/
==> DIRECTORY: http://testasp.vulnweb.com/Cgi-bin/
==> DIRECTORY: http://testasp.vulnweb.com/T/
==> DIRECTORY: http://testasp.vulnweb.com/TEMPLATES/
==> DIRECTORY: http://testasp.vulnweb.com/JScripts/
==> DIRECTORY: http://testasp.vulnweb.com/aspnet_Client/
==> DIRECTORY: http://testasp.vulnweb.com/Avatars/
---- Entering directory: http://testasp.vulnweb.com/cgi-bin/ ----

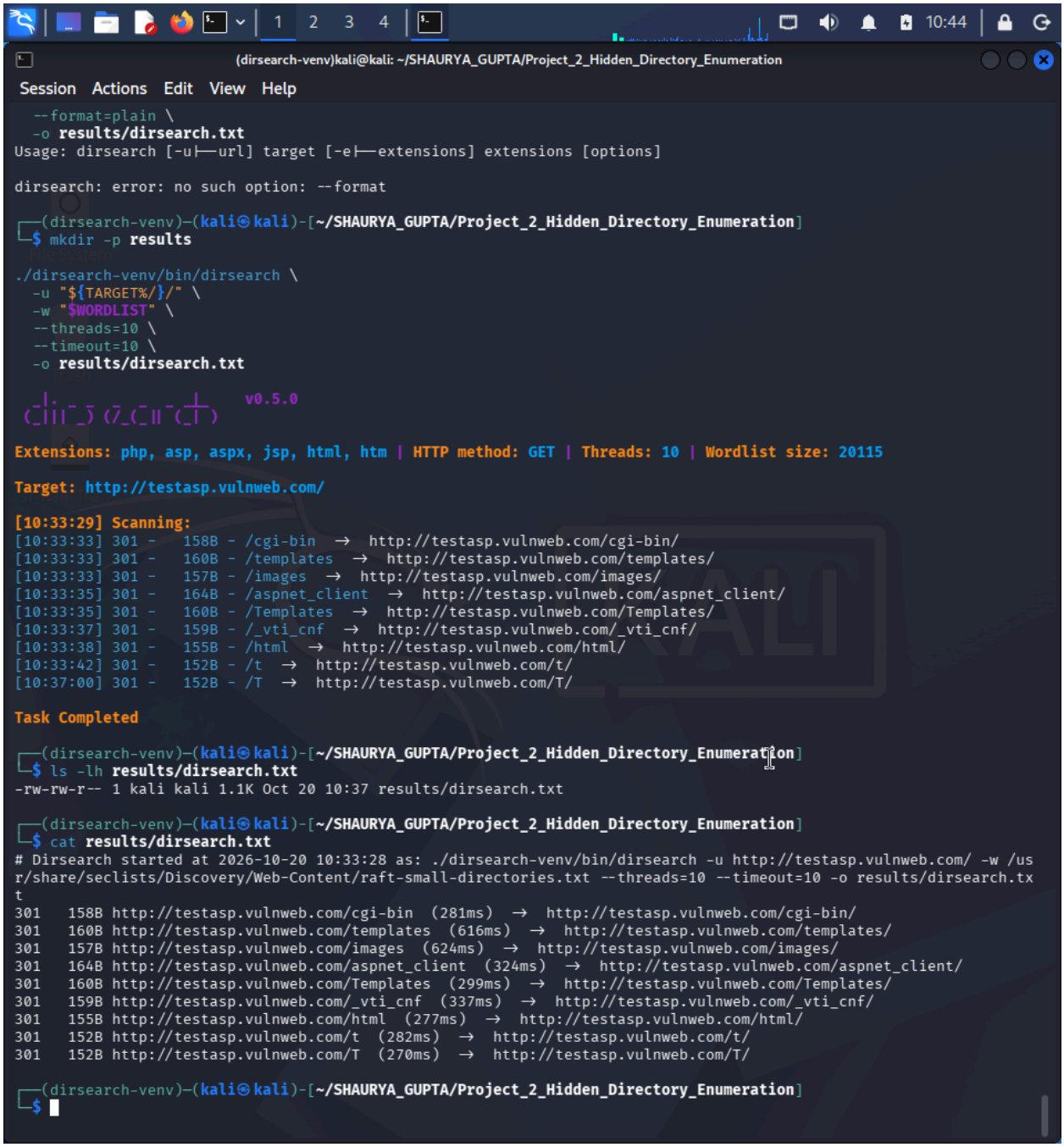
kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
Power Manager
System is running on low power. Save your work to avoid losing data
Suspend the system
Shutdown the system
EXAMPLES
dirb http://url/directory/ (Simple Test)
dirb http://url/ -X .html (Test files with '.html' extension)
dirb https://secure_url/ (Simple Test with SSL)
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ dirb "$TARGET/" "$WORDLIST" -o results/dirb.txt
DIRB v2.22
By The Dark Raver
(!) FATAL: Invalid URL format: /
(Use: "http://host/" or "https://host/" for SSL)
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ echo "TARGET = $TARGET"
echo "WORDLIST = $WORDLIST"
TARGET =
WORDLIST =
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ TARGET="http://testasp.vulnweb.com"
WORDLIST="/usr/share/dirb/wordlists/common.txt"
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ ls -lh "$WORDLIST"
-rw-r--r-- 1 root root 36K Nov 17 2014 /usr/share/dirb/wordlists/common.txt
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ cd ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
mkdir -p results
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ dirb "$TARGET/" "$WORDLIST" -o results/dirb.txt
DIRB v2.22
By The Dark Raver
OUTPUT_FILE: results/dirb.txt
START_TIME: Wed Oct 21 07:44:29 2026
URL_BASE: http://testasp.vulnweb.com/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
GENERATED WORDS: 4612
---- Scanning URL: http://testasp.vulnweb.com/ ----
==> DIRECTORY: http://testasp.vulnweb.com/_vti_cnf/
==> DIRECTORY: http://testasp.vulnweb.com/aspnet_client/
==> DIRECTORY: http://testasp.vulnweb.com/avatars/

1 2 3 4
14:56
kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
Power Manager
System is running on low power. Save your work to avoid losing data
Suspend the system
Shutdown the system
┌──(kali㉿kali)-[~]
└─$ cd ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ dirb "$TARGET/" "$WORDLIST" -o results/dirb.txt
DIRB v2.22
By The Dark Raver
(!) FATAL: Invalid URL format: /
(Use: "http://host/" or "https://host/" for SSL)
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ dirb
DIRB v2.22
By The Dark Raver
dirb <url_base> [<wordlist_file(s)>] [options]
NOTES
<url_base> : Base URL to scan. (Use -resume for session resuming)
<wordlist_file(s)> : List of wordfiles. (wordfile1,wordfile2,wordfile3 ...)
HOTKEYS
'n' → Go to next directory.
'q' → Stop scan. (Saving state for resume)
'r' → Remaining scan stats.
OPTIONS
-a <agent_string> : Specify your custom USER_AGENT.
-b : Use path as is.
-c <cookie_string> : Set a cookie for the HTTP request.
-E <certificate> : path to the client certificate.
-f : Fine tunning of NOT_FOUND (404) detection.
-H <header_string> : Add a custom header to the HTTP request.
-i : Use case-insensitive search.
-l : Print "Location" header when found.
-N <nf_code>: Ignore responses with this HTTP code.
-o <output_file> : Save output to disk.
-p <proxy[:port]> : Use this proxy. (Default port is 1080)
-P <proxy_username:proxy_password> : Proxy Authentication.
-r : Don't search recursively.
-R : Interactive recursion. (Asks for each directory)
-S : Silent Mode. Don't show tested words. (For dumb terminals)
-t : Don't force an ending '/' on URLs.
-u <username:password> : HTTP Authentication.
-v : Show also NOT_FOUND pages.
-w : Don't stop on WARNING messages.
-X <extensions> / -x <exts_file> : Append each word with this extensions.
-z <millisecs> : Add a milliseconds delay to not cause excessive Flood.

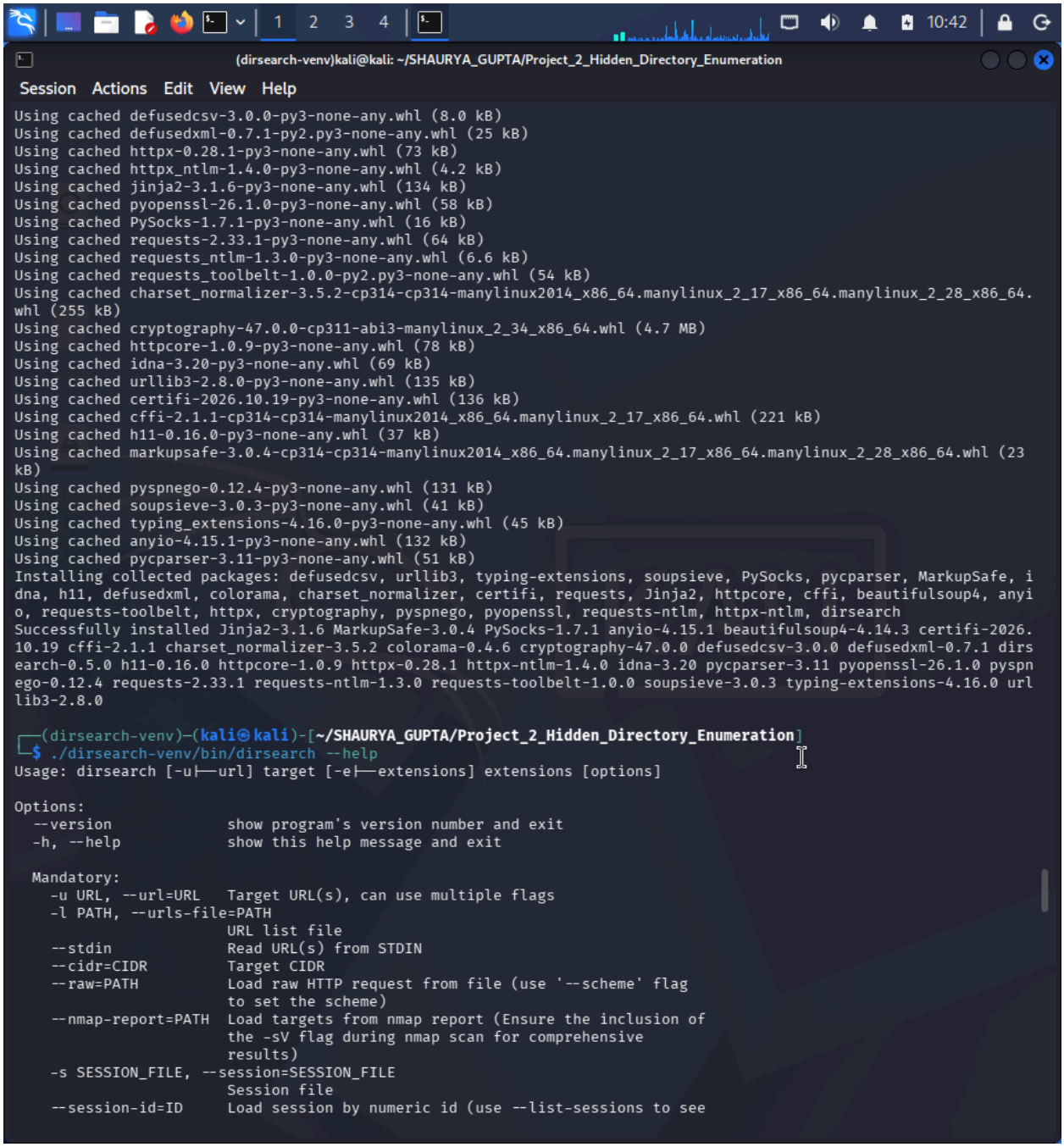
1 2 3 4
11:05
(dirsearch-venv)kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
(dirsearch-venv)-(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ dirb
DIRB v2.22
By The Dark Raver
dirb <url_base> [<wordlist_file(s)>] [options]
NOTES
<url_base> : Base URL to scan. (Use -resume for session resuming)
<wordlist_file(s)> : List of wordfiles. (wordfile1,wordfile2,wordfile3 ...)
HOTKEYS
'n' → Go to next directory.
'q' → Stop scan. (Saving state for resume)
'r' → Remaining scan stats.
OPTIONS
-a <agent_string> : Specify your custom USER_AGENT.
-b : Use path as is.
-c <cookie_string> : Set a cookie for the HTTP request.
-E <certificate> : path to the client certificate.
-f : Fine tunning of NOT_FOUND (404) detection.
-H <header_string> : Add a custom header to the HTTP request.
-i : Use case-insensitive search.
-l : Print "Location" header when found.
-N <nf_code>: Ignore responses with this HTTP code.
-o <output_file> : Save output to disk.
-p <proxy[:port]> : Use this proxy. (Default port is 1080)
-P <proxy_username:proxy_password> : Proxy Authentication.
-r : Don't search recursively.
-R : Interactive recursion. (Asks for each directory)
-S : Silent Mode. Don't show tested words. (For dumb terminals)
-t : Don't force an ending '/' on URLs.
-u <username:password> : HTTP Authentication.
-v : Show also NOT_FOUND pages.
-w : Don't stop on WARNING messages.
-X <extensions> / -x <exts_file> : Append each word with this extensions.
-z <millisecs> : Add a milliseconds delay to not cause excessive Flood.
EXAMPLES
dirb http://url/directory/ (Simple Test)
dirb http://url/ -X .html (Test files with '.html' extension)
dirb http://url/ /usr/share/dirb/wordlists/vulns/apache.txt (Test with apache.txt wordlist)
dirb https://secure_url/ (Simple Test with SSL)
(dirsearch-venv)-(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ dirb "$TARGET/" "$WORDLIST" -o results/dirb.txt
DIRB v2.22
By The Dark Raver

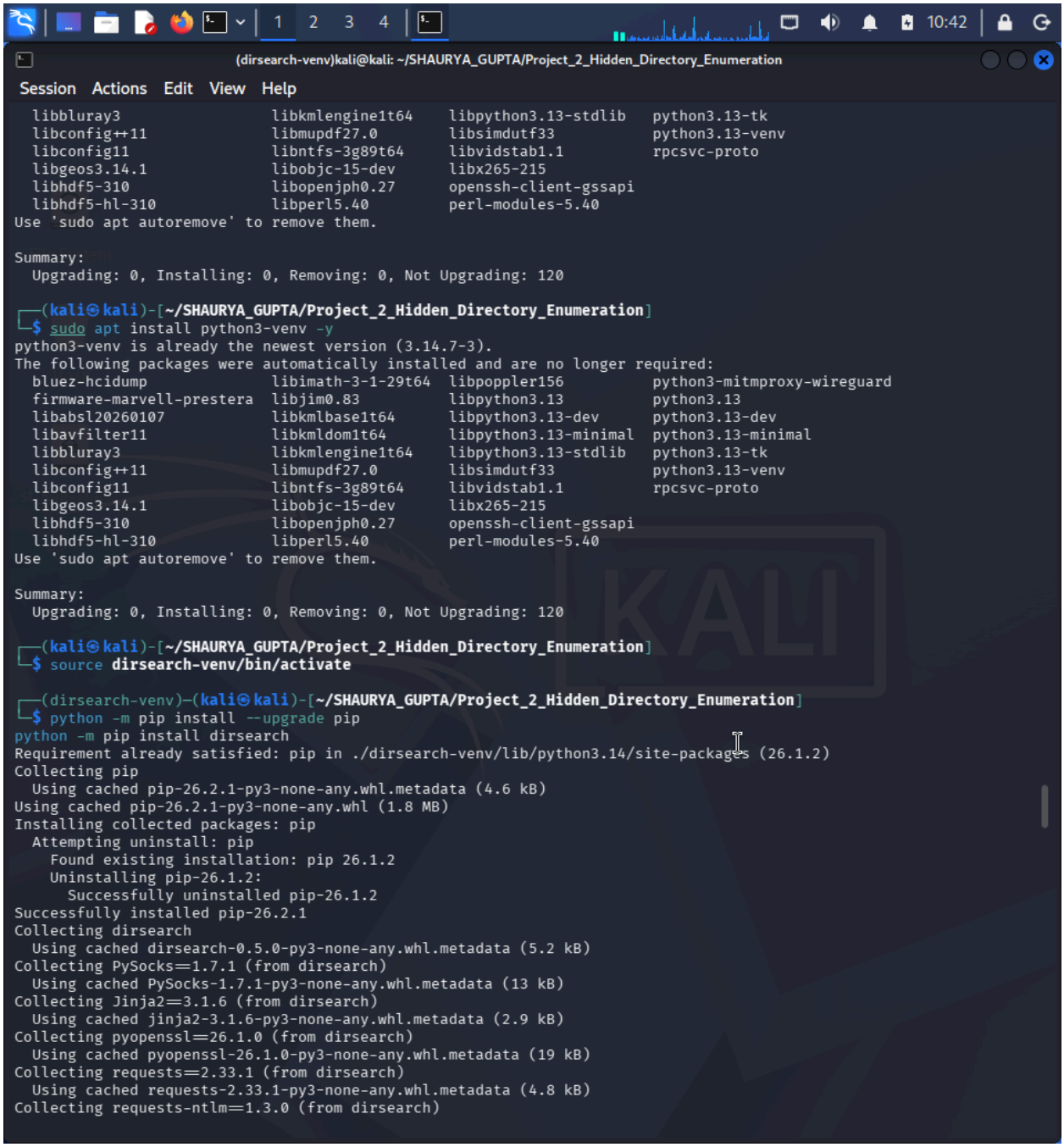

1 2 3 4
10:51
(dirsearch-venv)kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
┌──(dirsearch-venv)─(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ grep -E '\[(200|204|301|302|307|401|403|500)\]' \
results/dirsearch.txt
┌──(dirsearch-venv)─(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ ls -lh results/dirsearch.txt
-rw-rw-r-- 1 kali kali 1.1K Oct 20 10:37 results/dirsearch.txt
┌──(dirsearch-venv)─(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ wc -l results/dirsearch.txt
10 results/dirsearch.txt
┌──(dirsearch-venv)─(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ head -n 30 results/dirsearch.txt
Dirsearch started at 2026-10-20 10:33:28 as: ./dirsearch-venv/bin/dirsearch -u http://testasp.vulnweb.com/ -w /us
r/share/seclists/Discovery/Web-Content/raft-small-directories.txt --threads=10 --timeout=10 -o results/dirsearch.tx
t
301 158B http://testasp.vulnweb.com/cgi-bin (281ms) → http://testasp.vulnweb.com/cgi-bin/
301 160B http://testasp.vulnweb.com/templates (616ms) → http://testasp.vulnweb.com/templates/
301 157B http://testasp.vulnweb.com/images (624ms) → http://testasp.vulnweb.com/images/
301 164B http://testasp.vulnweb.com/aspnet_client (324ms) → http://testasp.vulnweb.com/aspnet_client/
301 160B http://testasp.vulnweb.com/Templates (299ms) → http://testasp.vulnweb.com/Templates/
301 159B http://testasp.vulnweb.com/_vti_cnf (337ms) → http://testasp.vulnweb.com/_vti_cnf/
301 155B http://testasp.vulnweb.com/html (277ms) → http://testasp.vulnweb.com/html/
301 152B http://testasp.vulnweb.com/t (282ms) → http://testasp.vulnweb.com/t/
301 152B http://testasp.vulnweb.com/T (270ms) → http://testasp.vulnweb.com/T/
┌──(dirsearch-venv)─(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ tail -n 20 results/dirsearch.txt
Dirsearch started at 2026-10-20 10:33:28 as: ./dirsearch-venv/bin/dirsearch -u http://testasp.vulnweb.com/ -w /us
r/share/seclists/Discovery/Web-Content/raft-small-directories.txt --threads=10 --timeout=10 -o results/dirsearch.tx
t
301 158B http://testasp.vulnweb.com/cgi-bin (281ms) → http://testasp.vulnweb.com/cgi-bin/
301 160B http://testasp.vulnweb.com/templates (616ms) → http://testasp.vulnweb.com/templates/
301 157B http://testasp.vulnweb.com/images (624ms) → http://testasp.vulnweb.com/images/
301 164B http://testasp.vulnweb.com/aspnet_client (324ms) → http://testasp.vulnweb.com/aspnet_client/
301 160B http://testasp.vulnweb.com/Templates (299ms) → http://testasp.vulnweb.com/Templates/
301 159B http://testasp.vulnweb.com/_vti_cnf (337ms) → http://testasp.vulnweb.com/_vti_cnf/
301 155B http://testasp.vulnweb.com/html (277ms) → http://testasp.vulnweb.com/html/
301 152B http://testasp.vulnweb.com/t (282ms) → http://testasp.vulnweb.com/t/
301 152B http://testasp.vulnweb.com/T (270ms) → http://testasp.vulnweb.com/T/
┌──(dirsearch-venv)─(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ grep -En '200|204|301|302|307|401|403|500' results/dirsearch.txt
2:301 158B http://testasp.vulnweb.com/cgi-bin (281ms) → http://testasp.vulnweb.com/cgi-bin/
3:301 160B http://testasp.vulnweb.com/templates (616ms) → http://testasp.vulnweb.com/templates/
4:301 157B http://testasp.vulnweb.com/images (624ms) → http://testasp.vulnweb.com/images/
5:301 164B http://testasp.vulnweb.com/aspnet_client (324ms) → http://testasp.vulnweb.com/aspnet_client/
6:301 160B http://testasp.vulnweb.com/Templates (299ms) → http://testasp.vulnweb.com/Templates/
7:301 159B http://testasp.vulnweb.com/_vti_cnf (337ms) → http://testasp.vulnweb.com/_vti_cnf/
8:301 155B http://testasp.vulnweb.com/html (277ms) → http://testasp.vulnweb.com/html/
9:301 152B http://testasp.vulnweb.com/t (282ms) → http://testasp.vulnweb.com/t/
10:301 152B http://testasp.vulnweb.com/T (270ms) → http://testasp.vulnweb.com/T/
┌──(dirsearch-venv)─(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$

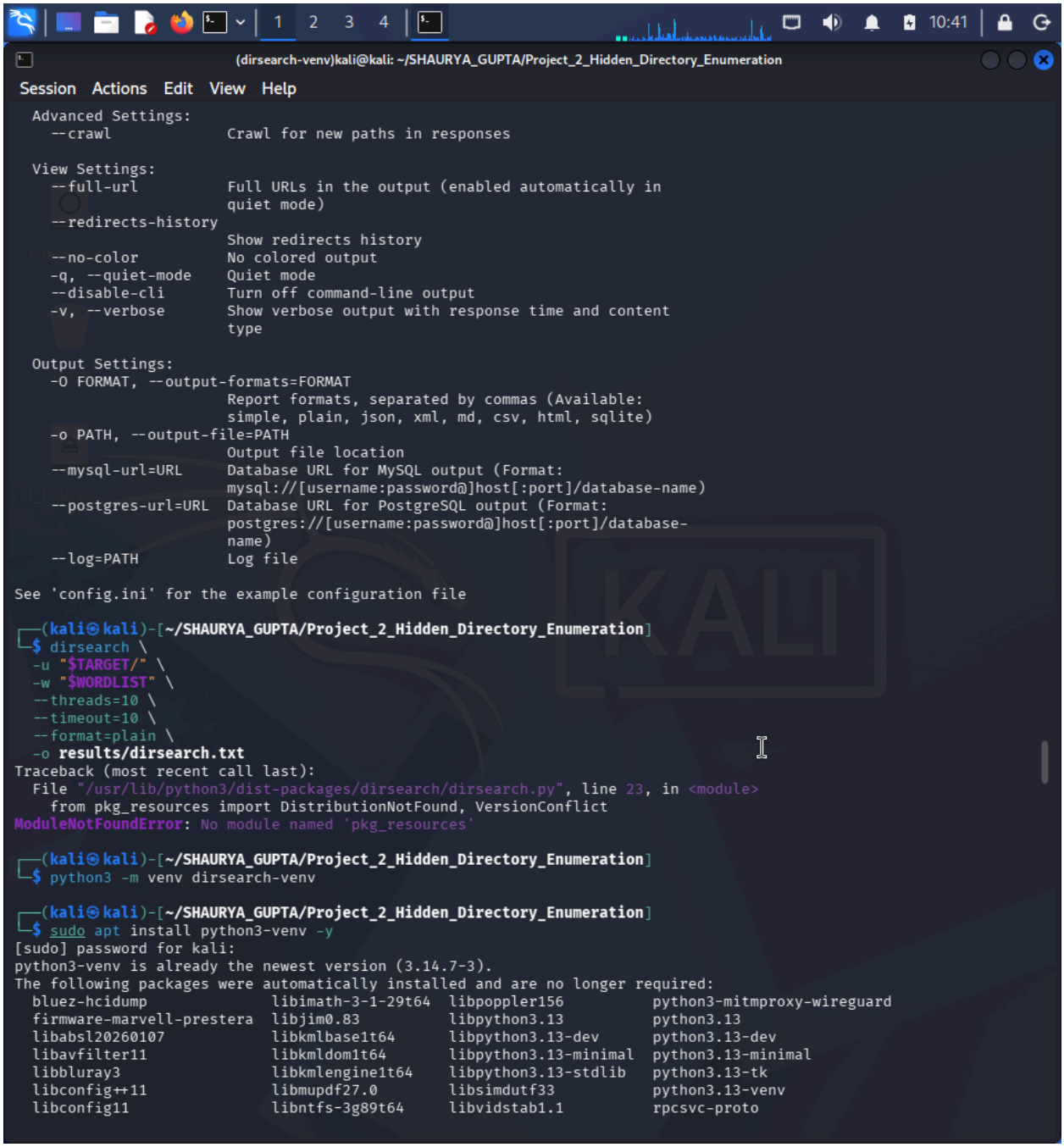

(dirsearch-venv)kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
[10:33:33] 301 - 160B - /templates → http://testasp.vulnweb.com/templates/
[10:33:33] 301 - 157B - /images → http://testasp.vulnweb.com/images/
[10:33:35] 301 - 164B - /aspnet_client → http://testasp.vulnweb.com/aspnet_client/
[10:33:35] 301 - 160B - /Templates → http://testasp.vulnweb.com/Templates/
[10:33:37] 301 - 159B - /_vti_cnf → http://testasp.vulnweb.com/_vti_cnf/
[10:33:38] 301 - 155B - /html → http://testasp.vulnweb.com/html/
[10:33:42] 301 - 152B - /t → http://testasp.vulnweb.com/t/
[10:37:00] 301 - 152B - /T → http://testasp.vulnweb.com/T/
Task Completed
(dirsearch-venv)-(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ ls -lh results/dirsearch.txt
-rw-rw-r-- 1 kali kali 1.1K Oct 20 10:37 results/dirsearch.txt
(dirsearch-venv)-(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ cat results/dirsearch.txt
# Dirsearch started at 2026-10-20 10:33:28 as: ./dirsearch-venv/bin/dirsearch -u http://testasp.vulnweb.com/ -w /usr/share/seclists/Discovery/Web-Content/raft-small-directories.txt --threads=10 --timeout=10 -o results/dirsearch.txt
301 158B http://testasp.vulnweb.com/cgi-bin (281ms) → http://testasp.vulnweb.com/cgi-bin/
301 160B http://testasp.vulnweb.com/templates (616ms) → http://testasp.vulnweb.com/templates/
301 157B http://testasp.vulnweb.com/images (624ms) → http://testasp.vulnweb.com/images/
301 164B http://testasp.vulnweb.com/aspnet_client (324ms) → http://testasp.vulnweb.com/aspnet_client/
301 160B http://testasp.vulnweb.com/Templates (299ms) → http://testasp.vulnweb.com/Templates/
301 159B http://testasp.vulnweb.com/_vti_cnf (337ms) → http://testasp.vulnweb.com/_vti_cnf/
301 155B http://testasp.vulnweb.com/html (277ms) → http://testasp.vulnweb.com/html/
301 152B http://testasp.vulnweb.com/t (282ms) → http://testasp.vulnweb.com/t/
301 152B http://testasp.vulnweb.com/T (270ms) → http://testasp.vulnweb.com/T/
(dirsearch-venv)-(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ wc -l results/dirsearch.txt
10 results/dirsearch.txt
(dirsearch-venv)-(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ grep -E '\[(200|204|301|302|307|401|403|500)\]' \
results/dirsearch.txt
(dirsearch-venv)-(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ ls -lh results/dirsearch.txt
-rw-rw-r-- 1 kali kali 1.1K Oct 20 10:37 results/dirsearch.txt
(dirsearch-venv)-(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ wc -l results/dirsearch.txt
10 results/dirsearch.txt
(dirsearch-venv)-(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ head -n 30 results/dirsearch.txt
# Dirsearch started at 2026-10-20 10:33:28 as: ./dirsearch-venv/bin/dirsearch -u http://testasp.vulnweb.com/ -w /usr/share/seclists/Discovery/Web-Content/raft-small-directories.txt --threads=10 --timeout=10 -o results/dirsearch.txt
301 158B http://testasp.vulnweb.com/cgi-bin (281ms) → http://testasp.vulnweb.com/cgi-bin/
301 160B http://testasp.vulnweb.com/templates (616ms) → http://testasp.vulnweb.com/templates/
301 157B http://testasp.vulnweb.com/images (624ms) → http://testasp.vulnweb.com/images/
301 164B http://testasp.vulnweb.com/aspnet_client (324ms) → http://testasp.vulnweb.com/aspnet_client/
301 160B http://testasp.vulnweb.com/Templates (299ms) → http://testasp.vulnweb.com/Templates/
301 159B http://testasp.vulnweb.com/_vti_cnf (337ms) → http://testasp.vulnweb.com/_vti_cnf/


(dirsearch-venv)kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
--format=plain \
-o results/dirsearch.txt
Usage: dirsearch [-u|--url] target [-e|--extensions] extensions [options]
dirsearch: error: no such option: --format
(dirsearch-venv)-(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ mkdir -p results
./dirsearch-venv/bin/dirsearch \
-u "${TARGET%/}/" \
-w "$WORDLIST" \
--threads=10 \
--timeout=10 \
-o results/dirsearch.txt
v0.5.0
Extensions: php, asp, aspx, jsp, html, htm | HTTP method: GET | Threads: 10 | Wordlist size: 20115
Target: http://testasp.vulnweb.com/
[10:33:29] Scanning:
[10:33:33] 301 - 158B - /cgi-bin → http://testasp.vulnweb.com/cgi-bin/
[10:33:33] 301 - 160B - /templates → http://testasp.vulnweb.com/templates/
[10:33:33] 301 - 157B - /images → http://testasp.vulnweb.com/images/
[10:33:35] 301 - 164B - /aspnet_client → http://testasp.vulnweb.com/aspnet_client/
[10:33:35] 301 - 160B - /Templates → http://testasp.vulnweb.com/Templates/
[10:33:37] 301 - 159B - /_vti_cnf → http://testasp.vulnweb.com/_vti_cnf/
[10:33:38] 301 - 155B - /html → http://testasp.vulnweb.com/html/
[10:33:42] 301 - 152B - /t → http://testasp.vulnweb.com/t/
[10:37:00] 301 - 152B - /T → http://testasp.vulnweb.com/T/
Task Completed
(dirsearch-venv)-(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ ls -lh results/dirsearch.txt
-rw-rw-r-- 1 kali kali 1.1K Oct 20 10:37 results/dirsearch.txt
(dirsearch-venv)-(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ cat results/dirsearch.txt
# Dirsearch started at 2026-10-20 10:33:28 as: ./dirsearch-venv/bin/dirsearch -u http://testasp.vulnweb.com/ -w /usr/share/seclists/Discovery/Web-Content/raft-small-directories.txt --threads=10 --timeout=10 -o results/dirsearch.txt
301 158B http://testasp.vulnweb.com/cgi-bin (281ms) → http://testasp.vulnweb.com/cgi-bin/
301 160B http://testasp.vulnweb.com/templates (616ms) → http://testasp.vulnweb.com/templates/
301 157B http://testasp.vulnweb.com/images (624ms) → http://testasp.vulnweb.com/images/
301 164B http://testasp.vulnweb.com/aspnet_client (324ms) → http://testasp.vulnweb.com/aspnet_client/
301 160B http://testasp.vulnweb.com/Templates (299ms) → http://testasp.vulnweb.com/Templates/
301 159B http://testasp.vulnweb.com/_vti_cnf (337ms) → http://testasp.vulnweb.com/_vti_cnf/
301 155B http://testasp.vulnweb.com/html (277ms) → http://testasp.vulnweb.com/html/
301 152B http://testasp.vulnweb.com/t (282ms) → http://testasp.vulnweb.com/t/
301 152B http://testasp.vulnweb.com/T (270ms) → http://testasp.vulnweb.com/T/
(dirsearch-venv)-(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$

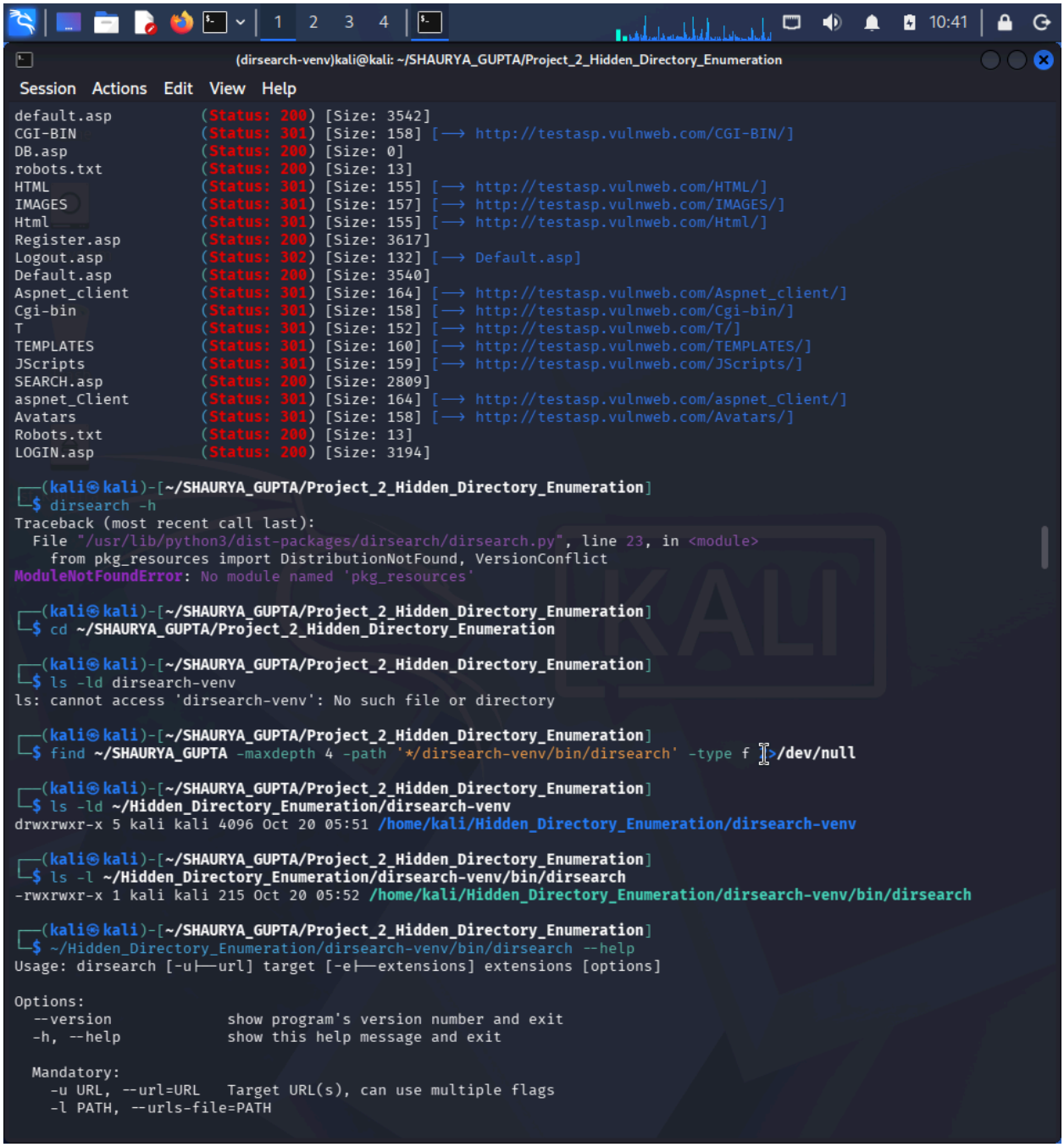
1 2 3 4
10:43
(dirsearch-venv)kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
Output Settings:
-O FORMAT, --output-formats=FORMAT
Report formats, separated by commas (Available:
simple, plain, json, xml, md, csv, html, sqlite)
-o PATH, --output-file=PATH
Output file location
--mysql-url=URL Database URL for MySQL output (Format:
mysql://[username:password@]host[:port]/database-name)
--postgres-url=URL Database URL for PostgreSQL output (Format:
postgres://[username:password@]host[:port]/database-
name)
--log=PATH Log file
See 'config.ini' for the example configuration file
(dirsearch-venv)-(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ printf 'Target: %s\nWordlist: %s\n' "$TARGET" "$WORDLIST"
Target: http://testasp.vulnweb.com
Wordlist: /usr/share/seclists/Discovery/Web-Content/raft-small-directories.txt
(dirsearch-venv)-(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ test -f "$WORDLIST" && echo "Wordlist found" || echo "Wordlist missing"
Wordlist found
(dirsearch-venv)-(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ mkdir -p results
./dirsearch-venv/bin/dirsearch \
-u "${TARGET%/}/" \
-w "$WORDLIST" \
--threads=10 \
--timeout=10 \
--format=plain \
-o results/dirsearch.txt
Usage: dirsearch [-u|--url] target [-e|--extensions] extensions [options]
dirsearch: error: no such option: --format
(dirsearch-venv)-(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ mkdir -p results
./dirsearch-venv/bin/dirsearch \
-u "${TARGET%/}/" \
-w "$WORDLIST" \
--threads=10 \
--timeout=10 \
-o results/dirsearch.txt
v0.5.0
Extensions: php, asp, aspx, jsp, html, htm | HTTP method: GET | Threads: 10 | Wordlist size: 20115
Target: http://testasp.vulnweb.com/
[10:33:29] Scanning:
[10:33:33] 301 - 158B - /cgi-bin → http://testasp.vulnweb.com/cgi-bin/

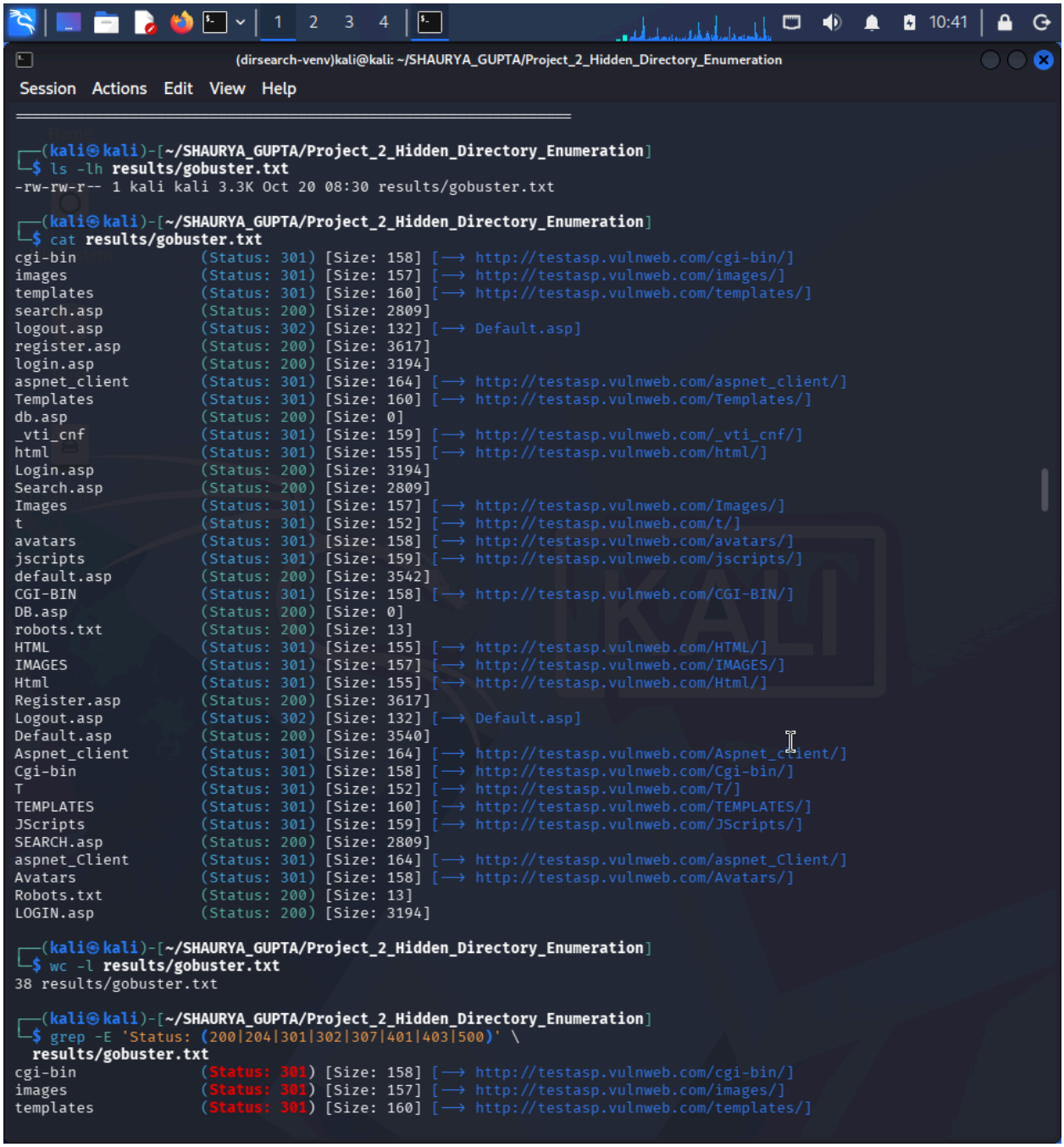

1 2 3 4
10:42
(dirsearch-venv)kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
Using cached defusedcsv-3.0.0-py3-none-any.whl (8.0 kB)
Using cached defusedxml-0.7.1-py2.py3-none-any.whl (25 kB)
Using cached httpx-0.28.1-py3-none-any.whl (73 kB)
Using cached httpx_ntlm-1.4.0-py3-none-any.whl (4.2 kB)
Using cached jinja2-3.1.6-py3-none-any.whl (134 kB)
Using cached pyopenssl-26.1.0-py3-none-any.whl (58 kB)
Using cached PySocks-1.7.1-py3-none-any.whl (16 kB)
Using cached requests-2.33.1-py3-none-any.whl (64 kB)
Using cached requests_ntlm-1.3.0-py3-none-any.whl (6.6 kB)
Using cached requests_toolbelt-1.0.0-py2.py3-none-any.whl (54 kB)
Using cached charset_normalizer-3.5.2-cp314-cp314-manylinux2014_x86_64.manylinux_2_17_x86_64.manylinux_2_28_x86_64.whl (255 kB)
Using cached cryptography-47.0.0-cp311-abi3-manylinux_2_34_x86_64.whl (4.7 MB)
Using cached httpcore-1.0.9-py3-none-any.whl (78 kB)
Using cached idna-3.20-py3-none-any.whl (69 kB)
Using cached urllib3-2.8.0-py3-none-any.whl (135 kB)
Using cached certifi-2026.10.19-py3-none-any.whl (136 kB)
Using cached cffi-2.1.1-cp314-cp314-manylinux2014_x86_64.manylinux_2_17_x86_64.whl (221 kB)
Using cached h11-0.16.0-py3-none-any.whl (37 kB)
Using cached markupsafe-3.0.4-cp314-cp314-manylinux2014_x86_64.manylinux_2_17_x86_64.manylinux_2_28_x86_64.whl (23 kB)
Using cached pyspnego-0.12.4-py3-none-any.whl (131 kB)
Using cached soupsieve-3.0.3-py3-none-any.whl (41 kB)
Using cached typing_extensions-4.16.0-py3-none-any.whl (45 kB)
Using cached anyio-4.15.1-py3-none-any.whl (132 kB)
Using cached pycparser-3.11-py3-none-any.whl (51 kB)
Installing collected packages: defusedcsv, urllib3, typing-extensions, soupsieve, PySocks, pycparser, MarkupSafe, idna, h11, defusedxml, colorama, charset_normalizer, certifi, requests, Jinja2, httpcore, cffi, beautifulsoup4, anyio, requests-toolbelt, httpx, cryptography, pyspnego, pyopenssl, requests-ntlm, httpx-ntlm, dirsearch
Successfully installed Jinja2-3.1.6 MarkupSafe-3.0.4 PySocks-1.7.1 anyio-4.15.1 beautifulsoup4-4.14.3 certifi-2026.10.19 cffi-2.1.1 charset_normalizer-3.5.2 colorama-0.4.6 cryptography-47.0.0 defusedcsv-3.0.0 defusedxml-0.7.1 dirsearch-0.5.0 h11-0.16.0 httpcore-1.0.9 httpx-0.28.1 httpx-ntlm-1.4.0 idna-3.20 pycparser-3.11 pyopenssl-26.1.0 pyspnego-0.12.4 requests-2.33.1 requests-ntlm-1.3.0 requests-toolbelt-1.0.0 soupsieve-3.0.3 typing-extensions-4.16.0 urllib3-2.8.0
┌──(dirsearch-venv)─(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ ./dirsearch-venv/bin/dirsearch --help
Usage: dirsearch [-u|--url] target [-e|--extensions] extensions [options]
Options:
--version show program's version number and exit
-h, --help show this help message and exit
Mandatory:
-u URL, --url=URL Target URL(s), can use multiple flags
-l PATH, --urls-file=PATH
URL list file
--stdin Read URL(s) from STDIN
--cidr=CIDR Target CIDR
--raw=PATH Load raw HTTP request from file (use '--scheme' flag
to set the scheme)
--nmap-report=PATH Load targets from nmap report (Ensure the inclusion of
the -sV flag during nmap scan for comprehensive
results)
-s SESSION_FILE, --session=SESSION_FILE
Session file
--session-id=ID Load session by numeric id (use --list-sessions to see

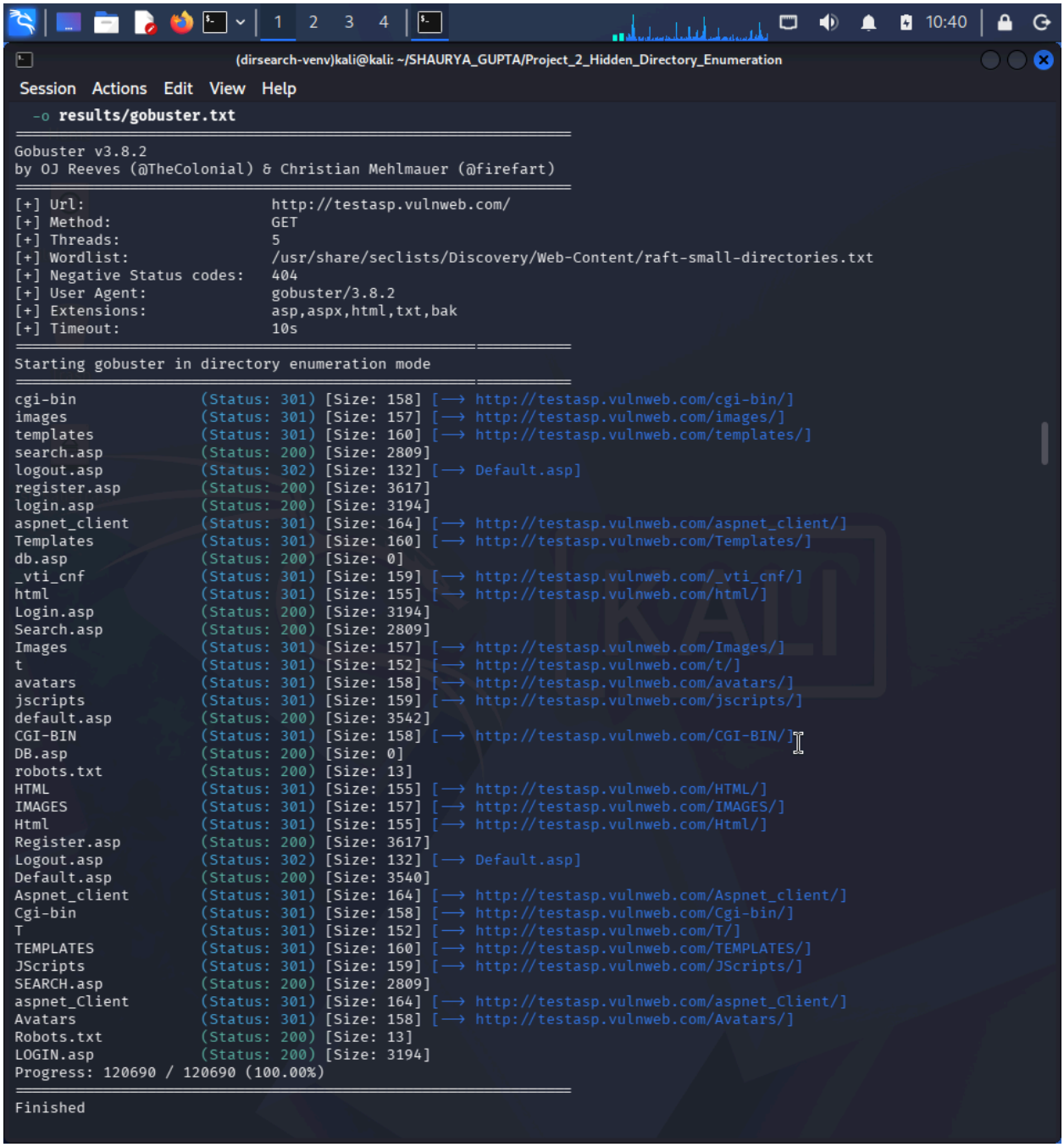

1 2 3 4
10:42
(dirsearch-venv)kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
libbluray3 libkmlengine1t64 libpython3.13-stdlib python3.13-tk
libconfig++11 libmupdf27.0 libsimdutf33 python3.13-venv
libconfig11 libntfs-3g89t64 libvidstab1.1 rpcsvc-proto
libgeos3.14.1 libobjc-15-dev libx265-215
libhdf5-310 libopenjph0.27 openssh-client-gssapi
libhdf5-hl-310 libperl5.40 perl-modules-5.40
Use 'sudo apt autoremove' to remove them.
Summary:
Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 120
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ sudo apt install python3-venv -y
python3-venv is already the newest version (3.14.7-3).
The following packages were automatically installed and are no longer required:
bluez-hcidump libimath-3-1-29t64 libpoppler156 python3-mitmproxy-wireguard
firmware-marvell-prestera libjim0.83 libpython3.13 python3.13
libabsl20260107 libkmlbase1t64 libpython3.13-dev python3.13-dev
libavfilter11 libkmldom1t64 libpython3.13-minimal python3.13-minimal
libbluray3 libkmlengine1t64 libpython3.13-stdlib python3.13-tk
libconfig++11 libmupdf27.0 libsimdutf33 python3.13-venv
libconfig11 libntfs-3g89t64 libvidstab1.1 rpcsvc-proto
libgeos3.14.1 libobjc-15-dev libx265-215
libhdf5-310 libopenjph0.27 openssh-client-gssapi
libhdf5-hl-310 libperl5.40 perl-modules-5.40
Use 'sudo apt autoremove' to remove them.
Summary:
Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 120
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ source dirsearch-venv/bin/activate
┌──(dirsearch-venv)─(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ python -m pip install --upgrade pip
python -m pip install dirsearch
Requirement already satisfied: pip in ./dirsearch-venv/lib/python3.14/site-packages (26.1.2)
Collecting pip
Using cached pip-26.2.1-py3-none-any.whl.metadata (4.6 kB)
Using cached pip-26.2.1-py3-none-any.whl (1.8 MB)
Installing collected packages: pip
Attempting uninstall: pip
Found existing installation: pip 26.1.2
Uninstalling pip-26.1.2:
Successfully uninstalled pip-26.1.2
Successfully installed pip-26.2.1
Collecting dirsearch
Using cached dirsearch-0.5.0-py3-none-any.whl.metadata (5.2 kB)
Collecting PySocks==1.7.1 (from dirsearch)
Using cached PySocks-1.7.1-py3-none-any.whl.metadata (13 kB)
Collecting Jinja2==3.1.6 (from dirsearch)
Using cached jinja2-3.1.6-py3-none-any.whl.metadata (2.9 kB)
Collecting pyopenssl==26.1.0 (from dirsearch)
Using cached pyopenssl-26.1.0-py3-none-any.whl.metadata (19 kB)
Collecting requests==2.33.1 (from dirsearch)
Using cached requests-2.33.1-py3-none-any.whl.metadata (4.8 kB)
Collecting requests-ntlm==1.3.0 (from dirsearch)


1 2 3 4
10:41
(dirsearch-venv)kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
Advanced Settings:
--crawl Crawl for new paths in responses
View Settings:
--full-url Full URLs in the output (enabled automatically in quiet mode)
--redirects-history Show redirects history
--no-color No colored output
-q, --quiet-mode Quiet mode
--disable-cli Turn off command-line output
-v, --verbose Show verbose output with response time and content type
Output Settings:
-O FORMAT, --output-formats=FORMAT Report formats, separated by commas (Available: simple, plain, json, xml, md, csv, html, sqlite)
-o PATH, --output-file=PATH Output file location
--mysql-url=URL Database URL for MySQL output (Format: mysql://[username:password@]host[:port]/database-name)
--postgres-url=URL Database URL for PostgreSQL output (Format: postgres://[username:password@]host[:port]/database-name)
--log=PATH Log file
See 'config.ini' for the example configuration file
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ dirsearch \
-u "$TARGET/" \
-w "$WORDLIST" \
--threads=10 \
--timeout=10 \
--format=plain \
-o results/dirsearch.txt
Traceback (most recent call last):
File "/usr/lib/python3/dist-packages/dirsearch/dirsearch.py", line 23, in <module>
from pkg_resources import DistributionNotFound, VersionConflict
ModuleNotFoundError: No module named 'pkg_resources'
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ python3 -m venv dirsearch-venv
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ sudo apt install python3-venv -y
[sudo] password for kali:
python3-venv is already the newest version (3.14.7-3).
The following packages were automatically installed and are no longer required:
bluez-hcidump libimath-3-1-29t64 libpoppler156 python3-mitmproxy-wireguard
firmware-marvell-prestera libjim0.83 libpython3.13 python3.13
libabsl20260107 libkmlbase1t64 libpython3.13-dev python3.13-dev
libavfilter11 libkmldom1t64 libpython3.13-minimal python3.13-minimal
libbluray3 libkmlengine1t64 libpython3.13-stdlib python3.13-tk
libconfig++11 libmupdf27.0 libsimdutf33 python3.13-venv
libconfig11 libntfs-3g89t64 libvidstab1.1 rpcsvc-proto

1 2 3 4
10:41
(dirsearch-venv)kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
└─$ ls -ld ~/Hidden_Directory_Enumeration/dirsearch-venv
drwxrwxr-x 5 kali kali 4096 Oct 20 05:51 /home/kali/Hidden_Directory_Enumeration/dirsearch-venv
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ ls -l ~/Hidden_Directory_Enumeration/dirsearch-venv/bin/dirsearch
-rwxrwxr-x 1 kali kali 215 Oct 20 05:52 /home/kali/Hidden_Directory_Enumeration/dirsearch-venv/bin/dirsearch
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ ~/Hidden_Directory_Enumeration/dirsearch-venv/bin/dirsearch --help
Usage: dirsearch [-u|--url] target [-e|--extensions] extensions [options]
Options:
--version show program's version number and exit
-h, --help show this help message and exit
Mandatory:
-u URL, --url=URL Target URL(s), can use multiple flags
-l PATH, --urls-file=PATH
URL list file
--stdin Read URL(s) from STDIN
--cidr=CIDR Target CIDR
--raw=PATH Load raw HTTP request from file (use '--scheme' flag
to set the scheme)
--nmap-report=PATH Load targets from nmap report (Ensure the inclusion of
the -sV flag during nmap scan for comprehensive
results)
-s SESSION_FILE, --session=SESSION_FILE
Session file
--session-id=ID Load session by numeric id (use --list-sessions to see
ids)
--config=PATH Path to configuration file (Default:
'DIRSEARCH_CONFIG' environment variable, otherwise
'config.ini')
Dictionary Settings:
-w WORDLISTS, --wordlists=WORDLISTS
Wordlist files or directories contain wordlists
(separated by commas)
--wordlist-categories=WORDLIST_CATEGORIES
Comma-separated wordlist category names (e.g.
common,conf,web). Use 'all' to include all bundled
categories
--wordlist-backend=BACKEND
Wordlist generation backend: auto, python, native
(default: auto)
--wordlist-status Show resolved wordlist files and generated entry
count, then exit
--wordlist-max-size=COUNT
Maximum generated wordlist entries before aborting
(default: 500000)
-e EXTENSIONS, --extensions=EXTENSIONS
Extension list, separated by commas (e.g. php,asp)
-f, --force-extensions
Add extensions to the end of every wordlist entry. By
default dirsearch only replaces the %EXT% keyword with
extensions
--overwrite-extensions


1 2 3 4
10:41
(dirsearch-venv)kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
default.asp (Status: 200) [Size: 3542]
CGI-BIN (Status: 301) [Size: 158] [--> http://testasp.vulnweb.com/CGI-BIN/]
DB.asp (Status: 200) [Size: 0]
robots.txt (Status: 200) [Size: 13]
HTML (Status: 301) [Size: 155] [--> http://testasp.vulnweb.com/HTML/]
IMAGES (Status: 301) [Size: 157] [--> http://testasp.vulnweb.com/IMAGES/]
Html (Status: 301) [Size: 155] [--> http://testasp.vulnweb.com/Html/]
Register.asp (Status: 200) [Size: 3617]
Logout.asp (Status: 302) [Size: 132] [--> Default.asp]
Default.asp (Status: 200) [Size: 3540]
Aspnet_client (Status: 301) [Size: 164] [--> http://testasp.vulnweb.com/Aspnet_client/]
Cgi-bin (Status: 301) [Size: 158] [--> http://testasp.vulnweb.com/Cgi-bin/]
T (Status: 301) [Size: 152] [--> http://testasp.vulnweb.com/T/]
TEMPLATES (Status: 301) [Size: 160] [--> http://testasp.vulnweb.com/TEMPLATES/]
JScripts (Status: 301) [Size: 159] [--> http://testasp.vulnweb.com/JScripts/]
SEARCH.asp (Status: 200) [Size: 2809]
aspnet_Client (Status: 301) [Size: 164] [--> http://testasp.vulnweb.com/aspnet_Client/]
Avatars (Status: 301) [Size: 158] [--> http://testasp.vulnweb.com/Avatars/]
Robots.txt (Status: 200) [Size: 13]
LOGIN.asp (Status: 200) [Size: 3194]
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ dirsearch -h
Traceback (most recent call last):
File "/usr/lib/python3/dist-packages/dirsearch/dirsearch.py", line 23, in <module>
from pkg_resources import DistributionNotFound, VersionConflict
ModuleNotFoundError: No module named 'pkg_resources'
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ cd ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ ls -ld dirsearch-venv
ls: cannot access 'dirsearch-venv': No such file or directory
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ find ~/SHAURYA_GUPTA -maxdepth 4 -path '*/dirsearch-venv/bin/dirsearch' -type f 2>/dev/null
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ ls -ld ~/Hidden_Directory_Enumeration/dirsearch-venv
drwxrwxr-x 5 kali kali 4096 Oct 20 05:51 /home/kali/Hidden_Directory_Enumeration/dirsearch-venv
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ ls -l ~/Hidden_Directory_Enumeration/dirsearch-venv/bin/dirsearch
-rwxrwxr-x 1 kali kali 215 Oct 20 05:52 /home/kali/Hidden_Directory_Enumeration/dirsearch-venv/bin/dirsearch
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ ~/Hidden_Directory_Enumeration/dirsearch-venv/bin/dirsearch --help
Usage: dirsearch [-u|--url] target [-e|--extensions] extensions [options]
Options:
--version show program's version number and exit
-h, --help show this help message and exit
Mandatory:
-u URL, --url=URL Target URL(s), can use multiple flags
-l PATH, --urls-file=PATH


1 2 3 4
10:41
(dirsearch-venv)kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ ls -lh results/gobuster.txt
-rw-rw-r-- 1 kali kali 3.3K Oct 20 08:30 results/gobuster.txt
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ cat results/gobuster.txt
cgi-bin (Status: 301) [Size: 158] [--> http://testasp.vulnweb.com/cgi-bin/]
images (Status: 301) [Size: 157] [--> http://testasp.vulnweb.com/images/]
templates (Status: 301) [Size: 160] [--> http://testasp.vulnweb.com/templates/]
search.asp (Status: 200) [Size: 2809]
logout.asp (Status: 302) [Size: 132] [--> Default.asp]
register.asp (Status: 200) [Size: 3617]
login.asp (Status: 200) [Size: 3194]
aspnet_client (Status: 301) [Size: 164] [--> http://testasp.vulnweb.com/aspnet_client/]
Templates (Status: 301) [Size: 160] [--> http://testasp.vulnweb.com/Templates/]
db.asp (Status: 200) [Size: 0]
_vti_cnf (Status: 301) [Size: 159] [--> http://testasp.vulnweb.com/_vti_cnf/]
html (Status: 301) [Size: 155] [--> http://testasp.vulnweb.com/html/]
Login.asp (Status: 200) [Size: 3194]
Search.asp (Status: 200) [Size: 2809]
Images (Status: 301) [Size: 157] [--> http://testasp.vulnweb.com/Images/]
t (Status: 301) [Size: 152] [--> http://testasp.vulnweb.com/t/]
avatars (Status: 301) [Size: 158] [--> http://testasp.vulnweb.com/avatars/]
jscripts (Status: 301) [Size: 159] [--> http://testasp.vulnweb.com/jscripts/]
default.asp (Status: 200) [Size: 3542]
CGI-BIN (Status: 301) [Size: 158] [--> http://testasp.vulnweb.com/CGI-BIN/]
DB.asp (Status: 200) [Size: 0]
robots.txt (Status: 200) [Size: 13]
HTML (Status: 301) [Size: 155] [--> http://testasp.vulnweb.com/HTML/]
IMAGES (Status: 301) [Size: 157] [--> http://testasp.vulnweb.com/IMAGES/]
Html (Status: 301) [Size: 155] [--> http://testasp.vulnweb.com/Html/]
Register.asp (Status: 200) [Size: 3617]
Logout.asp (Status: 302) [Size: 132] [--> Default.asp]
Default.asp (Status: 200) [Size: 3540]
Aspnet_client (Status: 301) [Size: 164] [--> http://testasp.vulnweb.com/Aspnet_client/]
Cgi-bin (Status: 301) [Size: 158] [--> http://testasp.vulnweb.com/Cgi-bin/]
T (Status: 301) [Size: 152] [--> http://testasp.vulnweb.com/T/]
TEMPLATES (Status: 301) [Size: 160] [--> http://testasp.vulnweb.com/TEMPLATES/]
JScripts (Status: 301) [Size: 159] [--> http://testasp.vulnweb.com/JScripts/]
SEARCH.asp (Status: 200) [Size: 2809]
aspnet_Client (Status: 301) [Size: 164] [--> http://testasp.vulnweb.com/aspnet_Client/]
Avatars (Status: 301) [Size: 158] [--> http://testasp.vulnweb.com/Avatars/]
Robots.txt (Status: 200) [Size: 13]
LOGIN.asp (Status: 200) [Size: 3194]
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ wc -l results/gobuster.txt
38 results/gobuster.txt
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ grep -E 'Status: (200|204|301|302|307|401|403|500)' \
results/gobuster.txt
cgi-bin (Status: 301) [Size: 158] [--> http://testasp.vulnweb.com/cgi-bin/]
images (Status: 301) [Size: 157] [--> http://testasp.vulnweb.com/images/]
templates (Status: 301) [Size: 160] [--> http://testasp.vulnweb.com/templates/]


(dirsearch-venv)kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
-o results/gobuster.txt
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
[+] Url: http://testasp.vulnweb.com/
[+] Method: GET
[+] Threads: 5
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/raft-small-directories.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: asp,aspx,html,txt,bak
[+] Timeout: 10s
Starting gobuster in directory enumeration mode
cgi-bin (Status: 301) [Size: 158] [--> http://testasp.vulnweb.com/cgi-bin/]
images (Status: 301) [Size: 157] [--> http://testasp.vulnweb.com/images/]
templates (Status: 301) [Size: 160] [--> http://testasp.vulnweb.com/templates/]
search.asp (Status: 200) [Size: 2809]
logout.asp (Status: 302) [Size: 132] [--> Default.asp]
register.asp (Status: 200) [Size: 3617]
login.asp (Status: 200) [Size: 3194]
aspnet_client (Status: 301) [Size: 164] [--> http://testasp.vulnweb.com/aspnet_client/]
Templates (Status: 301) [Size: 160] [--> http://testasp.vulnweb.com/Templates/]
db.asp (Status: 200) [Size: 0]
_vti_cnf (Status: 301) [Size: 159] [--> http://testasp.vulnweb.com/_vti_cnf/]
html (Status: 301) [Size: 155] [--> http://testasp.vulnweb.com/html/]
Login.asp (Status: 200) [Size: 3194]
Search.asp (Status: 200) [Size: 2809]
Images (Status: 301) [Size: 157] [--> http://testasp.vulnweb.com/Images/]
t (Status: 301) [Size: 152] [--> http://testasp.vulnweb.com/t/]
avatars (Status: 301) [Size: 158] [--> http://testasp.vulnweb.com/avatars/]
jscripts (Status: 301) [Size: 159] [--> http://testasp.vulnweb.com/jscripts/]
default.asp (Status: 200) [Size: 3542]
CGI-BIN (Status: 301) [Size: 158] [--> http://testasp.vulnweb.com/CGI-BIN/]
DB.asp (Status: 200) [Size: 0]
robots.txt (Status: 200) [Size: 13]
HTML (Status: 301) [Size: 155] [--> http://testasp.vulnweb.com/HTML/]
IMAGES (Status: 301) [Size: 157] [--> http://testasp.vulnweb.com/IMAGES/]
Html (Status: 301) [Size: 155] [--> http://testasp.vulnweb.com/Html/]
Register.asp (Status: 200) [Size: 3617]
Logout.asp (Status: 302) [Size: 132] [--> Default.asp]
Default.asp (Status: 200) [Size: 3540]
Aspnet_client (Status: 301) [Size: 164] [--> http://testasp.vulnweb.com/Aspnet_client/]
Cgi-bin (Status: 301) [Size: 158] [--> http://testasp.vulnweb.com/Cgi-bin/]
T (Status: 301) [Size: 152] [--> http://testasp.vulnweb.com/T/]
TEMPLATES (Status: 301) [Size: 160] [--> http://testasp.vulnweb.com/TEMPLATES/]
JScripts (Status: 301) [Size: 159] [--> http://testasp.vulnweb.com/JScripts/]
SEARCH.asp (Status: 200) [Size: 2809]
aspnet_Client (Status: 301) [Size: 164] [--> http://testasp.vulnweb.com/aspnet_Client/]
Avatars (Status: 301) [Size: 158] [--> http://testasp.vulnweb.com/Avatars/]
Robots.txt (Status: 200) [Size: 13]
LOGIN.asp (Status: 200) [Size: 3194]
Progress: 120690 / 120690 (100.00%)
Finished

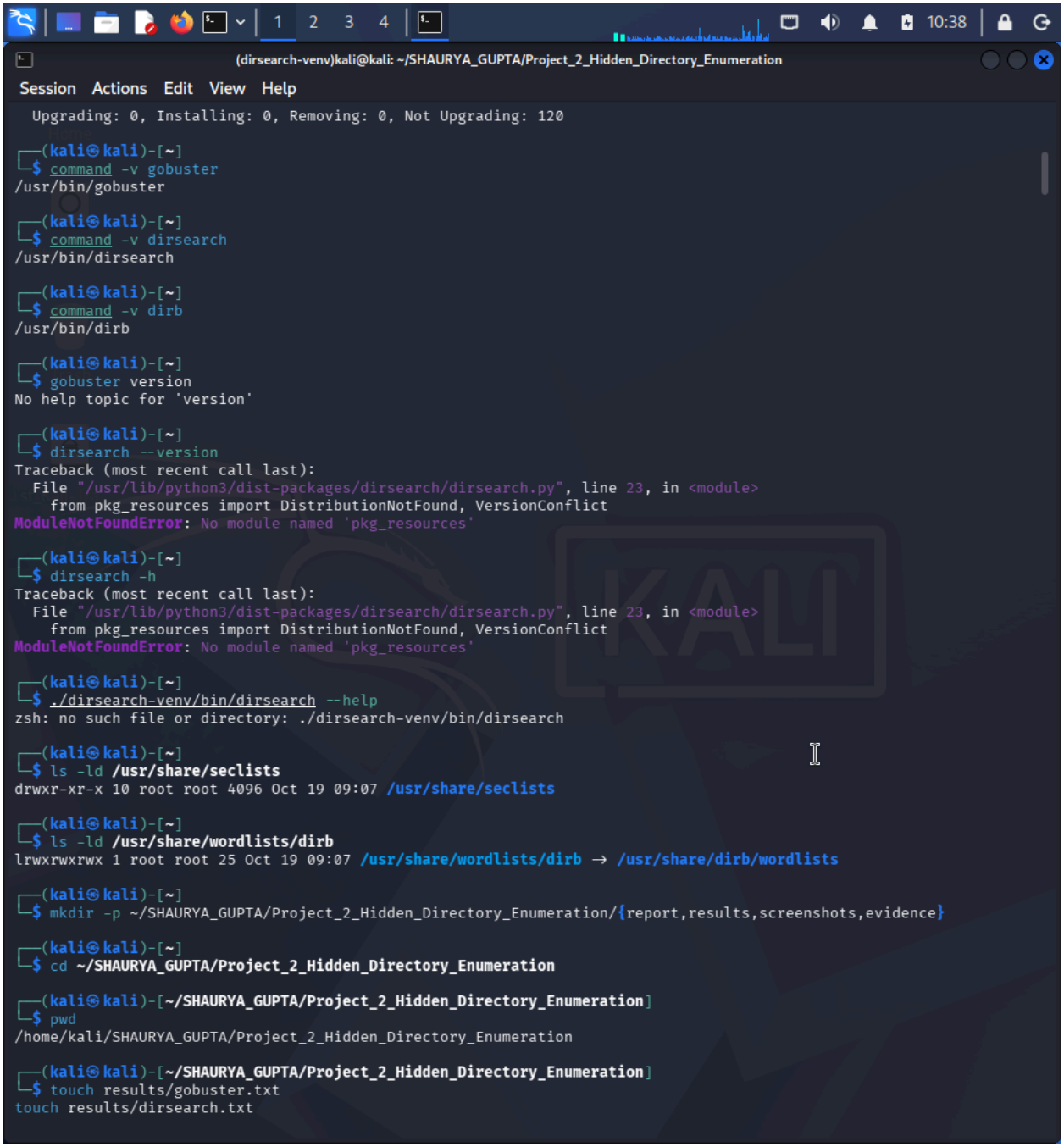
1 2 3 4
10:40
(dirsearch-venv)kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ cd ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ gobuster dir \
-u "$TARGET/" \
-w "$WORDLIST" \
-t 10 \
--timeout 10s \
-x asp,aspx,html,txt,bak \
-o results/gobuster.txt
2026/10/20 06:50:21 wordlist file "/usr/share/seclists/Discovery/Web-Content/directory-list-2.3-small.txt" does not exist: stat /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-small.txt: no such file or directory
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ echo "TARGET=$TARGET"
echo "WORDLIST=$WORDLIST"
TARGET=http://testasp.vulnweb.com
WORDLIST=/usr/share/seclists/Discovery/Web-Content/directory-list-2.3-small.txt
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ find /usr/share/seclists -type f \
\(-iname "directory-list-2.3-small.txt" \
-o -iname "raft-small-directories.txt" \
-o -iname "common.txt" \
-o -iname "directory-list-lowercase-2.3-small.txt" \) \
2>/dev/null
/usr/share/seclists/Miscellaneous/Words/Moby-Project/Moby-Words-II/COMMON.TXT
/usr/share/seclists/Discovery/Web-Content/raft-small-directories.txt
/usr/share/seclists/Discovery/Web-Content/common.txt
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ export WORDLIST="/usr/share/seclists/Discovery/Web-Content/raft-small-directories.txt"
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ test -f "$WORDLIST" && echo "Wordlist exists" || echo "Wordlist path is incorrect"
Wordlist exists
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ mkdir -p results
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ printf 'Target: %s\nWordlist: %s\n' "$TARGET" "$WORDLIST"
Target: http://testasp.vulnweb.com
Wordlist: /usr/share/seclists/Discovery/Web-Content/raft-small-directories.txt
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ gobuster dir \
-u "${TARGET%/}/" \
-w "$WORDLIST" \
-t 5 \
--timeout 10s \
-x asp,aspx,html,txt,bak \
-o results/gobuster.txt
Gobuster v3.8.2

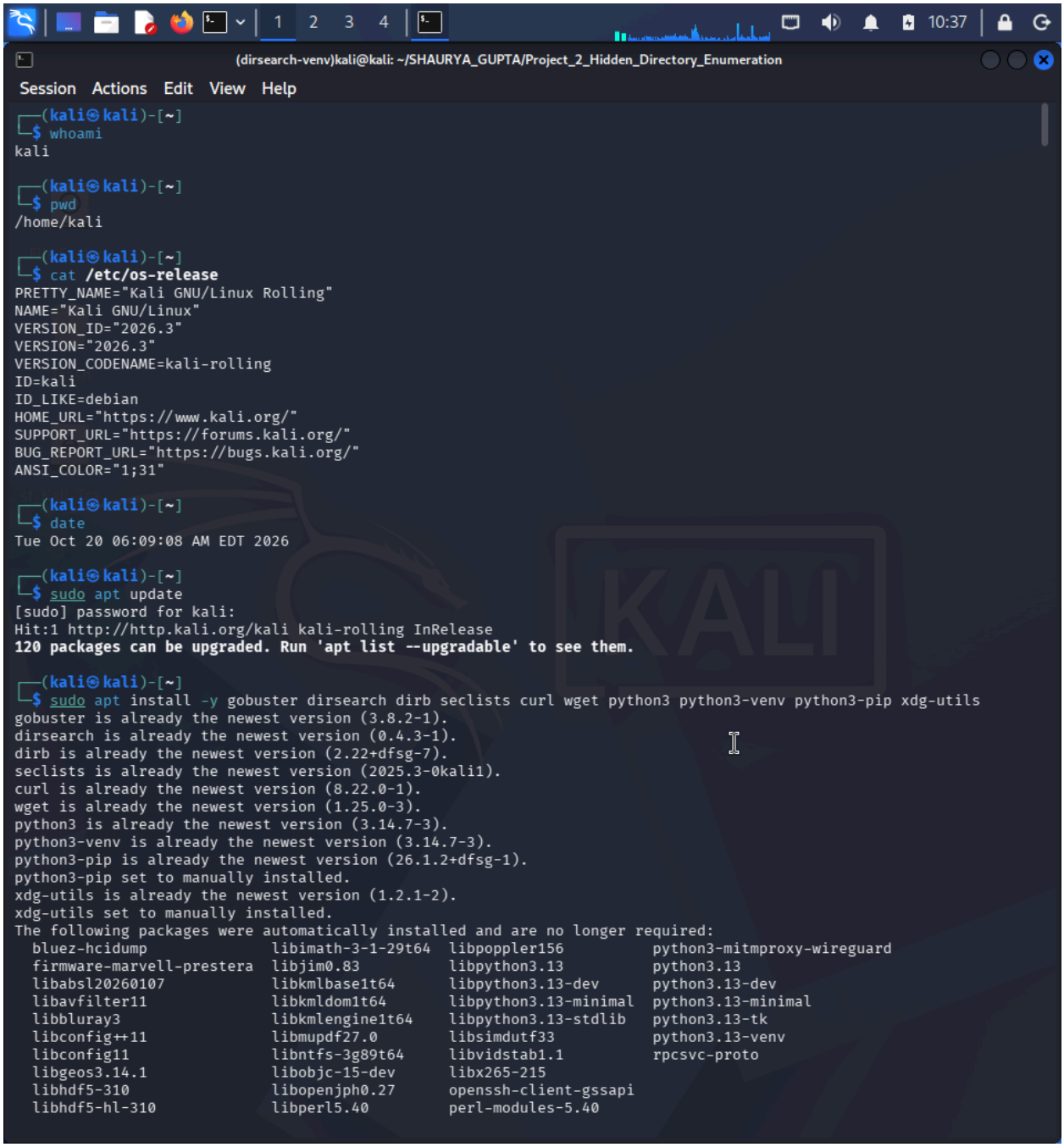
1 2 3 4
10:40
(dirsearch-venv)kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
cal-ip
--local-ip value specify local ip of network interface to use. Can't be used with interface
--wordlist value, -w value Path to the wordlist. Set to - to use STDIN.
--delay value, -d value Time each thread waits between requests (e.g. 1500ms) (default: 0s)
--threads value, -t value Number of concurrent threads (default: 10)
--wordlist-offset value, --wo value Resume from a given position in the wordlist (default: 0)
--output value, -o value Output file to write results to (defaults to stdout)
--quiet, -q Don't print the banner and other noise (default: false)
--no-progress, --np Don't display progress (default: false)
--no-error, --ne Don't display errors (default: false)
--pattern value, -p value File containing replacement patterns
--discover-pattern value, --pd value File containing replacement patterns applied to successful guesses
--no-color, --nc Disable color output (default: false)
--debug enable debug output (default: false)
--status-codes value, -s value Positive status codes (will be overwritten with status-codes-blacklist if set). Can also handle ranges like 200,300-400,404
--status-codes-blacklist value, -b value Negative status codes (will override status-codes if set). Can also handle ranges like 200,300-400,404. (default: "404")
--extensions value, -x value File extension(s) to search for
--extensions-file value, -X value Read file extension(s) to search from the file
--expanded, -e Expanded mode, print full URLs (default: false)
--no-status, -n Don't print status codes (default: false)
--hide-length, --hl Hide the length of the body in the output (default: false)
--add-slash, -f Append / to each request (default: false)
--discover-backup, --db Upon finding a file search for backup files by appending multiple backup extensions (default: false)
--exclude-length value, --xl value exclude the following content lengths (completely ignores the status). You can separate multiple lengths by comma and it also supports ranges like 203-206
--force Continue even if the prechecks fail. Please only use this if you know what you are doing, it can lead to unexpected results. (default: false)
--help, -h show help
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ cd ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ gobuster dir \
-u "$TARGET/" \
-w "$WORDLIST" \
-t 10 \
--timeout 10s \
-x asp,aspx,html,txt,bak \
-o results/gobuster.txt
2026/10/20 06:50:21 wordlist file "/usr/share/seclists/Discovery/Web-Content/directory-list-2.3-small.txt" does not exist: stat /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-small.txt: no such file or directory
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
$ echo "TARGET=$TARGET"
echo "WORDLIST=$WORDLIST"
TARGET=http://testasp.vulnweb.com
WORDLIST=/usr/share/seclists/Discovery/Web-Content/directory-list-2.3-small.txt

(dirsearch-venv)kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
</tr>
<tr>
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ curl -sS -L --max-time 20 "$TARGET/robots.txt" \
-D results/robots_headers.txt \
-o results/robots.txt
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ ls -lh /usr/share/seclists/Discovery/Web-Content/common.txt~
ls: cannot access '/usr/share/seclists/Discovery/Web-Content/common.txt~': No such file or directory
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ ls -ld /usr/share/seclists
drwxr-xr-x 10 root root 4096 Oct 19 09:07 /usr/share/seclists
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ ls -lh /usr/share/seclists/Discovery/Web-Content/common.txt
-rw-r--r-- 1 root root 38K Sep 19 2025 /usr/share/seclists/Discovery/Web-Content/common.txt
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ export WORDLIST="/usr/share/seclists/Discovery/Web-Content/common.txt"
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ test -r "$WORDLIST" && echo "Wordlist is readable" || echo "Wordlist is missing or unreadable"
Wordlist is readable
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ wc -l "$WORDLIST"
4749 /usr/share/seclists/Discovery/Web-Content/common.txt
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ find /usr/share/seclists /usr/share/wordlists \
-type f \(-name 'common.txt' -o -name 'directory-list-2.3-small.txt' \) \
2>/dev/null
/usr/share/seclists/Discovery/Web-Content/common.txt
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ export WORDLIST="/usr/share/seclists/Discovery/Web-Content/directory-list-2.3-small.txt"
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ gobuster dir -h
NAME:
gobuster dir - Uses directory/file enumeration mode
USAGE:
gobuster dir [command options] [arguments ...]
OPTIONS:
--url value, -u value The target URL
--cookies value, -c value Cookies to use for the requests
--username value, -U value Username for Basic Auth
--password value, -P value Password for Basic Auth
--follow-redirect, -r Follow redirects (default: false)
--headers value, -H value [--headers value, -H value] Specify HTTP headers, -H 'Header1: val1' -H 'Header2: val2'
--no-canonicalize-headers, --nch Do not canonicalize HTTP header names. If set header na

1 2 3 4
10:39
(dirsearch-venv)kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ export TARGET="http://testasp.vulnweb.com"
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ printf 'Target: %s\n' "$TARGET" | tee results/target.txt
Target: http://testasp.vulnweb.com
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ curl -sS -L -o /dev/null \
-w 'HTTP status: %{http_code}\nFinal URL: %{url_effective}\nResponse time: %{time_total}s\n' \
--max-time 20 "$TARGET/"
HTTP status: 200
Final URL: http://testasp.vulnweb.com/
Response time: 0.718248s
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ curl -sS -I --max-time 20 "$TARGET/" \
2>&1 | tee results/response_headers.txt
HTTP/1.1 200 OK
Cache-Control: private
Content-Length: 3538
Content-Type: text/html
Server: Microsoft-IIS/8.5
Set-Cookie: ASPSESSIONIDCCATTCSB=CKAKNHIDFNLHLFGELBJGPLOA; path=/
X-Powered-By: ASP.NET
Date: Tue, 20 Oct 2026 10:13:11 GMT
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ curl -sS -L --max-time 20 "$TARGET/" \
-o results/homepage.html
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ head -n 25 results/homepage.html
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN" "http://www.w3.org/TR/html4/loose.dtd">
<html><!-- InstanceBegin template="/Templates/MainTemplate.dwt.asp" codeOutsideHTMLIsLocked="false" -->
<head>
<!-- InstanceBeginEditable name="doctitle" -->
<title>acuforum forums</title>
<!-- InstanceEndEditable -->
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1">
<!-- InstanceBeginEditable name="head" -->
<!-- InstanceEndEditable -->
<link href="styles.css" rel="stylesheet" type="text/css">
</head>
<body>
<table width="100%" border="0" cellpadding="10" cellspacing="0">
<tr bgcolor="#008F00">
<td width="306px"><img src="Images/logo.gif" width="306" height="38" border
="0" alt="Acunetix website security"></td>
<td align="right" valign="middle" bgcolor="#008F00" class="disclaimer">TEST and Demonstration site for <a href=
"https://www.acunetix.com/vulnerability-scanner/">Acunetix Web Vulnerability Scanner</td>
</tr>
<tr>
<td colspan="2"> about - <a

1 2 3 4
10:38
(dirsearch-venv)kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
└─$ pwd
/home/kali/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ touch results/gobuster.txt
touch results/dirsearch.txt
touch results/dirb.txt
touch results/discovered_directories.txt
touch results/verification.txt
touch evidence/environment.txt
touch README.md
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ {
echo "Project: Hidden Directory and File Enumeration"
echo "Date: $(date -Is)"
echo "User: $(whoami)"
echo "Hostname: $(hostname)"
echo "Operating system:"
cat /etc/os-release
echo
echo "Tool paths:"
command -v gobuster
command -v dirsearch
command -v dirb
} 2>&1 | tee evidence/environment.txt
Project: Hidden Directory and File Enumeration
Date: 2026-10-20T06:11:59-04:00
User: kali
Hostname: kali
Operating system:
PRETTY_NAME="Kali GNU/Linux Rolling"
NAME="Kali GNU/Linux"
VERSION_ID="2026.3"
VERSION="2026.3"
VERSION_CODENAME=kali-rolling
ID=kali
ID_LIKE=debian
HOME_URL="https://www.kali.org/"
SUPPORT_URL="https://forums.kali.org/"
BUG_REPORT_URL="https://bugs.kali.org/"
ANSI_COLOR="1;31"
Tool paths:
/usr/bin/gobuster
/usr/bin/dirsearch
/usr/bin/dirb
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ find . -maxdepth 2 -type f -print | sort
./evidence/environment.txt
./README.md
./results/dirb.txt
./results/dirsearch.txt
./results/discovered_directories.txt
./results/gobuster.txt
./results/verification.txt


1 2 3 4
10:38
(dirsearch-venv)kali@kali: ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
Session Actions Edit View Help
Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 120
┌──(kali㉿kali)-[~]
└─$ command -v gobuster
/usr/bin/gobuster
┌──(kali㉿kali)-[~]
└─$ command -v dirsearch
/usr/bin/dirsearch
┌──(kali㉿kali)-[~]
└─$ command -v dirb
/usr/bin/dirb
┌──(kali㉿kali)-[~]
└─$ gobuster version
No help topic for 'version'
┌──(kali㉿kali)-[~]
└─$ dirsearch --version
Traceback (most recent call last):
File "/usr/lib/python3/dist-packages/dirsearch/dirsearch.py", line 23, in <module>
from pkg_resources import DistributionNotFound, VersionConflict
ModuleNotFoundError: No module named 'pkg_resources'
┌──(kali㉿kali)-[~]
└─$ dirsearch -h
Traceback (most recent call last):
File "/usr/lib/python3/dist-packages/dirsearch/dirsearch.py", line 23, in <module>
from pkg_resources import DistributionNotFound, VersionConflict
ModuleNotFoundError: No module named 'pkg_resources'
┌──(kali㉿kali)-[~]
└─$ ./dirsearch-venv/bin/dirsearch --help
zsh: no such file or directory: ./dirsearch-venv/bin/dirsearch
┌──(kali㉿kali)-[~]
└─$ ls -ld /usr/share/seclists
drwxr-xr-x 10 root root 4096 Oct 19 09:07 /usr/share/seclists
┌──(kali㉿kali)-[~]
└─$ ls -ld /usr/share/wordlists/dirb
lrwxrwxrwx 1 root root 25 Oct 19 09:07 /usr/share/wordlists/dirb → /usr/share/dirb/wordlists
┌──(kali㉿kali)-[~]
└─$ mkdir -p ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration/{report,results,screenshots,evidence}
┌──(kali㉿kali)-[~]
└─$ cd ~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ pwd
/home/kali/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_2_Hidden_Directory_Enumeration]
└─$ touch results/gobuster.txt
touch results/dirsearch.txt



NETWORK ANALYSIS REPORT

CyberSNova | Cyber Security Internship | Beginner Level | Project 3

1. Intern Details

- **Name:** Shaurya Gupta

- **Email:** shauryagupta0106@gmail.com
- **Reference Number:** CSN-OC-OL-26194
- **Registration Number:** CSN-OC-2026-194
- **Domain:** Cyber Security
- **Project Level:** Beginner
- **Project Number:** 3
- **Month/Year:** October 2026

---

2. Project Description

The objective of this project was to capture and analyze login-related network traffic to understand how web applications transmit information between a client and a server. The project focused on identifying HTTP requests, examining login-related POST requests, inspecting server responses where available, and understanding the importance of encryption when transmitting sensitive information.

The designated training website, `http://testasp.vulnweb.com/`, was used to generate and inspect web traffic. Wireshark and TShark were used for packet capture and analysis, while Burp Suite Community Edition was used to inspect HTTP traffic at the application layer.

The main objectives were:

1. Verify network connectivity to the assigned training website.
2. Capture HTTP and HTTPS-related TCP traffic.
3. Identify HTTP request methods, hostnames, request URIs, and content types.
4. Identify a POST request directed to the login endpoint.
5. Inspect traffic using Wireshark/TShark and Burp Suite.
6. Understand the security implications of transmitting sensitive information over unencrypted HTTP.
7. Document the observed results, limitations, and security recommendations.

---

3. Tools and Environment

Component	Details
Operating System	Kali Linux
Kernel Version	Linux 7.1.5+kali-amd64

Component	Details
Virtualization Platform	Oracle VirtualBox
Packet Capture Tool	Dumpcap, part of Wireshark
Wireshark Version	4.6.6
TShark Version	4.6.6
Burp Suite Version	Burp Suite Community Edition 2026.9-53998 (Early Adopter)
Browser	Burp Suite built-in browser, Chromium-based; observed User-Agent identifies Chrome 151.0.0.0
Network Interface	eth0
Local IPv4 Address	10.0.2.15
Default Gateway	10.0.2.2
Target Website	http://testasp.vulnweb.com/
Target Host Observed	testasp.vulnweb.com
Target IPv4 Address Observed	44.238.29.244
Burp Proxy Listener	127.0.0.1:8080
Capture Format	PCAPNG
Analysis Tools	TShark, Wireshark, Burp Suite Community Edition

---

The target IP address is the address observed during this exercise and may change over time.

---

4. Methodology

4.1 Connectivity Verification

The network configuration was inspected using the `ip` commands to identify the active interface, assigned IP address, and default gateway.

The target website was tested using `curl`. The recorded HTTP response included a `200 OK` status, confirming that the target responded to the connectivity request at that time.

4.2 Packet Capture

Dumpcap was used to capture traffic on the `eth0` network interface. A capture filter was applied to record TCP traffic on ports 80 and 443.

The capture was saved to:

`evidence/03_login_session.pcapng`

The capture summary reported:

- Total packets captured: 1,230
- Packets dropped: 0
- Capture duration: approximately 70.43 seconds
- File size: approximately 694 kB
- Capture interface: eth0
- Capture filter: `tcp port 80 or tcp port 443`

4.3 HTTP Request Filtering

TShark was used to filter HTTP requests and extract packet numbers, source and destination IP addresses, hostnames, request methods, and request URIs.

The extracted request metadata was saved to:

`evidence/04_http_requests.txt`

The analysis identified requests to the training website, including the homepage, supporting resources, and the login endpoint.

4.4 POST Request Inspection

TShark was used to filter HTTP POST requests and record their metadata.

The captured traffic included a POST request in frame 1213 directed to:

`/Login.asp?RetURL=%2FDefault%2Easp%3F`

The reported content type was:

`application/x-www-form-urlencoded`

The extracted POST request metadata was saved to:

`evidence/05_http_post_analysis.txt`

This confirms that a form-encoded POST request was observed. The request metadata alone does not prove that authentication succeeded or that credentials were accepted by the application.

4.5 Wireshark/TShark Protocol Analysis

The capture was analyzed using TShark's protocol hierarchy statistics. The results included HTTP and TLS traffic.

The analysis demonstrated that the capture contained web traffic suitable for examining request methods, destinations, and protocol usage.

The presence of TLS traffic elsewhere in the capture does not establish that the login request itself was protected by HTTPS.

4.6 Burp Suite Analysis

Burp Suite Community Edition was launched and configured with a proxy listener bound to `127.0.0.1:8080`.

The screenshots show the Burp HTTP history interface displaying requests to `testasp.vulnweb.com`, including GET requests with recorded HTTP 200 responses. The listener settings screenshot shows the proxy listener configured at `127.0.0.1:8080`.

The supplied screenshots establish that Burp was configured and that web requests were visible in its HTTP history. They do not independently establish that the login POST request and its associated response were captured in Burp. That finding should only be added after verifying the corresponding request in Burp's HTTP history.

---

5. Implementation and Evidence

The following evidence files and screenshots document the implementation. Screenshot numbers refer to the images supplied in the project screenshots folder.

Figure 1: Project Directory and Initial Setup

Evidence: `screenshots/01.png`

This screenshot shows the creation of the project directories, including the report, evidence, and results folders. It documents the initial organization of the project files.

Figure 2: Wireshark Version Verification

Evidence: `screenshots/02.png`

This screenshot records the installed Wireshark version as 4.6.6. It establishes the packet-analysis software version used during the exercise.

Figure 3: TShark Version Verification

Evidence: `screenshots/03.png`

This screenshot records TShark version 4.6.6, confirming the command-line packet-analysis tool used to filter and examine network traffic.

Figure 4: Network and Tool Information

Evidence: `screenshots/04.png`

This screenshot contains terminal output documenting the installed packet-analysis utilities and the Burp Suite command-line availability.

Figure 5: Network Interface Configuration

Evidence: `screenshots/06.png`

This screenshot records the active `eth0` interface, local IPv4 address `10.0.2.15`, and default gateway `10.0.2.2`. These details establish the network environment used for packet capture.

Figure 6: Target Connectivity Verification

Evidence: `screenshots/07.png`

This screenshot shows an HTTP response from `testasp.vulnweb.com`, including the `200 OK` status and HTTP response headers. It demonstrates that the target responded to the connectivity check.

Figure 7: Packet Capture Troubleshooting

Evidence: `screenshots/08.png`, `screenshots/16.png`, `screenshots/17.png`, `screenshots/18.png`

These screenshots document troubleshooting of the initial capture attempts, including permission errors and zero-packet captures. They also show the investigation used to identify the working interface and capture method.

Figure 8: Successful Packet Capture

Evidence: `screenshots/19.png`, `screenshots/20.png`, `screenshots/21.png`

These screenshots show the successful capture and subsequent analysis. The capture summary records 1,230 packets, zero reported dropped packets, and a duration of approximately 70.43 seconds.

Figure 9: Burp Suite HTTP History

Evidence: `screenshots/13.png`, `screenshots/14.png`

These screenshots show Burp Suite Community Edition's HTTP history interface and requests to the assigned training website. The displayed entries include GET requests and recorded HTTP 200 responses.

Figure 10: Burp Suite Proxy Listener

Evidence: `screenshots/15.png`

This screenshot shows the Burp proxy listener configuration at `127.0.0.1:8080`. It documents the local proxy configuration used for application-layer inspection.

Additional screenshots may be included where they show unique evidence relevant to the final analysis. All screenshots should be genuine captures from the lab, and any sensitive values must be redacted before submission.

---

6. Results and Findings

6.1 Packet Capture Results

The PCAPNG file contained 1,230 packets captured over approximately 70.43 seconds. Dumpcap reported zero dropped packets during the capture.

The protocol hierarchy showed HTTP and TLS traffic, confirming that multiple types of web traffic were present in the capture.

6.2 HTTP Request Findings

The request listing contained traffic to `testasp.vulnweb.com`, including requests to:

- `/`
- `/styles.css`
- `/favicon.ico`
- `/Images/logo.gif`
- `/Login.asp?RetURL=%2FDefault%2Easp%3F`

The login endpoint was requested using HTTP.

6.3 POST Request Findings

A POST request was observed in frame 1213 with the URI:

`/Login.asp?RetURL=%2FDefault%2Easp%3F`

Its content type was `application/x-www-form-urlencoded`.

This indicates that the request used a form-encoded body format. However, the extracted metadata does not establish the exact body contents, whether valid credentials were submitted, or whether authentication succeeded.

6.4 Response Findings

The target connectivity check recorded an HTTP `200 OK` response. Burp HTTP history screenshots also show GET requests with recorded `200` status codes.

The response status specifically associated with the login POST request has not been established by the supplied evidence. Therefore, no claim is made that the login was successful or unsuccessful.

6.5 Transport Security Findings

The capture contains HTTP and TLS traffic. The login endpoint was accessed over HTTP, which does not provide HTTP-layer encryption.

If sensitive login information was transmitted in the HTTP request body, it could potentially be readable by parties able to observe that traffic. The POST request metadata alone does not prove that a password or other secret was transmitted in readable form.

The presence of TLS traffic elsewhere in the capture does not establish that the login exchange used TLS.

6.6 Limitations

- The supplied POST analysis contains request metadata, not a verified authentication outcome.
- The login response code and authentication result have not been confirmed.
- The supplied Burp screenshots show GET requests and the proxy listener configuration, but do not independently prove that Burp captured the login POST request.
- The presence of a POST request does not by itself establish a vulnerability.
- No successful account compromise or unauthorized access was demonstrated.

---

7. Risk Assessment

Finding 1: Login Endpoint Accessible over HTTP

Observation: The login endpoint was requested over HTTP, and a POST request was observed in the packet capture.

Affected Data: Any credentials, session-related information, or other sensitive fields transmitted in the request, if present.

Potential Impact: If sensitive information is transmitted without encryption, a party able to observe the relevant network traffic may be able to read or intercept that information.

Evidence: `evidence/03_login_session.pcapng`, `evidence/04_http_requests.txt`, and `evidence/05_http_post_analysis.txt`.

Severity: Potentially high if actual credentials are transmitted in cleartext over an untrusted network. A definitive severity rating requires confirmation of the transmitted fields, the application's HTTPS behavior, and the relevant threat environment.

Status: Security concern requiring verification. The supplied metadata does not by itself prove that credentials were exposed.

Finding 2: Authentication Outcome Not Verified

Observation: A POST request to the login endpoint was identified, but the corresponding authentication result has not been established.

Potential Impact: Without examining the response and relevant application behavior, it is not possible to determine whether the submitted login attempt succeeded or failed.

Evidence: The POST request metadata and available response records.

Severity: Informational limitation, not a confirmed vulnerability.

Status: Further inspection is required.

Finding 3: TLS Traffic Present in the Capture

Observation: TLS traffic was identified in the protocol hierarchy.

Potential Impact: TLS can protect the confidentiality and integrity of supported connections when correctly configured. However, unrelated TLS traffic does not demonstrate that the login exchange was encrypted.

Evidence: `results/capture_summary.txt` and the TShark protocol hierarchy output.

Severity: No vulnerability can be assigned from this observation alone.

Status: The transport security of the specific login exchange requires verification.

---

8. Recommendations

1. **Enforce HTTPS:** Configure login pages and all pages handling sensitive information to use HTTPS. Redirect HTTP requests to HTTPS and consider HTTP Strict Transport Security where appropriate.

2. **Protect Authentication Data:** Ensure that passwords and other sensitive fields are never transmitted over unencrypted HTTP connections.

3. **Review Session Cookies:** Where applicable, configure session cookies with the `Secure` and `HttpOnly` attributes and an appropriate `SameSite` policy.

4. **Avoid Mixed Content:** Ensure that HTTPS pages do not load insecure HTTP resources that could undermine page security.

5. **Use Secure Session Management:** Generate unpredictable session identifiers, rotate session identifiers after authentication, invalidate sessions on logout, and apply suitable expiration controls.

6. **Verify Login Responses:** Inspect the actual server response to each test login request before classifying the attempt as successful or unsuccessful.

7. **Protect Evidence:** Store PCAPNG files and screenshots securely. Redact passwords, cookies, authorization headers, and other sensitive values before including evidence in the report.

8. **Validate Findings:** Confirm the exact request body, transport protection, and server behavior before assigning a final vulnerability severity.

9. **Maintain Authorized Testing Scope:** Perform packet capture and proxy inspection only against approved training systems or systems for which explicit authorization has been granted.

---

9. Summary and Conclusion

This project demonstrated the capture and analysis of web traffic using Kali Linux, Dumpcap, Wireshark, and TShark. The successful capture contained 1,230 packets, and the protocol analysis identified both HTTP and TLS traffic.

The HTTP request analysis identified requests to the designated training website and a POST request to the login endpoint. The POST request used the `application/x-www-form-urlencoded` content type. Burp Suite Community Edition was configured with a local proxy listener, and the supplied screenshots show HTTP history entries for the target website.

These results demonstrate how packet-analysis tools can be used to identify web requests and investigate application-layer traffic. The observations also highlight why login endpoints should use HTTPS when handling sensitive information.

However, the available evidence does not establish whether credentials were transmitted in readable form, whether the login attempt succeeded, or whether the login exchange was protected by TLS. Those conclusions require inspection of the relevant request body, corresponding response, and actual transport security.

The project provided practical experience in network configuration, packet capture, HTTP filtering, protocol analysis, proxy configuration, and evidence-based security reporting. It also demonstrated the importance of distinguishing observed facts from assumptions when evaluating potential security risks.

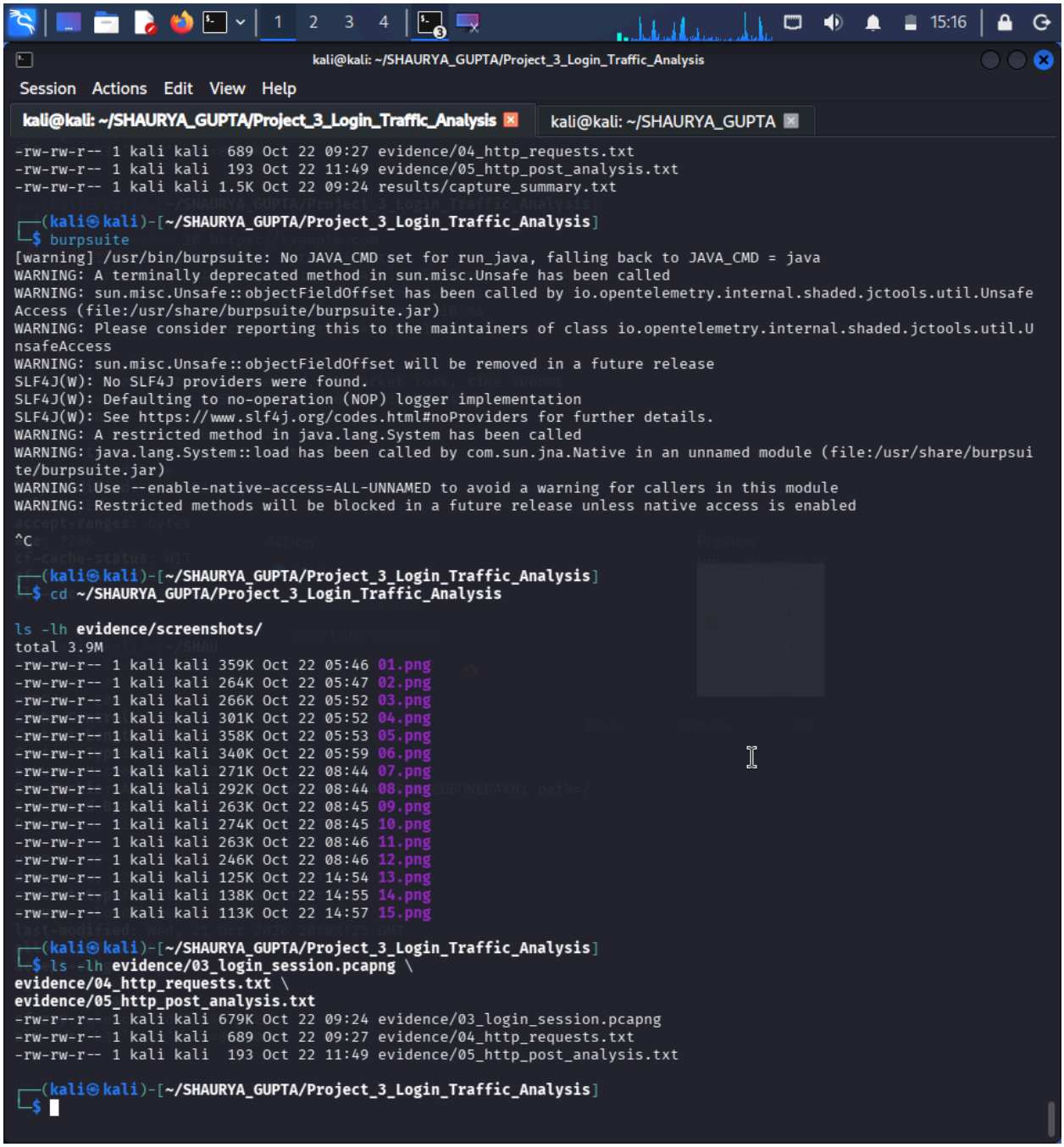
---

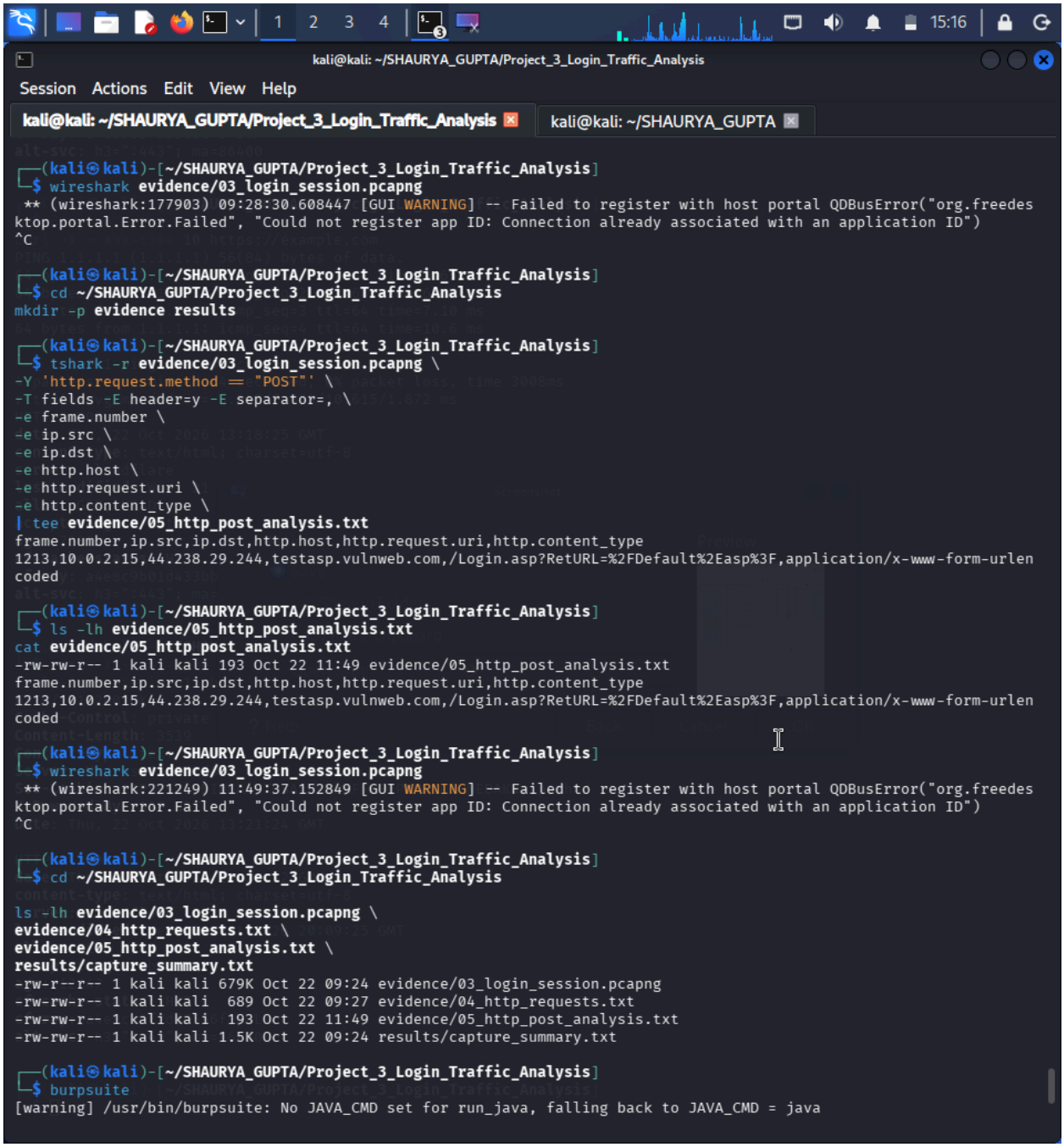
10. References

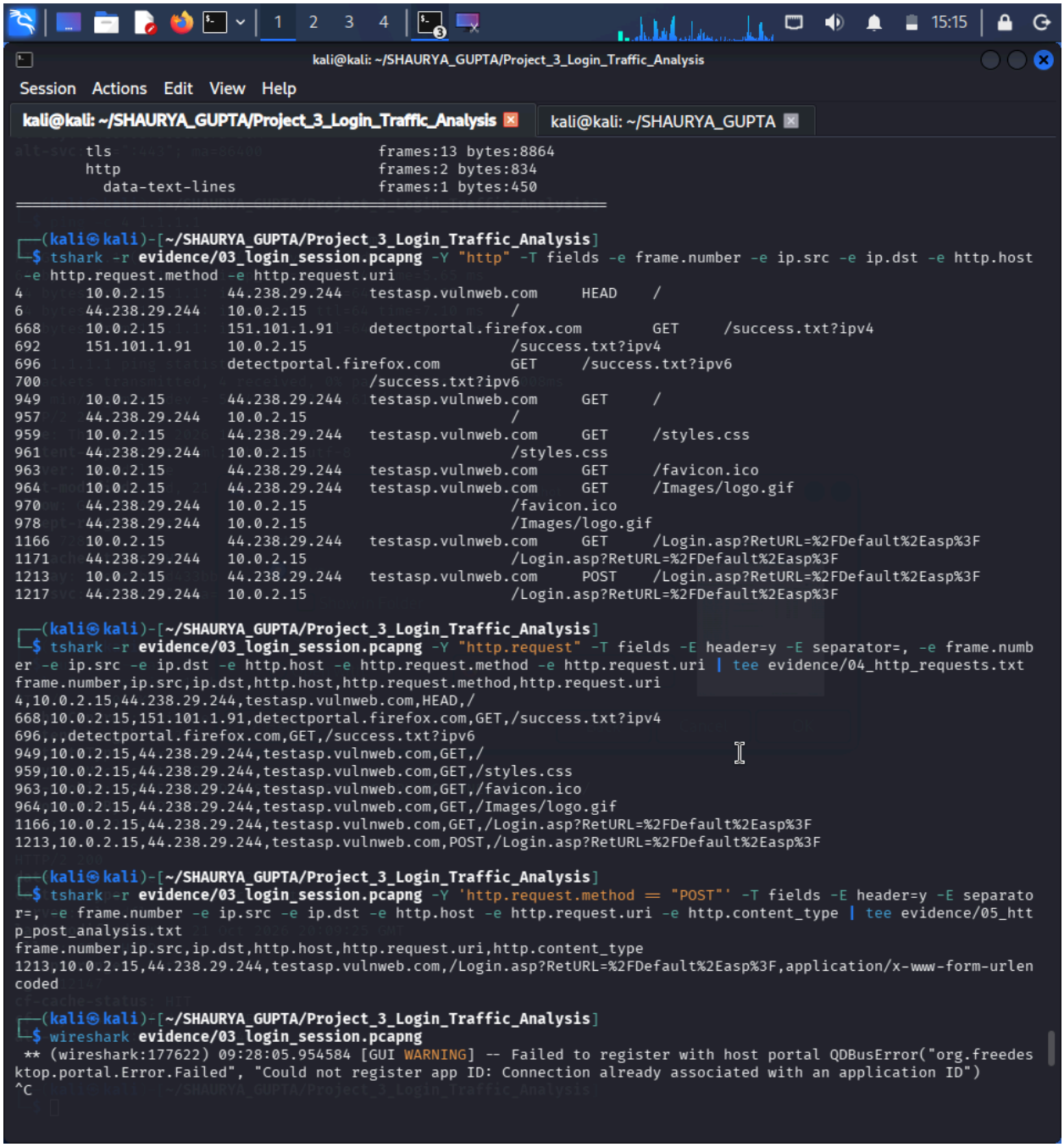
The following official documentation provides references for the tools and techniques used in this project. Retain only the sources you actually consulted while performing the exercise.

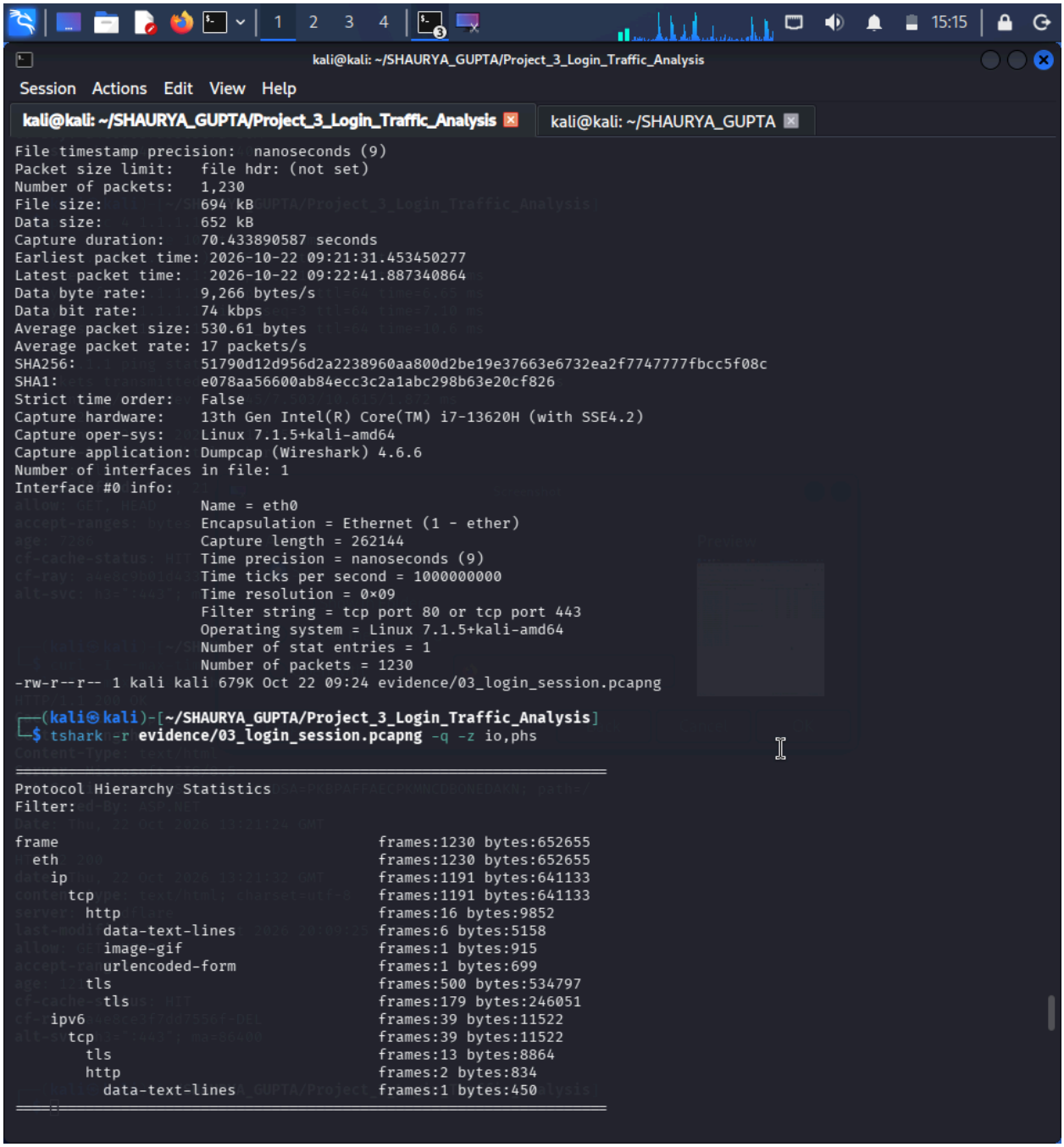
1. **Wireshark Documentation:** https://www.wireshark.org/docs/
2. **TShark Manual:** https://www.wireshark.org/docs/man-pages/tshark.html
3. **Burp Suite Documentation:** https://portswigger.net/burp/documentation
4. **PortSwigger Web Security Academy:** https://portswigger.net/web-security
5. **Kali Linux Documentation:** https://www.kali.org/docs/
6. **Training Website Used:** http://testasp.vulnweb.com/

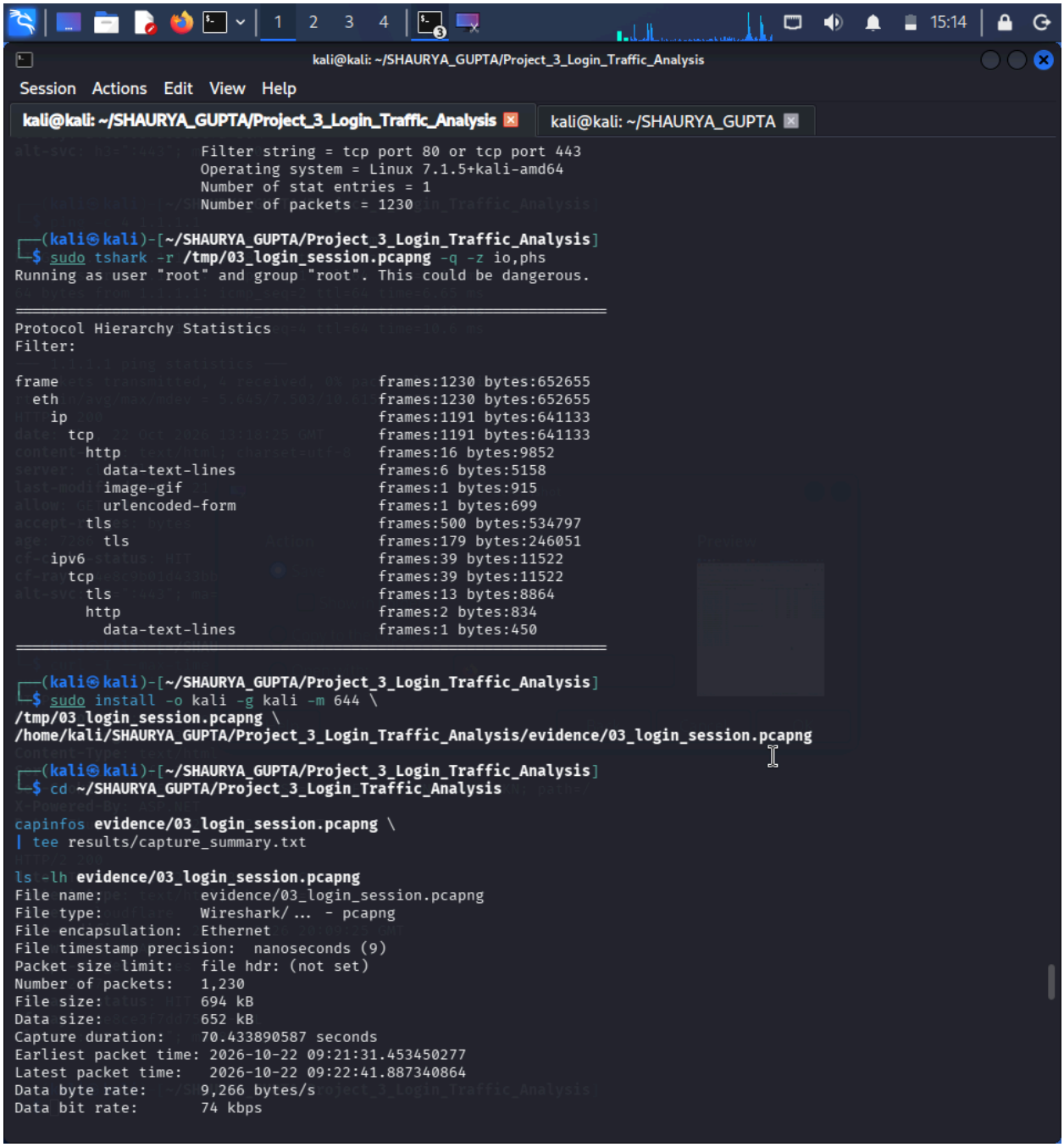
End of Report

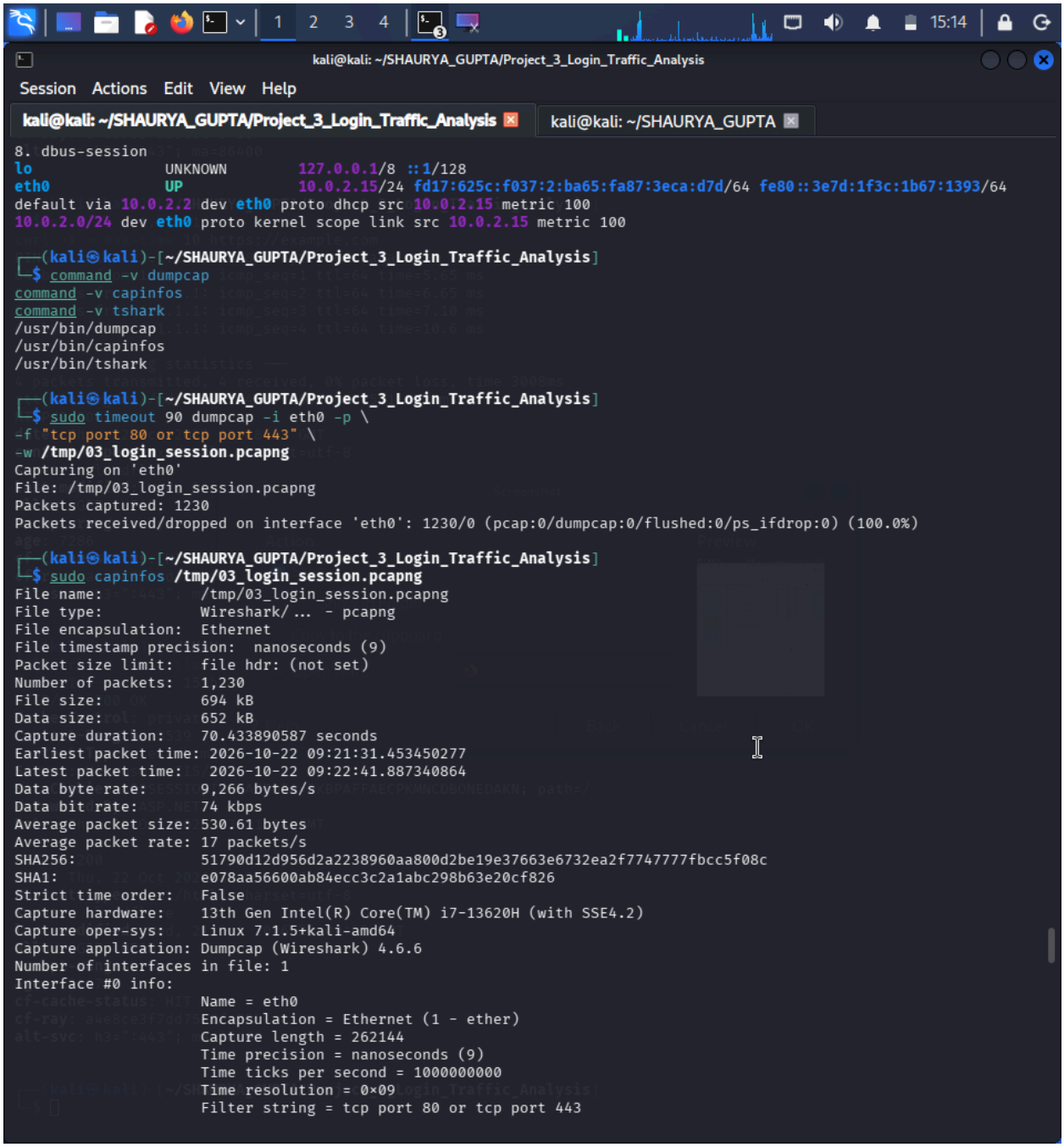

kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
Session Actions Edit View Help
kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
kali@kali: ~/SHAURYA_GUPTA
-rw-rw-r-- 1 kali kali 689 Oct 22 09:27 evidence/04_http_requests.txt
-rw-rw-r-- 1 kali kali 193 Oct 22 11:49 evidence/05_http_post_analysis.txt
-rw-rw-r-- 1 kali kali 1.5K Oct 22 09:24 results/capture_summary.txt
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
$ burpsuite
[warning] /usr/bin/burpsuite: No JAVA_CMD set for run_java, falling back to JAVA_CMD = java
WARNING: A terminally deprecated method in sun.misc.Unsafe has been called
WARNING: sun.misc.Unsafe::objectFieldOffset has been called by io.opentelemetry.internal.shaded.jctools.util.Unsafe
Access (file:/usr/share/burpsuite/burpsuite.jar)
WARNING: Please consider reporting this to the maintainers of class io.opentelemetry.internal.shaded.jctools.util.U
nsafeAccess
WARNING: sun.misc.Unsafe::objectFieldOffset will be removed in a future release
SLF4J(W): No SLF4J providers were found.
SLF4J(W): Defaulting to no-operation (NOP) logger implementation
SLF4J(W): See https://www.slf4j.org/codes.html#noProviders for further details.
WARNING: A restricted method in java.lang.System has been called
WARNING: java.lang.System::load has been called by com.sun.jna.Native in an unnamed module (file:/usr/share/burpsui
te/burpsuite.jar)
WARNING: Use --enable-native-access=ALL-UNNAMED to avoid a warning for callers in this module
WARNING: Restricted methods will be blocked in a future release unless native access is enabled
^C
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
$ cd ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
ls -lh evidence/screenshots/
total 3.9M
-rw-rw-r-- 1 kali kali 359K Oct 22 05:46 01.png
-rw-rw-r-- 1 kali kali 264K Oct 22 05:47 02.png
-rw-rw-r-- 1 kali kali 266K Oct 22 05:52 03.png
-rw-rw-r-- 1 kali kali 301K Oct 22 05:52 04.png
-rw-rw-r-- 1 kali kali 358K Oct 22 05:53 05.png
-rw-rw-r-- 1 kali kali 340K Oct 22 05:59 06.png
-rw-rw-r-- 1 kali kali 271K Oct 22 08:44 07.png
-rw-rw-r-- 1 kali kali 292K Oct 22 08:44 08.png
-rw-rw-r-- 1 kali kali 263K Oct 22 08:45 09.png
-rw-rw-r-- 1 kali kali 274K Oct 22 08:45 10.png
-rw-rw-r-- 1 kali kali 263K Oct 22 08:46 11.png
-rw-rw-r-- 1 kali kali 246K Oct 22 08:46 12.png
-rw-rw-r-- 1 kali kali 125K Oct 22 14:54 13.png
-rw-rw-r-- 1 kali kali 138K Oct 22 14:55 14.png
-rw-rw-r-- 1 kali kali 113K Oct 22 14:57 15.png
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
$ ls -lh evidence/03_login_session.pcapng \
evidence/04_http_requests.txt \
evidence/05_http_post_analysis.txt
-rw-r--r-- 1 kali kali 679K Oct 22 09:24 evidence/03_login_session.pcapng
-rw-rw-r-- 1 kali kali 689 Oct 22 09:27 evidence/04_http_requests.txt
-rw-rw-r-- 1 kali kali 193 Oct 22 11:49 evidence/05_http_post_analysis.txt
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
$

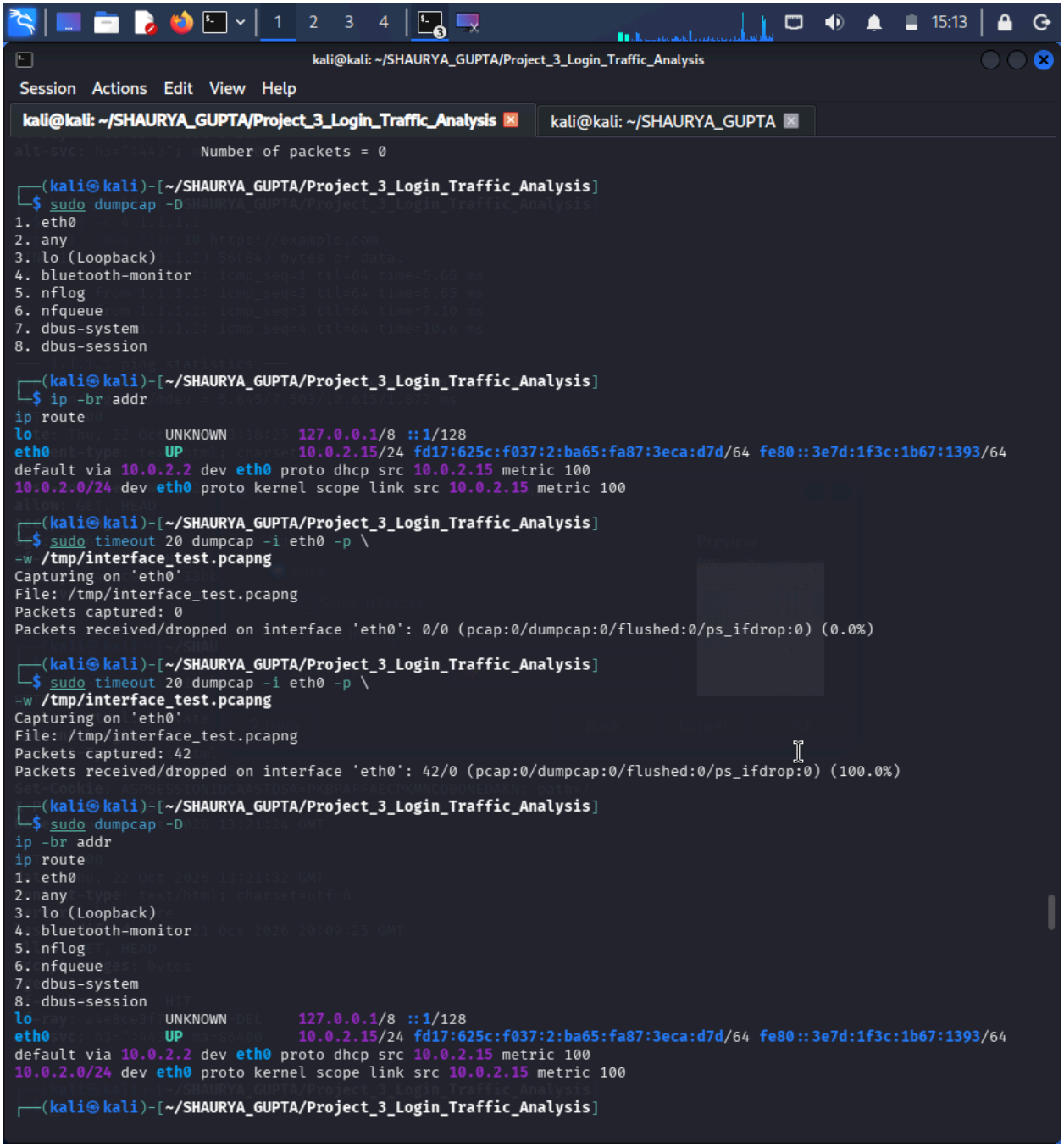

kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
Session Actions Edit View Help
kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
kali@kali: ~/SHAURYA_GUPTA
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ wireshark evidence/03_login_session.pcapng
** (wireshark:177903) 09:28:30.608447 [GUI WARNING] -- Failed to register with host portal QDBusError("org.freedesktop.portal.Error.Failed", "Could not register app ID: Connection already associated with an application ID")
^C
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ cd ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
mkdir -p evidence results
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ tshark -r evidence/03_login_session.pcapng \
-Y 'http.request.method == "POST"' \
-T fields -E header=y -E separator=, \
-e frame.number \
-e ip.src \
-e ip.dst \
-e http.host \
-e http.request.uri \
-e http.content_type \
| tee evidence/05_http_post_analysis.txt
frame.number,ip.src,ip.dst,http.host,http.request.uri,http.content_type
1213,10.0.2.15,44.238.29.244,testasp.vulnweb.com,/Login.asp?RetURL=%2FDefault%2Easp%3F,application/x-www-form-urlencoded
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ ls -lh evidence/05_http_post_analysis.txt
cat evidence/05_http_post_analysis.txt
-rw-rw-r-- 1 kali kali 193 Oct 22 11:49 evidence/05_http_post_analysis.txt
frame.number,ip.src,ip.dst,http.host,http.request.uri,http.content_type
1213,10.0.2.15,44.238.29.244,testasp.vulnweb.com,/Login.asp?RetURL=%2FDefault%2Easp%3F,application/x-www-form-urlencoded
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ wireshark evidence/03_login_session.pcapng
** (wireshark:221249) 11:49:37.152849 [GUI WARNING] -- Failed to register with host portal QDBusError("org.freedesktop.portal.Error.Failed", "Could not register app ID: Connection already associated with an application ID")
^C
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ cd ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
ls -lh evidence/03_login_session.pcapng \
evidence/04_http_requests.txt \
evidence/05_http_post_analysis.txt \
results/capture_summary.txt
-rw-r--r-- 1 kali kali 679K Oct 22 09:24 evidence/03_login_session.pcapng
-rw-rw-r-- 1 kali kali 689 Oct 22 09:27 evidence/04_http_requests.txt
-rw-rw-r-- 1 kali kali 193 Oct 22 11:49 evidence/05_http_post_analysis.txt
-rw-rw-r-- 1 kali kali 1.5K Oct 22 09:24 results/capture_summary.txt
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ burpsuite
[warning] /usr/bin/burpsuite: No JAVA_CMD set for run_java, falling back to JAVA_CMD = java

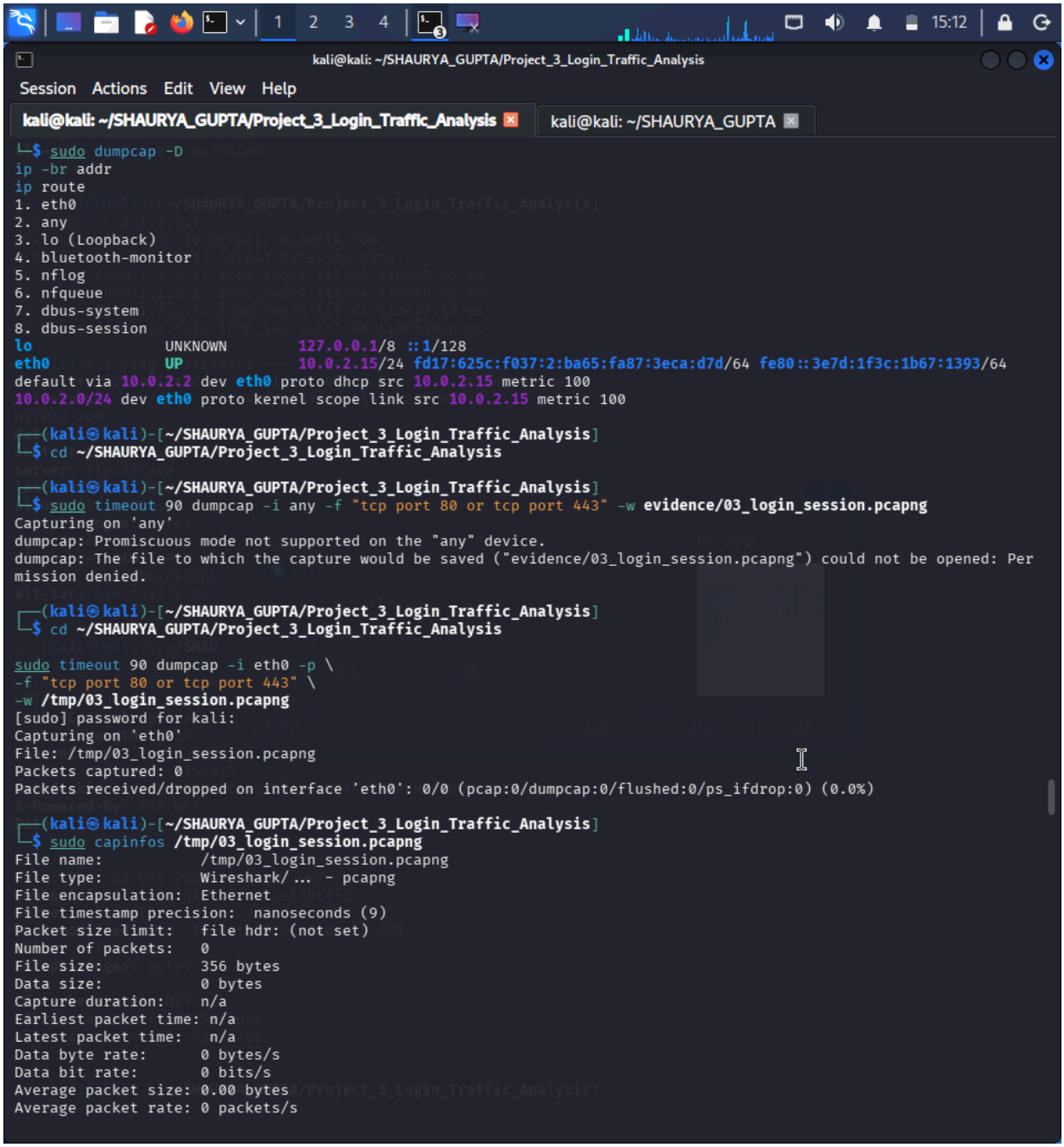

kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
Session Actions Edit View Help
kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
kali@kali: ~/SHAURYA_GUPTA
tls frames:13 bytes:8864
http frames:2 bytes:834
data-text-lines frames:1 bytes:450
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
$ tshark -r evidence/03_login_session.pcapng -Y "http" -T fields -e frame.number -e ip.src -e ip.dst -e http.host -e http.request.method -e http.request.uri
4 10.0.2.15 44.238.29.244 testasp.vulnweb.com HEAD /
6 44.238.29.244 10.0.2.15 /
668 10.0.2.15 151.101.1.91 detectportal.firefox.com GET /success.txt?ipv4
692 151.101.1.91 10.0.2.15 /success.txt?ipv4
696 detectportal.firefox.com GET /success.txt?ipv6
700 /success.txt?ipv6
949 10.0.2.15 44.238.29.244 testasp.vulnweb.com GET /
957 44.238.29.244 10.0.2.15 /
959 10.0.2.15 44.238.29.244 testasp.vulnweb.com GET /styles.css
961 44.238.29.244 10.0.2.15 /styles.css
963 10.0.2.15 44.238.29.244 testasp.vulnweb.com GET /favicon.ico
964 10.0.2.15 44.238.29.244 testasp.vulnweb.com GET /Images/logo.gif
970 44.238.29.244 10.0.2.15 /favicon.ico
978 44.238.29.244 10.0.2.15 /Images/logo.gif
1166 10.0.2.15 44.238.29.244 testasp.vulnweb.com GET /Login.asp?RetURL=%2FDefault%2Easp%3F
1171 44.238.29.244 10.0.2.15 /Login.asp?RetURL=%2FDefault%2Easp%3F
1213 10.0.2.15 44.238.29.244 testasp.vulnweb.com POST /Login.asp?RetURL=%2FDefault%2Easp%3F
1217 44.238.29.244 10.0.2.15 /Login.asp?RetURL=%2FDefault%2Easp%3F
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
$ tshark -r evidence/03_login_session.pcapng -Y "http.request" -T fields -E header=y -E separator=, -e frame.number -e ip.src -e ip.dst -e http.host -e http.request.method -e http.request.uri | tee evidence/04_http_requests.txt
frame.number,ip.src,ip.dst,http.host,http.request.method,http.request.uri
4,10.0.2.15,44.238.29.244,testasp.vulnweb.com,HEAD,/
668,10.0.2.15,151.101.1.91,detectportal.firefox.com,GET,/success.txt?ipv4
696,,,detectportal.firefox.com,GET,/success.txt?ipv6
949,10.0.2.15,44.238.29.244,testasp.vulnweb.com,GET,/
959,10.0.2.15,44.238.29.244,testasp.vulnweb.com,GET,/styles.css
963,10.0.2.15,44.238.29.244,testasp.vulnweb.com,GET,/favicon.ico
964,10.0.2.15,44.238.29.244,testasp.vulnweb.com,GET,/Images/logo.gif
1166,10.0.2.15,44.238.29.244,testasp.vulnweb.com,GET,/Login.asp?RetURL=%2FDefault%2Easp%3F
1213,10.0.2.15,44.238.29.244,testasp.vulnweb.com,POST,/Login.asp?RetURL=%2FDefault%2Easp%3F
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
$ tshark -r evidence/03_login_session.pcapng -Y 'http.request.method == "POST"' -T fields -E header=y -E separator=, -e frame.number -e ip.src -e ip.dst -e http.host -e http.request.uri -e http.content_type | tee evidence/05_http_post_analysis.txt
frame.number,ip.src,ip.dst,http.host,http.request.uri,http.content_type
1213,10.0.2.15,44.238.29.244,testasp.vulnweb.com,/Login.asp?RetURL=%2FDefault%2Easp%3F,application/x-www-form-urlencoded
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
$ wireshark evidence/03_login_session.pcapng
** (wireshark:177622) 09:28:05.954584 [GUI WARNING] -- Failed to register with host portal QDBusError("org.freedesktop.portal.Error.Failed", "Could not register app ID: Connection already associated with an application ID")
^C

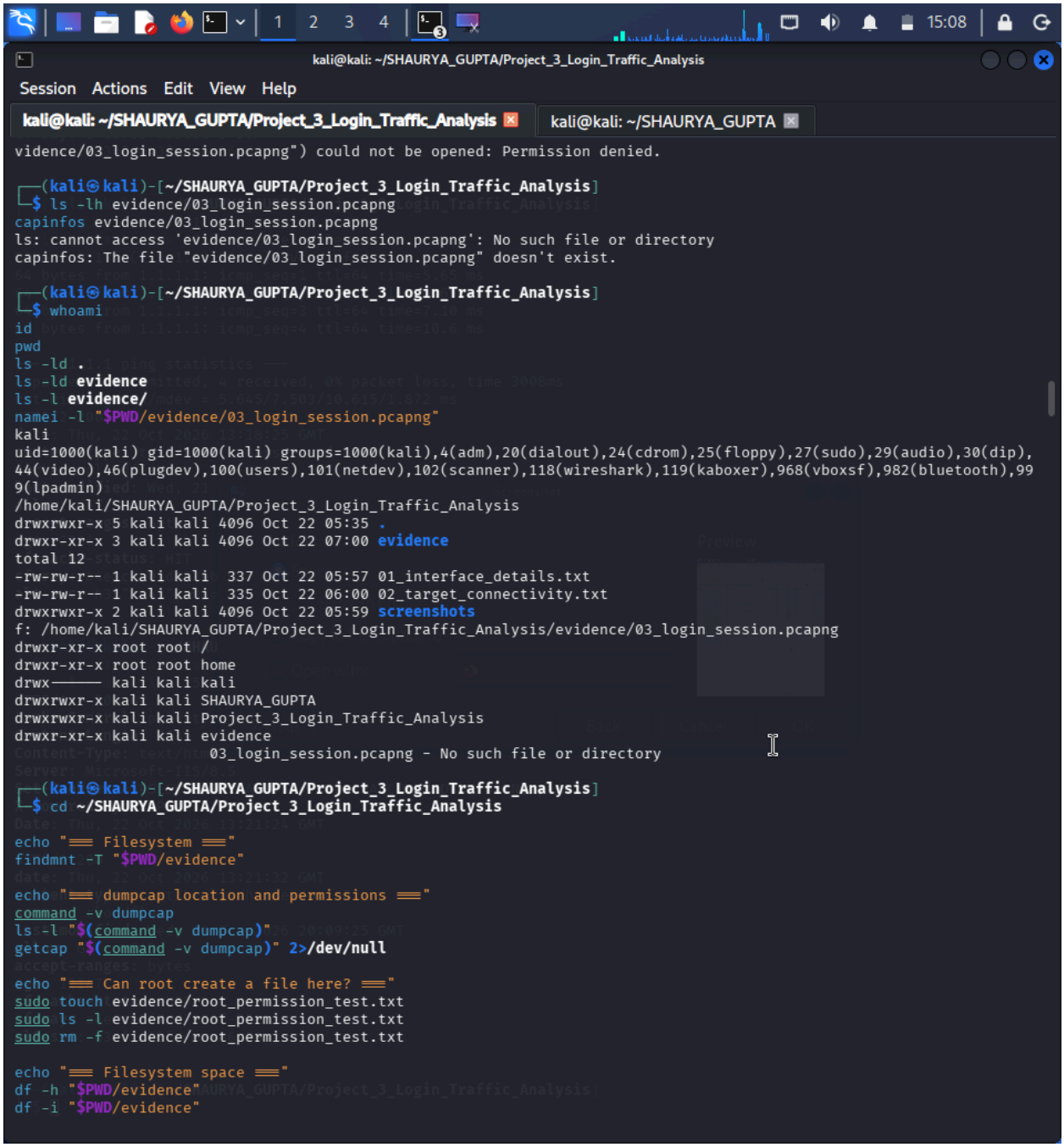

kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
Session Actions Edit View Help
kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
kali@kali: ~/SHAURYA_GUPTA
File timestamp precision: nanoseconds (9)
Packet size limit: file hdr: (not set)
Number of packets: 1,230
File size: 694 kB
Data size: 652 kB
Capture duration: 70.433890587 seconds
Earliest packet time: 2026-10-22 09:21:31.453450277
Latest packet time: 2026-10-22 09:22:41.887340864
Data byte rate: 9,266 bytes/s
Data bit rate: 74 kbps
Average packet size: 530.61 bytes
Average packet rate: 17 packets/s
SHA256: 51790d12d956d2a2238960aa800d2be19e37663e6732ea2f7747777fbcc5f08c
SHA1: e078aa56600ab84ecc3c2a1abc298b63e20cf826
Strict time order: False
Capture hardware: 13th Gen Intel(R) Core(TM) i7-13620H (with SSE4.2)
Capture oper-sys: Linux 7.1.5+kali-amd64
Capture application: Dumpcap (Wireshark) 4.6.6
Number of interfaces in file: 1
Interface #0 info:
Name = eth0
Encapsulation = Ethernet (1 - ether)
Capture length = 262144
Time precision = nanoseconds (9)
Time ticks per second = 1000000000
Time resolution = 0x09
Filter string = tcp port 80 or tcp port 443
Operating system = Linux 7.1.5+kali-amd64
Number of stat entries = 1
Number of packets = 1230
-rw-r--r-- 1 kali kali 679K Oct 22 09:24 evidence/03_login_session.pcapng
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
$ tshark -r evidence/03_login_session.pcapng -q -z io,phs
Protocol Hierarchy Statistics
Filter:
frame frames:1230 bytes:652655
eth frames:1230 bytes:652655
ip frames:1191 bytes:641133
tcp frames:1191 bytes:641133
http frames:16 bytes:9852
data-text-lines frames:6 bytes:5158
image-gif frames:1 bytes:915
urlencoded-form frames:1 bytes:699
tls frames:500 bytes:534797
tls frames:179 bytes:246051
ipv6 frames:39 bytes:11522
tcp frames:39 bytes:11522
tls frames:13 bytes:8864
http frames:2 bytes:834
data-text-lines frames:1 bytes:450

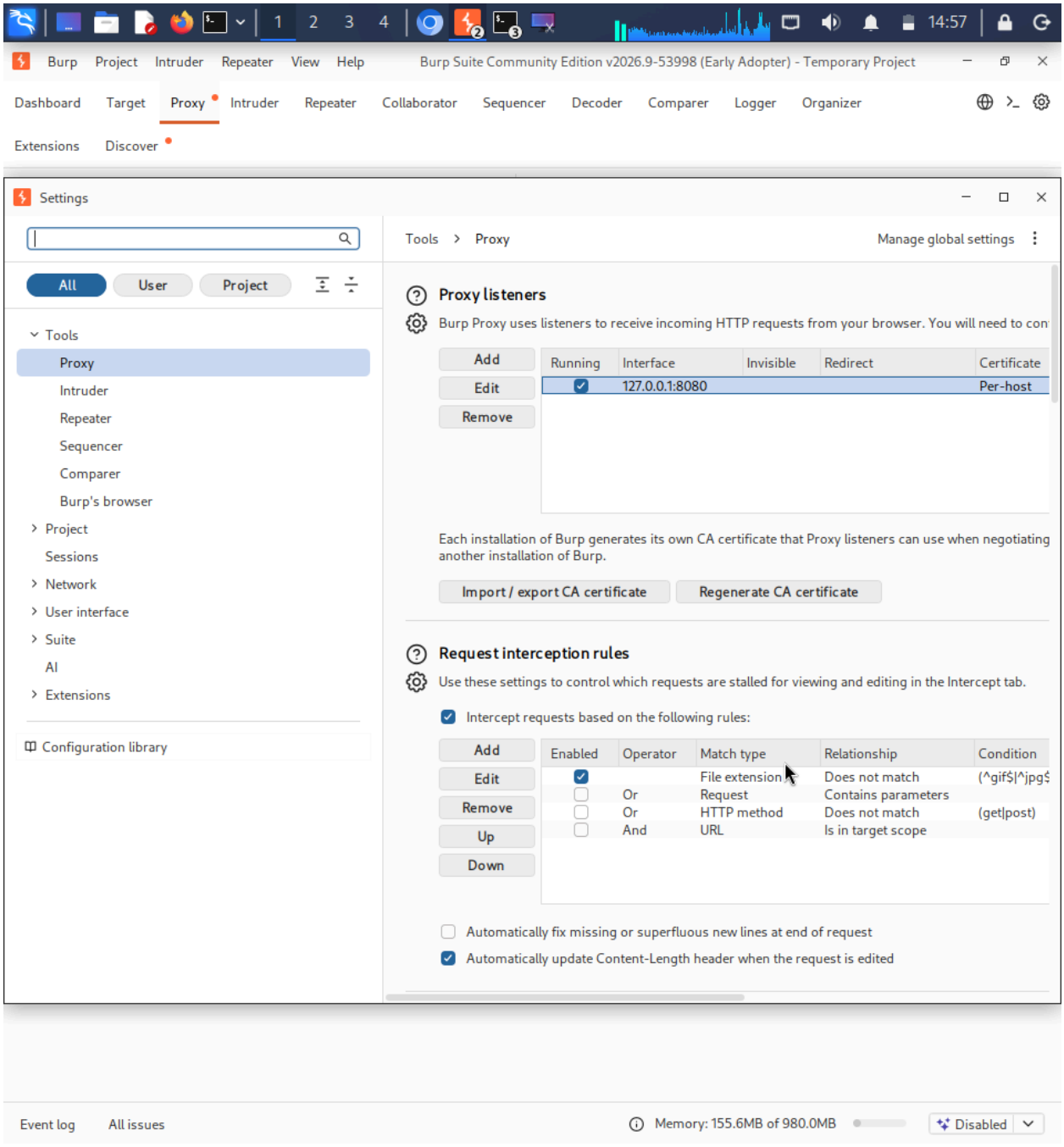

kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
Session Actions Edit View Help
kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
kali@kali: ~/SHAURYA_GUPTA
Filter string = tcp port 80 or tcp port 443
Operating system = Linux 7.1.5+kali-amd64
Number of stat entries = 1
Number of packets = 1230
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo tshark -r /tmp/03_login_session.pcapng -q -z io,phs
Running as user "root" and group "root". This could be dangerous.
Protocol Hierarchy Statistics
Filter:
frame frames:1230 bytes:652655
eth frames:1230 bytes:652655
ip frames:1191 bytes:641133
tcp frames:1191 bytes:641133
http frames:16 bytes:9852
data-text-lines frames:6 bytes:5158
image-gif frames:1 bytes:915
urlencoded-form frames:1 bytes:699
tls frames:500 bytes:534797
tls frames:179 bytes:246051
ipv6 frames:39 bytes:11522
tcp frames:39 bytes:11522
tls frames:13 bytes:8864
http frames:2 bytes:834
data-text-lines frames:1 bytes:450
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo install -o kali -g kali -m 644 \
/tmp/03_login_session.pcapng \
/home/kali/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis/evidence/03_login_session.pcapng
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ cd ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
capinfos evidence/03_login_session.pcapng \
| tee results/capture_summary.txt
ls -lh evidence/03_login_session.pcapng
File name: evidence/03_login_session.pcapng
File type: Wireshark/... - pcapng
File encapsulation: Ethernet
File timestamp precision: nanoseconds (9)
Packet size limit: file hdr: (not set)
Number of packets: 1,230
File size: 694 kB
Data size: 652 kB
Capture duration: 70.433890587 seconds
Earliest packet time: 2026-10-22 09:21:31.453450277
Latest packet time: 2026-10-22 09:22:41.887340864
Data byte rate: 9,266 bytes/s
Data bit rate: 74 kbps

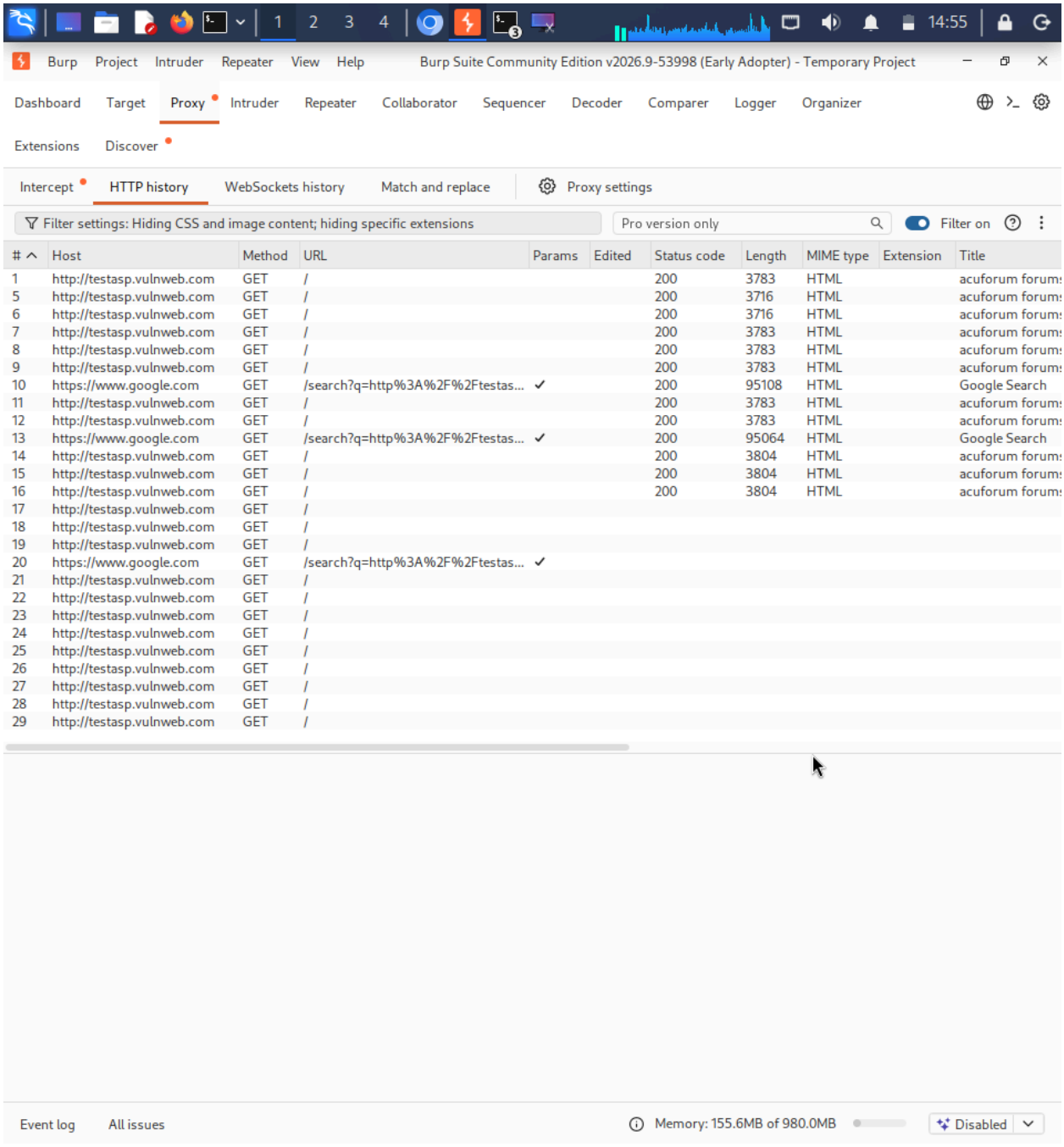

kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
Session Actions Edit View Help
kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
kali@kali: ~/SHAURYA_GUPTA
8. dbus-session
lo UNKNOWN 127.0.0.1/8 ::1/128
eth0 UP 10.0.2.15/24 fd17:625c:f037:2:ba65:fa87:3eca:d7d/64 fe80::3e7d:1f3c:1b67:1393/64
default via 10.0.2.2 dev eth0 proto dhcp src 10.0.2.15 metric 100
10.0.2.0/24 dev eth0 proto kernel scope link src 10.0.2.15 metric 100
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ command -v dumpcap
command -v capinfos
command -v tshark
/usr/bin/dumpcap
/usr/bin/capinfos
/usr/bin/tshark
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo timeout 90 dumpcap -i eth0 -p \
-f "tcp port 80 or tcp port 443" \
-w /tmp/03_login_session.pcapng
Capturing on 'eth0'
File: /tmp/03_login_session.pcapng
Packets captured: 1230
Packets received/dropped on interface 'eth0': 1230/0 (pcap:0/dumpcap:0/flushed:0/ps_ifdrop:0) (100.0%)
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo capinfos /tmp/03_login_session.pcapng
File name: /tmp/03_login_session.pcapng
File type: Wireshark/... - pcapng
File encapsulation: Ethernet
File timestamp precision: nanoseconds (9)
Packet size limit: file hdr: (not set)
Number of packets: 1,230
File size: 694 kB
Data size: 652 kB
Capture duration: 70.433890587 seconds
Earliest packet time: 2026-10-22 09:21:31.453450277
Latest packet time: 2026-10-22 09:22:41.887340864
Data byte rate: 9,266 bytes/s
Data bit rate: 74 kbps
Average packet size: 530.61 bytes
Average packet rate: 17 packets/s
SHA256: 51790d12d956d2a2238960aa800d2be19e37663e6732ea2f7747777fbcc5f08c
SHA1: e078aa56600ab84ecc3c2a1abc298b63e20cf826
Strict time order: False
Capture hardware: 13th Gen Intel(R) Core(TM) i7-13620H (with SSE4.2)
Capture oper-sys: Linux 7.1.5+kali-amd64
Capture application: Dumpcap (Wireshark) 4.6.6
Number of interfaces in file: 1
Interface #0 info:
Name = eth0
Encapsulation = Ethernet (1 - ether)
Capture length = 262144
Time precision = nanoseconds (9)
Time ticks per second = 1000000000
Time resolution = 0x09
Filter string = tcp port 80 or tcp port 443

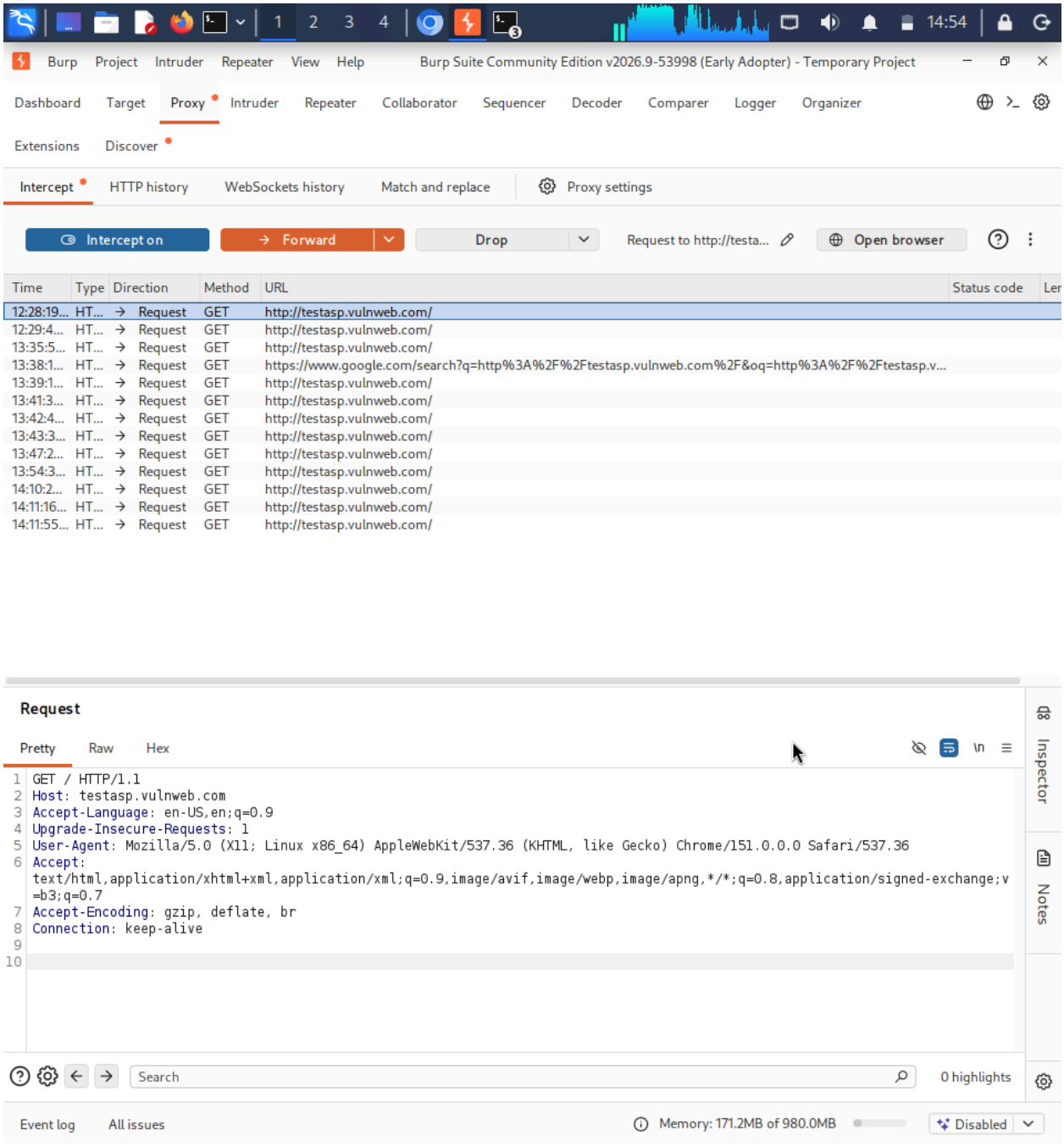

kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
Session Actions Edit View Help
kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
kali@kali: ~/SHAURYA_GUPTA
Number of packets = 0
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo dumpcap -D
1. eth0
2. any
3. lo (Loopback)
4. bluetooth-monitor
5. nflog
6. nfqueue
7. dbus-system
8. dbus-session
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ ip -br addr
ip route
lo UNKNOWN 127.0.0.1/8 ::1/128
eth0 UP 10.0.2.15/24 fd17:625c:f037:2:ba65:fa87:3eca:d7d/64 fe80::3e7d:1f3c:1b67:1393/64
default via 10.0.2.2 dev eth0 proto dhcp src 10.0.2.15 metric 100
10.0.2.0/24 dev eth0 proto kernel scope link src 10.0.2.15 metric 100
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo timeout 20 dumpcap -i eth0 -p \
-w /tmp/interface_test.pcapng
Capturing on 'eth0'
File: /tmp/interface_test.pcapng
Packets captured: 0
Packets received/dropped on interface 'eth0': 0/0 (pcap:0/dumpcap:0/flushed:0/ps_ifdrop:0) (0.0%)
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo timeout 20 dumpcap -i eth0 -p \
-w /tmp/interface_test.pcapng
Capturing on 'eth0'
File: /tmp/interface_test.pcapng
Packets captured: 42
Packets received/dropped on interface 'eth0': 42/0 (pcap:0/dumpcap:0/flushed:0/ps_ifdrop:0) (100.0%)
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo dumpcap -D
ip -br addr
ip route
1. eth0
2. any
3. lo (Loopback)
4. bluetooth-monitor
5. nflog
6. nfqueue
7. dbus-system
8. dbus-session
lo UNKNOWN 127.0.0.1/8 ::1/128
eth0 UP 10.0.2.15/24 fd17:625c:f037:2:ba65:fa87:3eca:d7d/64 fe80::3e7d:1f3c:1b67:1393/64
default via 10.0.2.2 dev eth0 proto dhcp src 10.0.2.15 metric 100
10.0.2.0/24 dev eth0 proto kernel scope link src 10.0.2.15 metric 100
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]


kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
Session Actions Edit View Help
kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
kali@kali: ~/SHAURYA_GUPTA
└─$ sudo dumpcap -D
ip -br addr
ip route
1. eth0
2. any
3. lo (Loopback)
4. bluetooth-monitor
5. nflog
6. nfqueue
7. dbus-system
8. dbus-session
lo UNKNOWN 127.0.0.1/8 ::1/128
eth0 UP 10.0.2.15/24 fd17:625c:f037:2:ba65:fa87:3eca:d7d/64 fe80::3e7d:1f3c:1b67:1393/64
default via 10.0.2.2 dev eth0 proto dhcp src 10.0.2.15 metric 100
10.0.2.0/24 dev eth0 proto kernel scope link src 10.0.2.15 metric 100
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ cd ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo timeout 90 dumpcap -i any -f "tcp port 80 or tcp port 443" -w evidence/03_login_session.pcapng
Capturing on 'any'
dumpcap: Promiscuous mode not supported on the "any" device.
dumpcap: The file to which the capture would be saved ("evidence/03_login_session.pcapng") could not be opened: Permission denied.
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ cd ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
sudo timeout 90 dumpcap -i eth0 -p \
-f "tcp port 80 or tcp port 443" \
-w /tmp/03_login_session.pcapng
[sudo] password for kali:
Capturing on 'eth0'
File: /tmp/03_login_session.pcapng
Packets captured: 0
Packets received/dropped on interface 'eth0': 0/0 (pcap:0/dumpcap:0/flushed:0/ps_ifdrop:0) (0.0%)
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo capinfos /tmp/03_login_session.pcapng
File name: /tmp/03_login_session.pcapng
File type: Wireshark/ ... - pcapng
File encapsulation: Ethernet
File timestamp precision: nanoseconds (9)
Packet size limit: file hdr: (not set)
Number of packets: 0
File size: 356 bytes
Data size: 0 bytes
Capture duration: n/a
Earliest packet time: n/a
Latest packet time: n/a
Data byte rate: 0 bytes/s
Data bit rate: 0 bits/s
Average packet size: 0.00 bytes
Average packet rate: 0 packets/s

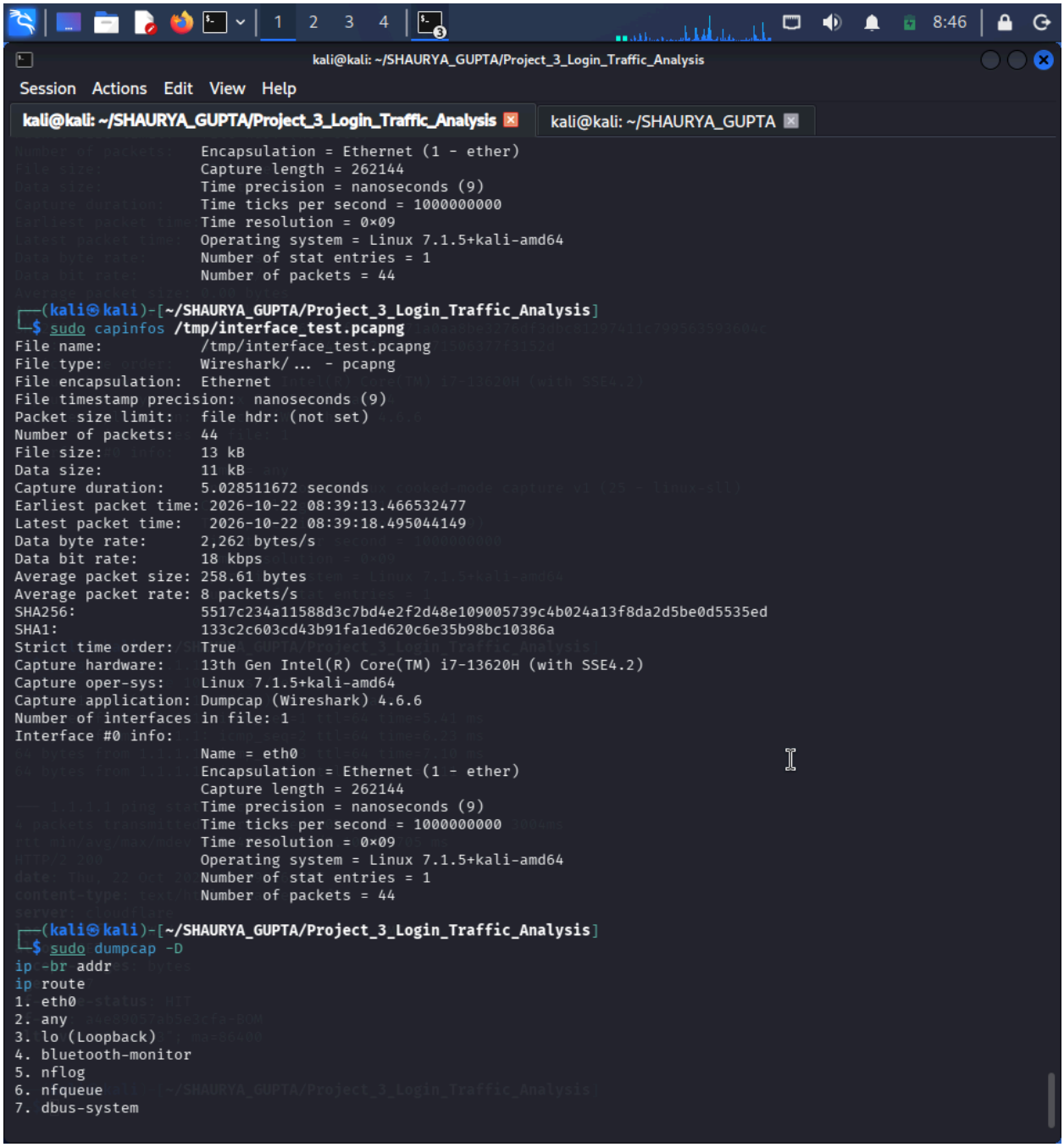

kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
Session Actions Edit View Help
kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
kali@kali: ~/SHAURYA_GUPTA
vidence/03_login_session.pcapng") could not be opened: Permission denied.
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ ls -lh evidence/03_login_session.pcapng
capinfos evidence/03_login_session.pcapng
ls: cannot access 'evidence/03_login_session.pcapng': No such file or directory
capinfos: The file "evidence/03_login_session.pcapng" doesn't exist.
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ whoami
id
pwd
ls -ld .
ls -ld evidence
ls -l evidence/
namei -l "$PWD/evidence/03_login_session.pcapng"
kali
uid=1000(kali) gid=1000(kali) groups=1000(kali),4(adm),20(dialout),24(cdrom),25(floppy),27(sudo),29(audio),30(dip),
44(video),46(plugdev),100(users),101(netdev),102(scanner),118(wireshark),119(kaboxer),968(vboxsf),982(bluetooth),99
9(lpadmin)
/home/kali/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
drwxrwxr-x 5 kali kali 4096 Oct 22 05:35 .
drwxr-xr-x 3 kali kali 4096 Oct 22 07:00 evidence
total 12
-rw-rw-r-- 1 kali kali 337 Oct 22 05:57 01_interface_details.txt
-rw-rw-r-- 1 kali kali 335 Oct 22 06:00 02_target_connectivity.txt
drwxrwxr-x 2 kali kali 4096 Oct 22 05:59 screenshots
f: /home/kali/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis/evidence/03_login_session.pcapng
drwxr-xr-x root root /
drwxr-xr-x root root home
drwx------ kali kali kali
drwxrwxr-x kali kali SHAURYA_GUPTA
drwxrwxr-x kali kali Project_3_Login_Traffic_Analysis
drwxr-xr-x kali kali evidence
03_login_session.pcapng - No such file or directory
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ cd ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
echo "=== Filesystem ==="
findmnt -T "$PWD/evidence"
echo "=== dumpcap location and permissions ==="
command -v dumpcap
ls -l "$(command -v dumpcap)"
getcap "$(command -v dumpcap)" 2>/dev/null
echo "=== Can root create a file here? ==="
sudo touch evidence/root_permission_test.txt
sudo ls -l evidence/root_permission_test.txt
sudo rm -f evidence/root_permission_test.txt
echo "=== Filesystem space ==="
df -h "$PWD/evidence"
df -i "$PWD/evidence"

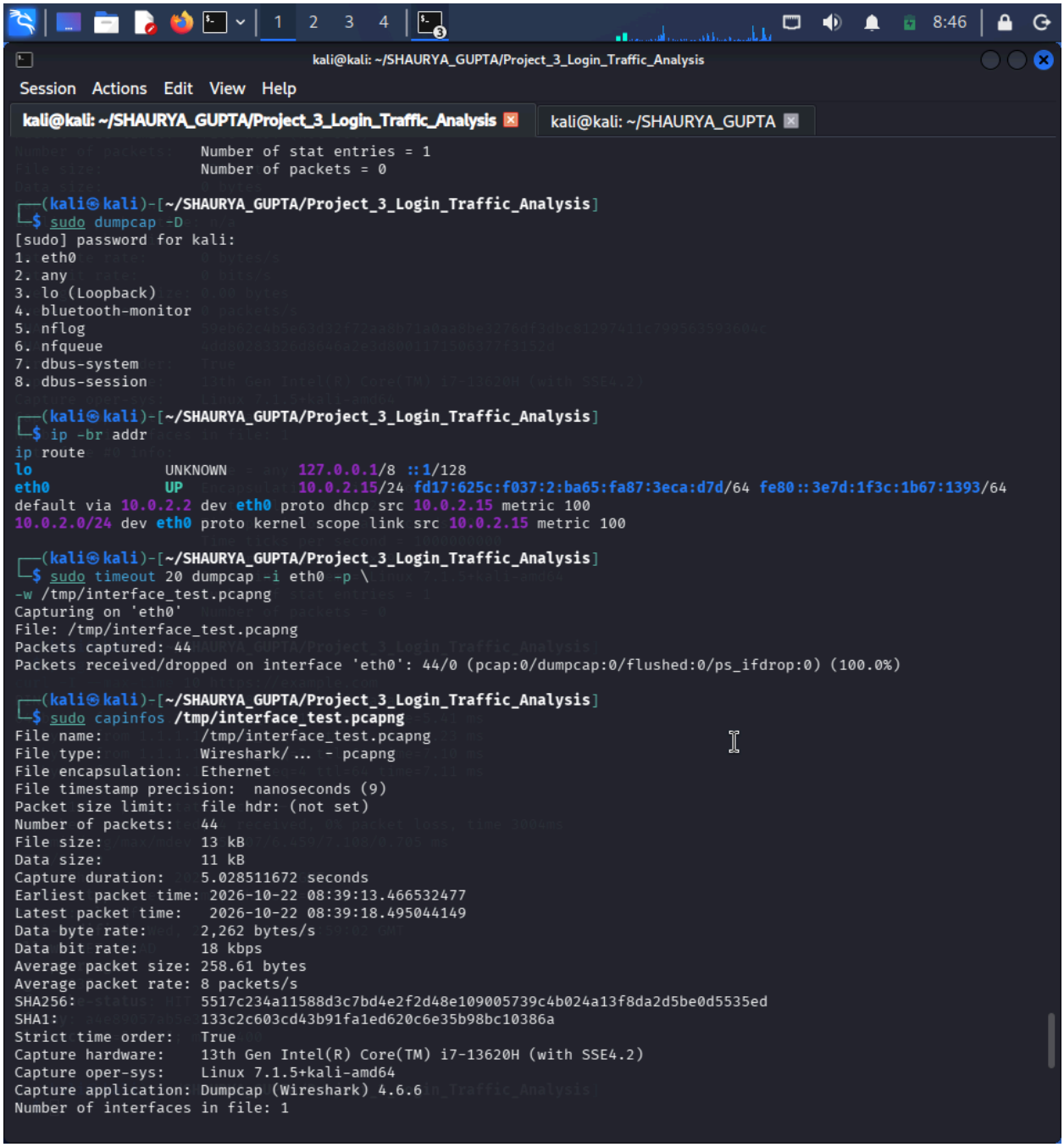

14:57
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Settings
All User Project
Tools
Proxy
Intruder
Repeater
Sequencer
Comparer
Burp's browser
Project
Sessions
Network
User interface
Suite
AI
Extensions
Configuration library
Tools > Proxy
Manage global settings
Proxy listeners
Burp Proxy uses listeners to receive incoming HTTP requests from your browser. You will need to con
Add
Edit
Remove
Running Interface Invisible Redirect Certificate
127.0.0.1:8080 Per-host
Each installation of Burp generates its own CA certificate that Proxy listeners can use when negotiating another installation of Burp.
Import / export CA certificate
Regenerate CA certificate
Request interception rules
Use these settings to control which requests are stalled for viewing and editing in the Intercept tab.
Intercept requests based on the following rules:
Add
Edit
Remove
Up
Down
Enabled Operator Match type Relationship Condition
File extension Does not match (^gif$|^jpg$
Or Request Contains parameters
Or HTTP method Does not match (get|post)
And URL Is in target scope
Automatically fix missing or superfluous new lines at end of request
Automatically update Content-Length header when the request is edited
Event log
All issues
Memory: 155.6MB of 980.0MB
Disabled

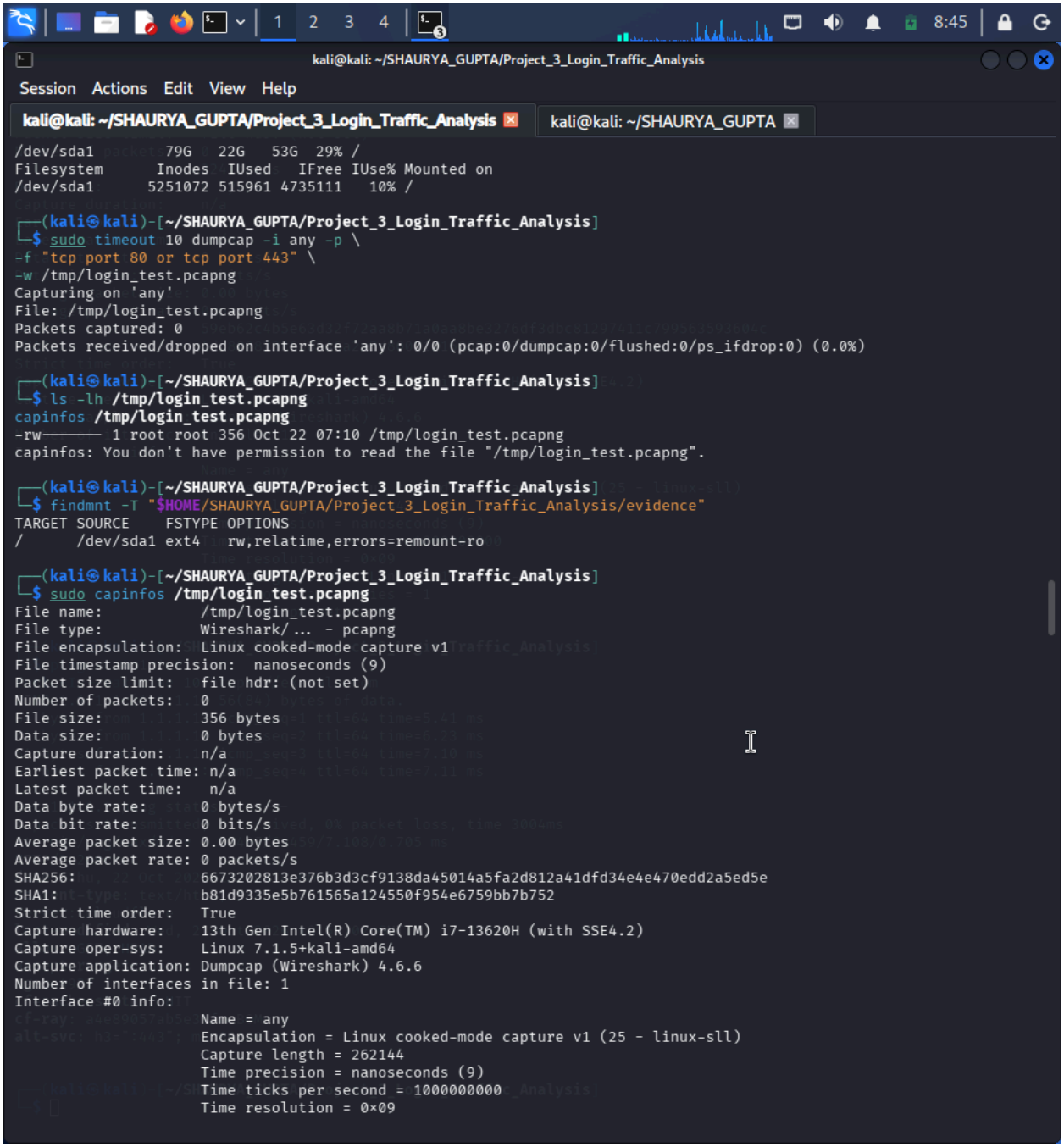

14:55
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title
1 http://testasp.vulnweb.com GET / 200 3783 HTML acuforum forums
5 http://testasp.vulnweb.com GET / 200 3716 HTML acuforum forums
6 http://testasp.vulnweb.com GET / 200 3716 HTML acuforum forums
7 http://testasp.vulnweb.com GET / 200 3783 HTML acuforum forums
8 http://testasp.vulnweb.com GET / 200 3783 HTML acuforum forums
9 http://testasp.vulnweb.com GET / 200 3783 HTML acuforum forums
10 https://www.google.com GET /search?q=http%3A%2F%2Ftestas... ✓ 200 95108 HTML Google Search
11 http://testasp.vulnweb.com GET / 200 3783 HTML acuforum forums
12 http://testasp.vulnweb.com GET / 200 3783 HTML acuforum forums
13 https://www.google.com GET /search?q=http%3A%2F%2Ftestas... ✓ 200 95064 HTML Google Search
14 http://testasp.vulnweb.com GET / 200 3804 HTML acuforum forums
15 http://testasp.vulnweb.com GET / 200 3804 HTML acuforum forums
16 http://testasp.vulnweb.com GET / 200 3804 HTML acuforum forums
17 http://testasp.vulnweb.com GET /
18 http://testasp.vulnweb.com GET /
19 http://testasp.vulnweb.com GET /
20 https://www.google.com GET /search?q=http%3A%2F%2Ftestas... ✓
21 http://testasp.vulnweb.com GET /
22 http://testasp.vulnweb.com GET /
23 http://testasp.vulnweb.com GET /
24 http://testasp.vulnweb.com GET /
25 http://testasp.vulnweb.com GET /
26 http://testasp.vulnweb.com GET /
27 http://testasp.vulnweb.com GET /
28 http://testasp.vulnweb.com GET /
29 http://testasp.vulnweb.com GET /
Event log All issues
Memory: 155.6MB of 980.0MB
Disabled

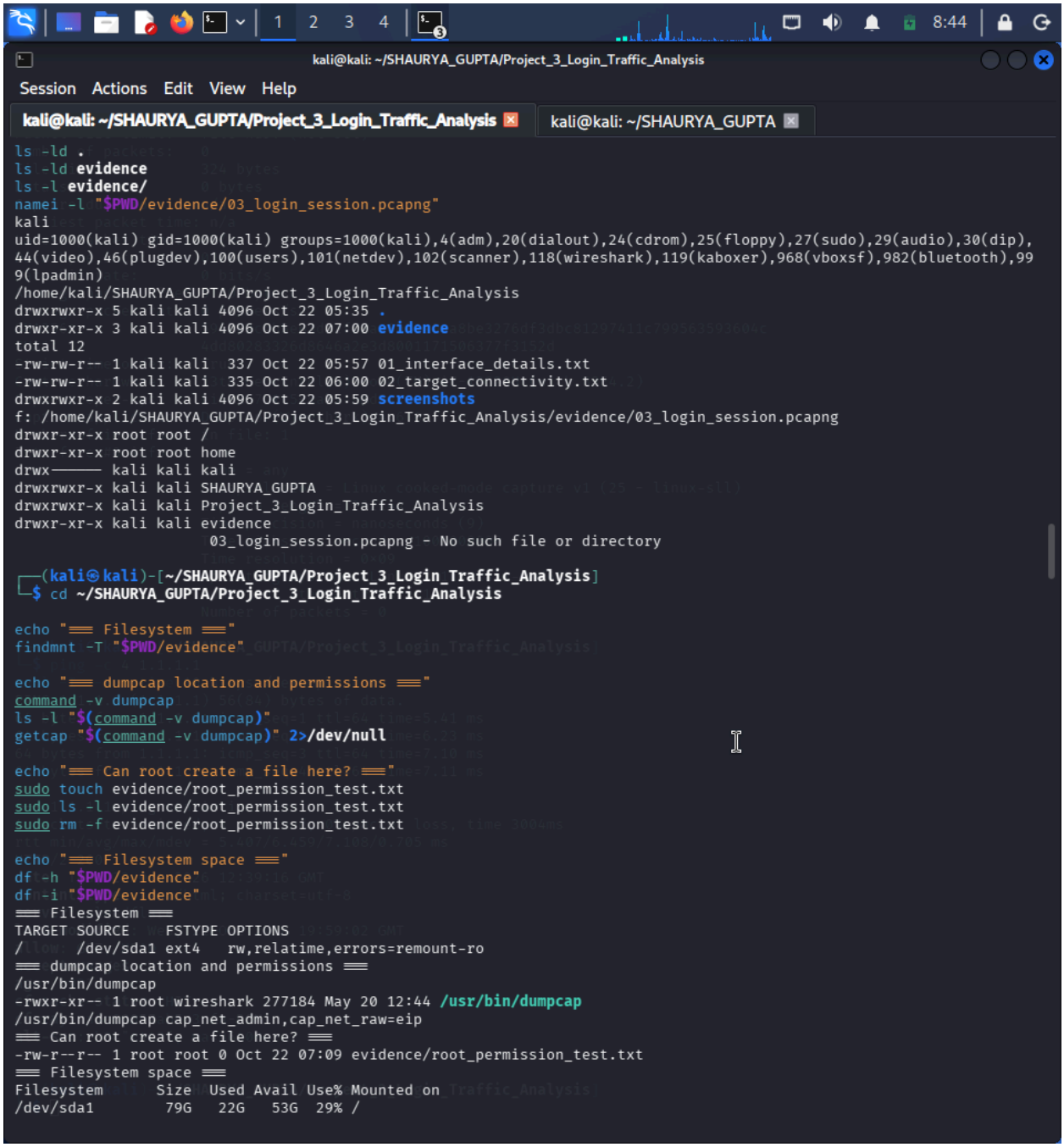

Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Intercept on Forward Drop Request to http://testa... Open browser
Time Type Direction Method URL Status code
12:28:19... HT... → Request GET http://testasp.vulnweb.com/
12:29:4... HT... → Request GET http://testasp.vulnweb.com/
13:35:5... HT... → Request GET http://testasp.vulnweb.com/
13:38:1... HT... → Request GET https://www.google.com/search?q=http%3A%2F%2Ftestasp.vulnweb.com%2F&oq=http%3A%2F%2Ftestasp.v...
13:39:1... HT... → Request GET http://testasp.vulnweb.com/
13:41:3... HT... → Request GET http://testasp.vulnweb.com/
13:42:4... HT... → Request GET http://testasp.vulnweb.com/
13:43:3... HT... → Request GET http://testasp.vulnweb.com/
13:47:2... HT... → Request GET http://testasp.vulnweb.com/
13:54:3... HT... → Request GET http://testasp.vulnweb.com/
14:10:2... HT... → Request GET http://testasp.vulnweb.com/
14:11:16... HT... → Request GET http://testasp.vulnweb.com/
14:11:55... HT... → Request GET http://testasp.vulnweb.com/

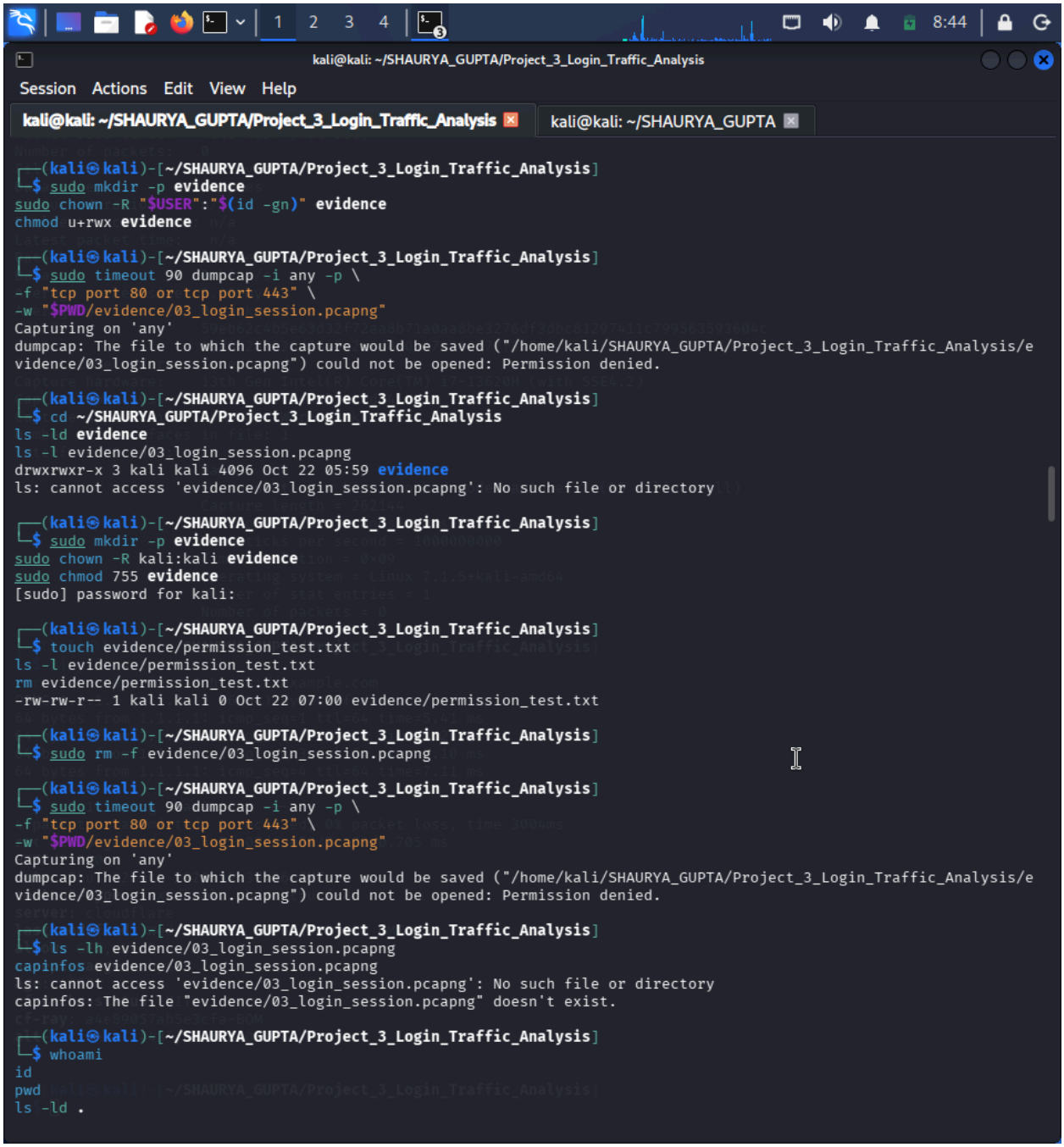
Request
Pretty Raw Hex
1 GET / HTTP/1.1
2 Host: testasp.vulnweb.com
3 Accept-Language: en-US,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
6 Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Accept-Encoding: gzip, deflate, br
8 Connection: keep-alive
9
10
Search
0 highlights
Inspector
Notes
Event log All issues
Memory: 171.2MB of 980.0MB
Disabled

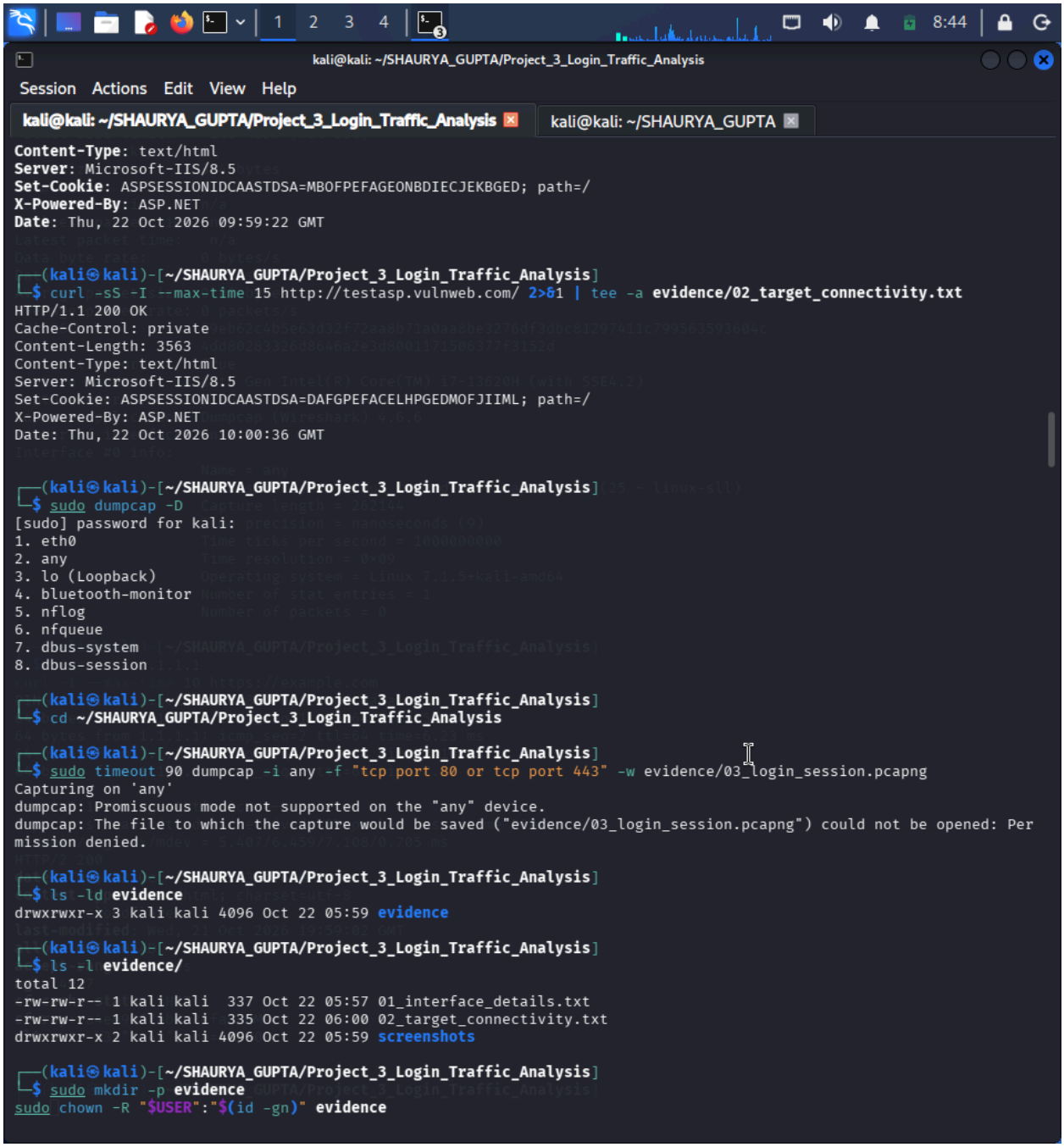

kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
Session Actions Edit View Help
kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
kali@kali: ~/SHAURYA_GUPTA
Encapsulation = Ethernet (1 - ether)
Capture length = 262144
Time precision = nanoseconds (9)
Time ticks per second = 1000000000
Time resolution = 0×09
Operating system = Linux 7.1.5+kali-amd64
Number of stat entries = 1
Number of packets = 44
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo capinfos /tmp/interface_test.pcapng
File name: /tmp/interface_test.pcapng
File type: Wireshark/... - pcapng
File encapsulation: Ethernet
File timestamp precision: nanoseconds (9)
Packet size limit: file hdr: (not set)
Number of packets: 44
File size: 13 kB
Data size: 11 kB
Capture duration: 5.028511672 seconds
Earliest packet time: 2026-10-22 08:39:13.466532477
Latest packet time: 2026-10-22 08:39:18.495044149
Data byte rate: 2,262 bytes/s
Data bit rate: 18 kbps
Average packet size: 258.61 bytes
Average packet rate: 8 packets/s
SHA256: 5517c234a11588d3c7bd4e2f2d48e109005739c4b024a13f8da2d5be0d5535ed
SHA1: 133c2c603cd43b91fa1ed620c6e35b98bc10386a
Strict time order: True
Capture hardware: 13th Gen Intel(R) Core(TM) i7-13620H (with SSE4.2)
Capture oper-sys: Linux 7.1.5+kali-amd64
Capture application: Dumpcap (Wireshark) 4.6.6
Number of interfaces in file: 1
Interface #0 info:
Name = eth0
Encapsulation = Ethernet (1 - ether)
Capture length = 262144
Time precision = nanoseconds (9)
Time ticks per second = 1000000000
Time resolution = 0×09
Operating system = Linux 7.1.5+kali-amd64
Number of stat entries = 1
Number of packets = 44
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo dumpcap -D
ip -br addr
ip route
1. eth0
2. any
3. lo (Loopback)
4. bluetooth-monitor
5. nflog
6. nfqueue
7. dbus-system

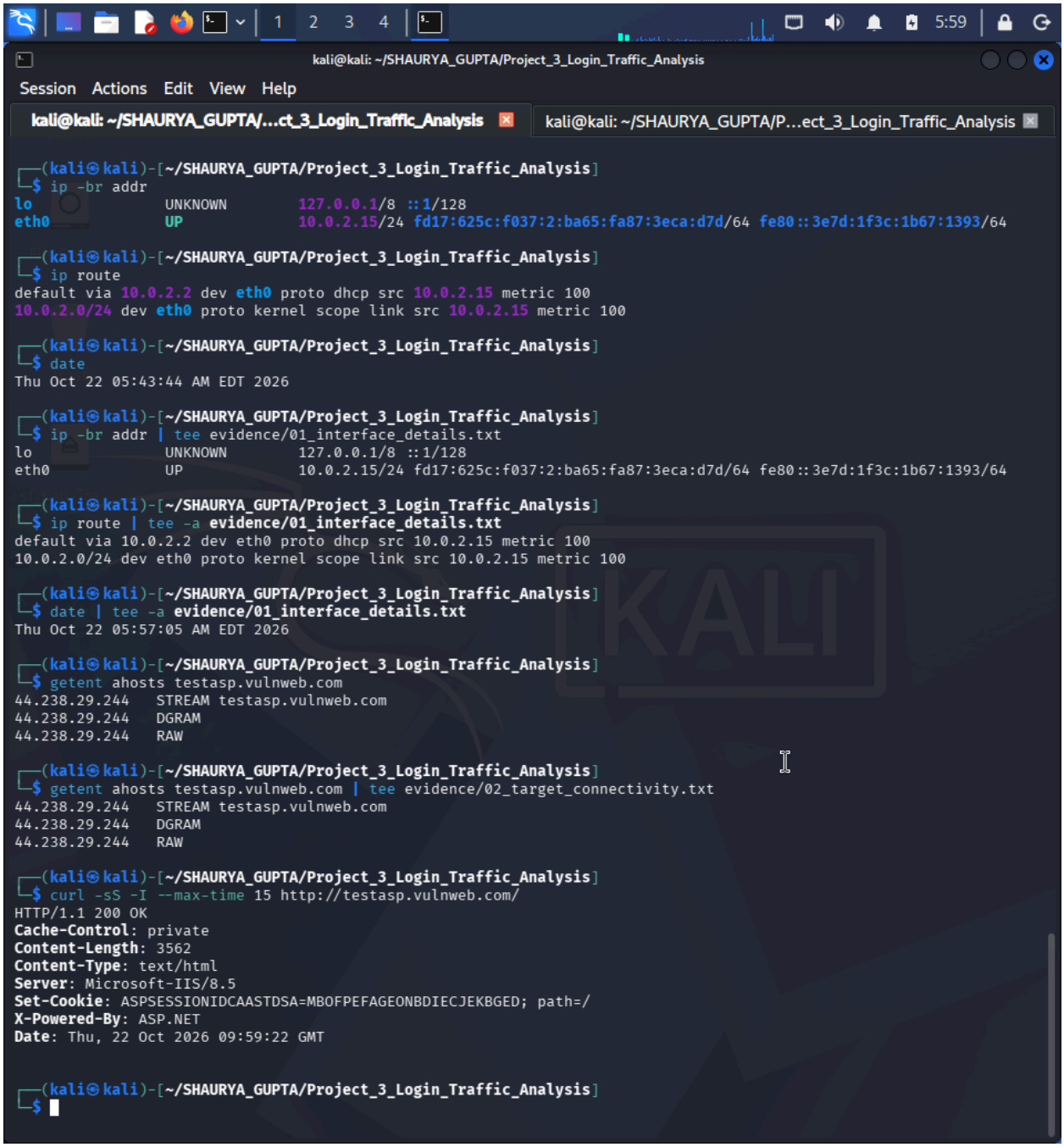

kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
Session Actions Edit View Help
kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
kali@kali: ~/SHAURYA_GUPTA
Number of stat entries = 1
Number of packets = 0
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo dumpcap -D
[sudo] password for kali:
1. eth0
2. any
3. lo (Loopback)
4. bluetooth-monitor
5. nflog
6. nfqueue
7. dbus-system
8. dbus-session
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ ip -br addr
lo UNKNOWN 127.0.0.1/8 ::1/128
eth0 UP 10.0.2.15/24 fd17:625c:f037:2:ba65:fa87:3eca:d7d/64 fe80::3e7d:1f3c:1b67:1393/64
default via 10.0.2.2 dev eth0 proto dhcp src 10.0.2.15 metric 100
10.0.2.0/24 dev eth0 proto kernel scope link src 10.0.2.15 metric 100
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo timeout 20 dumpcap -i eth0 -p \
-w /tmp/interface_test.pcapng
Capturing on 'eth0'
File: /tmp/interface_test.pcapng
Packets captured: 44
Packets received/dropped on interface 'eth0': 44/0 (pcap:0/dumpcap:0/flushed:0/ps_ifdrop:0) (100.0%)
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo capinfos /tmp/interface_test.pcapng
File name: /tmp/interface_test.pcapng
File type: Wireshark/... - pcapng
File encapsulation: Ethernet
File timestamp precision: nanoseconds (9)
Packet size limit: file hdr: (not set)
Number of packets: 44
File size: 13 kB
Data size: 11 kB
Capture duration: 5.028511672 seconds
Earliest packet time: 2026-10-22 08:39:13.466532477
Latest packet time: 2026-10-22 08:39:18.495044149
Data byte rate: 2,262 bytes/s
Data bit rate: 18 kbps
Average packet size: 258.61 bytes
Average packet rate: 8 packets/s
SHA256: 5517c234a11588d3c7bd4e2f2d48e109005739c4b024a13f8da2d5be0d5535ed
SHA1: 133c2c603cd43b91fa1ed620c6e35b98bc10386a
Strict time order: True
Capture hardware: 13th Gen Intel(R) Core(TM) i7-13620H (with SSE4.2)
Capture oper-sys: Linux 7.1.5+kali-amd64
Capture application: Dumpcap (Wireshark) 4.6.6
Number of interfaces in file: 1


kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
Session Actions Edit View Help
kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
kali@kali: ~/SHAURYA_GUPTA
/dev/sda1 79G 22G 53G 29% /
Filesystem Inodes IUsed IFree IUse% Mounted on
/dev/sda1 5251072 515961 4735111 10% /
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo timeout 10 dumpcap -i any -p \
-f "tcp port 80 or tcp port 443" \
-w /tmp/login_test.pcapng
Capturing on 'any'
File: /tmp/login_test.pcapng
Packets captured: 0
Packets received/dropped on interface 'any': 0/0 (pcap:0/dumpcap:0/flushed:0/ps_ifdrop:0) (0.0%)
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ ls -lh /tmp/login_test.pcapng
capinfos /tmp/login_test.pcapng
-rw------- 1 root root 356 Oct 22 07:10 /tmp/login_test.pcapng
capinfos: You don't have permission to read the file "/tmp/login_test.pcapng".
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ findmnt -T "$HOME/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis/evidence"
TARGET SOURCE FSTYPE OPTIONS
/ /dev/sda1 ext4 rw,relatime,errors=remount-ro
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo capinfos /tmp/login_test.pcapng
File name: /tmp/login_test.pcapng
File type: Wireshark/... - pcapng
File encapsulation: Linux cooked-mode capture v1
File timestamp precision: nanoseconds (9)
Packet size limit: file hdr: (not set)
Number of packets: 0
File size: 356 bytes
Data size: 0 bytes
Capture duration: n/a
Earliest packet time: n/a
Latest packet time: n/a
Data byte rate: 0 bytes/s
Data bit rate: 0 bits/s
Average packet size: 0.00 bytes
Average packet rate: 0 packets/s
SHA256: 6673202813e376b3d3cf9138da45014a5fa2d812a41dfd34e4e470edd2a5ed5e
SHA1: b81d9335e5b761565a124550f954e6759bb7b752
Strict time order: True
Capture hardware: 13th Gen Intel(R) Core(TM) i7-13620H (with SSE4.2)
Capture oper-sys: Linux 7.1.5+kali-amd64
Capture application: Dumpcap (Wireshark) 4.6.6
Number of interfaces in file: 1
Interface #0 info:
Name = any
Encapsulation = Linux cooked-mode capture v1 (25 - linux-sll)
Capture length = 262144
Time precision = nanoseconds (9)
Time ticks per second = 1000000000
Time resolution = 0x09


kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
Session Actions Edit View Help
kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
kali@kali: ~/SHAURYA_GUPTA
ls -ld .
ls -ld evidence
ls -l evidence/
namei -l "$PWD/evidence/03_login_session.pcapng"
kali
uid=1000(kali) gid=1000(kali) groups=1000(kali),4(adm),20(dialout),24(cdrom),25(floppy),27(sudo),29(audio),30(dip),44(video),46(plugdev),100(users),101(netdev),102(scanner),118(wireshark),119(kaboxer),968(vboxsf),982(bluetooth),999(lpadmin)
/home/kali/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
drwxrwxr-x 5 kali kali 4096 Oct 22 05:35 .
drwxr-xr-x 3 kali kali 4096 Oct 22 07:00 evidence
total 12
-rw-rw-r-- 1 kali kali 337 Oct 22 05:57 01_interface_details.txt
-rw-rw-r-- 1 kali kali 335 Oct 22 06:00 02_target_connectivity.txt
drwxrwxr-x 2 kali kali 4096 Oct 22 05:59 screenshots
f: /home/kali/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis/evidence/03_login_session.pcapng
drwxr-xr-x root root /
drwxr-xr-x root root home
drwx------ kali kali kali
drwxrwxr-x kali kali SHAURYA_GUPTA
drwxrwxr-x kali kali Project_3_Login_Traffic_Analysis
drwxr-xr-x kali kali evidence
03_login_session.pcapng - No such file or directory
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
$ cd ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
echo "=== Filesystem ==="
findmnt -T "$PWD/evidence"
echo "=== dumpcap location and permissions ==="
command -v dumpcap
ls -l "$(command -v dumpcap)"
getcap "$(command -v dumpcap)" 2>/dev/null
echo "=== Can root create a file here? ==="
sudo touch evidence/root_permission_test.txt
sudo ls -l evidence/root_permission_test.txt
sudo rm -f evidence/root_permission_test.txt
echo "=== Filesystem space ==="
df -h "$PWD/evidence"
df -i "$PWD/evidence"
=== Filesystem ===
TARGET SOURCE FSTYPE OPTIONS
/ /dev/sda1 ext4 rw,relatime,errors=remount-ro
=== dumpcap location and permissions ===
/usr/bin/dumpcap
-rwxr-xr-- 1 root wireshark 277184 May 20 12:44 /usr/bin/dumpcap
/usr/bin/dumpcap cap_net_admin,cap_net_raw=eip
=== Can root create a file here? ===
-rw-r--r-- 1 root root 0 Oct 22 07:09 evidence/root_permission_test.txt
=== Filesystem space ===
Filesystem Size Used Avail Use% Mounted on
/dev/sda1 79G 22G 53G 29% /


kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
Session Actions Edit View Help
kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
kali@kali: ~/SHAURYA_GUPTA
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo mkdir -p evidence
sudo chown -R "$USER":"$(id -gn)" evidence
chmod u+rwx evidence
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo timeout 90 dumpcap -i any -p \
-f "tcp port 80 or tcp port 443" \
-w "$PWD/evidence/03_login_session.pcapng"
Capturing on 'any'
dumpcap: The file to which the capture would be saved ("/home/kali/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis/evidence/03_login_session.pcapng") could not be opened: Permission denied.
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ cd ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
ls -ld evidence
ls -l evidence/03_login_session.pcapng
drwxrwxr-x 3 kali kali 4096 Oct 22 05:59 evidence
ls: cannot access 'evidence/03_login_session.pcapng': No such file or directory
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo mkdir -p evidence
sudo chown -R kali:kali evidence
sudo chmod 755 evidence
[sudo] password for kali:
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ touch evidence/permission_test.txt
ls -l evidence/permission_test.txt
rm evidence/permission_test.txt
-rw-rw-r-- 1 kali kali 0 Oct 22 07:00 evidence/permission_test.txt
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo rm -f evidence/03_login_session.pcapng
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo timeout 90 dumpcap -i any -p \
-f "tcp port 80 or tcp port 443" \
-w "$PWD/evidence/03_login_session.pcapng"
Capturing on 'any'
dumpcap: The file to which the capture would be saved ("/home/kali/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis/evidence/03_login_session.pcapng") could not be opened: Permission denied.
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ ls -lh evidence/03_login_session.pcapng
capinfos evidence/03_login_session.pcapng
ls: cannot access 'evidence/03_login_session.pcapng': No such file or directory
capinfos: The file "evidence/03_login_session.pcapng" doesn't exist.
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ whoami
id
pwd
ls -ld .


kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
Session Actions Edit View Help
kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
kali@kali: ~/SHAURYA_GUPTA
Content-Type: text/html
Server: Microsoft-IIS/8.5
Set-Cookie: ASPSESSIONIDCAASTDSA=MBOFPEFAGEONBDIECJEKBGED; path=/
X-Powered-By: ASP.NET
Date: Thu, 22 Oct 2026 09:59:22 GMT
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ curl -sS -I --max-time 15 http://testasp.vulnweb.com/ 2>&1 | tee -a evidence/02_target_connectivity.txt
HTTP/1.1 200 OK
Cache-Control: private
Content-Length: 3563
Content-Type: text/html
Server: Microsoft-IIS/8.5
Set-Cookie: ASPSESSIONIDCAASTDSA=DAFGPEFACELHPGEDMOFJIIML; path=/
X-Powered-By: ASP.NET
Date: Thu, 22 Oct 2026 10:00:36 GMT
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo dumpcap -D
[sudo] password for kali:
1. eth0
2. any
3. lo (Loopback)
4. bluetooth-monitor
5. nflog
6. nfqueue
7. dbus-system
8. dbus-session
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ cd ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo timeout 90 dumpcap -i any -f "tcp port 80 or tcp port 443" -w evidence/03_login_session.pcapng
Capturing on 'any'
dumpcap: Promiscuous mode not supported on the "any" device.
dumpcap: The file to which the capture would be saved ("evidence/03_login_session.pcapng") could not be opened: Per
mission denied.
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ ls -ld evidence
drwxrwxr-x 3 kali kali 4096 Oct 22 05:59 evidence
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ ls -l evidence/
total 12
-rw-rw-r-- 1 kali kali 337 Oct 22 05:57 01_interface_details.txt
-rw-rw-r-- 1 kali kali 335 Oct 22 06:00 02_target_connectivity.txt
drwxrwxr-x 2 kali kali 4096 Oct 22 05:59 screenshots
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ sudo mkdir -p evidence
sudo chown -R "$USER":"$(id -gn)" evidence

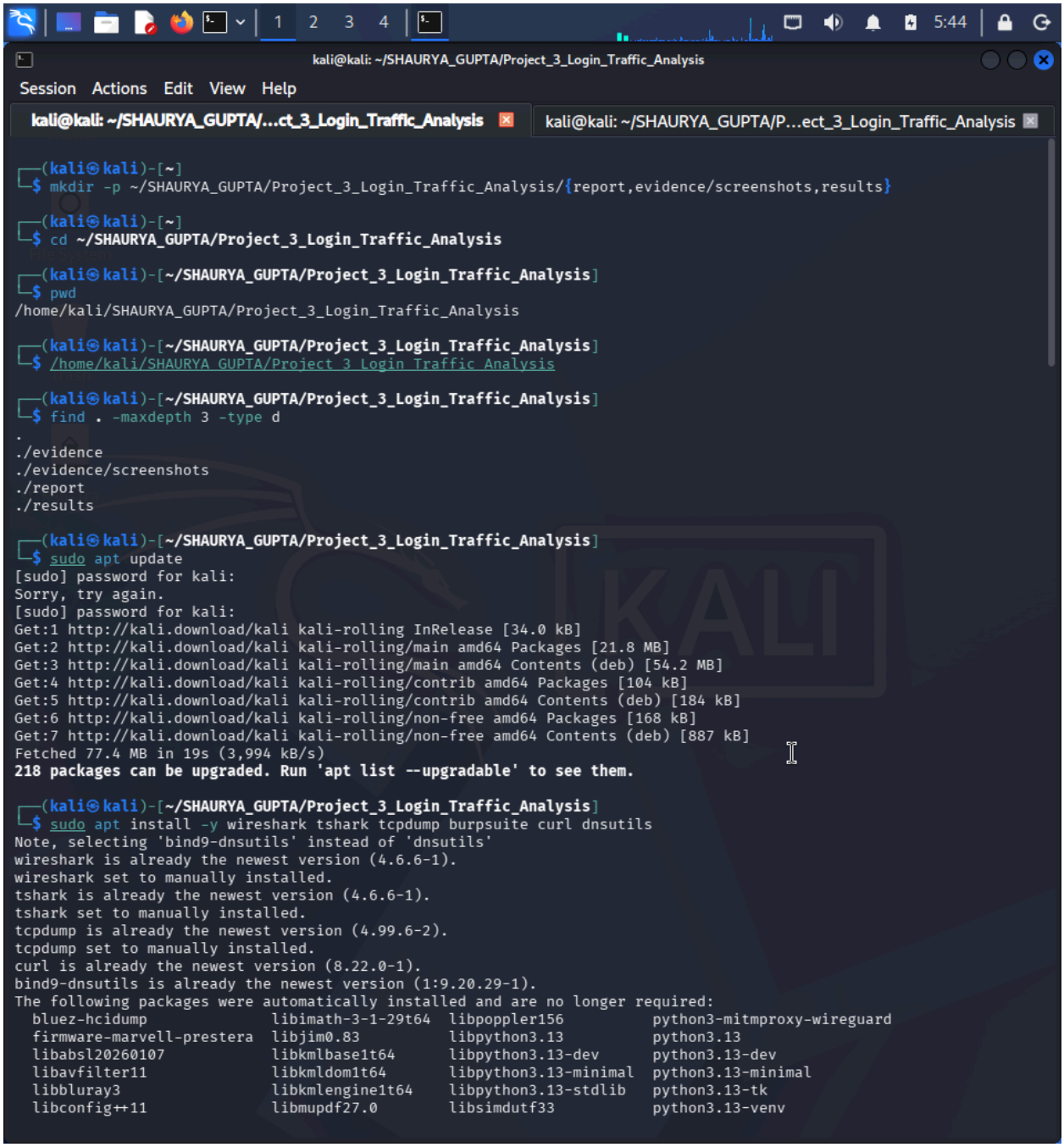

kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
Session Actions Edit View Help
kali@kali: ~/SHAURYA_GUPTA/...ct_3_Login_Traffic_Analysis
kali@kali: ~/SHAURYA_GUPTA/P...ect_3_Login_Traffic_Analysis
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
$ ip -br addr
lo UNKNOWN 127.0.0.1/8 ::1/128
eth0 UP 10.0.2.15/24 fd17:625c:f037:2:ba65:fa87:3eca:d7d/64 fe80::3e7d:1f3c:1b67:1393/64
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
$ ip route
default via 10.0.2.2 dev eth0 proto dhcp src 10.0.2.15 metric 100
10.0.2.0/24 dev eth0 proto kernel scope link src 10.0.2.15 metric 100
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
$ date
Thu Oct 22 05:43:44 AM EDT 2026
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
$ ip -br addr | tee evidence/01_interface_details.txt
lo UNKNOWN 127.0.0.1/8 ::1/128
eth0 UP 10.0.2.15/24 fd17:625c:f037:2:ba65:fa87:3eca:d7d/64 fe80::3e7d:1f3c:1b67:1393/64
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
$ ip route | tee -a evidence/01_interface_details.txt
default via 10.0.2.2 dev eth0 proto dhcp src 10.0.2.15 metric 100
10.0.2.0/24 dev eth0 proto kernel scope link src 10.0.2.15 metric 100
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
$ date | tee -a evidence/01_interface_details.txt
Thu Oct 22 05:57:05 AM EDT 2026
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
$ getent ahosts testasp.vulnweb.com
44.238.29.244 STREAM testasp.vulnweb.com
44.238.29.244 DGRAM
44.238.29.244 RAW
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
$ getent ahosts testasp.vulnweb.com | tee evidence/02_target_connectivity.txt
44.238.29.244 STREAM testasp.vulnweb.com
44.238.29.244 DGRAM
44.238.29.244 RAW
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
$ curl -sS -I --max-time 15 http://testasp.vulnweb.com/
HTTP/1.1 200 OK
Cache-Control: private
Content-Length: 3562
Content-Type: text/html
Server: Microsoft-IIS/8.5
Set-Cookie: ASPSESSIONIDCAASTDSA=MBOFPEFAGEONBDIECJEKBGED; path=/
X-Powered-By: ASP.NET
Date: Thu, 22 Oct 2026 09:59:22 GMT
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
$

kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
Session Actions Edit View Help
kali@kali: ~/SHAURYA_GUPTA/...ct_3_Login_Traffic_Analysis
kali@kali: ~/SHAURYA_GUPTA/P...ect_3_Login_Traffic_Analysis
OpenSSL 3.6.4 25 Aug 2026
64-bit build, 64-bit time_t
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ burpsuite --help
[warning] /usr/bin/burpsuite: No JAVA_CMD set for run_java, falling back to JAVA_CMD = java
Usage:
--help Print this message
--version Print version details
--disable-extensions Prevent loading of extensions on startup
--diagnostics Print diagnostic information
--use-defaults Start with default settings
--collaborator-server Run in Collaborator server mode
--collaborator-config Specify Collaborator server configuration file; defaults to collaborator.config
--data-dir Specify data directory
--project-file Open the specified project file; this will be created as a new project if the file does not exist
--developer-extension-class-name Fully qualified name of locally-developed extension class; extension will be loaded from the classpath
--config-file Load the specified project configuration file(s); this option may be repeated to load multiple files
--user-config-file Load the specified user configuration file(s); this option may be repeated to load multiple files
--auto-repair Automatically repair a corrupted project file specified by the --project-file option
--unpause-spider-and-scanner Do not pause the Spider and Scanner when opening an existing project
--disable-auto-update Suppress auto update behavior
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ ip -br addr
lo UNKNOWN 127.0.0.1/8 ::1/128
eth0 UP 10.0.2.15/24 fd17:625c:f037:2:ba65:fa87:3eca:d7d/64 fe80::3e7d:1f3c:1b67:1393/64
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ ip route
default via 10.0.2.2 dev eth0 proto dhcp src 10.0.2.15 metric 100
10.0.2.0/24 dev eth0 proto kernel scope link src 10.0.2.15 metric 100
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ date
Thu Oct 22 05:43:44 AM EDT 2026
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ ip -br addr | tee evidence/01_interface_details.txt
lo UNKNOWN 127.0.0.1/8 ::1/128
eth0 UP 10.0.2.15/24 fd17:625c:f037:2:ba65:fa87:3eca:d7d/64 fe80::3e7d:1f3c:1b67:1393/64
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ ip route | tee -a evidence/01_interface_details.txt
default via 10.0.2.2 dev eth0 proto dhcp src 10.0.2.15 metric 100
10.0.2.0/24 dev eth0 proto kernel scope link src 10.0.2.15 metric 100
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ ip -br addr | tee evidence/01_interface_details.txt

kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
Session Actions Edit View Help
kali@kali: ~/SHAURYA_GUPTA/...ct_3_Login_Traffic_Analysis
kali@kali: ~/SHAURYA_GUPTA/P...ect_3_Login_Traffic_Analysis
+Lua 5.4.8 +Zstandard 1.5.7
+LZ4 1.10.0
Without:
-zlib-ng
Runtime info:
OS: Linux 7.1.5+kali-amd64
CPU: 13th Gen Intel(R) Core(TM) i7-13620H (with SSE4.2)
Memory: 3916 MB of physical memory
GLib: 2.90.0
Locale: LC_TYPE=en_US.UTF-8
Plugins: supported, 0 loaded
With:
+brotli 1.2.0
+c-ares 1.34.8
+Gcrypt 1.12.4
+GnuTLS 3.8.13
+libpcap 1.10.7 (64-bit time_t, with TPACKET_V3)
+libsmi 0.4.8
+LZ4 1.10.0
+nghttp2 1.70.0
+nghttp3 1.17.0
+PCRE2 10.48 2026-08-31
+xxhash 803
+zlib 1.3.2
+Zstandard 1.5.7
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
$ tcpdump --version
tcpdump version 4.99.6
libpcap version 1.10.7 (64-bit time_t, with TPACKET_V3)
OpenSSL 3.6.4 25 Aug 2026
64-bit build, 64-bit time_t
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
$ burpsuite --help
[warning] /usr/bin/burpsuite: No JAVA_CMD set for run_java, falling back to JAVA_CMD = java
Usage:
--help Print this message
--version Print version details
--disable-extensions Prevent loading of extensions on startup
--diagnostics Print diagnostic information
--use-defaults Start with default settings
--collaborator-server Run in Collaborator server mode
--collaborator-config Specify Collaborator server configuration file; defaults to collaborator.config
--data-dir Specify data directory
--project-file Open the specified project file; this will be created as a new project if the file does not exist
--developer-extension-class-name Fully qualified name of locally-developed extension class; extension will be loaded from the classpath
--config-file Load the specified project configuration file(s); this option may be repeated to load multiple files
--user-config-file Load the specified user configuration file(s); this option may be repeated to load multiple files
--auto-repair Automatically repair a corrupted project file specified by the --project-file opt

kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
Session Actions Edit View Help
kali@kali: ~/SHAURYA_GUPTA/...ct_3_Login_Traffic_Analysis
kali@kali: ~/SHAURYA_GUPTA/P...ect_3_Login_Traffic_Analysis
+libsmi 0.4.8 +QtMultimedia
+libxml2 2.15.2 +Snappy 1.2.2
+Lua 5.4.8 +xxhash 0.8.3
+LZ4 1.10.0 +zlib 1.3.2
+MaxMind +Zstandard 1.5.7
+Minizip 1.3.2
Without:
-automatic updates -zlib-ng
Runtime info:
OS: Linux 7.1.5+kali-amd64
CPU: 13th Gen Intel(R) Core(TM) i7-13620H (with SSE4.2)
Memory: 3916 MB of physical memory
GLib: 2.90.0
Locale: LC_TYPE=en_US.UTF-8
Plugins: supported, 0 loaded
With:
+brotli 1.2.0
+c-ares 1.34.8
+Gcrypt 1.12.4
+GnuTLS 3.8.13
+libpcap 1.10.7 (64-bit time_t, with TPACKET_V3)
+libsmi 0.4.8
+LZ4 1.10.0
+nghttp2 1.70.0
+nghttp3 1.17.0
+PCRE2 10.48 2026-08-31
+Qt 6.10.2
+xxhash 803
+zlib 1.3.2
+Zstandard 1.5.7
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
$ tshark --version
TShark (Wireshark) 4.6.6.
Copyright 1998-2026 Gerald Combs <gerald@wireshark.org> and contributors.
Licensed under the terms of the GNU General Public License (version 2 or later).
This is free software; see the file named COPYING in the distribution. There is
NO WARRANTY; not even for MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE.
Compile-time info:
Bit width: 64-bit
Compiler: GCC 15.2.0
GLib: 2.88.1
With:
+brotli +MaxMind
+Gcrypt 1.12.2 +nghttp2 1.69.0
+GnuTLS 3.8.13 and PKCS#11 +nghttp3 1.15.0
+Kerberos (MIT) +PCRE2 10.46 2025-08-27
+libnl 3 +POSIX capabilities (Linux)
+libpcap +Snappy 1.2.2
+libsmi 0.4.8 +xxhash 0.8.3
+libxml2 2.15.2 +zlib 1.3.2
+Lua 5.4.8 +Zstandard 1.5.7

kali@kali: ~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis
Session Actions Edit View Help
kali@kali: ~/SHAURYA_GUPTA/...ct_3_Login_Traffic_Analysis
kali@kali: ~/SHAURYA_GUPTA/P...ect_3_Login_Traffic_Analysis
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ wireshark --version
Wireshark 4.6.6.
Copyright 1998-2026 Gerald Combs <gerald@wireshark.org> and contributors.
Licensed under the terms of the GNU General Public License (version 2 or later).
This is free software; see the file named COPYING in the distribution. There is
NO WARRANTY; not even for MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE.
Compile-time info:
Bit width: 64-bit
Compiler: GCC 15.2.0
GLib: 2.88.1
With:
+brotli +nghttp2 1.69.0
+Gcrypt 1.12.2 +nghttp3 1.15.0
+GnuTLS 3.8.13 and PKCS#11 +PCRE2 10.46 2025-08-27
+Kerberos (MIT) +POSIX capabilities (Linux)
+libnl 3 +Qt 6.10.2
+libpcap +QtDBus
+libsmi 0.4.8 +QtMultimedia
+libxml2 2.15.2 +Snappy 1.2.2
+Lua 5.4.8 +xxhash 0.8.3
+LZ4 1.10.0 +zlib 1.3.2
+MaxMind +Zstandard 1.5.7
+Minizip 1.3.2
Without:
-automatic updates -zlib-ng
Runtime info:
OS: Linux 7.1.5+kali-amd64
CPU: 13th Gen Intel(R) Core(TM) i7-13620H (with SSE4.2)
Memory: 3916 MB of physical memory
GLib: 2.90.0
Locale: LC_TYPE=en_US.UTF-8
Plugins: supported, 0 loaded
With:
+brotli 1.2.0
+c-ares 1.34.8
+Gcrypt 1.12.4
+GnuTLS 3.8.13
+libpcap 1.10.7 (64-bit time_t, with TPACKET_V3)
+libsmi 0.4.8
+LZ4 1.10.0
+nghttp2 1.70.0
+nghttp3 1.17.0
+PCRE2 10.48 2026-08-31
+Qt 6.10.2
+xxhash 803
+zlib 1.3.2
+Zstandard 1.5.7
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_3_Login_Traffic_Analysis]
└─$ tshark --version



BASIC WEB VULNERABILITY ASSESSMENT

Internship Details

Name: Shaurya Gupta

Email: shauryagupta0106@gmail.com

Reference Number: CSN-OC-OL-26194

Registration Number: CSN-OC-2026-194

Domain: Cyber Security

Project Level: Beginner

Project Number: Project 4

Internship Month/Year: October 2026

Table of Contents

1. Introduction
2. Objectives
3. Scope and Authorization
4. Tools and Environment
5. Assessment Methodology
6. Implementation Details
7. Findings and Severity Classification
8. Risk and Impact Analysis
9. Mitigation Recommendations
10. Limitations
11. Summary and Conclusion
12. References
13. Appendix: Commands and Evidence

---

1. Introduction

A Basic Web Vulnerability Assessment is a preliminary security assessment performed to identify potentially unsafe configurations, information disclosures, and other weaknesses in a web application. It helps developers and security testers identify issues that should be investigated and addressed before an application is deployed in a production environment.

Web applications communicate with clients through HTTP requests and responses. Security-related response headers, access controls, exposed files, and publicly accessible application paths can influence the security of an application. Reviewing these elements can

help identify weaknesses that may increase the risk of unauthorized access, information disclosure, or other attacks.

For this project, OWASP Juice Shop was deployed as a local training application in Docker on Kali Linux. The application was assessed using HTTP inspection with curl and automated scanning with Nikto. Burp Suite Community Edition was launched as part of the assessment workflow, but successful traffic interception was not confirmed in the available evidence.

The assessment identified missing recommended HTTP security headers, a publicly accessible robots.txt resource that disclosed a path for further investigation, and several additional paths flagged by Nikto that require manual verification.

The purpose of this report is to document the observed evidence, explain the potential security implications, and recommend practical mitigation measures without claiming that an unverified vulnerability was successfully exploited.

2. Objectives

The objectives of this project were:

- To deploy a local web application for authorized security testing.
- To inspect HTTP responses and identify the security headers returned by the application.
- To use Nikto to conduct a basic automated web server assessment.
- To inspect selected application endpoints using curl.
- To launch Burp Suite Community Edition and attempt to include proxy-based HTTP inspection in the assessment workflow.
- To distinguish confirmed observations from potential vulnerabilities and informational results.
- To classify findings according to their observed evidence and realistic impact.
- To document recommendations that can improve the application's security.
- To maintain an evidence-based assessment report suitable for a beginner-level cybersecurity internship project.

3. Scope and Authorization

Target: http://127.0.0.1:3000/

Application: OWASP Juice Shop

Environment: Local Kali Linux instance running OWASP Juice Shop in a Docker container.

Assessment period: 22 October 2026 to 23 October 2026. The main Nikto scan was recorded on 22 October 2026, followed by additional HTTP header inspection on 23 October 2026.

Authorization: Testing was restricted to the local OWASP Juice Shop training instance operated for this project.

Included activities

- Installing and checking the required assessment tools.
- Starting Docker and deploying OWASP Juice Shop locally.
- Confirming that the application responded over HTTP.
- Inspecting the homepage response headers.
- Saving the homepage response and HTTP header evidence.
- Running Nikto against the local target.
- Reviewing Nikto findings for missing headers, interesting paths, and possible information disclosure.
- Checking the HTTP responses from `/`, `/robots.txt`, and `/.well-known/security.txt`.
- Launching Burp Suite Community Edition to attempt proxy-based inspection.
- Documenting confirmed observations and potential issues.

Excluded activities

- Denial-of-service testing.
- Destructive testing.
- Testing systems outside the authorized local environment.
- Exploitation of real user accounts or production data.
- Password attacks or credential theft.
- Claims of successful exploitation without supporting evidence.
- Testing of endpoints on external systems not included in the project scope.

4. Tools and Environment

The following tools and environment details were recorded in the supplied terminal output.

Tool or component	Recorded version or configuration
Operating system	Kali Linux; exact release version not recorded
Web application	OWASP Juice Shop
Deployment	Docker container
Docker	28.5.2+dfsg4-5
Nikto	2.6.1

Tool or component	Recorded version or configuration
curl	8.22.0
Burp Suite	2026.9
Browser	Mozilla Firefox 153.4.0esr
Target address	`http://127.0.0.1:3000/`
Target port	TCP 3000
Docker container name	`juice-shop`
Docker image	`bkimminich/juice-shop:latest`

Tool purposes

Kali Linux: Provided the environment for executing the assessment commands and running the security tools.

Docker: Hosted the OWASP Juice Shop application locally. The recorded port mapping was `127.0.0.1:3000->3000/tcp`, restricting the published application port to the local loopback interface.

curl: Sent HTTP requests and recorded response headers and status codes for the target endpoints.

Nikto: Performed automated web server checks and identified missing recommended security headers and potentially interesting paths.

Burp Suite Community Edition: Was launched for proxy-based HTTP inspection. The available terminal evidence does not confirm that requests were successfully captured in HTTP history.

Firefox ESR: Was launched to open the local OWASP Juice Shop application.

5. Assessment Methodology

The assessment followed a basic, non-destructive workflow.

Step 1: Prepare the assessment environment

A project directory was created with separate folders for reports, screenshots, and results. Required tools were checked or installed through the Kali Linux package manager.

Step 2: Deploy the target application

Docker was enabled and started. The OWASP Juice Shop image was downloaded, and a container named `juice-shop` was started with port 3000 published on `127.0.0.1`.

The container status was checked using `sudo docker ps`.

Step 3: Confirm application availability

The command `curl -I http://127.0.0.1:3000/` was executed. The target returned `HTTP/1.1 200 OK`, confirming that the homepage was responding.

Step 4: Capture HTTP response evidence

The homepage response headers were saved to `results/response-headers.txt`, and the homepage body was saved to `results/homepage.html`.

Additional HTTP checks were conducted against:

- `/`
- `/robots.txt`
- `/.well-known/security.txt`

The outputs were saved in `results/http-checks.txt`.

Step 5: Run automated scanning

Nikto 2.6.1 was executed against the local target. Its output was saved to `results/nikto.txt` and copied to `results/nikto-scan-evidence.txt`.

The scan reported missing recommended headers, an entry in `robots.txt` pointing to `/ftp/`, and several paths that it considered potentially interesting.

Step 6: Review and classify findings

The response headers and Nikto output were reviewed to distinguish direct observations from scanner-generated alerts. Findings were classified as confirmed, potential, or informational according to the evidence available.

Step 7: Attempt proxy inspection

Burp Suite was launched twice. The recorded terminal output contains startup warnings and subsequent interruption, but no evidence that HTTP requests were successfully captured or analyzed through Burp Suite.

Therefore, Burp-based verification is recorded as incomplete.

Step 8: Prepare the report

The findings, evidence, limitations, and recommendations were documented in this report. No exploitation or data compromise is claimed.

6. Implementation Details

6.1 Project setup

The following project directory was created:

```
/home/kali/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment
```

It contained the following directories:

- `report/`
- `screenshots/`
- `results/`

A terminal session was also recorded in `commands.txt`.

6.2 Application deployment

The Docker service was started and enabled. The OWASP Juice Shop image was downloaded and launched using the following command:

```
sudo docker run -d --name juice-shop -p 127.0.0.1:3000:3000
bkimminich/juice-shop
```

The container was confirmed to be running using `sudo docker ps`.

The application was accessible at `http://127.0.0.1:3000/`.

6.3 HTTP header inspection

The homepage headers were inspected with:

```
curl -I http://127.0.0.1:3000/
```

The response included:

- `HTTP/1.1 200 OK`
- `Access-Control-Allow-Origin: *`
- `X-Content-Type-Options: nosniff`
- `X-Frame-Options: SAMEORIGIN`
- `Feature-Policy: payment 'self'`
- `X-Recruiting: /#/jobs`
- `Content-Type: text/html; charset=UTF-8`

The captured homepage response did not include `Content-Security-Policy`, `Permissions-Policy`, `Referrer-Policy`, or `Strict-Transport-Security`.

The full captured header output was saved to `results/response-headers.txt`.

6.4 Automated Nikto scan

The following command was executed:

```
nikto -host http://127.0.0.1:3000/ -output results/nikto.txt
```

The scan reported 8,826 requests, two errors, and 28 items. The recorded duration was approximately 115 seconds.

Notable results included:

- Missing recommended HTTP security headers.
- An entry for `/ftp/` in `robots.txt`.
- Potentially interesting paths such as `/.htpasswd`, `/.bash_history`, and several JSON filenames.
- A possible administrative-interface signature at `/JAMonAdmin.jsp`.

These results were treated as scanner findings requiring interpretation and, where applicable, manual verification. The output alone does not establish that all flagged files contain sensitive information.

6.5 Manual HTTP checks

The following command was used to inspect the homepage response headers:

```
curl -sS -D - -o /dev/null http://127.0.0.1:3000/
```

The following command checked `robots.txt`:

```
curl -sS -D - -o /dev/null http://127.0.0.1:3000/robots.txt
```

The following command checked the security contact resource:

```
curl -sS -D - -o /dev/null
http://127.0.0.1:3000/.well-known/security.txt
```

All three endpoints returned `HTTP/1.1 200 OK` in the recorded checks.

The combined output was saved in `results/http-checks.txt`.

6.6 Burp Suite

Burp Suite was launched from the terminal using:

```
burpsuite
```

Startup warnings were recorded, and the process was interrupted. A later launch was also interrupted. The supplied terminal log does not contain captured request entries or completed proxy analysis.

Burp Suite is therefore listed as an attempted tool, not as a source of verified vulnerability evidence.

6.7 Screenshot evidence

The supplied text file contains terminal logs but does not establish that screenshots were saved in the `screenshots/` directory. Screenshots should only be referenced in the final submission if the actual image files exist.

Recommended screenshots to capture before final submission are:

1. Docker container running with the local port mapping.
2. Homepage HTTP headers displayed in the terminal.
3. Nikto scan output showing the missing security headers.
4. Nikto scan output showing the `/ftp/` entry and potentially interesting paths.
5. Manual HTTP checks showing the status codes for the tested endpoints.
6. Burp Suite HTTP history, only if traffic capture is successfully completed.

7. Findings and Severity Classification

Finding F-01: Missing Recommended HTTP Security Headers

Affected endpoint: `http://127.0.0.1:3000/`

Severity: Low

Verification status: Confirmed configuration observation

Evidence:

The homepage returned `HTTP/1.1 200 OK`. The captured response included `X-Content-Type-Options: nosniff` and `X-Frame-Options: SAMEORIGIN`, but did not include the following recommended headers:

- `Content-Security-Policy`
- `Permissions-Policy`
- `Referrer-Policy`
- `Strict-Transport-Security`

Nikto independently reported these headers as missing in its scan output.

Verification method:

The response was inspected using curl, and the result was compared with the corresponding Nikto output in `results/nikto.txt`.

Impact:

Missing security headers can reduce defense-in-depth protections. A suitable Content Security Policy can help restrict permitted resource sources, while Referrer Policy can control the referrer information sent with requests. Permissions Policy can limit access to selected browser features.

The missing headers do not independently prove that a specific attack is exploitable. HSTS is relevant to HTTPS deployments and cannot be meaningfully assessed as an enforced HTTPS policy from the local HTTP response alone.

Recommended mitigation:

Configure appropriate security headers for the intended deployment. Define a Content Security Policy that is compatible with the application's functionality, select an appropriate Referrer

Policy, restrict unnecessary browser features through Permissions Policy, and configure HSTS for an HTTPS deployment.

Evidence reference: `results/response-headers.txt`, `results/http-checks.txt`, and `results/nikto.txt`.

Finding F-02: Publicly Accessible robots.txt Discloses a Path for Further Investigation

Affected endpoints:

- `http://127.0.0.1:3000/robots.txt`
- `http://127.0.0.1:3000/ftp/`

Severity: Informational

Verification status: Confirmed path disclosure; sensitive content exposure not confirmed

Evidence:

The `robots.txt` endpoint returned `HTTP/1.1 200 OK`. Nikto reported that `robots.txt` contained an entry for `/ftp/` and that the path returned a non-forbidden or redirect HTTP status of 200 during its scan.

Verification method:

The HTTP response for `/robots.txt` was checked using curl. The path disclosure was identified in the Nikto scan output. The available evidence does not include a detailed review of the content served by `/ftp/` or prove that sensitive files are exposed there.

Impact:

The `robots.txt` file can disclose paths that site owners prefer crawlers not to visit. This information may help an attacker identify areas for further reconnaissance. The file itself is not an access-control mechanism, and disclosure of a path does not establish unauthorized access to sensitive information.

Recommended mitigation:

Review the entries in `robots.txt` and remove unnecessary path disclosures where appropriate. Enforce authentication and authorization on sensitive resources, and ensure that

the `/ftp/` path does not expose backups or confidential files. Retest the path and document its actual response after applying access controls.

Evidence reference: `results/http-checks.txt` and `results/nikto.txt`.

Finding F-03: Potential Exposure of Sensitive Files and Administrative Resources

Affected paths flagged by Nikto:

- `/.psql_history`
- `/.htpasswd`
- `/.bash_history`
- `/.mysql_history`
- `/.sh_history`
- `/.sqlite_history`
- `/userdata.json`
- `/login.json`
- `/master.json`
- `/masters.json`
- `/connections.json`
- `/connection.json`
- `/PasswordsData.json`
- `/users.json`
- `/conndb.json`
- `/conn.json`
- `/accounts.json`
- `/JAMonAdmin.jsp`

Severity: Medium, provisional pending manual verification

Verification status: Potential; not independently confirmed

Evidence:

Nikto reported these paths as potentially interesting. Its output included descriptions suggesting possible authorization information, shell-history exposure, database-related files, JSON resources, and a possible JAMon administrative interface.

The scan did not provide sufficient endpoint-by-endpoint response content in the supplied evidence to establish that each path exposes the resource described by the scanner.

Verification method:

The paths were identified by the automated Nikto scan saved in `results/nikto.txt`. The available evidence does not independently establish the content, sensitivity, or functionality of each flagged resource.

Manual verification is required to record each path's actual HTTP status and response content before confirming a vulnerability.

Impact:

If genuine sensitive files are accessible, they could expose credentials, account information, configuration details, database information, or shell history. An accessible administrative interface may create additional risk if it is functional and lacks appropriate access controls.

These impacts are conditional. The current evidence does not demonstrate that credentials were retrieved, sensitive records were disclosed, or an administrative interface was successfully accessed.

Recommended mitigation:

Review every flagged path individually. Remove sensitive files from the web root, deny public access to configuration and backup files, store secrets outside web-accessible directories, and protect administrative interfaces with appropriate authentication and authorization. Retest each endpoint and document the actual status code and response content.

Evidence reference: `results/nikto.txt` and `results/nikto-scan-evidence.txt`.

Informational observation: Access-Control-Allow-Origin Header

Affected endpoint: `http://127.0.0.1:3000/`

Severity: Informational

Verification status: Header presence confirmed; vulnerability not established

Evidence:

The homepage response included:

```
Access-Control-Allow-Origin: *
```

Nikto also reported the wildcard value.

Impact:

A wildcard CORS response header allows cross-origin browser access to resources where the applicable browser CORS rules permit it. The presence of this header alone does not establish a vulnerability. The actual risk depends on the resources exposed, the other CORS response headers, authentication requirements, and whether sensitive data can be accessed cross-origin.

Recommended mitigation:

Review whether cross-origin access is required. If it is not required, remove the permissive policy. If it is required, configure the policy to allow only the intended origins where appropriate and test access to sensitive endpoints.

Evidence reference: `results/response-headers.txt` and `results/nikto.txt`.

Informational observation: Uncommon X-Recruiting Header

Affected endpoint: `http://127.0.0.1:3000/`

Severity: Informational

Verification status: Confirmed header presence; vulnerability not established

Evidence:

The homepage response included:

```
X-Recruiting: /#/jobs
```

Nikto identified this as an uncommon response header.

Impact:

The header reveals a route associated with the application's jobs page. No sensitive information disclosure or exploitable weakness was established by the supplied evidence.

Recommended mitigation:

Review whether this custom header is required. Remove it if it serves no operational purpose. Its presence alone does not justify classifying the application as vulnerable.

Evidence reference: `results/response-headers.txt` and `results/nikto.txt`.

8. Risk and Impact Analysis

The assessment identified one confirmed low-severity configuration observation, one confirmed path disclosure with informational severity, and a set of potential sensitive-resource exposures requiring further investigation. Two additional informational observations were recorded.

Finding	Status	Severity	Risk interpretation
F-01: Missing recommended security headers	Confirmed observation	Low	Reduced defense in depth; no exploit demonstrated
F-02: robots.txt path disclosure	Path disclosure confirmed	Informational	May assist reconnaissance; sensitive exposure not confirmed
F-03: Potential sensitive files and administrative resources	Potential	Medium, provisional	Impact could be significant if genuine sensitive resources are accessible
I-01: Wildcard CORS header	Header confirmed	Informational	Risk depends on resource exposure and CORS behavior
I-02: X-Recruiting header	Header confirmed	Informational	No security impact established

---

The potential sensitive-resource finding should receive manual verification priority because confirmed exposure of credentials or configuration files could have a greater impact than the other observations. However, the provisional severity must not be interpreted as proof that the resources are accessible or contain sensitive information.

No successful exploitation, credential recovery, account compromise, or data exfiltration was demonstrated in the supplied evidence.

9. Mitigation Recommendations

9.1 Configure appropriate HTTP security headers

Add suitable Content Security Policy, Referrer Policy, and Permissions Policy settings. Configure HSTS when the application is served over HTTPS. Verify the resulting response headers and confirm that legitimate application functionality continues to work.

9.2 Review robots.txt and the /ftp/ path

Check whether the disclosed path is necessary. Ensure that sensitive files cannot be accessed without authorization. Test the actual contents and access behavior of `/ftp/` before concluding that a vulnerability exists.

9.3 Verify potentially exposed files and administrative paths

Manually inspect the paths flagged by Nikto. Record the HTTP status, content type, and sanitized response details for each relevant path. Remove any sensitive resources from public access and apply appropriate authentication and authorization.

9.4 Review the CORS configuration

Determine whether cross-origin access is required. If it is, document the intended origins and verify the policy against sensitive endpoints. Avoid relying on the wildcard policy without understanding its effect on the application's resources.

9.5 Review unnecessary custom response headers

Determine whether `X-Recruiting` is required. Remove unnecessary metadata where appropriate, but do not classify the header as a vulnerability without evidence of an actual security impact.

9.6 Perform a follow-up assessment

After remediation:

- Repeat the curl header checks.
- Rerun Nikto against the authorized local target.
- Verify each previously flagged path manually.
- Compare the new results with the original evidence.
- Capture screenshots of actual test results.
- Record any findings that remain unresolved.

10. Limitations

The assessment had the following limitations:

1. **Limited testing scope:** Testing was restricted to the local OWASP Juice Shop instance at `http://127.0.0.1:3000/`.

2. **Automated scanner limitations:** Nikto identifies potential issues based on response patterns and signatures. Some findings may be false positives or may require manual verification.

3. **Incomplete endpoint verification:** The supplied logs do not include detailed response bodies and endpoint-specific verification for every path flagged by Nikto.

4. **Incomplete Burp Suite inspection:** Burp Suite was launched, but the terminal evidence does not show successfully captured HTTP history or completed proxy-based testing.

5. **No exploitation testing:** No exploit was demonstrated. The report does not claim credential recovery, account compromise, or data exfiltration.

6. **No remediation retest:** The supplied evidence does not establish that the recommended fixes were applied or retested.

7. **No screenshot confirmation:** The supplied terminal log does not establish that screenshots were saved in the project screenshots directory.

8. **Environment differences:** The application was tested locally over HTTP. Its configuration and behavior may differ from a production deployment using HTTPS, reverse proxies, or additional security controls.

9. **Incomplete environment inventory:** The exact Kali Linux release version was not recorded in the supplied output.

10. **Limited CORS assessment:** The wildcard CORS header was observed, but no detailed cross-origin test was recorded to determine whether sensitive resources are exposed.

11. **Limited application coverage:** The assessment did not establish comprehensive testing of authentication, authorization, input validation, session management, or business logic.

These limitations mean the report represents a basic assessment rather than a comprehensive penetration test.

11. Summary and Conclusion

A basic web vulnerability assessment was performed against a locally hosted OWASP Juice Shop instance on Kali Linux. The application was deployed using Docker and confirmed to be reachable over HTTP. The assessment used curl for response inspection and Nikto 2.6.1 for automated scanning.

The homepage response was confirmed to be missing several recommended security headers. The `robots.txt` endpoint returned HTTP 200 and disclosed the `/ftp/` path in the Nikto results. Nikto also flagged multiple potentially sensitive file paths and a possible administrative interface, but the available evidence does not independently confirm that these resources expose sensitive information.

The assessment additionally recorded a wildcard `Access-Control-Allow-Origin` header and an uncommon `X-Recruiting` header. Neither observation was independently established as an exploitable vulnerability.

The highest verification priority is to manually check the paths flagged by Nikto and determine whether any sensitive resources are genuinely accessible. The next priority is to review and configure appropriate HTTP security headers. The CORS policy should also be reviewed against the application's actual cross-origin requirements.

Burp Suite was launched, but successful HTTP traffic capture was not established in the supplied logs. Consequently, the project should not claim completed Burp-based verification.

Overall, the project demonstrates the use of basic web assessment tools, collection of HTTP evidence, interpretation of automated scan results, and evidence-based reporting. Further manual verification and a documented retest would improve the completeness of the final assessment.

12. References

The following documentation links were present in the assessment tool output or are relevant to the reported observations.

1. PortSwigger Web Security Academy, robots.txt File Issue: https://portswigger.net/kb/issues/00600600_robots-txt-file

2. MDN Web Docs, robots.txt: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt

3. MDN Web Docs, Content Security Policy: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP

4. MDN Web Docs, Permissions-Policy: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy

5. MDN Web Docs, Referrer-Policy: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy

6. MDN Web Docs, Strict-Transport-Security: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security

7. OWASP Web Security Testing Guide: https://owasp.org/www-project-web-security-testing-guide/

8. OWASP Top 10: https://owasp.org/www-project-top-ten/

9. National Vulnerability Database, CVE-2013-6235: https://nvd.nist.gov/vuln/detail/CVE-2013-6235

Note: The supplied terminal log confirms that the relevant Nikto output was generated. It does not establish that every reference above was independently opened or reviewed during the assessment.

13. Appendix: Commands and Evidence

13.1 Project setup

```
mkdir -p ~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment/{report,screenshots,results}

cd ~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment

pwd

find . -maxdepth 2 -type d | sort

script -a commands.txt
```

13.2 Tool installation and version checks

```
sudo apt update

sudo apt install -y curl wget nikto docker.io burpsuite firefox-esr

curl --version
```

nikto -Version

docker --version

burpsuite --help

firefox --version

apt-cache policy nikto docker.io burpsuite firefox-esr

13.3 Start Docker and deploy the application

sudo systemctl enable --now docker

sudo systemctl status docker --no-pager

sudo docker pull bkimminich/juice-shop

sudo docker run -d --name juice-shop -p 127.0.0.1:3000:3000 bkimminich/juice-shop

sudo docker ps

sudo docker logs --tail 50 juice-shop

13.4 Confirm the target and capture response headers

curl -I http://127.0.0.1:3000/

curl -sS -D results/response-headers.txt \

-o results/homepage.html \

http://127.0.0.1:3000/

date -Is | tee results/assessment-time.txt

echo "Target: http://127.0.0.1:3000/" | tee results/target.txt

echo "Scope: Local OWASP Juice Shop training instance" | tee -a results/target.txt

13.5 Run Nikto

nikto -host http://127.0.0.1:3000/ -output results/nikto.txt

cat results/nikto.txt

```
wc -l results/nikto.txt

cp results/nikto.txt results/nikto-scan-evidence.txt
```

13.6 Check the homepage and selected endpoints

```
curl -sS -D - -o /dev/null http://127.0.0.1:3000/

curl -sS -D - -o /dev/null http://127.0.0.1:3000/robots.txt

curl -sS -D - -o /dev/null http://127.0.0.1:3000/.well-known/security.txt
```

13.7 Save the combined HTTP check results

```
{
  echo "=== Homepage ==="
  curl -sS -D - -o /dev/null http://127.0.0.1:3000/
  echo "=== robots.txt ==="
  curl -sS -D - -o /dev/null http://127.0.0.1:3000/robots.txt
  echo "=== security.txt ==="
  curl -sS -D - -o /dev/null http://127.0.0.1:3000/.well-known/security.txt
} | tee results/http-checks.txt
```

13.8 Launch Burp Suite

```
burpsuite
```

The supplied terminal log shows startup warnings and interruption. It does not establish successful request capture or completed HTTP history analysis.

13.9 Evidence file inventory

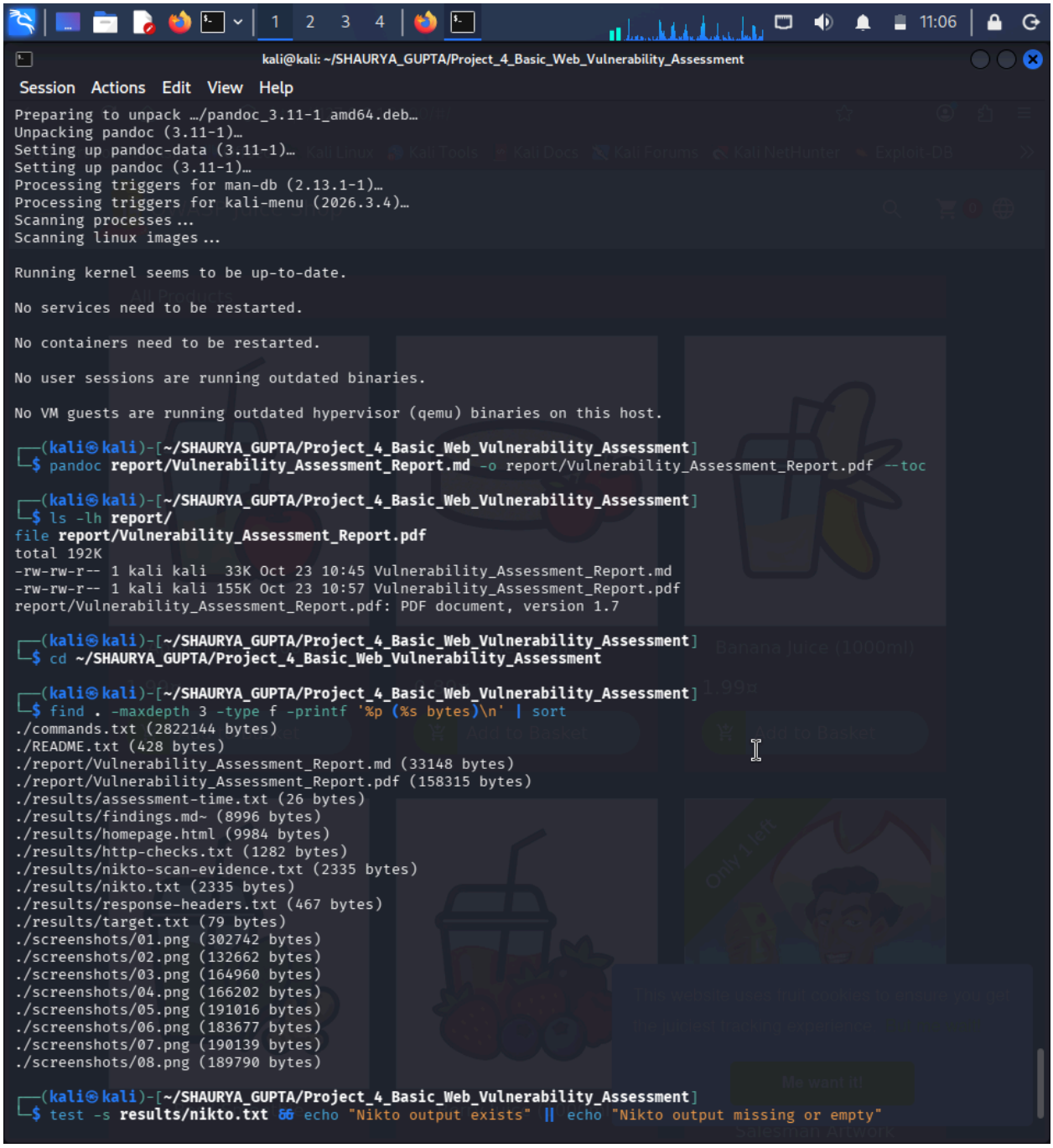
The following evidence files were explicitly created by commands shown in the supplied terminal log:

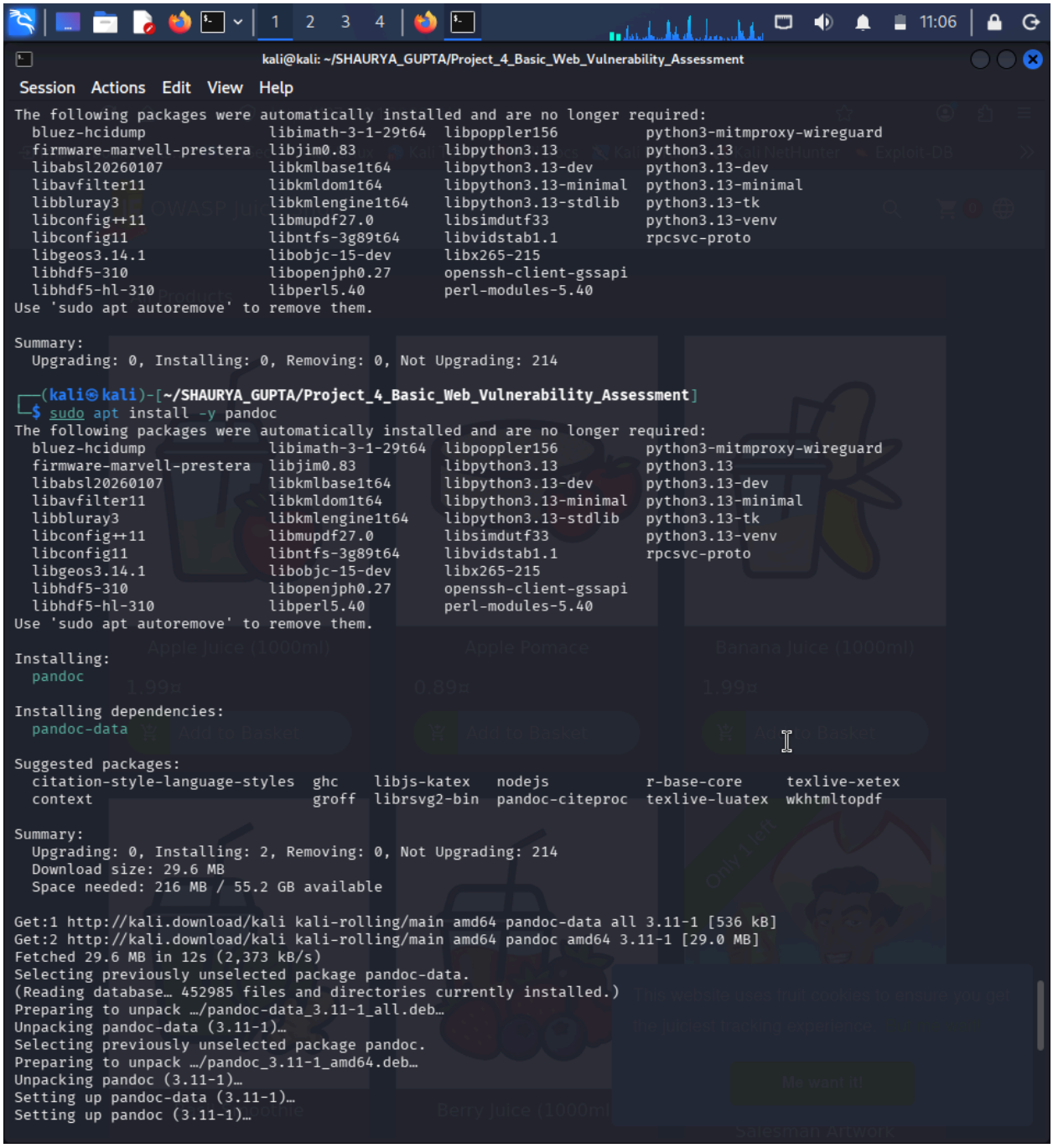
Evidence file	Purpose
`commands.txt`	Recorded terminal session

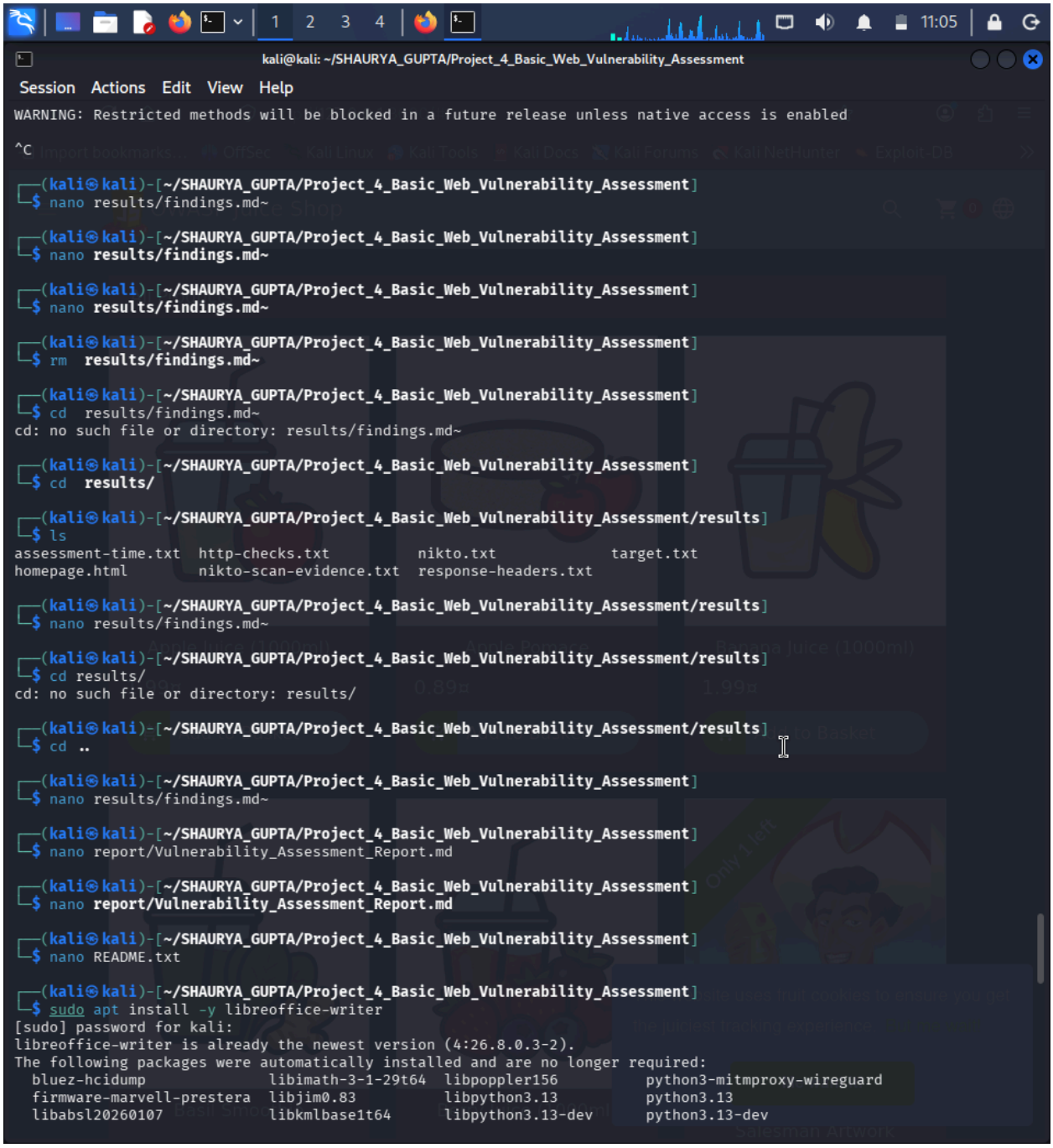
Evidence file	Purpose
`results/assessment-time.txt`	Assessment timestamp
`results/target.txt`	Target and scope
`results/response-headers.txt`	Captured homepage headers and response
`results/homepage.html`	Saved homepage body
`results/nikto.txt`	Nikto scan output
`results/nikto-scan-evidence.txt`	Copy of Nikto scan output
`results/http-checks.txt`	Combined HTTP response checks

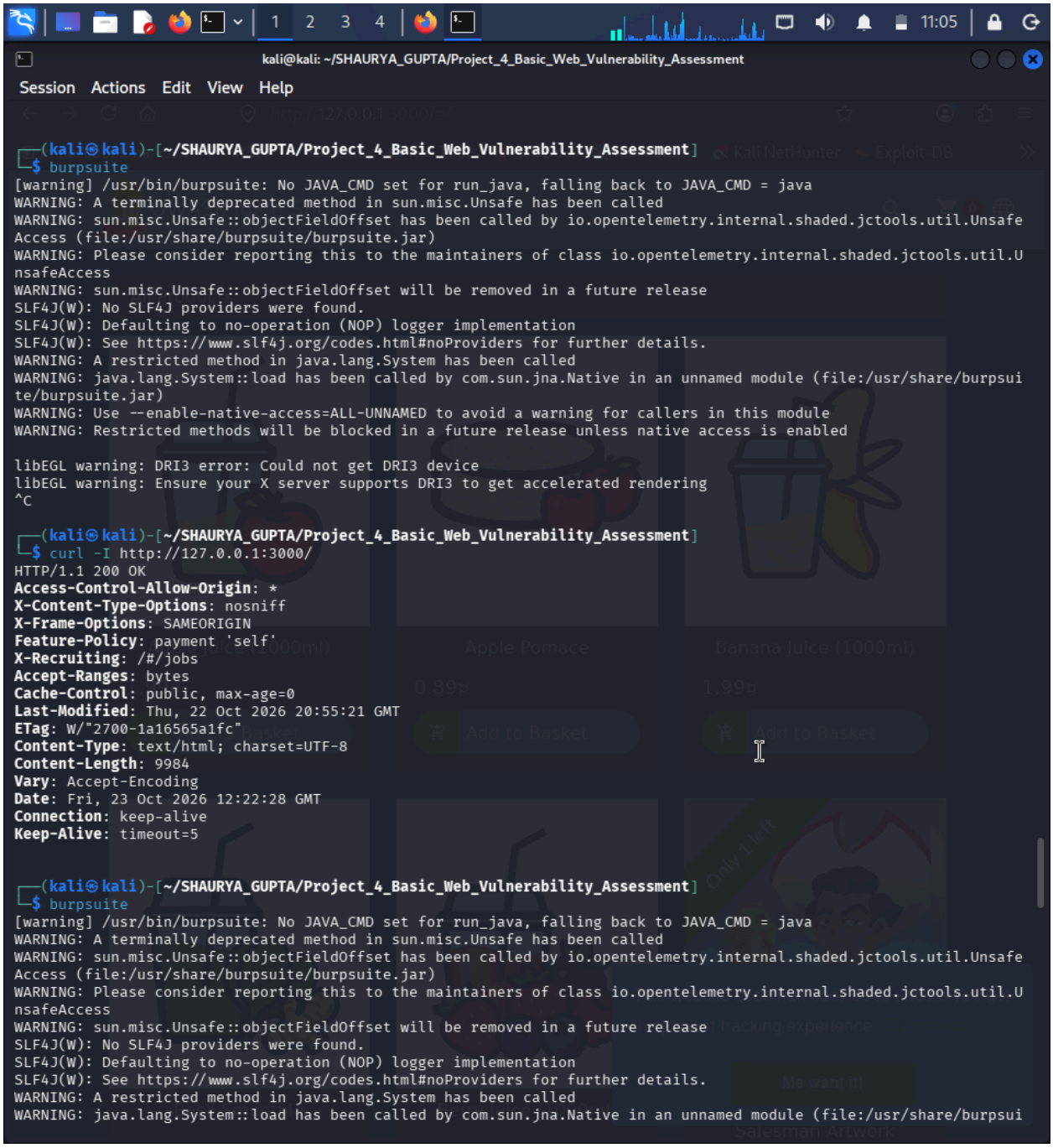
The presence of individual screenshot files was not established by the supplied evidence. Any screenshots included in the final submission should be genuine captures of the actual commands, tool outputs, and verification results.

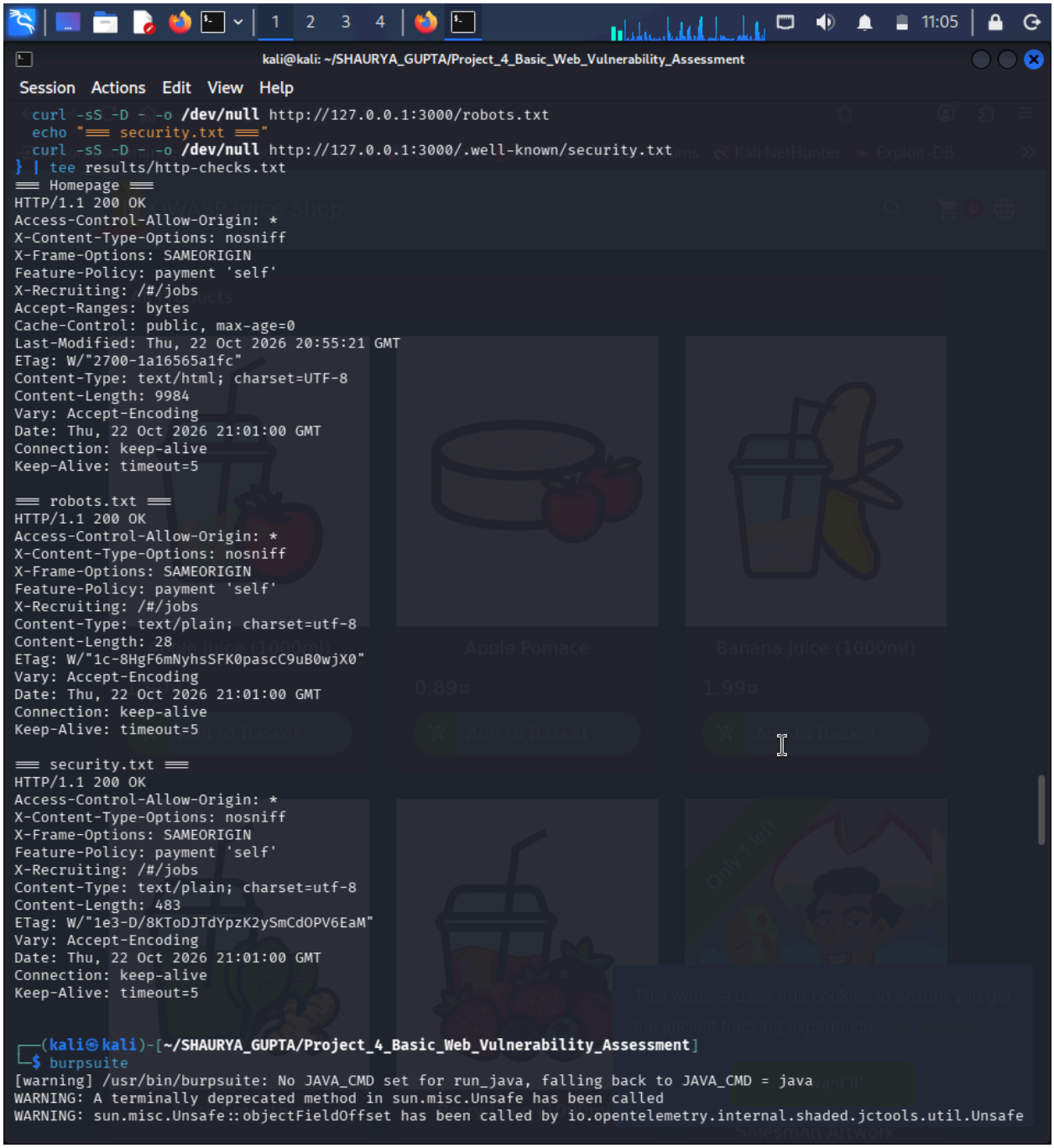
End of Report

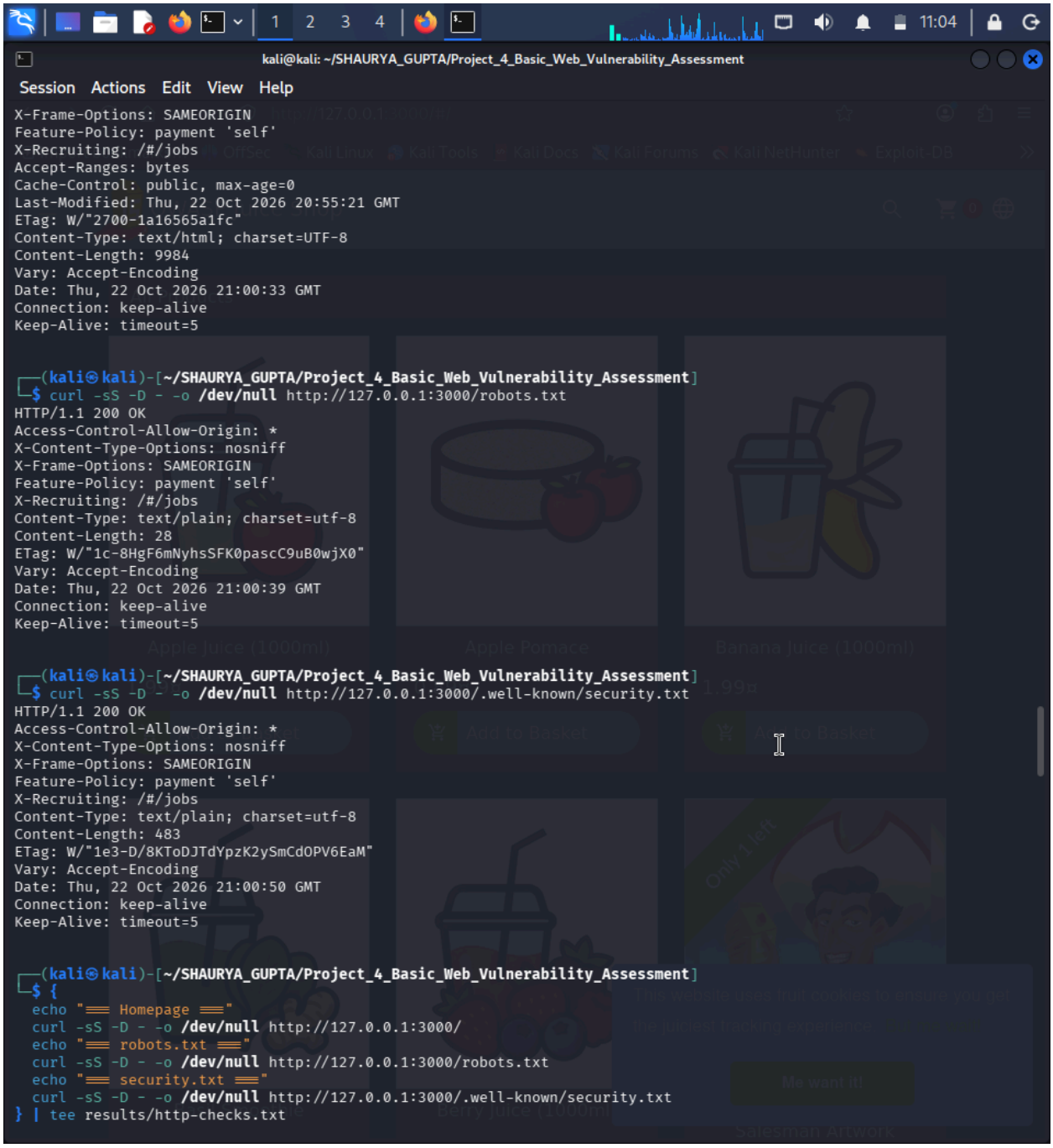

kali@kali: ~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment
Session Actions Edit View Help
Preparing to unpack .../pandoc_3.11-1_amd64.deb...
Unpacking pandoc (3.11-1)...
Setting up pandoc-data (3.11-1)...
Setting up pandoc (3.11-1)...
Processing triggers for man-db (2.13.1-1)...
Processing triggers for kali-menu (2026.3.4)...
Scanning processes...
Scanning linux images...
Running kernel seems to be up-to-date.
No services need to be restarted.
No containers need to be restarted.
No user sessions are running outdated binaries.
No VM guests are running outdated hypervisor (qemu) binaries on this host.
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
$ pandoc report/Vulnerability_Assessment_Report.md -o report/Vulnerability_Assessment_Report.pdf --toc
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
$ ls -lh report/
file report/Vulnerability_Assessment_Report.pdf
total 192K
-rw-rw-r-- 1 kali kali 33K Oct 23 10:45 Vulnerability_Assessment_Report.md
-rw-rw-r-- 1 kali kali 155K Oct 23 10:57 Vulnerability_Assessment_Report.pdf
report/Vulnerability_Assessment_Report.pdf: PDF document, version 1.7
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
$ cd ~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
$ find . -maxdepth 3 -type f -printf '%p (%s bytes)\n' | sort
./commands.txt (2822144 bytes)
./README.txt (428 bytes)
./report/Vulnerability_Assessment_Report.md (33148 bytes)
./report/Vulnerability_Assessment_Report.pdf (158315 bytes)
./results/assessment-time.txt (26 bytes)
./results/findings.md~ (8996 bytes)
./results/homepage.html (9984 bytes)
./results/http-checks.txt (1282 bytes)
./results/nikto-scan-evidence.txt (2335 bytes)
./results/nikto.txt (2335 bytes)
./results/response-headers.txt (467 bytes)
./results/target.txt (79 bytes)
./screenshots/01.png (302742 bytes)
./screenshots/02.png (132662 bytes)
./screenshots/03.png (164960 bytes)
./screenshots/04.png (166202 bytes)
./screenshots/05.png (191016 bytes)
./screenshots/06.png (183677 bytes)
./screenshots/07.png (190139 bytes)
./screenshots/08.png (189790 bytes)
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
$ test -s results/nikto.txt && echo "Nikto output exists" || echo "Nikto output missing or empty"

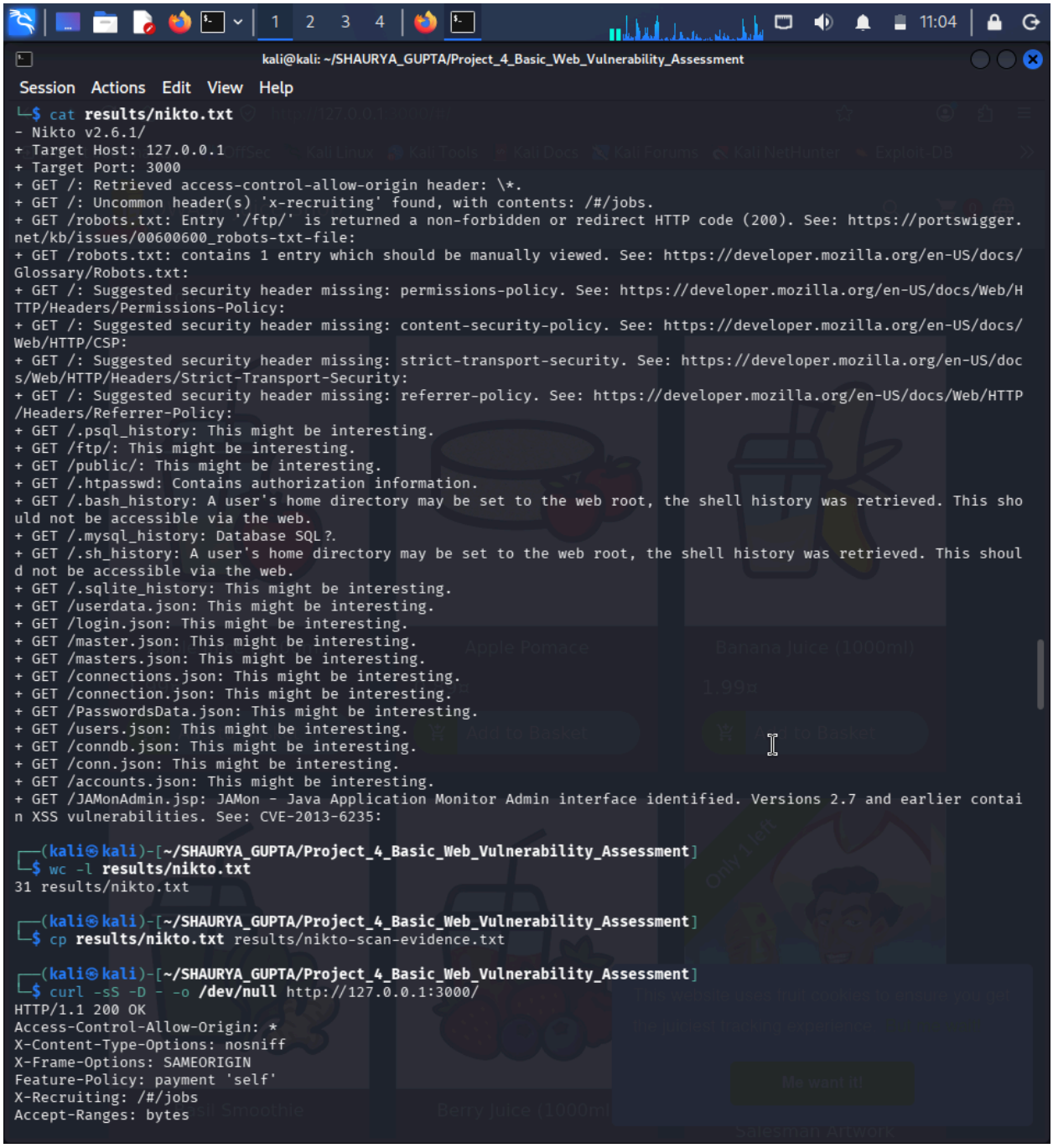

kali@kali: ~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment
Session Actions Edit View Help
The following packages were automatically installed and are no longer required:
bluez-hcidump libimath-3-1-29t64 libpoppler156 python3-mitmproxy-wireguard
firmware-marvell-prestera libjim0.83 libpython3.13 python3.13
libabsl20260107 libkmlbase1t64 libpython3.13-dev python3.13-dev
libavfilter11 libkmldom1t64 libpython3.13-minimal python3.13-minimal
libbluray3 libkmlengine1t64 libpython3.13-stdlib python3.13-tk
libconfig++11 libmupdf27.0 libsimdutf33 python3.13-venv
libconfig11 libntfs-3g89t64 libvidstab1.1 rpcsvc-proto
libgeos3.14.1 libobjc-15-dev libx265-215
libhdf5-310 libopenjph0.27 openssh-client-gssapi
libhdf5-hl-310 libperl5.40 perl-modules-5.40
Use 'sudo apt autoremove' to remove them.
Summary:
Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 214
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
$ sudo apt install -y pandoc
The following packages were automatically installed and are no longer required:
bluez-hcidump libimath-3-1-29t64 libpoppler156 python3-mitmproxy-wireguard
firmware-marvell-prestera libjim0.83 libpython3.13 python3.13
libabsl20260107 libkmlbase1t64 libpython3.13-dev python3.13-dev
libavfilter11 libkmldom1t64 libpython3.13-minimal python3.13-minimal
libbluray3 libkmlengine1t64 libpython3.13-stdlib python3.13-tk
libconfig++11 libmupdf27.0 libsimdutf33 python3.13-venv
libconfig11 libntfs-3g89t64 libvidstab1.1 rpcsvc-proto
libgeos3.14.1 libobjc-15-dev libx265-215
libhdf5-310 libopenjph0.27 openssh-client-gssapi
libhdf5-hl-310 libperl5.40 perl-modules-5.40
Use 'sudo apt autoremove' to remove them.
Installing:
pandoc
Installing dependencies:
pandoc-data
Suggested packages:
citation-style-language-styles ghc libjs-katex nodejs r-base-core texlive-xetex
context groff librsvg2-bin pandoc-citeproc texlive-luatex wkhtmltopdf
Summary:
Upgrading: 0, Installing: 2, Removing: 0, Not Upgrading: 214
Download size: 29.6 MB
Space needed: 216 MB / 55.2 GB available
Get:1 http://kali.download/kali kali-rolling/main amd64 pandoc-data all 3.11-1 [536 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 pandoc amd64 3.11-1 [29.0 MB]
Fetched 29.6 MB in 12s (2,373 kB/s)
Selecting previously unselected package pandoc-data.
(Reading database… 452985 files and directories currently installed.)
Preparing to unpack …/pandoc-data_3.11-1_all.deb…
Unpacking pandoc-data (3.11-1)…
Selecting previously unselected package pandoc.
Preparing to unpack …/pandoc_3.11-1_amd64.deb…
Unpacking pandoc (3.11-1)…
Setting up pandoc-data (3.11-1)…
Setting up pandoc (3.11-1)…

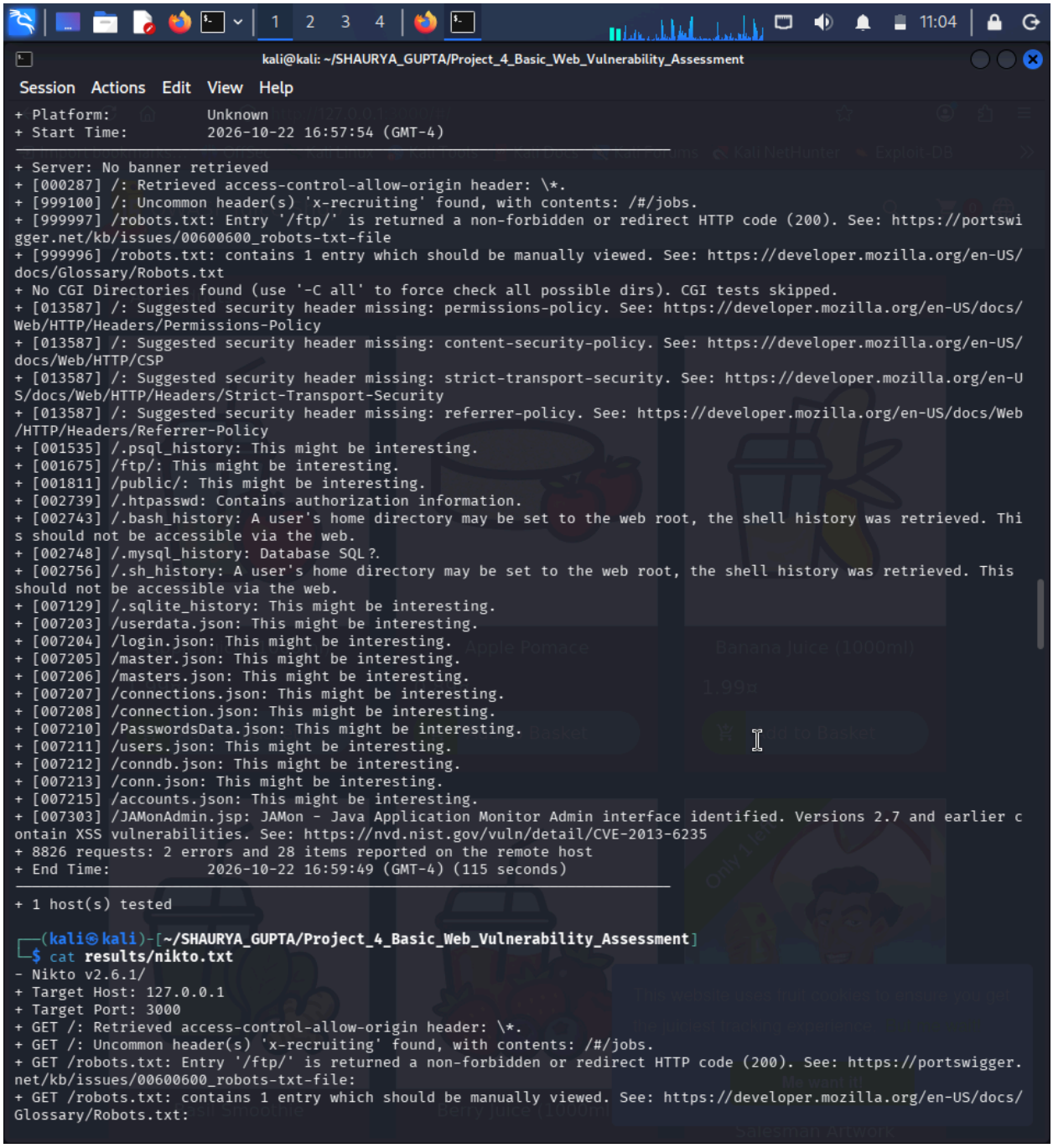

kali@kali: ~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment
Session Actions Edit View Help
WARNING: Restricted methods will be blocked in a future release unless native access is enabled
^C
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
$ nano results/findings.md~
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
$ nano results/findings.md~
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
$ nano results/findings.md~
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
$ rm results/findings.md~
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
$ cd results/findings.md~
cd: no such file or directory: results/findings.md~
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
$ cd results/
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment/results]
$ ls
assessment-time.txt http-checks.txt nikto.txt target.txt
homepage.html nikto-scan-evidence.txt response-headers.txt
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment/results]
$ nano results/findings.md~
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment/results]
$ cd results/
cd: no such file or directory: results/
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment/results]
$ cd ..
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
$ nano results/findings.md~
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
$ nano report/Vulnerability_Assessment_Report.md
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
$ nano report/Vulnerability_Assessment_Report.md
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
$ nano README.txt
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
$ sudo apt install -y libreoffice-writer
[sudo] password for kali:
libreoffice-writer is already the newest version (4:26.8.0.3-2).
The following packages were automatically installed and are no longer required:
bluez-hcidump libimath-3-1-29t64 libpoppler156 python3-mitmproxy-wireguard
firmware-marvell-prestera libjim0.83 libpython3.13 python3.13
libabsl20260107 libkmlbase1t64 libpython3.13-dev python3.13-dev

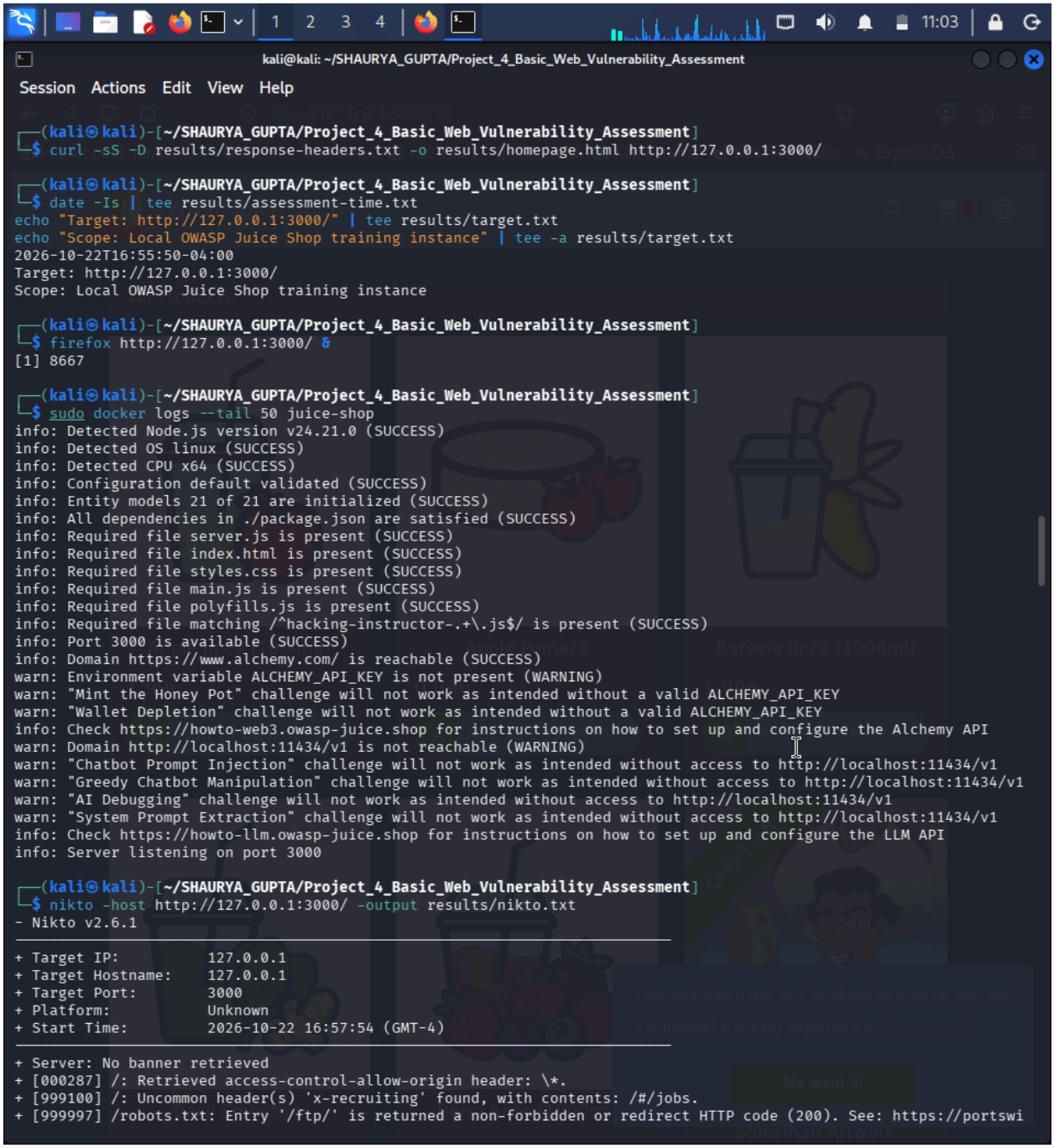

kali@kali: ~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment
Session Actions Edit View Help
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ burpsuite
[warning] /usr/bin/burpsuite: No JAVA_CMD set for run_java, falling back to JAVA_CMD = java
WARNING: A terminally deprecated method in sun.misc.Unsafe has been called
WARNING: sun.misc.Unsafe::objectFieldOffset has been called by io.opentelemetry.internal.shaded.jctools.util.UnsafeAccess (file:/usr/share/burpsuite/burpsuite.jar)
WARNING: Please consider reporting this to the maintainers of class io.opentelemetry.internal.shaded.jctools.util.UnsafeAccess
WARNING: sun.misc.Unsafe::objectFieldOffset will be removed in a future release
SLF4J(W): No SLF4J providers were found.
SLF4J(W): Defaulting to no-operation (NOP) logger implementation
SLF4J(W): See https://www.slf4j.org/codes.html#noProviders for further details.
WARNING: A restricted method in java.lang.System has been called
WARNING: java.lang.System::load has been called by com.sun.jna.Native in an unnamed module (file:/usr/share/burpsuite/burpsuite.jar)
WARNING: Use --enable-native-access=ALL-UNNAMED to avoid a warning for callers in this module
WARNING: Restricted methods will be blocked in a future release unless native access is enabled
libEGL warning: DRI3 error: Could not get DRI3 device
libEGL warning: Ensure your X server supports DRI3 to get accelerated rendering
^C
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ curl -I http://127.0.0.1:3000/
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Accept-Ranges: bytes
Cache-Control: public, max-age=0
Last-Modified: Thu, 22 Oct 2026 20:55:21 GMT
ETag: W/"2700-1a16565a1fc"
Content-Type: text/html; charset=UTF-8
Content-Length: 9984
Vary: Accept-Encoding
Date: Fri, 23 Oct 2026 12:22:28 GMT
Connection: keep-alive
Keep-Alive: timeout=5
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ burpsuite
[warning] /usr/bin/burpsuite: No JAVA_CMD set for run_java, falling back to JAVA_CMD = java
WARNING: A terminally deprecated method in sun.misc.Unsafe has been called
WARNING: sun.misc.Unsafe::objectFieldOffset has been called by io.opentelemetry.internal.shaded.jctools.util.UnsafeAccess (file:/usr/share/burpsuite/burpsuite.jar)
WARNING: Please consider reporting this to the maintainers of class io.opentelemetry.internal.shaded.jctools.util.UnsafeAccess
WARNING: sun.misc.Unsafe::objectFieldOffset will be removed in a future release
SLF4J(W): No SLF4J providers were found.
SLF4J(W): Defaulting to no-operation (NOP) logger implementation
SLF4J(W): See https://www.slf4j.org/codes.html#noProviders for further details.
WARNING: A restricted method in java.lang.System has been called
WARNING: java.lang.System::load has been called by com.sun.jna.Native in an unnamed module (file:/usr/share/burpsui

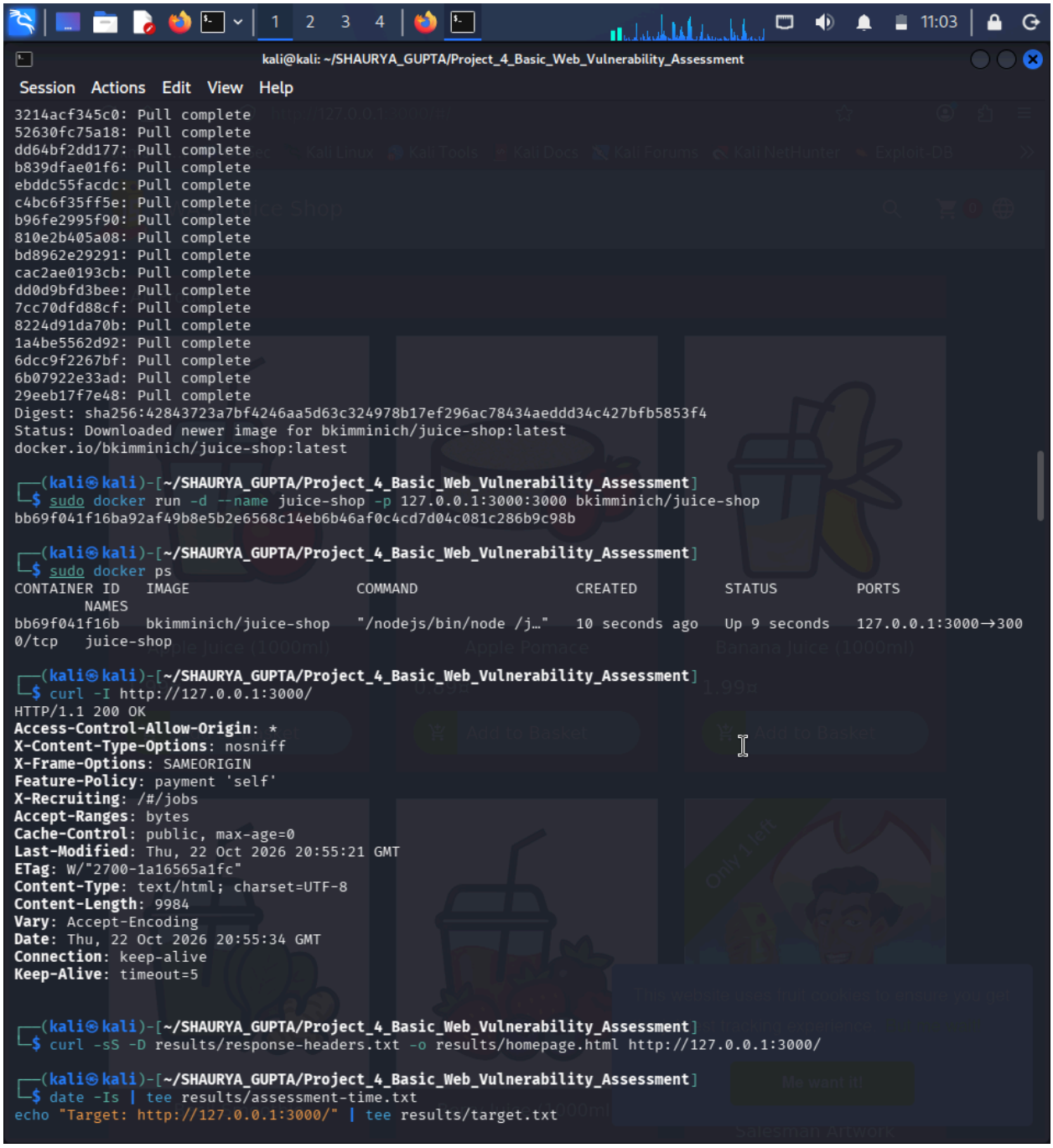

kali@kali: ~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment
Session Actions Edit View Help
curl -sS -D - -o /dev/null http://127.0.0.1:3000/robots.txt
echo "=== security.txt ==="
curl -sS -D - -o /dev/null http://127.0.0.1:3000/.well-known/security.txt
} | tee results/http-checks.txt
=== Homepage ===
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Accept-Ranges: bytes
Cache-Control: public, max-age=0
Last-Modified: Thu, 22 Oct 2026 20:55:21 GMT
ETag: W/"2700-1a16565a1fc"
Content-Type: text/html; charset=UTF-8
Content-Length: 9984
Vary: Accept-Encoding
Date: Thu, 22 Oct 2026 21:01:00 GMT
Connection: keep-alive
Keep-Alive: timeout=5
=== robots.txt ===
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Content-Type: text/plain; charset=utf-8
Content-Length: 28
ETag: W/"1c-8HgF6mNyhsSFK0pascC9uB0wjX0"
Vary: Accept-Encoding
Date: Thu, 22 Oct 2026 21:01:00 GMT
Connection: keep-alive
Keep-Alive: timeout=5
=== security.txt ===
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Content-Type: text/plain; charset=utf-8
Content-Length: 483
ETag: W/"1e3-D/8KToDJTdYpzK2ySmCdOPV6EaM"
Vary: Accept-Encoding
Date: Thu, 22 Oct 2026 21:01:00 GMT
Connection: keep-alive
Keep-Alive: timeout=5
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
$ burpsuite
[warning] /usr/bin/burpsuite: No JAVA_CMD set for run_java, falling back to JAVA_CMD = java
WARNING: A terminally deprecated method in sun.misc.Unsafe has been called
WARNING: sun.misc.Unsafe::objectFieldOffset has been called by io.opentelemetry.internal.shaded.jctools.util.Unsafe

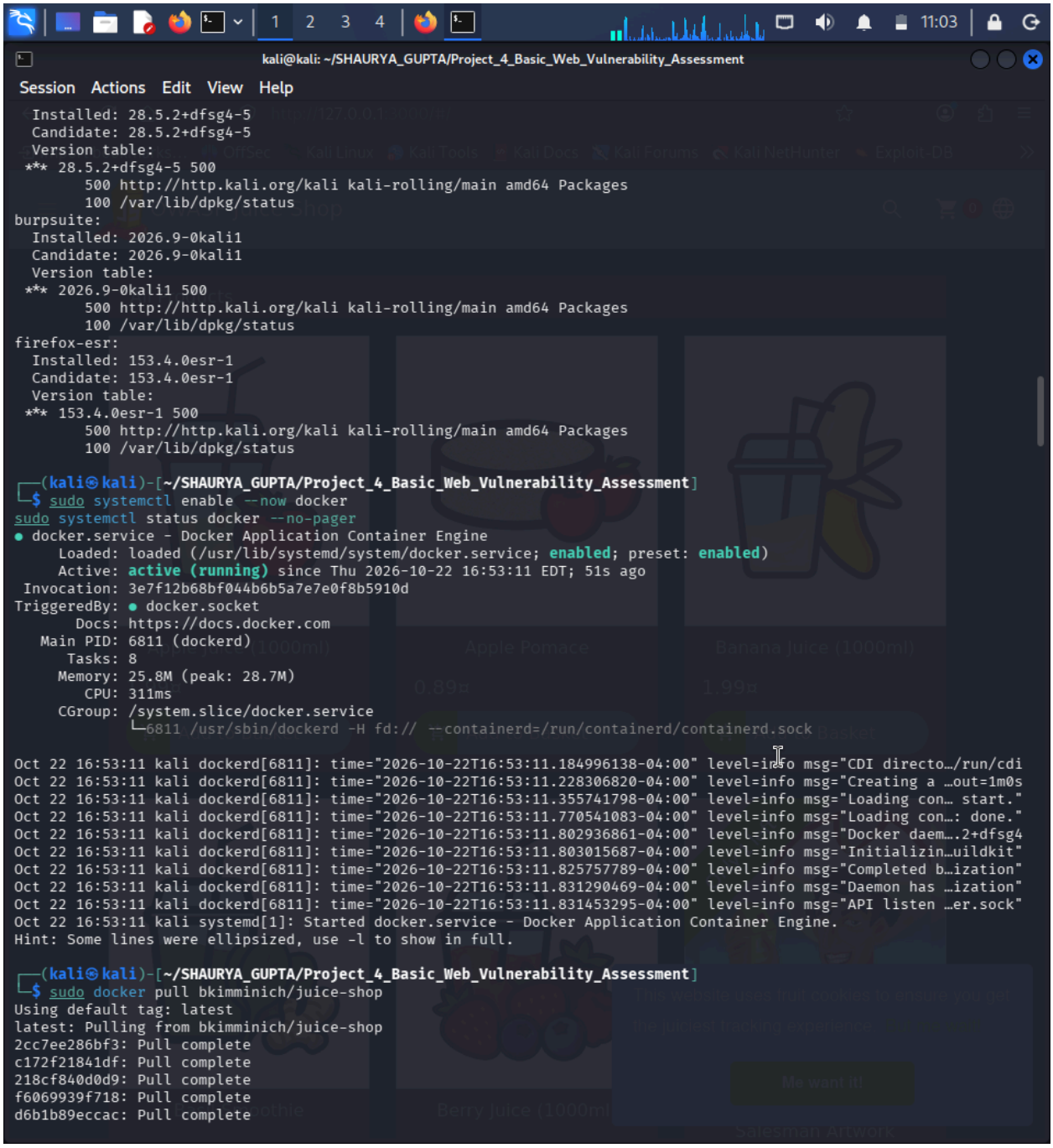

kali@kali: ~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment
Session Actions Edit View Help
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Accept-Ranges: bytes
Cache-Control: public, max-age=0
Last-Modified: Thu, 22 Oct 2026 20:55:21 GMT
ETag: W/"2700-1a16565a1fc"
Content-Type: text/html; charset=UTF-8
Content-Length: 9984
Vary: Accept-Encoding
Date: Thu, 22 Oct 2026 21:00:33 GMT
Connection: keep-alive
Keep-Alive: timeout=5
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ curl -sS -D - -o /dev/null http://127.0.0.1:3000/robots.txt
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Content-Type: text/plain; charset=utf-8
Content-Length: 28
ETag: W/"1c-8HgF6mNyhsSFK0pascC9uB0wjX0"
Vary: Accept-Encoding
Date: Thu, 22 Oct 2026 21:00:39 GMT
Connection: keep-alive
Keep-Alive: timeout=5
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ curl -sS -D - -o /dev/null http://127.0.0.1:3000/.well-known/security.txt
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Content-Type: text/plain; charset=utf-8
Content-Length: 483
ETag: W/"1e3-D/8KToDJTdYpzK2ySmCdOPV6EaM"
Vary: Accept-Encoding
Date: Thu, 22 Oct 2026 21:00:50 GMT
Connection: keep-alive
Keep-Alive: timeout=5
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ {
echo "=== Homepage ==="
curl -sS -D - -o /dev/null http://127.0.0.1:3000/
echo "=== robots.txt ==="
curl -sS -D - -o /dev/null http://127.0.0.1:3000/robots.txt
echo "=== security.txt ==="
curl -sS -D - -o /dev/null http://127.0.0.1:3000/.well-known/security.txt
} | tee results/http-checks.txt


kali@kali: ~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment
Session Actions Edit View Help
└─$ cat results/nikto.txt
- Nikto v2.6.1/
+ Target Host: 127.0.0.1
+ Target Port: 3000
+ GET /: Retrieved access-control-allow-origin header: *.
+ GET /: Uncommon header(s) 'x-recruiting' found, with contents: /#/jobs.
+ GET /robots.txt: Entry '/ftp/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file:
+ GET /robots.txt: contains 1 entry which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt:
+ GET /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy:
+ GET /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP:
+ GET /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security:
+ GET /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy:
+ GET /.psql_history: This might be interesting.
+ GET /ftp/: This might be interesting.
+ GET /public/: This might be interesting.
+ GET /.htpasswd: Contains authorization information.
+ GET /.bash_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.
+ GET /.mysql_history: Database SQL?.
+ GET /.sh_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.
+ GET /.sqlite_history: This might be interesting.
+ GET /userdata.json: This might be interesting.
+ GET /login.json: This might be interesting.
+ GET /master.json: This might be interesting.
+ GET /masters.json: This might be interesting.
+ GET /connections.json: This might be interesting.
+ GET /connection.json: This might be interesting.
+ GET /PasswordsData.json: This might be interesting.
+ GET /users.json: This might be interesting.
+ GET /conndb.json: This might be interesting.
+ GET /conn.json: This might be interesting.
+ GET /accounts.json: This might be interesting.
+ GET /JAMonAdmin.jsp: JAMon - Java Application Monitor Admin interface identified. Versions 2.7 and earlier contain XSS vulnerabilities. See: CVE-2013-6235:
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ wc -l results/nikto.txt
31 results/nikto.txt
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ cp results/nikto.txt results/nikto-scan-evidence.txt
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ curl -sS -D - -o /dev/null http://127.0.0.1:3000/
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Accept-Ranges: bytes

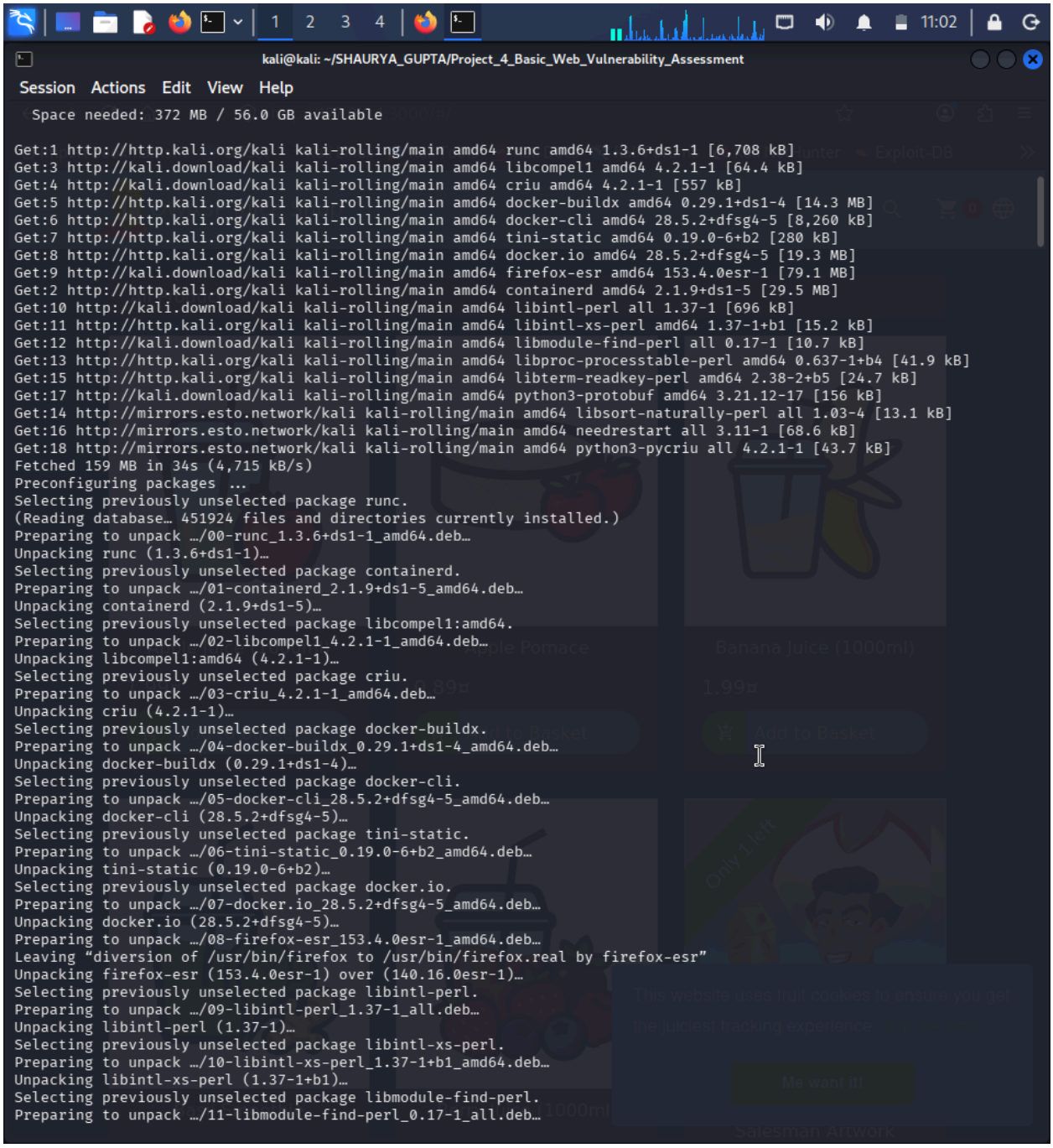

kali@kali: ~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment
Session Actions Edit View Help
+ Platform: Unknown
+ Start Time: 2026-10-22 16:57:54 (GMT-4)
+ Server: No banner retrieved
+ [000287] /: Retrieved access-control-allow-origin header: *.
+ [999100] /: Uncommon header(s) 'x-recruiting' found, with contents: /#/jobs.
+ [999997] /robots.txt: Entry '/ftp/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ [999996] /robots.txt: contains 1 entry which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [001535] /.psql_history: This might be interesting.
+ [001675] /ftp/: This might be interesting.
+ [001811] /public/: This might be interesting.
+ [002739] /.htpasswd: Contains authorization information.
+ [002743] /.bash_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.
+ [002748] /.mysql_history: Database SQL ?.
+ [002756] /.sh_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.
+ [007129] /.sqlite_history: This might be interesting.
+ [007203] /userdata.json: This might be interesting.
+ [007204] /login.json: This might be interesting.
+ [007205] /master.json: This might be interesting.
+ [007206] /masters.json: This might be interesting.
+ [007207] /connections.json: This might be interesting.
+ [007208] /connection.json: This might be interesting.
+ [007210] /PasswordsData.json: This might be interesting.
+ [007211] /users.json: This might be interesting.
+ [007212] /conndb.json: This might be interesting.
+ [007213] /conn.json: This might be interesting.
+ [007215] /accounts.json: This might be interesting.
+ [007303] /JAMonAdmin.jsp: JAMon - Java Application Monitor Admin interface identified. Versions 2.7 and earlier contain XSS vulnerabilities. See: https://nvd.nist.gov/vuln/detail/CVE-2013-6235
+ 8826 requests: 2 errors and 28 items reported on the remote host
+ End Time: 2026-10-22 16:59:49 (GMT-4) (115 seconds)
+ 1 host(s) tested
(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
$ cat results/nikto.txt
- Nikto v2.6.1/
+ Target Host: 127.0.0.1
+ Target Port: 3000
+ GET /: Retrieved access-control-allow-origin header: *.
+ GET /: Uncommon header(s) 'x-recruiting' found, with contents: /#/jobs.
+ GET /robots.txt: Entry '/ftp/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file:
+ GET /robots.txt: contains 1 entry which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt:

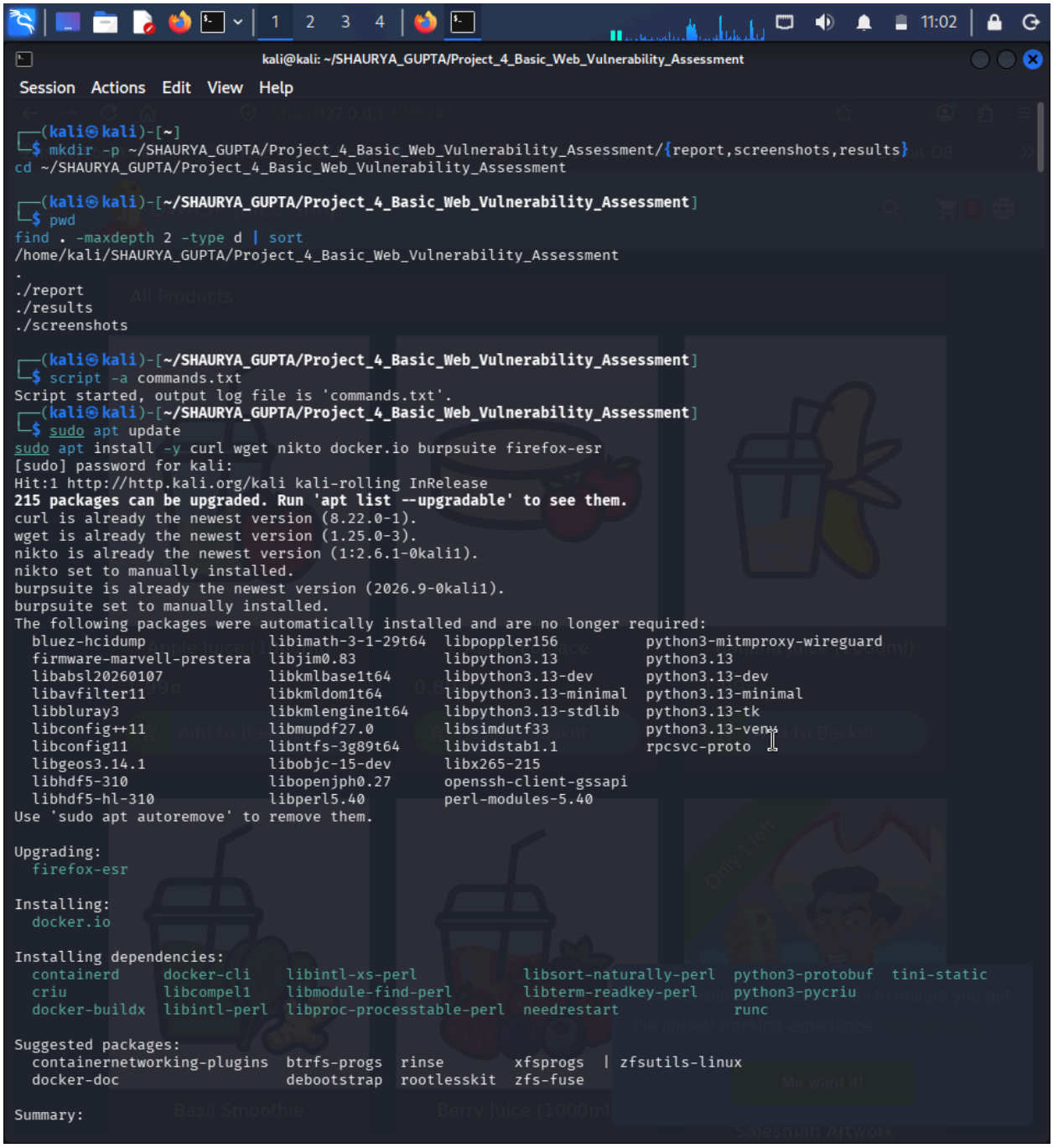

kali@kali: ~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment
Session Actions Edit View Help
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ curl -sS -D results/response-headers.txt -o results/homepage.html http://127.0.0.1:3000/
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ date -Is | tee results/assessment-time.txt
echo "Target: http://127.0.0.1:3000/" | tee results/target.txt
echo "Scope: Local OWASP Juice Shop training instance" | tee -a results/target.txt
2026-10-22T16:55:50-04:00
Target: http://127.0.0.1:3000/
Scope: Local OWASP Juice Shop training instance
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ firefox http://127.0.0.1:3000/ &
[1] 8667
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ sudo docker logs --tail 50 juice-shop
info: Detected Node.js version v24.21.0 (SUCCESS)
info: Detected OS linux (SUCCESS)
info: Detected CPU x64 (SUCCESS)
info: Configuration default validated (SUCCESS)
info: Entity models 21 of 21 are initialized (SUCCESS)
info: All dependencies in ./package.json are satisfied (SUCCESS)
info: Required file server.js is present (SUCCESS)
info: Required file index.html is present (SUCCESS)
info: Required file styles.css is present (SUCCESS)
info: Required file main.js is present (SUCCESS)
info: Required file polyfills.js is present (SUCCESS)
info: Required file matching /^hacking-instructor-.+\.js$/ is present (SUCCESS)
info: Port 3000 is available (SUCCESS)
info: Domain https://www.alchemy.com/ is reachable (SUCCESS)
warn: Environment variable ALCHEMY_API_KEY is not present (WARNING)
warn: "Mint the Honey Pot" challenge will not work as intended without a valid ALCHEMY_API_KEY
warn: "Wallet Depletion" challenge will not work as intended without a valid ALCHEMY_API_KEY
info: Check https://howto-web3.owasp-juice.shop for instructions on how to set up and configure the Alchemy API
warn: Domain http://localhost:11434/v1 is not reachable (WARNING)
warn: "Chatbot Prompt Injection" challenge will not work as intended without access to http://localhost:11434/v1
warn: "Greedy Chatbot Manipulation" challenge will not work as intended without access to http://localhost:11434/v1
warn: "AI Debugging" challenge will not work as intended without access to http://localhost:11434/v1
warn: "System Prompt Extraction" challenge will not work as intended without access to http://localhost:11434/v1
info: Check https://howto-llm.owasp-juice.shop for instructions on how to set up and configure the LLM API
info: Server listening on port 3000
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ nikto -host http://127.0.0.1:3000/ -output results/nikto.txt
- Nikto v2.6.1
+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 3000
+ Platform: Unknown
+ Start Time: 2026-10-22 16:57:54 (GMT-4)
+ Server: No banner retrieved
+ [000287] /: Retrieved access-control-allow-origin header: *.
+ [999100] /: Uncommon header(s) 'x-recruiting' found, with contents: /#/jobs.
+ [999997] /robots.txt: Entry '/ftp/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswi

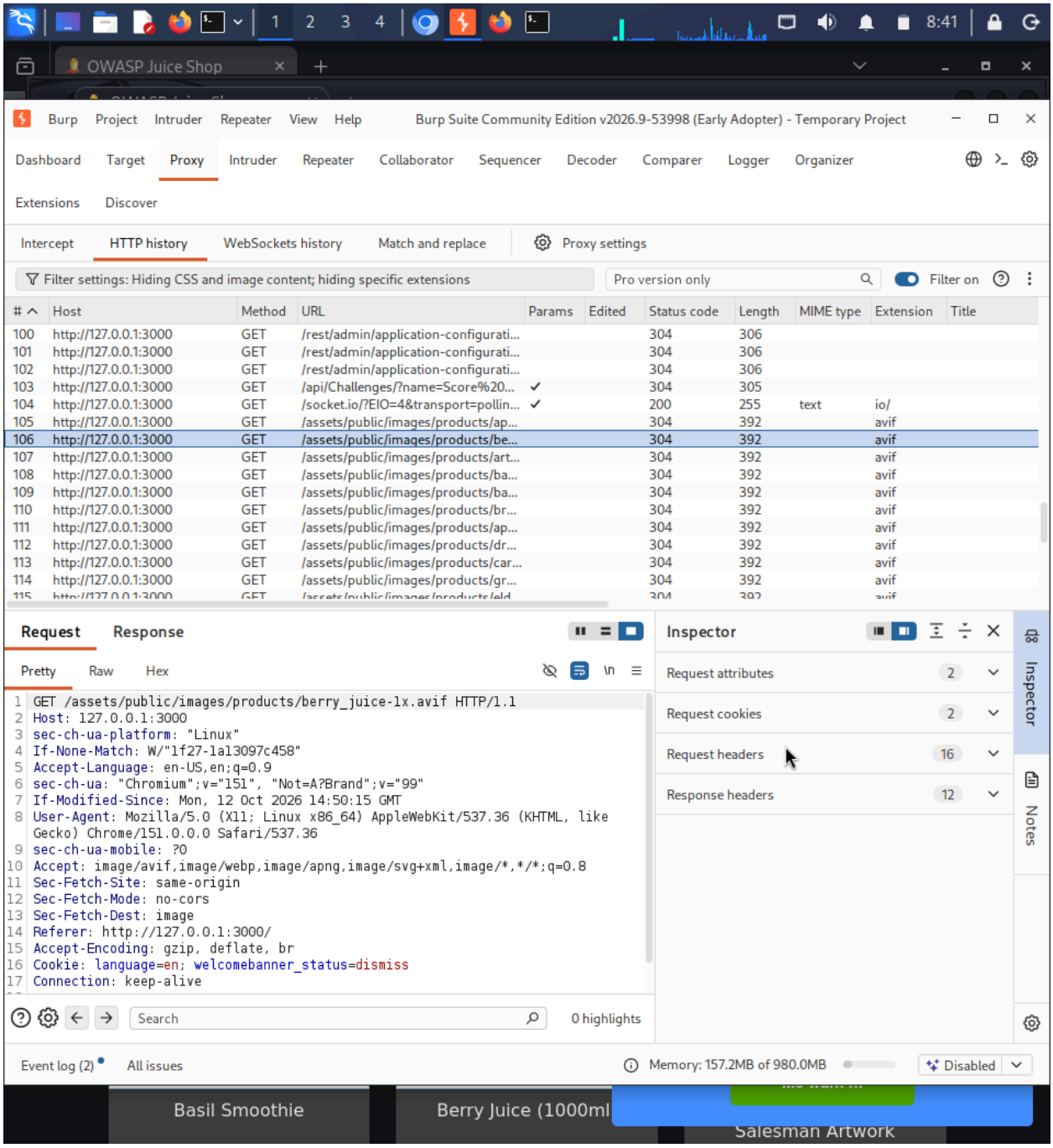

kali@kali: ~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment
Session Actions Edit View Help
3214acf345c0: Pull complete
52630fc75a18: Pull complete
dd64bf2dd177: Pull complete
b839dfae01f6: Pull complete
ebddc55facdc: Pull complete
c4bc6f35ff5e: Pull complete
b96fe2995f90: Pull complete
810e2b405a08: Pull complete
bd8962e29291: Pull complete
cac2ae0193cb: Pull complete
dd0d9bfd3bee: Pull complete
7cc70dfd88cf: Pull complete
8224d91da70b: Pull complete
1a4be5562d92: Pull complete
6dcc9f2267bf: Pull complete
6b07922e33ad: Pull complete
29eeb17f7e48: Pull complete
Digest: sha256:42843723a7bf4246aa5d63c324978b17ef296ac78434aeddd34c427bfb5853f4
Status: Downloaded newer image for bkimminich/juice-shop:latest
docker.io/bkimminich/juice-shop:latest
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ sudo docker run -d --name juice-shop -p 127.0.0.1:3000:3000 bkimminich/juice-shop
bb69f041f16ba92af49b8e5b2e6568c14eb6b46af0c4cd7d04c081c286b9c98b
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ sudo docker ps
CONTAINER ID IMAGE COMMAND CREATED STATUS PORTS
NAMES
bb69f041f16b bkimminich/juice-shop "/nodejs/bin/node /j…" 10 seconds ago Up 9 seconds 127.0.0.1:3000→300
0/tcp juice-shop
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ curl -I http://127.0.0.1:3000/
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Accept-Ranges: bytes
Cache-Control: public, max-age=0
Last-Modified: Thu, 22 Oct 2026 20:55:21 GMT
ETag: W/"2700-1a16565a1fc"
Content-Type: text/html; charset=UTF-8
Content-Length: 9984
Vary: Accept-Encoding
Date: Thu, 22 Oct 2026 20:55:34 GMT
Connection: keep-alive
Keep-Alive: timeout=5
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ curl -sS -D results/response-headers.txt -o results/homepage.html http://127.0.0.1:3000/
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ date -Is | tee results/assessment-time.txt
echo "Target: http://127.0.0.1:3000/" | tee results/target.txt

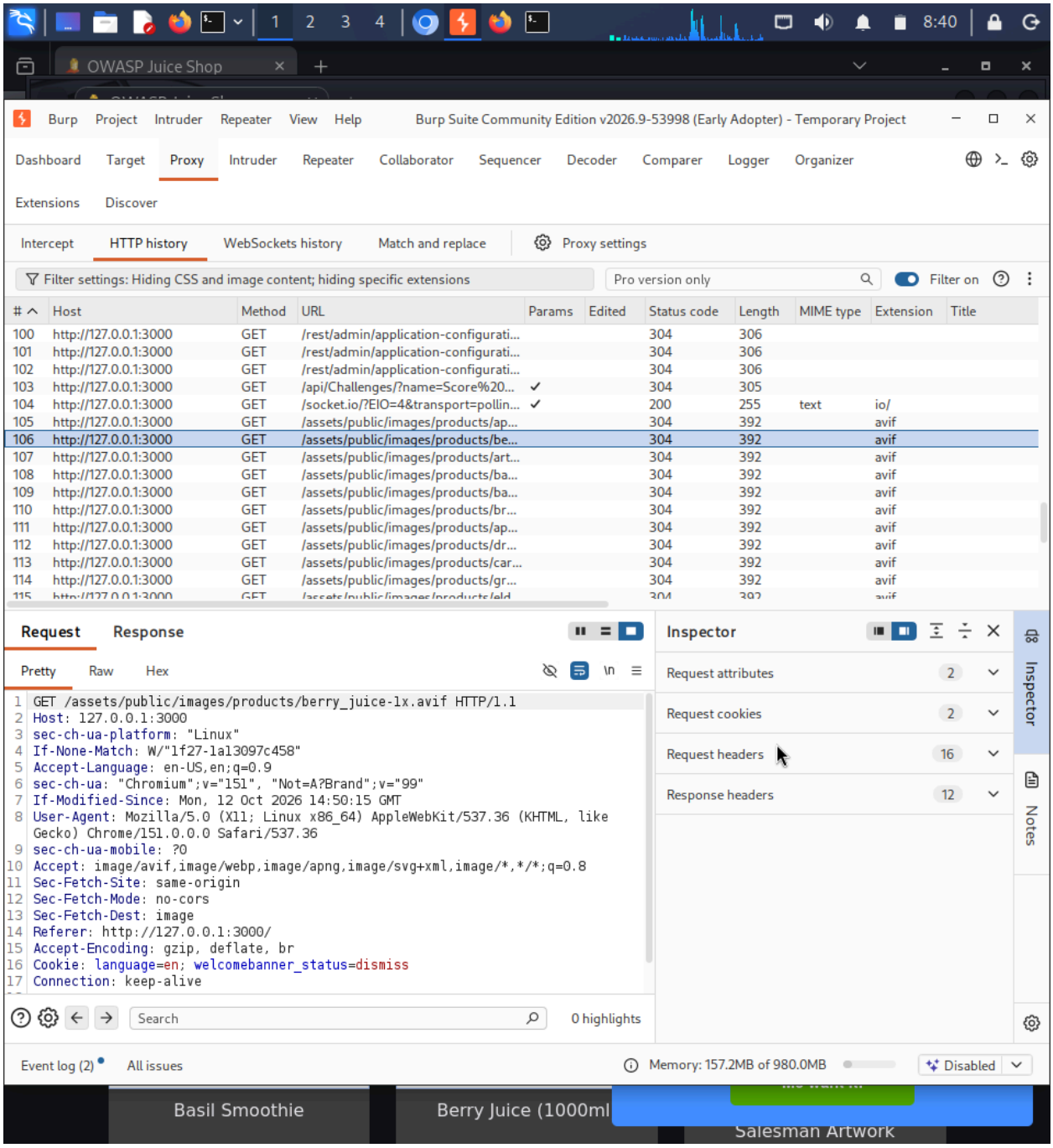

kali@kali: ~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment
Session Actions Edit View Help
Installed: 28.5.2+dfsg4-5
Candidate: 28.5.2+dfsg4-5
Version table:
*** 28.5.2+dfsg4-5 500
500 http://http.kali.org/kali kali-rolling/main amd64 Packages
100 /var/lib/dpkg/status
burpsuite:
Installed: 2026.9-0kali1
Candidate: 2026.9-0kali1
Version table:
*** 2026.9-0kali1 500
500 http://http.kali.org/kali kali-rolling/main amd64 Packages
100 /var/lib/dpkg/status
firefox-esr:
Installed: 153.4.0esr-1
Candidate: 153.4.0esr-1
Version table:
*** 153.4.0esr-1 500
500 http://http.kali.org/kali kali-rolling/main amd64 Packages
100 /var/lib/dpkg/status
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ sudo systemctl enable --now docker
sudo systemctl status docker --no-pager
● docker.service - Docker Application Container Engine
Loaded: loaded (/usr/lib/systemd/system/docker.service; enabled; preset: enabled)
Active: active (running) since Thu 2026-10-22 16:53:11 EDT; 51s ago
Invocation: 3e7f12b68bf044b6b5a7e7e0f8b5910d
TriggeredBy: ● docker.socket
Docs: https://docs.docker.com
Main PID: 6811 (dockerd)
Tasks: 8
Memory: 25.8M (peak: 28.7M)
CPU: 311ms
CGroup: /system.slice/docker.service
└─6811 /usr/sbin/dockerd -H fd:// --containerd=/run/containerd/containerd.sock
Oct 22 16:53:11 kali dockerd[6811]: time="2026-10-22T16:53:11.184996138-04:00" level=info msg="CDI directo…/run/cdi
Oct 22 16:53:11 kali dockerd[6811]: time="2026-10-22T16:53:11.228306820-04:00" level=info msg="Creating a …out=1m0s
Oct 22 16:53:11 kali dockerd[6811]: time="2026-10-22T16:53:11.355741798-04:00" level=info msg="Loading con… start."
Oct 22 16:53:11 kali dockerd[6811]: time="2026-10-22T16:53:11.770541083-04:00" level=info msg="Loading con…: done."
Oct 22 16:53:11 kali dockerd[6811]: time="2026-10-22T16:53:11.802936861-04:00" level=info msg="Docker daem….2+dfsg4
Oct 22 16:53:11 kali dockerd[6811]: time="2026-10-22T16:53:11.803015687-04:00" level=info msg="Initializin…uildkit"
Oct 22 16:53:11 kali dockerd[6811]: time="2026-10-22T16:53:11.825757789-04:00" level=info msg="Completed b…ization"
Oct 22 16:53:11 kali dockerd[6811]: time="2026-10-22T16:53:11.831290469-04:00" level=info msg="Daemon has …ization"
Oct 22 16:53:11 kali dockerd[6811]: time="2026-10-22T16:53:11.831453295-04:00" level=info msg="API listen …er.sock"
Oct 22 16:53:11 kali systemd[1]: Started docker.service - Docker Application Container Engine.
Hint: Some lines were ellipsized, use -l to show in full.
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ sudo docker pull bkimminich/juice-shop
Using default tag: latest
latest: Pulling from bkimminich/juice-shop
2cc7ee286bf3: Pull complete
c172f21841df: Pull complete
218cf840d0d9: Pull complete
f6069939f718: Pull complete
d6b1b89eccac: Pull complete

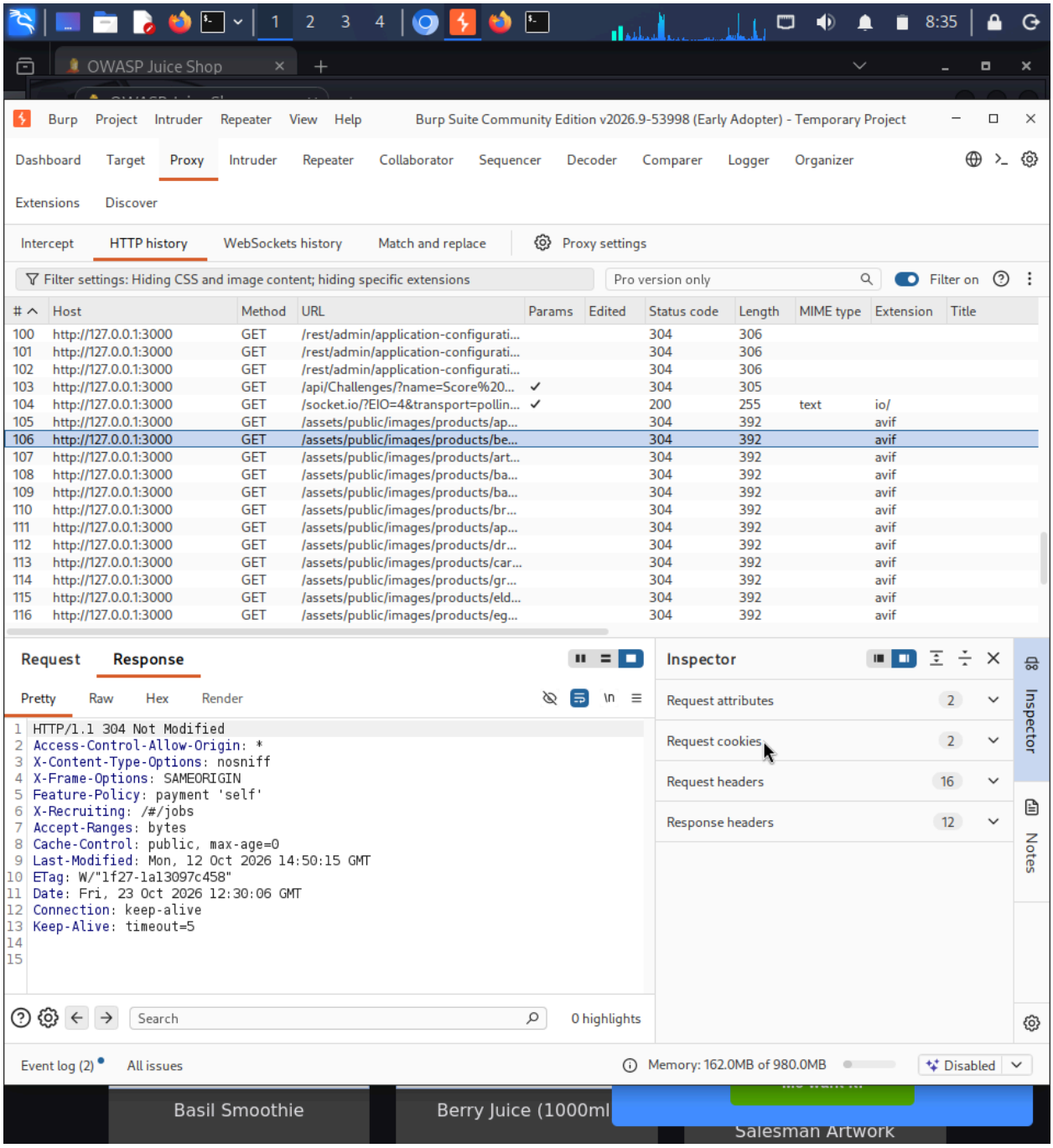
kali@kali: ~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment
Session Actions Edit View Help
Processing triggers for kali-menu (2026.3.4)…
Processing triggers for desktop-file-utils (0.28-1)…
Processing triggers for hicolor-icon-theme (0.18-2)…
Processing triggers for libc-bin (2.43-6)…
Processing triggers for man-db (2.13.1-1)…
Processing triggers for mailcap (3.77)…
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ curl --version
nikto -Version
docker --version
burpsuite --help
firefox --version
curl 8.22.0 (x86_64-pc-linux-gnu) libcurl/8.22.0 OpenSSL/3.6.4 zlib/1.3.2 brotli/1.2.0 zstd/1.5.7 libidn2/2.3.8 lib
psl/0.23.3 libssh2/1.11.1 nghttp2/1.70.0 ngtcp2/1.24.0 nghttp3/1.17.0 mit-krb5/1.22.1 OpenLDAP/2.6.14
Release-Date: 2026-09-02, security patched: 8.22.0-1
Protocols: dict file ftp ftps gopher gophers http https imap imaps ipfs ipns ldap ldaps mqtt mqtts pop3 pop3s rtsp
scp sftp smtp smtps telnet tftp ws wss
Features: alt-svc AsynchDNS brotli GSS-API HSTS HTTP2 HTTP3 HTTPS-proxy IDN IPv6 Kerberos Largefile libz PSL SPNEGO
SSL threadsafe UnixSockets zstd
Nikto 2.6.1 (LW 2.5)
Docker version 28.5.2+dfsg4, build 9cc6dea35e9a963f281434761c656fba4ac43aed
[warning] /usr/bin/burpsuite: No JAVA_CMD set for run_java, falling back to JAVA_CMD = java
Usage:
--help Print this message
--version Print version details
--disable-extensions Prevent loading of extensions on startup
--diagnostics Print diagnostic information
--use-defaults Start with default settings
--collaborator-server Run in Collaborator server mode
--collaborator-config Specify Collaborator server configuration file; defaults to collaborator.config
--data-dir Specify data directory
--project-file Open the specified project file; this will be created as a new project if the fil
e does not exist
--developer-extension-class-name Fully qualified name of locally-developed extension class; extension will be load
ed from the classpath
--config-file Load the specified project configuration file(s); this option may be repeated to
load multiple files
--user-config-file Load the specified user configuration file(s); this option may be repeated to loa
d multiple files
--auto-repair Automatically repair a corrupted project file specified by the --project-file opt
ion
--unpause-spider-and-scanner Do not pause the Spider and Scanner when opening an existing project
--disable-auto-update Suppress auto update behavior
Mozilla Firefox 153.4.0esr
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ apt-cache policy nikto docker.io burpsuite firefox-esr
nikto:
Installed: 1:2.6.1-0kali1
Candidate: 1:2.6.1-0kali1
Version table:
*** 1:2.6.1-0kali1 500
500 http://http.kali.org/kali kali-rolling/non-free amd64 Packages
100 /var/lib/dpkg/status
docker.io:
Installed: 28.5.2+dfsg4-5

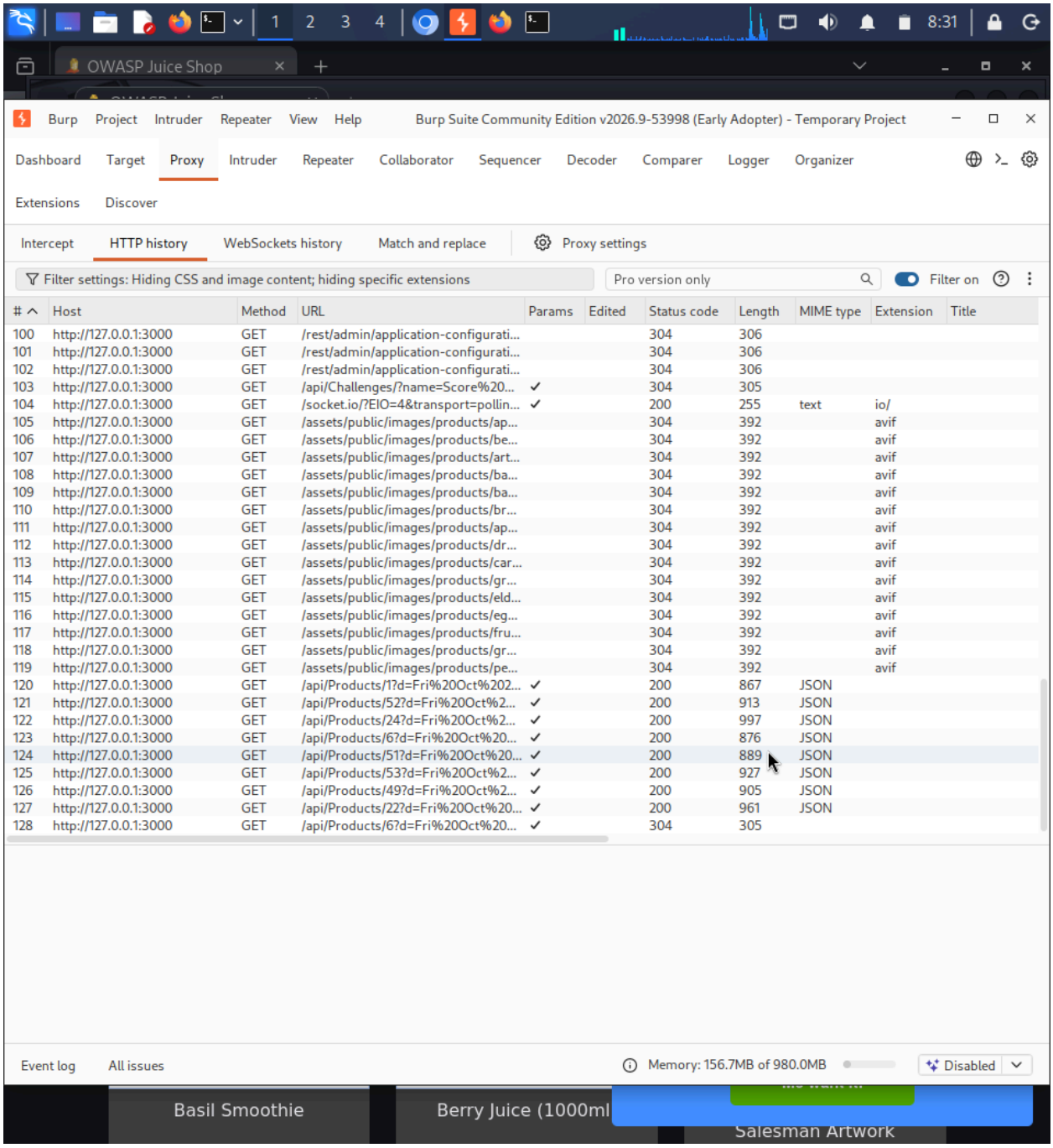

1 2 3 4
11:02
kali@kali: ~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment
Session Actions Edit View Help
Space needed: 372 MB / 56.0 GB available
Get:1 http://http.kali.org/kali kali-rolling/main amd64 runc amd64 1.3.6+ds1-1 [6,708 kB]
Get:3 http://kali.download/kali kali-rolling/main amd64 libcompel1 amd64 4.2.1-1 [64.4 kB]
Get:4 http://kali.download/kali kali-rolling/main amd64 criu amd64 4.2.1-1 [557 kB]
Get:5 http://http.kali.org/kali kali-rolling/main amd64 docker-buildx amd64 0.29.1+ds1-4 [14.3 MB]
Get:6 http://http.kali.org/kali kali-rolling/main amd64 docker-cli amd64 28.5.2+dfsg4-5 [8,260 kB]
Get:7 http://http.kali.org/kali kali-rolling/main amd64 tini-static amd64 0.19.0-6+b2 [280 kB]
Get:8 http://http.kali.org/kali kali-rolling/main amd64 docker.io amd64 28.5.2+dfsg4-5 [19.3 MB]
Get:9 http://kali.download/kali kali-rolling/main amd64 firefox-esr amd64 153.4.0esr-1 [79.1 MB]
Get:2 http://http.kali.org/kali kali-rolling/main amd64 containerd amd64 2.1.9+ds1-5 [29.5 MB]
Get:10 http://kali.download/kali kali-rolling/main amd64 libintl-perl all 1.37-1 [696 kB]
Get:11 http://http.kali.org/kali kali-rolling/main amd64 libintl-xs-perl amd64 1.37-1+b1 [15.2 kB]
Get:12 http://kali.download/kali kali-rolling/main amd64 libmodule-find-perl all 0.17-1 [10.7 kB]
Get:13 http://http.kali.org/kali kali-rolling/main amd64 libproc-processstable-perl amd64 0.637-1+b4 [41.9 kB]
Get:15 http://http.kali.org/kali kali-rolling/main amd64 libterm-readkey-perl amd64 2.38-2+b5 [24.7 kB]
Get:17 http://kali.download/kali kali-rolling/main amd64 python3-protobuf amd64 3.21.12-17 [156 kB]
Get:14 http://mirrors.esto.network/kali kali-rolling/main amd64 libsort-naturally-perl all 1.03-4 [13.1 kB]
Get:16 http://mirrors.esto.network/kali kali-rolling/main amd64 needrestart all 3.11-1 [68.6 kB]
Get:18 http://mirrors.esto.network/kali kali-rolling/main amd64 python3-pycriu all 4.2.1-1 [43.7 kB]
Fetched 159 MB in 34s (4,715 kB/s)
Preconfiguring packages ...
Selecting previously unselected package runc.
(Reading database… 451924 files and directories currently installed.)
Preparing to unpack …/00-runc_1.3.6+ds1-1_amd64.deb…
Unpacking runc (1.3.6+ds1-1)…
Selecting previously unselected package containerd.
Preparing to unpack …/01-containerd_2.1.9+ds1-5_amd64.deb…
Unpacking containerd (2.1.9+ds1-5)…
Selecting previously unselected package libcompel1:amd64.
Preparing to unpack …/02-libcompel1_4.2.1-1_amd64.deb…
Unpacking libcompel1:amd64 (4.2.1-1)…
Selecting previously unselected package criu.
Preparing to unpack …/03-criu_4.2.1-1_amd64.deb…
Unpacking criu (4.2.1-1)…
Selecting previously unselected package docker-buildx.
Preparing to unpack …/04-docker-buildx_0.29.1+ds1-4_amd64.deb…
Unpacking docker-buildx (0.29.1+ds1-4)…
Selecting previously unselected package docker-cli.
Preparing to unpack …/05-docker-cli_28.5.2+dfsg4-5_amd64.deb…
Unpacking docker-cli (28.5.2+dfsg4-5)…
Selecting previously unselected package tini-static.
Preparing to unpack …/06-tini-static_0.19.0-6+b2_amd64.deb…
Unpacking tini-static (0.19.0-6+b2)…
Selecting previously unselected package docker.io.
Preparing to unpack …/07-docker.io_28.5.2+dfsg4-5_amd64.deb…
Unpacking docker.io (28.5.2+dfsg4-5)…
Preparing to unpack …/08-firefox-esr_153.4.0esr-1_amd64.deb…
Leaving "diversion of /usr/bin/firefox to /usr/bin/firefox.real by firefox-esr"
Unpacking firefox-esr (153.4.0esr-1) over (140.16.0esr-1)…
Selecting previously unselected package libintl-perl.
Preparing to unpack …/09-libintl-perl_1.37-1_all.deb…
Unpacking libintl-perl (1.37-1)…
Selecting previously unselected package libintl-xs-perl.
Preparing to unpack …/10-libintl-xs-perl_1.37-1+b1_amd64.deb…
Unpacking libintl-xs-perl (1.37-1+b1)…
Selecting previously unselected package libmodule-find-perl.
Preparing to unpack …/11-libmodule-find-perl_0.17-1_all.deb…

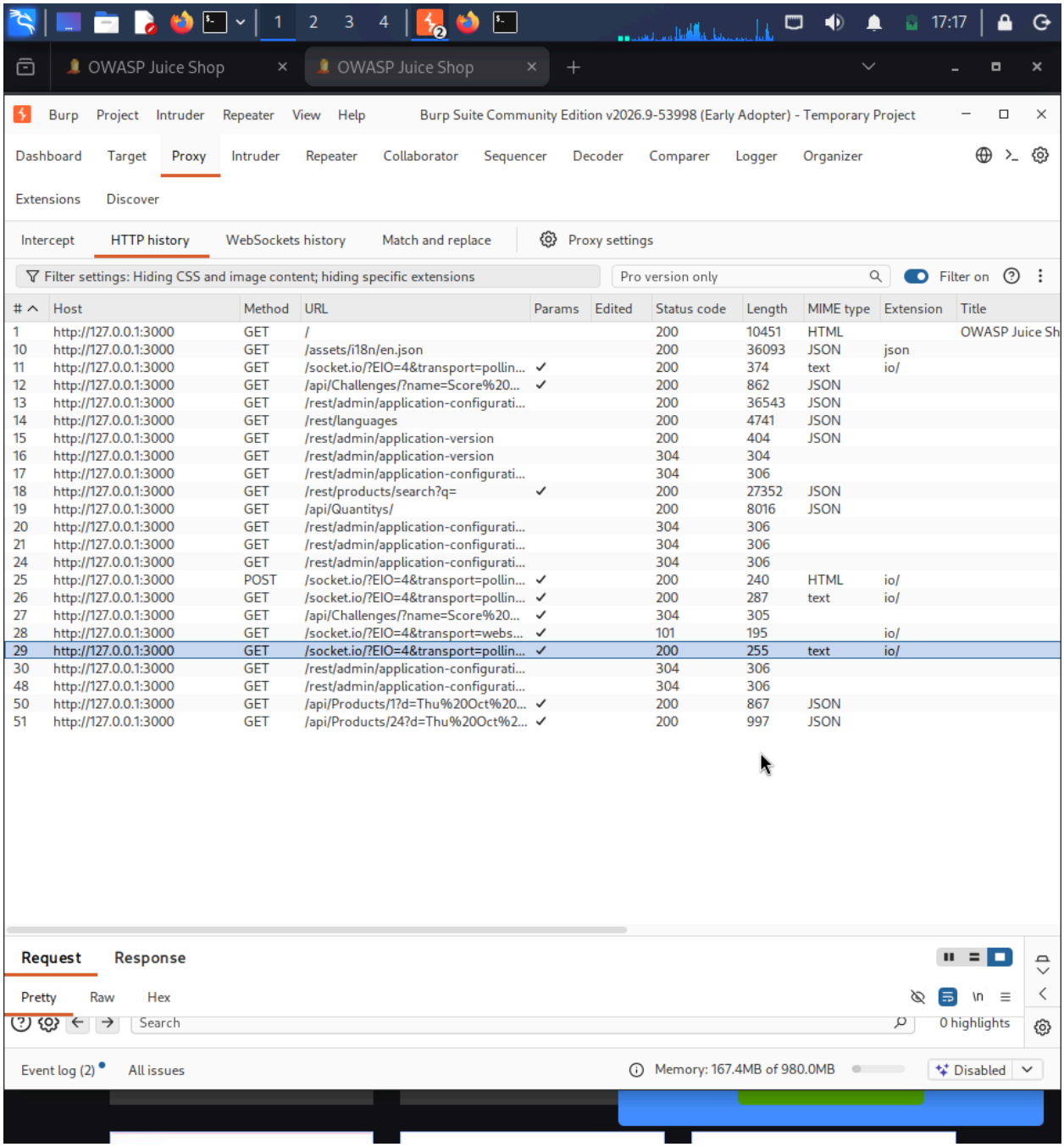

kali@kali: ~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment
Session Actions Edit View Help
┌──(kali㉿kali)-[~]
└─$ mkdir -p ~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment/{report,screenshots,results}
cd ~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ pwd
find . -maxdepth 2 -type d | sort
/home/kali/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment
.
./report
./results
./screenshots
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ script -a commands.txt
Script started, output log file is 'commands.txt'.
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Project_4_Basic_Web_Vulnerability_Assessment]
└─$ sudo apt update
sudo apt install -y curl wget nikto docker.io burpsuite firefox-esr
[sudo] password for kali:
Hit:1 http://http.kali.org/kali kali-rolling InRelease
215 packages can be upgraded. Run 'apt list --upgradable' to see them.
curl is already the newest version (8.22.0-1).
wget is already the newest version (1.25.0-3).
nikto is already the newest version (1:2.6.1-0kali1).
nikto set to manually installed.
burpsuite is already the newest version (2026.9-0kali1).
burpsuite set to manually installed.
The following packages were automatically installed and are no longer required:
bluez-hcidump libimath-3-1-29t64 libpoppler156 python3-mitmproxy-wireguard
firmware-marvell-prestera libjim0.83 libpython3.13 python3.13
libabsl20260107 libkmlbase1t64 libpython3.13-dev python3.13-dev
libavfilter11 libkmldom1t64 libpython3.13-minimal python3.13-minimal
libbluray3 libkmlengine1t64 libpython3.13-stdlib python3.13-tk
libconfig++11 libmupdf27.0 libsimdutf33 python3.13-venv
libconfig11 libntfs-3g89t64 libvidstab1.1 rpcsvc-proto
libgeos3.14.1 libobjc-15-dev libx265-215
libhdf5-310 libopenjph0.27 openssh-client-gssapi
libhdf5-hl-310 libperl5.40 perl-modules-5.40
Use 'sudo apt autoremove' to remove them.
Upgrading:
firefox-esr
Installing:
docker.io
Installing dependencies:
containerd docker-cli libintl-xs-perl libsort-naturally-perl python3-protobuf tini-static
criu libcompel1 libmodule-find-perl libterm-readkey-perl python3-pycriu
docker-buildx libintl-perl libproc-processtable-perl needrestart runc
Suggested packages:
containernetworking-plugins btrfs-progs rinse xfsprogs | zfsutils-linux
docker-doc debootstrap rootlesskit zfs-fuse
Summary:

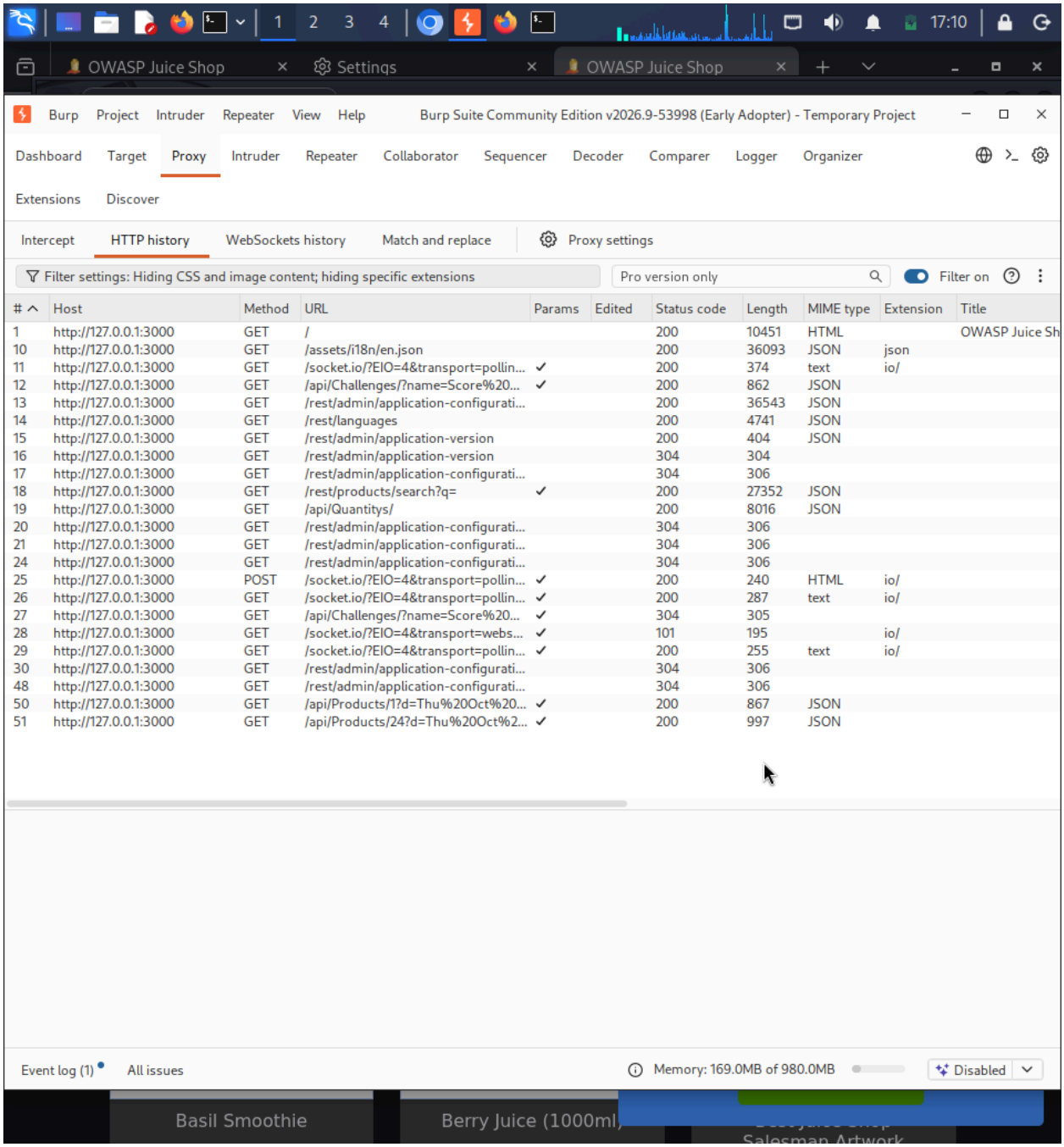

OWASP Juice Shop
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title
100 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 304 306
101 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 304 306
102 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 304 306
103 http://127.0.0.1:3000 GET /api/Challenges/?name=Score%20... ✓ 304 305
104 http://127.0.0.1:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 255 text io/
105 http://127.0.0.1:3000 GET /assets/public/images/products/ap... 304 392 avif
106 http://127.0.0.1:3000 GET /assets/public/images/products/be... 304 392 avif
107 http://127.0.0.1:3000 GET /assets/public/images/products/art... 304 392 avif
108 http://127.0.0.1:3000 GET /assets/public/images/products/ba... 304 392 avif
109 http://127.0.0.1:3000 GET /assets/public/images/products/ba... 304 392 avif
110 http://127.0.0.1:3000 GET /assets/public/images/products/br... 304 392 avif
111 http://127.0.0.1:3000 GET /assets/public/images/products/ap... 304 392 avif
112 http://127.0.0.1:3000 GET /assets/public/images/products/dr... 304 392 avif
113 http://127.0.0.1:3000 GET /assets/public/images/products/car... 304 392 avif
114 http://127.0.0.1:3000 GET /assets/public/images/products/gr... 304 392 avif
Request Response
Pretty Raw Hex
1 GET /assets/public/images/products/berry_juice-1x.avif HTTP/1.1
2 Host: 127.0.0.1:3000
3 sec-ch-ua-platform: "Linux"
4 If-None-Match: W/"1f27-1a13097c458"
5 Accept-Language: en-US,en;q=0.9
6 sec-ch-ua: "Chromium";v="151", "Not=A?Brand";v="99"
7 If-Modified-Since: Mon, 12 Oct 2026 14:50:15 GMT
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
9 sec-ch-ua-mobile: ?0
10 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: no-cors
13 Sec-Fetch-Dest: image
14 Referer: http://127.0.0.1:3000/
15 Accept-Encoding: gzip, deflate, br
16 Cookie: language=en; welcomebanner_status=dismiss
17 Connection: keep-alive
Search
0 highlights
Inspector
Request attributes 2
Request cookies 2
Request headers 16
Response headers 12
Inspector
Notes
Event log (2)
All issues
Memory: 157.2MB of 980.0MB
Disabled
Basil Smoothie
Berry Juice (1000ml
Salesman Artwork

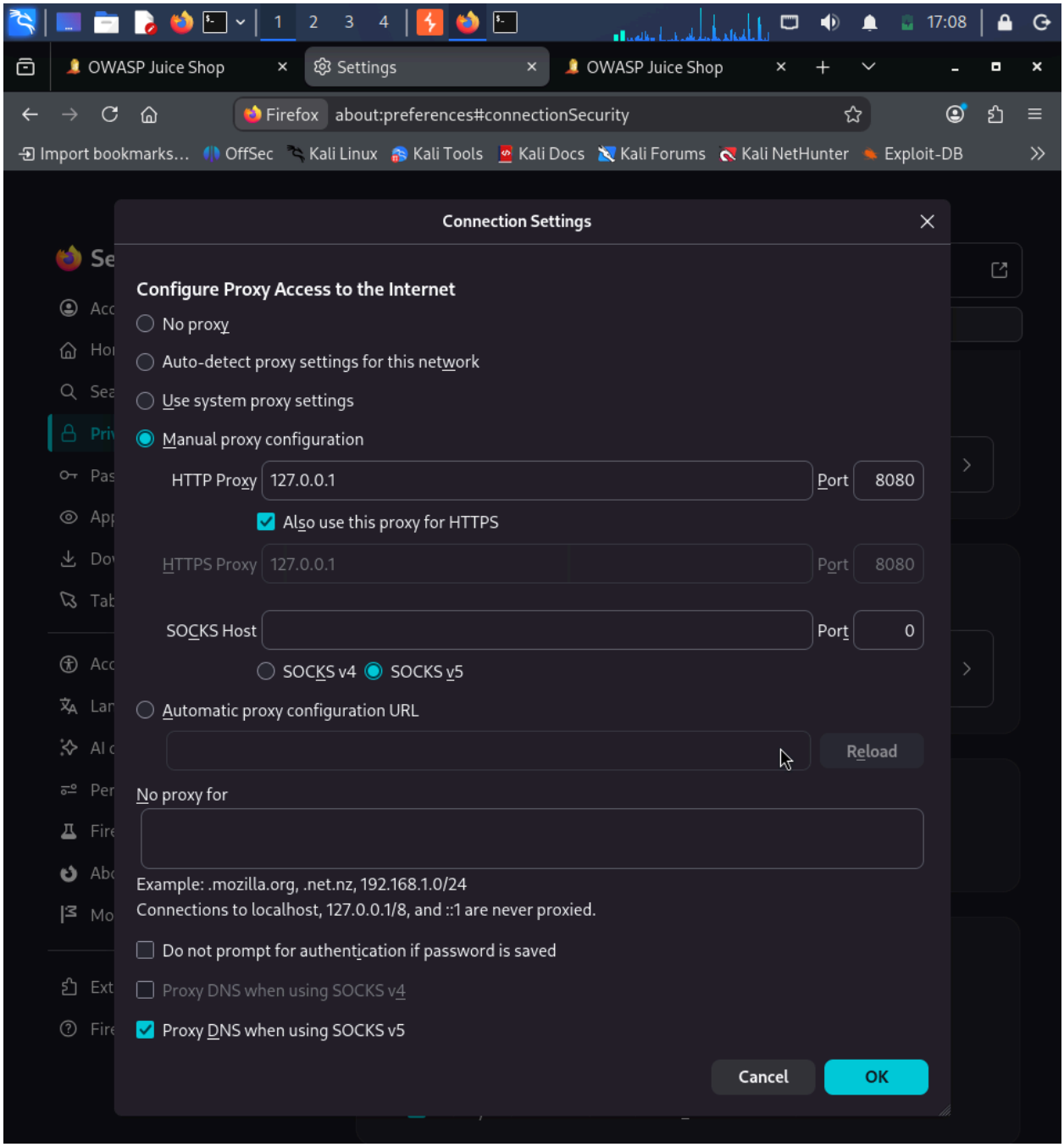

OWASP Juice Shop
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title
100 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 304 306
101 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 304 306
102 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 304 306
103 http://127.0.0.1:3000 GET /api/Challenges/?name=Score%20... ✓ 304 305
104 http://127.0.0.1:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 255 text io/
105 http://127.0.0.1:3000 GET /assets/public/images/products/ap... 304 392 avif
106 http://127.0.0.1:3000 GET /assets/public/images/products/be... 304 392 avif
107 http://127.0.0.1:3000 GET /assets/public/images/products/art... 304 392 avif
108 http://127.0.0.1:3000 GET /assets/public/images/products/ba... 304 392 avif
109 http://127.0.0.1:3000 GET /assets/public/images/products/ba... 304 392 avif
110 http://127.0.0.1:3000 GET /assets/public/images/products/br... 304 392 avif
111 http://127.0.0.1:3000 GET /assets/public/images/products/ap... 304 392 avif
112 http://127.0.0.1:3000 GET /assets/public/images/products/dr... 304 392 avif
113 http://127.0.0.1:3000 GET /assets/public/images/products/car... 304 392 avif
114 http://127.0.0.1:3000 GET /assets/public/images/products/gr... 304 392 avif
Request Response
Pretty Raw Hex
1 GET /assets/public/images/products/berry_juice-1x.avif HTTP/1.1
2 Host: 127.0.0.1:3000
3 sec-ch-ua-platform: "Linux"
4 If-None-Match: W/"1f27-1a13097c458"
5 Accept-Language: en-US,en;q=0.9
6 sec-ch-ua: "Chromium";v="151", "Not=A?Brand";v="99"
7 If-Modified-Since: Mon, 12 Oct 2026 14:50:15 GMT
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
9 sec-ch-ua-mobile: ?0
10 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: no-cors
13 Sec-Fetch-Dest: image
14 Referer: http://127.0.0.1:3000/
15 Accept-Encoding: gzip, deflate, br
16 Cookie: language=en; welcomebanner_status=dismiss
17 Connection: keep-alive
Search
0 highlights
Inspector
Request attributes 2
Request cookies 2
Request headers 16
Response headers 12
Inspector
Notes
Event log (2)
All issues
Memory: 157.2MB of 980.0MB
Disabled
Basil Smoothie
Berry Juice (1000ml
Salesman Artwork

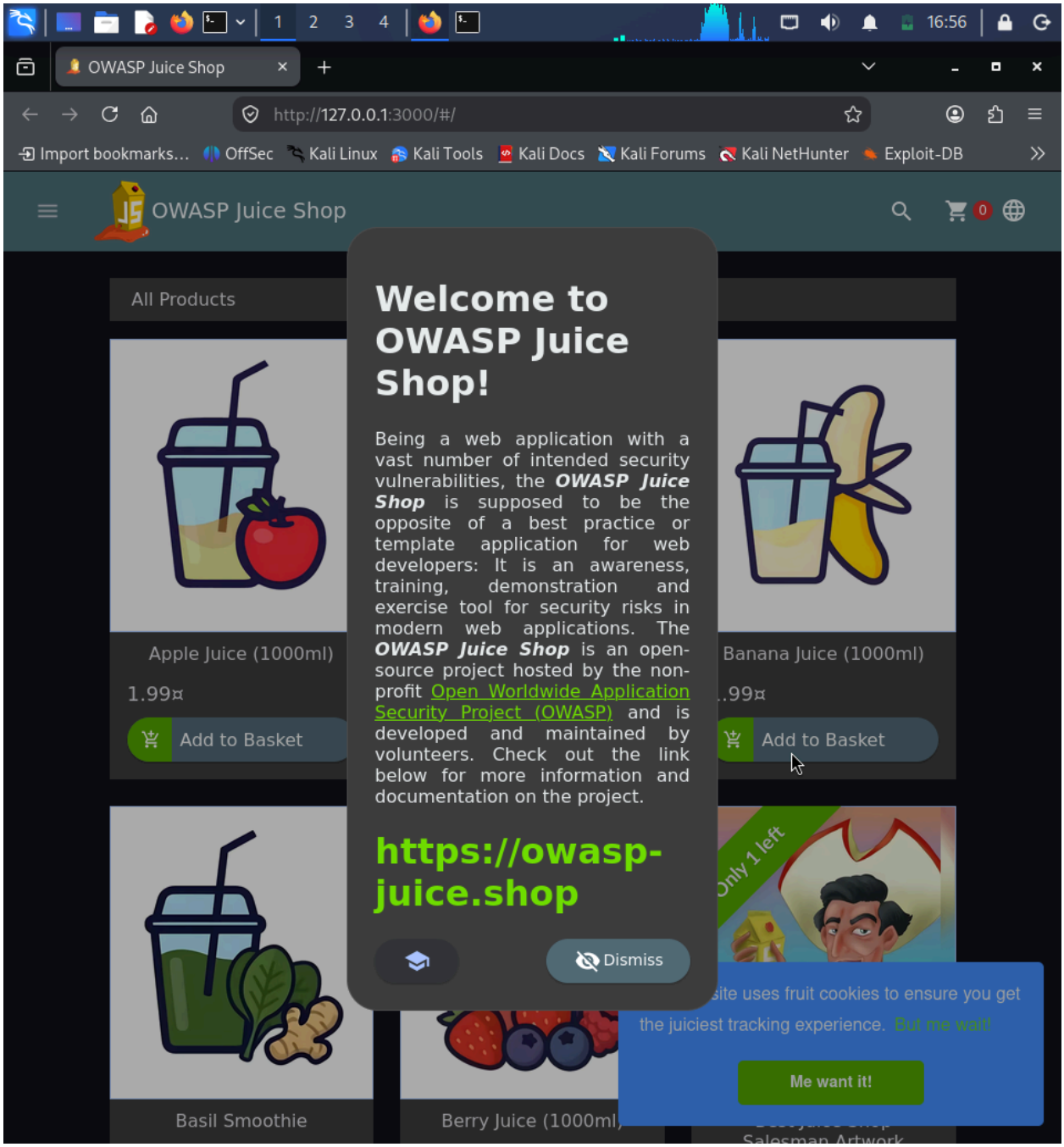

OWASP Juice Shop
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title
100 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 304 306
101 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 304 306
102 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 304 306
103 http://127.0.0.1:3000 GET /api/Challenges/?name=Score%20... ✓ 304 305
104 http://127.0.0.1:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 255 text io/
105 http://127.0.0.1:3000 GET /assets/public/images/products/ap... 304 392 avif
106 http://127.0.0.1:3000 GET /assets/public/images/products/be... 304 392 avif
107 http://127.0.0.1:3000 GET /assets/public/images/products/art... 304 392 avif
108 http://127.0.0.1:3000 GET /assets/public/images/products/ba... 304 392 avif
109 http://127.0.0.1:3000 GET /assets/public/images/products/ba... 304 392 avif
110 http://127.0.0.1:3000 GET /assets/public/images/products/br... 304 392 avif
111 http://127.0.0.1:3000 GET /assets/public/images/products/ap... 304 392 avif
112 http://127.0.0.1:3000 GET /assets/public/images/products/dr... 304 392 avif
113 http://127.0.0.1:3000 GET /assets/public/images/products/car... 304 392 avif
114 http://127.0.0.1:3000 GET /assets/public/images/products/gr... 304 392 avif
115 http://127.0.0.1:3000 GET /assets/public/images/products/eld... 304 392 avif
116 http://127.0.0.1:3000 GET /assets/public/images/products/eg... 304 392 avif
Request Response
Pretty Raw Hex Render
1 HTTP/1.1 304 Not Modified
2 Access-Control-Allow-Origin: *
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Feature-Policy: payment 'self'
6 X-Recruiting: /#/jobs
7 Accept-Ranges: bytes
8 Cache-Control: public, max-age=0
9 Last-Modified: Mon, 12 Oct 2026 14:50:15 GMT
10 ETag: W/"1f27-1a13097c458"
11 Date: Fri, 23 Oct 2026 12:30:06 GMT
12 Connection: keep-alive
13 Keep-Alive: timeout=5
14
15
Search
0 highlights
Inspector
Request attributes 2
Request cookies 2
Request headers 16
Response headers 12
Inspector
Notes
Event log (2)
All issues
Memory: 162.0MB of 980.0MB
Disabled
Basil Smoothie
Berry Juice (1000ml
Salesman Artwork


OWASP Juice Shop
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title
100 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 304 306
101 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 304 306
102 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 304 306
103 http://127.0.0.1:3000 GET /api/Challenges/?name=Score%20... ✓ 304 305
104 http://127.0.0.1:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 255 text io/
105 http://127.0.0.1:3000 GET /assets/public/images/products/ap... 304 392 avif
106 http://127.0.0.1:3000 GET /assets/public/images/products/be... 304 392 avif
107 http://127.0.0.1:3000 GET /assets/public/images/products/art... 304 392 avif
108 http://127.0.0.1:3000 GET /assets/public/images/products/ba... 304 392 avif
109 http://127.0.0.1:3000 GET /assets/public/images/products/ba... 304 392 avif
110 http://127.0.0.1:3000 GET /assets/public/images/products/br... 304 392 avif
111 http://127.0.0.1:3000 GET /assets/public/images/products/ap... 304 392 avif
112 http://127.0.0.1:3000 GET /assets/public/images/products/dr... 304 392 avif
113 http://127.0.0.1:3000 GET /assets/public/images/products/car... 304 392 avif
114 http://127.0.0.1:3000 GET /assets/public/images/products/gr... 304 392 avif
115 http://127.0.0.1:3000 GET /assets/public/images/products/eld... 304 392 avif
116 http://127.0.0.1:3000 GET /assets/public/images/products/eg... 304 392 avif
117 http://127.0.0.1:3000 GET /assets/public/images/products/fru... 304 392 avif
118 http://127.0.0.1:3000 GET /assets/public/images/products/gr... 304 392 avif
119 http://127.0.0.1:3000 GET /assets/public/images/products/pe... 304 392 avif
120 http://127.0.0.1:3000 GET /api/Products/1?d=Fri%20Oct%202... ✓ 200 867 JSON
121 http://127.0.0.1:3000 GET /api/Products/52?d=Fri%20Oct%2... ✓ 200 913 JSON
122 http://127.0.0.1:3000 GET /api/Products/24?d=Fri%20Oct%2... ✓ 200 997 JSON
123 http://127.0.0.1:3000 GET /api/Products/6?d=Fri%20Oct%20... ✓ 200 876 JSON
124 http://127.0.0.1:3000 GET /api/Products/51?d=Fri%20Oct%20... ✓ 200 889 JSON
125 http://127.0.0.1:3000 GET /api/Products/53?d=Fri%20Oct%2... ✓ 200 927 JSON
126 http://127.0.0.1:3000 GET /api/Products/49?d=Fri%20Oct%2... ✓ 200 905 JSON
127 http://127.0.0.1:3000 GET /api/Products/22?d=Fri%20Oct%20... ✓ 200 961 JSON
128 http://127.0.0.1:3000 GET /api/Products/6?d=Fri%20Oct%20... ✓ 304 305
Event log All issues
Memory: 156.7MB of 980.0MB
Disabled
Basil Smoothie
Berry Juice (1000ml
Salesman Artwork


OWASP Juice Shop
OWASP Juice Shop
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title
1 http://127.0.0.1:3000 GET / 200 10451 HTML OWASP Juice Sh
10 http://127.0.0.1:3000 GET /assets/i18n/en.json 200 36093 JSON json
11 http://127.0.0.1:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 374 text io/
12 http://127.0.0.1:3000 GET /api/Challenges/?name=Score%20... ✓ 200 862 JSON
13 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 200 36543 JSON
14 http://127.0.0.1:3000 GET /rest/languages 200 4741 JSON
15 http://127.0.0.1:3000 GET /rest/admin/application-version 200 404 JSON
16 http://127.0.0.1:3000 GET /rest/admin/application-version 304 304
17 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 304 306
18 http://127.0.0.1:3000 GET /rest/products/search?q= ✓ 200 27352 JSON
19 http://127.0.0.1:3000 GET /api/Quantitys/ 200 8016 JSON
20 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 304 306
21 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 304 306
24 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 304 306
25 http://127.0.0.1:3000 POST /socket.io/?EIO=4&transport=pollin... ✓ 200 240 HTML io/
26 http://127.0.0.1:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 287 text io/
27 http://127.0.0.1:3000 GET /api/Challenges/?name=Score%20... ✓ 304 305
28 http://127.0.0.1:3000 GET /socket.io/?EIO=4&transport=webs... ✓ 101 195 io/
29 http://127.0.0.1:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 255 text io/
30 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 304 306
48 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 304 306
50 http://127.0.0.1:3000 GET /api/Products/1?d=Thu%20Oct%20... ✓ 200 867 JSON
51 http://127.0.0.1:3000 GET /api/Products/24?d=Thu%20Oct%2... ✓ 200 997 JSON
Request Response
Pretty Raw Hex
Search
0 highlights
Event log (2) All issues
Memory: 167.4MB of 980.0MB
Disabled


OWASP Juice Shop
Settings
OWASP Juice Shop
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title
1 http://127.0.0.1:3000 GET / 200 10451 HTML OWASP Juice Sh
10 http://127.0.0.1:3000 GET /assets/i18n/en.json 200 36093 JSON json
11 http://127.0.0.1:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 374 text io/
12 http://127.0.0.1:3000 GET /api/Challenges/?name=Score%20... ✓ 200 862 JSON
13 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 200 36543 JSON
14 http://127.0.0.1:3000 GET /rest/languages 200 4741 JSON
15 http://127.0.0.1:3000 GET /rest/admin/application-version 200 404 JSON
16 http://127.0.0.1:3000 GET /rest/admin/application-version 304 304
17 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 304 306
18 http://127.0.0.1:3000 GET /rest/products/search?q= ✓ 200 27352 JSON
19 http://127.0.0.1:3000 GET /api/Quantitys/ 200 8016 JSON
20 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 304 306
21 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 304 306
24 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 304 306
25 http://127.0.0.1:3000 POST /socket.io/?EIO=4&transport=pollin... ✓ 200 240 HTML io/
26 http://127.0.0.1:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 287 text io/
27 http://127.0.0.1:3000 GET /api/Challenges/?name=Score%20... ✓ 304 305
28 http://127.0.0.1:3000 GET /socket.io/?EIO=4&transport=webs... ✓ 101 195 io/
29 http://127.0.0.1:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 255 text io/
30 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 304 306
48 http://127.0.0.1:3000 GET /rest/admin/application-configurati... 304 306
50 http://127.0.0.1:3000 GET /api/Products/1?d=Thu%20Oct%20... ✓ 200 867 JSON
51 http://127.0.0.1:3000 GET /api/Products/24?d=Thu%20Oct%2... ✓ 200 997 JSON
Event log (1)
All issues
Memory: 169.0MB of 980.0MB
Disabled
Basil Smoothie
Berry Juice (1000ml)


OWASP Juice Shop
Settings
OWASP Juice Shop
Firefox about:preferences#connectionSecurity
Import bookmarks...
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Connection Settings
Configure Proxy Access to the Internet
No proxy
Auto-detect proxy settings for this network
Use system proxy settings
Manual proxy configuration
HTTP Proxy 127.0.0.1
Port 8080
Also use this proxy for HTTPS
HTTPS Proxy 127.0.0.1
Port 8080
SOCKS Host
Port 0
SOCKS v4
SOCKS v5
Automatic proxy configuration URL
Reload
No proxy for
Example: .mozilla.org, .net.nz, 192.168.1.0/24
Connections to localhost, 127.0.0.1/8, and ::1 are never proxied.
Do not prompt for authentication if password is saved
Proxy DNS when using SOCKS v4
Proxy DNS when using SOCKS v5
Cancel
OK



OWASP Juice Shop Security Assessment

Intern Details

Name: Shaurya Gupta
Email: shauryagupta0106@gmail.com
Reference Number: CSN-OC-OL-26194

Registration Number: CSN-OC-2026-194
Domain: Cyber Security
Project Level: Intermediate
Project Number: 1
Internship Month/Year: October 2026

---

1. Project Description

The objective of this project was to conduct a practical web application security assessment of OWASP Juice Shop, an intentionally vulnerable web application designed for security education and authorized penetration-testing practice.

The assessment focused on exploring common web application security risks, observing how the application processes user input, examining authentication behaviour, inspecting HTTP requests and responses, and reviewing the application's publicly accessible information.

The primary investigation areas were:

1. Cross-Site Scripting (XSS)
2. Broken Access Control
3. Authentication Weaknesses
4. Injection and SQL Injection
5. Sensitive Information Exposure

Web application security testing is important because modern applications handle user accounts, personal information, transactions, and other potentially sensitive data. Security weaknesses in input handling, authentication, authorization, and information disclosure can expose applications to unauthorized access, data manipulation, or other security incidents.

Manual testing combined with HTTP traffic inspection helps identify unexpected application behaviour and provides evidence for evaluating whether a security weakness exists.

The project also provided practical experience with Kali Linux, Firefox, Burp Suite Community Edition, HTTP request analysis, evidence collection, and technical security reporting.

The assessment was performed as a training exercise against the local Juice Shop instance documented in the supplied screenshots.

---

2. Scope and Methodology

2.1 Assessment Scope

Target application: OWASP Juice Shop
Target URL documented in evidence: `http://localhost:3000`
Assessment type: Authorized security assessment of a local training application
Testing approach: Manual application exploration and HTTP request inspection

The original project template references `https://demo.owasp-juice.shop/`. However, the screenshots previously reviewed show the local application at `http://localhost:3000`. Therefore, this report documents the local environment. The external demo is not represented as having been tested.

2.2 Tools Used

Tool	Purpose
Kali Linux	Security testing environment
Mozilla Firefox	Accessing and interacting with the web application
Burp Suite Community Edition	Intercepting and inspecting HTTP requests and responses
OWASP Juice Shop	Intentionally vulnerable application used for testing
Terminal utilities	Checking application connectivity and supporting troubleshooting
Screenshots	Recording observed application behaviour and supporting findings

2.3 Testing Methodology

The assessment followed a manual testing process.

Step 1: Application access

The Juice Shop application was opened in Firefox. The local application address was used for the tests documented in the screenshots.

Step 2: Proxy configuration

Burp Suite was configured to use a local proxy listener at `127.0.0.1:8080`, and Firefox was configured to route browser traffic through the proxy.

Step 3: Application exploration

The login interface, product search functionality, shopping basket, About Us page, and Privacy Policy page were examined.

Step 4: HTTP traffic inspection

Burp Suite HTTP history was used to inspect browser-generated requests and corresponding responses.

Step 5: Security investigation

The application was examined for potential XSS, authorization weaknesses, authentication problems, injection issues, and sensitive information exposure.

Step 6: Evidence collection

Screenshots were collected to document the observed behaviour, relevant application interfaces, and HTTP traffic.

Step 7: Finding assessment

Each investigation was evaluated according to the available evidence. An attempted test was not treated as a confirmed vulnerability unless the observed behaviour supported the claim.

2.4 Scope Limitations

The assessment was limited to the functionality and evidence documented in the supplied screenshots. No claim is made that every endpoint, application component, or security control was exhaustively tested.

No destructive testing, production-system exploitation, or unauthorized access to another user's private information is claimed.

---

3. Implementation Details

3.1 Environment Setup

The assessment environment consisted of Kali Linux running in a virtualized environment, with Firefox used to access OWASP Juice Shop and Burp Suite Community Edition used for HTTP inspection.

The application address documented in the evidence was:

`http://localhost:3000`

This address refers to a local application instance. The assessment report therefore distinguishes the local instance from the separately hosted public demo.

3.2 Burp Suite Configuration

Burp Suite Community Edition was opened and configured using its default settings.

The intended proxy listener configuration was:

- Interface: `127.0.0.1`
- Port: `8080`
- Browser: Firefox running in Kali Linux

Firefox was configured to use the local Burp proxy. The Proxy Intercept feature was switched off during ordinary browsing so that requests could pass through without requiring manual forwarding.

The HTTP history interface was then used to inspect requests generated by the browser.

The supplied screenshots document HTTP history and selected requests. This report does not claim that every request was captured or that every HTTPS response was successfully decrypted.

3.3 Cross-Site Scripting Investigation

The product search feature was examined using ordinary search text and crafted test input.

The supplied screenshot `screenshots/02.png` documents a normal search interaction. `screenshots/03.png` documents the crafted search input and resulting search interaction. `screenshots/06.png` shows a browser alert displaying `xss`.

The alert is consistent with JavaScript execution in the tested application. This is the strongest potential vulnerability evidence in the supplied material.

The exact XSS subtype and execution path should be verified before final classification. The screenshot does not, by itself, demonstrate credential theft, session compromise, or impact on another user.

3.4 Broken Access Control Investigation

The shopping basket functionality was examined to observe the application's handling of basket data and related interface controls.

The supplied screenshots `screenshots/08.png` and `screenshots/09.png` document the basket interface and product entries.

The evidence demonstrates normal basket functionality. It does not establish that the application permitted unauthorized access to another user's basket or other protected resources.

3.5 Authentication Investigation

The login interface was examined using test inputs and unsuccessful authentication attempts.

Screenshots `screenshots/11.png`, `screenshots/12.png`, and `screenshots/14.png` through `screenshots/17.png` document the login interface and input states.

Related request and response evidence appears in `screenshots/13.png`, `screenshots/18.png`, and other Burp Suite screenshots.

The observed errors and failed-login behaviour were recorded. The available evidence does not establish successful authentication bypass, account compromise, or ineffective rate limiting.

3.6 Injection Investigation

The login input-handling investigation included a single-quote test and comparison with ordinary failed-login behaviour.

The purpose was to observe whether unusual input produced evidence of unsafe query processing or unexpected authentication behaviour.

The screenshots document unusual input and application errors. However, the supplied evidence does not establish that a database query was altered, that SQL injection occurred, or that authentication was bypassed.

3.7 Information Exposure Investigation

Public application information was reviewed through the About Us and Privacy Policy pages.

The supplied screenshots `screenshots/19.png` and `screenshots/21.png` document these pages. Related traffic is shown in `screenshots/20.png`.

The visible information was reviewed for evidence of sensitive data exposure. The screenshots do not demonstrate disclosure of credentials, authentication tokens, or private customer information.

3.8 Evidence Collection

The evidence was supplied as a ZIP archive containing screenshots. The filenames cited in this report refer to the screenshots as described in the previous evidence review.

Before external submission, screenshots should be checked for visible passwords, session cookies, authorization tokens, or other secrets. Sensitive values must be redacted without changing the underlying security evidence.

---

4. Findings Summary

The following table summarizes the five investigation areas. Only the XSS investigation produced evidence consistent with a security vulnerability. The other four areas remain unconfirmed.

ID	Finding or Investigation	Severity	Affected Feature	Evidence	Status	Recommended Action
F-01	JavaScript execution through search input	Medium, provisional	Product search	`screenshots/02.png`, `screenshots/03.png`, `screenshots/06.png`	Apparent XSS demonstrated; confirm exact execution path	Context-aware output encoding and safe DOM handling
F-02	Broken access control	Not assigned	Shopping basket	`screenshots/08.png`, `screensh`	Not confirmed	Verify server-side authorization and

ID	Finding or Investigation	Severity	Affected Feature	Evidence	Status	Recommended Action
				ots/09.png, screenshots/10.png		resource ownership
F-03	Authentication weakness	Not assigned	Login interface	screenshots/11.png, screenshots/12.png, screenshots/13.png, screenshots/17.png	Not confirmed	Review password verification, rate limiting, and session handling
F-04	Injection and SQL injection	Not assigned	Login input processing	screenshots/13.png, screenshots/17.png, screenshots/18.png, screenshots/22.png	Not confirmed	Verify safe query construction and investigate with a documented challenge
F-05	Sensitive information exposure	Not assigned	Public information pages	screenshots/19.png,	Not confirmed	Review public responses and restrict

ID	Finding or Investigation	Severity	Affected Feature	Evidence	Status	Recommended Action
				`screenshots/20.png`, `screenshots/21.png`		sensitive information

Confirmed-finding count: Zero formally verified findings based on a complete, reproducible technical validation process.

Apparent vulnerability requiring further verification: One XSS finding.

Other investigation areas not confirmed: Four.

The XSS evidence is consistent with script execution in the local training application. It is retained as a provisional finding pending confirmation of the exact execution path and reproducibility.

---

5. Detailed Findings

5.1 Finding F-01: Potential Cross-Site Scripting Through Search

Title: JavaScript execution associated with crafted search input

Category: Cross-Site Scripting (XSS)

Affected feature: Product search

Target: `http://localhost:3000`

Preconditions:

- The local OWASP Juice Shop application is accessible.
- The tester can interact with the product search field.
- Firefox can display the application response.

Steps performed:

1. Opened the Juice Shop homepage.
2. Entered ordinary search text and observed the result.
3. Entered crafted HTML/JavaScript input into the search field.
4. Observed the browser's behaviour.
5. Reviewed the related application traffic and screenshots.

Expected behaviour:

User-supplied search input should be treated as data and rendered safely. It should not be interpreted as executable script.

Actual observed behaviour:

The screenshot `screenshots/06.png` shows a browser alert displaying `xss` associated with the local Juice Shop application. This is consistent with JavaScript execution during the XSS investigation.

The available evidence does not independently establish the precise execution path, whether the issue is DOM-based or reflected, or whether an attacker could reliably exploit the behaviour against another user's session.

Security impact:

If the behaviour is reproducible and exploitable through an application-accessible input, an attacker may be able to execute JavaScript in the application's origin.

Depending on the affected context and security controls, possible consequences include unauthorized page manipulation, deceptive interface content, phishing, or access to information available to the injected script.

No evidence demonstrates that credentials were stolen, session tokens were compromised, or another user's account was affected.

Severity and justification:

Provisional severity: Medium.

This provisional rating reflects the apparent script execution and potential consequences of an XSS vulnerability. A formal severity rating requires confirmation of the execution context, exploitability, affected users, and demonstrated impact.

Evidence screenshots:

- `screenshots/02.png`: Normal search interaction.
- `screenshots/03.png`: Crafted search input and search result.
- `screenshots/06.png`: Browser alert displaying `xss`.
- `screenshots/01.png`: Burp Suite HTTP history.

Recommended mitigation:

1. Apply context-aware output encoding.
2. Avoid unsafe DOM APIs that interpret untrusted input as HTML or JavaScript.
3. Use safe DOM methods such as `textContent` where appropriate.
4. Sanitize HTML only when HTML rendering is necessary, using a maintained sanitizer.
5. Implement a restrictive Content Security Policy as defence in depth.
6. Add regression tests to verify that crafted search input is rendered safely.

Verification and retest result:

The supplied evidence documents the browser alert but does not contain a complete remediation and retest cycle.

A retest should repeat the original input after remediation and verify that it is displayed safely without executing script.

Status: Provisional. Apparent XSS behaviour documented; exact execution path and reproducibility require verification.

5.2 Finding F-02: Broken Access Control Investigation

Title: Authorization enforcement for basket resources

Category: Broken Access Control

Affected feature: Shopping basket

Preconditions:

- The Juice Shop application is accessible.
- The tester can access the basket interface.
- A test account and test data are available where required.

Steps performed:

1. Opened the application in Firefox.

2. Navigated to the basket.
3. Observed the displayed products and available controls.
4. Reviewed related HTTP traffic.

Expected behaviour:

The server should verify that each user is authorized to view or modify the requested resource. Access to another user's basket must not be granted solely because a request contains a particular resource identifier.

Actual observed behaviour:

The supplied screenshots show basket entries and normal basket functionality.

No successful unauthorized access to another user's data, cross-account basket modification, or other authorization bypass is demonstrated.

Security impact:

No security impact from a broken access-control flaw has been established by the supplied evidence.

If a resource-level authorization failure were confirmed, possible consequences could include exposure of private basket information or unauthorized modification of another user's data.

Severity and justification:

Not assigned because the required security failure has not been demonstrated.

Evidence screenshots:

- `screenshots/08.png`: Basket interface and product entries.
- `screenshots/09.png`: Basket view.
- `screenshots/10.png`: Related HTTP traffic.

Recommended mitigation:

- Enforce authorization on the server for each protected request.
- Validate resource ownership before returning or modifying data.
- Do not rely solely on client-side controls.
- Add automated tests for unauthorized cross-account access.

Verification and retest result:

No confirmed access-control failure or remediation retest is documented.

Status: Not confirmed. Additional authorized testing is required.

5.3 Finding F-03: Authentication Weakness Investigation

Title: Login failure handling and authentication controls

Category: Authentication

Affected feature: Login interface and authentication processing

Preconditions:

- The application login page is accessible.
- A test account or deliberately invalid credentials can be used.
- Burp Suite can inspect browser-generated requests.

Steps performed:

1. Opened the login interface.
2. Submitted authentication attempts using test input.
3. Observed the application's response to unsuccessful attempts.
4. Reviewed the related request and response evidence.

Expected behaviour:

Invalid credentials should not result in an authenticated session. Authentication controls should handle errors safely, protect passwords, and implement appropriate protections against automated guessing.

Actual observed behaviour:

The screenshots document the login form, unsuccessful authentication behaviour, and related HTTP traffic.

The supplied evidence does not establish successful authentication with invalid credentials, a session being granted without authentication, or the absence of effective rate limiting.

Security impact:

No authentication compromise has been demonstrated.

A confirmed authentication weakness could potentially enable unauthorized access or increase the risk of password guessing, depending on the weakness and its exploitability.

Severity and justification:

Not assigned because no specific authentication vulnerability has been confirmed.

Evidence screenshots:

- `screenshots/11.png`: Login page.
- `screenshots/12.png`: Login and registration interface.
- `screenshots/13.png`: Authentication request and response evidence.
- `screenshots/17.png`: Login error following unusual input.

Recommended mitigation:

- Use secure password hashing and verification.
- Implement appropriate authentication rate limiting and monitoring.
- Maintain secure session creation, storage, and invalidation.
- Avoid revealing unnecessary internal details in authentication errors.
- Test authentication controls using documented, controlled test cases.

Verification and retest result:

No successful authentication bypass or other specific weakness is established by the supplied evidence.

Status: Not confirmed.

5.4 Finding F-04: Injection and SQL Injection Investigation

Title: Login input handling and potential injection behaviour

Category: Injection

Affected feature: Login input processing

Preconditions:

- The application login form is accessible.
- The tester can submit controlled test input.
- Burp Suite HTTP history is available for request and response inspection.

Steps performed:

1. Submitted a normal failed-login attempt.
2. Submitted another attempt with a single quote in the email field and an incorrect password.
3. Observed the application response.
4. Compared the behaviour with the normal failed-login attempt.
5. Reviewed the relevant HTTP request and response evidence.

Expected behaviour:

Input should be processed safely. Invalid input should not alter the intended database query or authentication logic, and internal implementation details should not be exposed unnecessarily.

Actual observed behaviour:

The supplied screenshots document unusual login input, application errors, and related HTTP traffic.

The available evidence does not demonstrate that the single quote changed a database query, caused an exploitable SQL injection condition, or bypassed authentication.

An ordinary authentication error or malformed-input response is insufficient to establish SQL injection.

Security impact:

No SQL injection vulnerability or related unauthorized database access has been demonstrated.

If injection were confirmed, the impact would depend on the affected query and could include unauthorized data access or modification.

Severity and justification:

Not assigned because the existence and impact of an injection vulnerability have not been established.

Evidence screenshots:

- `screenshots/13.png`: Authentication request and response.
- `screenshots/17.png`: Login error after unusual input.
- `screenshots/18.png`: Burp Suite HTTP history.
- `screenshots/22.png`: Additional HTTP traffic evidence.

Recommended mitigation:

- Use parameterized queries and safe query-building mechanisms.
- Validate input on the server.
- Avoid exposing detailed database errors to users.
- Store diagnostic information in protected server logs.
- Test relevant operations against documented injection challenges appropriate to the application's backend technology.

Verification and retest result:

The supplied evidence does not confirm SQL injection. A further test using an appropriate documented Juice Shop challenge would be required.

Status: Not confirmed.

5.5 Finding F-05: Sensitive Information Exposure Investigation

Title: Review of publicly accessible application information

Category: Sensitive Information Exposure

Affected feature: About Us and Privacy Policy pages

Preconditions:

- The application is accessible through Firefox.
- Public information pages can be viewed.
- Burp Suite HTTP history is available for examining related responses.

Steps performed:

1. Opened the application's public information pages.
2. Reviewed the About Us page.
3. Reviewed the Privacy Policy page.
4. Observed the content presented to the browser.
5. Inspected related HTTP traffic.

Expected behaviour:

Public pages should contain only information intended for public access. Sensitive credentials, private customer information, authentication tokens, and other restricted data should not be disclosed without authorization.

Actual observed behaviour:

The supplied screenshots show the About Us and Privacy Policy pages and related HTTP history.

The available evidence does not demonstrate the exposure of credentials, session tokens, private customer data, or other clearly sensitive information.

Publicly accessible informational text is not automatically a vulnerability.

Security impact:

No sensitive information disclosure has been confirmed.

If restricted information were exposed, potential consequences could include privacy violations, unauthorized access, or misuse of confidential data.

Severity and justification:

Not assigned because no specific sensitive disclosure has been demonstrated.

Evidence screenshots:

- `screenshots/19.png`: About Us page.
- `screenshots/20.png`: Related Burp Suite HTTP history.
- `screenshots/21.png`: Privacy Policy page.

Recommended mitigation:

- Minimize information exposed through public responses.
- Never place credentials or private keys in client-accessible code.
- Restrict sensitive endpoints through server-side authorization.
- Use safe error responses and protect diagnostic logs.
- Review responses for unintended disclosure of private information.

Verification and retest result:

No confirmed sensitive information exposure or remediation retest is documented.

Status: Not confirmed.

---

6. Results

6.1 Summary of Results

The assessment documented manual testing of search functionality, login behaviour, basket functionality, public information pages, and HTTP traffic.

The main observations were:

- A browser alert displaying `xss` was captured during the search-input investigation.
- Normal basket functionality was observed.
- Unsuccessful login attempts and application errors were observed.
- A single-quote input test was performed as a preliminary injection investigation.
- Public About Us and Privacy Policy pages were inspected.
- Burp Suite screenshots documented selected application traffic.
- The supplied scoreboard screenshot showed four solved challenges at the time of capture.

6.2 Investigation Statistics

Metric	Result
Investigation areas documented	5
Formally verified vulnerabilities	0
Apparent XSS findings requiring technical verification	1
Other investigation areas not confirmed	4
Confirmed remediation and retest cycles	0

The distinction between a completed investigation and a confirmed vulnerability is important. A test may be completed without demonstrating a security flaw.

The apparent XSS behaviour is the strongest finding in the supplied evidence. It should be retained as a provisional finding until its execution path and reproducibility are verified.

6.3 Limitations

1. The assessment was limited to the functions and screenshots documented in the supplied evidence.

2. The precise execution path and subtype of the apparent XSS issue were not fully established.
3. Broken access control was not demonstrated through an unauthorized resource-access test.
4. Authentication bypass and ineffective rate limiting were not established.
5. SQL injection was not confirmed by the single-quote input test.
6. Sensitive information exposure was not demonstrated through the public information pages.
7. The scoreboard's solved-challenge count does not independently establish the number of distinct vulnerabilities confirmed.
8. No comprehensive source-code review, automated vulnerability scan, formal CVSS calculation, or remediation retest is claimed.
9. The screenshots document the local target. They do not establish that the external demo website was tested.
10. The assessment should not be considered a comprehensive security certification of the application.

---

7. Summary and Recommendations

7.1 Prioritized Recommendations

Priority 1: Verify and remediate the apparent XSS behaviour

The browser alert is the strongest security signal in the supplied evidence.

Recommended actions:

- Reproduce the original test in the local training application.
- Identify the exact input-handling path responsible for script execution.
- Determine whether the issue is DOM-based, reflected, or another XSS variant.
- Apply context-aware output encoding and safe DOM handling.
- Retest the same input and verify that it no longer executes JavaScript.

The provisional severity should be reassessed after confirming exploitability and impact.

Priority 2: Complete authorization testing

The basket screenshots show ordinary functionality rather than unauthorized access.

Recommended actions:

- Review server-side ownership checks for protected resources.

- Test authorization using separate accounts and controlled test data.
- Verify that one account cannot retrieve or modify another account's resources.
- Record both the request and the observed authorization result.

Priority 3: Review authentication controls

The login tests document unsuccessful authentication attempts but do not establish an authentication vulnerability.

Recommended actions:

- Verify that failed authentication never grants an authenticated session.
- Review password verification and session handling.
- Test appropriate rate limiting using controlled attempts.
- Record any specific weakness only after observing reproducible evidence.

Priority 4: Investigate injection using an appropriate challenge

The single-quote test did not establish SQL injection.

Recommended actions:

- Identify the actual backend processing path for the tested input.
- Use a documented Juice Shop injection challenge.
- Examine the application response and relevant request behaviour.
- Avoid classifying generic errors as SQL injection.
- Apply parameterized queries and safe input processing where applicable.

Priority 5: Continue reviewing information disclosure

The public information pages did not demonstrate sensitive data exposure.

Recommended actions:

- Inspect relevant public responses for unintended sensitive values.
- Verify whether any exposed information is genuinely confidential.
- Check that secrets are not included in client-accessible resources.
- Record the exact exposed data and security impact if a disclosure is found.

7.2 Retesting Strategy

After remediation, each confirmed issue should be retested using the original reproducible steps.

The retest should document:

1. The original test input or request.
2. The application response before remediation.
3. The change applied.
4. The application response after remediation.
5. Evidence showing whether the issue remains reproducible.

A finding should be marked as fixed only when the retest demonstrates that the original security failure no longer occurs.

7.3 General Security Recommendations

- Adopt secure coding practices for user input and output rendering.
- Enforce authorization checks on the server.
- Protect authentication and session-management processes.
- Use safe database query construction.
- Minimize sensitive information in public responses.
- Maintain regression tests for identified security issues.
- Keep technical evidence and findings traceable to reproducible tests.

---

8. Conclusion

This project provided practical experience in assessing a deliberately vulnerable web application using Kali Linux, Firefox, and Burp Suite Community Edition.

The assessment covered search functionality, authentication behaviour, basket operations, input handling, public information pages, and HTTP request inspection.

The strongest security signal in the supplied evidence was a browser alert displaying `xss` during the search-input investigation. This is consistent with JavaScript execution and warrants further technical verification before finalizing the finding's subtype and severity.

The other four investigation areas provided useful testing observations, but the supplied screenshots do not establish additional confirmed vulnerabilities. They therefore remain unconfirmed rather than being reported as successful exploits.

The project reinforced several important principles of web application security testing:

- Security claims must be supported by reproducible evidence.
- A test attempt is not equivalent to a confirmed vulnerability.
- HTTP request inspection helps explain application behaviour but does not independently prove exploitability.
- Severity should be based on demonstrated impact and realistic exploitability.

- Remediation must be verified through retesting.

The assessment demonstrates practical familiarity with manual web application testing, proxy-based HTTP inspection, evidence collection, and structured vulnerability reporting. Further testing and validation would be required to establish additional findings and complete a comprehensive security assessment.

---

9. References

1. **OWASP Juice Shop Project**
   https://owasp.org/www-project-juice-shop/

2. **OWASP Web Security Testing Guide**
   https://owasp.org/www-project-web-security-testing-guide/

3. **OWASP Top 10**
   https://owasp.org/www-project-top-ten/

4. **OWASP Juice Shop Companion Guide**
   https://pwning.owasp-juice.shop/

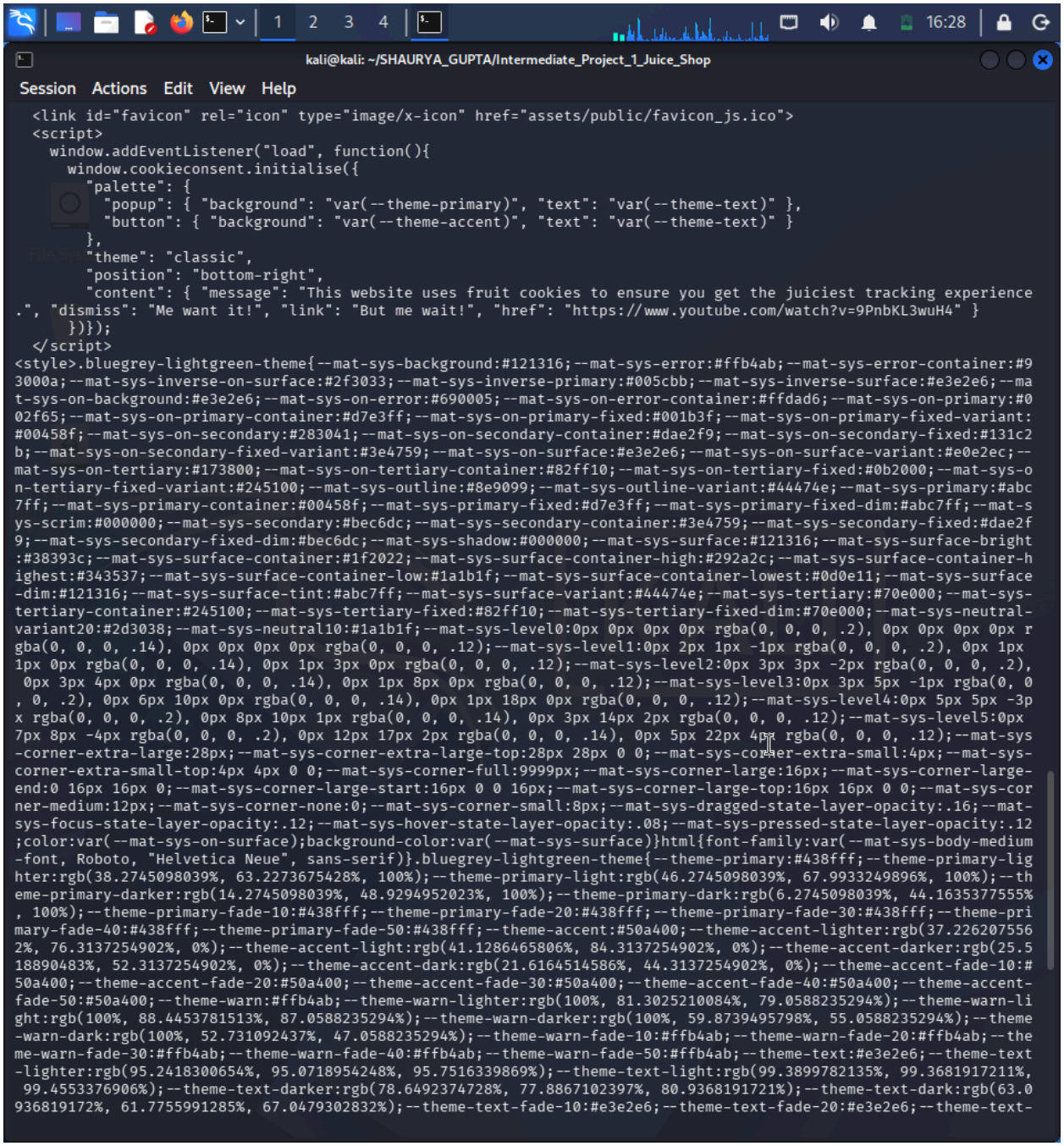
5. **PortSwigger Burp Suite Documentation**
   https://portswigger.net/burp/documentation

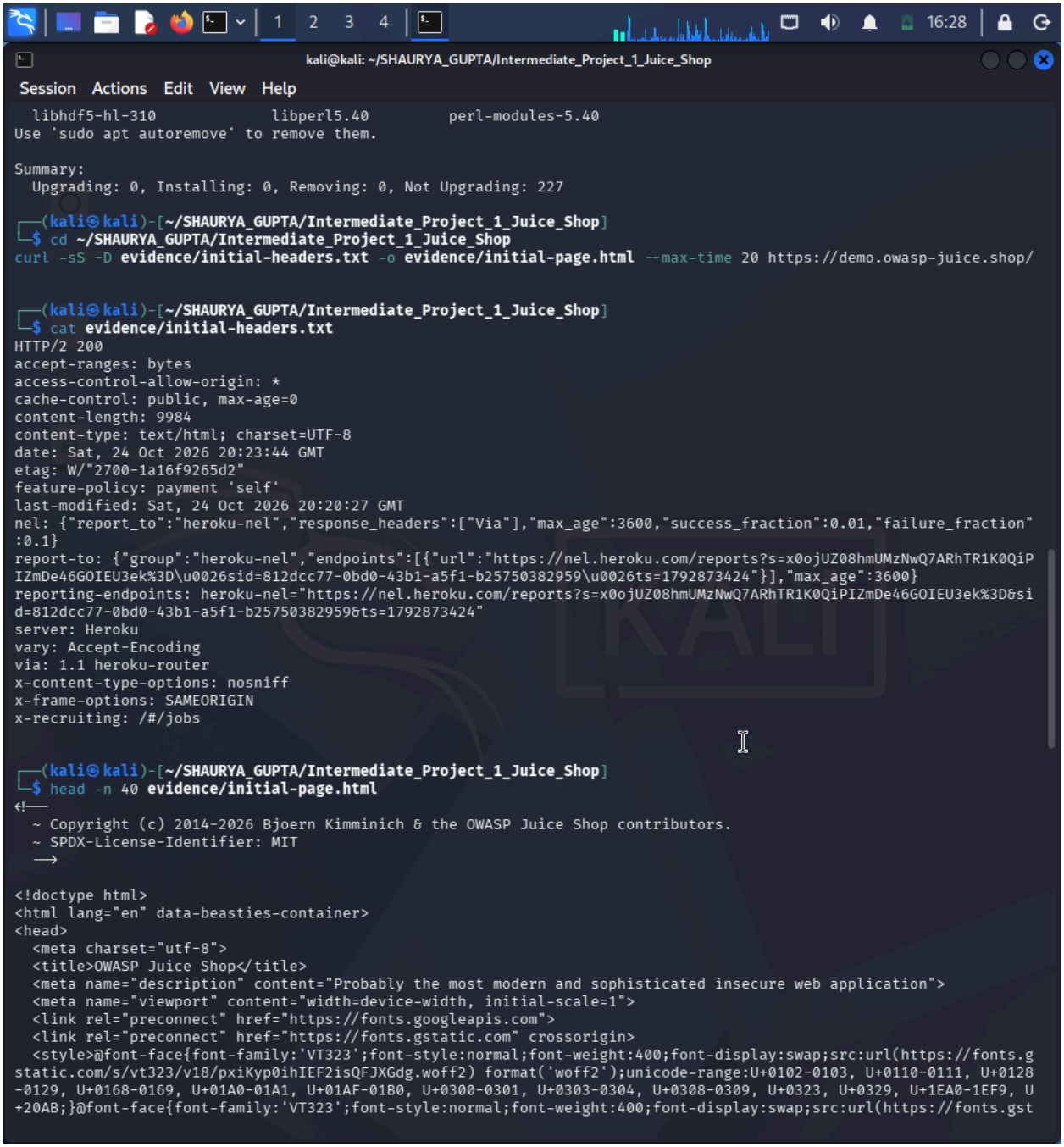
6. **OWASP Cross Site Scripting Prevention Cheat Sheet**
   https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html

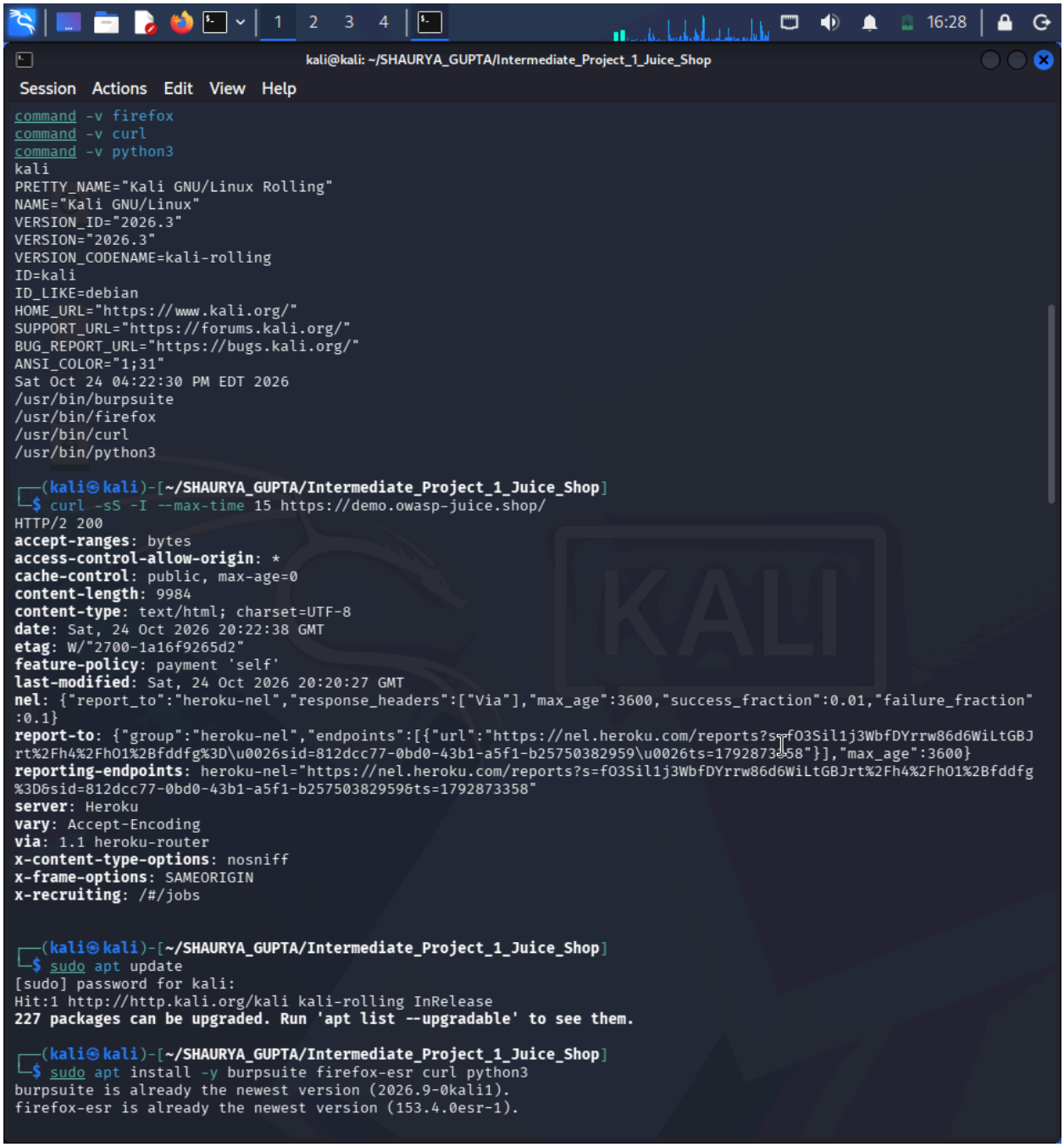
7. **OWASP SQL Injection Prevention Cheat Sheet**
   https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

8. **OWASP Authorization Cheat Sheet**
   https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html

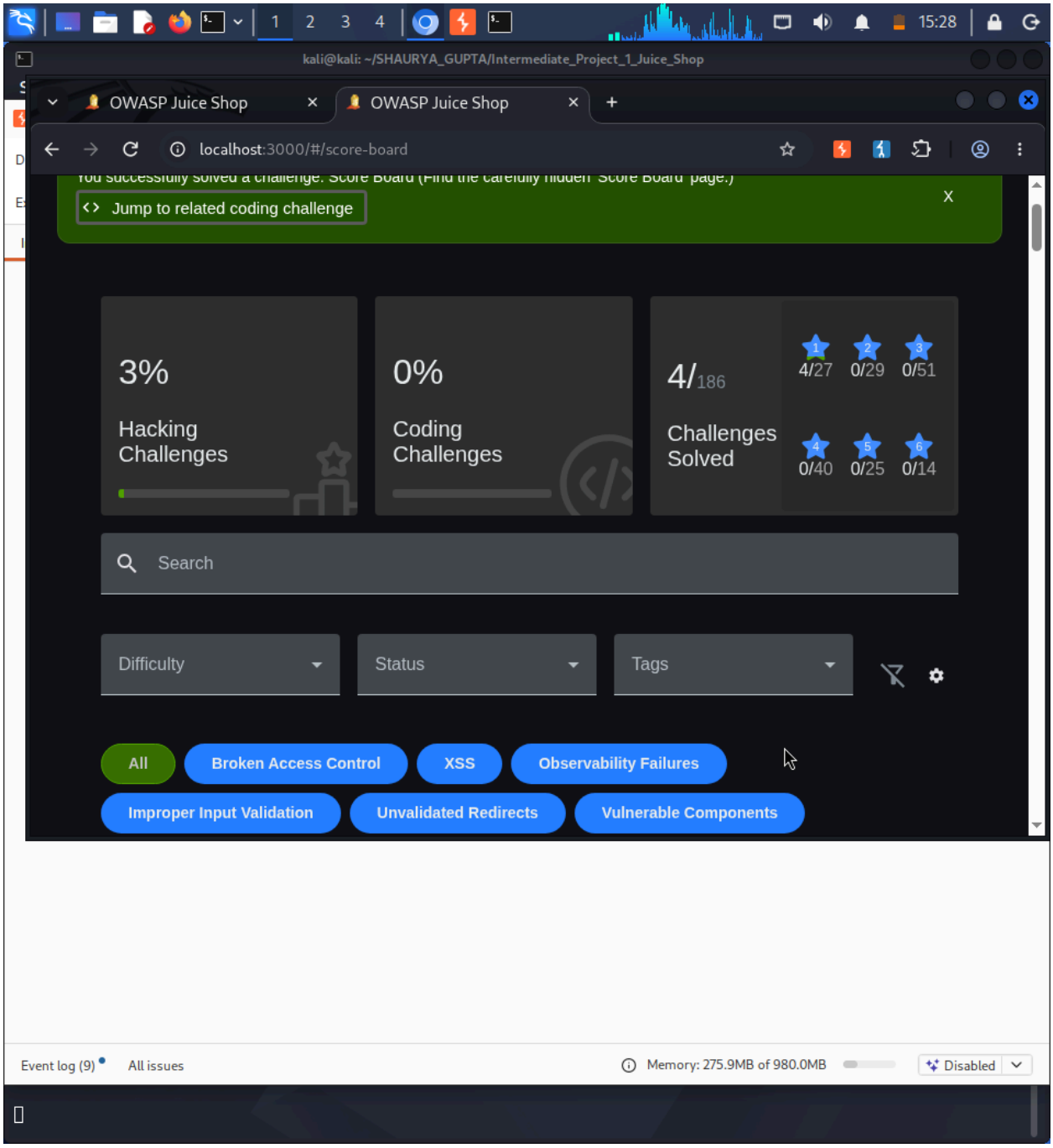
1 2 3 4
16:29
kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Session Actions Edit View Help
ner-medium:12px;--mat-sys-corner-none:0;--mat-sys-corner-small:8px;--mat-sys-dragged-state-layer-opacity:.16;--mat-sys-focus-state-layer-opacity:.12;--mat-sys-hover-state-layer-opacity:.08;--mat-sys-pressed-state-layer-opacity:.12;color:var(--mat-sys-on-surface);background-color:var(--mat-sys-surface)}html{font-family:var(--mat-sys-body-medium-font, Roboto, "Helvetica Neue", sans-serif)}.bluegrey-lightgreen-theme{--theme-primary:#438fff;--theme-primary-lighter:rgb(38.2745098039%, 63.2273675428%, 100%);--theme-primary-light:rgb(46.2745098039%, 67.9933249896%, 100%);--theme-primary-darker:rgb(14.2745098039%, 48.9294952023%, 100%);--theme-primary-dark:rgb(6.2745098039%, 44.1635377555%, 100%);--theme-primary-fade-10:#438fff;--theme-primary-fade-20:#438fff;--theme-primary-fade-30:#438fff;--theme-primary-fade-40:#438fff;--theme-primary-fade-50:#438fff;--theme-accent:#50a400;--theme-accent-lighter:rgb(37.2262075562%, 76.3137254902%, 0%);--theme-accent-light:rgb(41.1286465806%, 84.3137254902%, 0%);--theme-accent-darker:rgb(25.5188890483%, 52.3137254902%, 0%);--theme-accent-dark:rgb(21.6164514586%, 44.3137254902%, 0%);--theme-accent-fade-10:#50a400;--theme-accent-fade-20:#50a400;--theme-accent-fade-30:#50a400;--theme-accent-fade-40:#50a400;--theme-accent-fade-50:#50a400;--theme-warn:#ffb4ab;--theme-warn-lighter:rgb(100%, 81.3025210084%, 79.0588235294%);--theme-warn-light:rgb(100%, 88.4453781513%, 87.0588235294%);--theme-warn-darker:rgb(100%, 59.8739495798%, 55.0588235294%);--theme-warn-dark:rgb(100%, 52.731092437%, 47.0588235294%);--theme-warn-fade-10:#ffb4ab;--theme-warn-fade-20:#ffb4ab;--theme-warn-fade-30:#ffb4ab;--theme-warn-fade-40:#ffb4ab;--theme-warn-fade-50:#ffb4ab;--theme-text:#e3e2e6;--theme-text-lighter:rgb(95.2418300654%, 95.0718954248%, 95.7516339869%);--theme-text-light:rgb(99.3899782135%, 99.3681917211%, 99.4553376906%);--theme-text-darker:rgb(78.6492374728%, 77.8867102397%, 80.9368191721%);--theme-text-dark:rgb(63.0936819172%, 61.7755991285%, 67.0479302832%);--theme-text-fade-10:#e3e2e6;--theme-text-fade-20:#e3e2e6;--theme-text-fade-30:#e3e2e6;--theme-text-fade-40:#e3e2e6;--theme-text-fade-50:#e3e2e6;--theme-text-invert-15:rgb(77.3137254902%, 77.0392156863%, 78.137254902%);--theme-text-invert-30:rgb(65.6078431373%, 65.4509803922%, 66.0784313725%);--theme-background:#1f2022;--theme-background-lighter:rgb(17.8799396682%, 18.4567119155%, 19.6102564103%);--theme-background-light:rgb(21.6953242836%, 22.395173454%, 23.7948717949%);--theme-background-darker:rgb(6.433785822%, 6.6413273002%, 7.0564102564%);--theme-background-dark:rgb(2.6184012066%, 2.7028657617%, 2.8717948718%);--theme-background-darkest:hsl(220, 4.6153846154%, -1.2549019608%);--theme-thumbnail-border:1px solid #abc7ff;--mdc-filled-text-field-container-color:#0000;--mdc-filled-text-field-disabled-container-color:#0000;--theme-background:#3e3e3e;--theme-background-lighter:#4a4a4a;--theme-background-light:#5a5a5a;--theme-background-darker:#333638;--theme-background-dark:#303030;--theme-background-darkest:#2b2b2b;--theme-text:#e8ecef;--theme-text-lighter:#f2f5f7;--theme-text-light:#fff;--theme-text-darker:#b8c0c7;--theme-text-dark:#7f8a93;--mat-sys-surface:#333638;--mat-sys-on-surface:#e8ecef;--mat-sys-surface-container:#3e3e3e;--mat-sys-surface-container-high:#404244;--mat-sys-on-surface-variant:#b8c0c7;--mat-sys-outline:#5a5a5a;--mat-sys-outline-variant:#404244}.bluegrey-lightgreen-theme{--theme-warn:#f44336;--theme-warn-lighter:rgb(96.3089160192%, 36.9160192379%, 32.5538290788%);--theme-warn-light:rgb(96.7240103589%, 44.0103588605%, 40.1387347392%);--theme-warn-darker:rgb(95.0636330004%, 15.63300037%, 9.7991120977%);--theme-warn-dark:rgb(91.8368479467%, 10.9655937847%, 5.0258971513%);--theme-warn-fade-10:#f44336;--theme-warn-fade-20:#f44336;--theme-warn-fade-30:#f44336;--theme-warn-fade-40:#f44336;--theme-warn-fade-50:#f44336;--mat-sys-error:#f44336;--mat-sys-on-error:#fff}@media screen and (-webkit-min-device-pixel-ratio:0){}</style><link rel="stylesheet" href="styles.css" media="print" data-beasties-media="all"><noscript><link rel="stylesheet" href="styles.css"></noscript></head>
<body class="bluegrey-lightgreen-theme">
<app-root></app-root>
<link rel="modulepreload" href="rolldown-runtime-BoHGiXSq.js"><link rel="modulepreload" href="chunk-DBPdFzgj.js"><link rel="modulepreload" href="chunk-Cv2YgWUq.js"><link rel="modulepreload" href="chunk-1qQQGal7.js"><script src="polyfills.js" type="module"></script><script src="scripts.js" defer></script><script src="main.js" type="module"></script><script>document.querySelectorAll('link[data-beasties-media]').forEach(function(l){l.media=l.getAttribute('data-beasties-media');l.removeAttribute('data-beasties-media')})</script></body>
</html>
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop]
└─$ date -Is | tee -a notes/observations.txt
printf '%s\n' 'Baseline request completed. Review saved headers and page response.' | tee -a notes/observations.txt
2026-10-24T16:24:09-04:00
Baseline request completed. Review saved headers and page response.
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop]
└─$ burpsuite
[warning] /usr/bin/burpsuite: No JAVA_CMD set for run_java, falling back to JAVA_CMD = java
^C

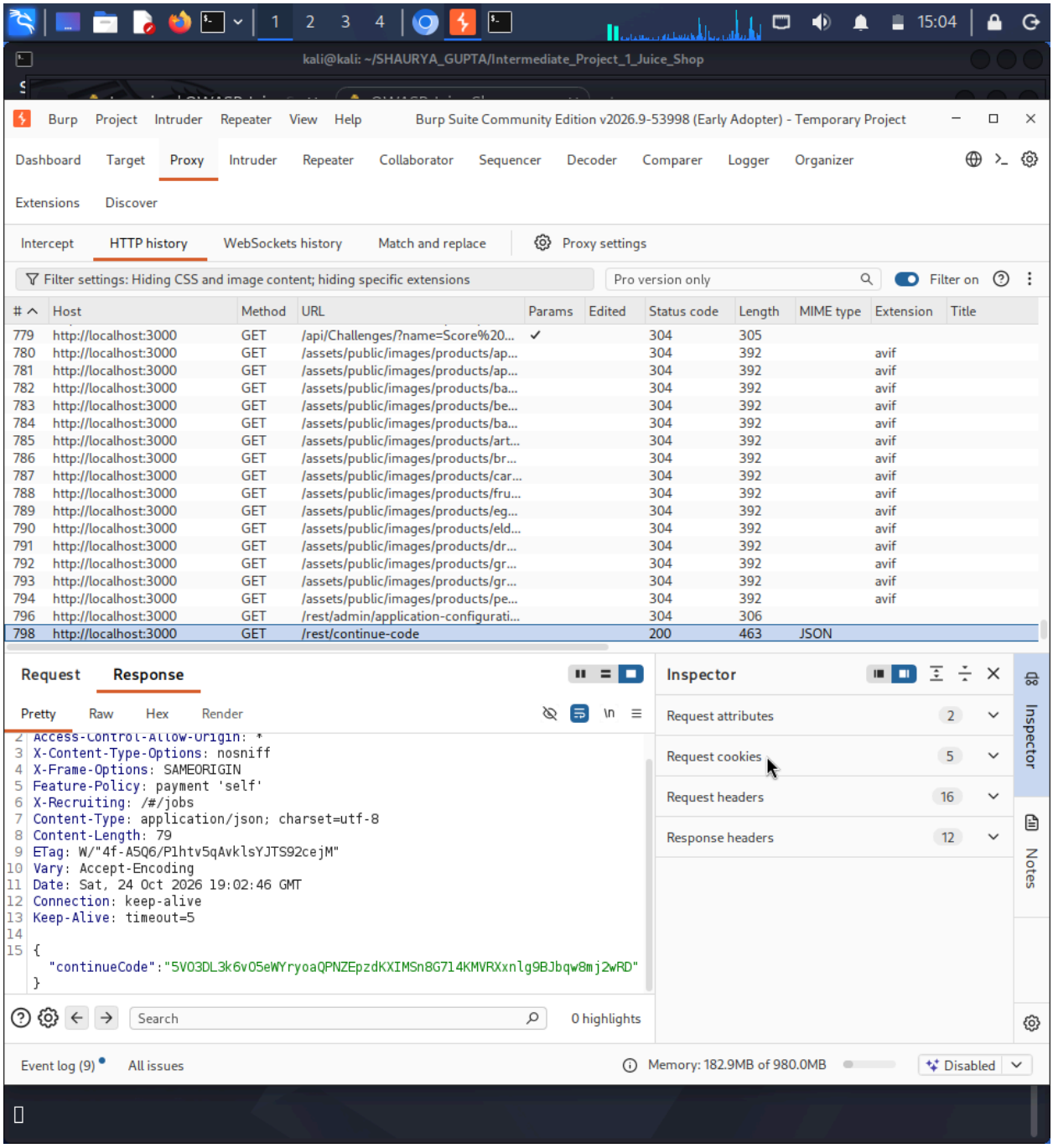

1 2 3 4
16:28
kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Session Actions Edit View Help
<link id="favicon" rel="icon" type="image/x-icon" href="assets/public/favicon_js.ico">
<script>
window.addEventListener("load", function(){
window.cookieconsent.initialise({
"palette": {
"popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" },
"button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" }
},
"theme": "classic",
"position": "bottom-right",
"content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking experience
.", "dismiss": "Me want it!", "link": "But me wait!", "href": "https://www.youtube.com/watch?v=9PnbKL3wuH4" }
})});
</script>
<style>.bluegrey-lightgreen-theme{--mat-sys-background:#121316;--mat-sys-error:#ffb4ab;--mat-sys-error-container:#9
3000a;--mat-sys-inverse-on-surface:#2f3033;--mat-sys-inverse-primary:#005cbb;--mat-sys-inverse-surface:#e3e2e6;--ma
t-sys-on-background:#e3e2e6;--mat-sys-on-error:#690005;--mat-sys-on-error-container:#ffdad6;--mat-sys-on-primary:#0
02f65;--mat-sys-on-primary-container:#d7e3ff;--mat-sys-on-primary-fixed:#001b3f;--mat-sys-on-primary-fixed-variant:
#00458f;--mat-sys-on-secondary:#283041;--mat-sys-on-secondary-container:#dae2f9;--mat-sys-on-secondary-fixed:#131c2
b;--mat-sys-on-secondary-fixed-variant:#3e4759;--mat-sys-on-surface:#e3e2e6;--mat-sys-on-surface-variant:#e0e2ec;--
mat-sys-on-tertiary:#173800;--mat-sys-on-tertiary-container:#82ff10;--mat-sys-on-tertiary-fixed:#0b2000;--mat-sys-o
n-tertiary-fixed-variant:#245100;--mat-sys-outline:#8e9099;--mat-sys-outline-variant:#44474e;--mat-sys-primary:#abc
7ff;--mat-sys-primary-container:#00458f;--mat-sys-primary-fixed:#d7e3ff;--mat-sys-primary-fixed-dim:#abc7ff;--mat-s
ys-scrim:#000000;--mat-sys-secondary:#bec6dc;--mat-sys-secondary-container:#3e4759;--mat-sys-secondary-fixed:#dae2f
9;--mat-sys-secondary-fixed-dim:#bec6dc;--mat-sys-shadow:#000000;--mat-sys-surface:#121316;--mat-sys-surface-bright
:#38393c;--mat-sys-surface-container:#1f2022;--mat-sys-surface-container-high:#292a2c;--mat-sys-surface-container-h
ighest:#343537;--mat-sys-surface-container-low:#1a1b1f;--mat-sys-surface-container-lowest:#0d0e11;--mat-sys-surface
-dim:#121316;--mat-sys-surface-tint:#abc7ff;--mat-sys-surface-variant:#44474e;--mat-sys-tertiary:#70e000;--mat-sys-
tertiary-container:#245100;--mat-sys-tertiary-fixed:#82ff10;--mat-sys-tertiary-fixed-dim:#70e000;--mat-sys-neutral-
variant20:#2d3038;--mat-sys-neutral10:#1a1b1f;--mat-sys-level0:0px 0px 0px 0px rgba(0, 0, 0, .2), 0px 0px 0px 0px r
gba(0, 0, 0, .14), 0px 0px 0px 0px rgba(0, 0, 0, .12);--mat-sys-level1:0px 2px 1px -1px rgba(0, 0, 0, .2), 0px 1px
1px 0px rgba(0, 0, 0, .14), 0px 1px 3px 0px rgba(0, 0, 0, .12);--mat-sys-level2:0px 3px 3px -2px rgba(0, 0, 0, .2),
0px 3px 4px 0px rgba(0, 0, 0, .14), 0px 1px 8px 0px rgba(0, 0, 0, .12);--mat-sys-level3:0px 3px 5px -1px rgba(0, 0
, 0, .2), 0px 6px 10px 0px rgba(0, 0, 0, .14), 0px 1px 18px 0px rgba(0, 0, 0, .12);--mat-sys-level4:0px 5px 5px -3p
x rgba(0, 0, 0, .2), 0px 8px 10px 1px rgba(0, 0, 0, .14), 0px 3px 14px 2px rgba(0, 0, 0, .12);--mat-sys-level5:0px
7px 8px -4px rgba(0, 0, 0, .2), 0px 12px 17px 2px rgba(0, 0, 0, .14), 0px 5px 22px 4px rgba(0, 0, 0, .12);--mat-sys
-corner-extra-large:28px;--mat-sys-corner-extra-large-top:28px 28px 0 0;--mat-sys-corner-extra-small:4px;--mat-sys-
corner-extra-small-top:4px 4px 0 0;--mat-sys-corner-full:9999px;--mat-sys-corner-large:16px;--mat-sys-corner-large-
end:0 16px 16px 0;--mat-sys-corner-large-start:16px 0 0 16px;--mat-sys-corner-large-top:16px 16px 0 0;--mat-sys-cor
ner-medium:12px;--mat-sys-corner-none:0;--mat-sys-corner-small:8px;--mat-sys-dragged-state-layer-opacity:.16;--mat-
sys-focus-state-layer-opacity:.12;--mat-sys-hover-state-layer-opacity:.08;--mat-sys-pressed-state-layer-opacity:.12
;color:var(--mat-sys-on-surface);background-color:var(--mat-sys-surface)}html{font-family:var(--mat-sys-body-medium
-font, Roboto, "Helvetica Neue", sans-serif)}.bluegrey-lightgreen-theme{--theme-primary:#438fff;--theme-primary-lig
hter:rgb(38.2745098039%, 63.2273675428%, 100%);--theme-primary-light:rgb(46.2745098039%, 67.9933249896%, 100%);--th
eme-primary-darker:rgb(14.2745098039%, 48.9294952023%, 100%);--theme-primary-dark:rgb(6.2745098039%, 44.1635377555%
, 100%);--theme-primary-fade-10:#438fff;--theme-primary-fade-20:#438fff;--theme-primary-fade-30:#438fff;--theme-pri
mary-fade-40:#438fff;--theme-primary-fade-50:#438fff;--theme-accent:#50a400;--theme-accent-lighter:rgb(37.226207556
2%, 76.3137254902%, 0%);--theme-accent-light:rgb(41.1286465806%, 84.3137254902%, 0%);--theme-accent-darker:rgb(25.5
18890483%, 52.3137254902%, 0%);--theme-accent-dark:rgb(21.6164514586%, 44.3137254902%, 0%);--theme-accent-fade-10:#
50a400;--theme-accent-fade-20:#50a400;--theme-accent-fade-30:#50a400;--theme-accent-fade-40:#50a400;--theme-accent-
fade-50:#50a400;--theme-warn:#ffb4ab;--theme-warn-lighter:rgb(100%, 81.3025210084%, 79.0588235294%);--theme-warn-li
ght:rgb(100%, 88.4453781513%, 87.0588235294%);--theme-warn-darker:rgb(100%, 59.8739495798%, 55.0588235294%);--theme
-warn-dark:rgb(100%, 52.731092437%, 47.0588235294%);--theme-warn-fade-10:#ffb4ab;--theme-warn-fade-20:#ffb4ab;--the
me-warn-fade-30:#ffb4ab;--theme-warn-fade-40:#ffb4ab;--theme-warn-fade-50:#ffb4ab;--theme-text:#e3e2e6;--theme-text
-lighter:rgb(95.2418300654%, 95.0718954248%, 95.7516339869%);--theme-text-light:rgb(99.3899782135%, 99.3681917211%,
99.4553376906%);--theme-text-darker:rgb(78.6492374728%, 77.8867102397%, 80.9368191721%);--theme-text-dark:rgb(63.0
936819172%, 61.7755991285%, 67.0479302832%);--theme-text-fade-10:#e3e2e6;--theme-text-fade-20:#e3e2e6;--theme-text-

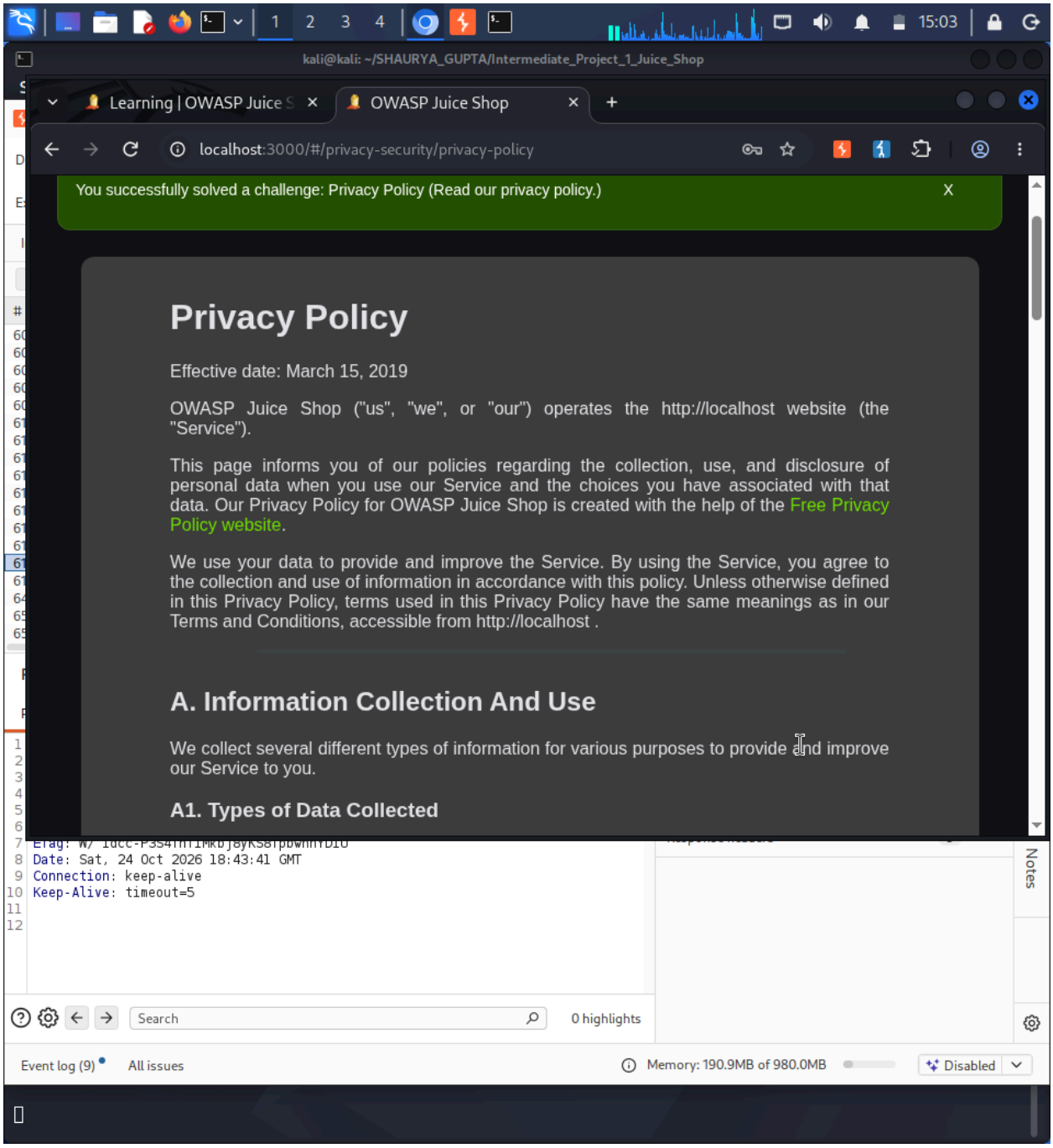

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Session Actions Edit View Help
libhdf5-hl-310 libperl5.40 perl-modules-5.40
Use 'sudo apt autoremove' to remove them.
Summary:
Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 227
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop]
└─$ cd ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
curl -sS -D evidence/initial-headers.txt -o evidence/initial-page.html --max-time 20 https://demo.owasp-juice.shop/
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop]
└─$ cat evidence/initial-headers.txt
HTTP/2 200
accept-ranges: bytes
access-control-allow-origin: *
cache-control: public, max-age=0
content-length: 9984
content-type: text/html; charset=UTF-8
date: Sat, 24 Oct 2026 20:23:44 GMT
etag: W/"2700-1a16f9265d2"
feature-policy: payment 'self'
last-modified: Sat, 24 Oct 2026 20:20:27 GMT
nel: {"report_to":"heroku-nel","response_headers":["Via"],"max_age":3600,"success_fraction":0.01,"failure_fraction"
:0.1}
report-to: {"group":"heroku-nel","endpoints":[{"url":"https://nel.heroku.com/reports?s=x0ojUZ08hmUMzNwQ7ARhTR1K0QiP
IZmDe46GOIEU3ek%3D\u0026sid=812dcc77-0bd0-43b1-a5f1-b25750382959\u0026ts=1792873424"}],"max_age":3600}
reporting-endpoints: heroku-nel="https://nel.heroku.com/reports?s=x0ojUZ08hmUMzNwQ7ARhTR1K0QiPIZmDe46GOIEU3ek%3D&si
d=812dcc77-0bd0-43b1-a5f1-b25750382959&ts=1792873424"
server: Heroku
vary: Accept-Encoding
via: 1.1 heroku-router
x-content-type-options: nosniff
x-frame-options: SAMEORIGIN
x-recruiting: /#/jobs
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop]
└─$ head -n 40 evidence/initial-page.html
<!--
~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
~ SPDX-License-Identifier: MIT
-->
<!doctype html>
<html lang="en" data-beasties-container>
<head>
<meta charset="utf-8">
<title>OWASP Juice Shop</title>
<meta name="description" content="Probably the most modern and sophisticated insecure web application">
<meta name="viewport" content="width=device-width, initial-scale=1">
<link rel="preconnect" href="https://fonts.googleapis.com">
<link rel="preconnect" href="https://fonts.gstatic.com" crossorigin>
<style>@font-face{font-family:'VT323';font-style:normal;font-weight:400;font-display:swap;src:url(https://fonts.g
static.com/s/vt323/v18/pxiKyp0ihIEF2isQFJXGdg.woff2) format('woff2');unicode-range:U+0102-0103, U+0110-0111, U+0128
-0129, U+0168-0169, U+01A0-01A1, U+01AF-01B0, U+0300-0301, U+0303-0304, U+0308-0309, U+0323, U+0329, U+1EA0-1EF9, U
+20AB;}@font-face{font-family:'VT323';font-style:normal;font-weight:400;font-display:swap;src:url(https://fonts.gst

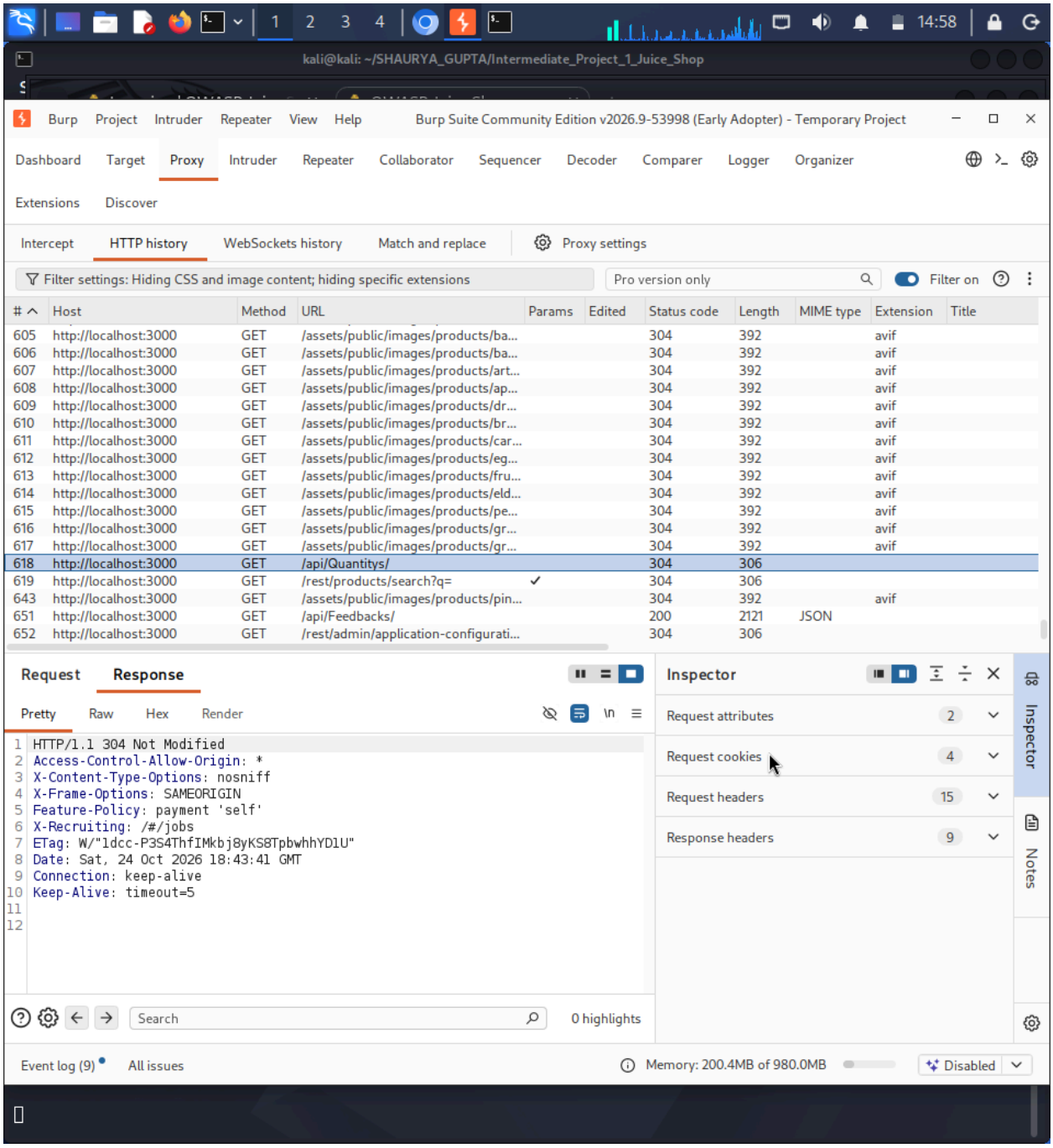

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Session Actions Edit View Help
command -v firefox
command -v curl
command -v python3
kali
PRETTY_NAME="Kali GNU/Linux Rolling"
NAME="Kali GNU/Linux"
VERSION_ID="2026.3"
VERSION="2026.3"
VERSION_CODENAME=kali-rolling
ID=kali
ID_LIKE=debian
HOME_URL="https://www.kali.org/"
SUPPORT_URL="https://forums.kali.org/"
BUG_REPORT_URL="https://bugs.kali.org/"
ANSI_COLOR="1;31"
Sat Oct 24 04:22:30 PM EDT 2026
/usr/bin/burpsuite
/usr/bin/firefox
/usr/bin/curl
/usr/bin/python3
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop]
└─$ curl -sS -I --max-time 15 https://demo.owasp-juice.shop/
HTTP/2 200
accept-ranges: bytes
access-control-allow-origin: *
cache-control: public, max-age=0
content-length: 9984
content-type: text/html; charset=UTF-8
date: Sat, 24 Oct 2026 20:22:38 GMT
etag: W/"2700-1a16f9265d2"
feature-policy: payment 'self'
last-modified: Sat, 24 Oct 2026 20:20:27 GMT
nel: {"report_to":"heroku-nel","response_headers":["Via"],"max_age":3600,"success_fraction":0.01,"failure_fraction"
:0.1}
report-to: {"group":"heroku-nel","endpoints":[{"url":"https://nel.heroku.com/reports?s=fO3Sil1j3WbfDYrrw86d6WiLtGBJ
rt%2Fh4%2FhO1%2Bfddfg%3D\u0026sid=812dcc77-0bd0-43b1-a5f1-b25750382959\u0026ts=1792873358"}],"max_age":3600}
reporting-endpoints: heroku-nel="https://nel.heroku.com/reports?s=fO3Sil1j3WbfDYrrw86d6WiLtGBJrt%2Fh4%2FhO1%2Bfddfg
%3D&sid=812dcc77-0bd0-43b1-a5f1-b25750382959&ts=1792873358"
server: Heroku
vary: Accept-Encoding
via: 1.1 heroku-router
x-content-type-options: nosniff
x-frame-options: SAMEORIGIN
x-recruiting: /#/jobs
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop]
└─$ sudo apt update
[sudo] password for kali:
Hit:1 http://http.kali.org/kali kali-rolling InRelease
227 packages can be upgraded. Run 'apt list --upgradable' to see them.
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop]
└─$ sudo apt install -y burpsuite firefox-esr curl python3
burpsuite is already the newest version (2026.9-0kali1).
firefox-esr is already the newest version (153.4.0esr-1).

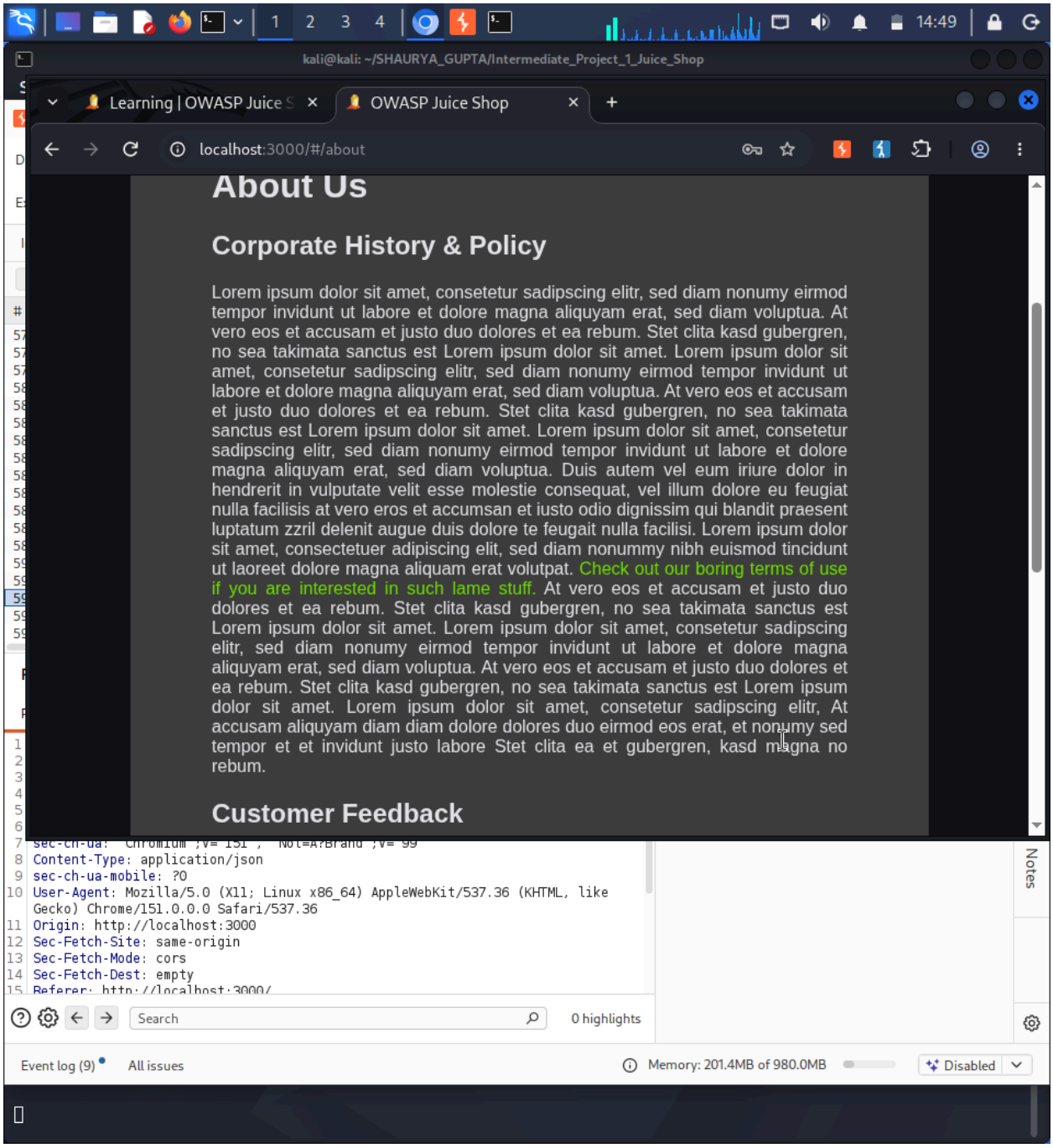
kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Session Actions Edit View Help
mkdir -p ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop/{report,screenshots,evidence,notes}
cd ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
ls
evidence Kali-Transfer notes README.md report screenshots
pwd
find . -maxdepth 2 -type d | sort
/home/kali/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
.
./evidence
./Kali-Transfer
./notes
./report
./screenshots
printf '%s\n' 'https://demo.owasp-juice.shop/' > evidence/target.txt
date -Is > evidence/assessment-start.txt
cat > README.md <<'EOF'
OWASP Juice Shop Security Assessment
Domain: Cyber Security
Level: Intermediate
Project Number: 1
Target: https://demo.owasp-juice.shop/
Objective
Assess the intentionally vulnerable OWASP Juice Shop training
application, document at least five distinct vulnerabilities,
collect genuine evidence, and recommend mitigations.
Contents
report/ Report draft and final report
screenshots/ Genuine screenshots of testing and results
evidence/ Sanitized supporting evidence
notes/ Testing notes and findings register
Evidence policy
Record only findings verified during testing.
Do not fabricate screenshots, responses, or results.
Redact credentials, tokens, and personal information.
EOF
script -a notes/commands.txt
Script started, output log file is 'notes/commands.txt'.
whoami
cat /etc/os-release
date
command -v burpsuite

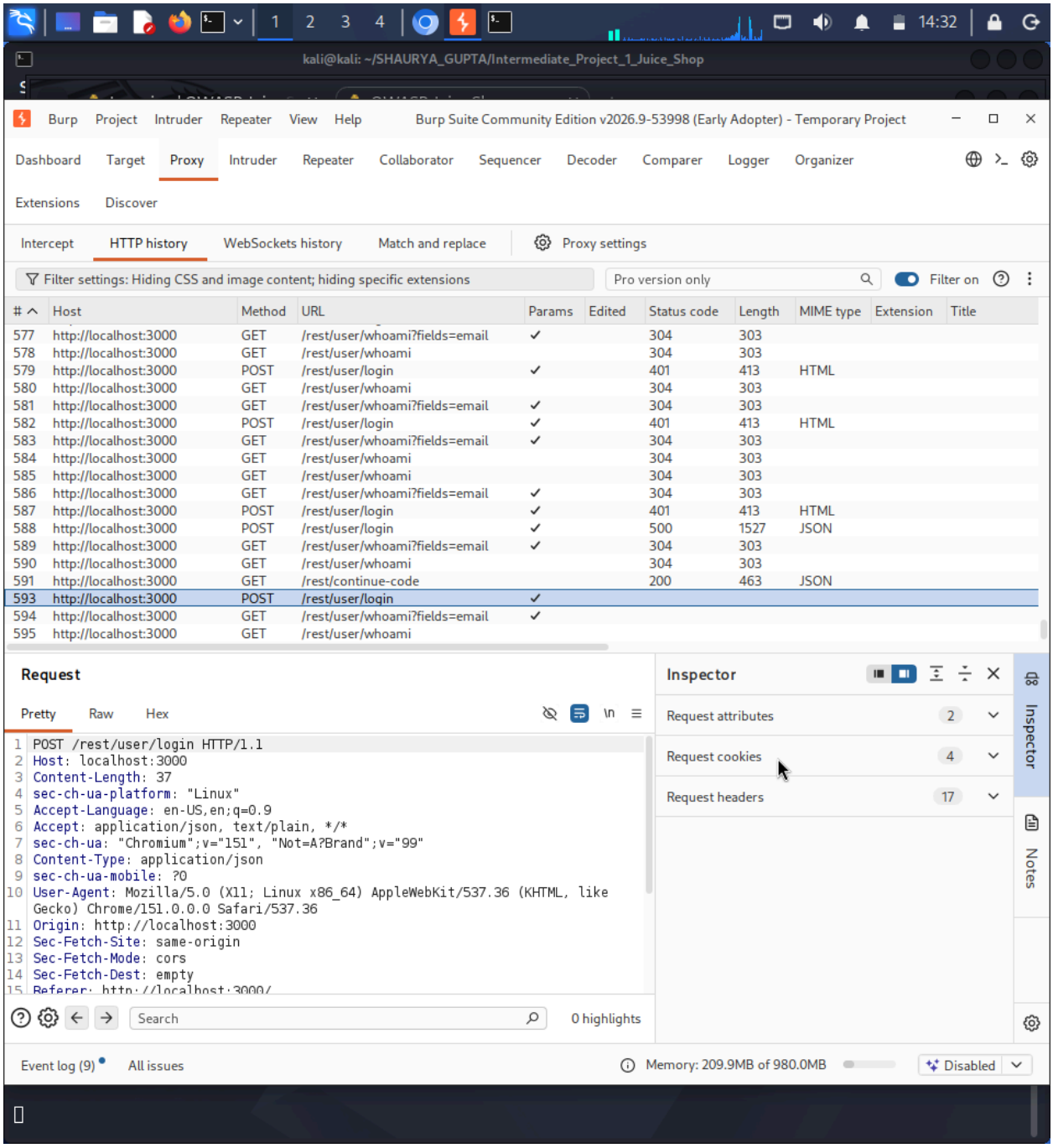

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
OWASP Juice Shop
OWASP Juice Shop
localhost:3000/#/score-board
Jump to related coding challenge
3%
Hacking Challenges
0%
Coding Challenges
4/186
Challenges Solved
4/27
0/29
0/51
0/40
0/25
0/14
Search
Difficulty
Status
Tags
All
Broken Access Control
XSS
Observability Failures
Improper Input Validation
Unvalidated Redirects
Vulnerable Components
Event log (9)
All issues
Memory: 275.9MB of 980.0MB
Disabled

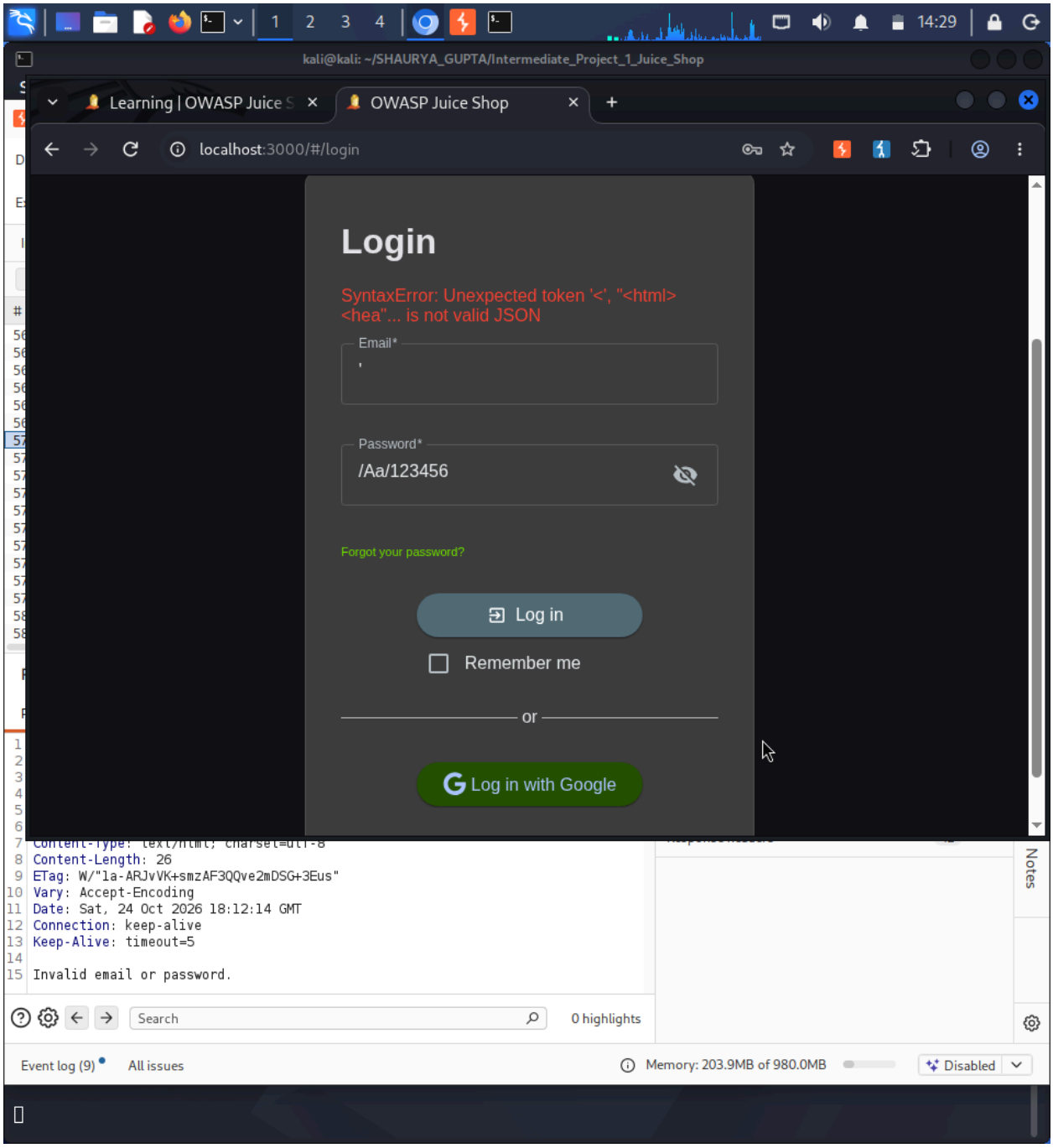

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title
779 http://localhost:3000 GET /api/Challenges/?name=Score%20... ✓ 304 305
780 http://localhost:3000 GET /assets/public/images/products/ap... 304 392 avif
781 http://localhost:3000 GET /assets/public/images/products/ap... 304 392 avif
782 http://localhost:3000 GET /assets/public/images/products/ba... 304 392 avif
783 http://localhost:3000 GET /assets/public/images/products/be... 304 392 avif
784 http://localhost:3000 GET /assets/public/images/products/ba... 304 392 avif
785 http://localhost:3000 GET /assets/public/images/products/art... 304 392 avif
786 http://localhost:3000 GET /assets/public/images/products/br... 304 392 avif
787 http://localhost:3000 GET /assets/public/images/products/car... 304 392 avif
788 http://localhost:3000 GET /assets/public/images/products/fru... 304 392 avif
789 http://localhost:3000 GET /assets/public/images/products/eg... 304 392 avif
790 http://localhost:3000 GET /assets/public/images/products/eld... 304 392 avif
791 http://localhost:3000 GET /assets/public/images/products/dr... 304 392 avif
792 http://localhost:3000 GET /assets/public/images/products/gr... 304 392 avif
793 http://localhost:3000 GET /assets/public/images/products/gr... 304 392 avif
794 http://localhost:3000 GET /assets/public/images/products/pe... 304 392 avif
796 http://localhost:3000 GET /rest/admin/application-configurati... 304 306
798 http://localhost:3000 GET /rest/continue-code 200 463 JSON
Request Response
Pretty Raw Hex Render
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Content-Type: application/json; charset=utf-8
Content-Length: 79
ETag: W/"4f-A5Q6/P1htv5qAvklsYJTS92cejM"
Vary: Accept-Encoding
Date: Sat, 24 Oct 2026 19:02:46 GMT
Connection: keep-alive
Keep-Alive: timeout=5
{
"continueCode":"5VO3DL3k6vO5eWYryoaQPNZEpzdKXIMSn8G7l4KMVRXxnlg9BJbqw8mj2wRD"
}
Search
0 highlights
Inspector
Request attributes 2
Request cookies 5
Request headers 16
Response headers 12
Inspector
Notes
Event log (9)
All issues
Memory: 182.9MB of 980.0MB
Disabled

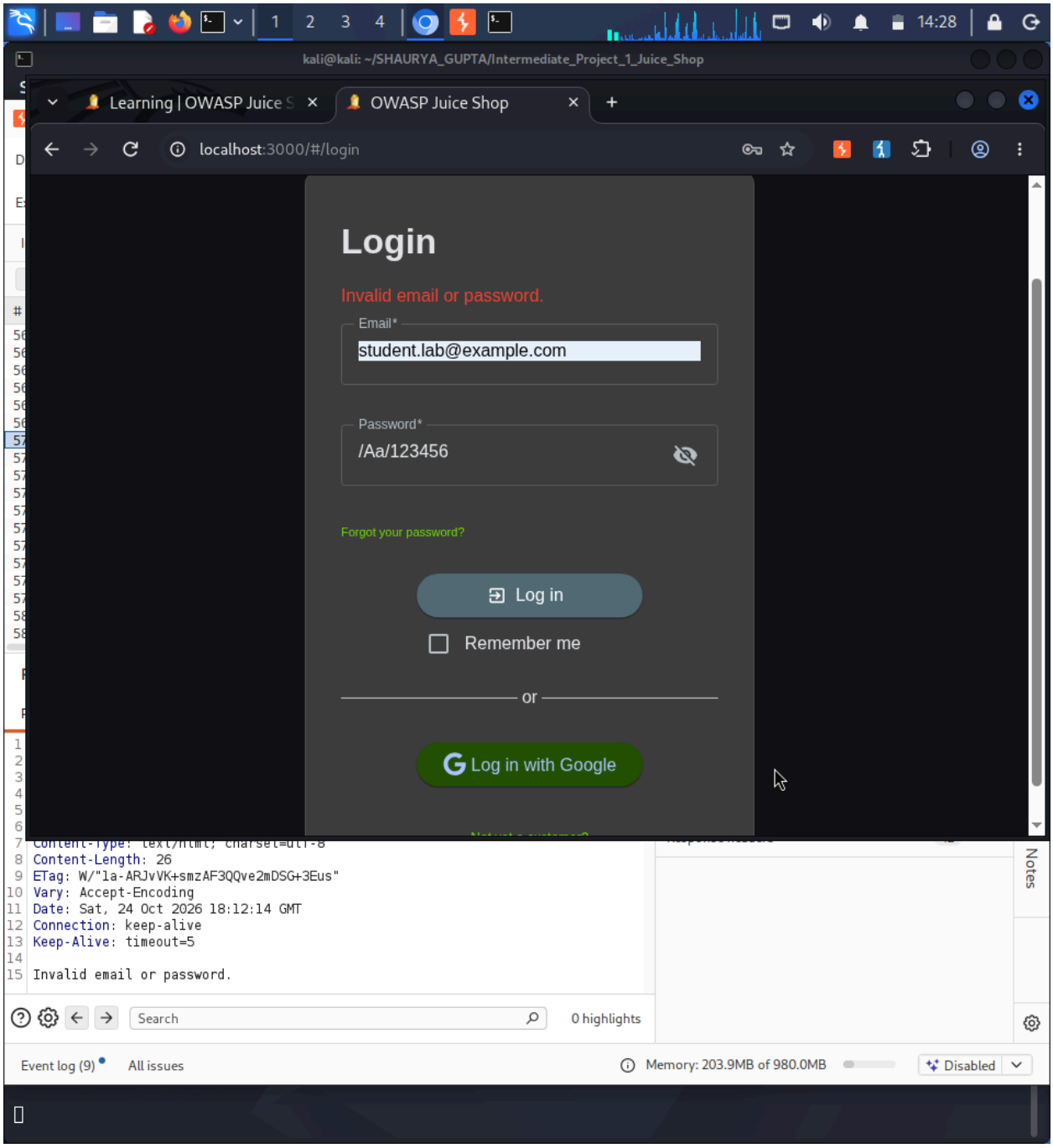

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Learning | OWASP Juice S
OWASP Juice Shop
localhost:3000/#/privacy-security/privacy-policy
You successfully solved a challenge: Privacy Policy (Read our privacy policy.)
X
Privacy Policy
Effective date: March 15, 2019
OWASP Juice Shop ("us", "we", or "our") operates the http://localhost website (the "Service").
This page informs you of our policies regarding the collection, use, and disclosure of personal data when you use our Service and the choices you have associated with that data. Our Privacy Policy for OWASP Juice Shop is created with the help of the Free Privacy Policy website.
We use your data to provide and improve the Service. By using the Service, you agree to the collection and use of information in accordance with this policy. Unless otherwise defined in this Privacy Policy, terms used in this Privacy Policy have the same meanings as in our Terms and Conditions, accessible from http://localhost .
A. Information Collection And Use
We collect several different types of information for various purposes to provide and improve our Service to you.
A1. Types of Data Collected
Date: Sat, 24 Oct 2026 18:43:41 GMT
Connection: keep-alive
Keep-Alive: timeout=5
Search
0 highlights
Notes
Event log (9)
All issues
Memory: 190.9MB of 980.0MB
Disabled

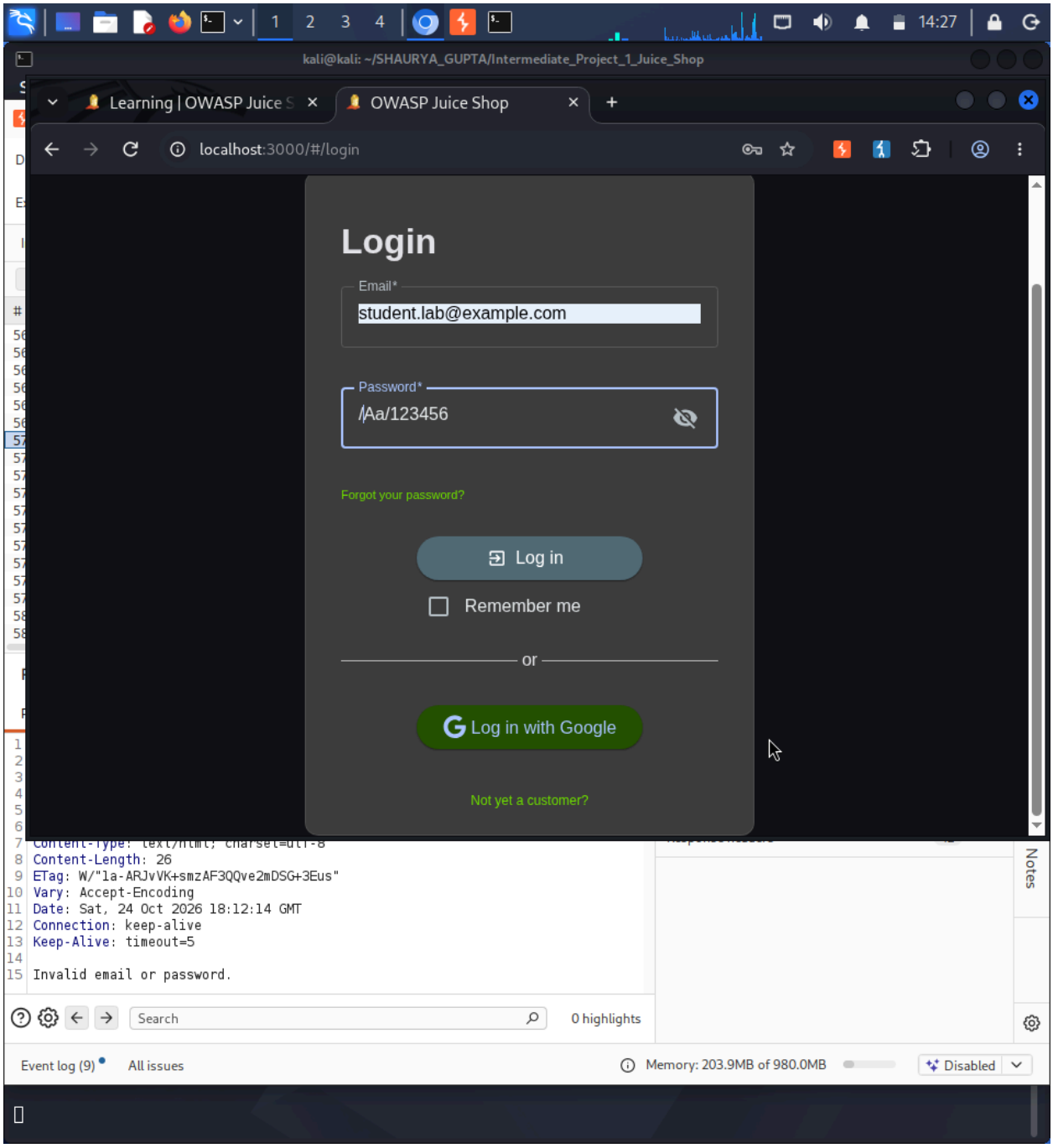

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title
605 http://localhost:3000 GET /assets/public/images/products/ba... 304 392 avif
606 http://localhost:3000 GET /assets/public/images/products/ba... 304 392 avif
607 http://localhost:3000 GET /assets/public/images/products/art... 304 392 avif
608 http://localhost:3000 GET /assets/public/images/products/ap... 304 392 avif
609 http://localhost:3000 GET /assets/public/images/products/dr... 304 392 avif
610 http://localhost:3000 GET /assets/public/images/products/br... 304 392 avif
611 http://localhost:3000 GET /assets/public/images/products/car... 304 392 avif
612 http://localhost:3000 GET /assets/public/images/products/eg... 304 392 avif
613 http://localhost:3000 GET /assets/public/images/products/fru... 304 392 avif
614 http://localhost:3000 GET /assets/public/images/products/eld... 304 392 avif
615 http://localhost:3000 GET /assets/public/images/products/pe... 304 392 avif
616 http://localhost:3000 GET /assets/public/images/products/gr... 304 392 avif
617 http://localhost:3000 GET /assets/public/images/products/gr... 304 392 avif
618 http://localhost:3000 GET /api/Quantitys/ 304 306
619 http://localhost:3000 GET /rest/products/search?q= ✓ 304 306
643 http://localhost:3000 GET /assets/public/images/products/pin... 304 392 avif
651 http://localhost:3000 GET /api/Feedbacks/ 200 2121 JSON
652 http://localhost:3000 GET /rest/admin/application-configurati... 304 306
Request Response
Pretty Raw Hex Render
1 HTTP/1.1 304 Not Modified
2 Access-Control-Allow-Origin: *
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Feature-Policy: payment 'self'
6 X-Recruiting: /#/jobs
7 ETag: W/"1dcc-P3S4ThfIMkbj8yKS8TpbwhhYD1U"
8 Date: Sat, 24 Oct 2026 18:43:41 GMT
9 Connection: keep-alive
10 Keep-Alive: timeout=5
11
12
Search
0 highlights
Inspector
Request attributes 2
Request cookies 4
Request headers 15
Response headers 9
Inspector
Notes
Event log (9)
All issues
Memory: 200.4MB of 980.0MB
Disabled

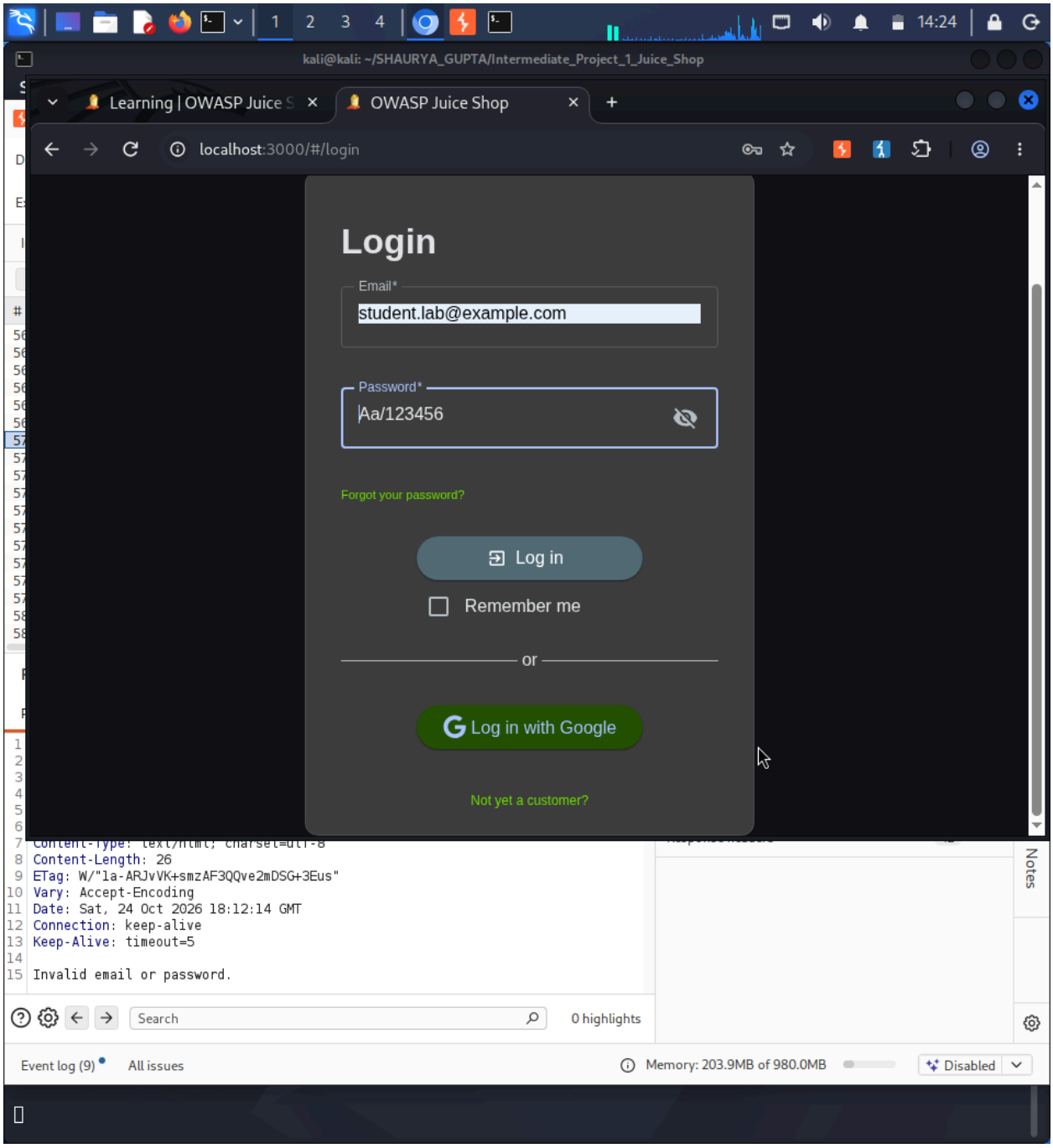

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Learning | OWASP Juice S
OWASP Juice Shop
localhost:3000/#/about
About Us
Corporate History & Policy
Lorem ipsum dolor sit amet, consetetur sadipscing elitr, sed diam nonumy eirmod tempor invidunt ut labore et dolore magna aliquyam erat, sed diam voluptua. At vero eos et accusam et justo duo dolores et ea rebum. Stet clita kasd gubergren, no sea takimata sanctus est Lorem ipsum dolor sit amet. Lorem ipsum dolor sit amet, consetetur sadipscing elitr, sed diam nonumy eirmod tempor invidunt ut labore et dolore magna aliquyam erat, sed diam voluptua. At vero eos et accusam et justo duo dolores et ea rebum. Stet clita kasd gubergren, no sea takimata sanctus est Lorem ipsum dolor sit amet. Lorem ipsum dolor sit amet, consetetur sadipscing elitr, sed diam nonumy eirmod tempor invidunt ut labore et dolore magna aliquyam erat, sed diam voluptua. Duis autem vel eum iriure dolor in hendrerit in vulputate velit esse molestie consequat, vel illum dolore eu feugiat nulla facilisis at vero eros et accumsan et iusto odio dignissim qui blandit praesent luptatum zzril delenit augue duis dolore te feugait nulla facilisi. Lorem ipsum dolor sit amet, consectetuer adipiscing elit, sed diam nonummy nibh euismod tincidunt ut laoreet dolore magna aliquam erat volutpat. Check out our boring terms of use if you are interested in such lame stuff. At vero eos et accusam et justo duo dolores et ea rebum. Stet clita kasd gubergren, no sea takimata sanctus est Lorem ipsum dolor sit amet. Lorem ipsum dolor sit amet, consetetur sadipscing elitr, sed diam nonumy eirmod tempor invidunt ut labore et dolore magna aliquyam erat, sed diam voluptua. At vero eos et accusam et justo duo dolores et ea rebum. Stet clita kasd gubergren, no sea takimata sanctus est Lorem ipsum dolor sit amet. Lorem ipsum dolor sit amet, consetetur sadipscing elitr, At accusam aliquyam diam diam dolore dolores duo eirmod eos erat, et nonumy sed tempor et et invidunt justo labore Stet clita ea et gubergren, kasd magna no rebum.
Customer Feedback
Content-Type: application/json
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
Origin: http://localhost:3000
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Search
0 highlights
Notes
Event log (9)
All issues
Memory: 201.4MB of 980.0MB
Disabled

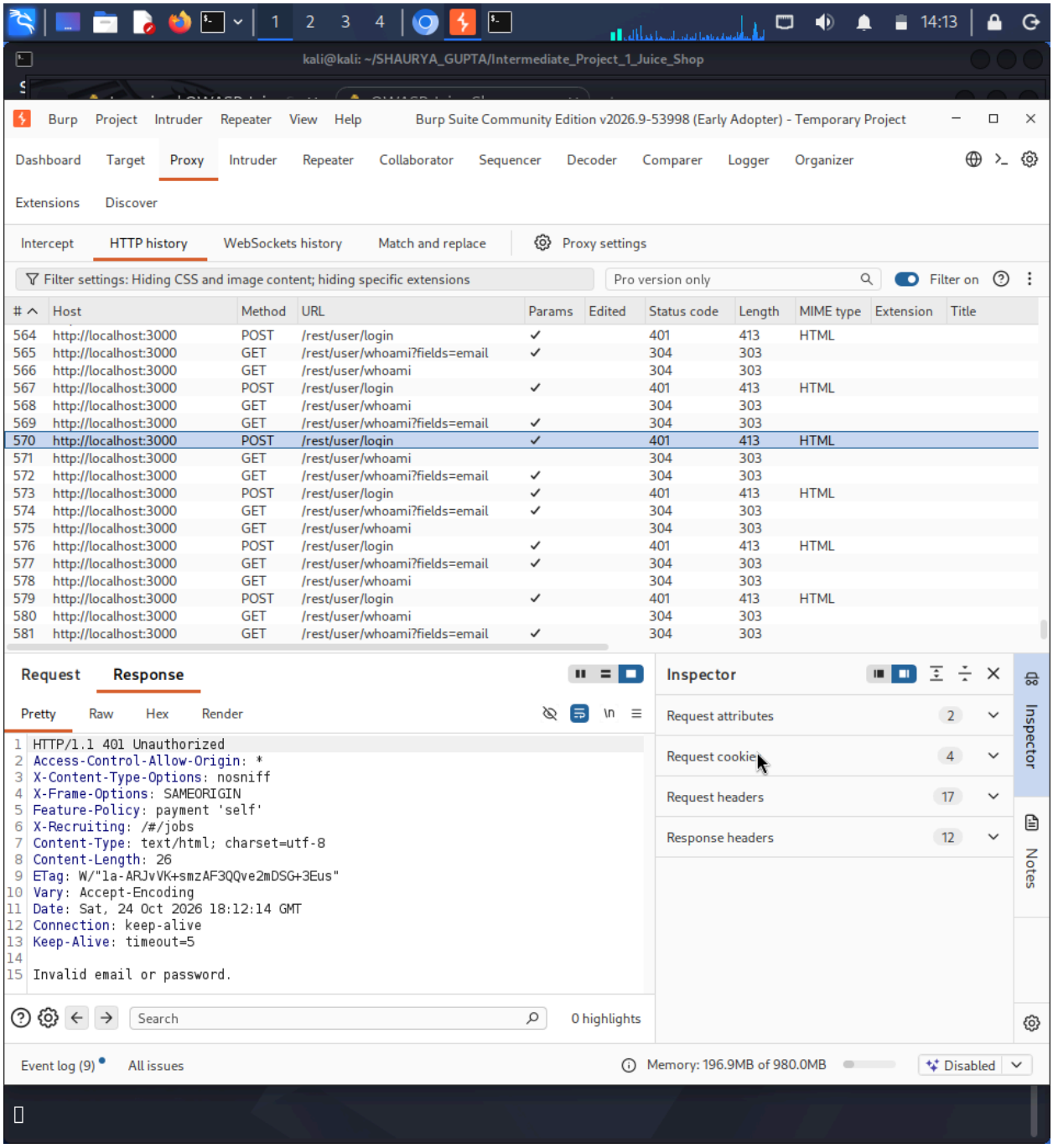

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title
577 http://localhost:3000 GET /rest/user/whoami?fields=email ✓ 304 303
578 http://localhost:3000 GET /rest/user/whoami 304 303
579 http://localhost:3000 POST /rest/user/login ✓ 401 413 HTML
580 http://localhost:3000 GET /rest/user/whoami 304 303
581 http://localhost:3000 GET /rest/user/whoami?fields=email ✓ 304 303
582 http://localhost:3000 POST /rest/user/login ✓ 401 413 HTML
583 http://localhost:3000 GET /rest/user/whoami?fields=email ✓ 304 303
584 http://localhost:3000 GET /rest/user/whoami 304 303
585 http://localhost:3000 GET /rest/user/whoami 304 303
586 http://localhost:3000 GET /rest/user/whoami?fields=email ✓ 304 303
587 http://localhost:3000 POST /rest/user/login ✓ 401 413 HTML
588 http://localhost:3000 POST /rest/user/login ✓ 500 1527 JSON
589 http://localhost:3000 GET /rest/user/whoami?fields=email ✓ 304 303
590 http://localhost:3000 GET /rest/user/whoami 304 303
591 http://localhost:3000 GET /rest/continue-code 200 463 JSON
593 http://localhost:3000 POST /rest/user/login ✓
594 http://localhost:3000 GET /rest/user/whoami?fields=email ✓
595 http://localhost:3000 GET /rest/user/whoami
Request
Pretty Raw Hex
1 POST /rest/user/login HTTP/1.1
2 Host: localhost:3000
3 Content-Length: 37
4 sec-ch-ua-platform: "Linux"
5 Accept-Language: en-US,en;q=0.9
6 Accept: application/json, text/plain, */*
7 sec-ch-ua: "Chromium";v="151", "Not=A?Brand";v="99"
8 Content-Type: application/json
9 sec-ch-ua-mobile: ?0
10 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
11 Origin: http://localhost:3000
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: http://localhost:3000/
Search
0 highlights
Inspector
Request attributes 2
Request cookies 4
Request headers 17
Inspector
Notes
Event log (9)
All issues
Memory: 209.9MB of 980.0MB
Disabled

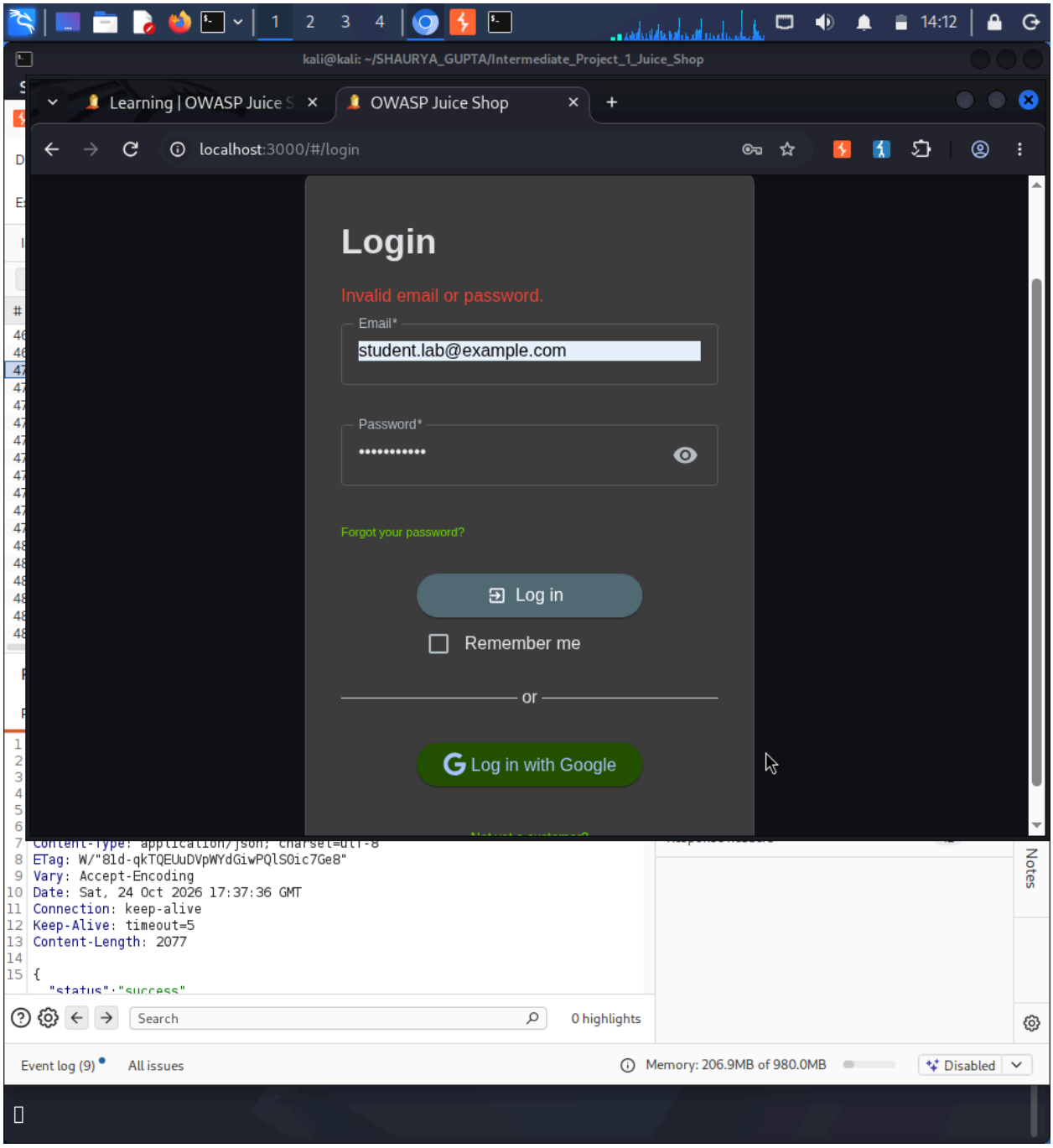

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Learning | OWASP Juice S
OWASP Juice Shop
localhost:3000/#/login
Login
SyntaxError: Unexpected token '<', "<html> <hea"... is not valid JSON
Email*
'
Password*
/Aa/123456
Forgot your password?
Log in
Remember me
or
Log in with Google
Content-Type: text/html; charset=utf-8
Content-Length: 26
ETag: W/"1a-ARJvVK+smzAF3QQve2mDSG+3Eus"
Vary: Accept-Encoding
Date: Sat, 24 Oct 2026 18:12:14 GMT
Connection: keep-alive
Keep-Alive: timeout=5
Invalid email or password.
Search
0 highlights
Notes
Event log (9)
All issues
Memory: 203.9MB of 980.0MB
Disabled

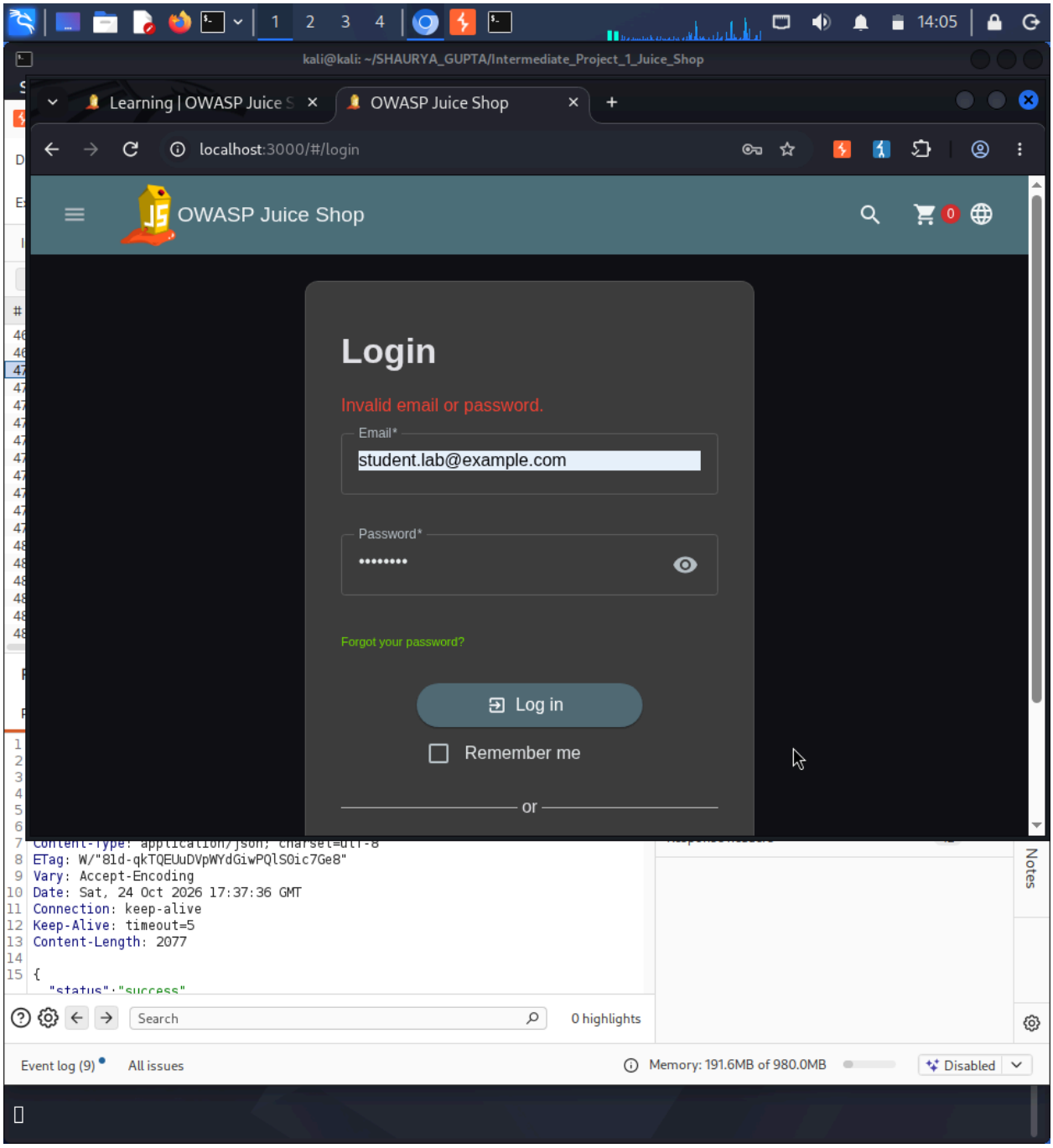

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Learning | OWASP Juice S
OWASP Juice Shop
localhost:3000/#/login
Login
Invalid email or password.
Email*
student.lab@example.com
Password*
/Aa/123456
Forgot your password?
Log in
Remember me
or
Log in with Google
Content-Type: text/html; charset=utf-8
Content-Length: 26
ETag: W/"1a-ARJvVK+smzAF3QQve2mDSG+3Eus"
Vary: Accept-Encoding
Date: Sat, 24 Oct 2026 18:12:14 GMT
Connection: keep-alive
Keep-Alive: timeout=5
Invalid email or password.
Search
0 highlights
Notes
Event log (9)
All issues
Memory: 203.9MB of 980.0MB
Disabled

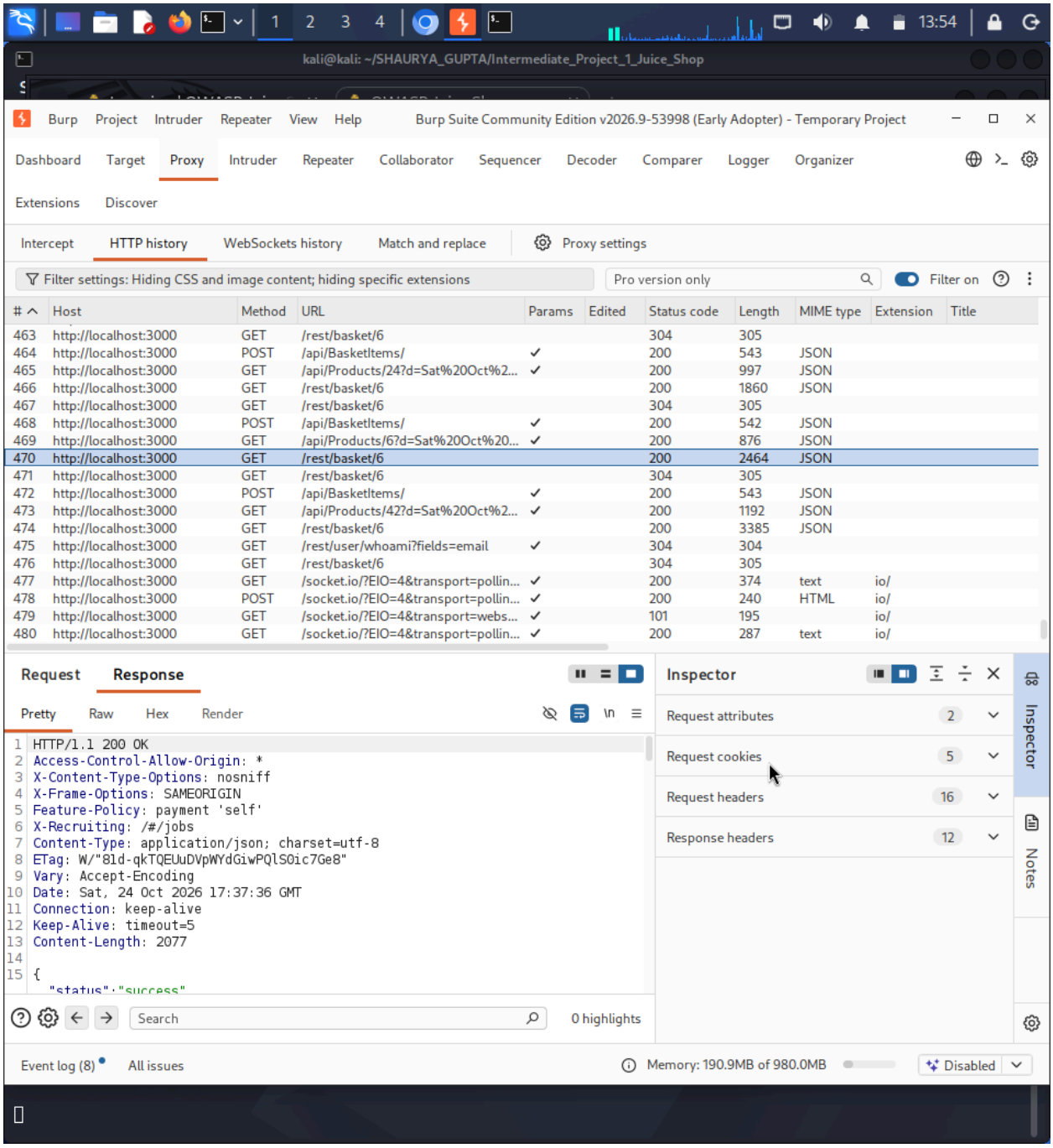

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Learning | OWASP Juice S
OWASP Juice Shop
localhost:3000/#/login
Login
Email*
student.lab@example.com
Password*
/Aa/123456
Forgot your password?
Log in
Remember me
or
Log in with Google
Not yet a customer?
Content-Length: 26
ETag: W/"1a-ARJvVK+smzAF3QQve2mDSG+3Eus"
Vary: Accept-Encoding
Date: Sat, 24 Oct 2026 18:12:14 GMT
Connection: keep-alive
Keep-Alive: timeout=5
Invalid email or password.
Search
0 highlights
Notes
Event log (9)
All issues
Memory: 203.9MB of 980.0MB
Disabled

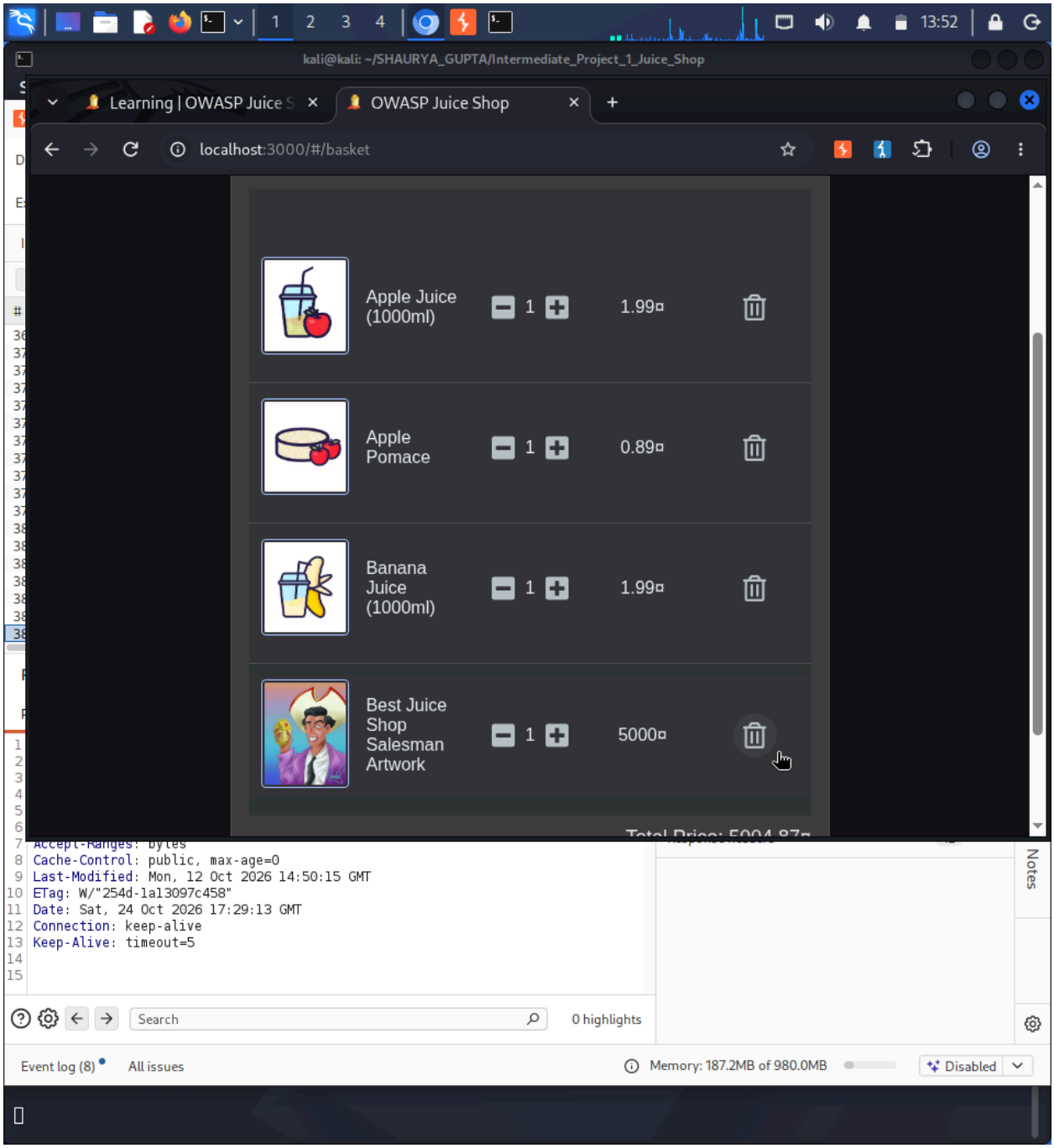

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Learning | OWASP Juice S
OWASP Juice Shop
localhost:3000/#/login
Login
Email*
student.lab@example.com
Password*
Aa/123456
Forgot your password?
Log in
Remember me
or
Log in with Google
Not yet a customer?
Content-Type: text/html; charset=utf-8
Content-Length: 26
ETag: W/"1a-ARJvVK+smzAF3QQve2mDSG+3Eus"
Vary: Accept-Encoding
Date: Sat, 24 Oct 2026 18:12:14 GMT
Connection: keep-alive
Keep-Alive: timeout=5
Invalid email or password.
Search
0 highlights
Notes
Event log (9)
All issues
Memory: 203.9MB of 980.0MB
Disabled

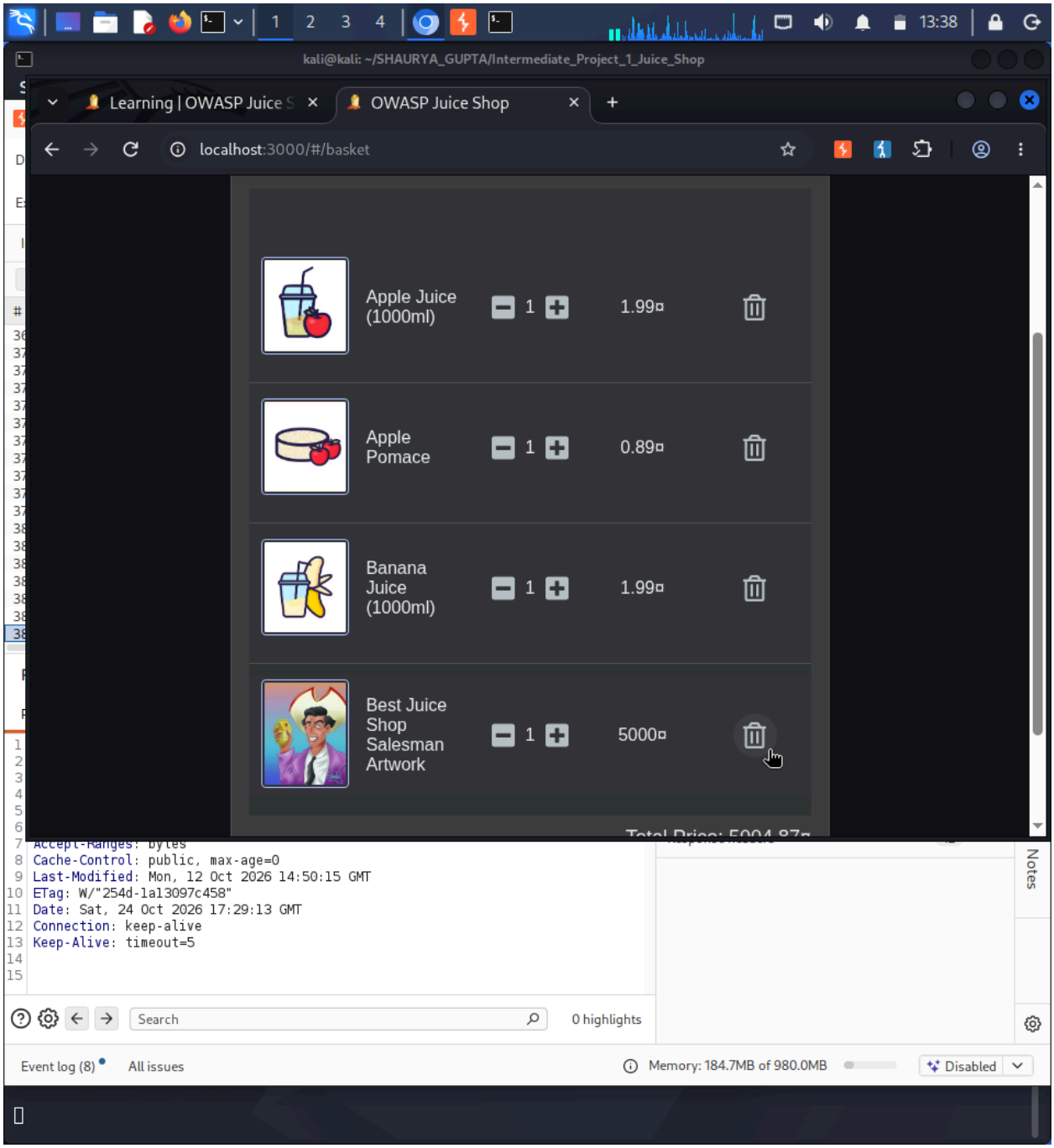

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title
564 http://localhost:3000 POST /rest/user/login ✓ 401 413 HTML
565 http://localhost:3000 GET /rest/user/whoami?fields=email ✓ 304 303
566 http://localhost:3000 GET /rest/user/whoami 304 303
567 http://localhost:3000 POST /rest/user/login ✓ 401 413 HTML
568 http://localhost:3000 GET /rest/user/whoami 304 303
569 http://localhost:3000 GET /rest/user/whoami?fields=email ✓ 304 303
570 http://localhost:3000 POST /rest/user/login ✓ 401 413 HTML
571 http://localhost:3000 GET /rest/user/whoami 304 303
572 http://localhost:3000 GET /rest/user/whoami?fields=email ✓ 304 303
573 http://localhost:3000 POST /rest/user/login ✓ 401 413 HTML
574 http://localhost:3000 GET /rest/user/whoami?fields=email ✓ 304 303
575 http://localhost:3000 GET /rest/user/whoami 304 303
576 http://localhost:3000 POST /rest/user/login ✓ 401 413 HTML
577 http://localhost:3000 GET /rest/user/whoami?fields=email ✓ 304 303
578 http://localhost:3000 GET /rest/user/whoami 304 303
579 http://localhost:3000 POST /rest/user/login ✓ 401 413 HTML
580 http://localhost:3000 GET /rest/user/whoami 304 303
581 http://localhost:3000 GET /rest/user/whoami?fields=email ✓ 304 303
Request Response
Pretty Raw Hex Render
1 HTTP/1.1 401 Unauthorized
2 Access-Control-Allow-Origin: *
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Feature-Policy: payment 'self'
6 X-Recruiting: /#/jobs
7 Content-Type: text/html; charset=utf-8
8 Content-Length: 26
9 ETag: W/"1a-ARJvVK+smzAF3QQve2mDSG+3Eus"
10 Vary: Accept-Encoding
11 Date: Sat, 24 Oct 2026 18:12:14 GMT
12 Connection: keep-alive
13 Keep-Alive: timeout=5
14
15 Invalid email or password.
Search
0 highlights
Inspector
Request attributes 2
Request cookies 4
Request headers 17
Response headers 12
Inspector
Notes
Event log (9)
All issues
Memory: 196.9MB of 980.0MB
Disabled

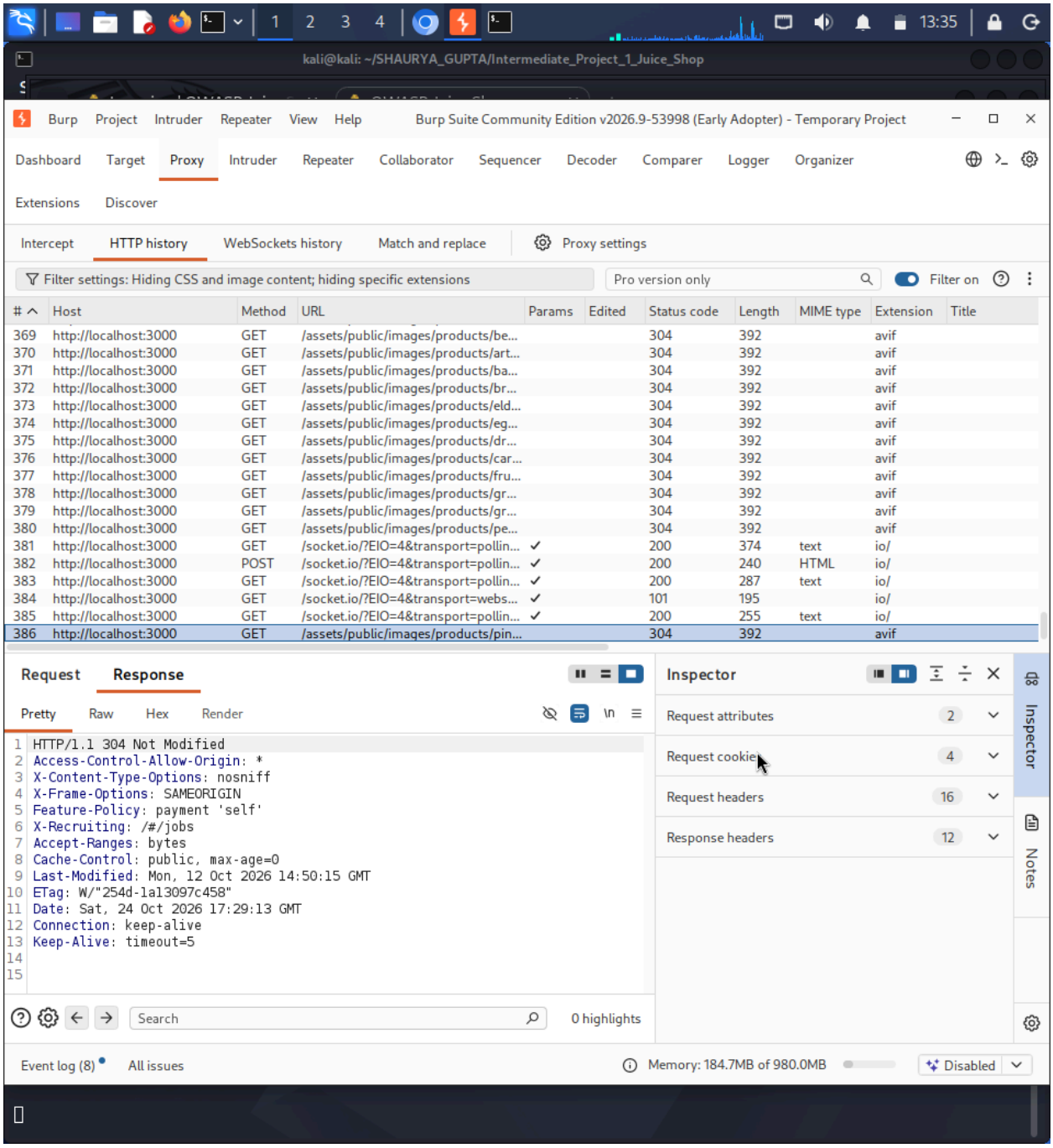

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Learning | OWASP Juice S
OWASP Juice Shop
localhost:3000/#/login
Login
Invalid email or password.
Email*
student.lab@example.com
Password*
Forgot your password?
Log in
Remember me
or
Log in with Google
Content-Type: application/json; charset=utf-8
ETag: W/"81d-qkTQEUuDVpWYdGiwPQlS0ic7Ge8"
Vary: Accept-Encoding
Date: Sat, 24 Oct 2026 17:37:36 GMT
Connection: keep-alive
Keep-Alive: timeout=5
Content-Length: 2077
{
"status":"success"
Search
0 highlights
Notes
Event log (9)
All issues
Memory: 206.9MB of 980.0MB
Disabled

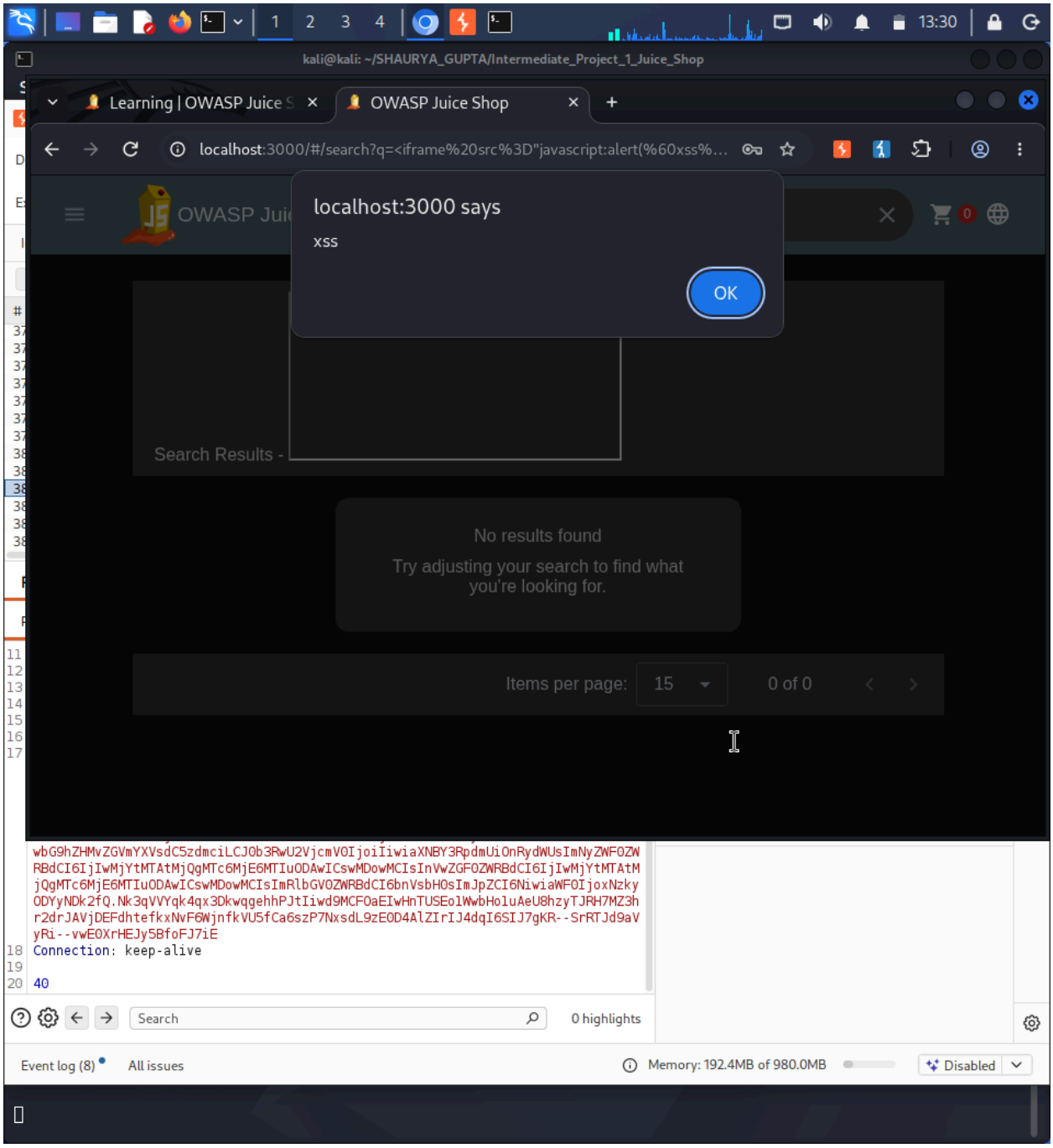

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Learning | OWASP Juice S
OWASP Juice Shop
localhost:3000/#/login
OWASP Juice Shop
Login
Invalid email or password.
Email*
student.lab@example.com
Password*
Forgot your password?
Log in
Remember me
or
Content-Type: application/json; charset=utf-8
ETag: W/"81d-qkTQEUuDVpWYdGiwPQlSOic7Ge8"
Vary: Accept-Encoding
Date: Sat, 24 Oct 2026 17:37:36 GMT
Connection: keep-alive
Keep-Alive: timeout=5
Content-Length: 2077
{
"status":"success"
Search
0 highlights
Notes
Event log (9)
All issues
Memory: 191.6MB of 980.0MB
Disabled

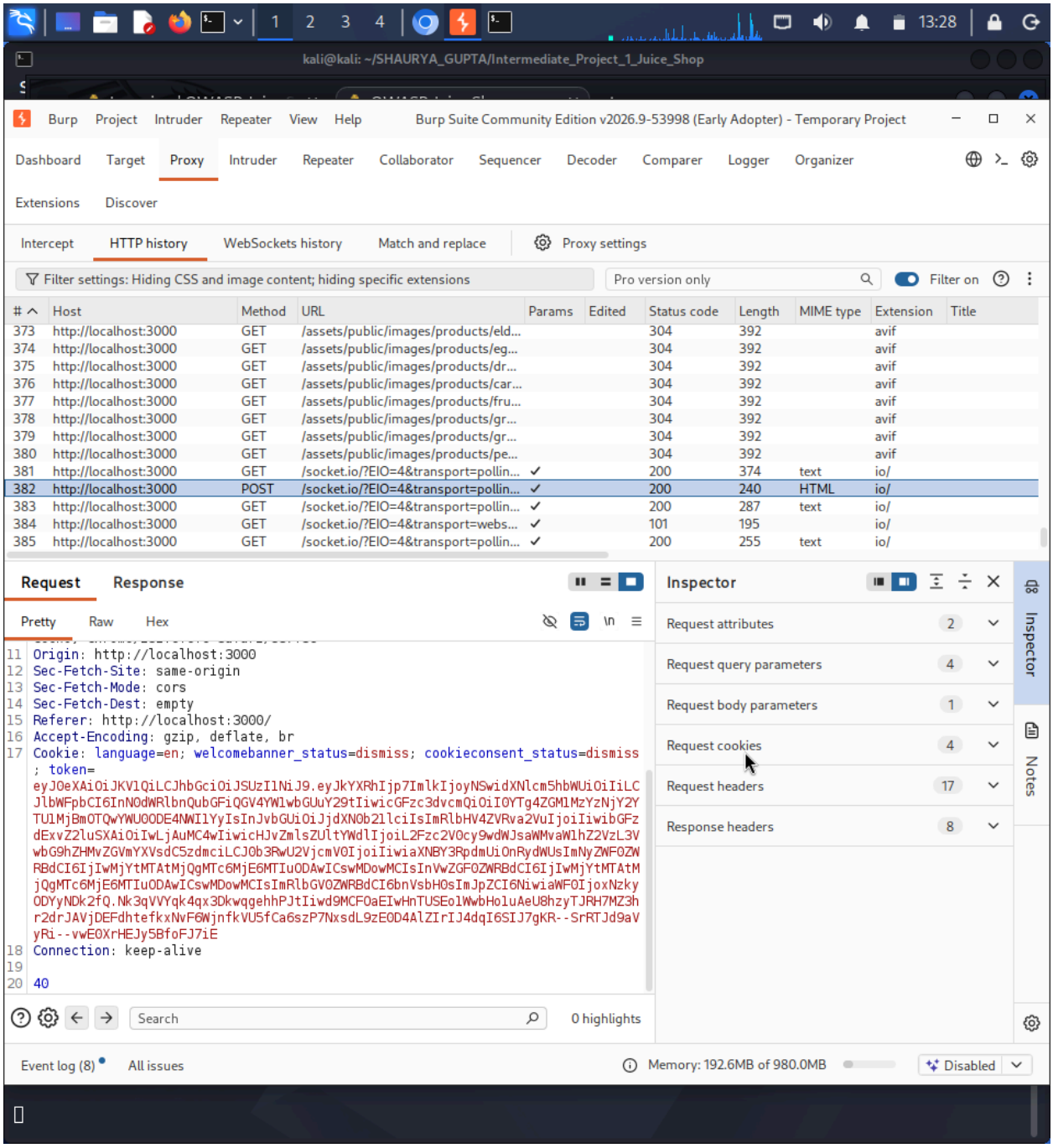

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title
463 http://localhost:3000 GET /rest/basket/6 304 305
464 http://localhost:3000 POST /api/BasketItems/ ✓ 200 543 JSON
465 http://localhost:3000 GET /api/Products/24?d=Sat%20Oct%2... ✓ 200 997 JSON
466 http://localhost:3000 GET /rest/basket/6 200 1860 JSON
467 http://localhost:3000 GET /rest/basket/6 304 305
468 http://localhost:3000 POST /api/BasketItems/ ✓ 200 542 JSON
469 http://localhost:3000 GET /api/Products/6?d=Sat%20Oct%20... ✓ 200 876 JSON
470 http://localhost:3000 GET /rest/basket/6 200 2464 JSON
471 http://localhost:3000 GET /rest/basket/6 304 305
472 http://localhost:3000 POST /api/BasketItems/ ✓ 200 543 JSON
473 http://localhost:3000 GET /api/Products/42?d=Sat%20Oct%2... ✓ 200 1192 JSON
474 http://localhost:3000 GET /rest/basket/6 200 3385 JSON
475 http://localhost:3000 GET /rest/user/whoami?fields=email ✓ 304 304
476 http://localhost:3000 GET /rest/basket/6 304 305
477 http://localhost:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 374 text io/
478 http://localhost:3000 POST /socket.io/?EIO=4&transport=pollin... ✓ 200 240 HTML io/
479 http://localhost:3000 GET /socket.io/?EIO=4&transport=webs... ✓ 101 195 io/
480 http://localhost:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 287 text io/
Request Response
Pretty Raw Hex Render
1 HTTP/1.1 200 OK
2 Access-Control-Allow-Origin: *
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Feature-Policy: payment 'self'
6 X-Recruiting: /#/jobs
7 Content-Type: application/json; charset=utf-8
8 ETag: W/"81d-qkTQEUuDVpWYdGiwPQlS0ic7Ge8"
9 Vary: Accept-Encoding
10 Date: Sat, 24 Oct 2026 17:37:36 GMT
11 Connection: keep-alive
12 Keep-Alive: timeout=5
13 Content-Length: 2077
14
15 {
"status":"success"
Search
0 highlights
Inspector
Request attributes 2
Request cookies 5
Request headers 16
Response headers 12
Inspector
Notes
Event log (8)
All issues
Memory: 190.9MB of 980.0MB
Disabled

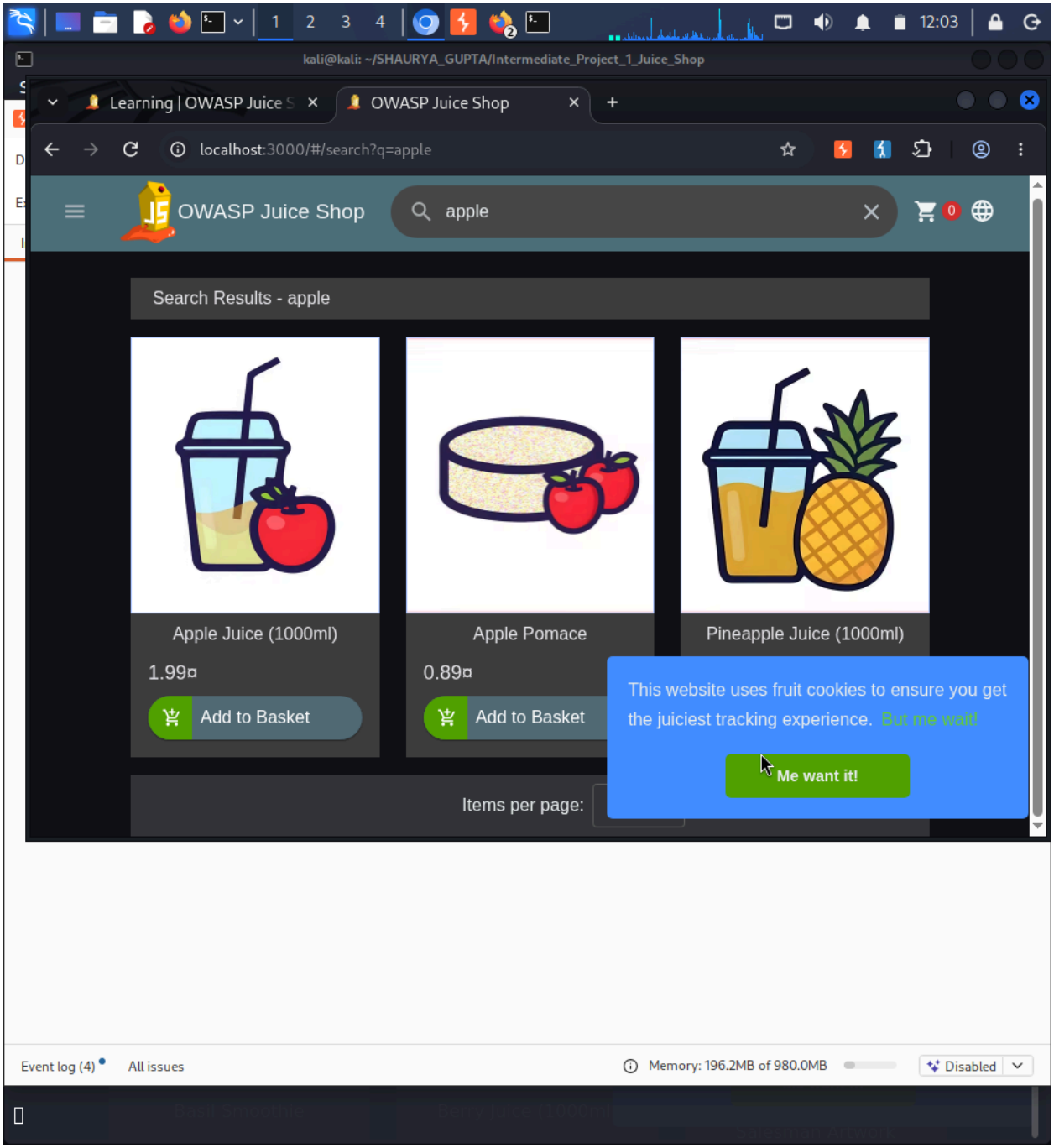

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Learning | OWASP Juice S
OWASP Juice Shop
localhost:3000/#/basket
Apple Juice (1000ml)
1
1.99¤
Apple Pomace
1
0.89¤
Banana Juice (1000ml)
1
1.99¤
Best Juice Shop Salesman Artwork
1
5000¤
Accept-Ranges: bytes
Cache-Control: public, max-age=0
Last-Modified: Mon, 12 Oct 2026 14:50:15 GMT
ETag: W/"254d-1a13097c458"
Date: Sat, 24 Oct 2026 17:29:13 GMT
Connection: keep-alive
Keep-Alive: timeout=5
Search
0 highlights
Notes
Event log (8)
All issues
Memory: 187.2MB of 980.0MB
Disabled

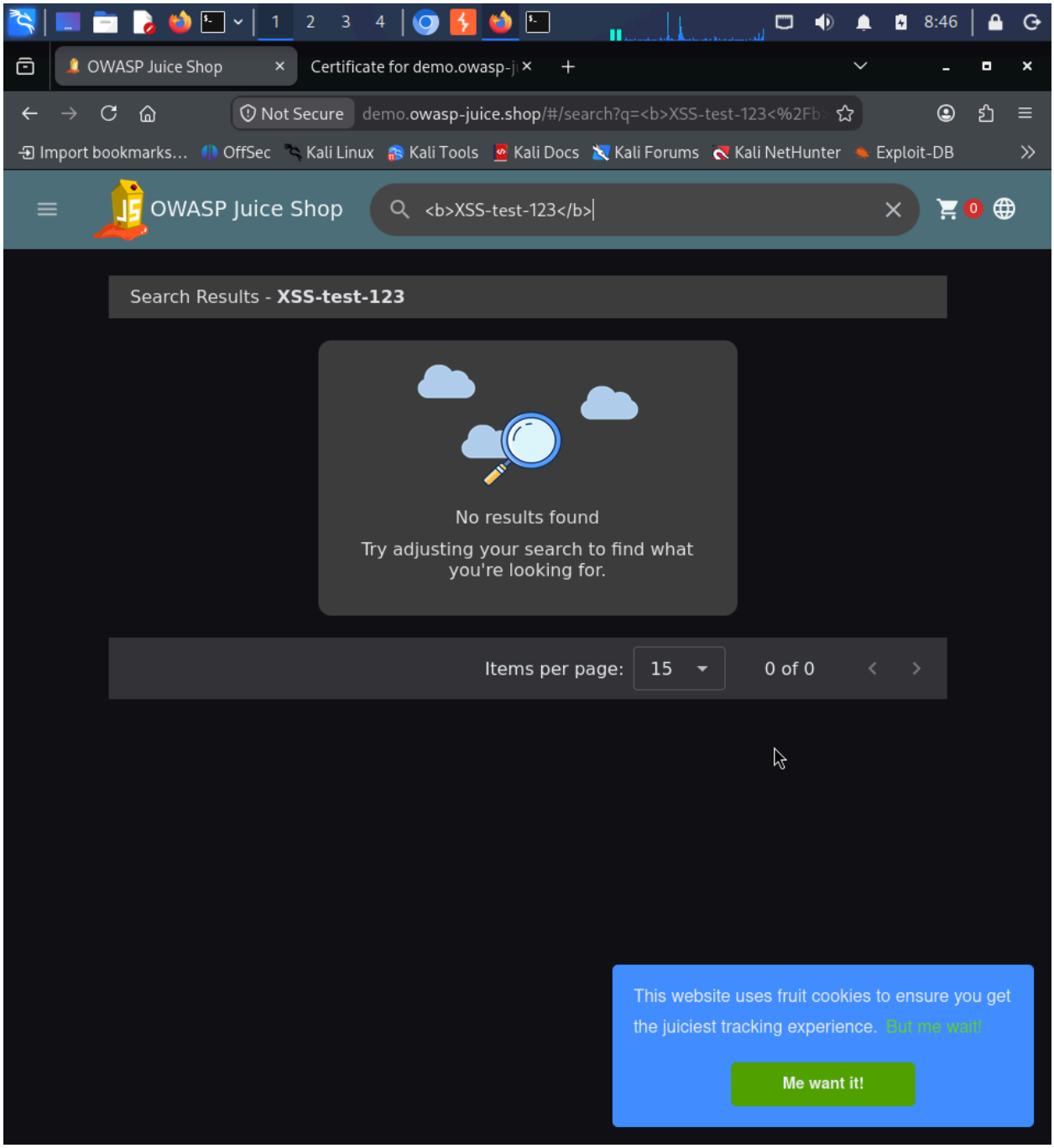

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Learning | OWASP Juice S
OWASP Juice Shop
localhost:3000/#/basket
Apple Juice (1000ml)
1
1.99¤
Apple Pomace
1
0.89¤
Banana Juice (1000ml)
1
1.99¤
Best Juice Shop Salesman Artwork
1
5000¤
Accept-Ranges: bytes
Cache-Control: public, max-age=0
Last-Modified: Mon, 12 Oct 2026 14:50:15 GMT
ETag: W/"254d-1a13097c458"
Date: Sat, 24 Oct 2026 17:29:13 GMT
Connection: keep-alive
Keep-Alive: timeout=5
Search
0 highlights
Notes
Event log (8)
All issues
Memory: 184.7MB of 980.0MB
Disabled

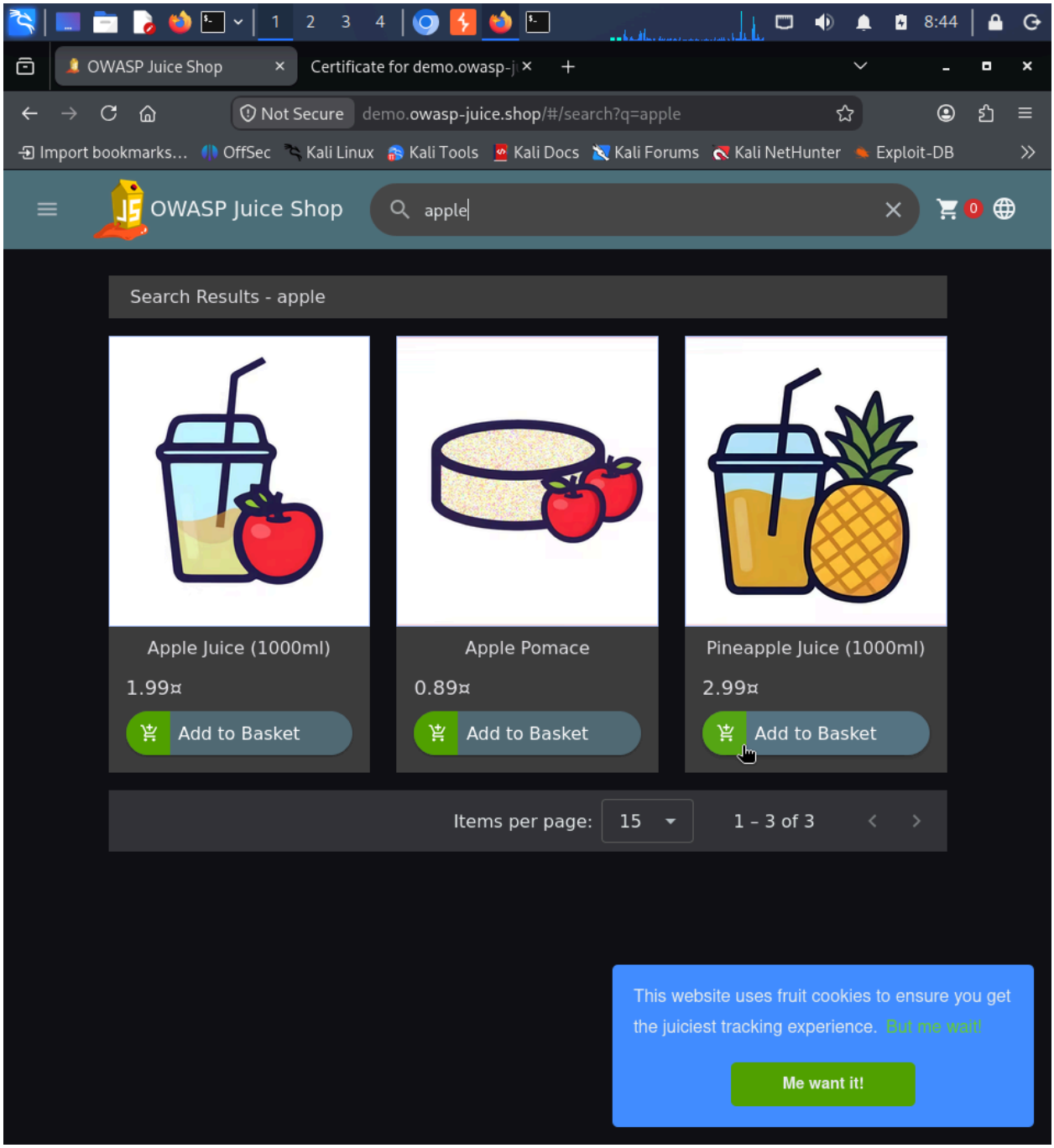

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title
369 http://localhost:3000 GET /assets/public/images/products/be... 304 392 avif
370 http://localhost:3000 GET /assets/public/images/products/art... 304 392 avif
371 http://localhost:3000 GET /assets/public/images/products/ba... 304 392 avif
372 http://localhost:3000 GET /assets/public/images/products/br... 304 392 avif
373 http://localhost:3000 GET /assets/public/images/products/eld... 304 392 avif
374 http://localhost:3000 GET /assets/public/images/products/eg... 304 392 avif
375 http://localhost:3000 GET /assets/public/images/products/dr... 304 392 avif
376 http://localhost:3000 GET /assets/public/images/products/car... 304 392 avif
377 http://localhost:3000 GET /assets/public/images/products/fru... 304 392 avif
378 http://localhost:3000 GET /assets/public/images/products/gr... 304 392 avif
379 http://localhost:3000 GET /assets/public/images/products/gr... 304 392 avif
380 http://localhost:3000 GET /assets/public/images/products/pe... 304 392 avif
381 http://localhost:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 374 text io/
382 http://localhost:3000 POST /socket.io/?EIO=4&transport=pollin... ✓ 200 240 HTML io/
383 http://localhost:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 287 text io/
384 http://localhost:3000 GET /socket.io/?EIO=4&transport=webs... ✓ 101 195 io/
385 http://localhost:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 255 text io/
386 http://localhost:3000 GET /assets/public/images/products/pin... 304 392 avif
Request Response
Pretty Raw Hex Render
1 HTTP/1.1 304 Not Modified
2 Access-Control-Allow-Origin: *
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Feature-Policy: payment 'self'
6 X-Recruiting: /#/jobs
7 Accept-Ranges: bytes
8 Cache-Control: public, max-age=0
9 Last-Modified: Mon, 12 Oct 2026 14:50:15 GMT
10 ETag: W/"254d-1a13097c458"
11 Date: Sat, 24 Oct 2026 17:29:13 GMT
12 Connection: keep-alive
13 Keep-Alive: timeout=5
14
15
Search
0 highlights
Inspector
Request attributes 2
Request cookies 4
Request headers 16
Response headers 12
Inspector
Notes
Event log (8)
All issues
Memory: 184.7MB of 980.0MB
Disabled

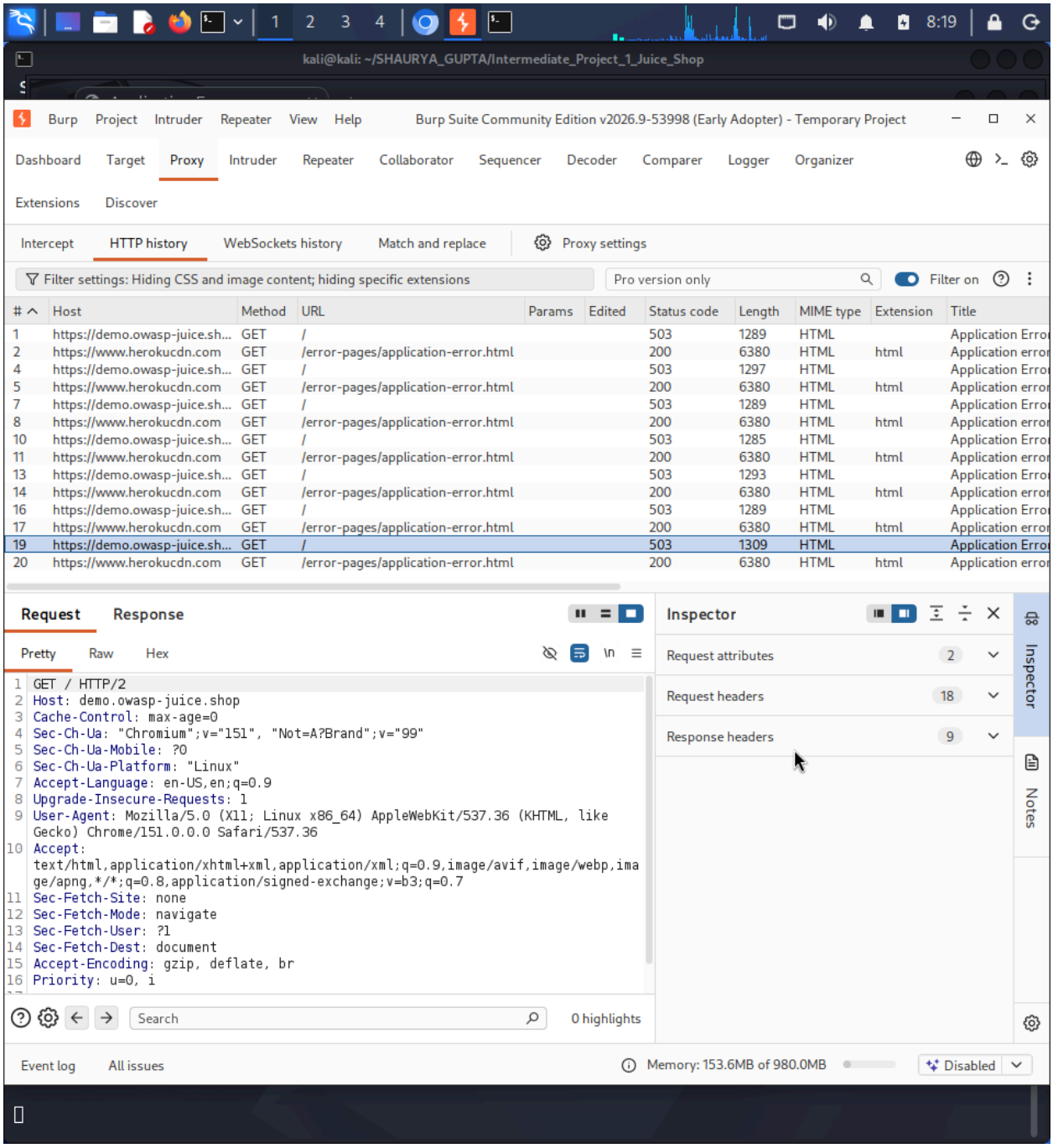

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Learning | OWASP Juice S
OWASP Juice Shop
localhost:3000/#/search?q=<iframe%20src%3D"javascript:alert(%60xss%...
localhost:3000 says
xss
OK
Search Results -
No results found
Try adjusting your search to find what you're looking for.
Items per page: 15
0 of 0
Search
0 highlights
Event log (8)
All issues
Memory: 192.4MB of 980.0MB
Disabled

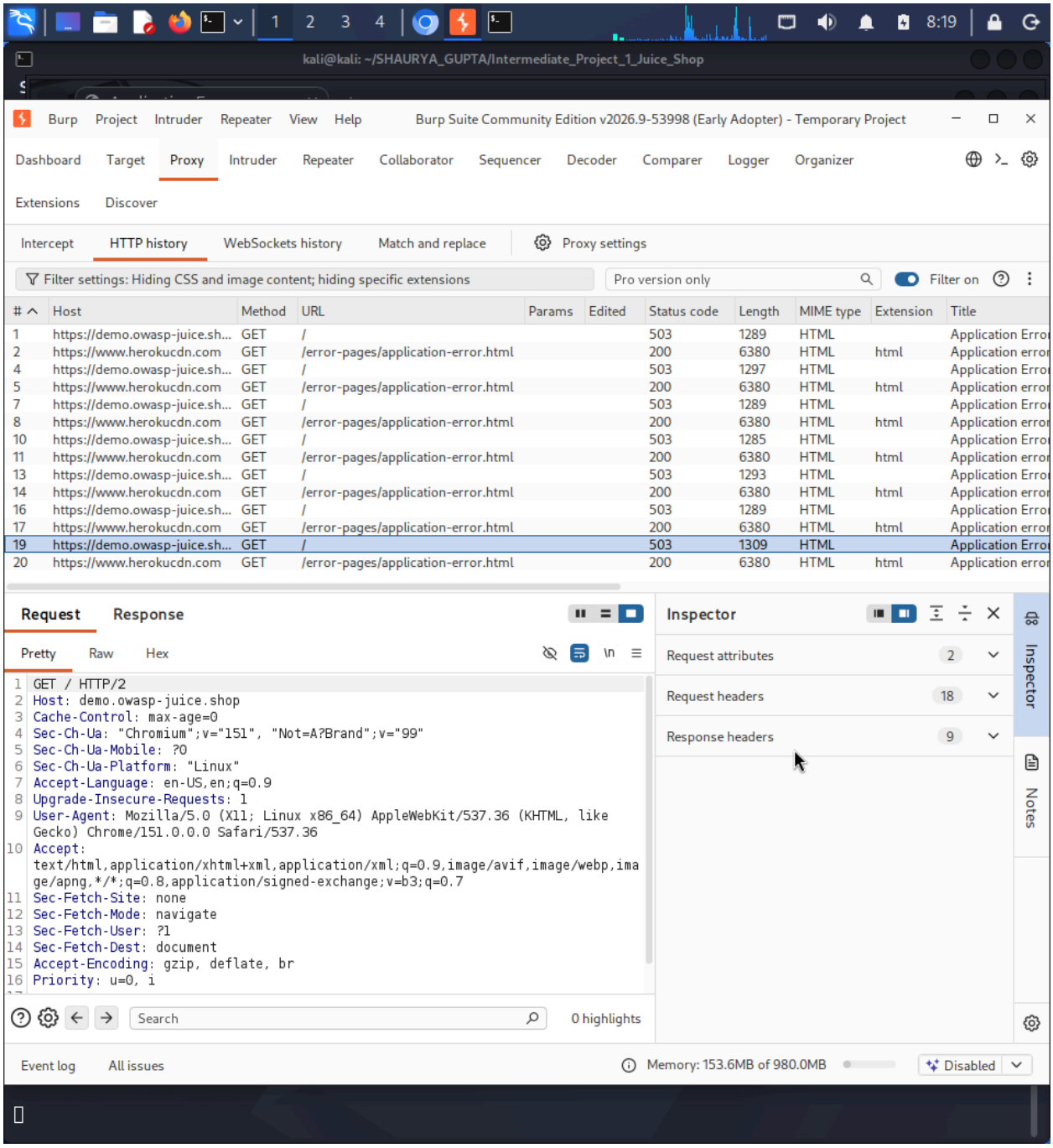

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title
373 http://localhost:3000 GET /assets/public/images/products/eld... 304 392 avif
374 http://localhost:3000 GET /assets/public/images/products/eg... 304 392 avif
375 http://localhost:3000 GET /assets/public/images/products/dr... 304 392 avif
376 http://localhost:3000 GET /assets/public/images/products/car... 304 392 avif
377 http://localhost:3000 GET /assets/public/images/products/fru... 304 392 avif
378 http://localhost:3000 GET /assets/public/images/products/gr... 304 392 avif
379 http://localhost:3000 GET /assets/public/images/products/gr... 304 392 avif
380 http://localhost:3000 GET /assets/public/images/products/pe... 304 392 avif
381 http://localhost:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 374 text io/
382 http://localhost:3000 POST /socket.io/?EIO=4&transport=pollin... ✓ 200 240 HTML io/
383 http://localhost:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 287 text io/
384 http://localhost:3000 GET /socket.io/?EIO=4&transport=webs... ✓ 101 195 io/
385 http://localhost:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 255 text io/
Request Response
Pretty Raw Hex
11 Origin: http://localhost:3000
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: http://localhost:3000/
16 Accept-Encoding: gzip, deflate, br
17 Cookie: language=en; welcomebanner_status=dismiss; cookieconsent_status=dismiss; token=
eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJkYXRhIjp7ImlkIjoyNSwidXNlcm5hbWUiOiIiLCJlbWFpbCI6InN0dWRlbnQubGFiQGV4YW1wbGUuY29tIiwicGFzc3dvcmQiOiI0YTg4ZGM1MzYzNjY2YTU1MjBmOTQwYWU0ODE4NWI1YyIsInJvbGUiOiJjdXN0b2llciIsImRlbHV4ZVRva2VuIjoiIiwibGFzdExvZ2luSXAiOiIwLjAuMC4wIiwicHJvZmlsZUltYWdlIjoiL2Fzc2V0cy9wdWJsaWMvaW1hZ2VzL3VwbG9hZHMvZGVmYXVsdC5zdmciLCJ0b3RwU2VjcmV0IjoiIiwiaXNBY3RpdmUiOnRydWUsImNyZWF0ZWRBdCI6IjIwMjYtMTAtMjQgMTc6MjE6MTIuODAwICswMDowMCIsInVwZGF0ZWRBdCI6IjIwMjYtMTAtMjQgMTc6MjE6MTIuODAwICswMDowMCIsImRlbGV0ZWRBdCI6bnVsbH0sImJpZCI6NiwiaWF0IjoxNzkyODYyNDk2fQ.Nk3qVVYqk4qx3DkwqgehhPJtIiwd9MCFOaEIwHnTUSEolWwbHoluAeU8hzyTJRH7MZ3hr2drJAVjDEFdhtefkxNvF6WjnfkVU5fCa6szP7NxsdL9zEOD4AlZIrIJ4dqI6SIJ7gKR--SrRTJd9aVyRi--vwE0XrHEJy5BfoFJ7iE
18 Connection: keep-alive
19
20 40
Search
0 highlights
Inspector
Request attributes 2
Request query parameters 4
Request body parameters 1
Request cookies 4
Request headers 17
Response headers 8
Inspector
Notes
Event log (8)
All issues
Memory: 192.6MB of 980.0MB
Disabled

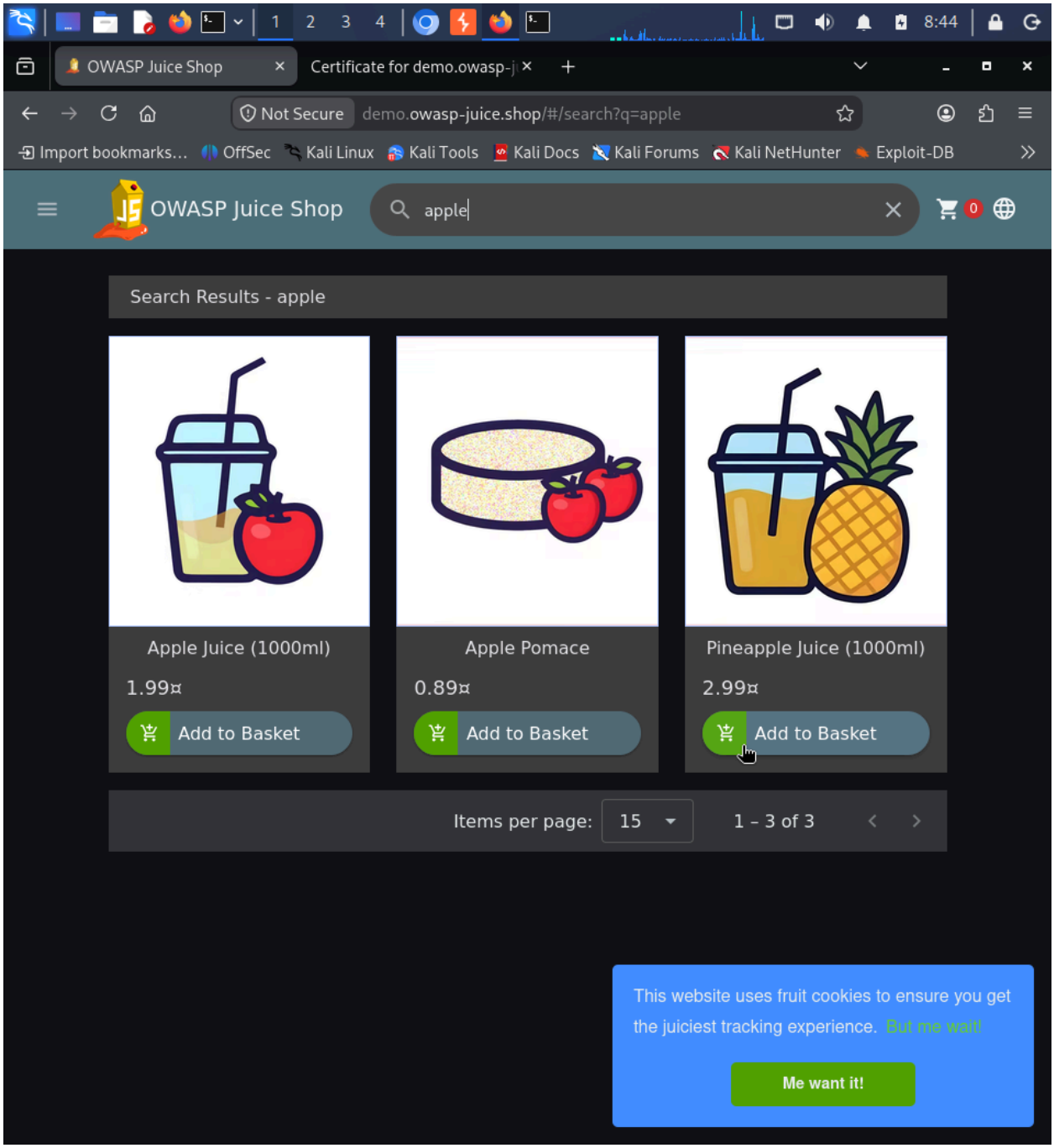

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Learning | OWASP Juice S
OWASP Juice Shop
localhost:3000/#/search?q=apple
OWASP Juice Shop
apple
Search Results - apple
Apple Juice (1000ml)
1.99¤
Add to Basket
Apple Pomace
0.89¤
Add to Basket
Pineapple Juice (1000ml)
This website uses fruit cookies to ensure you get the juiciest tracking experience. But me wait!
Me want it!
Items per page:
Event log (4)
All issues
Memory: 196.2MB of 980.0MB
Disabled

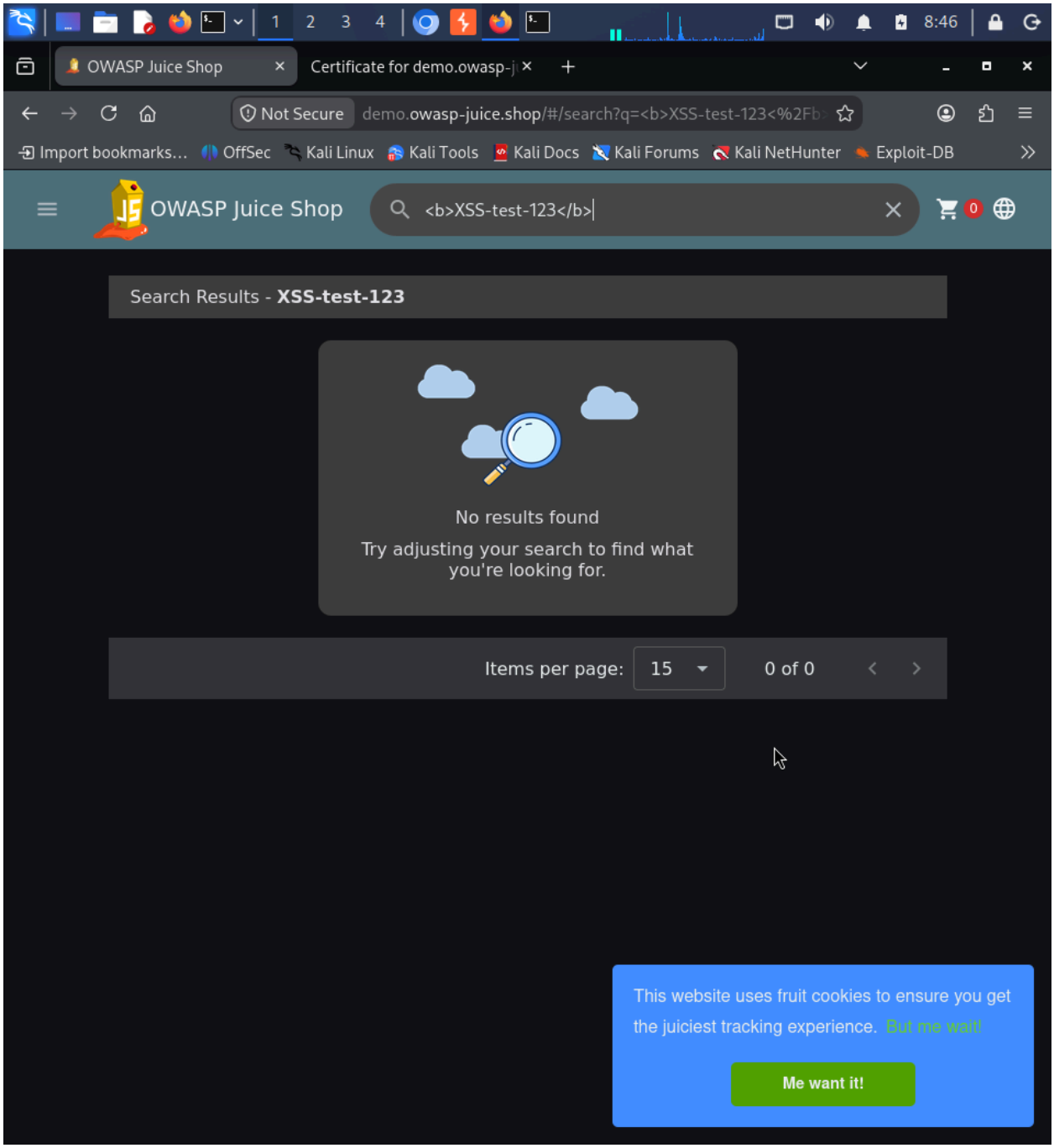

8:46
OWASP Juice Shop
Certificate for demo.owasp-j
Not Secure
demo.owasp-juice.shop/#/search?q=XSS-test-123<%2Fb
Import bookmarks...
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
OWASP Juice Shop
XSS-test-123
Search Results - XSS-test-123
No results found
Try adjusting your search to find what you're looking for.
Items per page:
15
0 of 0
This website uses fruit cookies to ensure you get the juiciest tracking experience.
But me wait!
Me want it!

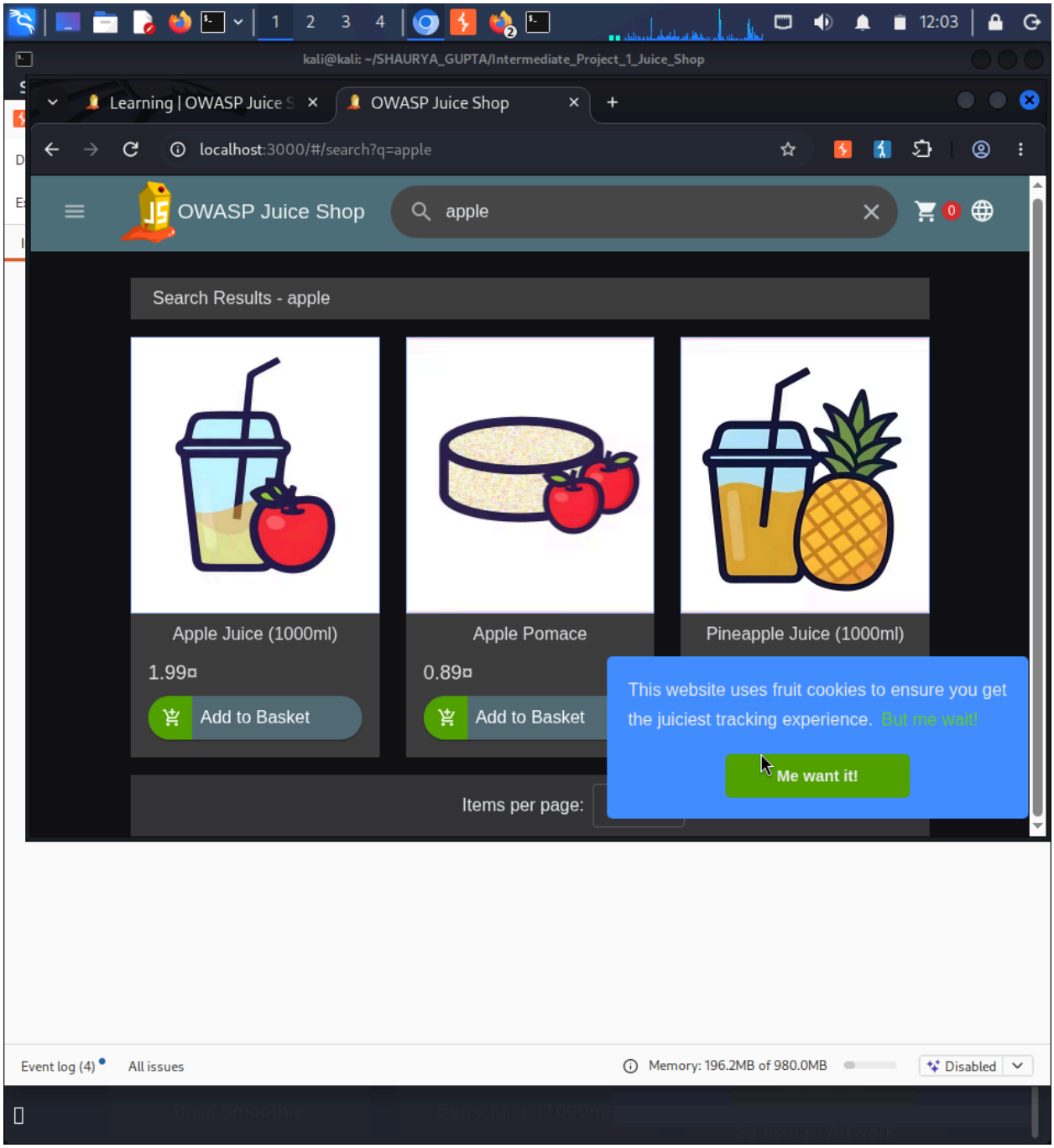

OWASP Juice Shop
Certificate for demo.owasp-j
Not Secure
demo.owasp-juice.shop/#/search?q=apple
Import bookmarks...
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
OWASP Juice Shop
apple
Search Results - apple
Apple Juice (1000ml)
1.99¤
Add to Basket
Apple Pomace
0.89¤
Add to Basket
Pineapple Juice (1000ml)
2.99¤
Add to Basket
Items per page:
15
1 - 3 of 3
This website uses fruit cookies to ensure you get the juiciest tracking experience.
But me wait!
Me want it!

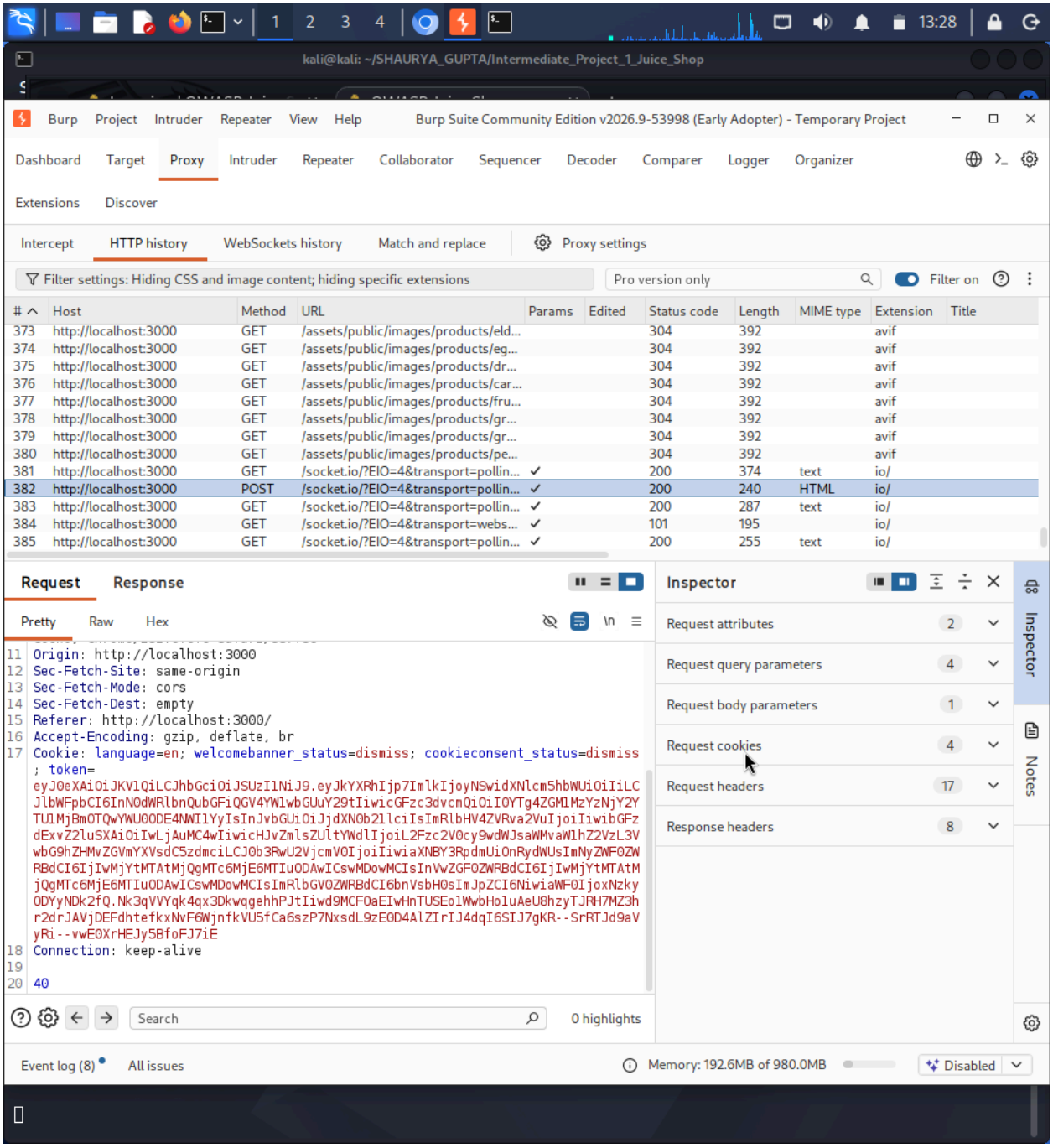

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title
1 https://demo.owasp-juice.sh... GET / 503 1289 HTML Application Erro
2 https://www.herokucdn.com GET /error-pages/application-error.html 200 6380 HTML html Application error
4 https://demo.owasp-juice.sh... GET / 503 1297 HTML Application Erro
5 https://www.herokucdn.com GET /error-pages/application-error.html 200 6380 HTML html Application error
7 https://demo.owasp-juice.sh... GET / 503 1289 HTML Application Erro
8 https://www.herokucdn.com GET /error-pages/application-error.html 200 6380 HTML html Application error
10 https://demo.owasp-juice.sh... GET / 503 1285 HTML Application Erro
11 https://www.herokucdn.com GET /error-pages/application-error.html 200 6380 HTML html Application error
13 https://demo.owasp-juice.sh... GET / 503 1293 HTML Application Erro
14 https://www.herokucdn.com GET /error-pages/application-error.html 200 6380 HTML html Application error
16 https://demo.owasp-juice.sh... GET / 503 1289 HTML Application Erro
17 https://www.herokucdn.com GET /error-pages/application-error.html 200 6380 HTML html Application error
19 https://demo.owasp-juice.sh... GET / 503 1309 HTML Application Erro
20 https://www.herokucdn.com GET /error-pages/application-error.html 200 6380 HTML html Application error
Request Response
Pretty Raw Hex
GET / HTTP/2
Host: demo.owasp-juice.shop
Cache-Control: max-age=0
Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Priority: u=0, i
Search
0 highlights
Inspector
Request attributes 2
Request headers 18
Response headers 9
Inspector
Notes
Event log All issues
Memory: 153.6MB of 980.0MB
Disabled

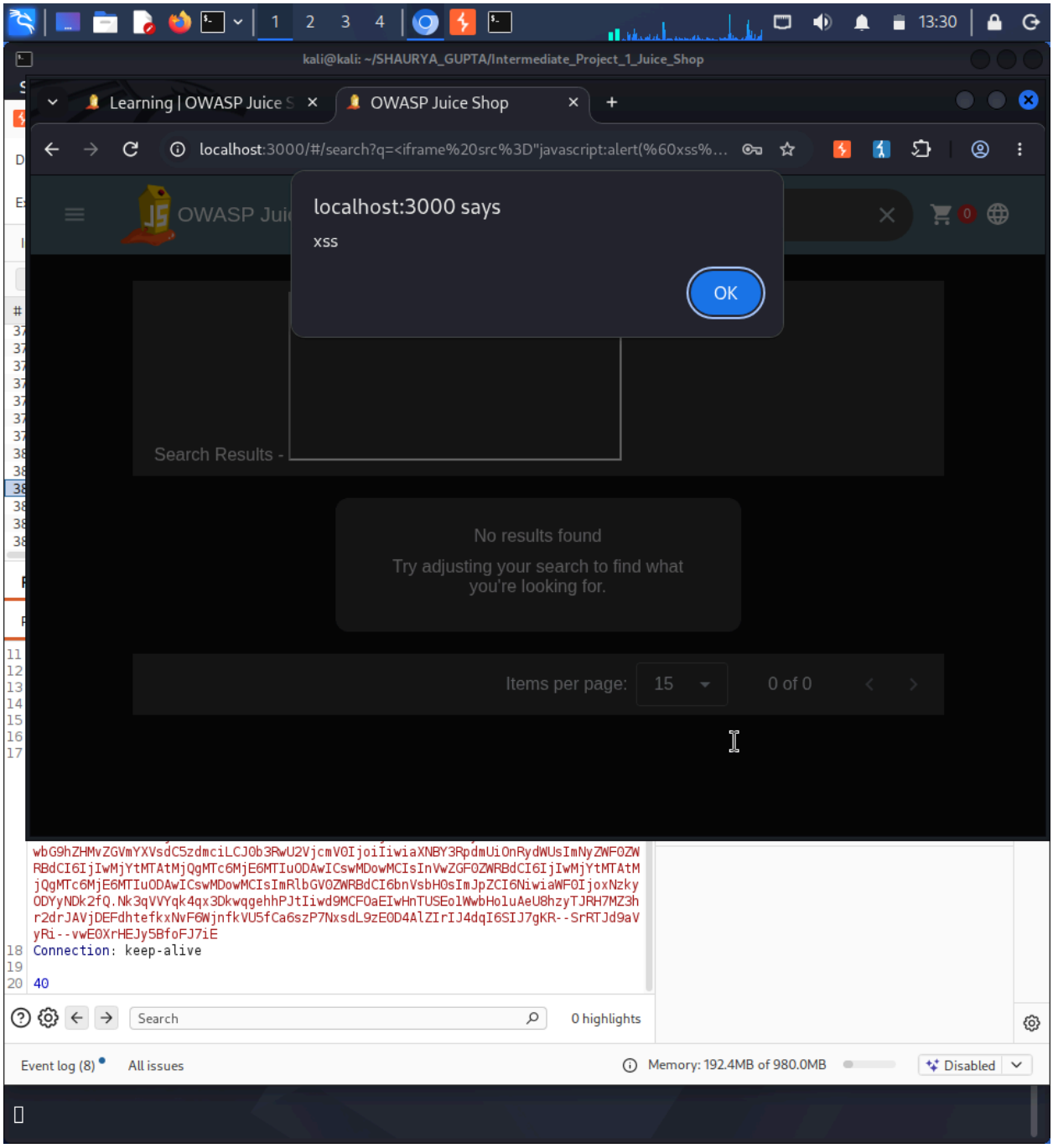

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title
1 https://demo.owasp-juice.sh... GET / 503 1289 HTML Application Erro
2 https://www.herokucdn.com GET /error-pages/application-error.html 200 6380 HTML html Application error
4 https://demo.owasp-juice.sh... GET / 503 1297 HTML Application Erro
5 https://www.herokucdn.com GET /error-pages/application-error.html 200 6380 HTML html Application error
7 https://demo.owasp-juice.sh... GET / 503 1289 HTML Application Erro
8 https://www.herokucdn.com GET /error-pages/application-error.html 200 6380 HTML html Application error
10 https://demo.owasp-juice.sh... GET / 503 1285 HTML Application Erro
11 https://www.herokucdn.com GET /error-pages/application-error.html 200 6380 HTML html Application error
13 https://demo.owasp-juice.sh... GET / 503 1293 HTML Application Erro
14 https://www.herokucdn.com GET /error-pages/application-error.html 200 6380 HTML html Application error
16 https://demo.owasp-juice.sh... GET / 503 1289 HTML Application Erro
17 https://www.herokucdn.com GET /error-pages/application-error.html 200 6380 HTML html Application error
19 https://demo.owasp-juice.sh... GET / 503 1309 HTML Application Erro
20 https://www.herokucdn.com GET /error-pages/application-error.html 200 6380 HTML html Application error
Request Response
Pretty Raw Hex
GET / HTTP/2
Host: demo.owasp-juice.shop
Cache-Control: max-age=0
Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Priority: u=0, i
Search
0 highlights
Inspector
Request attributes 2
Request headers 18
Response headers 9
Inspector
Notes
Event log All issues
Memory: 153.6MB of 980.0MB
Disabled

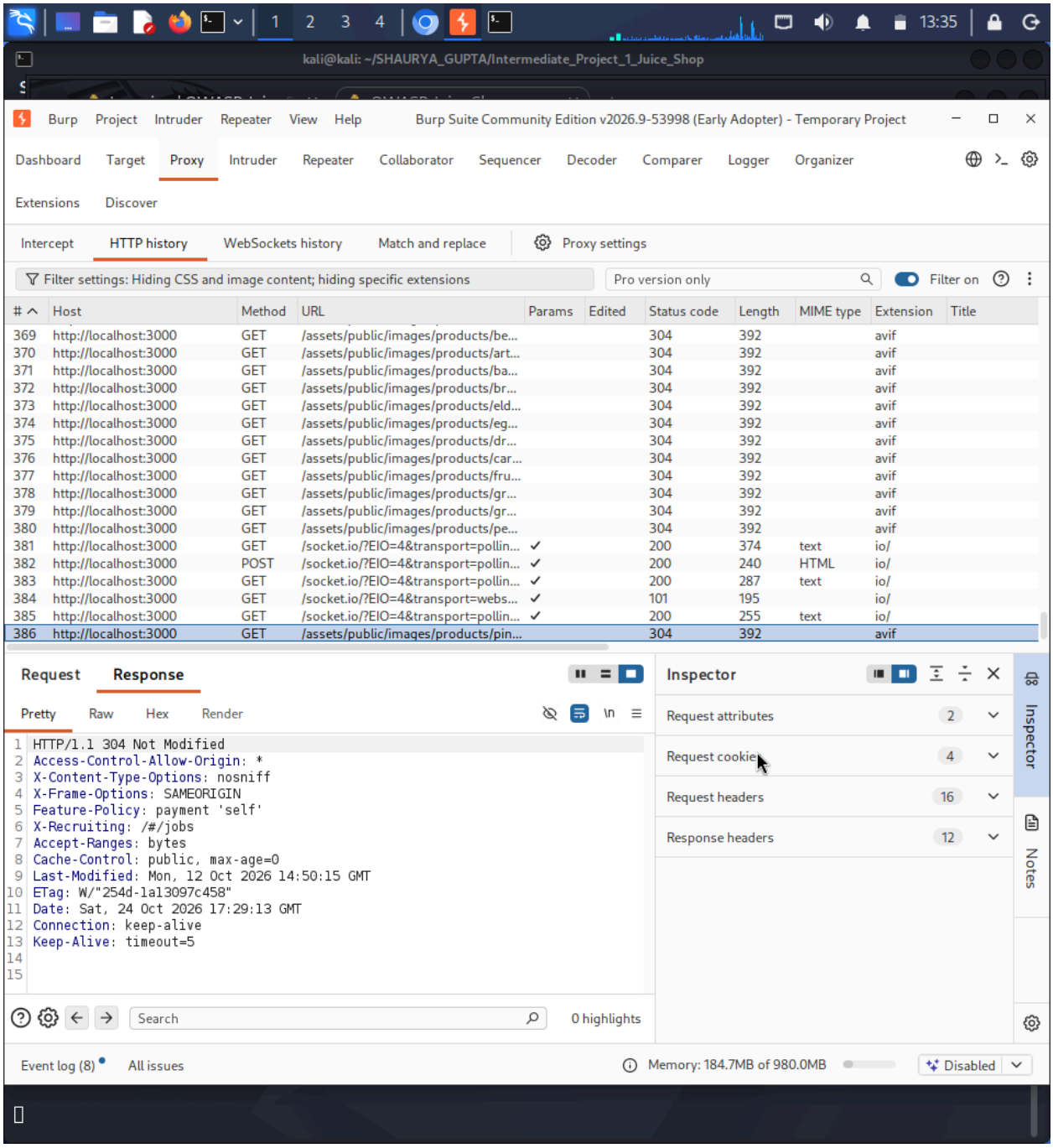

OWASP Juice Shop
Certificate for demo.owasp-j
Not Secure
demo.owasp-juice.shop/#/search?q=apple
Import bookmarks...
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
OWASP Juice Shop
apple
Search Results - apple
Apple Juice (1000ml)
1.99¤
Add to Basket
Apple Pomace
0.89¤
Add to Basket
Pineapple Juice (1000ml)
2.99¤
Add to Basket
Items per page:
15
1 - 3 of 3
This website uses fruit cookies to ensure you get the juiciest tracking experience.
But me wait!
Me want it!

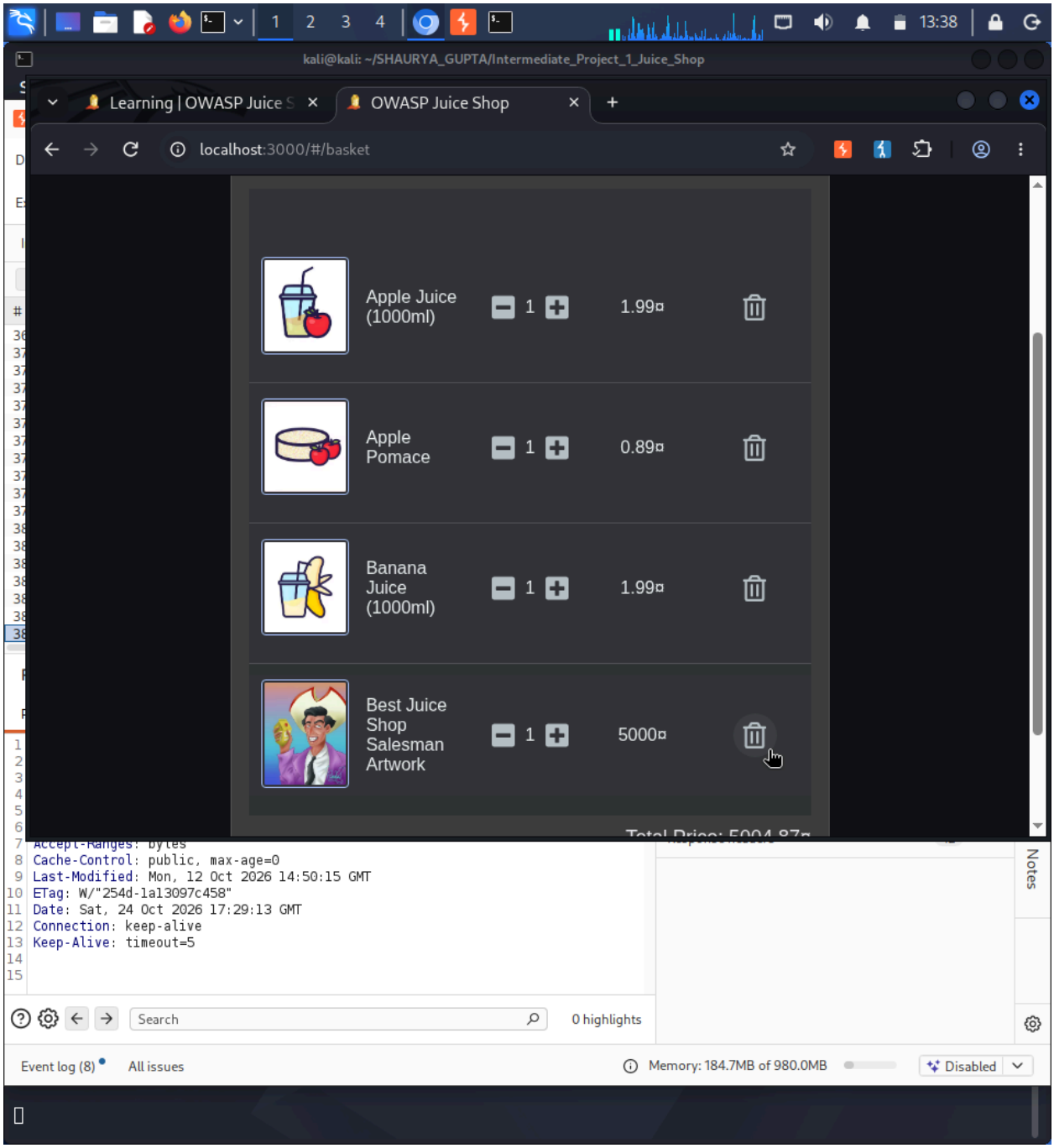

8:46
OWASP Juice Shop
Certificate for demo.owasp-j
Not Secure
demo.owasp-juice.shop/#/search?q=XSS-test-123<%2Fb
Import bookmarks...
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
OWASP Juice Shop
XSS-test-123
Search Results - XSS-test-123
No results found
Try adjusting your search to find what you're looking for.
Items per page:
15
0 of 0
This website uses fruit cookies to ensure you get the juiciest tracking experience.
But me wait!
Me want it!

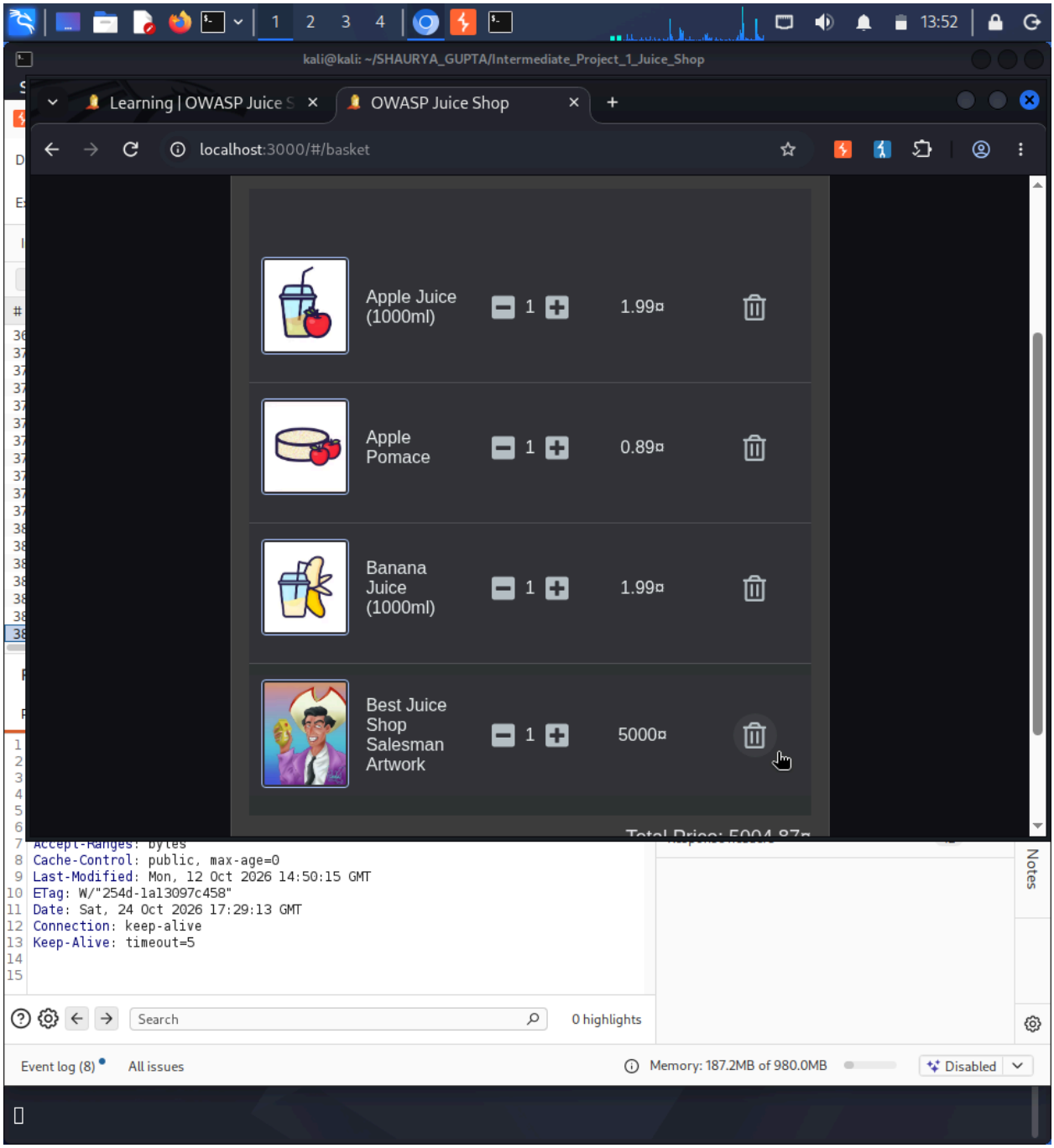

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Learning | OWASP Juice S
OWASP Juice Shop
localhost:3000/#/search?q=apple
OWASP Juice Shop
apple
Search Results - apple
Apple Juice (1000ml)
1.99¤
Add to Basket
Apple Pomace
0.89¤
Add to Basket
Pineapple Juice (1000ml)
This website uses fruit cookies to ensure you get the juiciest tracking experience. But me wait!
Me want it!
Items per page:
Event log (4)
All issues
Memory: 196.2MB of 980.0MB
Disabled

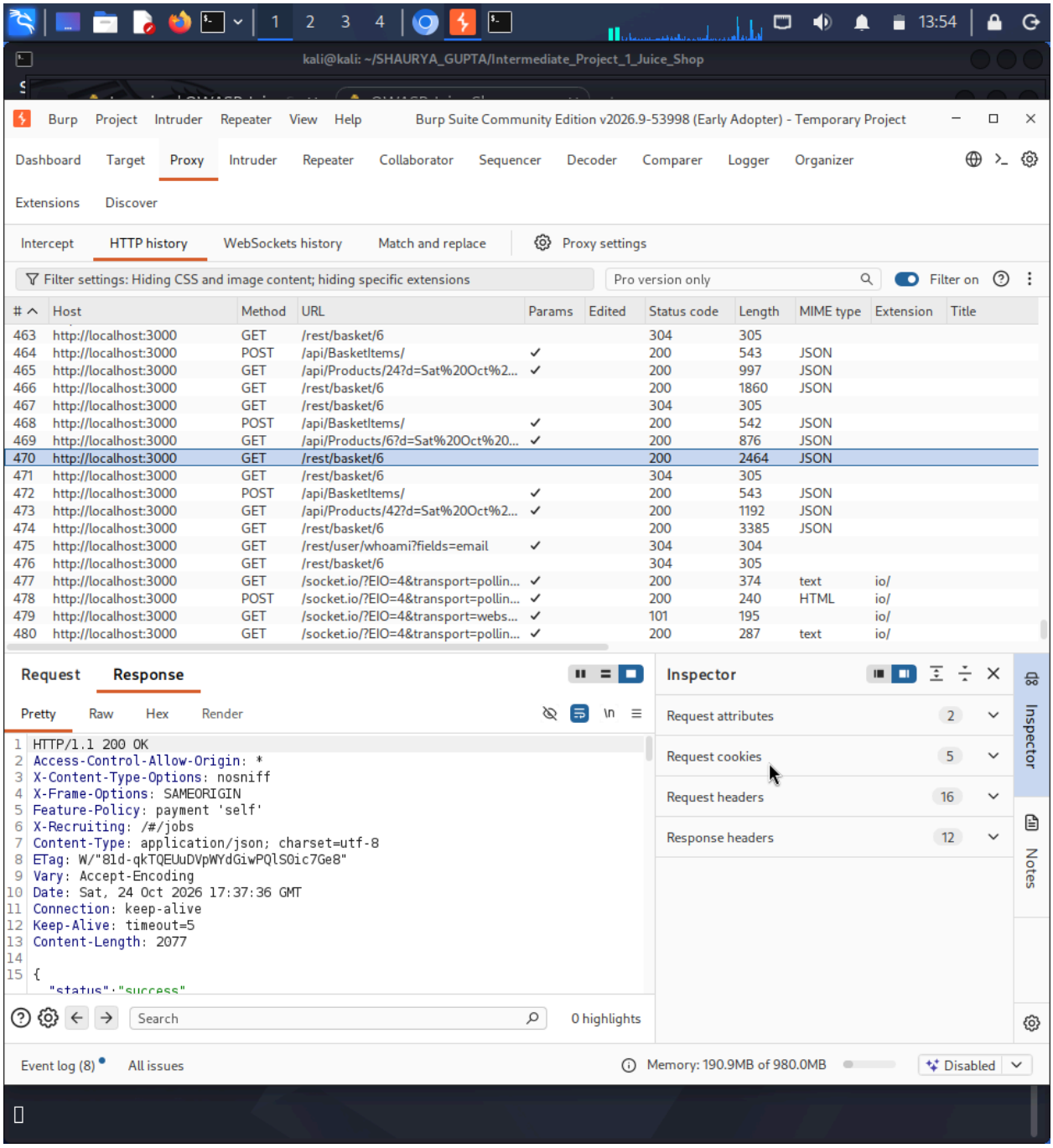

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title
373 http://localhost:3000 GET /assets/public/images/products/eld... 304 392 avif
374 http://localhost:3000 GET /assets/public/images/products/eg... 304 392 avif
375 http://localhost:3000 GET /assets/public/images/products/dr... 304 392 avif
376 http://localhost:3000 GET /assets/public/images/products/car... 304 392 avif
377 http://localhost:3000 GET /assets/public/images/products/fru... 304 392 avif
378 http://localhost:3000 GET /assets/public/images/products/gr... 304 392 avif
379 http://localhost:3000 GET /assets/public/images/products/gr... 304 392 avif
380 http://localhost:3000 GET /assets/public/images/products/pe... 304 392 avif
381 http://localhost:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 374 text io/
382 http://localhost:3000 POST /socket.io/?EIO=4&transport=pollin... ✓ 200 240 HTML io/
383 http://localhost:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 287 text io/
384 http://localhost:3000 GET /socket.io/?EIO=4&transport=webs... ✓ 101 195 io/
385 http://localhost:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 255 text io/
Request Response
Pretty Raw Hex
11 Origin: http://localhost:3000
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: http://localhost:3000/
16 Accept-Encoding: gzip, deflate, br
17 Cookie: language=en; welcomebanner_status=dismiss; cookieconsent_status=dismiss; token=
eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJkYXRhIjp7ImlkIjoyNSwidXNlcm5hbWUiOiIiLCJlbWFpbCI6InN0dWRlbnQubGFiQGV4YW1wbGUuY29tIiwicGFzc3dvcmQiOiI0YTg4ZGM1MzYzNjY2YTU1MjBmOTQwYWU0ODE4NWI1YyIsInJvbGUiOiJjdXN0b2llciIsImRlbHV4ZVRva2VuIjoiIiwibGFzdExvZ2luSXAiOiIwLjAuMC4wIiwicHJvZmlsZUltYWdlIjoiL2Fzc2V0cy9wdWJsaWMvaW1hZ2VzL3VwbG9hZHMvZGVmYXVsdC5zdmciLCJ0b3RwU2VjcmV0IjoiIiwiaXNBY3RpdmUiOnRydWUsImNyZWF0ZWRBdCI6IjIwMjYtMTAtMjQgMTc6MjE6MTIuODAwICswMDowMCIsInVwZGF0ZWRBdCI6IjIwMjYtMTAtMjQgMTc6MjE6MTIuODAwICswMDowMCIsImRlbGV0ZWRBdCI6bnVsbH0sImJpZCI6NiwiaWF0IjoxNzkyODYyNDk2fQ.Nk3qVVYqk4qx3DkwqgehhPJtIiwd9MCFOaEIwHnTUSEolWwbHoluAeU8hzyTJRH7MZ3hr2drJAVjDEFdhtefkxNvF6WjnfkVU5fCa6szP7NxsdL9zEOD4AlZIrIJ4dqI6SIJ7gKR--SrRTJd9aVyRi--vwE0XrHEJy5BfoFJ7iE
18 Connection: keep-alive
19
20 40
Search
0 highlights
Inspector
Request attributes 2
Request query parameters 4
Request body parameters 1
Request cookies 4
Request headers 17
Response headers 8
Inspector
Notes
Event log (8)
All issues
Memory: 192.6MB of 980.0MB
Disabled

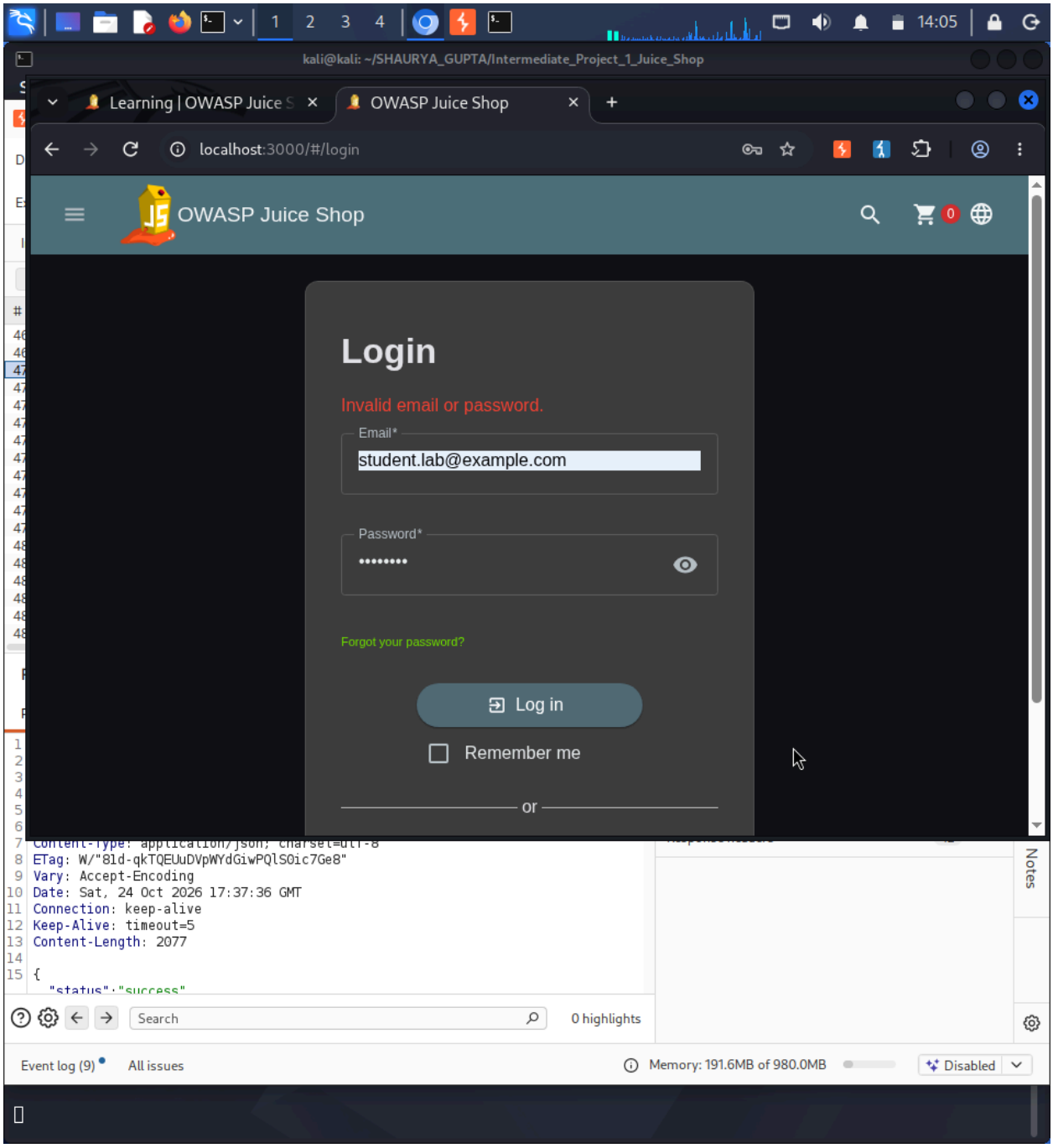

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Learning | OWASP Juice S
OWASP Juice Shop
localhost:3000/#/search?q=<iframe%20src%3D"javascript:alert(%60xss%...
localhost:3000 says
xss
OK
Search Results -
No results found
Try adjusting your search to find what you're looking for.
Items per page: 15
0 of 0
Search
0 highlights
Event log (8)
All issues
Memory: 192.4MB of 980.0MB
Disabled

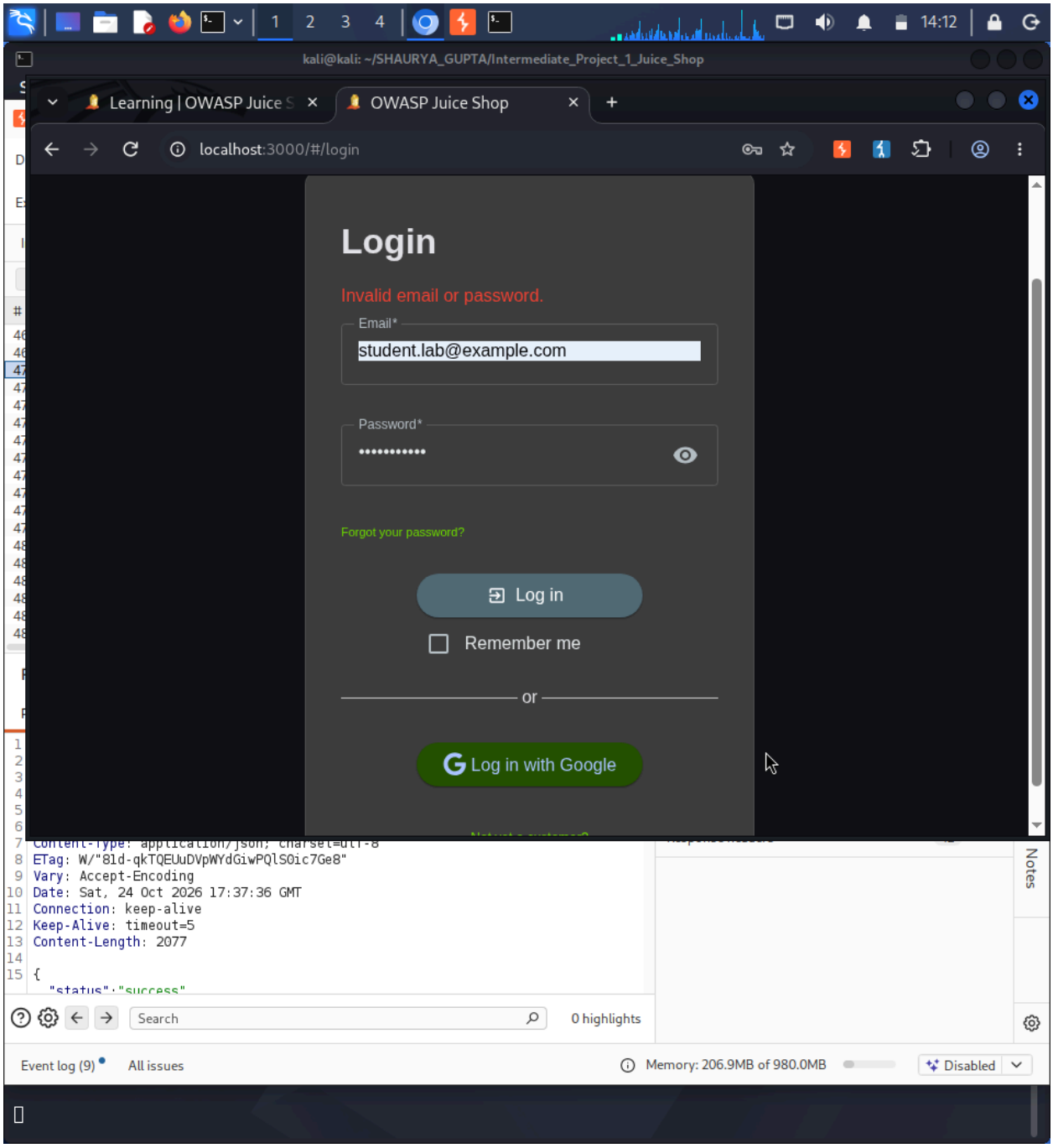

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title
369 http://localhost:3000 GET /assets/public/images/products/be... 304 392 avif
370 http://localhost:3000 GET /assets/public/images/products/art... 304 392 avif
371 http://localhost:3000 GET /assets/public/images/products/ba... 304 392 avif
372 http://localhost:3000 GET /assets/public/images/products/br... 304 392 avif
373 http://localhost:3000 GET /assets/public/images/products/eld... 304 392 avif
374 http://localhost:3000 GET /assets/public/images/products/eg... 304 392 avif
375 http://localhost:3000 GET /assets/public/images/products/dr... 304 392 avif
376 http://localhost:3000 GET /assets/public/images/products/car... 304 392 avif
377 http://localhost:3000 GET /assets/public/images/products/fru... 304 392 avif
378 http://localhost:3000 GET /assets/public/images/products/gr... 304 392 avif
379 http://localhost:3000 GET /assets/public/images/products/gr... 304 392 avif
380 http://localhost:3000 GET /assets/public/images/products/pe... 304 392 avif
381 http://localhost:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 374 text io/
382 http://localhost:3000 POST /socket.io/?EIO=4&transport=pollin... ✓ 200 240 HTML io/
383 http://localhost:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 287 text io/
384 http://localhost:3000 GET /socket.io/?EIO=4&transport=webs... ✓ 101 195 io/
385 http://localhost:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 255 text io/
386 http://localhost:3000 GET /assets/public/images/products/pin... 304 392 avif
Request Response
Pretty Raw Hex Render
1 HTTP/1.1 304 Not Modified
2 Access-Control-Allow-Origin: *
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Feature-Policy: payment 'self'
6 X-Recruiting: /#/jobs
7 Accept-Ranges: bytes
8 Cache-Control: public, max-age=0
9 Last-Modified: Mon, 12 Oct 2026 14:50:15 GMT
10 ETag: W/"254d-1a13097c458"
11 Date: Sat, 24 Oct 2026 17:29:13 GMT
12 Connection: keep-alive
13 Keep-Alive: timeout=5
14
15
Search
0 highlights
Inspector
Request attributes 2
Request cookies 4
Request headers 16
Response headers 12
Inspector
Notes
Event log (8)
All issues
Memory: 184.7MB of 980.0MB
Disabled

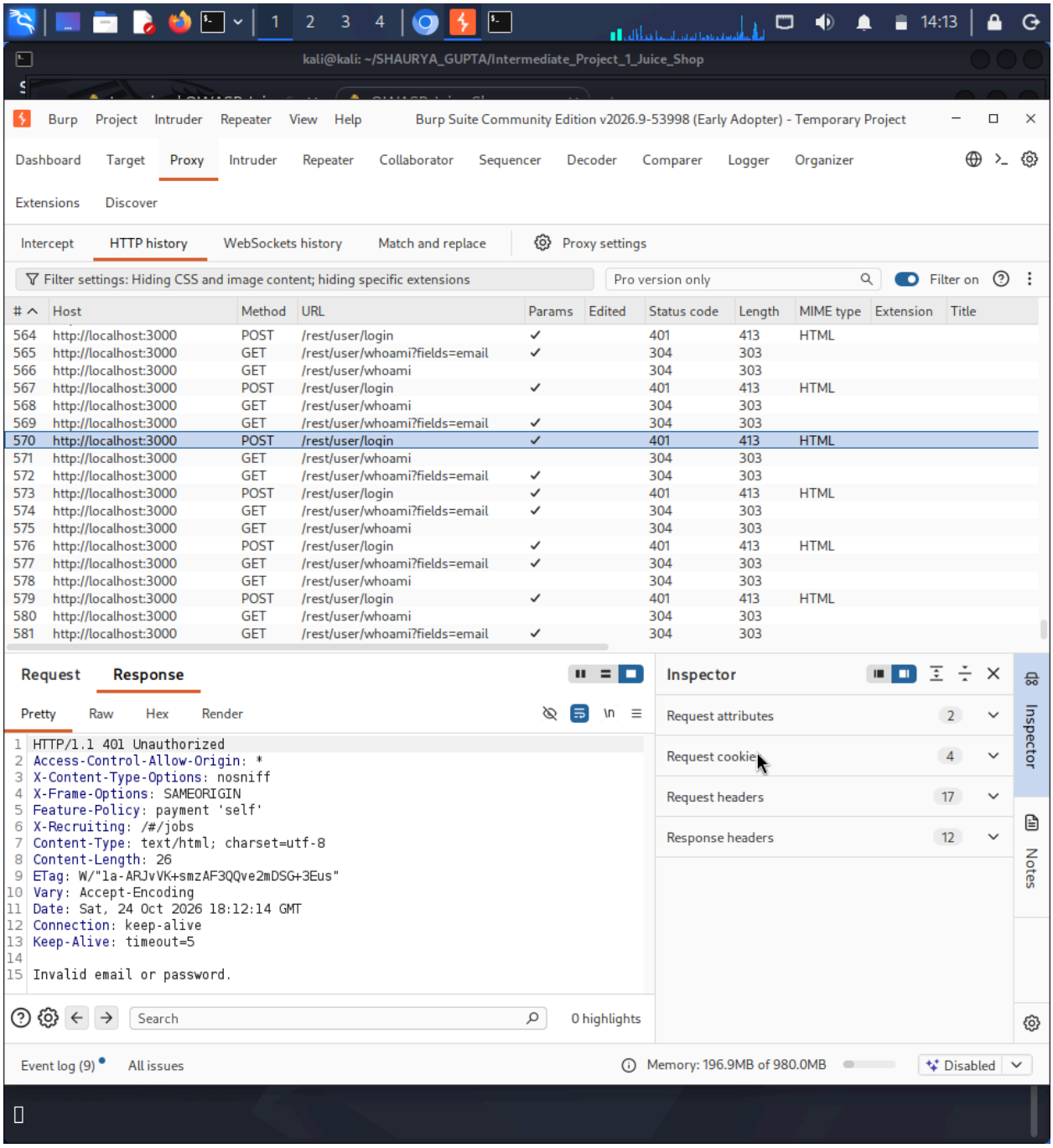

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Learning | OWASP Juice S
OWASP Juice Shop
localhost:3000/#/basket
Apple Juice (1000ml)
1
1.99¤
Apple Pomace
1
0.89¤
Banana Juice (1000ml)
1
1.99¤
Best Juice Shop Salesman Artwork
1
5000¤
Accept-Ranges: bytes
Cache-Control: public, max-age=0
Last-Modified: Mon, 12 Oct 2026 14:50:15 GMT
ETag: W/"254d-1a13097c458"
Date: Sat, 24 Oct 2026 17:29:13 GMT
Connection: keep-alive
Keep-Alive: timeout=5
Search
0 highlights
Notes
Event log (8)
All issues
Memory: 184.7MB of 980.0MB
Disabled

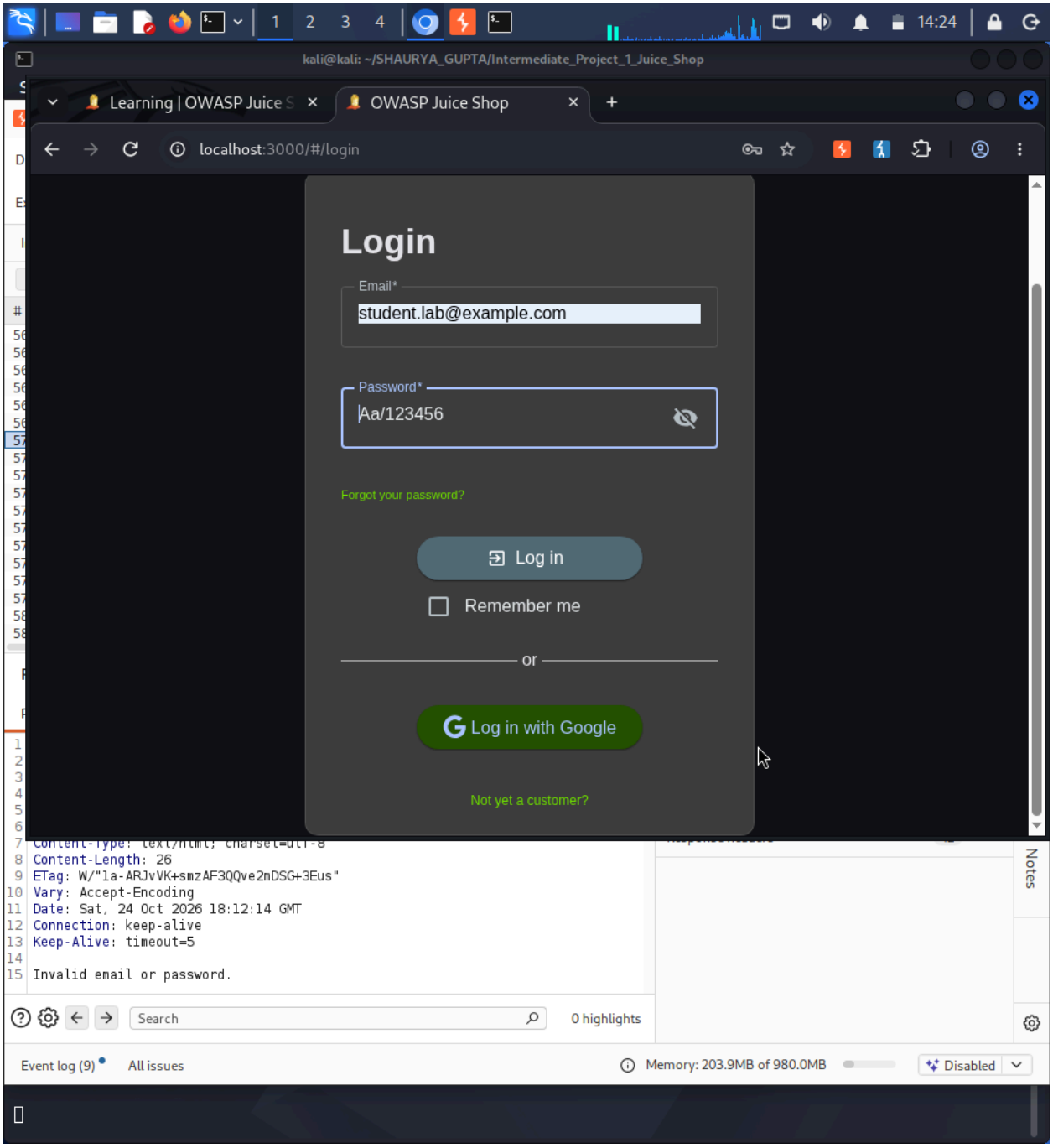

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Learning | OWASP Juice S
OWASP Juice Shop
localhost:3000/#/basket
Apple Juice (1000ml)
1
1.99¤
Apple Pomace
1
0.89¤
Banana Juice (1000ml)
1
1.99¤
Best Juice Shop Salesman Artwork
1
5000¤
Accept-Ranges: bytes
Cache-Control: public, max-age=0
Last-Modified: Mon, 12 Oct 2026 14:50:15 GMT
ETag: W/"254d-1a13097c458"
Date: Sat, 24 Oct 2026 17:29:13 GMT
Connection: keep-alive
Keep-Alive: timeout=5
Search
0 highlights
Notes
Event log (8)
All issues
Memory: 187.2MB of 980.0MB
Disabled

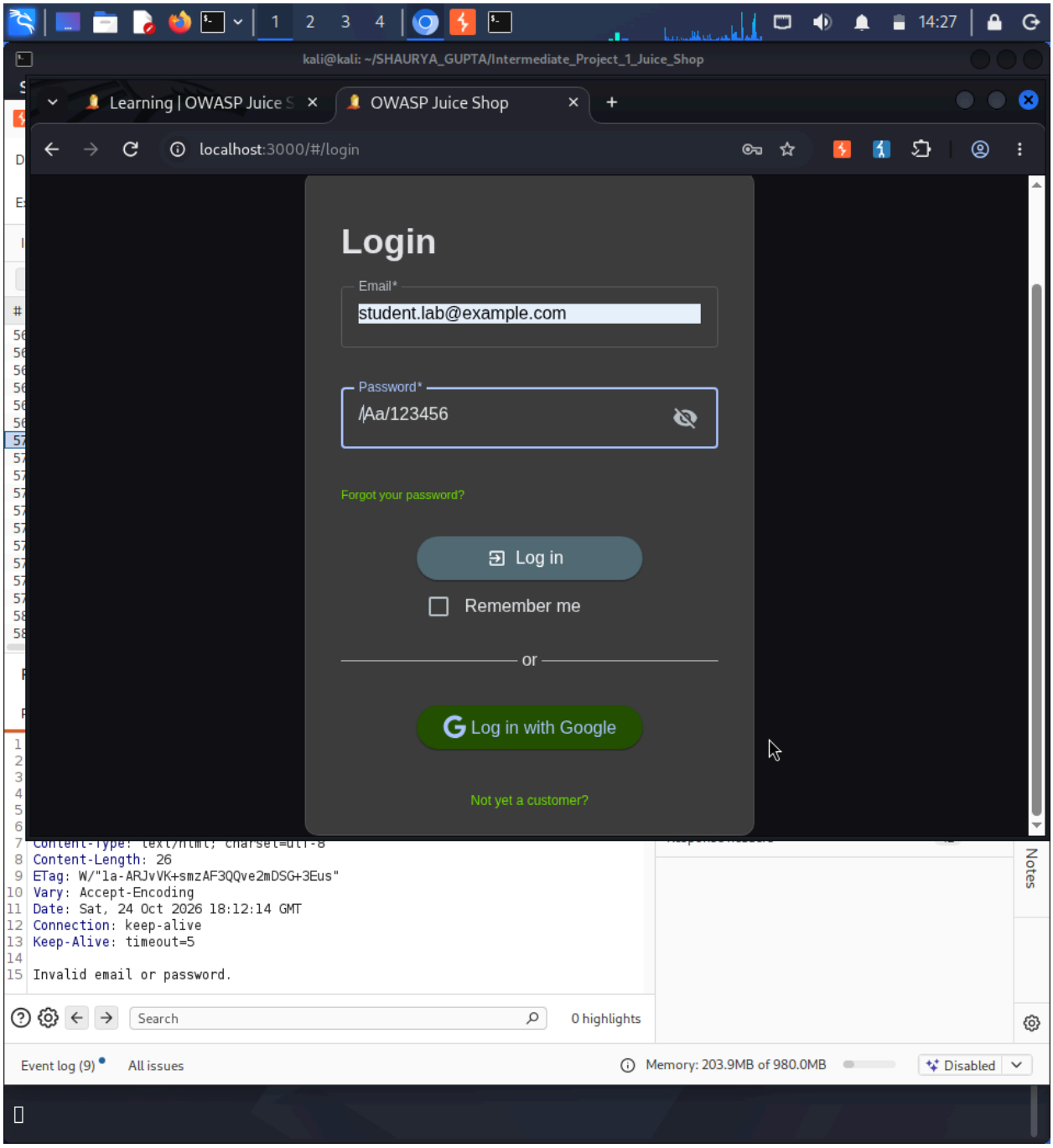

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title
463 http://localhost:3000 GET /rest/basket/6 304 305
464 http://localhost:3000 POST /api/BasketItems/ ✓ 200 543 JSON
465 http://localhost:3000 GET /api/Products/24?d=Sat%20Oct%2... ✓ 200 997 JSON
466 http://localhost:3000 GET /rest/basket/6 200 1860 JSON
467 http://localhost:3000 GET /rest/basket/6 304 305
468 http://localhost:3000 POST /api/BasketItems/ ✓ 200 542 JSON
469 http://localhost:3000 GET /api/Products/6?d=Sat%20Oct%20... ✓ 200 876 JSON
470 http://localhost:3000 GET /rest/basket/6 200 2464 JSON
471 http://localhost:3000 GET /rest/basket/6 304 305
472 http://localhost:3000 POST /api/BasketItems/ ✓ 200 543 JSON
473 http://localhost:3000 GET /api/Products/42?d=Sat%20Oct%2... ✓ 200 1192 JSON
474 http://localhost:3000 GET /rest/basket/6 200 3385 JSON
475 http://localhost:3000 GET /rest/user/whoami?fields=email ✓ 304 304
476 http://localhost:3000 GET /rest/basket/6 304 305
477 http://localhost:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 374 text io/
478 http://localhost:3000 POST /socket.io/?EIO=4&transport=pollin... ✓ 200 240 HTML io/
479 http://localhost:3000 GET /socket.io/?EIO=4&transport=webs... ✓ 101 195 io/
480 http://localhost:3000 GET /socket.io/?EIO=4&transport=pollin... ✓ 200 287 text io/
Request Response
Pretty Raw Hex Render
1 HTTP/1.1 200 OK
2 Access-Control-Allow-Origin: *
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Feature-Policy: payment 'self'
6 X-Recruiting: /#/jobs
7 Content-Type: application/json; charset=utf-8
8 ETag: W/"81d-qkTQEUuDVpWYdGiwPQlS0ic7Ge8"
9 Vary: Accept-Encoding
10 Date: Sat, 24 Oct 2026 17:37:36 GMT
11 Connection: keep-alive
12 Keep-Alive: timeout=5
13 Content-Length: 2077
14
15 {
"status":"success"
Search
0 highlights
Inspector
Request attributes 2
Request cookies 5
Request headers 16
Response headers 12
Inspector
Notes
Event log (8)
All issues
Memory: 190.9MB of 980.0MB
Disabled

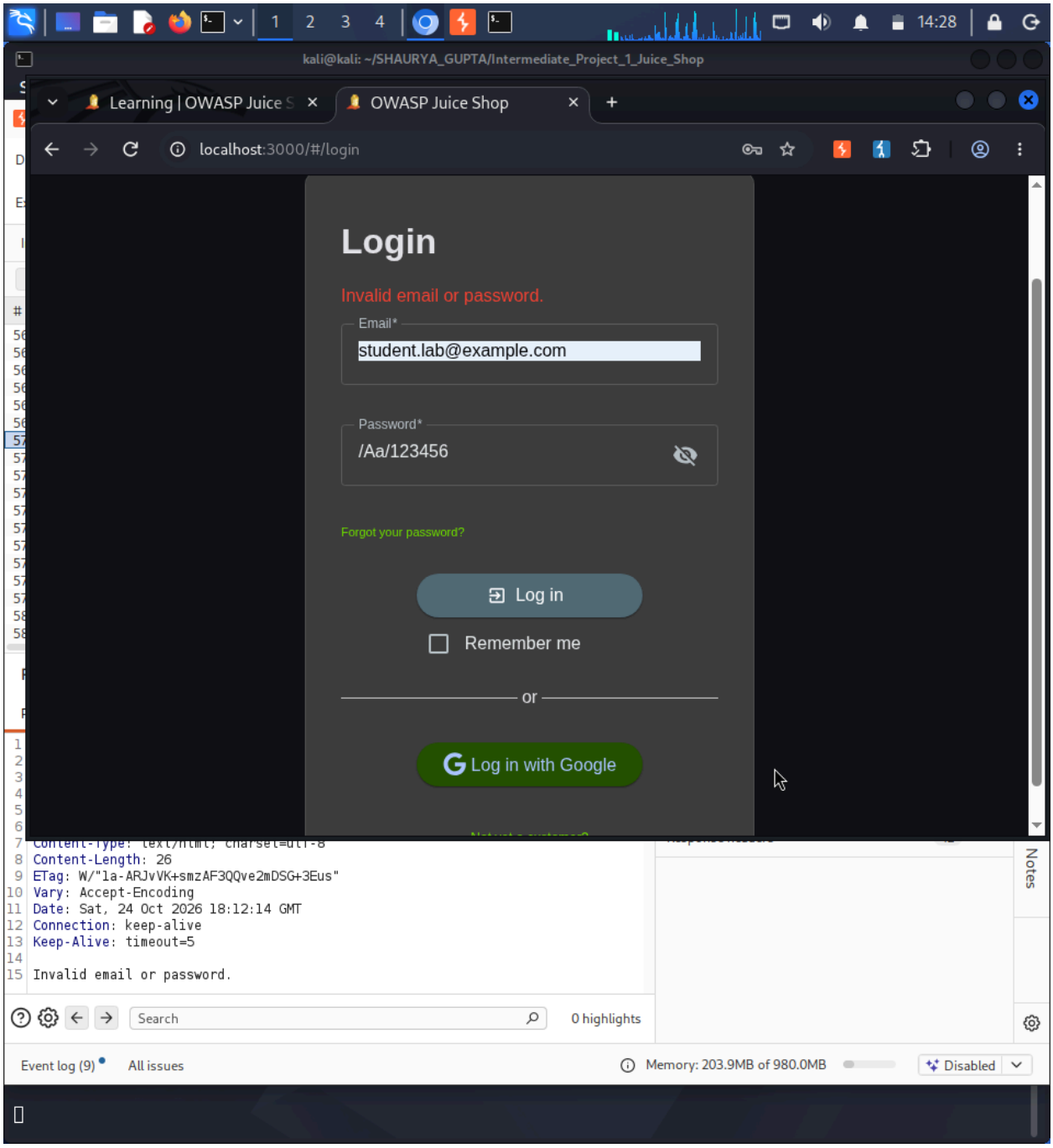

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Learning | OWASP Juice S
OWASP Juice Shop
localhost:3000/#/login
OWASP Juice Shop
Login
Invalid email or password.
Email*
student.lab@example.com
Password*
Forgot your password?
Log in
Remember me
or
Content-Type: application/json; charset=utf-8
ETag: W/"81d-qkTQEUuDVpWYdGiwPQlSOic7Ge8"
Vary: Accept-Encoding
Date: Sat, 24 Oct 2026 17:37:36 GMT
Connection: keep-alive
Keep-Alive: timeout=5
Content-Length: 2077
{
"status":"success"
Search
0 highlights
Notes
Event log (9)
All issues
Memory: 191.6MB of 980.0MB
Disabled

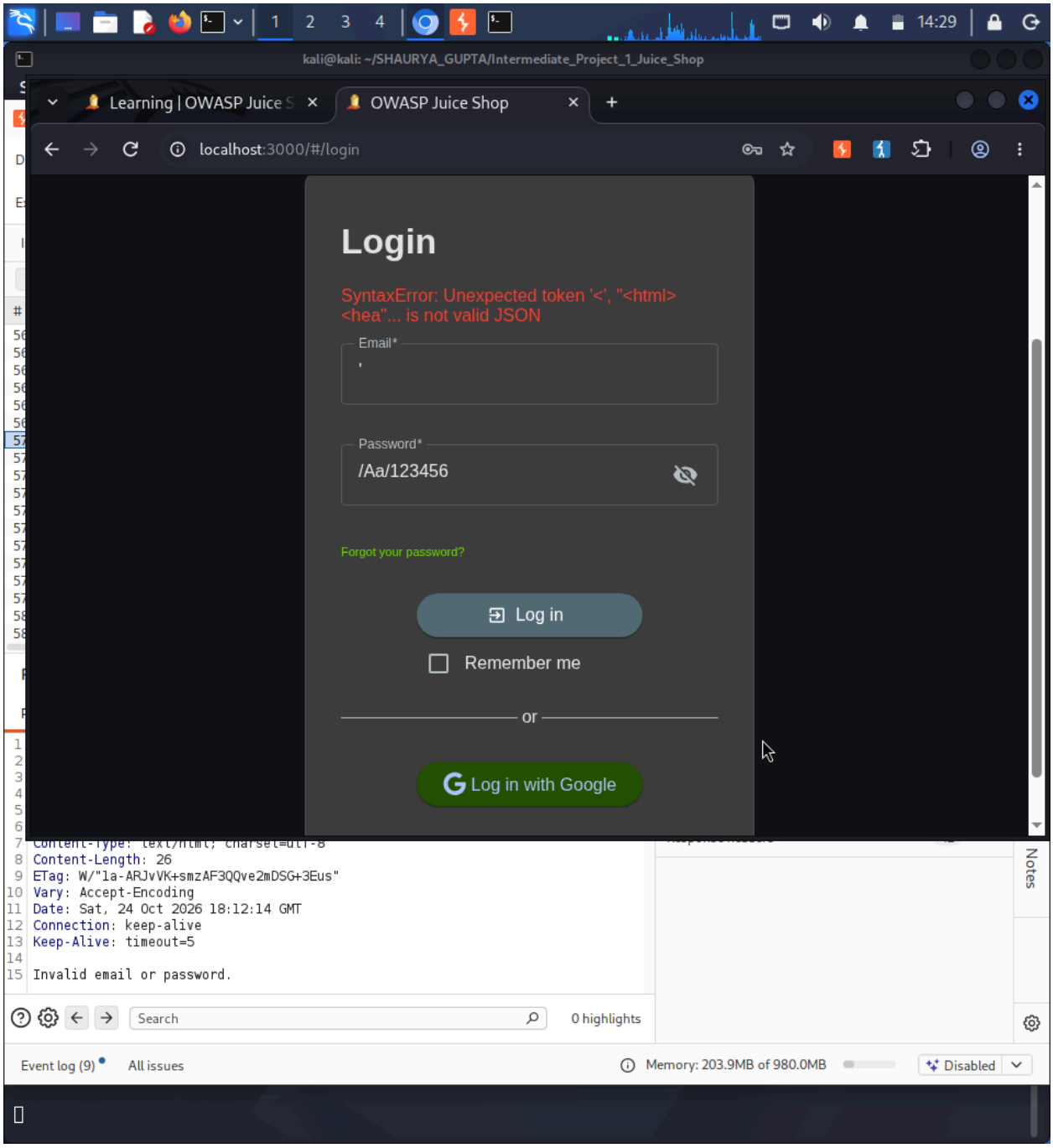

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Learning | OWASP Juice S
OWASP Juice Shop
localhost:3000/#/login
Login
Invalid email or password.
Email*
student.lab@example.com
Password*
Forgot your password?
Log in
Remember me
or
Log in with Google
Content-Type: application/json; charset=utf-8
ETag: W/"81d-qkTQEUuDVpWYdGiwPQlS0ic7Ge8"
Vary: Accept-Encoding
Date: Sat, 24 Oct 2026 17:37:36 GMT
Connection: keep-alive
Keep-Alive: timeout=5
Content-Length: 2077
{
"status":"success"
Search
0 highlights
Notes
Event log (9)
All issues
Memory: 206.9MB of 980.0MB
Disabled

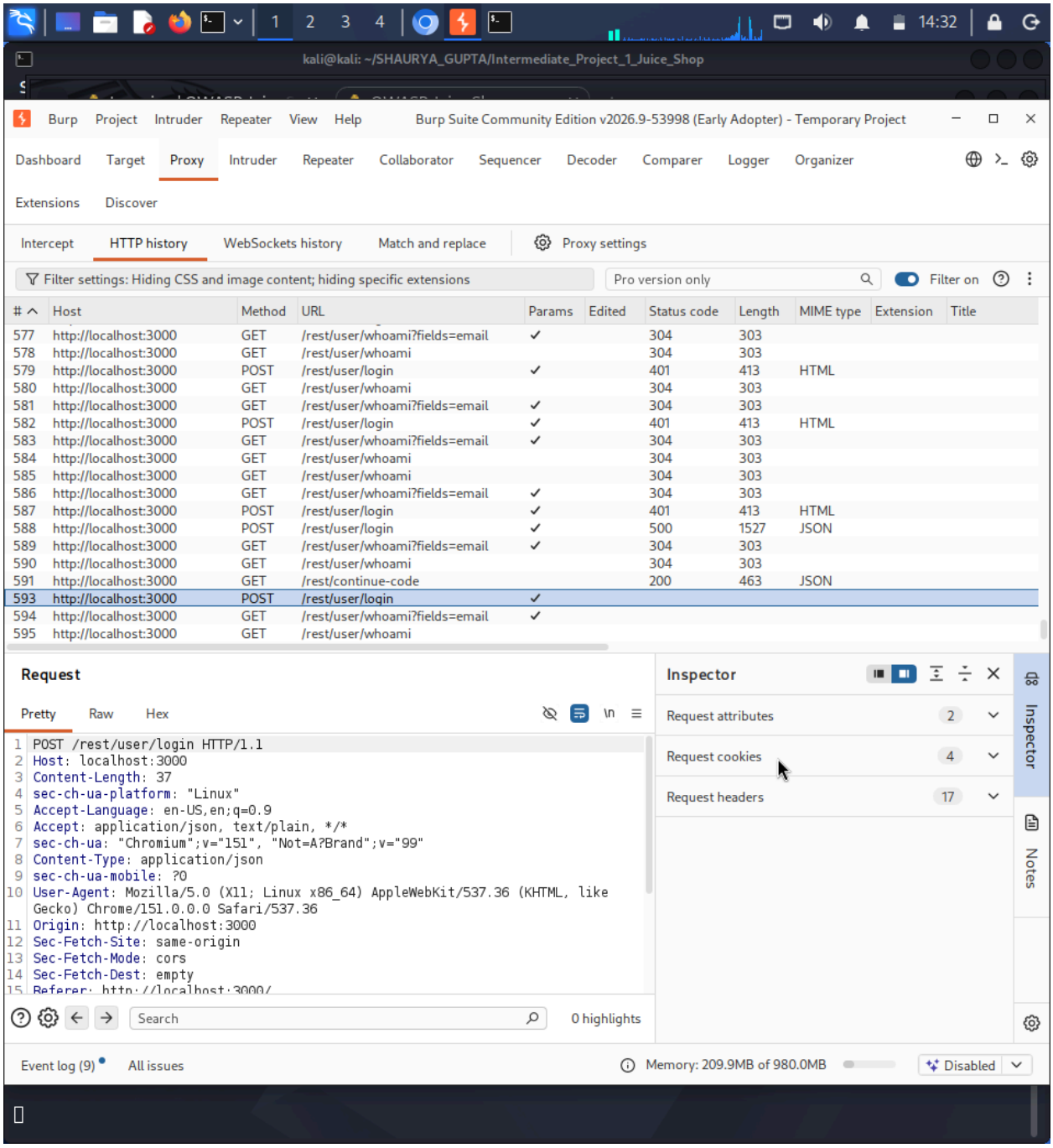

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title
564 http://localhost:3000 POST /rest/user/login ✓ 401 413 HTML
565 http://localhost:3000 GET /rest/user/whoami?fields=email ✓ 304 303
566 http://localhost:3000 GET /rest/user/whoami 304 303
567 http://localhost:3000 POST /rest/user/login ✓ 401 413 HTML
568 http://localhost:3000 GET /rest/user/whoami 304 303
569 http://localhost:3000 GET /rest/user/whoami?fields=email ✓ 304 303
570 http://localhost:3000 POST /rest/user/login ✓ 401 413 HTML
571 http://localhost:3000 GET /rest/user/whoami 304 303
572 http://localhost:3000 GET /rest/user/whoami?fields=email ✓ 304 303
573 http://localhost:3000 POST /rest/user/login ✓ 401 413 HTML
574 http://localhost:3000 GET /rest/user/whoami?fields=email ✓ 304 303
575 http://localhost:3000 GET /rest/user/whoami 304 303
576 http://localhost:3000 POST /rest/user/login ✓ 401 413 HTML
577 http://localhost:3000 GET /rest/user/whoami?fields=email ✓ 304 303
578 http://localhost:3000 GET /rest/user/whoami 304 303
579 http://localhost:3000 POST /rest/user/login ✓ 401 413 HTML
580 http://localhost:3000 GET /rest/user/whoami 304 303
581 http://localhost:3000 GET /rest/user/whoami?fields=email ✓ 304 303
Request Response
Pretty Raw Hex Render
1 HTTP/1.1 401 Unauthorized
2 Access-Control-Allow-Origin: *
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Feature-Policy: payment 'self'
6 X-Recruiting: /#/jobs
7 Content-Type: text/html; charset=utf-8
8 Content-Length: 26
9 ETag: W/"1a-ARJvVK+smzAF3QQve2mDSG+3Eus"
10 Vary: Accept-Encoding
11 Date: Sat, 24 Oct 2026 18:12:14 GMT
12 Connection: keep-alive
13 Keep-Alive: timeout=5
14
15 Invalid email or password.
Search
0 highlights
Inspector
Request attributes 2
Request cookies 4
Request headers 17
Response headers 12
Inspector
Notes
Event log (9)
All issues
Memory: 196.9MB of 980.0MB
Disabled

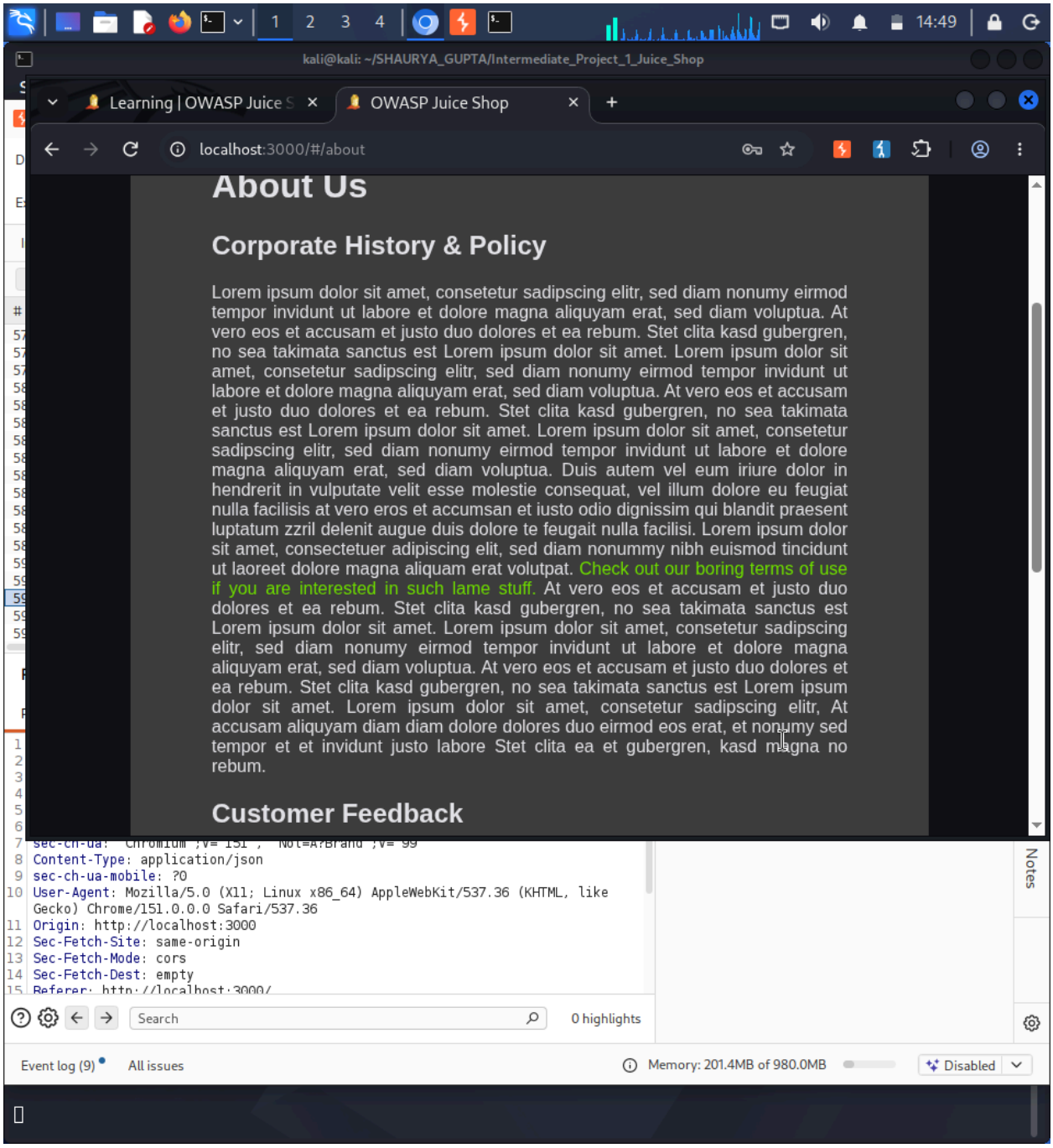

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Learning | OWASP Juice S
OWASP Juice Shop
localhost:3000/#/login
Login
Email*
student.lab@example.com
Password*
Aa/123456
Forgot your password?
Log in
Remember me
or
Log in with Google
Not yet a customer?
Content-Type: text/html; charset=utf-8
Content-Length: 26
ETag: W/"1a-ARJvVK+smzAF3QQve2mDSG+3Eus"
Vary: Accept-Encoding
Date: Sat, 24 Oct 2026 18:12:14 GMT
Connection: keep-alive
Keep-Alive: timeout=5
Invalid email or password.
Search
0 highlights
Notes
Event log (9)
All issues
Memory: 203.9MB of 980.0MB
Disabled

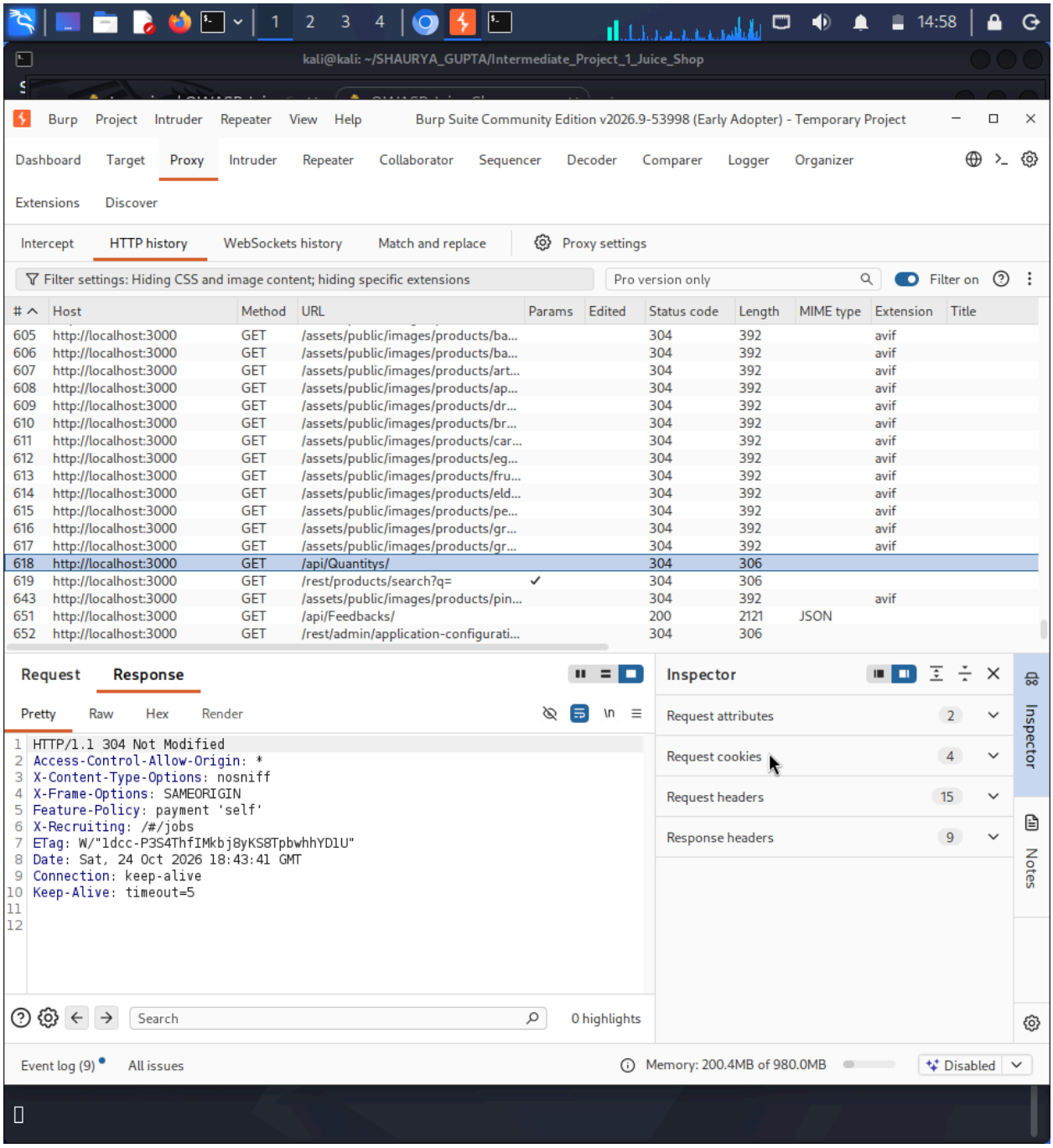

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Learning | OWASP Juice S
OWASP Juice Shop
localhost:3000/#/login
Login
Email*
student.lab@example.com
Password*
/Aa/123456
Forgot your password?
Log in
Remember me
or
Log in with Google
Not yet a customer?
Content-Length: 26
ETag: W/"1a-ARJvVK+smzAF3QQve2mDSG+3Eus"
Vary: Accept-Encoding
Date: Sat, 24 Oct 2026 18:12:14 GMT
Connection: keep-alive
Keep-Alive: timeout=5
Invalid email or password.
Search
0 highlights
Notes
Event log (9)
All issues
Memory: 203.9MB of 980.0MB
Disabled

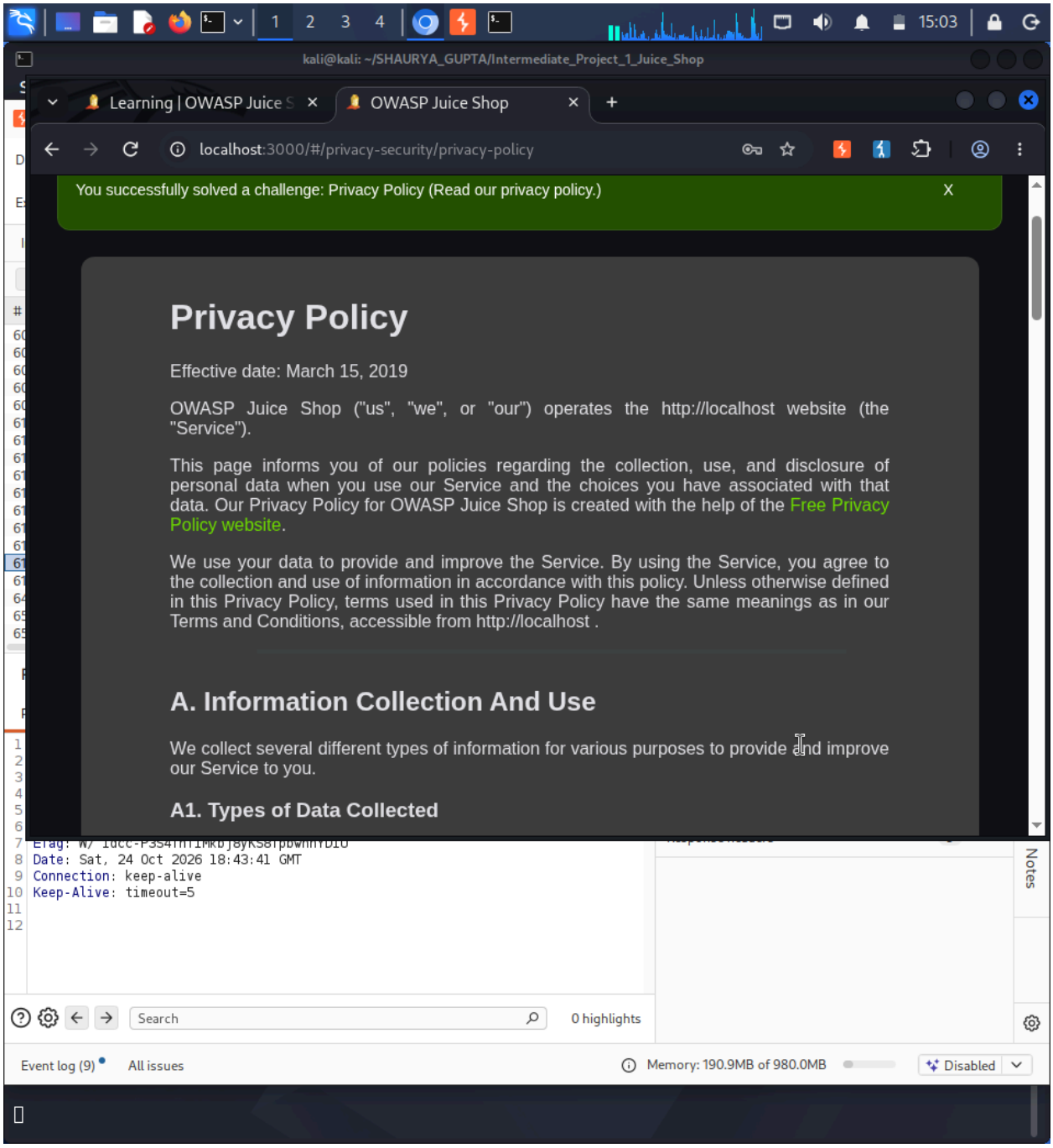

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Learning | OWASP Juice S
OWASP Juice Shop
localhost:3000/#/login
Login
Invalid email or password.
Email*
student.lab@example.com
Password*
/Aa/123456
Forgot your password?
Log in
Remember me
or
Log in with Google
Content-Type: text/html; charset=utf-8
Content-Length: 26
ETag: W/"1a-ARJvVK+smzAF3QQve2mDSG+3Eus"
Vary: Accept-Encoding
Date: Sat, 24 Oct 2026 18:12:14 GMT
Connection: keep-alive
Keep-Alive: timeout=5
Invalid email or password.
Search
0 highlights
Notes
Event log (9)
All issues
Memory: 203.9MB of 980.0MB
Disabled

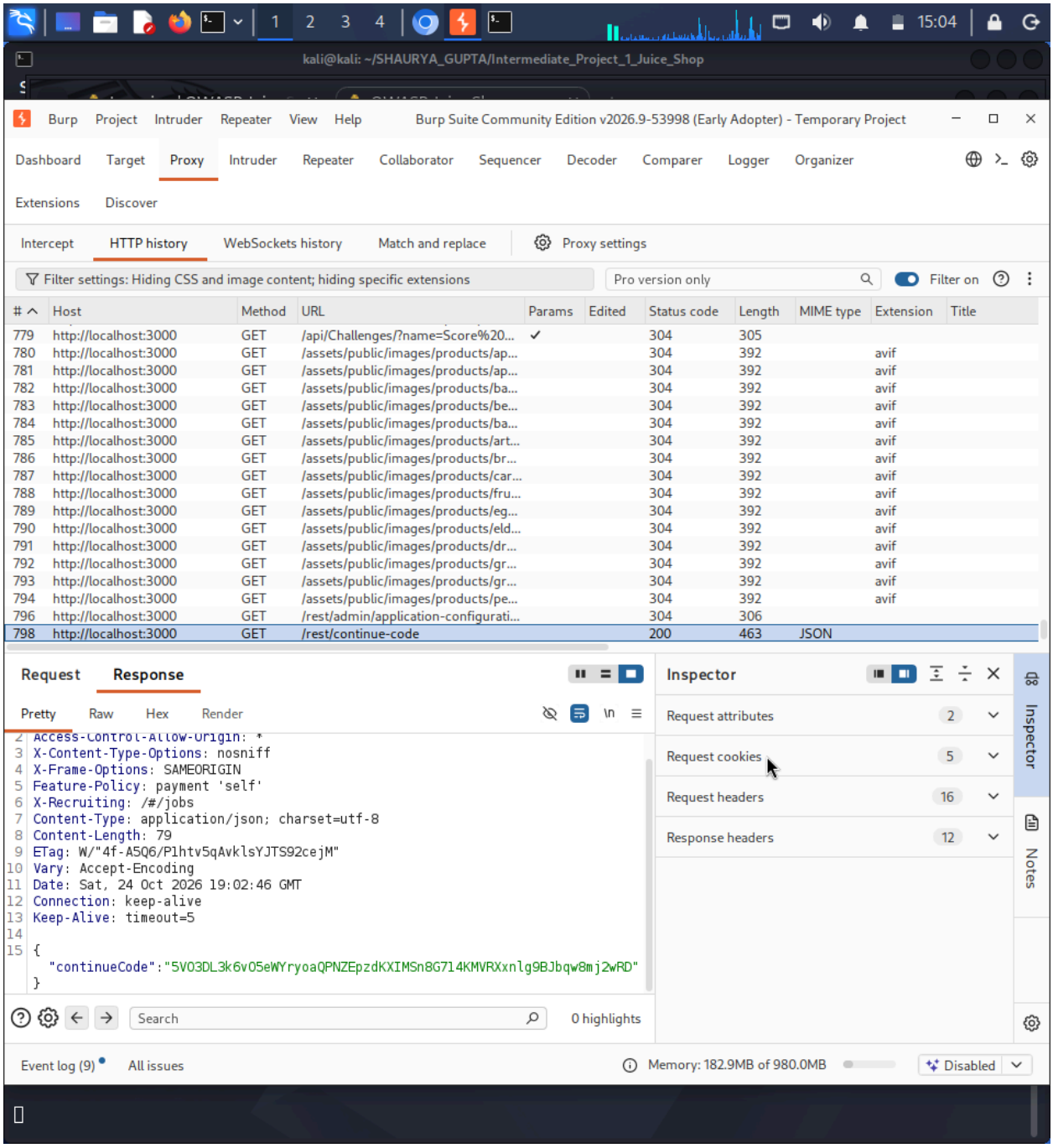

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Learning | OWASP Juice S
OWASP Juice Shop
localhost:3000/#/login
Login
SyntaxError: Unexpected token '<', "<html> <hea"... is not valid JSON
Email*
'
Password*
/Aa/123456
Forgot your password?
Log in
Remember me
or
Log in with Google
Content-Type: text/html; charset=utf-8
Content-Length: 26
ETag: W/"1a-ARJvVK+smzAF3QQve2mDSG+3Eus"
Vary: Accept-Encoding
Date: Sat, 24 Oct 2026 18:12:14 GMT
Connection: keep-alive
Keep-Alive: timeout=5
Invalid email or password.
Search
0 highlights
Notes
Event log (9)
All issues
Memory: 203.9MB of 980.0MB
Disabled

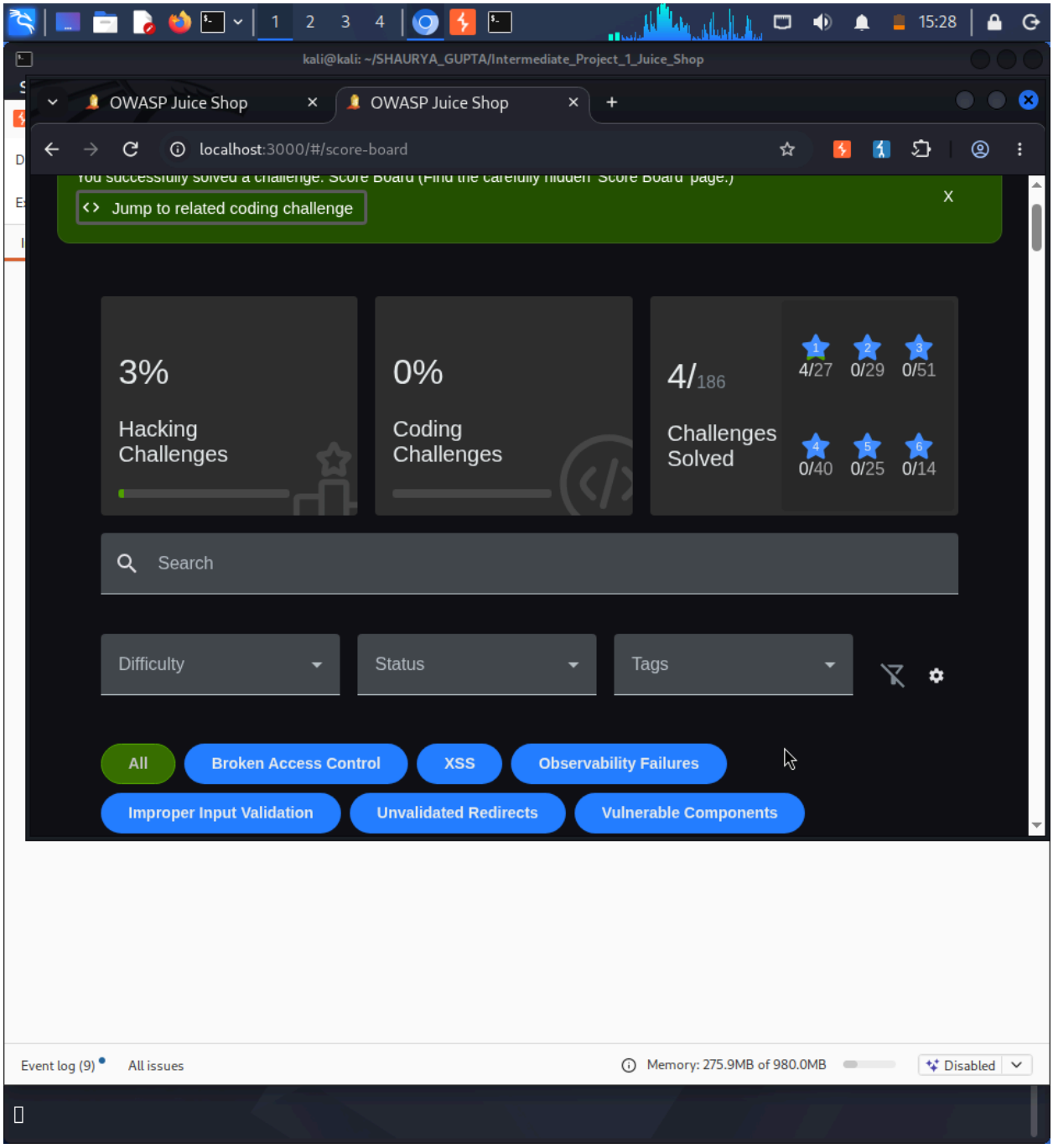

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title
577 http://localhost:3000 GET /rest/user/whoami?fields=email ✓ 304 303
578 http://localhost:3000 GET /rest/user/whoami 304 303
579 http://localhost:3000 POST /rest/user/login ✓ 401 413 HTML
580 http://localhost:3000 GET /rest/user/whoami 304 303
581 http://localhost:3000 GET /rest/user/whoami?fields=email ✓ 304 303
582 http://localhost:3000 POST /rest/user/login ✓ 401 413 HTML
583 http://localhost:3000 GET /rest/user/whoami?fields=email ✓ 304 303
584 http://localhost:3000 GET /rest/user/whoami 304 303
585 http://localhost:3000 GET /rest/user/whoami 304 303
586 http://localhost:3000 GET /rest/user/whoami?fields=email ✓ 304 303
587 http://localhost:3000 POST /rest/user/login ✓ 401 413 HTML
588 http://localhost:3000 POST /rest/user/login ✓ 500 1527 JSON
589 http://localhost:3000 GET /rest/user/whoami?fields=email ✓ 304 303
590 http://localhost:3000 GET /rest/user/whoami 304 303
591 http://localhost:3000 GET /rest/continue-code 200 463 JSON
593 http://localhost:3000 POST /rest/user/login ✓
594 http://localhost:3000 GET /rest/user/whoami?fields=email ✓
595 http://localhost:3000 GET /rest/user/whoami
Request
Pretty Raw Hex
1 POST /rest/user/login HTTP/1.1
2 Host: localhost:3000
3 Content-Length: 37
4 sec-ch-ua-platform: "Linux"
5 Accept-Language: en-US,en;q=0.9
6 Accept: application/json, text/plain, */*
7 sec-ch-ua: "Chromium";v="151", "Not=A?Brand";v="99"
8 Content-Type: application/json
9 sec-ch-ua-mobile: ?0
10 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
11 Origin: http://localhost:3000
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: http://localhost:3000/
Search
0 highlights
Inspector
Request attributes 2
Request cookies 4
Request headers 17
Inspector
Notes
Event log (9)
All issues
Memory: 209.9MB of 980.0MB
Disabled


kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Learning | OWASP Juice S
OWASP Juice Shop
localhost:3000/#/about
About Us
Corporate History & Policy
Lorem ipsum dolor sit amet, consetetur sadipscing elitr, sed diam nonumy eirmod tempor invidunt ut labore et dolore magna aliquyam erat, sed diam voluptua. At vero eos et accusam et justo duo dolores et ea rebum. Stet clita kasd gubergren, no sea takimata sanctus est Lorem ipsum dolor sit amet. Lorem ipsum dolor sit amet, consetetur sadipscing elitr, sed diam nonumy eirmod tempor invidunt ut labore et dolore magna aliquyam erat, sed diam voluptua. At vero eos et accusam et justo duo dolores et ea rebum. Stet clita kasd gubergren, no sea takimata sanctus est Lorem ipsum dolor sit amet. Lorem ipsum dolor sit amet, consetetur sadipscing elitr, sed diam nonumy eirmod tempor invidunt ut labore et dolore magna aliquyam erat, sed diam voluptua. Duis autem vel eum iriure dolor in hendrerit in vulputate velit esse molestie consequat, vel illum dolore eu feugiat nulla facilisis at vero eros et accumsan et iusto odio dignissim qui blandit praesent luptatum zzril delenit augue duis dolore te feugait nulla facilisi. Lorem ipsum dolor sit amet, consectetuer adipiscing elit, sed diam nonummy nibh euismod tincidunt ut laoreet dolore magna aliquam erat volutpat. Check out our boring terms of use if you are interested in such lame stuff. At vero eos et accusam et justo duo dolores et ea rebum. Stet clita kasd gubergren, no sea takimata sanctus est Lorem ipsum dolor sit amet. Lorem ipsum dolor sit amet, consetetur sadipscing elitr, sed diam nonumy eirmod tempor invidunt ut labore et dolore magna aliquyam erat, sed diam voluptua. At vero eos et accusam et justo duo dolores et ea rebum. Stet clita kasd gubergren, no sea takimata sanctus est Lorem ipsum dolor sit amet. Lorem ipsum dolor sit amet, consetetur sadipscing elitr, At accusam aliquyam diam diam dolore dolores duo eirmod eos erat, et nonumy sed tempor et et invidunt justo labore Stet clita ea et gubergren, kasd magna no rebum.
Customer Feedback
Content-Type: application/json
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
Origin: http://localhost:3000
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Search
0 highlights
Notes
Event log (9)
All issues
Memory: 201.4MB of 980.0MB
Disabled


kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title
605 http://localhost:3000 GET /assets/public/images/products/ba... 304 392 avif
606 http://localhost:3000 GET /assets/public/images/products/ba... 304 392 avif
607 http://localhost:3000 GET /assets/public/images/products/art... 304 392 avif
608 http://localhost:3000 GET /assets/public/images/products/ap... 304 392 avif
609 http://localhost:3000 GET /assets/public/images/products/dr... 304 392 avif
610 http://localhost:3000 GET /assets/public/images/products/br... 304 392 avif
611 http://localhost:3000 GET /assets/public/images/products/car... 304 392 avif
612 http://localhost:3000 GET /assets/public/images/products/eg... 304 392 avif
613 http://localhost:3000 GET /assets/public/images/products/fru... 304 392 avif
614 http://localhost:3000 GET /assets/public/images/products/eld... 304 392 avif
615 http://localhost:3000 GET /assets/public/images/products/pe... 304 392 avif
616 http://localhost:3000 GET /assets/public/images/products/gr... 304 392 avif
617 http://localhost:3000 GET /assets/public/images/products/gr... 304 392 avif
618 http://localhost:3000 GET /api/Quantitys/ 304 306
619 http://localhost:3000 GET /rest/products/search?q= ✓ 304 306
643 http://localhost:3000 GET /assets/public/images/products/pin... 304 392 avif
651 http://localhost:3000 GET /api/Feedbacks/ 200 2121 JSON
652 http://localhost:3000 GET /rest/admin/application-configurati... 304 306
Request Response
Pretty Raw Hex Render
1 HTTP/1.1 304 Not Modified
2 Access-Control-Allow-Origin: *
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Feature-Policy: payment 'self'
6 X-Recruiting: /#/jobs
7 ETag: W/"1dcc-P3S4ThfIMkbj8yKS8TpbwhhYD1U"
8 Date: Sat, 24 Oct 2026 18:43:41 GMT
9 Connection: keep-alive
10 Keep-Alive: timeout=5
11
12
Search
0 highlights
Inspector
Request attributes 2
Request cookies 4
Request headers 15
Response headers 9
Inspector
Notes
Event log (9)
All issues
Memory: 200.4MB of 980.0MB
Disabled


kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Learning | OWASP Juice S
OWASP Juice Shop
localhost:3000/#/privacy-security/privacy-policy
You successfully solved a challenge: Privacy Policy (Read our privacy policy.)
X
Privacy Policy
Effective date: March 15, 2019
OWASP Juice Shop ("us", "we", or "our") operates the http://localhost website (the "Service").
This page informs you of our policies regarding the collection, use, and disclosure of personal data when you use our Service and the choices you have associated with that data. Our Privacy Policy for OWASP Juice Shop is created with the help of the Free Privacy Policy website.
We use your data to provide and improve the Service. By using the Service, you agree to the collection and use of information in accordance with this policy. Unless otherwise defined in this Privacy Policy, terms used in this Privacy Policy have the same meanings as in our Terms and Conditions, accessible from http://localhost .
A. Information Collection And Use
We collect several different types of information for various purposes to provide and improve our Service to you.
A1. Types of Data Collected
Date: Sat, 24 Oct 2026 18:43:41 GMT
Connection: keep-alive
Keep-Alive: timeout=5
Search
0 highlights
Notes
Event log (9)
All issues
Memory: 190.9MB of 980.0MB
Disabled


kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer
Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Filter settings: Hiding CSS and image content; hiding specific extensions
Pro version only
Filter on
Host Method URL Params Edited Status code Length MIME type Extension Title
779 http://localhost:3000 GET /api/Challenges/?name=Score%20... ✓ 304 305
780 http://localhost:3000 GET /assets/public/images/products/ap... 304 392 avif
781 http://localhost:3000 GET /assets/public/images/products/ap... 304 392 avif
782 http://localhost:3000 GET /assets/public/images/products/ba... 304 392 avif
783 http://localhost:3000 GET /assets/public/images/products/be... 304 392 avif
784 http://localhost:3000 GET /assets/public/images/products/ba... 304 392 avif
785 http://localhost:3000 GET /assets/public/images/products/art... 304 392 avif
786 http://localhost:3000 GET /assets/public/images/products/br... 304 392 avif
787 http://localhost:3000 GET /assets/public/images/products/car... 304 392 avif
788 http://localhost:3000 GET /assets/public/images/products/fru... 304 392 avif
789 http://localhost:3000 GET /assets/public/images/products/eg... 304 392 avif
790 http://localhost:3000 GET /assets/public/images/products/eld... 304 392 avif
791 http://localhost:3000 GET /assets/public/images/products/dr... 304 392 avif
792 http://localhost:3000 GET /assets/public/images/products/gr... 304 392 avif
793 http://localhost:3000 GET /assets/public/images/products/gr... 304 392 avif
794 http://localhost:3000 GET /assets/public/images/products/pe... 304 392 avif
796 http://localhost:3000 GET /rest/admin/application-configurati... 304 306
798 http://localhost:3000 GET /rest/continue-code 200 463 JSON
Request Response
Pretty Raw Hex Render
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Content-Type: application/json; charset=utf-8
Content-Length: 79
ETag: W/"4f-A5Q6/P1htv5qAvklsYJTS92cejM"
Vary: Accept-Encoding
Date: Sat, 24 Oct 2026 19:02:46 GMT
Connection: keep-alive
Keep-Alive: timeout=5
{
"continueCode":"5VO3DL3k6vO5eWYryoaQPNZEpzdKXIMSn8G7l4KMVRXxnlg9BJbqw8mj2wRD"
}
Search
0 highlights
Inspector
Request attributes 2
Request cookies 5
Request headers 16
Response headers 12
Inspector
Notes
Event log (9)
All issues
Memory: 182.9MB of 980.0MB
Disabled


kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_1_Juice_Shop
OWASP Juice Shop
OWASP Juice Shop
localhost:3000/#/score-board
Jump to related coding challenge
3%
Hacking Challenges
0%
Coding Challenges
4/186
Challenges Solved
4/27
0/29
0/51
0/40
0/25
0/14
Search
Difficulty
Status
Tags
All
Broken Access Control
XSS
Observability Failures
Improper Input Validation
Unvalidated Redirects
Vulnerable Components
Event log (9)
All issues
Memory: 275.9MB of 980.0MB
Disabled

CyberSNova Cyber Security Internship

Intermediate Project 2: PortSwigger Web Security Academy Labs

1. Intern Details

Name: Shaurya Gupta
Email: shauryagupta0106@gmail.com
Reference Number: CSN-OC-OL-26194
Registration Number: CSN-OC-2026-194
Domain: Cyber Security
Project Level: Intermediate
Project Number: 2
Month/Year: October 2026

2. Project Description

This project involves completing five Apprentice-level labs on PortSwigger Web Security Academy. The exercises investigate web application security weaknesses, demonstrate their impact in the assigned training environment, and identify suitable mitigations.

The five completed exercises cover SQL injection in a WHERE clause, SQL injection login bypass, file path traversal, reflected cross-site scripting, and user role control through a request parameter.

3. Environment and Tools

Operating system: Kali GNU/Linux Rolling 2026.3 Browser: Mozilla Firefox 153.4.0 ESR Testing tool: Burp Suite Community Edition 2026.9 Additional tools: Terminal, curl 8.22.0, Python 3.14.7, zip 3.0, scrot 2.0.0, Firefox Developer Tools Practice platform: PortSwigger Web Security Academy Virtualization platform: Oracle VirtualBox

Project directory: /home/kali/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger

The environment log confirms the installed operating system, Python version, Burp Suite executable, and Firefox executable. The screenshots provide evidence of the five Academy lab exercises.

4. Scope and Methodology

Scope: Only the five assigned PortSwigger Academy lab instances.

Methodology:

1. Review the relevant vulnerability learning material.
2. Explore normal application behavior.
3. Capture and inspect relevant HTTP requests and responses.
4. Perform controlled tests within the assigned lab.
5. Verify completion using the Academy's lab status.
6. Save screenshots and record observations.
7. Recommend mitigations based on the observed behavior.

All practical testing was conducted against the assigned intentionally vulnerable training labs. The assessment did not target unrelated websites.

5. Lab 1: SQL Injection in a WHERE Clause

Lab title: SQL injection vulnerability in WHERE clause allowing retrieval of hidden data

Objective: Determine whether input to a database filter can alter the application's intended query behavior.

Procedure:

1. Opened the assigned SQL injection lab on PortSwigger Web Security Academy.
2. Examined the online shop and its product category filtering.
3. Observed how the selected category affected the displayed products and the application's request.
4. Tested the relevant category input using the lab's SQL injection technique.
5. Examined the resulting product listing.
6. Verified the Academy's successful lab completion indicator.

Evidence: screenshots/lab1_sql_injection/01.png screenshots/lab1_sql_injection/02.png screenshots/lab1_sql_injection/03.png screenshots/lab1_sql_injection/04.png

Observed result: The supplied screenshots show the assigned lab and its solved confirmation. The exercise demonstrates that unsafe SQL query construction can allow a category filter to return records that were intended to remain hidden.

Security impact: An attacker may retrieve unreleased or otherwise restricted database records by manipulating an input used in a SQL query. This can expose information that the application intended to exclude from normal results.

Recommended mitigation: Use parameterized queries, avoid SQL string concatenation, apply least-privilege database permissions, and test query handling with security-focused automated tests.

6. Lab 2: SQL Injection Login Bypass

Lab title: SQL injection vulnerability allowing login bypass

Objective: Evaluate whether unsafe query construction can bypass the application's authentication logic.

Procedure:

1. Opened the assigned SQL injection login bypass lab.
2. Accessed the login page and examined the available fields.
3. Submitted a login test using the lab's intended procedure.
4. Tested the username input using the SQL injection technique specified for the exercise.
5. Examined the resulting account page.
6. Verified the Academy's successful lab completion indicator.

Evidence: screenshots/lab2_login_bypass/01.png screenshots/lab2_login_bypass/02.png screenshots/lab2_login_bypass/03.png

Observed result: The supplied screenshots show the login page, a login test, and the Academy's solved confirmation. The exercise demonstrates how an improperly constructed SQL query can undermine the application's authentication checks.

Security impact: An authentication bypass may expose protected accounts, private information, or privileged functionality.

Recommended mitigation: Use parameterized queries, securely verify passwords, implement server-side authentication, and test login logic against injection attacks.

7. Lab 3: File Path Traversal

Lab title: File path traversal, simple case

Objective: Determine whether user-controlled file paths can escape their intended directory.

Procedure:

1. Opened the assigned file path traversal lab.
2. Examined the shop's product images and associated file requests.

3. Identified a request containing a filename parameter.
4. Tested the filename parameter using the path traversal technique specified in the lab.
5. Examined the server response.
6. Verified the Academy's successful lab completion indicator.

Evidence: screenshots/lab3_path_traversal/01.png screenshots/lab3_path_traversal/02.png screenshots/lab3_path_traversal/03.png screenshots/lab3_path_traversal/04.png

Observed result: The supplied screenshots show the normal image request, the file response, and the Academy's solved confirmation. The exercise demonstrates that an insufficiently restricted file path can permit access to files outside the intended image directory.

Security impact: Sensitive files may be exposed if filesystem access is not restricted to approved resources.

Recommended mitigation: Canonicalize and validate paths, enforce directory boundaries, map identifiers to approved files, and run the application with minimum filesystem privileges.

8. Lab 4: Reflected Cross-Site Scripting

Lab title: Reflected XSS into HTML context with nothing encoded

Objective: Determine whether untrusted input is interpreted as executable browser content.

Procedure:

1. Opened the assigned reflected XSS lab.
2. Located the application's search input.
3. Submitted a normal search term and observed the results page.
4. Tested the input using the harmless JavaScript alert proof of concept specified for the exercise.
5. Observed the browser's response to the submitted input.
6. Verified the Academy's successful lab completion indicator.

Evidence: screenshots/lab4_reflected_xss/01.png screenshots/lab4_reflected_xss/02.png screenshots/lab4_reflected_xss/03.png

Observed result: The supplied screenshots show the search page, the browser alert test, and the Academy's solved confirmation. The exercise demonstrates that untrusted input reflected into an HTML context without appropriate handling can execute as browser content.

Security impact: Successful XSS may allow attacker-controlled actions in a victim's browser under the application's origin.

Recommended mitigation: Use context-aware output encoding, safe templating, safe DOM APIs, and a suitable Content Security Policy.

9. Lab 5: Broken Access Control

Lab title: User role controlled by request parameter

Objective: Test whether a client-controlled role value improperly influences authorization decisions.

Procedure:

1. Opened the assigned user role control lab.
2. Examined the application's normal pages and account access.
3. Accessed the login page and used the training credentials supplied by the Academy.
4. Inspected the lab's authorization behavior and the relevant client-controlled cookie using browser developer tools.
5. Tested the role-related value according to the lab procedure.
6. Accessed the administrative functionality.
7. Completed the required user-management action in the lab.
8. Verified the Academy's successful lab completion indicator.

Evidence: screenshots/lab5_access_control/01.png screenshots/lab5_access_control/02.png screenshots/lab5_access_control/03.png screenshots/lab5_access_control/04.png screenshots/lab5_access_control/05.png screenshots/lab5_access_control/06.png

Observed result: The supplied screenshots show the lab pages, account access, administrative functionality, and the Academy's solved confirmation. The exercise demonstrates the risk of trusting a client-controlled role value when making authorization decisions.

Security impact: Improper authorization can allow users to access data or operations beyond their assigned permissions.

Recommended mitigation: Enforce authorization server-side on every protected request. Derive roles from trusted server-side data and test for privilege escalation.

10. Results Summary

Lab	Vulnerability	Actual status
1	SQL injection in WHERE clause	Solved
2	SQL injection login bypass	Solved

Lab	Vulnerability	Actual status
3	Path traversal	Solved
4	Reflected XSS	Solved
5	Broken access control	Solved

All five assigned labs are marked as solved in the supplied screenshots.

11. General Recommendations

1. Use parameterized database queries.
2. Apply context-aware output encoding.
3. Validate and safely resolve file paths.
4. Enforce authorization on the server.
5. Follow least-privilege principles.
6. Maintain security regression tests.
7. Log relevant security events without recording unnecessary passwords, tokens, or personal data.

12. Conclusion

The project covered five common web application security vulnerabilities through practical exercises on PortSwigger Web Security Academy.

The completed labs covered SQL injection in a WHERE clause, SQL injection login bypass, file path traversal, reflected cross-site scripting, and authorization weaknesses involving a client-controlled role value.

The exercises demonstrated how unsafe database query construction can expose hidden records or undermine login checks, how insufficient file path restrictions can expose server files, how reflected untrusted input can execute as browser content, and how trusting client-controlled role values can compromise authorization.

The main defensive lessons are to use parameterized SQL queries, safely handle output and file paths, and enforce authorization using trusted server-side information.

The supplied evidence package contains screenshots for all five labs, including solved confirmations. These screenshots support the recorded completion status.

13. Evidence Index

Lab 1: SQL Injection in a WHERE Clause

- screenshots/lab1_sql_injection/01.png
- screenshots/lab1_sql_injection/02.png
- screenshots/lab1_sql_injection/03.png
- screenshots/lab1_sql_injection/04.png

Lab 2: SQL Injection Login Bypass

- screenshots/lab2_login_bypass/01.png
- screenshots/lab2_login_bypass/02.png
- screenshots/lab2_login_bypass/03.png

Lab 3: File Path Traversal

- screenshots/lab3_path_traversal/01.png
- screenshots/lab3_path_traversal/02.png
- screenshots/lab3_path_traversal/03.png
- screenshots/lab3_path_traversal/04.png

Lab 4: Reflected Cross-Site Scripting

- screenshots/lab4_reflected_xss/01.png
- screenshots/lab4_reflected_xss/02.png
- screenshots/lab4_reflected_xss/03.png

Lab 5: Broken Access Control

- screenshots/lab5_access_control/01.png
- screenshots/lab5_access_control/02.png
- screenshots/lab5_access_control/03.png
- screenshots/lab5_access_control/04.png
- screenshots/lab5_access_control/05.png
- screenshots/lab5_access_control/06.png

Environment and terminal records:

- logs/environment.txt
- logs/terminal-20261025-045808.log

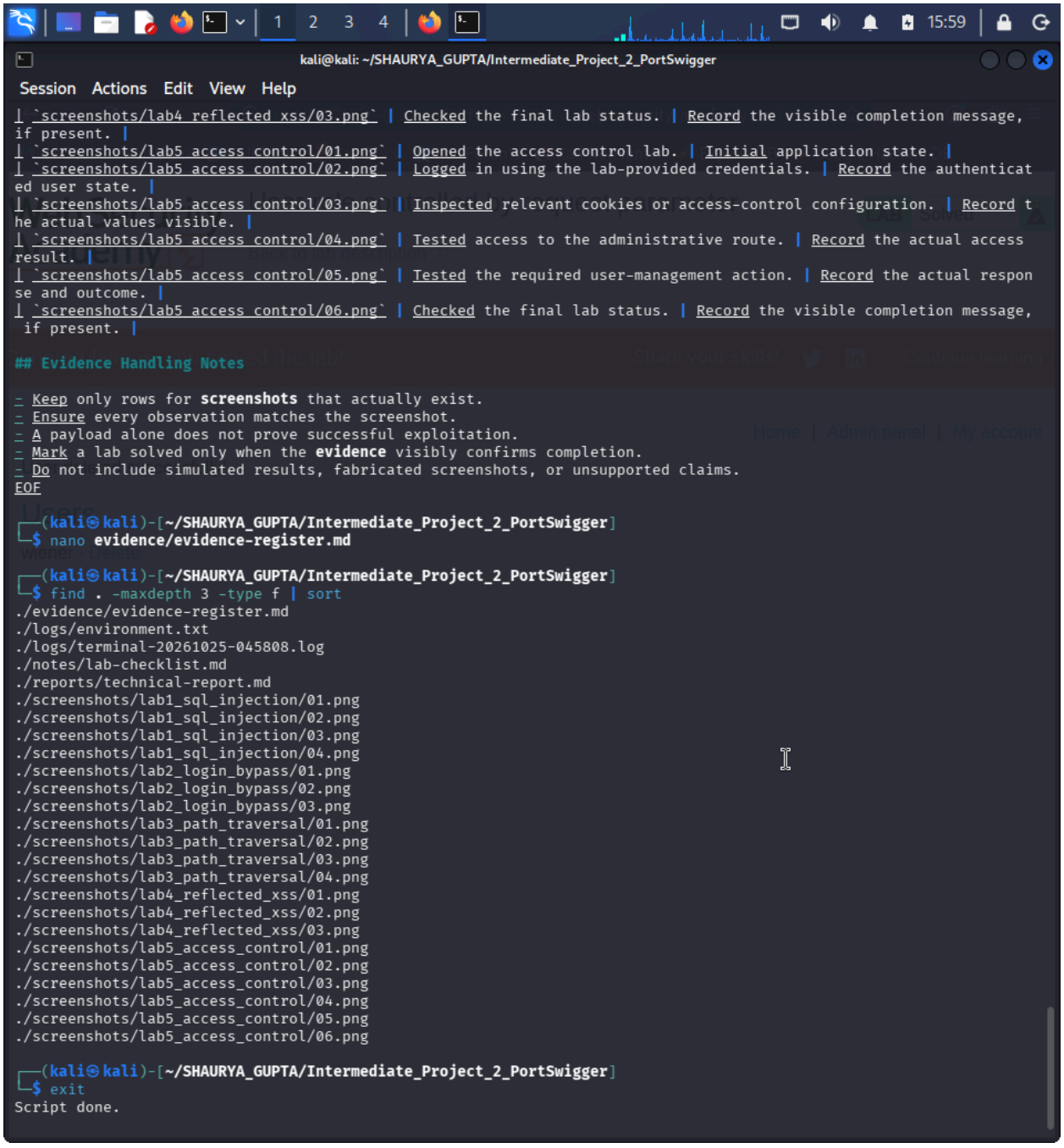
The screenshot filenames above correspond to the supplied evidence ZIP. The environment and terminal records are listed as project artifacts and should be included in the submission directory if available.

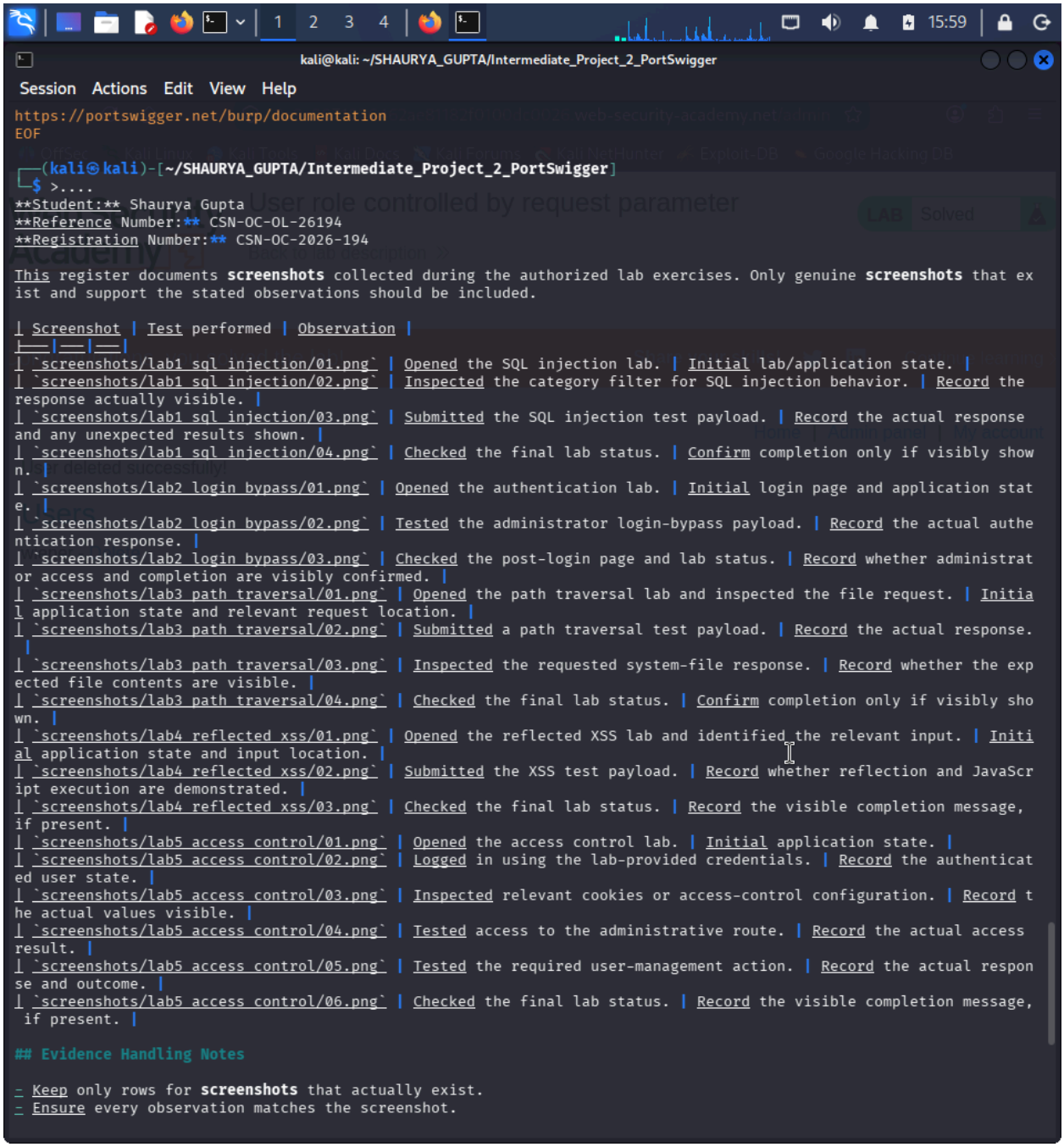
14. References

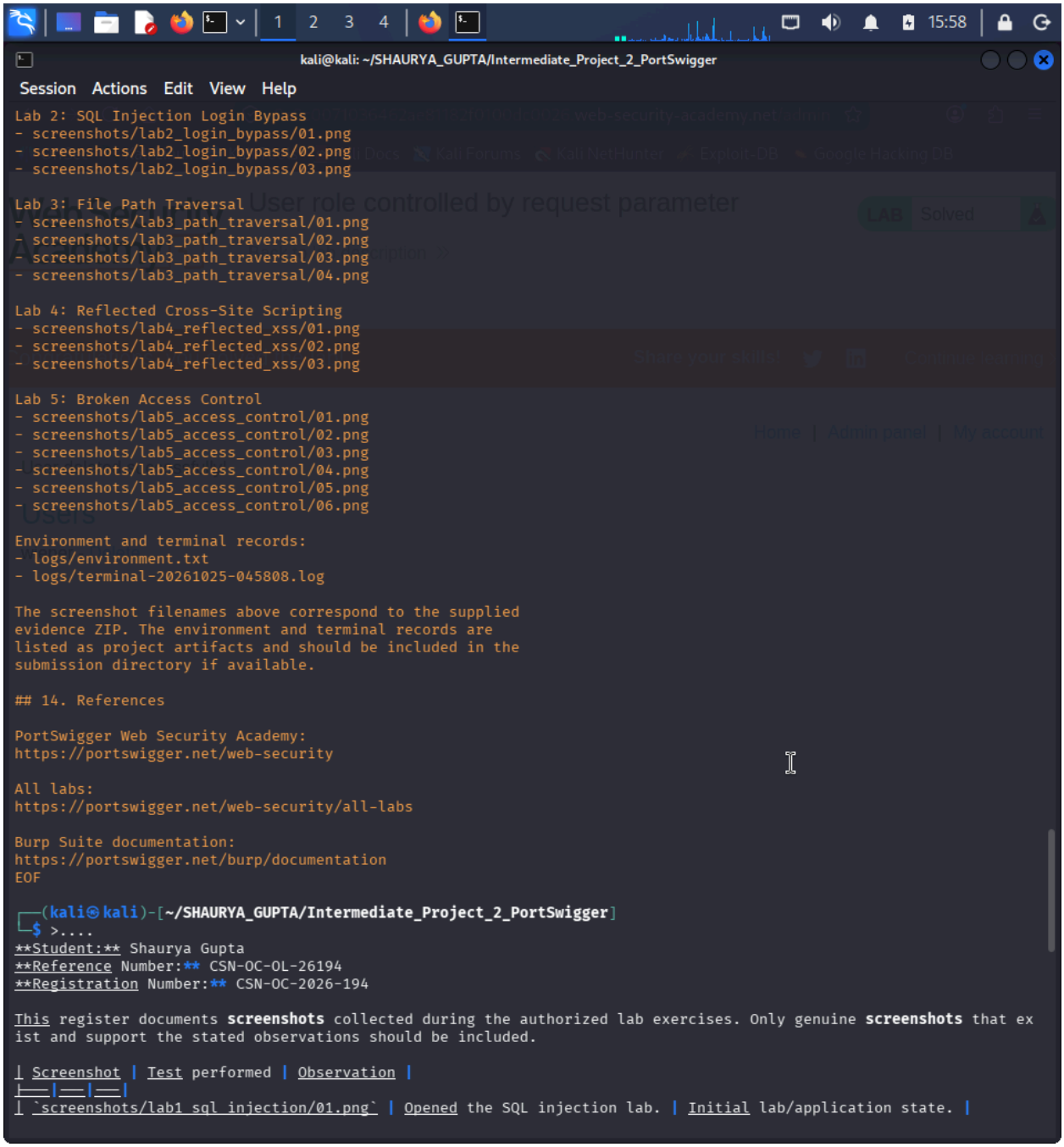
PortSwigger Web Security Academy: https://portswigger.net/web-security

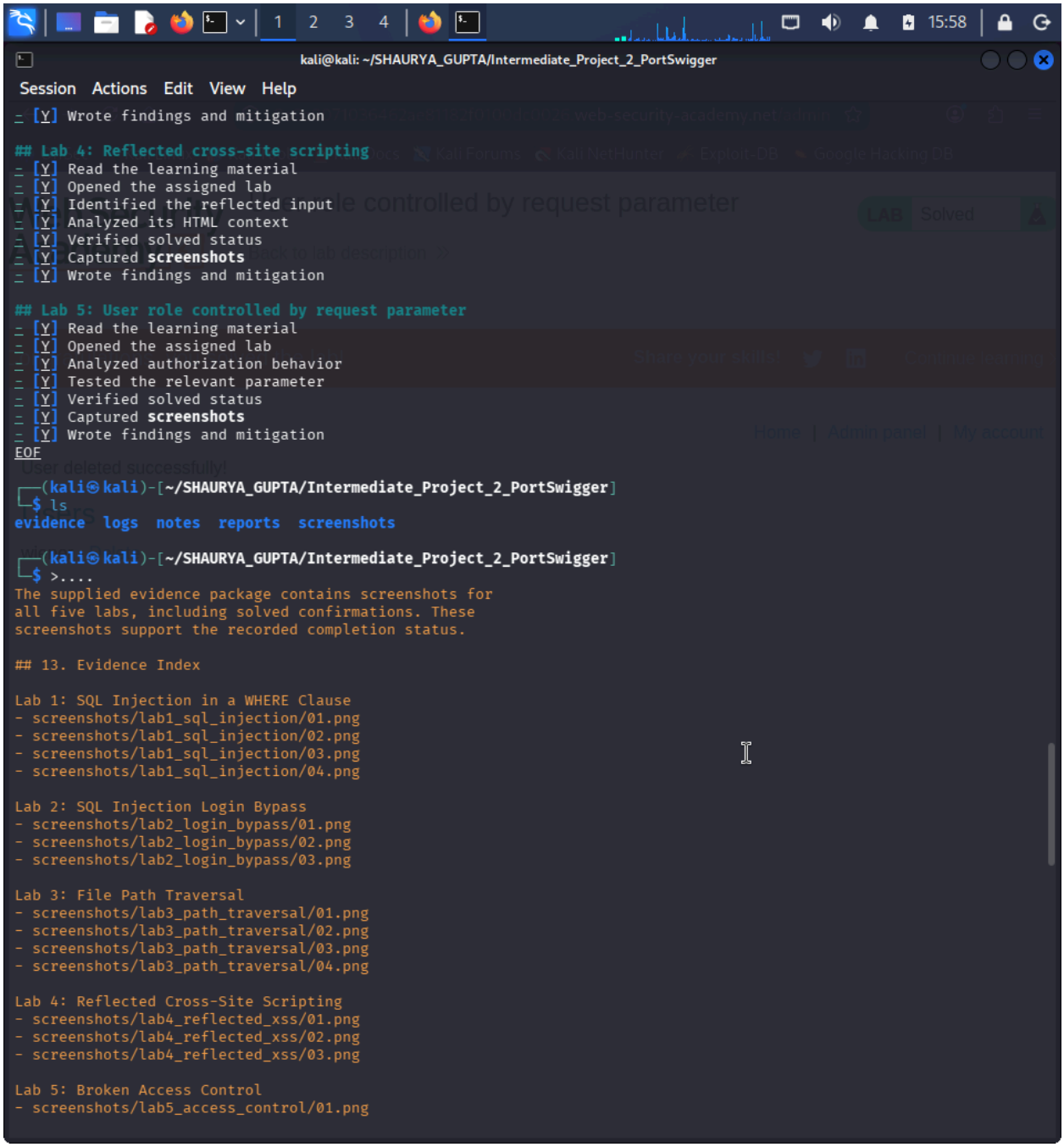
All labs: https://portswigger.net/web-security/all-labs

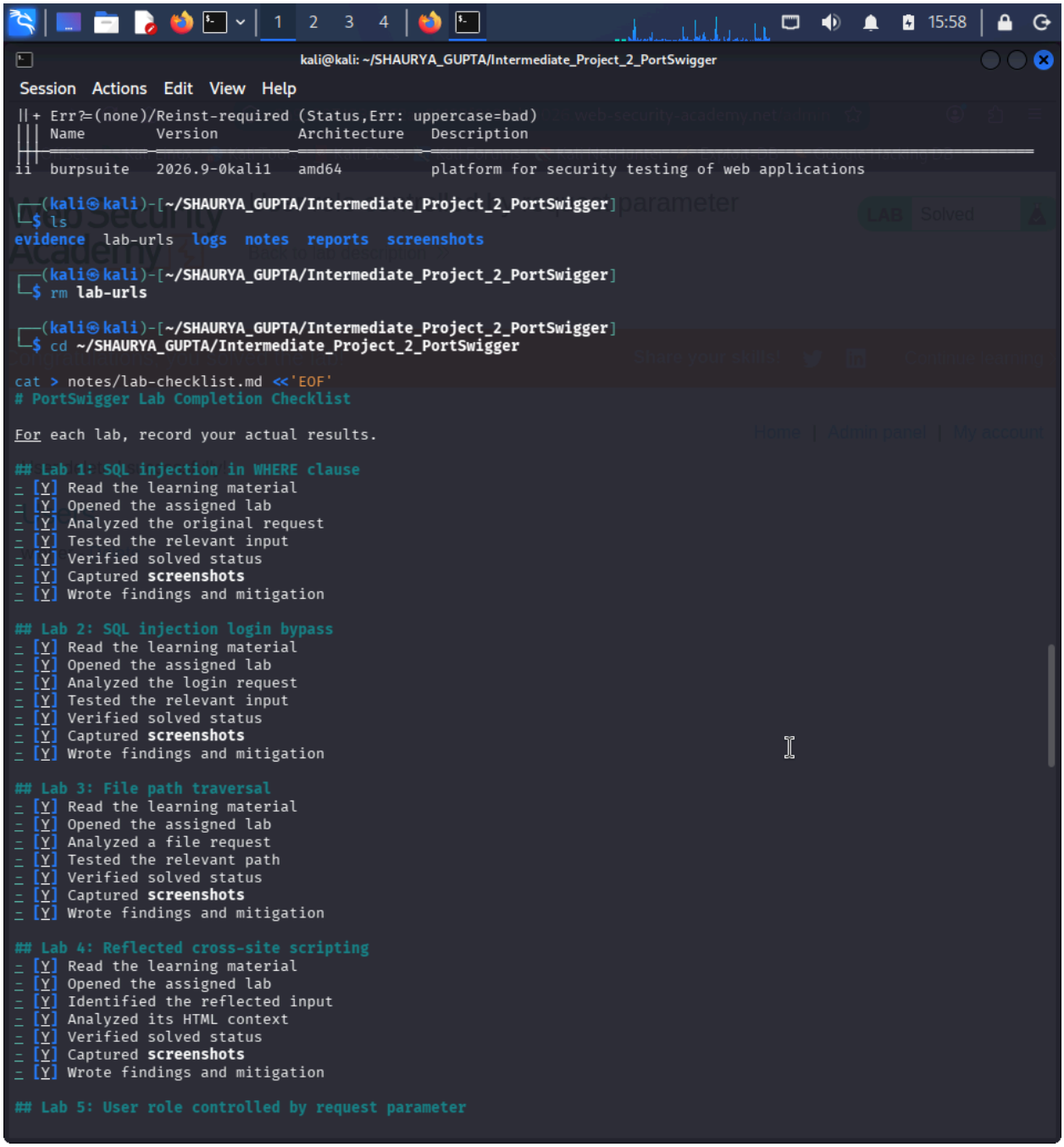
Burp Suite documentation: https://portswigger.net/burp/documentation

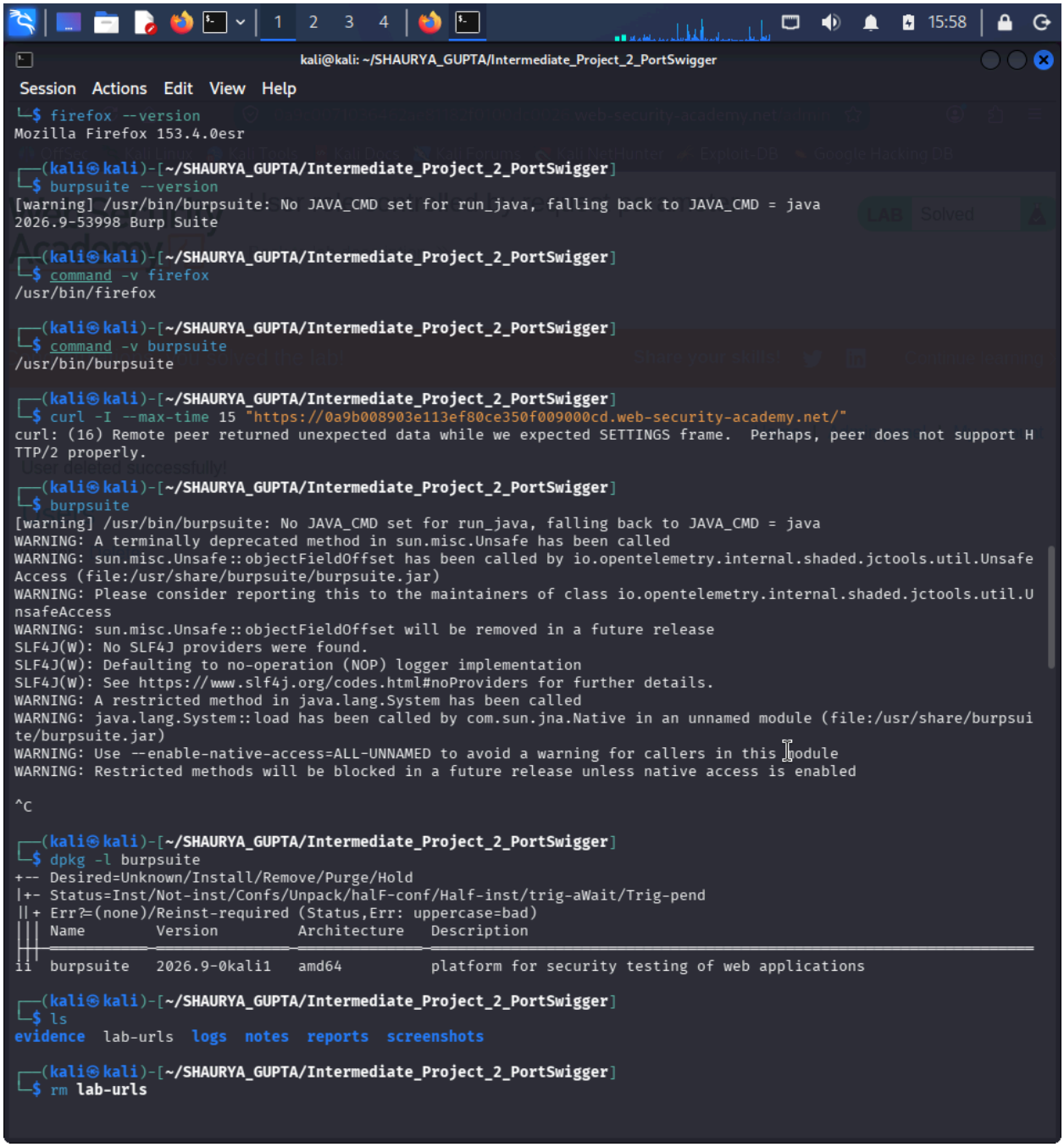

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger
Session Actions Edit View Help
`screenshots/lab4_reflected_xss/03.png`	Checked the final lab status.	Record the visible completion message, if present.
`screenshots/lab5_access_control/01.png`	Opened the access control lab.	Initial application state.
`screenshots/lab5_access_control/02.png`	Logged in using the lab-provided credentials.	Record the authenticated user state.
`screenshots/lab5_access_control/03.png`	Inspected relevant cookies or access-control configuration.	Record the actual values visible.
`screenshots/lab5_access_control/04.png`	Tested access to the administrative route.	Record the actual access result.
`screenshots/lab5_access_control/05.png`	Tested the required user-management action.	Record the actual response and outcome.
`screenshots/lab5_access_control/06.png`	Checked the final lab status.	Record the visible completion message, if present.
Evidence Handling Notes
- Keep only rows for screenshots that actually exist.
- Ensure every observation matches the screenshot.
- A payload alone does not prove successful exploitation.
- Mark a lab solved only when the evidence visibly confirms completion.
- Do not include simulated results, fabricated screenshots, or unsupported claims.
EOF
(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
$ nano evidence/evidence-register.md
(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
$ find . -maxdepth 3 -type f | sort
./evidence/evidence-register.md
./logs/environment.txt
./logs/terminal-20261025-045808.log
./notes/lab-checklist.md
./reports/technical-report.md
./screenshots/lab1_sql_injection/01.png
./screenshots/lab1_sql_injection/02.png
./screenshots/lab1_sql_injection/03.png
./screenshots/lab1_sql_injection/04.png
./screenshots/lab2_login_bypass/01.png
./screenshots/lab2_login_bypass/02.png
./screenshots/lab2_login_bypass/03.png
./screenshots/lab3_path_traversal/01.png
./screenshots/lab3_path_traversal/02.png
./screenshots/lab3_path_traversal/03.png
./screenshots/lab3_path_traversal/04.png
./screenshots/lab4_reflected_xss/01.png
./screenshots/lab4_reflected_xss/02.png
./screenshots/lab4_reflected_xss/03.png
./screenshots/lab5_access_control/01.png
./screenshots/lab5_access_control/02.png
./screenshots/lab5_access_control/03.png
./screenshots/lab5_access_control/04.png
./screenshots/lab5_access_control/05.png
./screenshots/lab5_access_control/06.png
(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
$ exit
Script done.

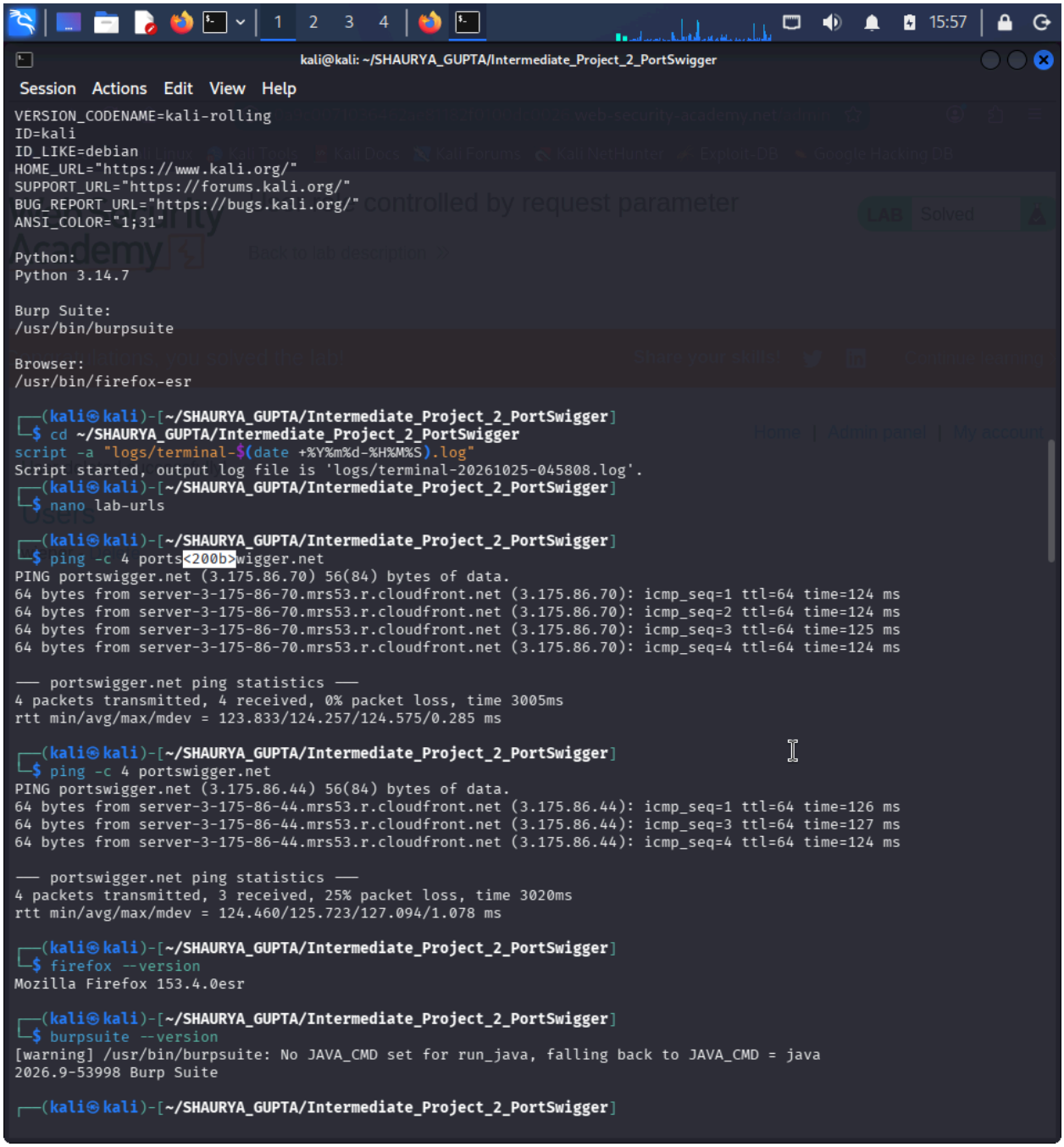

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger
Session Actions Edit View Help
https://portswigger.net/burp/documentation
EOF
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ >....
Student: Shaurya Gupta
Reference Number: CSN-OC-OL-26194
Registration Number: CSN-OC-2026-194
This register documents screenshots collected during the authorized lab exercises. Only genuine screenshots that exist and support the stated observations should be included.
Screenshot	Test performed	Observation
`screenshots/lab1_sql_injection/01.png`	Opened the SQL injection lab.	Initial lab/application state.
`screenshots/lab1_sql_injection/02.png`	Inspected the category filter for SQL injection behavior.	Record the response actually visible.
`screenshots/lab1_sql_injection/03.png`	Submitted the SQL injection test payload.	Record the actual response and any unexpected results shown.
`screenshots/lab1_sql_injection/04.png`	Checked the final lab status.	Confirm completion only if visibly shown.
`screenshots/lab2_login_bypass/01.png`	Opened the authentication lab.	Initial login page and application state.
`screenshots/lab2_login_bypass/02.png`	Tested the administrator login-bypass payload.	Record the actual authentication response.
`screenshots/lab2_login_bypass/03.png`	Checked the post-login page and lab status.	Record whether administrator access and completion are visibly confirmed.
`screenshots/lab3_path_traversal/01.png`	Opened the path traversal lab and inspected the file request.	Initial application state and relevant request location.
`screenshots/lab3_path_traversal/02.png`	Submitted a path traversal test payload.	Record the actual response.
`screenshots/lab3_path_traversal/03.png`	Inspected the requested system-file response.	Record whether the expected file contents are visible.
`screenshots/lab3_path_traversal/04.png`	Checked the final lab status.	Confirm completion only if visibly shown.
`screenshots/lab4_reflected_xss/01.png`	Opened the reflected XSS lab and identified the relevant input.	Initial application state and input location.
`screenshots/lab4_reflected_xss/02.png`	Submitted the XSS test payload.	Record whether reflection and JavaScript execution are demonstrated.
`screenshots/lab4_reflected_xss/03.png`	Checked the final lab status.	Record the visible completion message, if present.
`screenshots/lab5_access_control/01.png`	Opened the access control lab.	Initial application state.
`screenshots/lab5_access_control/02.png`	Logged in using the lab-provided credentials.	Record the authenticated user state.
`screenshots/lab5_access_control/03.png`	Inspected relevant cookies or access-control configuration.	Record the actual values visible.
`screenshots/lab5_access_control/04.png`	Tested access to the administrative route.	Record the actual access result.
`screenshots/lab5_access_control/05.png`	Tested the required user-management action.	Record the actual response and outcome.
`screenshots/lab5_access_control/06.png`	Checked the final lab status.	Record the visible completion message, if present.
Evidence Handling Notes
- Keep only rows for screenshots that actually exist.
- Ensure every observation matches the screenshot.

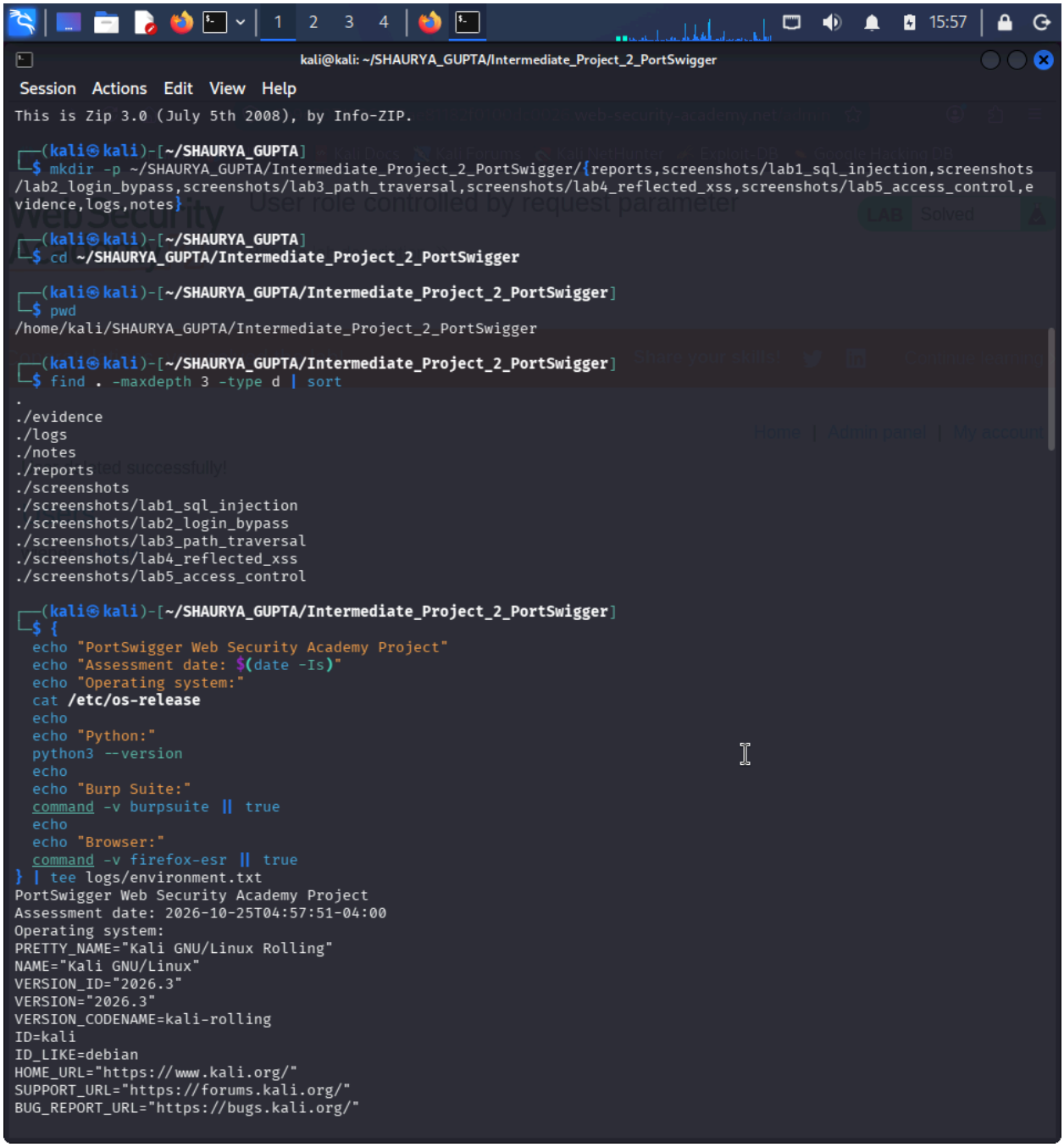

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger
Session Actions Edit View Help
Lab 2: SQL Injection Login Bypass
- screenshots/lab2_login_bypass/01.png
- screenshots/lab2_login_bypass/02.png
- screenshots/lab2_login_bypass/03.png
Lab 3: File Path Traversal
- screenshots/lab3_path_traversal/01.png
- screenshots/lab3_path_traversal/02.png
- screenshots/lab3_path_traversal/03.png
- screenshots/lab3_path_traversal/04.png
Lab 4: Reflected Cross-Site Scripting
- screenshots/lab4_reflected_xss/01.png
- screenshots/lab4_reflected_xss/02.png
- screenshots/lab4_reflected_xss/03.png
Lab 5: Broken Access Control
- screenshots/lab5_access_control/01.png
- screenshots/lab5_access_control/02.png
- screenshots/lab5_access_control/03.png
- screenshots/lab5_access_control/04.png
- screenshots/lab5_access_control/05.png
- screenshots/lab5_access_control/06.png
Environment and terminal records:
- logs/environment.txt
- logs/terminal-20261025-045808.log
The screenshot filenames above correspond to the supplied
evidence ZIP. The environment and terminal records are
listed as project artifacts and should be included in the
submission directory if available.
14. References
PortSwigger Web Security Academy:
https://portswigger.net/web-security
All labs:
https://portswigger.net/web-security/all-labs
Burp Suite documentation:
https://portswigger.net/burp/documentation
EOF
(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
$ >....
Student: Shaurya Gupta
Reference Number: CSN-OC-OL-26194
Registration Number: CSN-OC-2026-194
This register documents screenshots collected during the authorized lab exercises. Only genuine screenshots that exist and support the stated observations should be included.
| Screenshot | Test performed | Observation |
| `screenshots/lab1_sql_injection/01.png` | Opened the SQL injection lab. | Initial lab/application state. |

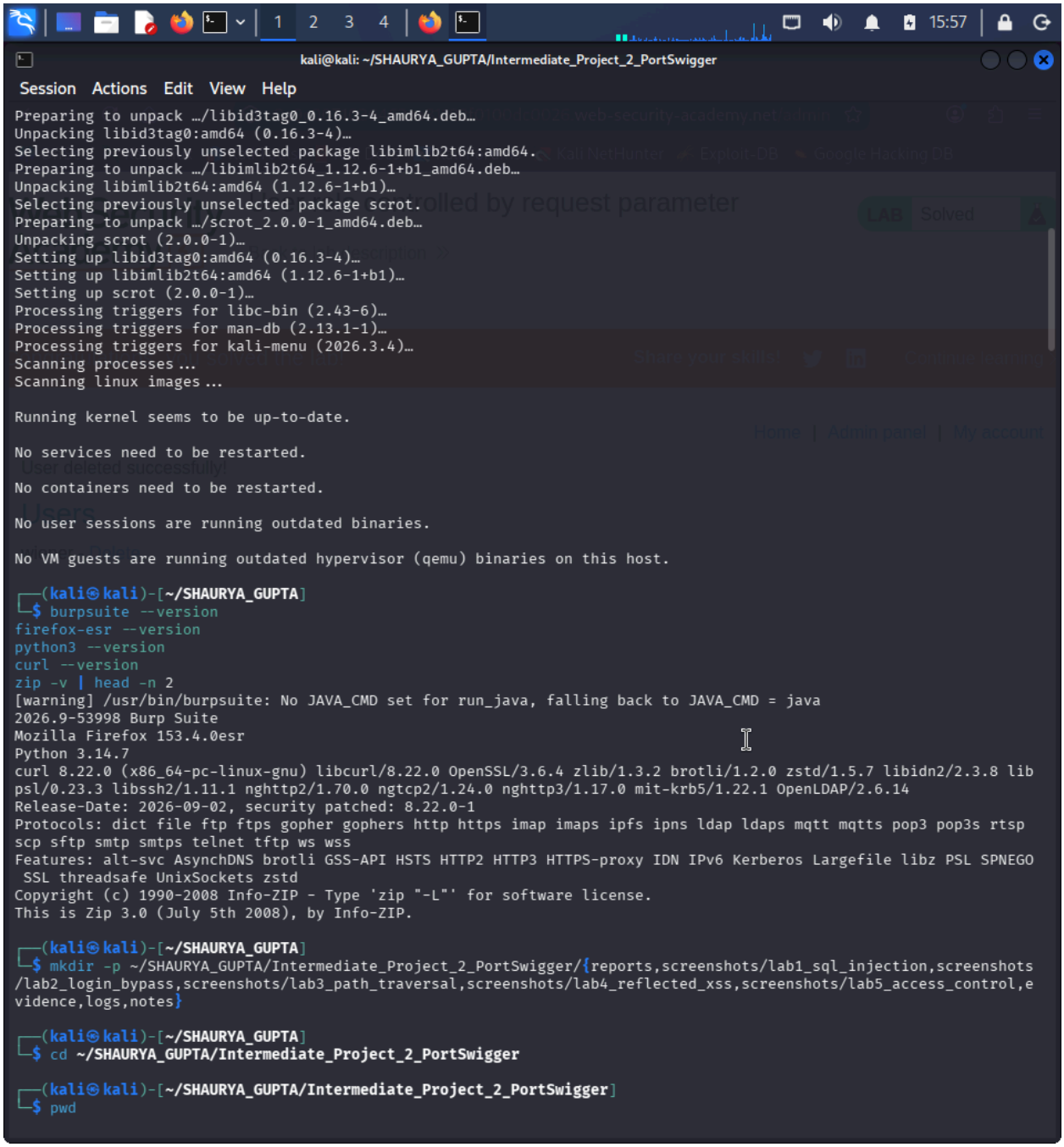

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger
Session Actions Edit View Help
- [Y] Wrote findings and mitigation
Lab 4: Reflected cross-site scripting
- [Y] Read the learning material
- [Y] Opened the assigned lab
- [Y] Identified the reflected input
- [Y] Analyzed its HTML context
- [Y] Verified solved status
- [Y] Captured screenshots
- [Y] Wrote findings and mitigation
Lab 5: User role controlled by request parameter
- [Y] Read the learning material
- [Y] Opened the assigned lab
- [Y] Analyzed authorization behavior
- [Y] Tested the relevant parameter
- [Y] Verified solved status
- [Y] Captured screenshots
- [Y] Wrote findings and mitigation
EOF
(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
$ ls
evidence logs notes reports screenshots
(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
$ >....
The supplied evidence package contains screenshots for
all five labs, including solved confirmations. These
screenshots support the recorded completion status.
13. Evidence Index
Lab 1: SQL Injection in a WHERE Clause
- screenshots/lab1_sql_injection/01.png
- screenshots/lab1_sql_injection/02.png
- screenshots/lab1_sql_injection/03.png
- screenshots/lab1_sql_injection/04.png
Lab 2: SQL Injection Login Bypass
- screenshots/lab2_login_bypass/01.png
- screenshots/lab2_login_bypass/02.png
- screenshots/lab2_login_bypass/03.png
Lab 3: File Path Traversal
- screenshots/lab3_path_traversal/01.png
- screenshots/lab3_path_traversal/02.png
- screenshots/lab3_path_traversal/03.png
- screenshots/lab3_path_traversal/04.png
Lab 4: Reflected Cross-Site Scripting
- screenshots/lab4_reflected_xss/01.png
- screenshots/lab4_reflected_xss/02.png
- screenshots/lab4_reflected_xss/03.png
Lab 5: Broken Access Control
- screenshots/lab5_access_control/01.png

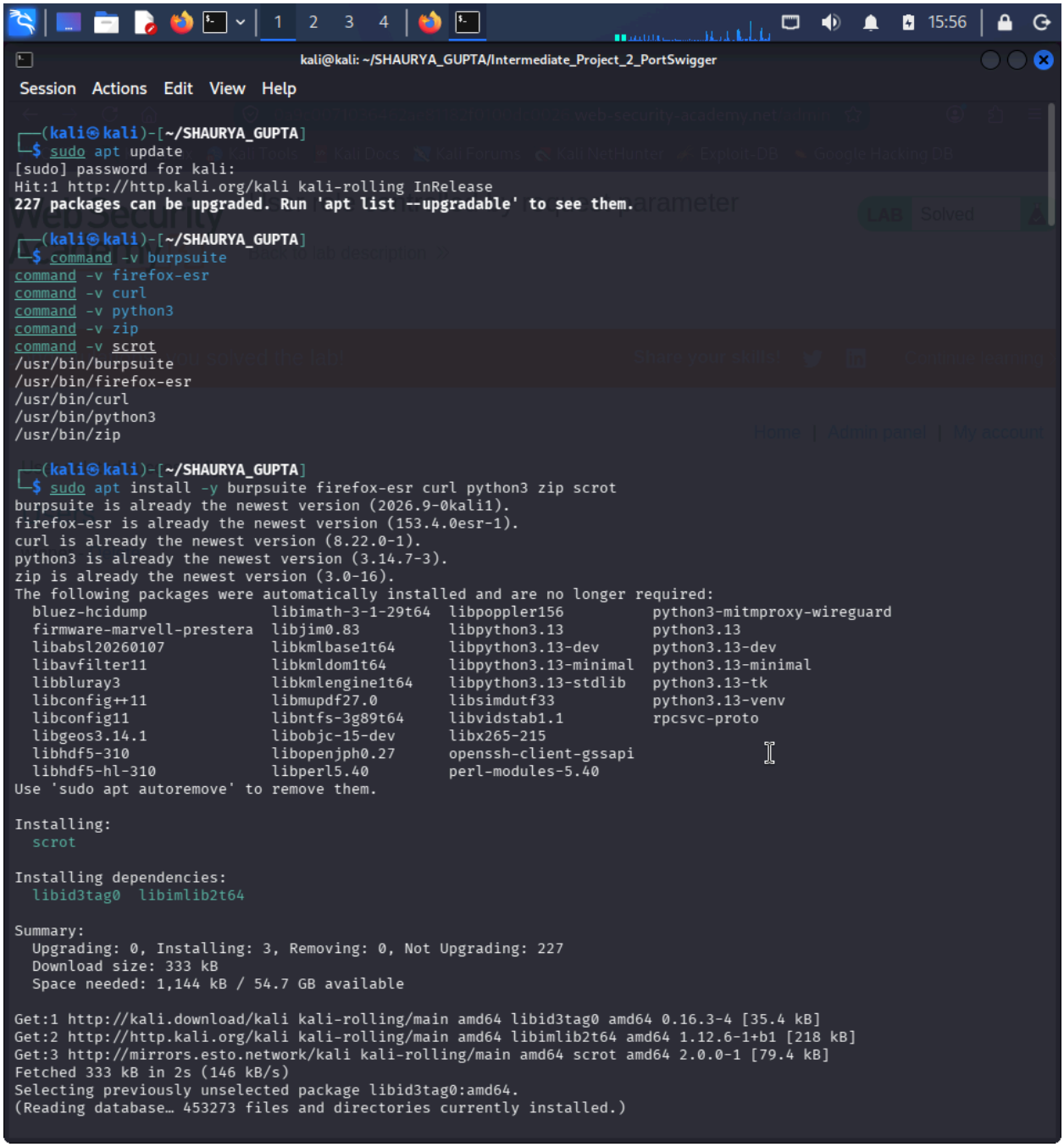

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger
Session Actions Edit View Help
|| + Err?=(none)/Reinst-required (Status,Err: uppercase=bad)
||| Name Version Architecture Description
ii burpsuite 2026.9-0kali1 amd64 platform for security testing of web applications
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ ls
evidence lab-urls logs notes reports screenshots
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ rm lab-urls
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ cd ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger
cat > notes/lab-checklist.md <<'EOF'
PortSwigger Lab Completion Checklist
For each lab, record your actual results.
Lab 1: SQL injection in WHERE clause
- [Y] Read the learning material
- [Y] Opened the assigned lab
- [Y] Analyzed the original request
- [Y] Tested the relevant input
- [Y] Verified solved status
- [Y] Captured screenshots
- [Y] Wrote findings and mitigation
Lab 2: SQL injection login bypass
- [Y] Read the learning material
- [Y] Opened the assigned lab
- [Y] Analyzed the login request
- [Y] Tested the relevant input
- [Y] Verified solved status
- [Y] Captured screenshots
- [Y] Wrote findings and mitigation
Lab 3: File path traversal
- [Y] Read the learning material
- [Y] Opened the assigned lab
- [Y] Analyzed a file request
- [Y] Tested the relevant path
- [Y] Verified solved status
- [Y] Captured screenshots
- [Y] Wrote findings and mitigation
Lab 4: Reflected cross-site scripting
- [Y] Read the learning material
- [Y] Opened the assigned lab
- [Y] Identified the reflected input
- [Y] Analyzed its HTML context
- [Y] Verified solved status
- [Y] Captured screenshots
- [Y] Wrote findings and mitigation
Lab 5: User role controlled by request parameter

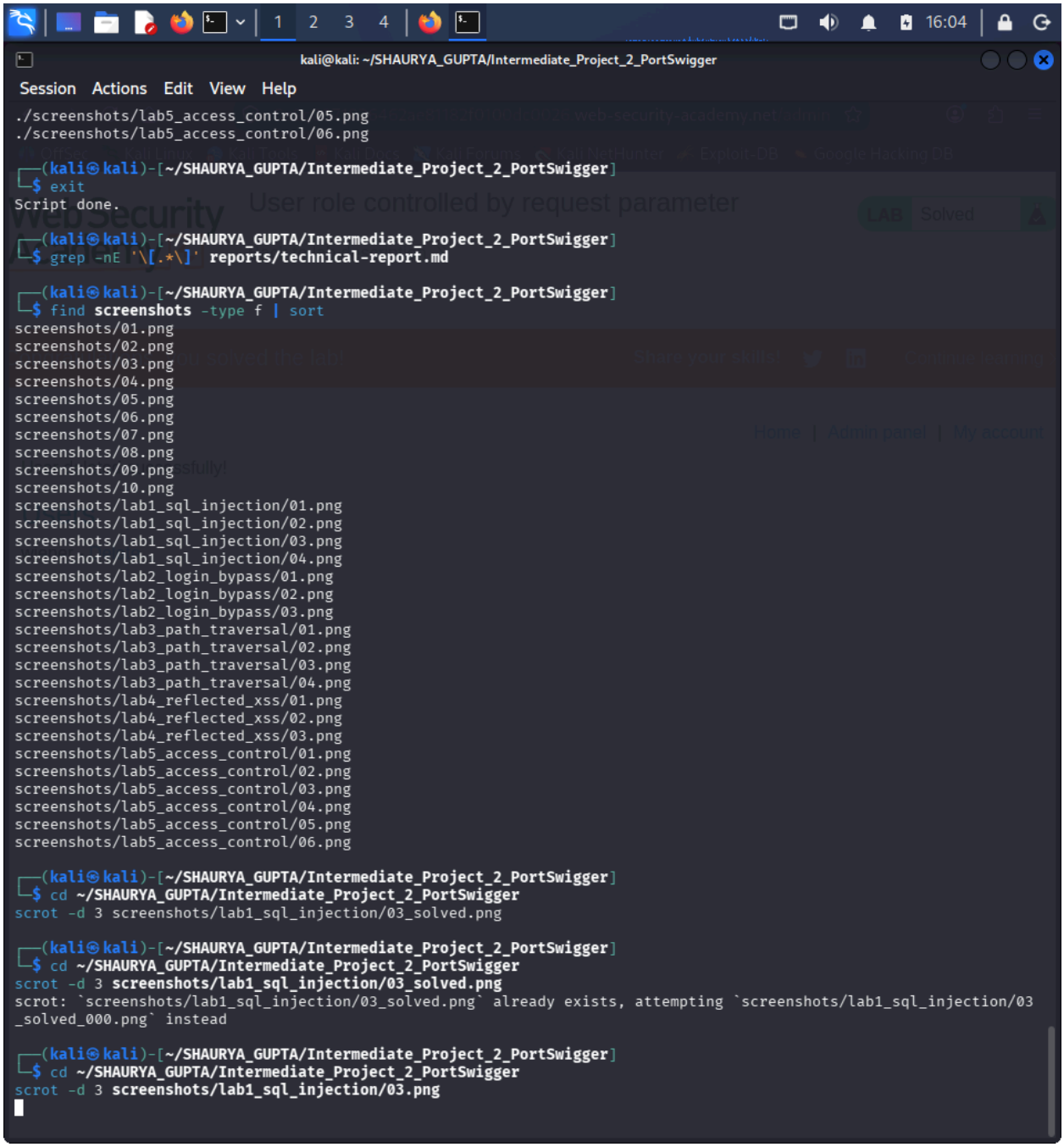

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger
Session Actions Edit View Help
└─$ firefox --version
Mozilla Firefox 153.4.0esr
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ burpsuite --version
[warning] /usr/bin/burpsuite: No JAVA_CMD set for run_java, falling back to JAVA_CMD = java
2026.9-53998 Burp Suite
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ command -v firefox
/usr/bin/firefox
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ command -v burpsuite
/usr/bin/burpsuite
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ curl -I --max-time 15 "https://0a9b008903e113ef80ce350f009000cd.web-security-academy.net/"
curl: (16) Remote peer returned unexpected data while we expected SETTINGS frame. Perhaps, peer does not support HTTP/2 properly.
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ burpsuite
[warning] /usr/bin/burpsuite: No JAVA_CMD set for run_java, falling back to JAVA_CMD = java
WARNING: A terminally deprecated method in sun.misc.Unsafe has been called
WARNING: sun.misc.Unsafe::objectFieldOffset has been called by io.opentelemetry.internal.shaded.jctools.util.UnsafeAccess (file:/usr/share/burpsuite/burpsuite.jar)
WARNING: Please consider reporting this to the maintainers of class io.opentelemetry.internal.shaded.jctools.util.UnsafeAccess
WARNING: sun.misc.Unsafe::objectFieldOffset will be removed in a future release
SLF4J(W): No SLF4J providers were found.
SLF4J(W): Defaulting to no-operation (NOP) logger implementation
SLF4J(W): See https://www.slf4j.org/codes.html#noProviders for further details.
WARNING: A restricted method in java.lang.System has been called
WARNING: java.lang.System::load has been called by com.sun.jna.Native in an unnamed module (file:/usr/share/burpsuite/burpsuite.jar)
WARNING: Use --enable-native-access=ALL-UNNAMED to avoid a warning for callers in this module
WARNING: Restricted methods will be blocked in a future release unless native access is enabled
^C
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ dpkg -l burpsuite
+++ Desired=Unknown/Install/Remove/Purge/Hold
|+- Status=Inst/Not-inst/Confs/Unpack/halF-conf/Half-inst/trig-aWait/Trig-pend
||+ Err?=(none)/Reinst-required (Status,Err: uppercase=bad)
||| Name Version Architecture Description
ii burpsuite 2026.9-0kali1 amd64 platform for security testing of web applications
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ ls
evidence lab-urls logs notes reports screenshots
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ rm lab-urls

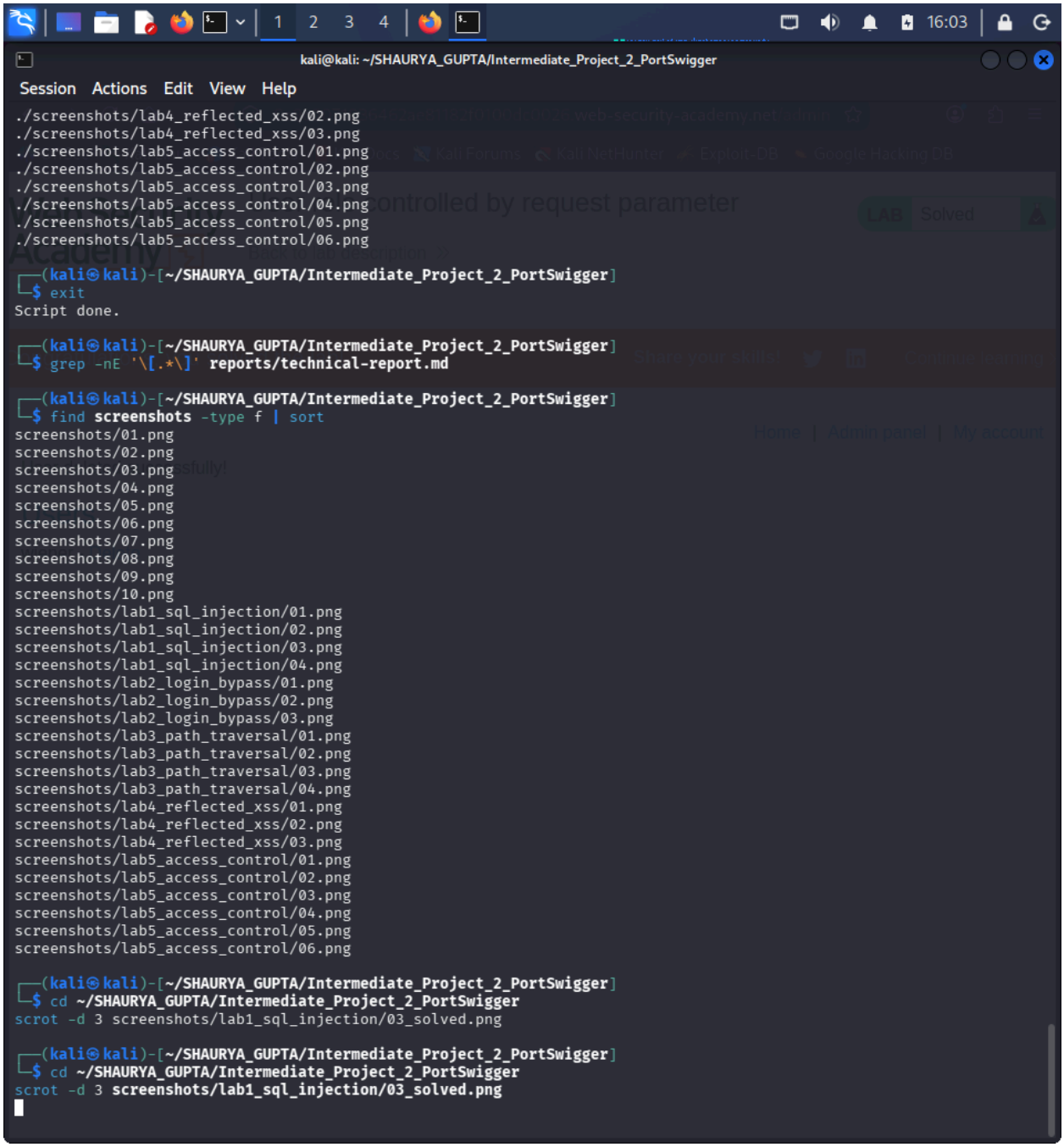

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger
Session Actions Edit View Help
VERSION_CODENAME=kali-rolling
ID=kali
ID_LIKE=debian
HOME_URL="https://www.kali.org/"
SUPPORT_URL="https://forums.kali.org/"
BUG_REPORT_URL="https://bugs.kali.org/"
ANSI_COLOR="1;31"
Python:
Python 3.14.7
Burp Suite:
/usr/bin/burpsuite
Browser:
/usr/bin/firefox-esr
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ cd ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger
script -a "logs/terminal-$(date +%Y%m%d-%H%M%S).log"
Script started, output log file is 'logs/terminal-20261025-045808.log'.
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ nano lab-urls
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ ping -c 4 ports<200b>wigger.net
PING portswigger.net (3.175.86.70) 56(84) bytes of data.
64 bytes from server-3-175-86-70.mrs53.r.cloudfront.net (3.175.86.70): icmp_seq=1 ttl=64 time=124 ms
64 bytes from server-3-175-86-70.mrs53.r.cloudfront.net (3.175.86.70): icmp_seq=2 ttl=64 time=124 ms
64 bytes from server-3-175-86-70.mrs53.r.cloudfront.net (3.175.86.70): icmp_seq=3 ttl=64 time=125 ms
64 bytes from server-3-175-86-70.mrs53.r.cloudfront.net (3.175.86.70): icmp_seq=4 ttl=64 time=124 ms
— portswigger.net ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3005ms
rtt min/avg/max/mdev = 123.833/124.257/124.575/0.285 ms
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ ping -c 4 portswigger.net
PING portswigger.net (3.175.86.44) 56(84) bytes of data.
64 bytes from server-3-175-86-44.mrs53.r.cloudfront.net (3.175.86.44): icmp_seq=1 ttl=64 time=126 ms
64 bytes from server-3-175-86-44.mrs53.r.cloudfront.net (3.175.86.44): icmp_seq=3 ttl=64 time=127 ms
64 bytes from server-3-175-86-44.mrs53.r.cloudfront.net (3.175.86.44): icmp_seq=4 ttl=64 time=124 ms
— portswigger.net ping statistics —
4 packets transmitted, 3 received, 25% packet loss, time 3020ms
rtt min/avg/max/mdev = 124.460/125.723/127.094/1.078 ms
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ firefox --version
Mozilla Firefox 153.4.0esr
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ burpsuite --version
[warning] /usr/bin/burpsuite: No JAVA_CMD set for run_java, falling back to JAVA_CMD = java
2026.9-53998 Burp Suite
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]

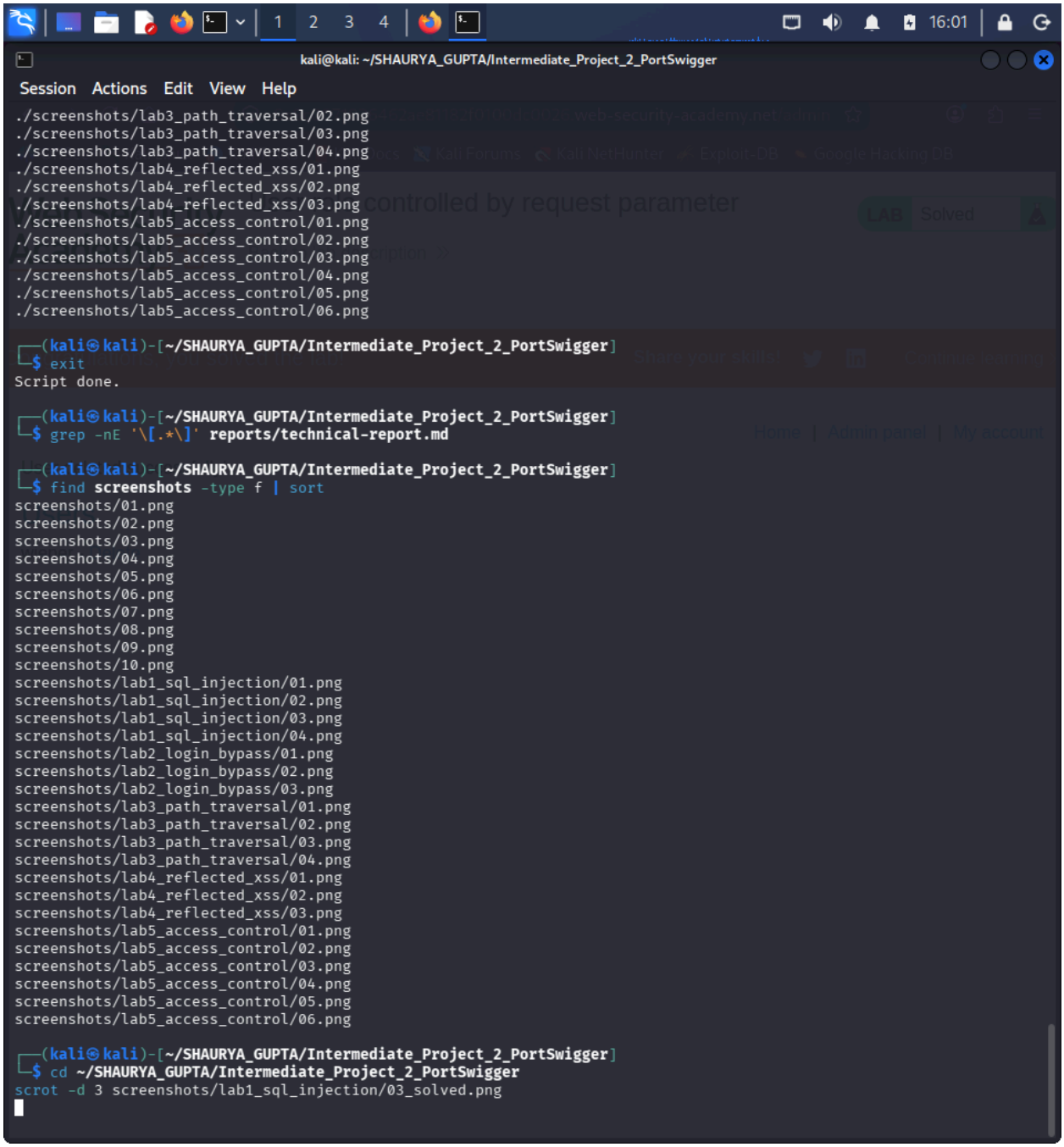

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger
Session Actions Edit View Help
This is Zip 3.0 (July 5th 2008), by Info-ZIP.
┌──(kali㉿kali)-[~/SHAURYA_GUPTA]
└─$ mkdir -p ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger/{reports,screenshots/lab1_sql_injection,screenshots/lab2_login_bypass,screenshots/lab3_path_traversal,screenshots/lab4_reflected_xss,screenshots/lab5_access_control,evidence,logs,notes}
┌──(kali㉿kali)-[~/SHAURYA_GUPTA]
└─$ cd ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ pwd
/home/kali/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ find . -maxdepth 3 -type d | sort
.
./evidence
./logs
./notes
./reports
./screenshots
./screenshots/lab1_sql_injection
./screenshots/lab2_login_bypass
./screenshots/lab3_path_traversal
./screenshots/lab4_reflected_xss
./screenshots/lab5_access_control
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ {
echo "PortSwigger Web Security Academy Project"
echo "Assessment date: $(date -Is)"
echo "Operating system:"
cat /etc/os-release
echo
echo "Python:"
python3 --version
echo
echo "Burp Suite:"
command -v burpsuite || true
echo
echo "Browser:"
command -v firefox-esr || true
} | tee logs/environment.txt
PortSwigger Web Security Academy Project
Assessment date: 2026-10-25T04:57:51-04:00
Operating system:
PRETTY_NAME="Kali GNU/Linux Rolling"
NAME="Kali GNU/Linux"
VERSION_ID="2026.3"
VERSION="2026.3"
VERSION_CODENAME=kali-rolling
ID=kali
ID_LIKE=debian
HOME_URL="https://www.kali.org/"
SUPPORT_URL="https://forums.kali.org/"
BUG_REPORT_URL="https://bugs.kali.org/"

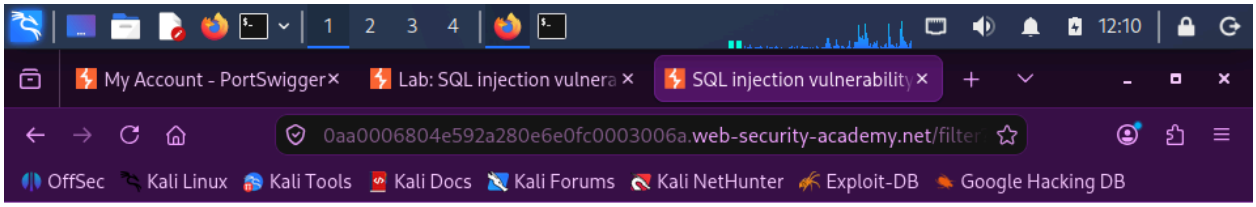

kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger
Session Actions Edit View Help
Preparing to unpack …/libid3tag0_0.16.3-4_amd64.deb…
Unpacking libid3tag0:amd64 (0.16.3-4)…
Selecting previously unselected package libimlib2t64:amd64.
Preparing to unpack …/libimlib2t64_1.12.6-1+b1_amd64.deb…
Unpacking libimlib2t64:amd64 (1.12.6-1+b1)…
Selecting previously unselected package scrot.
Preparing to unpack …/scrot_2.0.0-1_amd64.deb…
Unpacking scrot (2.0.0-1)…
Setting up libid3tag0:amd64 (0.16.3-4)…
Setting up libimlib2t64:amd64 (1.12.6-1+b1)…
Setting up scrot (2.0.0-1)…
Processing triggers for libc-bin (2.43-6)…
Processing triggers for man-db (2.13.1-1)…
Processing triggers for kali-menu (2026.3.4)…
Scanning processes…
Scanning linux images…
Running kernel seems to be up-to-date.
No services need to be restarted.
No containers need to be restarted.
No user sessions are running outdated binaries.
No VM guests are running outdated hypervisor (qemu) binaries on this host.
┌──(kali㉿kali)-[~/SHAURYA_GUPTA]
└─$ burpsuite --version
firefox-esr --version
python3 --version
curl --version
zip -v | head -n 2
[warning] /usr/bin/burpsuite: No JAVA_CMD set for run_java, falling back to JAVA_CMD = java
2026.9-53998 Burp Suite
Mozilla Firefox 153.4.0esr
Python 3.14.7
curl 8.22.0 (x86_64-pc-linux-gnu) libcurl/8.22.0 OpenSSL/3.6.4 zlib/1.3.2 brotli/1.2.0 zstd/1.5.7 libidn2/2.3.8 lib
psl/0.23.3 libssh2/1.11.1 nghttp2/1.70.0 ngtcp2/1.24.0 nghttp3/1.17.0 mit-krb5/1.22.1 OpenLDAP/2.6.14
Release-Date: 2026-09-02, security patched: 8.22.0-1
Protocols: dict file ftp ftps gopher gophers http https imap imaps ipfs ipns ldap ldaps mqtt mqtts pop3 pop3s rtsp
scp sftp smtp smtps telnet tftp ws wss
Features: alt-svc AsynchDNS brotli GSS-API HSTS HTTP2 HTTP3 HTTPS-proxy IDN IPv6 Kerberos Largefile libz PSL SPNEGO
SSL threadsafe UnixSockets zstd
Copyright (c) 1990-2008 Info-ZIP - Type 'zip "-L"' for software license.
This is Zip 3.0 (July 5th 2008), by Info-ZIP.
┌──(kali㉿kali)-[~/SHAURYA_GUPTA]
└─$ mkdir -p ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger/{reports,screenshots/lab1_sql_injection,screenshots
/lab2_login_bypass,screenshots/lab3_path_traversal,screenshots/lab4_reflected_xss,screenshots/lab5_access_control,e
vidence,logs,notes}
┌──(kali㉿kali)-[~/SHAURYA_GUPTA]
└─$ cd ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ pwd


kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger
Session Actions Edit View Help
┌──(kali㉿kali)-[~/SHAURYA_GUPTA]
└─$ sudo apt update
[sudo] password for kali:
Hit:1 http://http.kali.org/kali kali-rolling InRelease
227 packages can be upgraded. Run 'apt list --upgradable' to see them.
┌──(kali㉿kali)-[~/SHAURYA_GUPTA]
└─$ command -v burpsuite
command -v firefox-esr
command -v curl
command -v python3
command -v zip
command -v scrot
/usr/bin/burpsuite
/usr/bin/firefox-esr
/usr/bin/curl
/usr/bin/python3
/usr/bin/zip
┌──(kali㉿kali)-[~/SHAURYA_GUPTA]
└─$ sudo apt install -y burpsuite firefox-esr curl python3 zip scrot
burpsuite is already the newest version (2026.9-0kali1).
firefox-esr is already the newest version (153.4.0esr-1).
curl is already the newest version (8.22.0-1).
python3 is already the newest version (3.14.7-3).
zip is already the newest version (3.0-16).
The following packages were automatically installed and are no longer required:
bluez-hcidump libimath-3-1-29t64 libpoppler156 python3-mitmproxy-wireguard
firmware-marvell-prestera libjim0.83 libpython3.13 python3.13
libabsl20260107 libkmlbase1t64 libpython3.13-dev python3.13-dev
libavfilter11 libkmldom1t64 libpython3.13-minimal python3.13-minimal
libbluray3 libkmlengine1t64 libpython3.13-stdlib python3.13-tk
libconfig++11 libmupdf27.0 libsimdutf33 python3.13-venv
libconfig11 libntfs-3g89t64 libvidstab1.1 rpcsvc-proto
libgeos3.14.1 libobjc-15-dev libx265-215
libhdf5-310 libopenjph0.27 openssh-client-gssapi
libhdf5-hl-310 libperl5.40 perl-modules-5.40
Use 'sudo apt autoremove' to remove them.
Installing:
scrot
Installing dependencies:
libid3tag0 libimlib2t64
Summary:
Upgrading: 0, Installing: 3, Removing: 0, Not Upgrading: 227
Download size: 333 kB
Space needed: 1,144 kB / 54.7 GB available
Get:1 http://kali.download/kali kali-rolling/main amd64 libid3tag0 amd64 0.16.3-4 [35.4 kB]
Get:2 http://http.kali.org/kali kali-rolling/main amd64 libimlib2t64 amd64 1.12.6-1+b1 [218 kB]
Get:3 http://mirrors.esto.network/kali kali-rolling/main amd64 scrot amd64 2.0.0-1 [79.4 kB]
Fetched 333 kB in 2s (146 kB/s)
Selecting previously unselected package libid3tag0:amd64.
(Reading database… 453273 files and directories currently installed.)


1 2 3 4
16:04
kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger
Session Actions Edit View Help
./screenshots/lab5_access_control/05.png
./screenshots/lab5_access_control/06.png
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ exit
Script done.
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ grep -nE '\[.*\]' reports/technical-report.md
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ find screenshots -type f | sort
screenshots/01.png
screenshots/02.png
screenshots/03.png
screenshots/04.png
screenshots/05.png
screenshots/06.png
screenshots/07.png
screenshots/08.png
screenshots/09.png
screenshots/10.png
screenshots/lab1_sql_injection/01.png
screenshots/lab1_sql_injection/02.png
screenshots/lab1_sql_injection/03.png
screenshots/lab1_sql_injection/04.png
screenshots/lab2_login_bypass/01.png
screenshots/lab2_login_bypass/02.png
screenshots/lab2_login_bypass/03.png
screenshots/lab3_path_traversal/01.png
screenshots/lab3_path_traversal/02.png
screenshots/lab3_path_traversal/03.png
screenshots/lab3_path_traversal/04.png
screenshots/lab4_reflected_xss/01.png
screenshots/lab4_reflected_xss/02.png
screenshots/lab4_reflected_xss/03.png
screenshots/lab5_access_control/01.png
screenshots/lab5_access_control/02.png
screenshots/lab5_access_control/03.png
screenshots/lab5_access_control/04.png
screenshots/lab5_access_control/05.png
screenshots/lab5_access_control/06.png
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ cd ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger
scrot -d 3 screenshots/lab1_sql_injection/03_solved.png
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ cd ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger
scrot -d 3 screenshots/lab1_sql_injection/03_solved.png
scrot: `screenshots/lab1_sql_injection/03_solved.png` already exists, attempting `screenshots/lab1_sql_injection/03_solved_000.png` instead
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ cd ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger
scrot -d 3 screenshots/lab1_sql_injection/03.png


kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger
Session Actions Edit View Help
./screenshots/lab4_reflected_xss/02.png
./screenshots/lab4_reflected_xss/03.png
./screenshots/lab5_access_control/01.png
./screenshots/lab5_access_control/02.png
./screenshots/lab5_access_control/03.png
./screenshots/lab5_access_control/04.png
./screenshots/lab5_access_control/05.png
./screenshots/lab5_access_control/06.png
(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
$ exit
Script done.
(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
$ grep -nE '\[.*\]' reports/technical-report.md
(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
$ find screenshots -type f | sort
screenshots/01.png
screenshots/02.png
screenshots/03.png
screenshots/04.png
screenshots/05.png
screenshots/06.png
screenshots/07.png
screenshots/08.png
screenshots/09.png
screenshots/10.png
screenshots/lab1_sql_injection/01.png
screenshots/lab1_sql_injection/02.png
screenshots/lab1_sql_injection/03.png
screenshots/lab1_sql_injection/04.png
screenshots/lab2_login_bypass/01.png
screenshots/lab2_login_bypass/02.png
screenshots/lab2_login_bypass/03.png
screenshots/lab3_path_traversal/01.png
screenshots/lab3_path_traversal/02.png
screenshots/lab3_path_traversal/03.png
screenshots/lab3_path_traversal/04.png
screenshots/lab4_reflected_xss/01.png
screenshots/lab4_reflected_xss/02.png
screenshots/lab4_reflected_xss/03.png
screenshots/lab5_access_control/01.png
screenshots/lab5_access_control/02.png
screenshots/lab5_access_control/03.png
screenshots/lab5_access_control/04.png
screenshots/lab5_access_control/05.png
screenshots/lab5_access_control/06.png
(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
$ cd ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger
scrot -d 3 screenshots/lab1_sql_injection/03_solved.png
(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
$ cd ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger
scrot -d 3 screenshots/lab1_sql_injection/03_solved.png


1 2 3 4
16:01
kali@kali: ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger
Session Actions Edit View Help
./screenshots/lab3_path_traversal/02.png
./screenshots/lab3_path_traversal/03.png
./screenshots/lab3_path_traversal/04.png
./screenshots/lab4_reflected_xss/01.png
./screenshots/lab4_reflected_xss/02.png
./screenshots/lab4_reflected_xss/03.png
./screenshots/lab5_access_control/01.png
./screenshots/lab5_access_control/02.png
./screenshots/lab5_access_control/03.png
./screenshots/lab5_access_control/04.png
./screenshots/lab5_access_control/05.png
./screenshots/lab5_access_control/06.png
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ exit
Script done.
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ grep -nE '\[.*\]' reports/technical-report.md
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ find screenshots -type f | sort
screenshots/01.png
screenshots/02.png
screenshots/03.png
screenshots/04.png
screenshots/05.png
screenshots/06.png
screenshots/07.png
screenshots/08.png
screenshots/09.png
screenshots/10.png
screenshots/lab1_sql_injection/01.png
screenshots/lab1_sql_injection/02.png
screenshots/lab1_sql_injection/03.png
screenshots/lab1_sql_injection/04.png
screenshots/lab2_login_bypass/01.png
screenshots/lab2_login_bypass/02.png
screenshots/lab2_login_bypass/03.png
screenshots/lab3_path_traversal/01.png
screenshots/lab3_path_traversal/02.png
screenshots/lab3_path_traversal/03.png
screenshots/lab3_path_traversal/04.png
screenshots/lab4_reflected_xss/01.png
screenshots/lab4_reflected_xss/02.png
screenshots/lab4_reflected_xss/03.png
screenshots/lab5_access_control/01.png
screenshots/lab5_access_control/02.png
screenshots/lab5_access_control/03.png
screenshots/lab5_access_control/04.png
screenshots/lab5_access_control/05.png
screenshots/lab5_access_control/06.png
┌──(kali㉿kali)-[~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger]
└─$ cd ~/SHAURYA_GUPTA/Intermediate_Project_2_PortSwigger
scrot -d 3 screenshots/lab1_sql_injection/03_solved.png



Web Security Academy

SQL injection vulnerability in WHERE clause allowing retrieval of hidden data

LAB Solved

Back to lab description »

Congratulations, you solved the lab! Share your skills! Continue learning »

Home

WE LIKE TO SHOP

Corporate gifts' OR 1=1--

Refine your search:

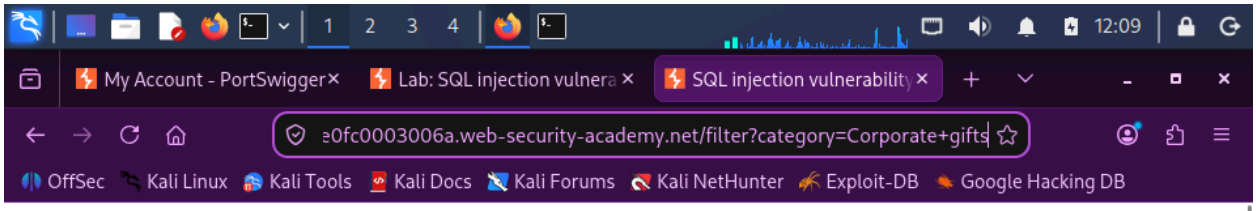
All | Corporate gifts | Food & Drink | Lifestyle | Pets

Balance Beams

There is No 'I' in Team

Roulette Drinking Game

Hydrated Crackers



Web Security Academy

SQL injection vulnerability in WHERE clause allowing retrieval of hidden data

LAB Not solved

Back to lab home | Back to lab description »

Home

WE LIKE TO SHOP

Corporate gifts

Refine your search:

All | Corporate gifts | Food & Drink | Lifestyle | Pets

The Giant Enter Key

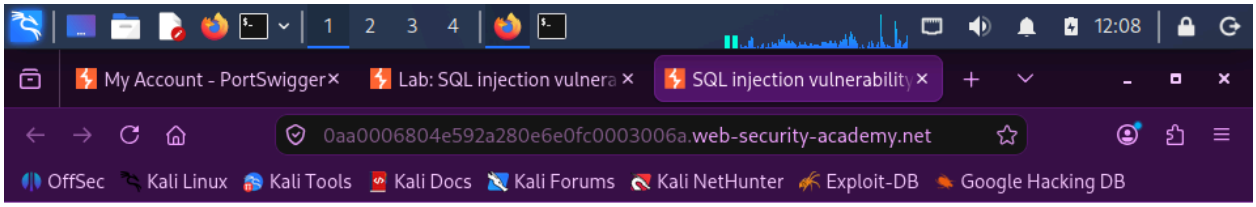
$76.59 View details

Com-Tool

$88.95 View details

Caution Sign

$49.35 View details



Web Security Academy

SQL injection vulnerability in WHERE clause allowing retrieval of hidden data

LAB Not solved

Back to lab description »

Home

WE LIKE TO SHOP

Refine your search:

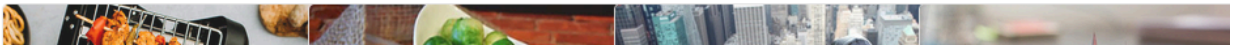
All | Corporate gifts | Food & Drink | Lifestyle | Pets

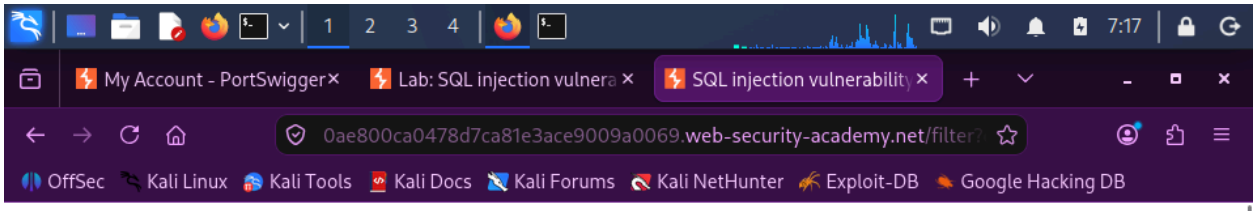
The Giant Enter Key
★★★☆☆ $76.59
View details

Com-Tool
★☆☆☆☆ $88.95
View details

Caution Sign
★★★★★ $49.35
View details

Waterproof Tea Bags
★☆☆☆☆ $38.13
View details





Web Security Academy

SQL injection vulnerability in WHERE clause allowing retrieval of hidden data

LAB Solved

Back to lab description »

Congratulations, you solved the lab! Share your skills! Continue learning »

Home

WE LIKE TO SHOP

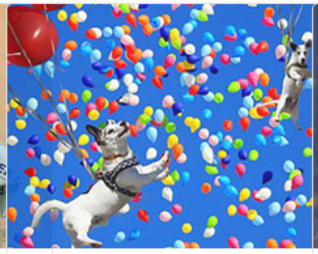
Gifts' OR 1=1--

Refine your search:

All | Accessories | Corporate gifts | Gifts | Pets

Folding Gadgets

★★★★☆



Pet Experience Days

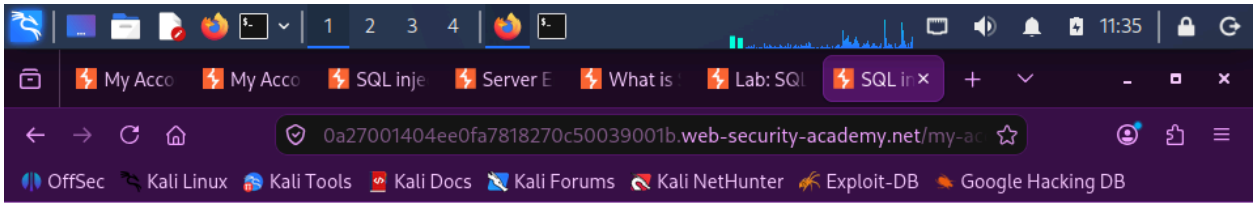
★★☆☆☆

ZZZZZZ Bed - Your New Home Office

★★☆☆☆

Lightbulb Moments

★☆☆☆☆



Web Security Academy

SQL injection vulnerability allowing login bypass

LAB Solved

Back to lab description »

Congratulations, you solved the lab! Share your skills! Continue learning »

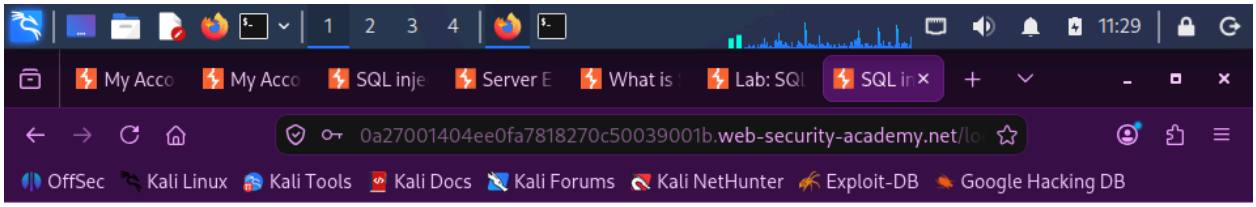
Home | My account | Log out

My Account

Your username is: administrator

Email

Update email



Web Security Academy

SQL injection vulnerability allowing login bypass

Back to lab description »

LAB Not solved

Home | My account

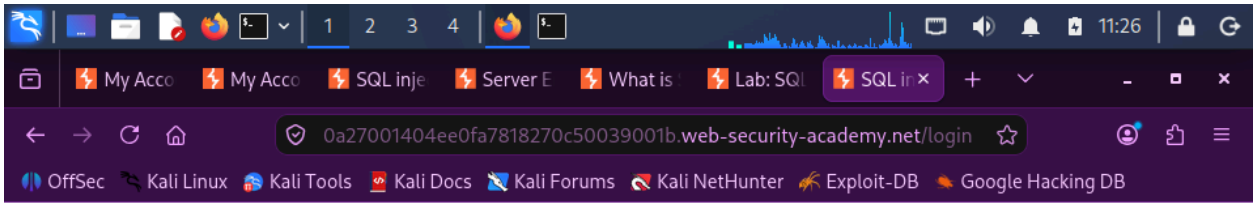
Login

Invalid username or password.

Username

Password

Log in



Web Security Academy

SQL injection vulnerability allowing login bypass

Back to lab description »

LAB Not solved

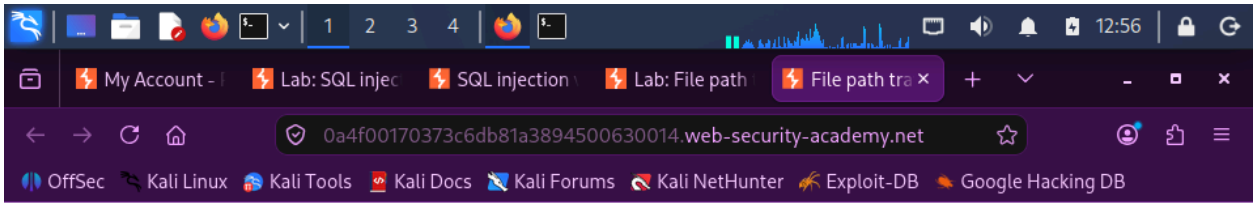
Home | My account

Login

Username

Password

Log in



Web Security Academy

File path traversal, simple case

Back to lab description »

LAB Solved

Congratulations, you solved the lab! Share your skills! Continue learning »

Home

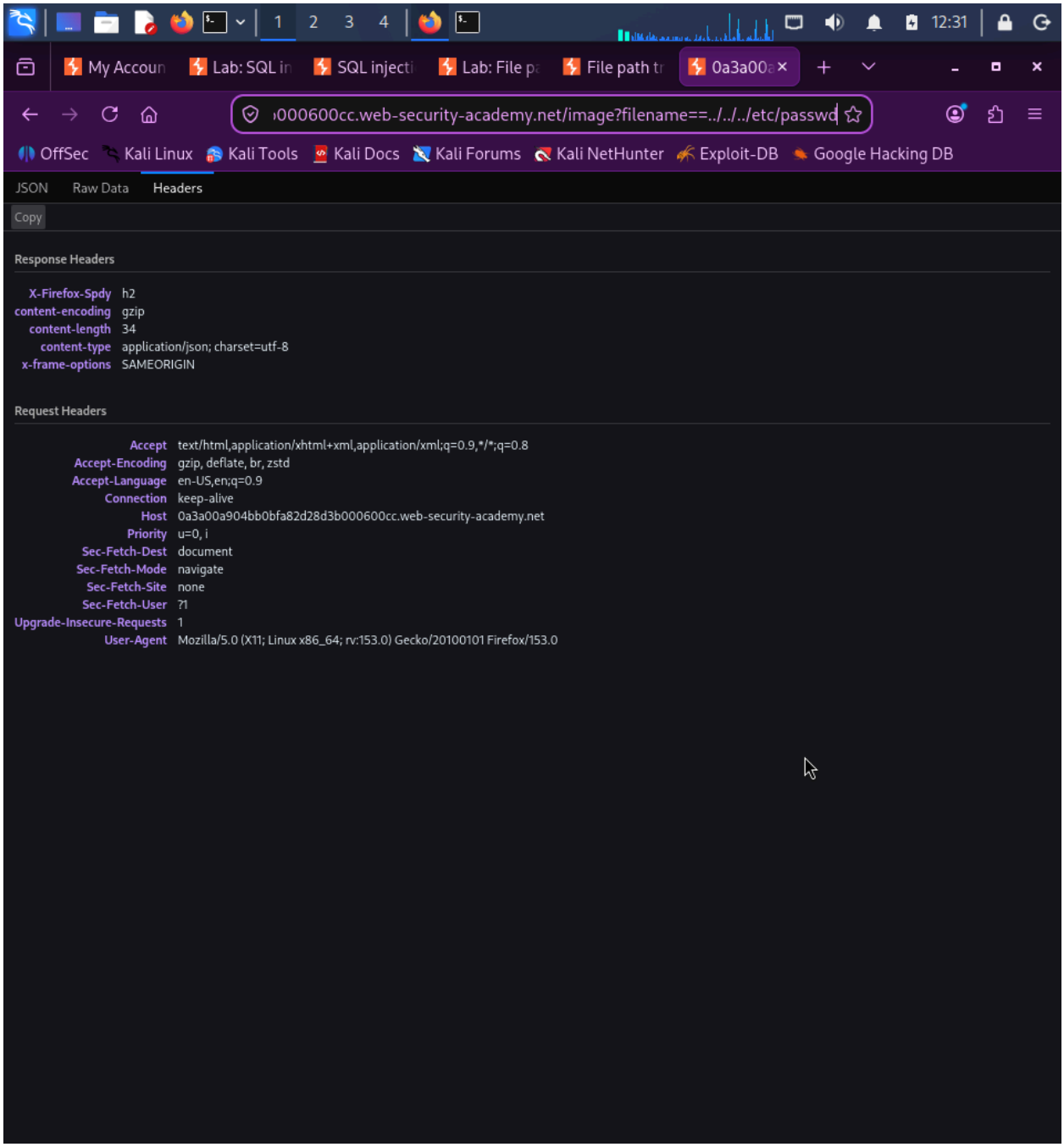
WE LIKE TO SHOP

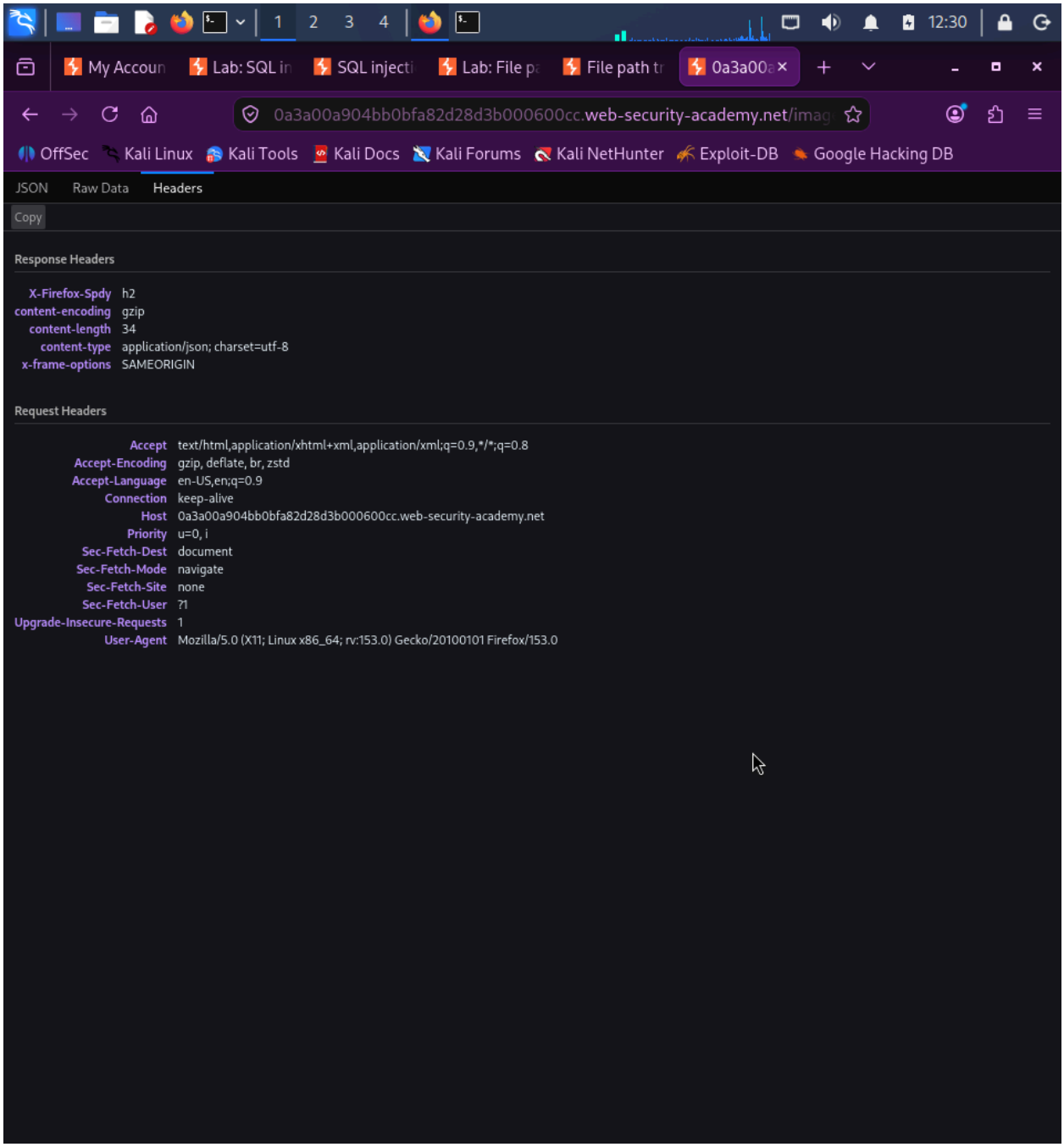
Sarcastic 9 Ball
★★★★☆ $55.90
View details

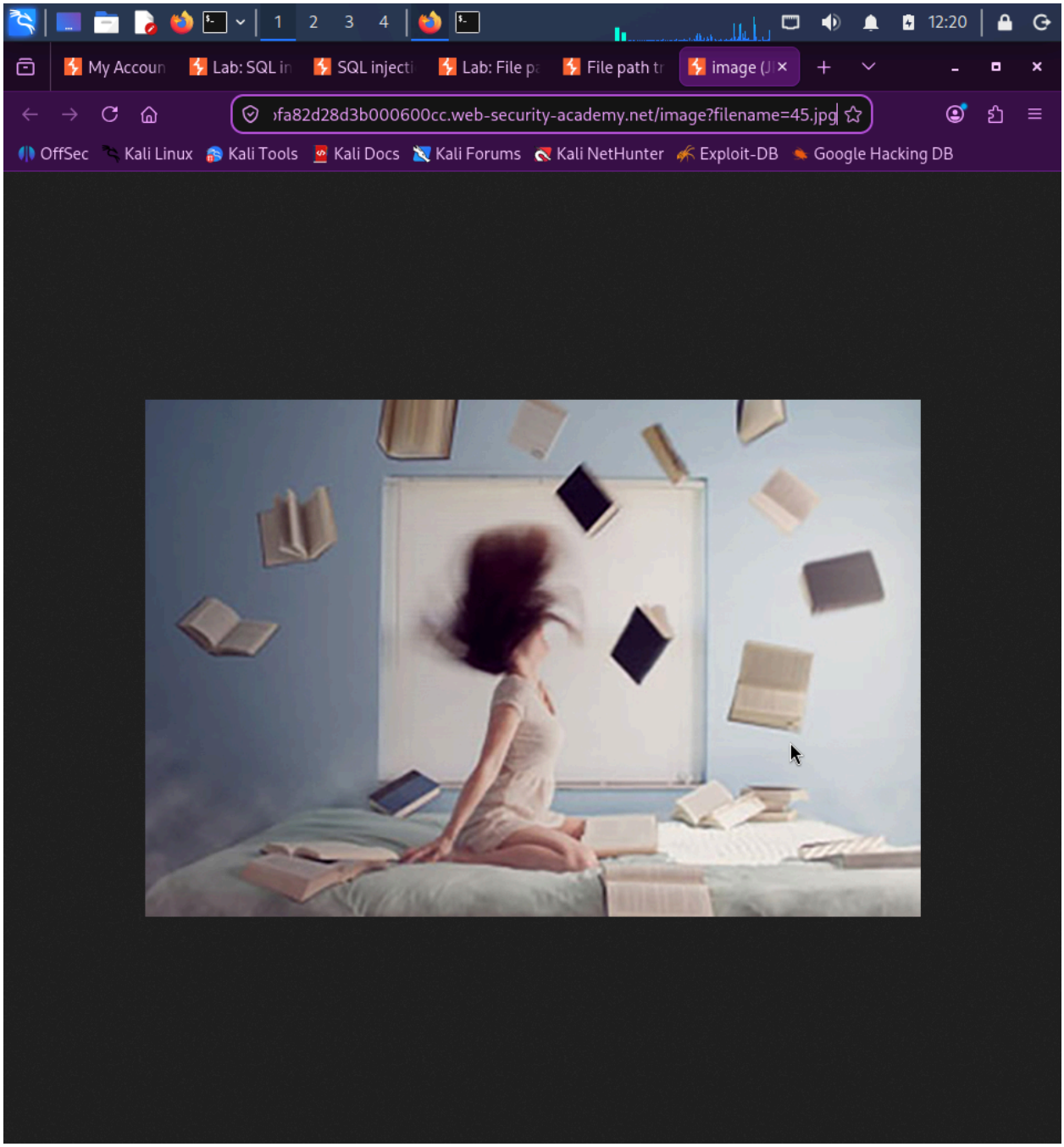
Cheshire Cat Grin
★★☆☆☆ $31.93
View details

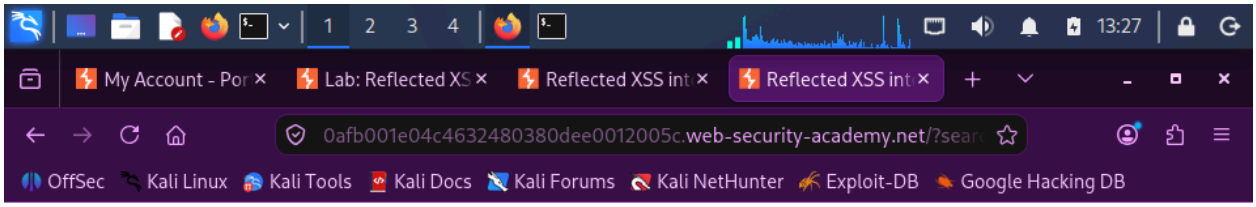
Conversation Controlling Lemon
★★☆☆☆ $46.30
View details

Dancing In The Dark
★★☆☆☆ $81.15
View details


12:31
My Accoun
Lab: SQL in
SQL injecti
Lab: File pa
File path tr
0a3a00a
000600cc.web-security-academy.net/image?filename=../../../etc/passwd
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
JSON
Raw Data
Headers
Copy
Response Headers
X-Firefox-Spdy h2
content-encoding gzip
content-length 34
content-type application/json; charset=utf-8
x-frame-options SAMEORIGIN
Request Headers
Accept text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding gzip, deflate, br, zstd
Accept-Language en-US,en;q=0.9
Connection keep-alive
Host 0a3a00a904bb0bfa82d28d3b000600cc.web-security-academy.net
Priority u=0, i
Sec-Fetch-Dest document
Sec-Fetch-Mode navigate
Sec-Fetch-Site none
Sec-Fetch-User ?1
Upgrade-Insecure-Requests 1
User-Agent Mozilla/5.0 (X11; Linux x86_64; rv:153.0) Gecko/20100101 Firefox/153.0


12:30
My Accoun
Lab: SQL in
SQL injecti
Lab: File pa
File path tr
0a3a00a904bb0bfa82d28d3b000600cc.web-security-academy.net/imag
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
JSON
Raw Data
Headers
Copy
Response Headers
X-Firefox-Spdy h2
content-encoding gzip
content-length 34
content-type application/json; charset=utf-8
x-frame-options SAMEORIGIN
Request Headers
Accept text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding gzip, deflate, br, zstd
Accept-Language en-US,en;q=0.9
Connection keep-alive
Host 0a3a00a904bb0bfa82d28d3b000600cc.web-security-academy.net
Priority u=0, i
Sec-Fetch-Dest document
Sec-Fetch-Mode navigate
Sec-Fetch-Site none
Sec-Fetch-User ?1
Upgrade-Insecure-Requests 1
User-Agent Mozilla/5.0 (X11; Linux x86_64; rv:153.0) Gecko/20100101 Firefox/153.0


1 2 3 4
12:20
My Accoun
Lab: SQL in
SQL injecti
Lab: File pa
File path tr
image (J
›fa82d28d3b000600cc.web-security-academy.net/image?filename=45.jpg
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB



Web Security Academy

Reflected XSS into HTML context with nothing encoded

LAB Solved

Back to lab description »

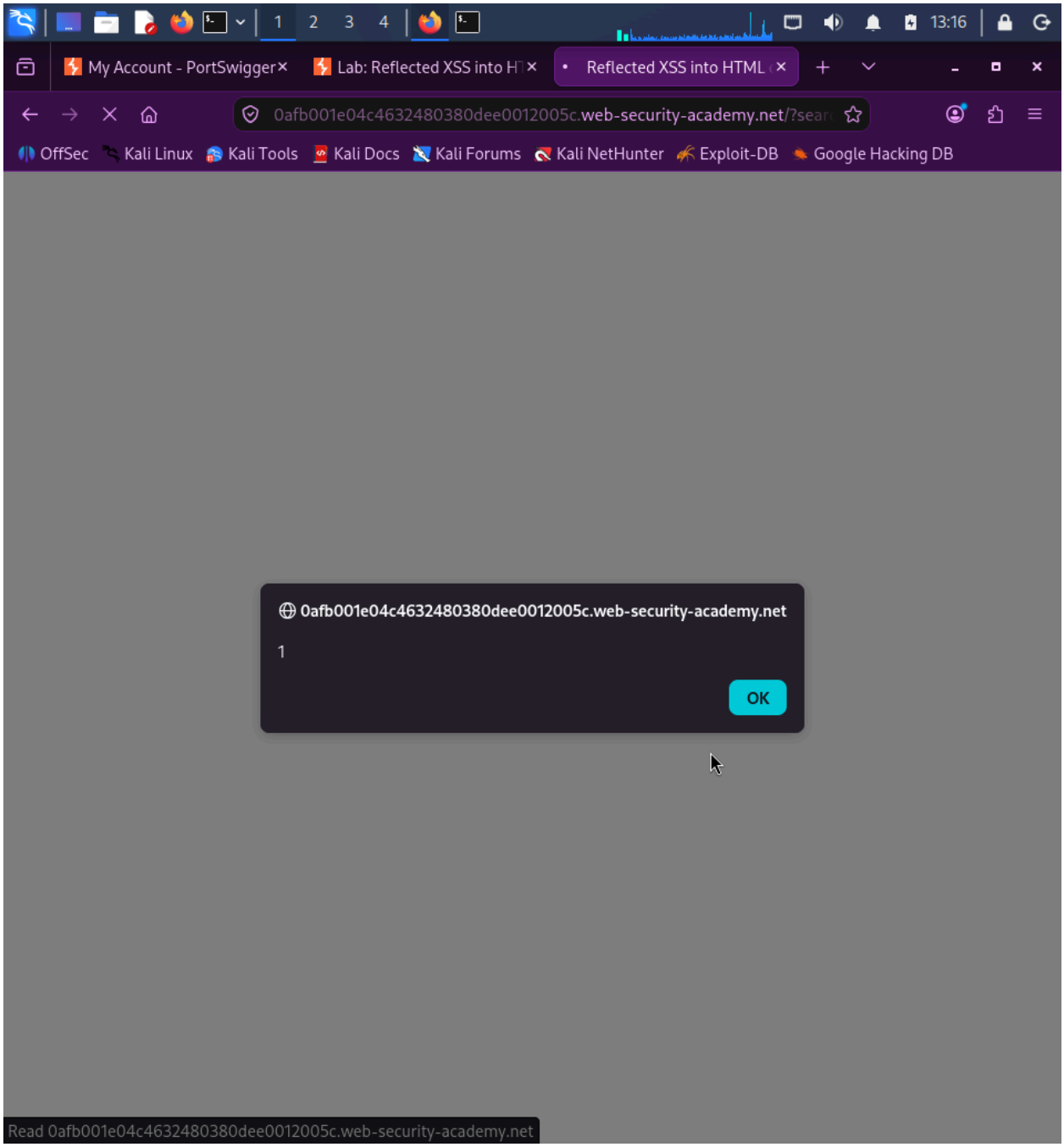
Congratulations, you solved the lab! Share your skills! Continue learning »

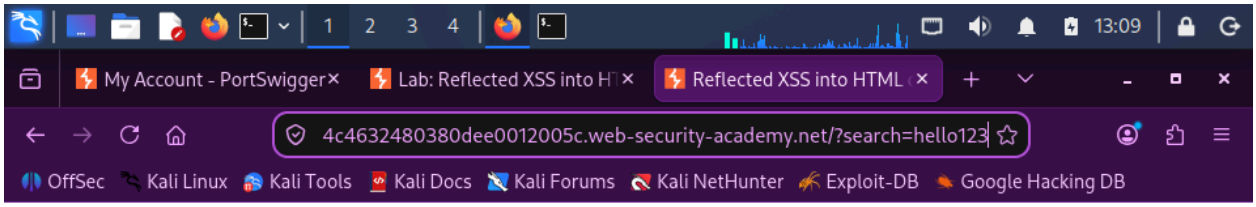
Home

0 search results for ''

Search the blog... Search

< Back to Blog


1 2 3 4
13:16
My Account - PortSwigger
Lab: Reflected XSS into HT
Reflected XSS into HTML
0afb001e04c4632480380dee0012005c.web-security-academy.net/?sear
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
0afb001e04c4632480380dee0012005c.web-security-academy.net
1
OK
Read 0afb001e04c4632480380dee0012005c.web-security-academy.net



Web Security Academy

Reflected XSS into HTML context with nothing encoded

LAB Not solved

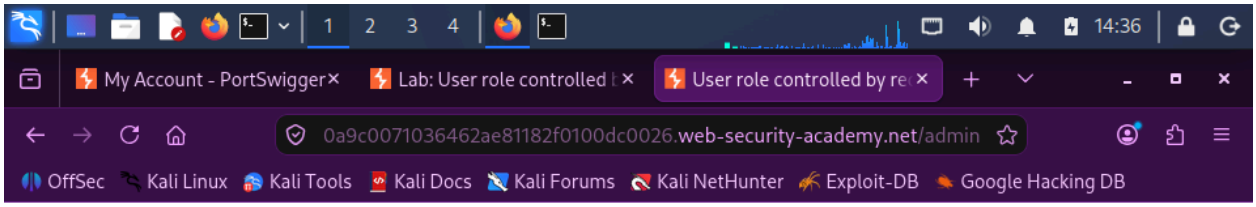
Back to lab description

Home

0 search results for 'hello123'

Search the blog... Search

< Back to Blog



Web Security Academy

User role controlled by request parameter

Back to lab description

LAB Solved

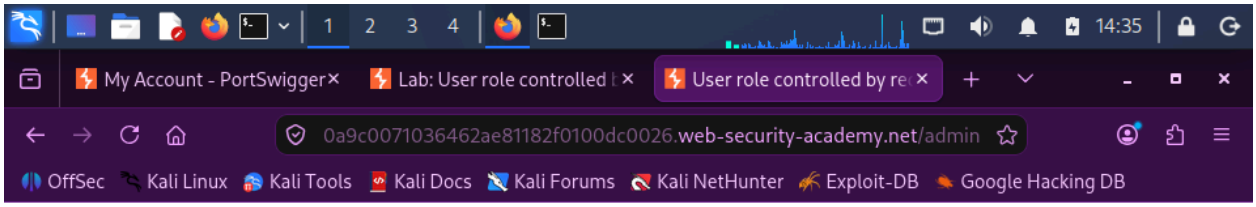
Congratulations, you solved the lab! Share your skills! Continue learning

Home | Admin panel | My account

User deleted successfully!

Users

wiener - Delete



Web Security Academy

User role controlled by request parameter

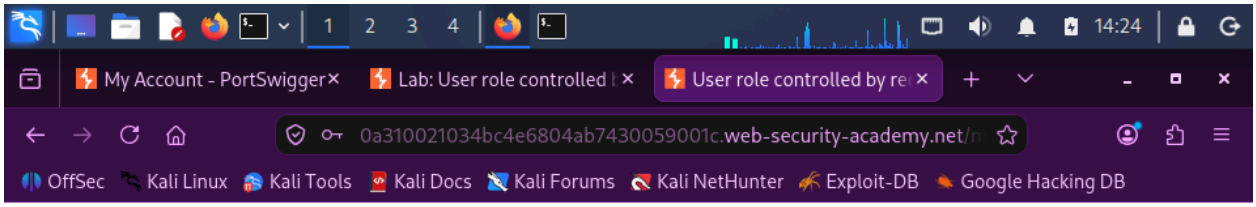
Back to lab description »

LAB Not solved

Home | Admin panel | My account

Users

wiener - Delete
carlos - Delete



Web Security Academy

User role controlled by request parameter

Back to lab description »

LAB Not solved

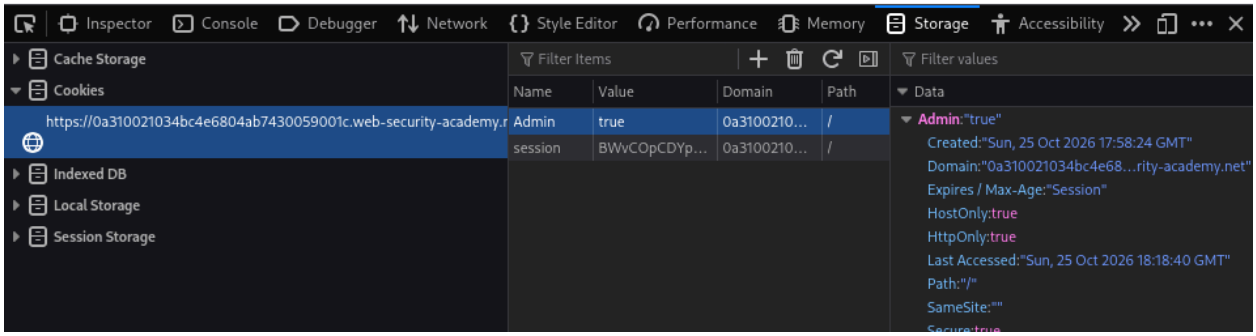
Home | My account | Log out

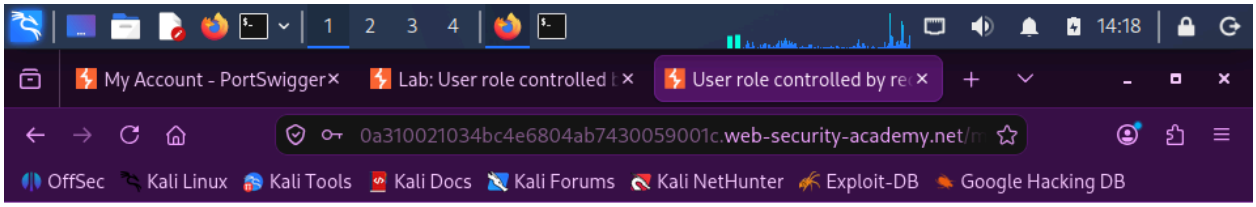
My Account

Your username is: wiener

Email

Update email





Web Security Academy

User role controlled by request parameter

Back to lab description »

LAB Not solved

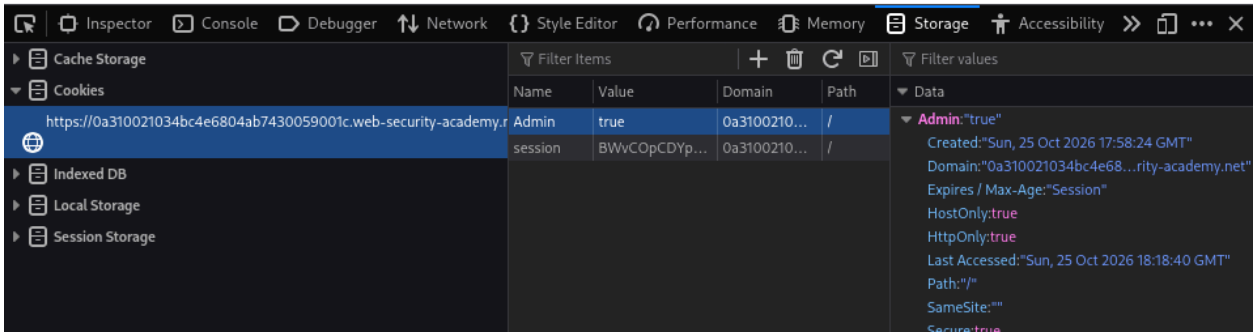
Home | My account | Log out

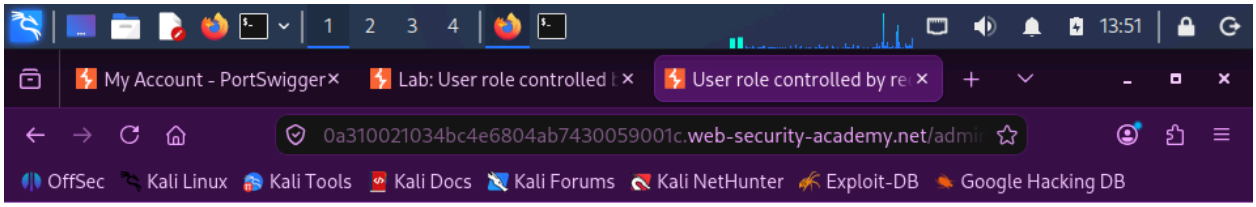
My Account

Your username is: wiener

Email

Update email





Web Security Academy

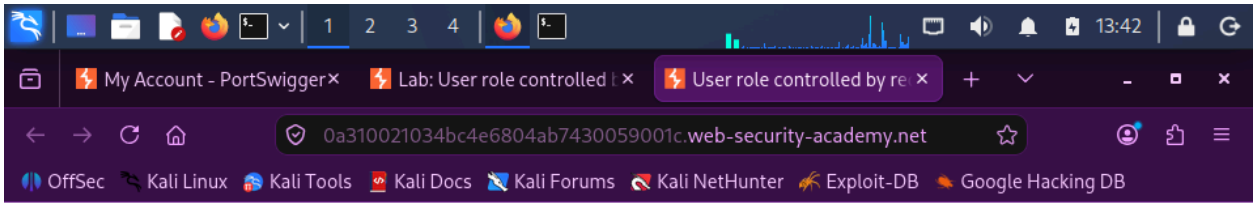
User role controlled by request parameter

Back to lab description »

LAB Not solved

Home | My account

Admin interface only available if logged in as an administrator



Web Security Academy

User role controlled by request parameter

Back to lab description »

LAB Not solved

Home | My account

WE LIKE TO SHOP

Potato Theater	Conversation Controlling Lemon	The Splash	Real Life Photoshopping
$75.35	$35.56	$64.14	$89.37
View details	View details	View details	View details

Overall Summary and Recommendations

1. Summary

This report documents six cybersecurity projects completed as part of the CyberSNova Cyber Security Internship for October 2026. The projects cover network reconnaissance and service enumeration, hidden directory and file enumeration, login traffic analysis, basic web vulnerability assessment, OWASP Juice Shop security testing, and PortSwigger Web Security Academy labs.

The projects demonstrate practical experience with tools and techniques including Nmap, WhatWeb, Netcat, curl, Gobuster, Dirsearch, Dirb, Wireshark, Nikto, browser developer tools, and Burp Suite Community Edition. The work includes command outputs, application responses, packet-capture evidence, screenshots, and technical reports.

Project 1: Network Reconnaissance and Service Enumeration

The assessment targeted `testphp.vulnweb.com`. DNS resolution succeeded and returned the IPv4 address `44.228.249.3`. However, the top-100 TCP port scan reported all 100 scanned ports as filtered, with no response. Separate checks for TCP ports 80 and 443 also reported filtered states. HTTP and HTTPS connection attempts, WhatWeb fingerprinting, and additional connection checks did not produce sufficient responses to identify accessible services or confirm the technologies used by the target.

Consequently, the available evidence documents the reconnaissance process and its connectivity limitations, but does not establish any open ports, confirmed service versions, or exploitable vulnerabilities.

Project 2: Hidden Directory and File Enumeration

The enumeration assessment used Gobuster, Dirsearch, and Dirb to investigate paths on `testasp.vulnweb.com`. The recorded results included several directory and application-path responses, including redirects and successful HTTP responses. Examples included `/cgi-bin/`, `/templates/`, `/images/`, `/avatars/`, `/jscripts/`, `/search.asp`, `/login.asp`, `/register.asp`, `/logout.asp`, and `/db.asp`.

These responses identify resources for further investigation, but a discovered path or HTTP status code alone does not prove that sensitive information is exposed or that access controls can be bypassed. Each potentially sensitive resource should be manually reviewed before it is classified as a confirmed security finding.

Project 3: Login Traffic Analysis

The traffic-analysis project used packet-capture evidence and network-analysis tools to examine traffic generated during web application interaction. The supplied evidence includes an HTTP POST request to `testasp.vulnweb.com`, with the request path `/Login.asp?RetURL=%2FDefault%2Easp%3F` and content type `application/x-www-form-urlencoded`.

This request demonstrates that an HTTP POST was captured during the recorded activity. However, the existence of a POST request alone does not establish that credentials were exposed. The actual request payload, the protocol used for the authentication exchange, and the relevant packet details must be examined before making a definitive conclusion about the protection of sensitive information.

Project 4: Basic Web Vulnerability Assessment

The basic web vulnerability assessment examined a local OWASP Juice Shop instance at `http://127.0.0.1:3000/` using HTTP response inspection, curl, Nikto, and an attempted Burp Suite workflow. The documented observations included missing recommended HTTP security headers, a publicly accessible `robots.txt` resource containing a path for further investigation, and additional paths flagged by the scanner for manual verification.

These observations provide useful security-review leads. Missing headers and scanner-generated path results should be interpreted in context and validated against the application's requirements and actual behaviour. Successful Burp Suite traffic interception and exploitation of additional vulnerabilities were not established by the available evidence.

Project 5: OWASP Juice Shop Security Assessment

The OWASP Juice Shop project examined application behaviour involving search functionality, authentication, basket operations, input handling, public information pages, and HTTP request inspection in a local training environment.

The strongest security signal documented in the supplied evidence was a browser alert displaying `xss` during the search-input investigation. This behaviour is consistent with JavaScript execution and warrants further validation of the precise execution path, reproducibility, and security impact. The report retains this as a provisional XSS finding rather than treating it as a fully verified exploit.

Four other investigation areas, involving access control, authentication, injection, and sensitive-information exposure, were not established as confirmed vulnerabilities by the supplied evidence. The current evidence therefore does not demonstrate five distinct, successfully exploited Juice Shop vulnerabilities. Additional authorized testing and supporting

screenshots are required to meet the internship task's requirement of at least five different vulnerabilities successfully exploited and documented.

Project 6: PortSwigger Web Security Academy Labs

The PortSwigger project documents five Apprentice-level lab exercises covering:

1. SQL injection in a `WHERE` clause.
2. SQL injection authentication bypass.
3. File path traversal.
4. Reflected cross-site scripting.
5. Broken access control involving a client-controlled role value.

The project report describes the vulnerability categories, testing approaches, and defensive lessons associated with these exercises. The supporting lab-completion screenshots should be checked against each lab's title and solved status to ensure that every exercise is traceable to its corresponding evidence.

Overall, the projects show experience with reconnaissance, enumeration, traffic inspection, automated scanning, manual web application testing, and structured security reporting. The conclusions remain limited to the tests performed and the evidence available for each project.

2. General Security Recommendations

Based on the project observations and the vulnerability categories investigated, the following defensive recommendations are appropriate:

1. **Validate findings before assigning severity.** Reproduce each suspected issue, record the exact test input and response, demonstrate the security impact, and assign severity according to the evidence and realistic exploitability.
2. **Protect authentication traffic.** Use HTTPS throughout authentication and authenticated sessions, configure TLS appropriately, and avoid transmitting passwords or other sensitive authentication data over unencrypted HTTP. Inspect the complete authentication exchange before concluding whether sensitive information was exposed.
3. **Apply secure input handling and output encoding.** Treat user-supplied input as untrusted. Validate it where appropriate and apply context-aware output encoding to prevent browsers from interpreting user-controlled content as executable HTML or JavaScript.
4. **Prevent SQL injection.** Use parameterized queries or prepared statements instead of constructing database queries by concatenating user input. Apply least-privilege permissions to database accounts and test input-handling controls after remediation.

5. **Enforce authorization on the server.** Verify the user's identity, permissions, and resource ownership for every protected operation. Do not rely on client-controlled parameters, interface restrictions, or hidden form fields to determine privileges.
6. **Restrict sensitive files and application paths.** Review directory enumeration results individually. Disable unnecessary directory listings, prevent public access to backups and configuration files, and ensure that administrative or sensitive resources require appropriate authorization.
7. **Configure HTTP security headers according to the application's needs.** Review Content Security Policy, Strict-Transport-Security, Referrer-Policy, and Permissions-Policy where applicable. Configure each header appropriately for the deployment rather than treating every missing header as an independently confirmed vulnerability.
8. **Review scanner results manually.** Tools such as Nikto and directory enumeration utilities can identify potential issues, but their output should be checked against the actual application response. Distinguish informational observations, potential weaknesses, false positives, and confirmed vulnerabilities.
9. **Maintain secure session management.** Protect session identifiers, use appropriate cookie attributes such as `Secure`, `HttpOnly`, and `SameSite` where applicable, and invalidate sessions properly during logout or other security-sensitive events.
10. **Retest after remediation.** Repeat the original test using the same relevant request or input, compare behaviour before and after the change, and retain evidence showing whether the issue has been resolved.
11. **Maintain traceable evidence.** Give every screenshot, packet capture, scan output, and relevant request a clear filename or evidence identifier. Link each finding to the specific evidence that supports its observation, impact, and conclusion.

3. Limitations

The conclusions in this report are limited to the targets, test cases, tool outputs, and evidence documented in the six project chapters.

For the network reconnaissance project, the recorded connection failures and filtered ports prevented reliable identification of accessible services. These results do not prove that all services were disabled or that the target was free of vulnerabilities.

For directory enumeration, HTTP status codes and discovered paths identify resources that may warrant review but do not, by themselves, establish sensitive information disclosure or unauthorized access.

For login traffic analysis, the captured HTTP POST request confirms that a request was observed, but a definitive conclusion about credential exposure requires examination of the relevant packet payload and authentication protocol.

For the basic web vulnerability assessment, scanner warnings and missing security headers must be interpreted in the context of the local application's configuration and validated before being classified as exploitable vulnerabilities.

For the OWASP Juice Shop assessment, the browser alert associated with the search-input investigation is a provisional indication of possible XSS. The available evidence does not establish four additional confirmed vulnerabilities, and therefore does not yet demonstrate completion of the requirement to exploit and document at least five different vulnerabilities.

For the PortSwigger project, the lab-completion screenshots and written explanations should be checked for accurate correspondence with all five lab exercises.

No conclusion should be interpreted as proof of the presence or absence of a vulnerability beyond what the documented tests demonstrate. Any finding that has not been reproduced and supported by sufficient evidence remains unconfirmed.

4. Conclusion

The six projects provide practical exposure to foundational and intermediate cybersecurity assessment activities, including network reconnaissance, web resource enumeration, packet inspection, automated security scanning, manual vulnerability testing, and security-focused analysis of web application behaviour.

The work emphasizes the importance of a structured methodology, appropriate authorization, reproducible testing, evidence collection, careful interpretation of tool output, and practical defensive recommendations. It also demonstrates why connection failures, scanner warnings, and individual application responses must not be overstated as confirmed vulnerabilities.

Before final submission, the report should undergo a final evidence and completeness review. This review should verify screenshot filenames and references, confirm that packet-analysis conclusions match the captured traffic, distinguish confirmed findings from unverified observations, and ensure that all required project criteria have been satisfied. In particular, the OWASP Juice Shop project requires additional validation and evidence of five distinct successfully exploited vulnerabilities before it can be described as meeting the stated intermediate-level requirement.

The report should be considered complete for submission only when its final claims are supported by the actual evidence and all required deliverables have been verified.